



Michael LANG · Hans LÖHR

IT-Sicherheit

Technologien und Best Practices
für die Umsetzung im Unternehmen

2. Auflage

HANSER

Lang/Löhr (Hrsg.)
IT-Sicherheit



Bleiben Sie auf dem Laufenden!

Der Hanser Computerbuch-Newsletter informiert Sie regelmäßig über neue Bücher und Termine aus den verschiedenen Bereichen der IT. Profitieren Sie auch von Gewinnspielen und exklusiven Leseproben. Gleich anmelden unter

www.hanser-fachbuch.de/newsletter

Herausgegeben von
Michael Lang und Hans Löhr

IT-Sicherheit

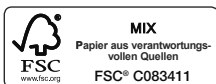
Technologien und Best Practices für die Umsetzung
im Unternehmen

2., überarbeitete Auflage

Mit Beiträgen von

Daniel Angermeier, Jürgen Großmann, Hans Höfken,
Thomas Jansen, Florian Jörgens, Stefan Karg, Nicolai Kuntze,
Ümit Kuşdoğan, Hagen Lauer, Thomas Lohre, Markus Nauroth,
Norbert Pohlmann, Markus Schmall, Marko Schuba,
Martin Serror, Christoph Skornia, Kristin Weber, Marcel Winandy

HANSER



Print-ISBN: 978-3-446-48082-7

E-Book-ISBN: 978-3-446-48116-9

E-Pub-ISBN: 978-3446-48323-1

Alle in diesem Werk enthaltenen Informationen, Verfahren und Darstellungen wurden zum Zeitpunkt der Veröffentlichung nach bestem Wissen zusammengestellt. Dennoch sind Fehler nicht ganz auszuschließen. Aus diesem Grund sind die im vorliegenden Werk enthaltenen Informationen für Autor:innen, Herausgeber:innen und Verlag mit keiner Verpflichtung oder Garantie irgendeiner Art verbunden. Autor:innen, Herausgeber:innen und Verlag übernehmen infolgedessen keine Verantwortung und werden keine daraus folgende oder sonstige Haftung übernehmen, die auf irgendeine Weise aus der Benutzung dieser Informationen – oder Teilen davon – entsteht. Ebenso wenig übernehmen Autor:innen, Herausgeber:innen und Verlag die Gewähr dafür, dass die beschriebenen Verfahren usw. frei von Schutzrechten Dritter sind. Die Wiedergabe von Gebrauchsnamen, Handelsnamen, Warenbezeichnungen usw. in diesem Werk berechtigt also auch ohne besondere Kennzeichnung nicht zu der Annahme, dass solche Namen im Sinne der Warenzeichen- und Markenschutz-Gesetzgebung als frei zu betrachten wären und daher von jedermann benützt werden dürften.

Die endgültige Entscheidung über die Eignung der Informationen für die vorgesehene Verwendung in einer bestimmten Anwendung liegt in der alleinigen Verantwortung des Nutzers.

Bibliografische Information der Deutschen Nationalbibliothek:

Die Deutsche Nationalbibliothek verzeichnet diese Publikation in der Deutschen Nationalbibliografie; detaillierte bibliografische Daten sind im Internet unter <http://dnb.d-nb.de> abrufbar.

Dieses Werk ist urheberrechtlich geschützt.

Alle Rechte, auch die der Übersetzung, des Nachdruckes und der Vervielfältigung des Werkes, oder Teilen daraus, vorbehalten. Kein Teil des Werkes darf ohne schriftliche Einwilligung des Verlages in irgendeiner Form (Fotokopie, Mikrofilm oder einem anderen Verfahren), auch nicht für Zwecke der Unterrichtsgestaltung – mit Ausnahme der in den §§ 53, 54 UrhG genannten Sonderfälle –, reproduziert oder unter Verwendung elektronischer Systeme verarbeitet, vervielfältigt oder verbreitet werden.

Wir behalten uns auch eine Nutzung des Werks für Zwecke des Text- und Data Mining nach § 44b UrhG ausdrücklich vor.

© 2025 Carl Hanser Verlag GmbH & Co. KG, München

www.hanser-fachbuch.de

Lektorat: Sylvia Hasselbach

Copy editing: Sandra Gottmann, Wasserburg

Coverkonzept: Marc Müller-Bremer, www.rebranding.de, München

Covergestaltung: Tom West

Titelmotiv: © stock.adobe.com/blackboard

Herstellung: Eberl & Koesel Studio, Kempten

Satz: le-tex publishing services GmbH, Leipzig

Druck: CPI Books GmbH, Leck

Printed in Germany

Inhalt

Vorwort	XV
1 IT-Sicherheit konsequent und effizient umsetzen	1
<i>Norbert Pohlmann</i>	
1.1 Einleitung	1
1.1.1 Chancen durch die Digitalisierung	1
1.1.2 Risiken durch die Digitalisierung	3
1.1.3 IT-Sicherheitsbedürfnisse als Grundwerte der IT-Sicherheit	3
1.2 Beispiele von aktuellen Angriffsvektoren	4
1.3 IT-Sicherheitsstrategien	8
1.3.1 Vermeiden von Angriffen	9
1.3.2 Entgegenwirken von Angriffen	11
1.3.3 Erkennen von Angriffen	13
1.3.4 Reaktion auf Angriffe	13
1.4 Umsetzung eines angemessenen IT-Sicherheitslevels	14
1.5 IT-Sicherheitsmechanismen, die gegen Angriffe wirken	16
1.6 Die wichtigsten Punkte in Kürze	25
2 Grundprinzipien zur Gewährleistung der IT-Sicherheit	27
<i>Hagen Lauer, Nicolai Kuntze</i>	
2.1 Einleitung	27
2.1.1 Trends	27
2.1.2 Herausforderungen	28
2.1.3 IT-Sicherheit vs. Sicherheit	30
2.1.4 Schutzziele	31

2.2	Grundprinzipien der IT-Sicherheit	37
2.2.1	Kenne die Bedrohungen	37
2.2.2	Sicherheit und Wirtschaftlichkeit	39
2.2.3	Keine „Security through Obscurity“	40
2.2.4	Security by Design	40
2.2.5	Prinzip der geringsten Berechtigung	42
2.2.6	Trennung der Verantwortlichkeiten	42
2.2.7	Zugriffskontrolle	43
2.2.8	Defense in Depth	44
2.2.9	Der Mensch als Faktor	45
2.2.10	Design for Resilience	46
3	Organisation des IT-Sicherheitsmanagements im Unternehmen	49
	<i>Markus Nauroth</i>	
3.1	Einführende Bemerkungen	50
3.2	Imperative des IT-Sicherheitsmanagements	51
3.2.1	Sicherheit ist aktiv und proaktiv	51
3.2.2	Routine	51
3.2.3	Sicherheit liegt in der Verantwortung eines jeden	51
3.2.4	Worst-Case-Szenario	52
3.2.5	Es bedarf vieler Unterstützer	52
3.2.6	Denken wie ein Angreifer	52
3.2.7	Mehrschichtige Verteidigung verwenden	52
3.3	Grundlegende Pfeiler einer IT-Sicherheitsorganisation	53
3.3.1	Gängige Organisationsstrukturen nach organisatorischem Reifegrad	54
3.3.1.1	Neugründung	54
3.3.1.2	Kleine und mittlere Unternehmen (KMU)	55
3.3.1.3	Großunternehmen	57
3.3.2	Das Information Technology Risk Council (ITRC)	58
3.3.2.1	ITRC-Vertreter	59
3.3.2.2	ITRC-Rollen und Zuständigkeiten	59
3.4	Die Rolle des CISO: Wie man eine Führungsrolle im Sicherheitsbereich gestaltet	61
3.4.1	Die richtige CISO-Rolle für Ihr Unternehmen entwerfen	61
3.4.1.1	Identifizieren der dringlichsten sicherheitsrelevanten Herausforderungen	62

3.4.1.2	Priorisierung der CISO-Rolle und -Verantwortlichkeiten . . .	62
3.4.1.3	CISO-RACI-Diagramm	64
3.4.1.4	Häufig vertretene CISO-Profile	64
3.5	Finale Anmerkungen	67
4	Rechtliche Rahmenbedingungen der IT-Sicherheit	69
	<i>Thomas Jansen</i>	
4.1	Einleitung	69
4.2	Vertrags- und haftungsrechtliche Risiken	70
4.2.1	Allgemeine Sorgfaltspflichten	70
4.2.2	Pflichten zur Gewährleistung der IT-Sicherheit	72
4.2.3	Haftung für Verstöße gegen IT-sicherheitsrechtliche Anforderungen	72
4.2.4	Anforderungen der DSGVO an technische und organisatorische Schutzmaßnahmen zum Schutz der IT-Sicherheit	74
4.2.5	Anforderungen des TKG und des TTDSG an technische und organisatorische Schutzmaßnahmen zum Schutz der IT-Sicherheit	75
4.2.6	Empfehlungen des BSI in Bezug auf technisch-organisatorische Maßnahmen	76
4.3	Straf- und ordnungswidrigkeitsrechtliche Folgen bei der Verletzung der IT-Sicherheit	77
4.3.1	Strafrechtliche Normen zum Schutz vor Cyberkriminalität	77
4.3.2	Strafrechtliche Verantwortlichkeit der einzelnen Akteure	79
4.4	Das IT-Sicherheitsgesetz (ITSiG 2.0)	80
4.5	Das NIS-2-Umsetzungs- und Cybersicherheitsstärkungsgesetz (NIS2UmsuCG)	83
4.6	Der Cyber Resilience Act	85
4.7	Der AI-Act	86
4.8	Die wichtigsten Punkte in Kürze	87
5	Standards und Zertifizierungen	91
	<i>Thomas Lohre</i>	
5.1	Einleitung	91
5.2	Standards	94
5.2.1	Synergien zwischen Standards auflösen und nutzen	103
5.2.2	Zertifizierung/Testierung	105
5.3	Kompetenznachweise für Beteiligte der Informationssicherheit	109
5.4	Die wichtigsten Punkte in Kürze	113

6	Datenschutz und Informationssicherheit: ungleiche Zwillinge	115
	<i>Stefan Karg</i>	
6.1	Einleitung	115
6.2	Rahmenbedingungen	117
6.2.1	Datenschutz	118
6.2.2	Managementsysteme	120
6.2.3	Das Standard-Datenschutzmodell (SDM)	120
6.3	Strategische/präventive Aspekte	122
6.3.1	Risikomanagement	122
6.3.2	Regelmäßige Überprüfung der Maßnahmen	123
6.3.3	Entwicklungsprozess	124
6.4	Operative Aspekte: technische und organisatorische Maßnahmen	126
6.4.1	Schutz der Vertraulichkeit	128
6.4.2	Schutz der Integrität	130
6.4.3	Schutz der Verfügbarkeit und Belastbarkeit	131
6.4.4	Vorfallsbehandlung (Incident Management)	131
6.5	Organisationsaspekte	133
6.6	Fazit	134
7	IT-Sicherheit durch Bedrohungs- und Risikoanalysen stärken	137
	<i>Daniel Angermeier</i>	
7.1	Einleitung	137
7.2	Nutzen und Mehrwert von Bedrohungs- und Risikoanalysen	138
7.3	Ablauf von Bedrohungs- und Risikoanalysen	140
7.4	Einbindung in Unternehmensprozesse	142
7.4.1	Anforderungsanalyse und Konzeptphase	142
7.4.2	Tests planen und priorisieren, Testergebnisse bewerten	148
7.4.3	Schwachstellen bewerten und behandeln	148
7.4.4	Laufende Systeme bewerten	149
7.5	Auswahlkriterien für geeignete Methoden	150
7.6	Die wichtigsten Punkte in Kürze	151
8	Sicherheitstesten	153
	<i>Jürgen Großmann</i>	
8.1	Sicherheitstesten – ein Grundverständnis	154
8.1.1	Testen als Analysemethode	154

8.1.2	Spezifische Herausforderungen beim Sicherheitstesten	156
8.1.3	Testobjekte beim Sicherheitstesten	157
8.1.4	Grundlagen und Ziele des Sicherheitstestens	159
8.1.5	Definition von Sicherheitstestzielen	160
8.2	Testmethoden und Testtechniken	161
8.2.1	Audits und Reviews	161
8.2.2	Statische Analyse	162
8.2.3	Der funktionale Sicherheitstest	163
8.2.4	Fuzz-Testing	164
8.2.5	Last- und Performanztesten	166
8.2.6	Schwachstellen-Scanning	166
8.2.7	Monitoring und passives Testen	167
8.2.8	Risikobasiertes Sicherheitstesten	168
8.2.9	Penetrationstesten	169
8.3	Prozessuale Einbettung des Sicherheitstestens	170
8.3.1	Der Sicherheitstestprozess	171
8.3.2	Sicherheitstesten im SDLC	172
8.3.3	Sicherheitstesten in agiler Entwicklung und DevOps	174
8.4	Chancen und Herausforderungen durch KI	176
8.4.1	KI-gestützte Automatisierung beim Sicherheitstest	176
8.4.2	Sicherheitstesten von KI	178
8.5	Zusammenfassung	179
9	Der Faktor Mensch	183
	<i>Kristin Weber</i>	
9.1	Der Mensch als Lösung	184
9.2	Der Mensch als Bedrohung	186
9.2.1	Sicheres und unsicheres Verhalten	187
9.2.2	Gründe für unsicheres Verhalten	189
9.3	Der Mensch als Opfer	192
9.3.1	Social Engineering	192
9.3.2	Instrumente im Social Engineering	193
9.3.3	Psychologische Tricks	196
9.4	Menschen sensibilisieren	200
9.4.1	Information Security Awareness	200

9.4.2	Psychologische Grundlagen von Awareness	203
9.4.3	Individualisierung	205
9.5	Awareness fördern	207
9.5.1	Wissen erhöhen und Fähigkeiten fördern	208
9.5.2	Verhaltensabsicht fördern und beeinflussen	211
9.5.3	Salienz fördern	218
9.5.4	Gewohnheiten fördern	220
9.6	Ausblick	223
9.7	Die wichtigsten Punkte in Kürze	225
10	IT-Sicherheit – Aus dem Blickwinkel eines CISO	229
	<i>Ümit Kuşdoğan</i>	
10.1	Einleitung	229
10.1.1	Das Wichtigste beim Start mit IT-Sicherheit	230
10.1.2	Strategien, Methoden und Tools	232
10.2	Organisatorische Verankerung	241
10.2.1	Rollen in der IT-Sicherheit	244
10.2.2	Kompetenzen in der IT-Sicherheit	245
10.3	Entscheidende Änderungen bei IT-Sicherheit	247
10.4	Besondere IT-Sicherheitsherausforderungen	248
10.5	Erfolge erzielen – Fehler vermeiden	248
10.5.1	Erfolgsfaktoren	249
10.5.2	Fehler, die zu vermeiden sind	249
10.5.3	Verbesserungspotenziale	250
10.5.4	Lessons Learned	250
10.5.5	Was könnte man anders machen?	251
10.6	Zusammenfassung	252
10.6.1	Hot Topics	253
10.6.2	Top-3-Ratschläge	254
11	Warum IT-Sicherheit zwischen Erfolg und Insolvenz entscheidet	257
	<i>Florian Jörgens</i>	
11.1	Das Wichtigste beim Start mit IT-Sicherheit	257
11.2	Organisatorische Verankerung	259
11.3	Verbesserungspotenzial	260

11.4	Entscheidende Änderungen bei IT-Sicherheit	261
11.5	Besondere IT-Sicherheitsherausforderungen in der eigenen Branche	262
11.6	Rolle des „IT-Sicherheitsverantwortlichen“	263
11.7	Kompetenzen der IT-Sicherheitsverantwortlichen sowie aller Beschäftigten	264
11.8	Top-3-Ratschläge	265
12	IT-Sicherheit heute und morgen – aus Sicht eines CISO	267
	<i>Markus Schmall</i>	
12.1	Das Wichtigste beim Start mit IT-Sicherheit	267
12.2	Aufnahme des IST-Zustands	269
	12.2.1 Verständnis der Angriffsvektoren/Angreiferlage	271
	12.2.2 Verständnis der Angriffspfade	272
12.3	Typische Fehler	273
12.4	Organisation	275
12.5	Erfolgsfaktoren	277
	12.5.1 Kommunikation	277
	12.5.2 Großes technisches Wissen	278
	12.5.3 Umfangreiches Wissen über Security bzw. die Angreiferlage	279
	12.5.4 Lösungsorientierung	279
	12.5.5 Doppelte Absicherung/Avoid Vendor Lock-in	280
	12.5.6 Betriebliche Nähe	280
12.6	Verbesserungspotenziale	281
12.7	Entscheidende Änderungen bei IT-Sicherheit	281
12.8	Besondere IT-Sicherheitsherausforderungen in der eigenen Branche	283
12.9	Hot Topics	284
12.10	Rolle des IT-Sicherheitsverantwortlichen	285
12.11	Lessons Learned	286
12.12	Kompetenzen eines erfolgreichen Sicherheitsverantwortlichen	287
12.13	Top-3-Ratschläge	288
12.14	Die wichtigsten Punkte in Kürze	289
13	Entwicklung sicherer Software	291
	<i>Nicolai Kuntze, Hagen Lauer</i>	
13.1	Einleitung	291
13.2	Vorgehensmodelle der Softwareentwicklung	293
13.3	Secure Development Lifecycles	295

13.4	Requirements Engineering	297
13.5	Architektur und Entwurf	298
13.6	Implementierung	299
13.7	Coding-Standards	300
13.8	Wahl der Programmiersprache	302
13.9	Tests	304
13.10	Code Reviews	304
13.11	Static Code Analysis	305
13.12	Formale Analyse	305
13.13	Validierung	306
13.14	Maintenance	307
13.15	Die wichtigsten Punkte in Kürze	308
14	Cybersicherheit in Produktion, Automotive und intelligenten Gebäuden	311
	<i>Marko Schuba, Hans Höfken</i>	
14.1	Einleitung	311
14.1.1	Automatisierungstechnik	312
14.1.2	Spezifische Anforderungen der Automatisierungstechnik	314
14.1.3	Spezifische Eigenschaften der Automatisierungstechnik	316
14.2	Schöne neue Welt – das Internet der Dinge	318
14.2.1	Internet der Dinge (IoT)	318
14.2.2	IoT-Chancen für die Automatisierungstechnik	319
14.2.3	IoT-Risiken für die Automatisierungstechnik	320
14.3	Was läuft schief?	320
14.3.1	Zu viel Vertrauen in andere	321
14.3.2	Zu wenig Management-Fokus	321
14.3.3	Sicherheits-Features zu teuer oder nicht genutzt	321
14.3.4	Es ist noch nie etwas passiert – und das bleibt auch so	322
14.3.5	Never change a running system	322
14.3.6	Sensibilisierung und Weiterbildung zu teuer/aufwendig	323
14.4	Was ist zu tun?	324
14.4.1	Cybersicherheit allgemein	324
14.4.2	Cybersicherheit in der Automatisierung	325
14.5	Praxisbeispiel: Einführung von Cybersicherheit in der Produktion (Orientierung an ISA/IEC 62 443)	328

14.5.1	Audit	329
14.5.2	Festlegen eines Sicherheitslevels	330
14.5.3	Risikobeurteilung	330
14.5.4	Defense in Depth	331
14.5.5	Zonierung	332
14.5.6	Patchmanagement	333
14.5.7	Dienstleister	335
14.6	Zusammenfassung und Fazit	336
15	Edge Computing: Chancen und Sicherheitsrisiken	339
	<i>Marcel Winandy</i>	
15.1	Einleitung	339
15.2	Was ist Edge Computing?	341
15.2.1	Das Internet der Dinge	341
15.2.2	Von der Cloud zur Edge	342
15.2.3	Impulsgeber für IoT Edge Computing	344
15.3	Chancen und Sicherheitsrisiken	345
15.3.1	Eröffnung neuer Möglichkeiten durch IoT Edge Computing	346
15.3.2	IoT Edge Computing bringt auch neue Sicherheitsrisiken	348
15.4	Entwicklung sicherer Edge-Computing-Plattformen	351
15.4.1	Security-by-Design-Prinzipien	351
15.4.2	Privacy-by-Design-Prinzipien	353
15.4.3	Spezielle Entwicklungsprinzipien für Edge Computing	354
15.5	Technologien für sichere Edge-Computing-Plattformen	356
15.5.1	Sicherheitskerne	356
15.5.2	Trusted Execution Environments und Confidential Computing	359
15.5.3	Kryptoagilität	359
15.6	Die wichtigsten Punkte in Kürze	361
16	Cybersicherheit für kritische Infrastrukturen (KRITIS)	363
	<i>Martin Serror</i>	
16.1	Einleitung	363
16.1.1	Technische Grundlagen	365
16.1.2	Regulierungen und Pflichten	366
16.1.3	Bedrohungen durch Cyberangriffe	369

16.2	Herausforderungen	371
16.2.1	IT/OT-Konvergenz.	371
16.2.2	„Safety first“	372
16.2.3	Mangelnde physische Sicherheit	373
16.2.4	Mangelnde Eigeninitiative	374
16.3	Cyberangriffe verstehen	375
16.3.1	Fähigkeiten des Angreifers.	375
16.3.2	Vorgehen und Ablauf.	377
16.4	Gegenmaßnahmen	380
16.4.1	Prävention	382
16.4.2	Detektion	385
16.4.3	Reaktion	387
16.5	Fazit	389
16.6	Die wichtigsten Punkte in Kürze	390
17	Sicherheit in der Cloud	393
	<i>Christoph Skornia</i>	
17.1	Einleitung	393
17.2	Nutzungsmodelle	394
17.2.1	Servicemodelle	394
17.2.2	Bereitstellungsmodelle	396
17.3	Risiken des Cloud-Computing	397
17.3.1	Überblick	397
17.3.2	Beispiele	399
17.4	Sicherheitsmaßnahmen	400
17.4.1	Sicherheitsrahmen	400
17.4.2	Zugangskontrolle	403
17.4.3	Datensicherheit	404
17.4.4	Monitoring und Überwachung	406
17.5	Zusammenfassung	409
17.6	Die wichtigsten Punkte in Kürze	409
	Herausgeber, Autorin und Autoren	411
	Index	419



Vorwort

Informationen sind das wertvollste Gut für Unternehmen. Die zur Informationsverarbeitung eingesetzten IT-Systeme sind heutzutage zentraler Bestandteil jedes Unternehmens und bilden die Grundlage für nahezu alle Geschäftsprozesse. Ohne sie funktioniert fast nichts mehr.

Kommt es zu Störungen in der IT, kann dies im schlimmsten Fall das komplette Unternehmen zum Stillstand bringen und existenzbedrohend sein. Gleiches gilt, wenn Informationen des Unternehmens oder dessen Kunden verloren gehen, gestohlen werden, manipuliert werden oder nicht mehr verarbeitet werden können.

Daher ist es für Unternehmen existenziell bedeutend, die Sicherheit der Informationen, Systeme und Produkte zu gewährleisten. Dies trifft heute mehr denn je zu, denn mit zunehmender Vernetzung wächst auch die Angriffsfläche: Jedes vernetzte Gerät ist ein potenzielles Einfallstor für Gefährdungen, und das erhöht das Risiko zusätzlich.

Doch wie können Sie Ihr Unternehmen vor diesen Gefährdungen schützen und Sicherheit gewährleisten?

Die Antwort auf diese Frage – und viele hilfreiche Impulse und Best Practices zur Umsetzung – erhalten Sie in diesem Buch.

Wir freuen uns, dass dazu 18 ausgewiesene Experten/Expertinnen als Autoren/Autorinnen an diesem Buch mitgewirkt haben, um Ihnen die relevanten Aspekte zur IT-Sicherheit von Unternehmen zu beschreiben.

Mit diesem Buch erhalten Sie nicht nur 14 Fachartikel zu den relevanten Aspekten von IT-Sicherheit, sondern zusätzlich auch Erfahrungsberichte von drei erfahrenen Chief Information Security Officer mit konkreten praxisrelevanten Tipps zur Umsetzung von IT-Sicherheit.

Wir wünschen Ihnen viel Spaß beim Lesen der zweiten Auflage des Buches „IT-Sicherheit“ und – einmal mehr – viel Erfolg beim Umsetzen der dabei gewonnenen Erkenntnisse!

Ihre Herausgeber

Michael Lang und Hans Löhr

1

IT-Sicherheit konsequent und effizient umsetzen

Norbert Pohlmann



In diesem Beitrag erfahren Sie,

- welche Chancen und Risiken die fortschreitende Digitalisierung mit sich bringt,
- welche Angriffsvektoren heute für erfolgreiche Angriffe genutzt werden,
- welche IT-Sicherheitsstrategien helfen Risiken zu reduzieren und mit verbleibenden Risiken umzugehen und
- welche IT-Sicherheitsmechanismen, gegen welche Angriffe wirken.

1.1 Einleitung

Wir befinden uns gerade in einer digitalen Transformation, die mit einer radikalen Umgestaltung unseres Alltags und unserer Arbeitswelt sowie aller Geschäftsmodelle und Verwaltungsprozesse einhergeht. Wirtschaftskraft und Wohlstand sowie die Leistungsfähigkeit unserer modernen Gesellschaft werden durch den gelungenen digitalen Wandel bestimmt.

1.1.1 Chancen durch die Digitalisierung

Die Digitalisierung eröffnet über alle Branchen und Unternehmensgrößen hinweg enorme Wachstumschancen und führt zu immer besseren Prozessen, die die Effizienz steigern und Kosten reduzieren. Die Digitalisierung beschleunigt auf allen Ebenen und der Wertschöpfungsanteil der IT in allen Produkten und Lösungen wird immer größer (Pohlmann 2020), siehe Bild 1.1, obere Kurve.

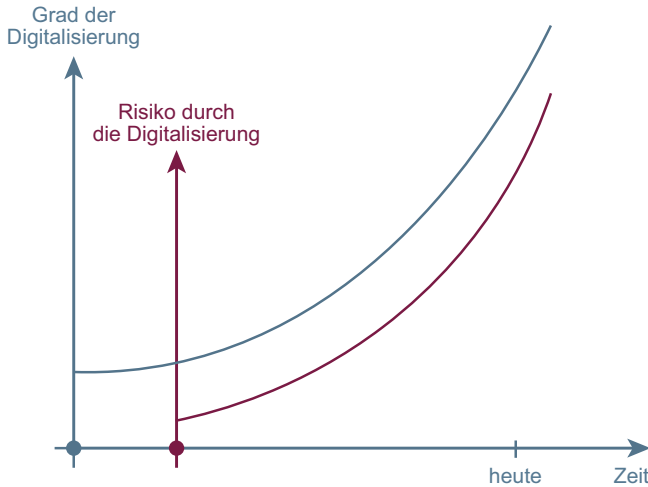


Bild 1.1 Entwicklung der Digitalisierung und des korrespondierenden Risikos

Mögliche Erfolgsfaktoren der Digitalisierung sind vielfältig:

- Mit 5G- und Glasfasernetzen erhöhen sich Kommunikationsgeschwindigkeit und -qualität, wodurch neue Anwendungen möglich werden.
- Smarte Endgeräte wie Smartwatches, Smartphones, PADs oder IoT-Geräte bringen viele neue sinnvolle Anwendungen mit sich.
- Zunehmend leistungsfähige zentrale IT-Systeme wie Cloudsysteme, Edge-Computing oder Hyperscaler schaffen Innovationen mit großen Potenzialen.
- Da immer mehr Daten zur Verfügung stehen, ist die Verwendung von KI (ML ...) ein weiterer Treiber von neuen Geschäftsmodellen (Pohlmann 2019a).
- Moderne Benutzerschnittstellen, wie Sprache und Gestik, vereinfachen die Bedienung der smarten Endgeräte.
- Die Optimierung von Prozessen schafft ein enormes Rationalisierungspotenzial, das es zu heben gilt, um wettbewerbsfähig zu bleiben und Wachstumschancen zu nutzen.
- Neue Optionen wie Video-Konferenzen, Cloudanwendungen ermöglichen im Home-office zu arbeiten und damit die Personenmobilität zu reduzieren sowie letztendlich die Umwelt zu schonen.

1.1.2 Risiken durch die Digitalisierung

Wir müssen aber auch feststellen, dass seit Beginn der IT – sowie jetzt mit der zunehmenden Digitalisierung – die IT-Sicherheitsprobleme jedes Jahr größer werden und auf absehbare Zeit definitiv nicht abnehmen. Eine wichtige Erkenntnis ist, dass die heutigen IT-Architekturen unserer Endgeräte, Server, Netzkomponenten und zentralen IT-Dienstleistungen nicht sicher genug konzipiert und aufgebaut sind, um den Angriffen intelligenter Hacker erfolgreich entgegenzuwirken. Die Vielzahl der lokalen und zentralen Anwendungen, die unterschiedlichen Zugänge zum Internet, die Masse der IT-Systeme und IT-Infrastrukturen sowie die zunehmenden Abhängigkeiten innerhalb der Supply Chain machen die Komplexität der IT immer größer und damit auch die Anfälligkeit für bösartige Angriffe. Täglich können wir den Medien entnehmen, wie sich kriminelle Hacker die unzureichende Qualität der Software zu Nutze machen, indem sie Malware installieren und damit Passwörter sowie Identitäten stehlen, Endgeräte ausspionieren oder die IT-Systeme verschlüsseln, um Lösegeld für die notwendigen Schlüssel zur Entsperrung zu erpressen. Aufgrund der generierten Datenmengen werden die Angriffsziele mit fortschreitender Digitalisierung kontinuierlich lukrativer.

Die Robustheit und Resilienz unserer IT-Systeme sind nicht hinreichend und der Level an IT-Sicherheit entspricht nicht dem „Stand der Technik“. Mit dem höheren Grad an Digitalisierung steigt momentan das Risiko eines Schadensfalls, siehe Bild 1.1, untere Kurve. Daraus ergibt sich in der Konsequenz, dass durch Diebstahl, Spionage und Sabotage der deutschen Wirtschaft jährlich ein Gesamtschaden von mehr als 220 Milliarden Euro entsteht.

1.1.3 IT-Sicherheitsbedürfnisse als Grundwerte der IT-Sicherheit

IT-Sicherheitsbedürfnisse sind Grundwerte der IT-Sicherheit, die mithilfe von IT-Sicherheitsmechanismen befriedigt werden können. IT-Sicherheitsbedürfnisse werden auch als IT-Sicherheitsziele bezeichnet.

- **Gewährleistung der Vertraulichkeit**

Vertraulichkeit ist wichtig, damit keine unautorisierten Personen oder Organisationen in der Lage sind, übertragene oder gespeicherte Informationen zu lesen.

- **Gewährleistung der Authentifikation**

Mithilfe des IT-Sicherheitsmechanismus Authentifikation wird verifiziert, wer der Partner bei der Kommunikation oder Transaktion ist beziehungsweise welcher Nutzer auf Betriebsmittel und Informationen zugreift.

- **Gewährleistung der Authentizität**

Mithilfe des IT-Sicherheitsmechanismus Authentizität wird verifiziert, dass Informationen oder Identitäten echt sind.

- **Gewährleistung der Integrität**

Beim IT-Sicherheitsbedürfnis „Gewährleistung der Integrität“ wird überprüft, ob Informationen, die übertragen werden oder gespeichert sind, unverändert, d. h. original, sind.

- **Gewährleistung der Verbindlichkeit**

Das IT-Sicherheitsbedürfnis „Gewährleistung der Verbindlichkeit“ sorgt für die Gewissheit, dass die Prozesse und die damit verbundenen Aktionen auch verbindlich sind.

- **Gewährleistung der Verfügbarkeit**

Dieses IT-Sicherheitsbedürfnis sorgt für die Gewissheit, dass die Informationen und Dienste auch zur Verfügung stehen.

- **Gewährleistung der Anonymisierung/Pseudonymisierung**

Mit diesem IT-Sicherheitsbedürfnis wird gewährleistet, dass eine Person nicht oder nicht unmittelbar identifiziert werden kann.

1.2 Beispiele von aktuellen Angriffsvektoren

Im Folgenden werden exemplarisch relevante Beispiele von Angriffsvektoren mit den entsprechenden Angriffstechniken und Angriffswege dargestellt.

1. Malware-Infiltration über manipulierte Webseiten

Als erstes wird mit einem gezielten Hacking-Angriff auf den Webserver die Platzierung von Angriffssoftware zur Durchführung eines Drive-by-Downloads unter Nutzung einer vorhandenen Schwachstelle auf dem Webserver umgesetzt. Um einen Nutzer (Opfer) zum Besuch der manipulierten Webseite zu motivieren kann beispielsweise ein Phishing-/Social-Engineering-Angriff durchgeführt werden. Beim Zugriff auf die manipulierten Webseiten werden dann beim Drive-by-Download Sicherheitslücken des Browsers oder des Betriebssystems des Opfer-IT-Systems des Nutzers ausgenutzt, um Malware zu installieren. Mit der generalisierten installierten Malware kann dann der Angreifer spezielle Schadfunktionen nutzen, um das gekaperte IT-System gemäß seinem Ziel zu manipulieren.

2. Malware-Infiltration über schadhafte E-Mail-Anhänge

Mithilfe von Sozialen- und Berufsnetzwerken werden die Vorlieben eines potenziellen Opfers analysiert. Mit diesen Kenntnissen wird dem Opfer eine persönliche

Nachricht gesendet, die perfekt dazu verleitet, auf den Anhang der E-Mail zu klicken. Durch das Klicken wird ein Prozess ausgelöst, der ermöglicht, über vorhandene Schwachstellen eine Malware zu installieren. Damit ist die Übernahme der Kontrolle über das betroffene Opfer-IT-System umgesetzt. Anschließend nutzt der Angreifer entsprechende Schadfunktionen, um seine Ziele auf dem Opfer-IT-System umzusetzen.

3. Mehrstufiger Angriff auf die IT-Infrastruktur von Unternehmen

Ein Angreifer verschafft sich einen ersten Zugang auf ein IT-System in einem Unternehmen, wie in den Beispielen 1 und 2 beschrieben. Dann sorgt der Angreifer mit der Schaffung einer individualisierten Malware dafür, dass er den Zugang etabliert, um sich im IT-System frei bewegen zu können und seine Spuren zu verwischen. Anschließend verschafft sich der Angreifer mit zusätzlichen Angriffstechniken mehr Administrationsrechte. Damit kann er die Kontrolle über weitere IT-Systeme bekommen und lateral in große Teile des Netzwerks gelangen. So sammelt der Angreifer umfangreiches Wissen über vorhandene Schwachstellen, Funktionen oder Werte auf den IT-Systemen des Unternehmens und kann darüber eine Strategie für den eigentlichen Angriff entwickeln und erfolgreich umsetzen. Diese Vorgehensweise wird auch als Advanced Persistent Threat (APT) bezeichnet.

4. Man-in-the-Middle-Angriff (MITM)

Bei der Man-in-the-Middle-Angriffsmethode schleust sich ein Angreifer aktiv, aber heimlich – physisch oder logisch – in die Kommunikation zwischen mindestens zwei Kommunikationspartnern, mit dem Ziel Daten lesen oder manipulieren zu können. Die Kommunikationspartner bemerken diesen Eingriff nicht und gehen davon aus, dass sie direkt und vertraulich miteinander kommunizieren, da sich der Angreifer bei beiden Kommunikationspartnern jeweils als das wahrgenommene Gegenüber ausgibt. Durch einen Man-in-the-Middle-Angriff ist es möglich Passwörter oder weitere wichtige Daten mitzulesen, Kommunikationsverbindungen zum Beispiel nach einer Authentifikation zu übernehmen oder Daten zu manipulieren.

5. Angriff mithilfe eines Software-Updates (Supply Chain-Angriff)

Bei einem Supply Chain-Angriff oder Lieferketten-Angriff ist die prinzipielle Idee, dass ein vertrauenswürdiger Dienst (Software), der seit längerer Zeit bei einer Organisation/einem Unternehmen in Einsatz ist, irgendwann für einen Angriff verwendet wird. Als Angriffsvektor missbraucht der Angreifer ein legitimes Software-Update, das der vertrauenswürdige Softwarehersteller (Supplier) zur Verfügung stellt. Für die Durchführung dringt der Angreifer zuerst in das IT-System des vertrauenswürdigen Softwareherstellers ein und infiltrierte ein Software-Update mit Malware. Voraussetzung für den eigentlichen Angriff ist, dass dieser Vorgang unbemerkt bleibt, daher muss er an einer bestimmten Prozess-

stelle umgesetzt werden. Nur so lässt sich sicherstellen, dass das manipulierte Software-Update offiziell als Hersteller-Update digital signiert wird, wodurch es mit einem autorisierten Code versehen ist und dadurch vom Kunden akzeptiert und eingespielt werden kann. Darauf basierend ist es dem Angreifer möglich bei mehreren Tausend Organisationen gleichzeitig das Software-Update des Herstellers nutzen, um die eigentlichen Angriffe umzusetzen. Beispiele dieser Angriffsmethode sind: Kaseya und SolarWinds.

6. Angriff auf die Verfügbarkeit von IT-Systemen (DDoS-Angriff)

Der Angreifer nutzt die Schwachstelle aus, dass IT-Systeme nur begrenzte Ressourcen (Bandbreite, CPU, RAM ...) haben. Für den Angriff wird das IT-System gezielt mit einer großen Last spezieller Anfragen überflutet, dadurch überlastet und letztendlich lahmgelegt. Dies wird in der Regel unter Einsatz von Botnetzen, bei denen die Bots die Schadfunktion DDoS aktiviert haben, und weiteren Verstärkungsmechanismen wie Reflection und Amplification, erfolgreich umgesetzt. Die Motivation der Angreifer ist vielfältig: Entweder soll ein IT-System für eine definierte Zeit lahmgelegt werden, um beispielsweise einen Wettbewerber zu behindern oder es steckt eine erpresserische Absicht dahinter, um von dem angegriffenen Unternehmen eine bestimmte Summe verlangen zu können, damit der DDoS-Angriff gestoppt oder gar nicht erst durchgeführt wird.

7. Missbräuchliche Ausnutzung einer Business-Beziehung mit einem High-Level-Phishing Angriff

Ein Angreifer erlangt mithilfe eines Malware-Keyloggers den Zugang zu einem E-Mail-Konto im Unternehmen. In der Vorbereitungsphase analysiert der Angreifer kontinuierlich die E-Mails des angegriffenen Mitarbeiters dahingehend, welche Informationen für einen Angriff verwendbar sind. Das kann zum Beispiel eine hohe Rechnung an einen langfristigen Kunden sein. Sobald diese über das E-Mail-Konto versendet wird, beginnt der Angriff. Im ersten Schritt wird dafür diese E-Mail zusammen mit allen alten Inhalten kopiert, im zweiten Schritt dann in der PDF-Rechnung die Kontonummer verändert. Nach einer sehr kurzen Zeitspanne erfolgt dann der Versand dieser E-Mail zusammen mit einer E-Mail, in der der Angreifer nachfragt, ob die Rechnung bereits beglichen wurde. Der Zeitpunkt muss so gewählt sein, dass es sehr unwahrscheinlich ist, dass eine Bezahlung bereits stattgefunden hat. Denn nur so ist es möglich das angegriffene Unternehmen dazu aufzufordern die Rechnung an eine neue Kontonummer zu überweisen, zum Beispiel mit der Begründung, dies sei aufgrund aktueller Sicherheitsvorkehrungen notwendig geworden. Wichtig ist, diese E-Mail wird seitens des Angreifers von einem anderen E-Mail-Konto versendet, damit der Mitarbeiter – dessen E-Mail-Account kompromittiert wurde – den Vorgang nicht mitbekommt. Trotzdem ist bei dieser E-Mail der eigentliche Mitarbeiter als Absender angegeben (Mail-Spoofing).

Als Return-Pfad im E-Mail-Header ist jedoch eine andere E-Mail-Adresse angegeben, damit, falls der Empfänger eine Nachfrage hat, diese nicht bei dem Mitarbeiter des (angegriffenen) Unternehmens ankommt, denn es ist in diesem Szenario zwingend notwendig, dass der Angreifer diese (eventuelle) E-Mail erhält, damit er entsprechend reagieren kann.

Dass der Empfänger glaubt, die E-Mail kommt von der altbekannten Kundenbeziehung lässt sich dadurch erreichen, indem die Absenderadresse dieselbe ist und Fragmente älterer E-Mail integriert sind. Durch diese umfangreiche Vorarbeit ist sichergestellt, dass das angegriffene Unternehmen den geforderten Betrag auf das neue Konto überweist. Aufgrund längerer Zahlungsziele, zum Beispiel von sechs Wochen fällt den beteiligten Unternehmen nicht rechtzeitig auf, dass sie einem Phishing-Angriff ausgesetzt waren. Daher ist die Verfolgung des Vorfalls sehr schwer bis unmöglich.

8. Nutzung von homografischen Domänen für einen Angriff

Eine Ergänzung zum Angriffsvektor 7 im Business-Bereich ist, dass der Angreifer eine ähnliche Domäne, eine sogenannte homografische Domäne eines Unternehmens registriert, um diese für einen Angriff zu nutzen. Dies ist möglich, da die homografische Domäne Zeichen enthält, die der den Buchstaben der originalen Domäne ähnlich sind: Etwa die Ziffer 0, die dem Buchstaben O ähnelt oder der Buchstaben l (kleines L) und I (großes i). Beispiel für eine homografische Domäne: internet-sicherheit.de – im Original mit einem i am Anfang –, manipuliert mit einem kleingeschriebenen L also Internet-sicherheit.de.

Der Angreifer kann diese Domäne für einen E-Mail-Dienst nutzen, um sich so fälschlicherweise als das eigentliche Unternehmen auszugeben, da der Empfänger die Täuschung mit hoher Wahrscheinlichkeit nicht bemerkt. Dadurch ist es dem Angreifer möglich, mit einer beliebigen falschen E-Mail-Adresse eine Kommunikationsbeziehung mit einem Mitarbeiter eines beliebigen Kunden von dem anvisierten Unternehmen aufzubauen, denn Kommunikationsinhalte sowie die richtigen Kommunikationspartner lassen sich leicht und strukturiert über Webseiten, Social Media-Kanäle sowie Businessnetzwerke ermitteln. So ist es möglich einen hohen Schaden anzurichten, beispielsweise bezüglich der Reputation: Aufkündigung von Verträgen oder Veränderung von Konditionen zuungunsten des Unternehmens.

9. Die Geschichte eines erfolgreichen APT-Angriffs

Ein Steuerberater erhält per E-Mail die Mitteilung, dass über einen längeren Zeitraum eine Kopie seiner kompletten Mandantenkartei angefertigt wurde. In der gleichen E-Mail fordert der Angreifer den Steuerberater auf, 100000 Euro zu zahlen, da er ansonsten den gesamten Datenbestand veröffentlichen würde. Zum Beweis, dass der Steuerberater nicht kontinuierlich zahlen müsse, übersendet der

Angreifer, als Zeichen seiner Vertrauenswürdigkeit, eine Referenzliste. In dieser waren die Kontaktdaten derjenigen Steuerbüros aufgeführt, die aufgrund der Zahlung tatsächlich eine Veröffentlichung dauerhaft abgewendet haben. Interessant ist in diesem Fall auch die Frage bezüglich der Höhe des geforderten Betrags – also warum nicht 50 000 oder 250 000 Euro? Die Erklärung dafür lieferten im Weiteren die Experten, die der Steuerberater zur Hilfe holte. Diese fanden heraus, dass der Angreifer sich tief in die IT des Steuerberaters eingenistet hatte. Das ließ den Schluss zu, dass es sich nicht um Freizeit-Hacker handelte, sondern ein Profi mit einem langfristigen „Geschäftsmodell“ am Werk war, der die Lösegeldzahlung als einmalige und deshalb für die Opfer lohnenswerte Investition sieht. Zur Ermittlung der Summe hatte der Angreifer jahrelang jede digitale Bewegung beobachtet, geduldig die betriebswirtschaftliche Entwicklung des Steuerbüros verfolgt und dann zugeschlagen als das Geschäft für ihn einträglich, aber gleichzeitig für den Steuerberater wirtschaftlich verkraftbar war.

1.3 IT-Sicherheitsstrategien

Durch die steigende Digitalisierung wird das Risiko eines Schadens immer größer (Bild 1.2, linke Kurve), weil dadurch nicht nur die Angriffsziele kontinuierlich lukrativer werden, sondern auch die Angriffsfläche zunehmend größer wird. Um diese Situation im Sinne der Unternehmen zu verbessern, werden grundsätzliche IT-Sicherheitsstrategien benötigt, die die IT-Sicherheitsrisiken strategisch reduzieren (Bild 1.2, gestrichelte Kurve).

■ IT-Sicherheitsstrategien zur Reduzierung der Risiken

Die IT-Sicherheitsstrategien „Vermeiden von Angriffen“ und „Entgegenwirken von Angriffen“ helfen, den Level an verbleibenden Risiken so weit wie möglich zu verringern und zu halten. Die verbleibenden Risiken beschreiben die noch vorhandene Eintrittswahrscheinlichkeit eines Schadens, der trotz durchgeführter IT-Sicherheitsmaßnahmen zur Reduzierung der Risiken in Unternehmen auftreten kann, weil es keine hundertprozentige IT-Sicherheit gibt.

■ IT-Sicherheitsstrategien, um mit verbleibenden Risiken umzugehen

Da mit dem Einsatz der IT-Sicherheitsstrategien zur Reduzierung der Risiken keine hundertprozentige IT-Sicherheit erzielt werden kann, müssen weitere IT-Sicherheitsstrategien für die verbleibenden Risiken angewendet werden. Hier helfen die zwei IT-Sicherheitsstrategien „Erkennen von Angriffen“ und „Reagieren auf Angriffe“.

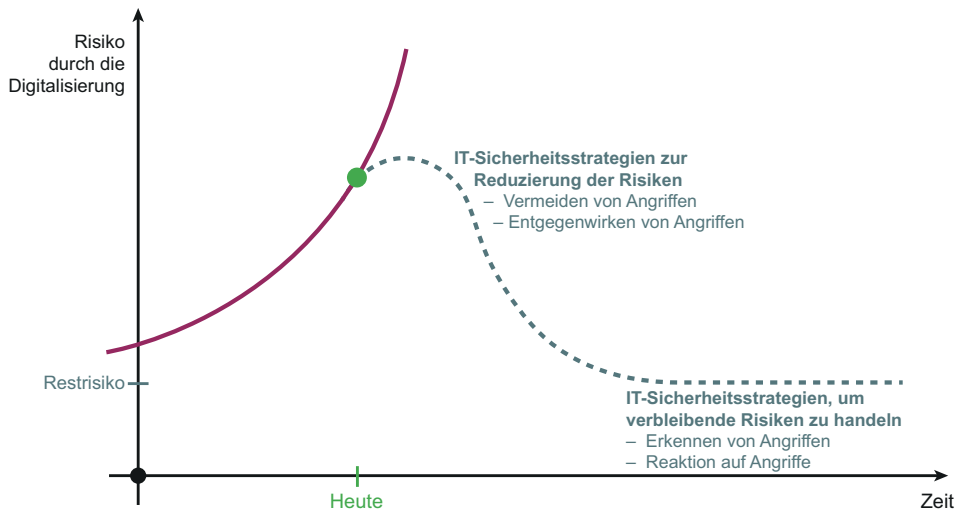


Bild 1.2 IT-Sicherheitsstrategien, um die Risiken der Digitalisierung zu managen

Im Folgenden werden die vier prinzipielle IT-Sicherheitsstrategien beschrieben, die helfen können, IT-Sicherheitsmechanismen in strategische Ziele einzuteilen, um die Risiken der Digitalisierung zu managen. So können deren Wirkung auf Angriffe und den Schutz der Werte besser verstanden und geeignete IT-Sicherheitsstrategien ausgesucht sowie umgesetzt werden.

1.3.1 Vermeiden von Angriffen

Eine generelle IT-Sicherheitsstrategie zum Schutz der Werte eines Unternehmens ist die Idee, einen Schaden durch Angriffe zu vermeiden – die sogenannte Vermeidungsstrategie. Durch diese Vorgehensweise wird eine Reduzierung der Angriffsfläche und damit die Reduzierung der Risiken erreicht. Die Herausforderung besteht darin, die IT so einzurichten, dass das Unternehmen alles wirklich Notwendige für das Business umsetzen kann, aber alles andere aktiv vermieden wird.

Im Folgenden werden unterschiedliche Prinzipien der Vermeidung von erfolgreichen Angriffen aufgezeigt:

1. Prinzip der Datensparsamkeit

Ein Aspekt der Vermeidungsstrategie ist das Prinzip der Datensparsamkeit, d. h., so wenig wertvolle Daten generieren wie möglich und nur so viele wie nötig. Das Prinzip: Daten, die nicht auf IT-Systemen vorhanden sind, können nicht angegriffen werden. Daher sollten nur Daten gespeichert werden, die wirklich notwendig

sind. Abgeleitete Daten, Zusammenfassungen und so weiter sollten nicht permanent erfasst, sondern bei Bedarf automatisiert neu berechnet werden.

2. Nur sichere IT-Technologien, -Produkte und -Dienste verwenden

Ein weiteres Prinzip der IT-Sicherheitsstrategie Vermeiden von Angriffen ist: „Keine Technologien, Produkte und Dienste mit bekannten Schwachstellen verwenden“. Dazu müssen natürlich die entsprechenden Schwachstellen bekannt sein, damit ihnen begegnet werden kann. Beispiele von IT-Lösungen, bei denen dieses Prinzip umgesetzt werden kann, sind Browser, Betriebssysteme und Internet-Dienste. Hilfreich ist hier die Realisierung einer Zwei-Hersteller-Strategie: Beispielsweise bei Browsern. Diese ermöglicht, dass wenn bei einem Browser Schwachstellen bekannt werden, unmittelbar der zweite Browser, ohne bekannte Schwachstelle, mit allen Einstellungen weiterverwendet werden kann.

3. Fokussierung

Aus Studien ist bekannt, dass im Schnitt circa 5 Prozent aller vorhandenen Daten in Unternehmen besonders schützenswert sind. Welche Daten zu den 5 Prozent gehören und von daher besonders schützenswert sind, wissen die Verantwortlichen in der Regel nicht genau. Generell sind dies unter anderem Daten, die dem Unternehmen einen hohen Schaden verursachen, wenn sie in die Hände des Wettbewerbs fallen würden, also beispielsweise das geistige Eigentum des Unternehmens, Kalkulationsdaten oder Kundendaten. Aus diesem Grund ist eine Schutzbedarfsanalyse notwendig, um diese unternehmenskritischen Daten auf den vorhandenen IT-Systemen zu identifizieren und deren IT-Schutzbedürfnisse genau zu kennen. Mit dem exakten Wissen, welche Daten für das Unternehmen besonders schutzbedürftig sind, werden die Verantwortlichen in die Lage versetzt, sich auf möglichst wenige IT-Systeme zu konzentrieren und diese besonders zu schützen. Zum Beispiel, wie in Bild 1.3 aufgezeigt, dass nur auf dem IT-System in der Mitte besonders sicherheitsrelevante Werte gespeichert sind, die schlussfolgernd der IT-Schutzbedürfnisse spezifisch und besonders geschützt werden müssen.

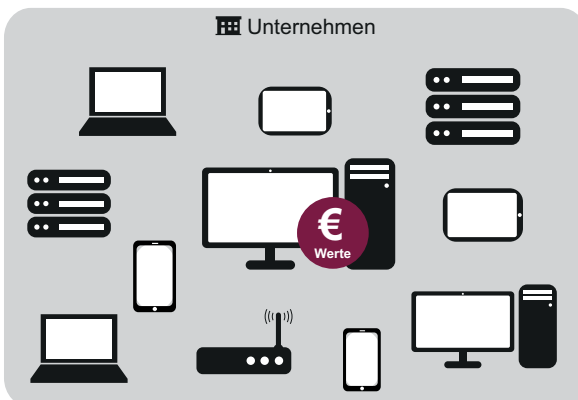


Bild 1.3

Idee der Fokussierung

4. Reduzierung von IT-Möglichkeiten

Die Reduzierung der IT-Möglichkeiten ist ein weiteres Prinzip zur Vermeidung von Angriffen. Nicht notwendige Software vom IT-System entfernen, nicht verwendete Funktionen einer Anwendung deaktivieren oder Kommunikationsmöglichkeiten zum Beispiel mithilfe von Routern und Firewall-Systemen reduzieren helfen, die potenziellen Angriffsflächen zu verringern.

5. Sicherheitsbewusste Mitarbeiter

Security Awareness, also das Vorhandensein eines Sicherheitsbewusstseins, ist ein weiterer wichtiger Punkt der Vermeidungsstrategie. Sicherheitsbewusstsein setzt sich aus Wissen und einer bestimmten Einstellung der Mitarbeiter zusammen, beides dient dazu, die IT mit all ihren Werten zu schützen. Das relevante Wissen erstreckt sich hierbei über die Werte eines Unternehmens, die zu schützen sind, den Schutzbedarf dieser Werte sowie die Bedrohungen, die auf diese Werte wirken. Aber auch unter anderem darüber, welche organisatorischen Regelungen einzuhalten sind oder die richtige Nutzung von IT-Sicherheitsmaßnahmen zum Schutz der Werte. Mit der Einstellung ist gemeint, dieses Wissen zu verinnerlichen und zum Schutz des Unternehmens aktiv umzusetzen.

Bewertung der Vermeidungsstrategie

Das Vermeiden von Angriffen ist die beste IT-Sicherheitsstrategie, um Schäden zu reduzieren. Leider ist die Vermeidungsstrategie jedoch praktisch nur eingeschränkt umsetzbar, da eine bestimmte Anzahl an IT-Systemen und Daten benötigt wird, um die gewünschten digitalen Aktivitäten umzusetzen. Das Vermeiden von Angriffen reduziert zwar die Angriffsfläche, aber für die gewollten IT-Anwendungen und -Dienste sowie die erforderliche Kommunikation etwa mit Kunden oder Dienstleistern muss eine weitere IT-Sicherheitsstrategie, wie das Entgegenwirken von Angriffen, zum Einsatz kommen, um die vorhandenen Risiken weiter zu minimieren.

1.3.2 Entgegenwirken von Angriffen

Das Entgegenwirken von Angriffen ist die meistverwendete IT-Sicherheitsstrategie, um das vorhandene Risiko zu minimieren und damit Schäden zu vermeiden. Dazu werden IT-Sicherheitsmechanismen verwendet, die eine hohe Wirkung gegen bekannte Angriffe zur Verfügung stellen und damit die Werte angemessen schützen. Die Stärke der Wirkung eines IT-Sicherheitsmechanismus hängt prinzipiell von unterschiedlichen Aspekten ab. Es müssen die Fachkenntnisse, Gelegenheit und Ressourcen der Angreifer bei der Diskussion der Wirksamkeit betrachten werden. Da Angriffe immer ausgefeilter, komplexer und intelligenter werden, müssen IT-Sicherheitsmechanismen kontinuierlich optimiert werden, um die notwendige Wirkung aufrecht zu halten (Pohlmann 2019b).

IT-Sicherheitsmechanismen, die gegen spezielle Angriffe wirken, sind zum Beispiel:

- **Verschlüsselung**

(Datei-, Festplatten-, E-Mail-Verschlüsselung, VPN-Systeme, SSL/TLS ...)

Die Verschlüsselung sorgt dafür, dass keine unerlaubten Informationen im Klartext gelesen werden können.

- **Multifaktor-Authentifikationsverfahren**

Mithilfe einer Multifaktor-Authentifikation wird verhindert, dass unerlaubte Nutzer Zugriff auf das IT-System oder den IT-Dienst erhalten.

- **Anti-Malware-Lösungen**

Anti-Malware-Lösungen sorgen dafür, dass illegales Aufspielen und kriminelles Nutzen von Malware auf IT-Systemen nicht umgesetzt werden kann.

- **Anti-DDoS-Verfahren**

Mithilfe von Anti-DDoS-Verfahren wird die erfolgreiche Umsetzung von DDoS-Angriffen verhindert.

- **Signaturverfahren**

Die Nutzung von Signaturverfahren ermöglicht es zu verhindern, dass digitale Handlungen geleugnet werden können.

- **Hardware-Sicherheitsmodule**

Mithilfe von Hardware-Sicherheitsmodulen (Smartcards, TPMs, High-Level Security Modules) wird der unerlaubte Zugriff auf Sicherheitsinformationen und die unerlaubte Nutzung von Kryptographie-Funktionen mit Schlüssel unterbunden.

Da Angreifer zunehmend schneller mehr, aber auch neue Angriffsmethoden entwickeln und umsetzen sowie die potenziellen Ressourcen für Angriffe immer leistungstärker werden, müssen die IT-Sicherheitsmechanismen, die diese abwehren sollen, kontinuierlich und zeitnah verbessert werden.

Bewertung des Entgegenwirkens

Die IT-Sicherheitsstrategien „Entgegenwirken von Angriffen“ ist eine naheliegende Vorgehensweise, digitale Werte angemessen zu schützen. IT-Sicherheitsmechanismen sollten dem Stand der Technik genügen, um mittels einer hohen Wirkung einen angemessenen IT-Sicherheitslevel zu erzielen. Momentan stehen nicht genügend, beziehungsweise nicht schnell genug, wirkungsvolle IT-Sicherheitstechnologien, -lösungen und -produkte gegen die immer intelligenteren Angriffe zur Verfügung oder werden nicht angemessen und vollumfänglich genug eingesetzt. Das dokumentiert die Vielzahl der professionell durchgeführten und daher erfolgreichen Angriffe. Da es keine hundertprozentige IT-Sicherheit gibt und somit immer ein Restrisiko bleibt, muss mit weiteren IT-Sicherheitsstrategien gegen die verbleibenden Risiken vorgegangen werden.

1.3.3 Erkennen von Angriffen

Wenn Angriffen mithilfe von IT-Sicherheitsmechanismen nicht angemessen oder vollständig entgegengewirkt werden oder eine Vermeidung die Angriffsfläche nicht ausreichend reduzieren kann, bleibt noch die Strategie, Angriffe erkennen und zu versuchen, den Schaden so schnell wie möglich zu minimieren.

In diesem Bereich spielen prinzipiell Frühwarn- und Lagebildsysteme eine besondere Rolle, da sie Lagebilder erstellen und Warnungen erzeugen, wenn die Bedrohungslage ungewöhnlich groß ist und gerade umgesetzte Angriffe erkannt werden.

Hier ist die Idee, dass in einem definierten Bereich (etwa IT- und Kommunikationsinfrastruktur, Endgeräte oder Server) nach Angriffssignaturen oder Anomalien gesucht wird. Bei Erkennen eines Angriffs werden die Hintergründe analysiert und adäquate Gegenmaßnahmen eingeleitet, um weitere Schäden zu verhindern oder zumindest zu reduzieren.

Bewertung des Erkennens

Die IT-Sicherheitsstrategie „Erkennen von Angriffen“ ist sehr hilfreich, hat aber definierte Grenzen, da es keine hundertprozentige Erkennungsrate gibt. Aus diesem Grund wird es in der Zukunft wichtig, auf diesem Gebiet durch mehr und bessere Sensoren sowie einen unternehmensübergreifenden Austausch viele sicherheitsrelevante Informationen verfügbar zu machen, aber auch durch den Einsatz von KI-Systemen die Erkennungsraten so weit wie möglich zu steigern. Zudem ist es wichtig, schnell und angemessen zu reagieren. Daher müssen die IT-Sicherheitsstrategien „Erkennen von Angriffen“ und „Reaktion auf Angriffe“ zusammen betrachtet werden.

1.3.4 Reaktion auf Angriffe

Wenn Angriffe erkannt werden, gilt es so schnell wie möglich mit passenden Aktionen zu reagieren.

1. Automatisierte Reaktion

Wenn ein Angriff erkannt wird, können zum Beispiel sofort und (halb-)automatisiert Firewall-Regeln oder E-Mail-Server-Regel so reduziert werden, dass nur noch die wichtigen Prozesse für das Unternehmen aufrechterhalten bleiben. Durch die Reduktion der Angriffsfläche lassen sich die potenziellen Schäden so gut wie möglich verringern.

2. Definition von Befugnissen, Informationsflüssen, Entscheidungsprozessen und Kommunikationsstrategien

Für das gesamte Abschalten der Internetverbindung oder die Notwendigkeit des Herunterfahrens vieler IT-Systeme, etwa bei großen Ransomware-Angriffen, müs-

sen in der Regel die Verantwortlichkeiten sowie die damit verbundenen Rechte definiert sein. Um schneller handeln zu können, ist es notwendig die erforderlichen Informationsflüsse und Reaktionsmöglichkeiten exakt ausgearbeitet und vereinbart zu haben. Wichtig für ein angegriffenes Unternehmen sind somit ein sehr kurzer Entscheidungsprozess, effiziente Pfade für die Informationsverteilung sowie klar definierte Befugnisse der Akteure, um im Notfall schnell und verantwortungsvoll reagieren zu können. Zudem muss die Kommunikationsstrategie bezüglich Mitarbeiter, Kunden, Regulierungsbehörden und Medien sorgfältig geplant sein, um einen hohen Imageschaden zu vermeiden.

3. Digitale Forensik

Grundsätzlich ist die digitale Forensik eine streng methodisch vorgenommene Datenanalyse auf Datenträgern und von IT-Systemen und Kommunikationsnetzwerken zur Aufklärung von Vorfällen durch forensische Sicherung von digitalen Beweisen sowie der Analyse der digitalen Beweismittel. Im Sinne der eigenen Reaktion lässt sich durch die Analyse eines Angriffs gewährleisten, dass eventuell vorhandene Lücken geschlossen, vorhandene IT-Sicherheitsmaßnahmen optimiert oder weitere integriert werden, damit das Unternehmen zukünftig besser geschützt ist.

4. Notfallplanung

Wichtig ist auch, dass es bereits getestete Reaktionskonzepte (Notfallplanungen) gibt, in denen die richtige Vorgehensweise im Krisenfall definiert ist aber auch welche Personen die Rechte haben, die entsprechenden Reaktionen auszulösen. Besonders relevant ist dabei, alle definierten Abläufe in ausreichendem Maße mit allen Mitarbeitern zu trainieren, damit im Ernstfall die adäquaten Reaktionen schnell und erfolgreich umgesetzt werden können.

Bewertung der Reaktion

Die IT-Sicherheitsstrategie „Reagieren auf Angriffe“ hilft Schäden zu vermeiden oder zu minimieren. Es kann jedoch nur reagiert werden, wenn Angriffe erkannt werden. Notwendig ist, die Reaktionskonzepte vorher definiert sowie getestet zu haben, um im Ernstfall schnell und wirkungsvoll reagieren zu können.

1.4 Umsetzung eines angemessenen IT-Sicherheitslevels

Der Stand der Technik bezeichnet die am Markt verfügbare Bestleistung einer IT-Sicherheitsmaßnahme, um ein gesetzliches IT-Sicherheitsziel zu erreichen (TeleTrust 2021).

Das Technologie- und IT-Sicherheitsniveau „Stand der Technik“ ist angesiedelt zwischen dem innovativeren Technologiestand „Stand der Wissenschaft und Forschung“ und dem bewährten Technologiestand „allgemein anerkannte Regeln der Technik“, siehe Bild 1.4.

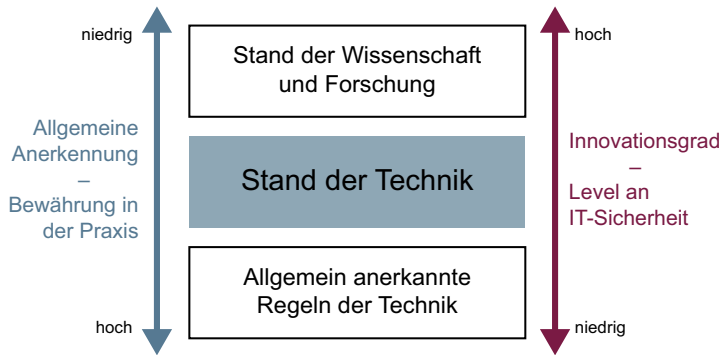


Bild 1.4 Angemessener IT-Sicherheitslevel durch den Stand der Technik

- **Stand der Technik:** Der Stand der Technik bezeichnet die am Markt verfügbare Bestleistung einer IT-Sicherheitsmaßnahme, um das entsprechende IT-Sicherheitsziel zu erreichen. IT-Sicherheitslösungen, die dem Stand der Technik genügen, bieten einen angemessenen Level an IT-Sicherheit für den aktuellen Grad der Digitalisierung.
- **Stand der Wissenschaft und Forschung:** Technische IT-Sicherheitsmaßnahmen im Stadium „Stand der Wissenschaft und Forschung“ haben einen hohen Innovationsgrad sowie IT-Sicherheitslevel, sind sehr dynamisch in ihrer Entwicklung und gehen mit der Erreichung der Marktreife (oder zumindest mit ihrer Markteinführung) in das Stadium „Stand der Technik“ über. Dort nimmt die Dynamik ab, etwa durch die Standardisierung der Prozesse.
- **Allgemein anerkannte Regeln der Technik:** Auch technische Maßnahmen im Stadium „allgemein anerkannte Regeln der Technik“ sind am Markt verfügbar. Ihr Innovationsgrad ist geringer, sie haben sich jedoch in der Praxis bewährt und werden oftmals in den entsprechenden Standards beschrieben. Jedoch ist im Stadium „allgemein anerkannte Regeln der Technik“ das Entgegenwirken von innovativen Angreifern nicht mehr so wirkungsvoll. Einige Beispiele hierfür sind: Die Nutzung von Passwörtern für die Authentifikation, oder die Nutzung von nicht mehr sicheren Kryptographie-Algorithmen etwa bei Signaturen, Authentifikation oder Verschlüsselung. Aber ebenso Anti-Malware-Lösungen, die überwiegend auf der Basis der Signatuererkennung funktionieren, oder Firewall-Systeme, die keine sicheren Regeln nutzen oder umsetzen können, gehören – in Anbetracht der aktuell sehr dynamischen Digitalisierung – in diese nicht mehr angemessene Kategorie.

- **Verfügbare Bestleistung einer IT-Sicherheitsmaßnahme:** Unter anderem im „Gesetz zur Erhöhung der Sicherheit informationstechnischer Systeme (IT-Sicherheitsgesetz)“ und in der „EU-Datenschutz-Grundverordnung (DSGVO)“ ist vorgeschrieben, dass sich die IT-Sicherheitsmaßnahmen an dem Stand der Technik orientieren. Daher kommt diesem eine hohe Bedeutung zu, auch aus der Sicht der Haftung im Schadensfall.

1.5 IT-Sicherheitsmechanismen, die gegen Angriffe wirken

Im Folgenden werden einige IT-Sicherheitsmechanismen beschrieben, die gegen Angriffe wirken (Pohlmann 2019b).

1. Verschlüsselung

Das Ziel der Verschlüsselung besteht darin, Daten in einer solchen Weise einer mathematischen Transformation zu unterziehen, dass es einem Unbefugten unmöglich ist, die Originaldaten aus den transformierten, verschlüsselten Daten zu rekonstruieren. Damit die verschlüsselten Daten für ihren legitimen Nutzer dennoch verwendbar bleiben, muss es diesem jedoch möglich sein, durch Anwendung einer inversen Transformation daraus wieder die Originaldaten zu generieren (siehe Bild 1.5).

Die Verschlüsselung wird zur Übertragung und Speicherung vertraulicher Daten verwendet, die nur dem legitimen Empfänger/Besitzer zugänglich sein sollen. Anwendungsfälle sind unter anderem: Datei-, Festplatten-, E-Mail-Verschlüsselung, IP-Sec-Verschlüsselungssysteme, SSL/TLS-Absicherung.

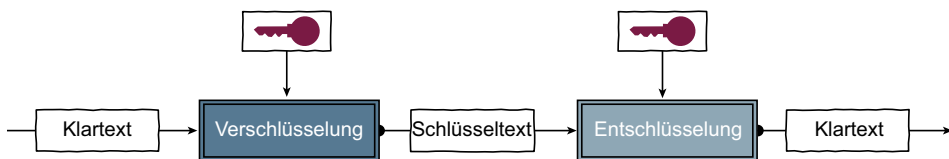


Bild 1.5 Verschlüsselung

Im Bereich Verschlüsselung gibt es bei den meisten Unternehmen noch einen großen Nachholbedarf. Aus diesem Grund sollte ein Konzept erarbeitet werden, wie die Verschlüsselung und eine dazu notwendige IT-Sicherheitsinfrastruktur umgesetzt werden kann.

Kryptoagilität: Beim Einsatz von Verschlüsselungssystemen sollte auf die Kryptoagilität geachtet werden. Die Kryptoagilität ermöglicht es einem IT-Sicherheitssystem auf

ein alternatives, neues Kryptosystem (unter anderem bezüglich kryptografischer Algorithmen, Schlüssellänge, Schlüsselgenerierungsverfahren, technische Umsetzung) sehr schnell umzuschalten, ohne wesentliche Änderungen am IT-System oder IT-Sicherheitssystem (wie Systemarchitekturen oder Protokolle) vorzunehmen. Damit kann garantiert werden, dass ein IT-Sicherheitssystem kontinuierlich ein Mindestniveau an IT-Sicherheit halten kann.

In Bezug auf die wichtigsten Angriffsvektoren, wie Man-in-the-Middle (MITM), hilft Verschlüsselung diese zu verhindern.

2. Authentifikationsverfahren

Authentifikation bezeichnet einen Prozess, in dem überprüft wird, ob der Nutzer (Mitarbeiter, Kunde und andere Personen), der gerade auf ein IT-System zugreifen möchte, echt ist. Bei der Authentifikation wird mit der Erbringung eines oder mehrere Nachweise bestätigt, ob es sich um den Nutzer mit der angegebenen und behaupteten digitalen Identität handelt (siehe Bild 1.6).

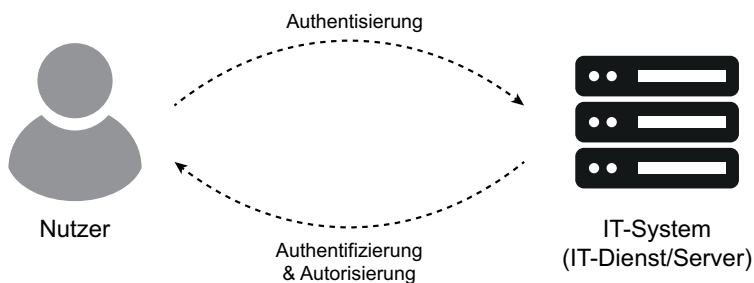


Bild 1.6 Authentifikation, Authentisierung & Autorisierung

- **Authentisierung: (Sichtweise Nutzer):**

Der Nutzer authentisiert sich gegenüber einem IT-System (etwa Endgerät, Server, IT-Dienst oder Cloud), indem er einen Nachweis über seine digitale Identität erbringt, zum Beispiel den Nutzernamen.

- **Authentifizierung: (Sichtweise IT-System):**

Das IT-System (etwa Endgerät, Server, IT-Dienst oder Cloud) überprüft den Nachweis, um die Echtheit der digitalen Identität eines Nutzers im Rahmen der Authentifizierung festzustellen.

- **Autorisierung: (Sichtweise IT-System):**

Wenn die Echtheit der digitalen Identität eines Nutzers erfolgreich verifiziert werden konnte, kann das IT-System (etwa Endgerät, Server, IT-Dienst oder Cloud) dem Nutzer definierte Rechte einräumen.

Klassen von Authentifizierungsverfahren: Es werden verschiedene Klassen von Authentifizierungsverfahren unterschieden, bei denen unterschiedliche Aspekte eine Rolle spielen und diverse Charakteristika berücksichtigt werden müssen.

1. *Wissen:* Bei dieser Klasse von Authentifizierungsverfahren wird über einen Nachweis der Kenntnis von Wissen die Echtheit eines Nutzers überprüft. Beispiele von Wissen sind: Passwort, PIN oder Antwort auf eine bestimmte Frage (Sicherheitsfrage).
2. *Besitz:* Verwendung eines Besitzums für das Authentifizierungsverfahren ist eine weitere Klasse. Beispiele für Besitz sind: Neuer Personalausweis, SIM-Karte im Smartphone und weitere Hardware-Sicherheitsmodule, wie Smartcard oder USB-Stick. In der Regel wird in diesem Bereich der Besitz von geheimen Schlüsseln mithilfe von Challenge-Response-Verfahren nachgewiesen, die in den Hardware-Sicherheitsmodulen sicher gespeichert sind.
3. *Sein:* Bei dieser Klasse von Authentifizierungsverfahren muss der Nutzer gegenwärtig sein. Beispiele von Sein sind: Biometrische Merkmale wie Fingerabdruck, Gesichtsgeometrie oder Iris.
4. *Weitere unterstützende Faktoren (Reputation, Standort, Zeit, Technologie):* Es können noch weitere unterstützende Faktoren für die Beurteilung der Echtheit des Nutzers herangezogen werden. Beispiele sind: Vergangene Transaktionen des Nutzers (Reputation), verwendete Endgeräte und Software des Nutzers (Technologie), Standort und Zeit des Authentisierungsprozesses.

Multifaktor-Authentifizierung: Stand der Technik heute ist die Multifaktor-Authentifizierung. Mit einer Multifaktor-Authentifizierung (MFA) kann flexibel agiert und mit einer höheren Vertrauenswürdigkeit authentifiziert werden. Ein Beispiel für eine Multifaktor-Authentifizierung ist: Es wird als Basis eine digitale Signatur einer Zufallszahl mithilfe eines Hardware-Sicherheitsmoduls (etwa Smartcard, USB-Stick oder Sicherheitsmodul im Smartphone) umgesetzt, das mit einem Passwort oder PIN aktiviert werden muss. Um den Nutzerbezug zu verstärken, muss der Nutzer noch mithilfe eines Fingerabdrucks oder Gesichtserkennung seine Gegenwärtigkeit zusätzlich verifizieren lassen.

Konzept der risikobasierten und adaptiven Authentifizierung: Die adaptive Authentifizierung entscheidet auf der Basis der Vertrauenswürdigkeit des zugreifenden Nutzers, der Kritikalität der konkreten Anwendung/Aktion und den Rahmenbedingungen des aktuellen Zugriffs, welche Klassen von Authentifikationsverfahren zum Einsatz kommen sollen. Dieser Risiko-orientierte Ansatz erhöht das allgemeine Sicherheitsniveau und vermindert die Anzahl nicht notwendiger starker Authentifizierungen. Es wird das Optimum zwischen Sicherheit und Komfort angestrebt. Umgesetzt werden Konzepte der adaptiven Authentifizierung mithilfe von Multifaktor-Authentifizierung (MFA), die flexibel, in Abhängigkeit des gerade notwendigen

Sicherheitsniveaus oder Risiken, die passenden Klassen von Authentifikationsverfahren auswählt.

3. Firewall-Systeme

Ein Firewall-System sichert und kontrolliert den Übergang von einem zu schützenden Netz zu einem unsicheren Netz, wie dem öffentlichen Internet. Ein Firewall-System lässt erlaubte Kommunikation durch (linke Wolke) und blockiert nicht gewünschte (rechte Wolke), siehe Bild 1.7. Die grundsätzliche Idee ist, zwischen verbundenen Netzen durch Regulierung und Kontrolle Sicherheitsdomänen mit unterschiedlichem Schutzbedarf zu schaffen. Durch eine Reduzierung von Kommunikationsmöglichkeiten über ein Firewall-System wird die Angriffsfläche und dadurch das Risikopotenzial minimiert.

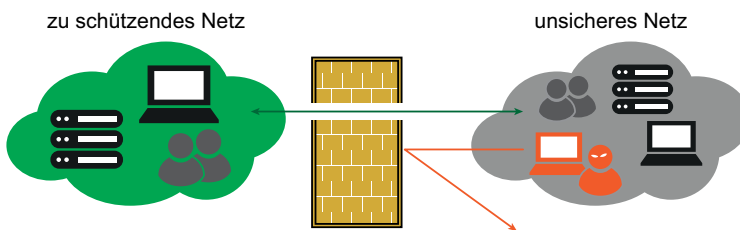


Bild 1.7 Firewall-System

Unternehmen müssen auswerten sowie entscheiden, welche Protokolle und Methoden sie über das Firewall-System zu welchen Zeiten und welchen Mitarbeitern möglich machen wollen, damit die notwendigen Aufgabenstellungen umgesetzt werden können. Diese müssen aktiv eingestellt und regelmäßig überwacht werden, damit die Reduzierung der Möglichkeiten und damit der Angriffsfläche immer optimal umgesetzt werden kann. Außerdem sollten die eingesetzten Firewall-Systeme eine hohe Qualität haben, damit durch eine ausreichende Tiefe der Analyse gewährleistet ist, dass Angriffe erkannt und darauf reagiert werden kann.

4. Zero Trust-Konzept

Das Zero Trust-Modell ist ein IT-Sicherheitskonzept, das auf dem Prinzip basiert, weder dem IT-System noch einem Nutzer, IT-Dienst, Netzwerk zu vertrauen und ebenfalls keiner IT-Anwendung, IT-Infrastruktur – allgemein IT-Entität – innerhalb oder außerhalb des eigenen Netzwerks (Zero Trust).

Das bedeutet, sämtliche Kommunikation zwischen den IT-Entitäten wird kontrolliert sowie auf Angriffe untersucht und alle IT-Entitäten müssen sich authentifizieren.

Herkömmliche IT-Sicherheitskonzepte wie die Perimeter-Sicherheit stufen lediglich externe Kommunikation als gefährlich ein und vertrauen sämtlichen internen

IT-Entitäten. Diese IT-Sicherheitskonzepte haben den Nachteil, dass sobald jemand in das Unternehmensnetz eingedrungen ist oder von innen angreift, kaum noch IT-Sicherheitsmaßnahmen zur Verfügung stehen, um gegen diese Angriffe vorgehen zu können.

Daher hat das Zero Trust-Konzept beachtliche Auswirkungen auf die IT-Sicherheits-Architektur eines Unternehmens, weil alle IT-Entitäten mit zusätzlichen IT-Sicherheitsmaßnahmen ausgestattet werden müssen, anstatt nur die Sicherung der Netzwerkgrenzen. Durch die zusätzliche Umsetzung der minimalen Rechte auf allen IT-Entitäten werden die Möglichkeiten für Angreifer stark eingeschränkt und somit ein höheres Level an IT-Sicherheit erreicht. Mit dem Zero Trust-Konzept (vgl. Bild 1.8) werden zum Beispiel mehrstufige Angriffe/Advanced Persistent Threat (APT) verhindert (Pohlmann 2024).

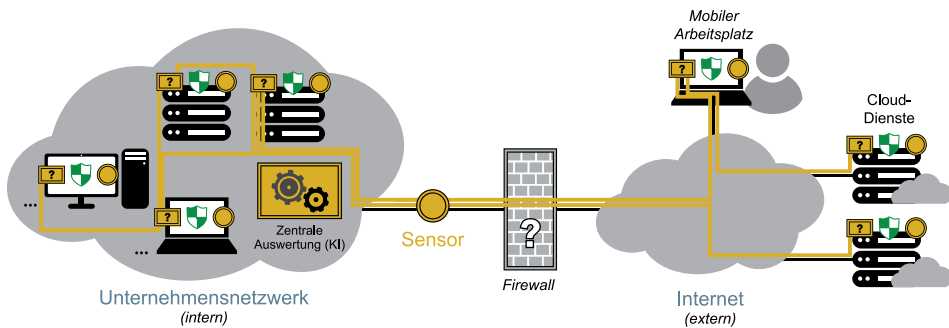


Bild 1.8 Zero Trust-Konzept

5. Blockchain-Technologie (Vertrauensdienst)

Mit Hilfe der Blockchain-Technologien werden zusätzlich zu PKIs Vertrauensdienste angeboten, die neue Möglichkeiten im Rahmen der Digitalisierung für mehr Sicherheit und Vertrauenswürdigkeit anbieten. Insbesondere im Bereich der Verifizierung etwa von Bescheinigungen, Berechtigungen, Beglaubigungen, oder Qualifikationen wird es in der nahen Zukunft viele Anwendungen geben, die die Digitalisierung von Unternehmensprozessen vertrauenswürdig und sicher möglich machen. Ein weiterer wichtiger Anwendungsbereich der Blockchain-Technologie ist eine vertrauenswürdige und automatisierte Zusammenarbeit zwischen verschiedenen Organisationen, die Prozesse sehr viel schneller effizienter und kostengünstiger umsetzen lässt.

Unterschiedliche Sichtweisen auf die Blockchain-Technologie: Die verschiedenen Disziplinen können die Blockchain-Technologie aus sehr unterschiedlichen Blickwinkeln betrachten und bewerten (siehe Bild 1.9).

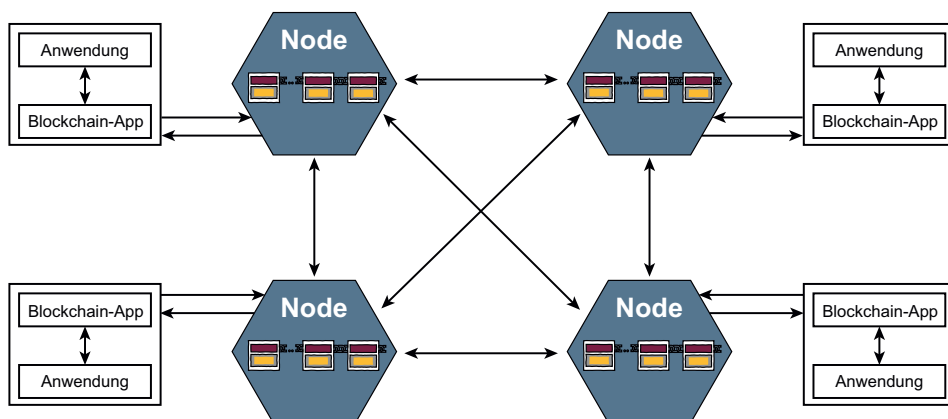


Bild 1.9 Blockchain-Technologien

Für einen Informatiker produziert die Blockchain-Technologie eine einfache Datenstruktur, die Blockchain, die Daten als Transaktionen in einzelnen Blöcken verkettet und in einem verteilten Peer-to-Peer-Netz redundant verwaltet. Die Alternative wäre eine konventionelle Datenbank, die kontinuierlich von allen Teilnehmern repliziert wird.

Für die IT-Sicherheitsexperten hat die Blockchain-Technologie den Vorteil, dass die Daten als Transaktionen in den einzelnen Blöcken manipulationssicher gespeichert werden können, d. h., die Teilnehmer der Blockchain sind in der Lage, die Echtheit, den Ursprung sowie die Unversehrtheit der gespeicherten Daten (Transaktionen) zu überprüfen. Die Alternative wäre hier zum Beispiel ein PKI-System als zentraler Vertrauensdienstanbieter.

Für den Anwendungsdesigner bedeutet die Nutzung der Blockchain-Technologie eine vertrauenswürdige Zusammenarbeit zwischen verschiedenen Organisationen, ohne die Einbindung einer zentralen Instanz etwa eines PKI-Systems oder Notars. Die Alternative könnte hier ein kostenintensiver Treuhänder sein, der die Zusammenarbeit und Eigentumsübertragung zwischen den verschiedenen Organisationen verwaltet und verifiziert.

Da die Blockchain-Technologie dies automatisiert macht, werden durch die vertrauenswürdige Zusammenarbeit die Prozesse sehr viel schneller und effizienter. Das macht einen Vertrauensdienst auf der Basis einer Blockchain-Technologie preisgünstiger und das Vertrauen verteilt sich auch die Node-Betreiber.

6. Trusted Computing (moderne IT-Sicherheitsarchitektur)

Trusted Computing ist eine IT-Sicherheits- und Vertrauenswürdigkeitstechnologie. Mithilfe von Trusted Computing stehen moderne und intelligente IT-Sicherheitsarchi-

tekturen, -konzepte und -funktionen zur Verfügung, die es ermöglichen IT-Systeme mit einer höheren Robustheit sowie einem höheren IT-Sicherheitslevel umzusetzen. Der besondere Schwerpunkt liegt dabei auf der Verifikation der Integrität eines IT-Systems, wodurch einige große IT-Sicherheitsprobleme, wie Softwarefehler und Malware in ihrer Wirkung deutlich eingeschränkt werden können.

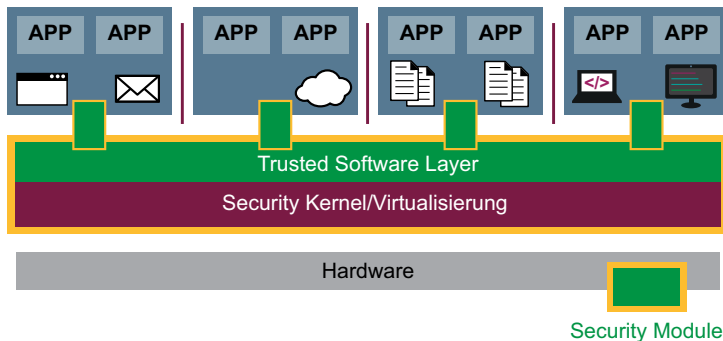


Bild 1.10 Trusted Computing (moderne IT-Sicherheitsarchitektur)

Trusted Computing basiert auf einem Hardware-Sicherheitsmodul und arbeitet mit einem kleinen Sicherheitskern (sichere Betriebssysteme) und Virtualisierung, siehe Bild 1.10. Auf dieser Basis können mit Trusted Computing Funktionen in dem Trusted Software-Layer Software- und Hardware-Konfigurationen messbar im Sinne der Vertrauenswürdigkeit machen und mit einer starken Isolation Anwendungen mit ihren Daten separiert werden. Der IT-Sicherheitsaspekt der Modularisierung ist eine Möglichkeit Anwendungen, die zusammengehören, in einer virtuellen Maschine laufen zu lassen und Anwendungen, die getrennt sein sollten, in unterschiedlichen virtuellen Maschinen zu positionieren. Dieser IT-Sicherheitsaspekt offeriert einen interessanten Gestaltungsspielraum, mit dem sich ein sehr hoher Grad an IT-Sicherheit erzielen lässt, weil für verschiedene IT-Sicherheitslevel von Anwendungen verschiedene virtuelle Maschinen genutzt werden können. Beispiel: Das Office-Paket läuft in einer virtuellen Maschine, das Design-Paket für die Business-Anwendung in einer anderen und der Browser hat eine separate virtuelle Maschine.

7. Anti-Malware-Lösungen

Malware ist der Oberbegriff für „Schadsoftware“ wie Viren, Würmer, trojanische Pferde usw. Angreifer (kriminelle Organisationen, politisch und wirtschaftlich orientierte Spione, Terroristen, Strafverfolger, usw.) nutzen Softwareschwachstellen und menschliche Unzulänglichkeiten aus, um Malware auf IT-Systemen zu installieren. Über E-Mail-Anhänge oder unsichere Webseiten mithilfe von sogenannten Drive-by-Downloads wird Malware hauptsächlich in IT-Endgeräte unbemerkt eingeschleust.

Ein Botnetz ist eine Gruppe von IT-Endgeräten, die unter zentraler Kontrolle eines Angreifers stehen und von ihm für Angriffe genutzt werden.

Ein Angreifer kann die Malware aus der „Ferne“ mit verschiedenen Schadfunktionen bespielen. Dadurch können Angreifer unterschiedliche Arten von Angriffen durchführen, wie Informationen von IT-Systemen mithilfe von Keyloggern und Trojanern auslesen, IT-Systeme für die Spam-Verteilung und DDoS-Angriffe nutzen sowie mit Ransomware Daten verschlüsseln und Lösegeld für die Entschlüsselung verlangen. Bei Ransomware verschlüsseln die Angreifer mithilfe der Malware wichtige Daten auf dem IT-System und verlangen vom Besitzer zum Beispiel einige Tausend Euro für die Herausgabe des Schlüssels, mit dem die Daten wieder entschlüsselt werden können.

Anti-Malware-Lösungen haben das Ziel Malware zu erkennen und damit entsprechende Angriffe zu verhindern.

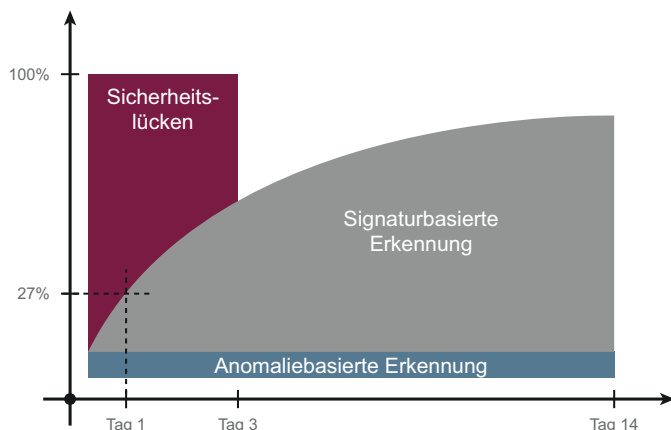


Bild 1.11 Anti-Malware-Lösungen

Herkömmliche Anti-Malware-Lösungen haben heute bei Massen-Angriffen mit 75 bis 95 Prozent eine zu schwache Erkennungsrate. Bei gezielten direkten Angriffen auf ein ausgewähltes IT-System liegt die Erkennungsrate im Schnitt sogar nur bei 27 Prozent. Hintergrund dieser Entwicklung ist, dass signaturbasierte Erkennungen bei gezielten Angriffen ihre Wirkung verlieren, da keine Signaturen mehr erstellt und verteilt werden, aber auch weil Signaturen bei einem direkten Angriff individuell sind, siehe Bild 1.11.

Moderne Anti-Malware-Lösungen arbeiten mit intelligenten Sensoren in den IT-Endpunkten wie Smartphone, Notebooks oder IoT-Geräten, die ihre Daten an ein zentrales System in der Cloud senden. Im zentralen System werden die Daten mithilfe von KI-Systemen analysiert, eine globale Sichtweise aufgebaut, mit Threat Intelligent In-

formationen abgeglichen und dann eine geeignete Reaktion umgesetzt, falls ein Angriff erkannt wird. Eine passende Reaktion kann zum Beispiel die Isolierung eines oder mehrere Notebooks sein. Mit modernen Anti-Malware-Lösungen können die am häufigsten verwendeten Angriffsvektoren verhindert werden.

8. IT-Sicherheit-Frühwarn- und Lagebildsystem

Alle Organisationen sind zunehmend von der Verfügbarkeit der eigenen und öffentlichen IT-Infrastruktur im Cyberraum abhängig. Ausfälle und Störungen der weltweiten Kommunikation, der angebotenen Dienste und digitalen Geschäftsprozesse können zu unkalkulierbaren Schäden führen. Ein IT-Sicherheit-Frühwarn- und Lagebildsystem hilft, die IT-Sicherheitslage aktuell aufzuzeigen, möglichst früh Angriffspotenziale sowie reale Angriffe zu erkennen und dient dazu, rechtzeitig Warnhinweise zu geben, damit Schäden auf IT-Systemen und IT-Infrastruktur minimiert oder verhindert werden können. Ein IT-Sicherheit-Frühwarn- und Lagebildsystem hilft, Sicherheit und Vertrauenswürdigkeit von IT-Systemen und IT-Infrastruktur nachhaltig zu erhöhen und diese widerstandsfähiger zu gestalten.

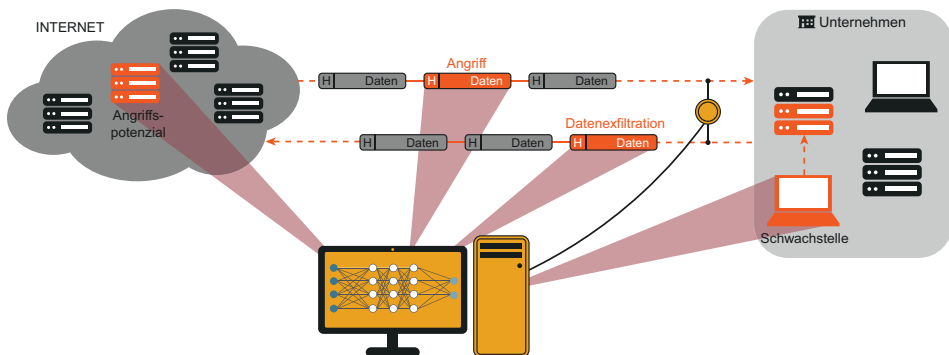


Bild 1.12 IT-Sicherheit-Frühwarn- und Lagebildsystem

Aus diesem Grund sollten Unternehmen eine Vielzahl von Sensoren einsetzen, damit möglichst viele digitalen Aktivitäten beobachtet werden können, um einen kontinuierlichen Status der gesamten IT des Unternehmens zu haben, um die Angriffspotenziale und reale Angriffe identifizieren zu können.

Weitere IT-Sicherheitsmechanismen sind zum Beispiel, Anti-DDoS-Verfahren, Signaturverfahren, Enterprise Identity and Access Management, E-Mail-Sicherheit usw. (Pohlmann 2019b).

1.6 Die wichtigsten Punkte in Kürze

- Die IT-Sicherheitsrisiken eines Unternehmens steigen mit dem Grad der Digitalisierung.
- IT-Systeme müssen in Zukunft mit einer möglichst umfassenden Angriffs-Resilienz ausgestattet werden. Das bedeutet, die notwendige IT, die im Rahmen der Digitalisierung sowieso neu innoviert wird, mit IT-Sicherheitsarchitekturen und -mechanismen im Sinne Security by Design/Security by Default auszustatten, die eine deutliche höhere Wirkung gegen Angriffe aufzeigen, optimalerweise automatisch funktionieren und eine hohe Qualität besitzen.
- Die Verantwortlichen für die IT-Sicherheit in Unternehmen sollten verschiedene IT-Sicherheitsstrategien umsetzen, um das Risiko von Schäden zu reduzieren.
- Die IT-Sicherheitsstrategie „Vermeiden von Angriffen“ hilft das Schadenspotential zu reduzieren, hat jedoch Grenzen in der Umsetzung und Wirkung, weil die geforderten digitalen Aktivitäten ohne Einschränkung zur Verfügung stehen müssen.
- Die IT-Sicherheitsstrategie „Entgegenwirken von Angriffen“ ist sehr naheliegend und erfolgsversprechend. Wichtig ist jedoch, dass hier IT-Sicherheitslösungen und -Maßnahmen gemäß Stand der Technik eingesetzt werden, um einen hohen Wirkungsgrad gegen intelligente Angriffe zu erreichen.
- Die verbleibenden Risiken sollten mit der IT-Sicherheitsstrategie „Erkennen von Angriffen“, also durch das Identifizieren von aktuell stattfindenden Angriffen, unter Kontrolle gebracht werden.
- Mit der IT-Sicherheitsstrategie „Reaktion auf Angriffe“ kann ein Schaden entweder vollständig verhindert oder zumindest reduziert werden.
- Im Prinzip sind alle Voraussetzungen gegeben, um den Kampf gegen professionalisierte Angreifer oder Cyberkriminelle zu gewinnen. Wichtig ist hierbei auch, dies mit allen Stakeholdern (Anbieter- und Anwenderwirtschaft, Wissenschaft, Politik und Staat) gemeinsam umzusetzen, um aufgrund der erzeugten Synergien noch effizienter vorgehen zu können.
- Selbstverständlich wird es ohne IT-Sicherheit keine nachhaltige Digitalisierung geben können – daher steht der Bedarf hinsichtlich des weiteren Fortschritts und nachweislicher Erfolge in der IT-Sicherheit vollkommen außer Frage.

Literatur

Bundesverband IT-Sicherheit – TeleTrust: *Handreichung zum – Stand der Technik – technischer und organisatorischer Maßnahmen*, Berlin 2021. <https://www.teletrust.de/publikationen/broschueren/stand-der-technik/>.

Pohlmann, Norbert: *Wertschöpfung der Digitalisierung sichern – Vier Cybersicherheitsstrategien für den erfolgreichen Wandel in der IT*. In: IT-Sicherheit – Mittelstandsmagazin für Informationssicherheit und Datenschutz, DATAKONTEXT-Fachverlag, 1/2020, S. 60 – 65.

Pohlmann, Norbert: *Künstliche Intelligenz und Cybersicherheit – Unausgegoren aber notwendig*. In: IT-Sicherheit – Fachmagazin für Informationssicherheit und Compliance, DATAKONTEXT-Fachverlag, 1/2019, S. 56 – 63.

Pohlmann, Norbert: *Cyber-Sicherheit – Das Lehrbuch für Konzepte, Mechanismen, Architekturen und Eigenschaften von Cyber-Sicherheitssystemen in der Digitalisierung*. Springer-Vieweg Verlag, Wiesbaden 2022.

Pohlmann, Norbert: *Die Notwendigkeit von neuen IT-Sicherheitskonzepten*, DuD Datenschutz und Datensicherheit – Recht und Sicherheit in Informationsverarbeitung und Kommunikation, Vieweg Verlag, 1/2024.

2

Grundprinzipien zur Gewährleistung der IT-Sicherheit

Hagen Lauer, Nicolai Kuntze



In diesem Beitrag erfahren Sie,

- welche Grundprinzipien für IT-Sicherheit sich bis heute als nützlich erwiesen haben.
- welche grundlegenden Aspekte der IT-Sicherheit zu berücksichtigen sind und welche Herausforderung dort vorliegen,
- was die Zusammenhänge von Schutzgütern, Angriffen und Schutzzielen sind.

2.1 Einleitung

Die IT-Sicherheit ist ein wesentlicher Funktionsbestandteil und Qualitätsmerkmal in nahezu allen Systemen. Dafür gibt es zahlreiche Belege, die einerseits nahezu vollständig virtuelle Anwendungen basierend auf Blockchain-Technologien und im anderen Extrem cyber-physische Steuer- und Kontrollsysteme von Industrieanlagen oder Energienetzen umfassen können. Die Sicherheitsanforderungen in beiden Fällen sind unterschiedlich und beinhalten Schutzziele als Qualitätsmerkmale, wie etwa „Privatheit“, „Vertraulichkeit“ und „Verbindlichkeit“ bzw. „Verfügbarkeit“, „Integrität“ und „Betriebssicherheit“ bei Industrieanlagen.

2.1.1 Trends

Die scharfen Grenzen solcher Anwendungen verschwimmen jedoch zunehmend, und das hat in der IT-Welt Tradition. Ein kurzer Blick in die Vergangenheit verrät viel über die Herausforderungen und Möglichkeiten von morgen. Computersysteme, je-

denfalls solche, die den heutigen am ähnlichsten sind, wurden erstmals in den 1940er- und 1950er-Jahren eingesetzt und dienten dabei primär militärischen Zwecken (u. a. Studien für Ballistik). Ähnliche Systeme wurden später auch wesentlich in der Buchhaltung und im Rechnungswesen eingesetzt. Bis heute sind leistungsfähige Computersysteme dafür eine Grundlage, und der Einsatz zur „Berechnung“ ist nach wie vor aktuell für die Modellierung komplexer Systeme, künstlicher Intelligenz, virtueller Realität, Computergrafik etc.

Der nächste wesentliche Trend beginnt rund 30 Jahre später in den 1980ern mit der Vernetzung von Computern und denen sich daraus ergebenden Anwendungen: E-Mail, verteilte Berechnung und Speicherung, eine Vielzahl von „Messengern“, Suchmaschinen, Social Media, Streaming und Unterhaltung sowie Heimarbeitsplätzen. Der Trend zur Vernetzung ist wie im Fall zuvor weit entfernt davon, überholt oder auch nur verlangsamt zu sein. Die Vernetzung sowohl durch kabelgebundene als auch durch drahtlose Technologien nimmt stetig zu und ist die Grundlage unserer modernen Welt – auch in Zukunft.

Der dritte wesentliche Trend wurde in den 2010er-Jahren groß und war nicht etwa Cloud Computing (z. B. Vernetzung, verteilte Speicher und Rechner), sondern das verbreitete Vorkommen von eingebetteten Systemen in nahezu allen wichtigen Sektoren und Produkten vom Haushalt bis hin zur Industrie. Sogenannte Cyber-Physical Systems (CPS) stellen das Rückgrat des Internet-of-Things (IoT), Industrial-Internet-of-Things (IIoT), Health IoT, Smart Grid, Industrie 4.0 und von vielen weiteren Applikationen dar. Der wesentliche Unterschied zu vorherigen Integrationskonzepten ist hier die planmäßige Interaktion, als Sensor und gleichzeitig Aktuator, zwischen IT und dem System, in das sie eingebettet ist.

Zukünftig werden wir einen vierten Trend beobachten: Computersysteme werden dann nicht nur mit der Welt interagieren, sondern sie werden wesentlich in Prozesse integriert werden, um diese zu verbessern und um Fähigkeiten zu erweitern und so etwa unsere Bewegung, Wahrnehmung oder unser Denken im Falle biologischer Prozesse zu unterstützen.

2.1.2 Herausforderungen

Aus diesen Trends ergaben sich bahnbrechende neue Möglichkeiten und heute dominierende Geschäftsfelder. Jedoch beobachtete man auch eine Zunahme an Komplexität und Umfang der Systeme und eine steigende Zahl ihrer missbräuchlichen Nutzung, die bis hin zur Erpressung und gezielten Sabotage von Staaten reicht. Dabei war zu Beginn „Sicherheit“ einfach: Wollte man etwa einen Computer verwenden, so brachte man Unterlagen wie Programme und Daten mit in einen Raum, fütterte den lokalen Computer mit selbigen, erhielt Ergebnisse und nahm diese samt aller Eingä-

ben beim Verlassen des Raumes wieder mit. Sicherheit lag offensichtlich in der Verantwortung der Nutzerinnen und Nutzer.

Dies änderte sich grundlegend mit „Timesharing“- und Mehrbenutzerbetriebssystemen, die es erstmals erlaubten, dass mehrere Nutzer auf einem Rechner jeweils einen scheinbar eigenen Arbeitsplatz hatten. Nutzerinnen und Nutzer teilten sich nicht nur dieselbe Hardware, sondern konnten auch Daten und Programme untereinander austauschen. Was einerseits massiv nützlich erscheint, brachte auch ein ewiges Dilemma ein: „Sharing vs. Isolation“, oder: was geteilt werden soll im Gegensatz zu dem, was abgeschirmt sein muss. Über die Zeit wuchs dieses Dilemma trotz größter Anstrengungen, und heute teilen sich „Social Media“- und Banking-Applikationen die gleiche Hardware und das Betriebssystem, und in Cloudsystemen laufen unsere Anwendungen ohne genaues Wissen darüber, wo der Server steht, wer darauf Zugriff hat und welche anderen Applikationen dort laufen. Tatsächliche physische Isolation und der Betrieb von eigenen Systemen sind in solchen Fällen schlicht zu teuer, nicht mehr umsetzbar und vor allem massiv unbequem für Nutzerinnen und Nutzer – Bequemlichkeit siegt über Sicherheit.

Vernetzung als weiterer Trend ermöglichte das heute allgegenwärtige Cloud Computing und damit die revolutionär instantane Verfügbarkeit von Rechenleistung, Daten und Features. Die zunehmende Vernetzung, sowohl in Ausdehnung als auch in Bandbreite, und der Trend zum Betriebsmodus „Always Online“ stellen zudem die Grundlage für hochgradig kollaborative und automatisierte Systeme dar. Eine wichtige Grundlage dafür wurde in den 1970ern in Form der asymmetrischen Kryptografie geliefert: Zwei Parteien konnten erstmals mit einfachen Schlüsselaustauschverfahren sichere Kommunikationskanäle herstellen. Weitere Verfahren adressierten die Geheimhaltung von Daten während der Berechnung, die zumindest in der Theorie für eine Vielzahl von Anwendungen brauchbar wären. Zusätzlich kennen wir verlässliche Methoden zur Authentifizierung und Verifikation von verschiedenen Eigenschaften in vernetzten Infrastrukturen. Ein wesentliches Problem bei vernetzten Systemen bleibt jedoch die Vertrauenswürdigkeit der einzelnen Systeme, denn diese können perfekt sicher kommunizieren und doch prinzipiell nicht kollaborieren, weil sie sich nicht vertrauen oder tatsächlich nicht vertrauenswürdig sind. Ein aktuelles Beispiel stellt hier Client-Side-Scanning¹ als ein Verfahren dar, bei dem Daten nicht in der Übertragung abgefangen und entschlüsselt werden, sondern „einfach“ die Endpunkte (z. B. Smartphones) digital durchsuchbar gemacht werden; Gleiches gilt natürlich für andere, von Angreifern kompromittierte Systeme.

Als Letztes bleiben noch die mit ihrer Umwelt interagierenden Cyber-Physical Systems, deren Potenzial für Automatisierung, Optimierung und Kostensenkung unum-

¹ <https://netzpolitik.org/2021/client-side-scanning-beruehmte-it-sicherheitsforscherinnen-warnen-vor-wanzen-in-unserer-hosentasche/>

stritten ist. Ebenfalls unumstritten ist die unausweichliche Kopplung zwischen IT- und Betriebssicherheit, die nicht immer zugunsten beider Seiten gestaltet werden kann; oft ist hier eine Balance notwendig, die vor allem die Betriebssicherheit nicht vernachlässigen darf. Beispiele für solche Trade-offs sind z. B. Interfaces und Schnittstellen, die zwar im „Normalbetrieb“ Mittel für Authentifikation und Autorisierung einsetzen, welche jedoch im „Notfall“ (d. h. wenn die Betriebssicherheit auf dem Spiel steht) außer Kraft gesetzt werden können. In einem solchen Fall verliert die IT-Sicherheit gegen die Betriebssicherheit, und das gerade dann, wenn ein „Notfall“ als Vorwand dient, um Systeme zu kompromittieren.

2.1.3 IT-Sicherheit vs. Sicherheit

Warum ist IT-Sicherheit überhaupt ein spezielles Problem? Die Frage stellt sich schon allein, weil man sich im Alltag kaum fragt, ob der Tresor wohl jemals geknackt werden kann, ob alle Türschlösser absolut sicher sind und ob die Zugangsberechtigungen in Gebäuden wohl perfekt funktionieren. Der Grund ist offensichtlich, in der „echten“ Welt basiert „Sicherheit“, oder unser relatives Verständnis des Konzeptes, niemals auf einer Maßnahme (z. B. Schlösser) alleine. Sicherheit, wie wir sie alltäglich kennen, basiert stattdessen auf einer nicht perfekten Kombination aus Risiko, Hürden und Abschreckung. Eine Risikobewertung ist wohl die Grundlage sowohl in der Verteidigung (z. B. welches Gut schütze ich mit welchen Mitteln) als auch bei Verbrechen (z. B. wie hoch ist der Aufwand und das Risiko, erwischt zu werden, im Vergleich zum Wert der Beute). Viele Verbrechen finden also schlicht nicht statt, weil eine rationale Risikobewertung nicht für einen „Angriff“ sprechen. Tresore, Wachdienste, Schlösser, Türen, Fenster, Zäune etc. zählen alle zu den potenziellen Hürden, die Güter oder ganze Bereiche vor dem Zutritt und Zugriff durch Unbefugte schützen sollen. Auch hier herrscht keine absolute Sicherheit, und man versucht nicht, Unbefugte auf unbestimmte Zeit auszusperren, sondern eine Art „praktische“ Sicherheit für eine bestimmte Zeit (z. B. während der das Firmengelände nicht frequentiert wird) in Form von passenden Hürden zu schaffen.

Zuletzt gibt es in jeder Gesellschaft noch ein bestimmtes Maß an Abschreckung. Verbrechen jeder Art werden aufgedeckt, verachtet und zuletzt auch bestraft. Hierzu zählen Einrichtungen, die Verbrechen verfolgen und Urheber ermitteln, gesellschaftliche Strukturen, die Verbrechen und Verbrecher nicht dulden oder ausschließen und zuletzt auch mit Strafen verfolgen und so abschrecken. Obwohl keine einzelne Maßnahme für sich genommen perfekt ist, bilden Risiken, Hürden und Abschreckung zusammen einen Verbund, der, wenn er intakt ist, versucht, Verbrechen in der Praxis sehr selten zu machen. Hierin liegt auch zusammengefasst eine der größten Herausforderungen der IT-Sicherheit: Man müsste sie so gestalten, dass sie im Prinzip funktioniert wie praktische Sicherheit in der „echten“ Welt (B. Lampson, „Real-World Se-

curity“). Hier beobachtet Stanislaw Lem, dass „jeder einmal ein Verbrechen begehen möchte, aber nicht wie ein Verbrecher wirken mag“. Leider fehlen der IT-Sicherheit (noch) essenzielle Bausteine im Bereich der Forensik, Strafverfolgung und im gesellschaftlichen Bewusstsein, sodass man Angreifern zunächst schlicht die Gelegenheit entziehen muss. Konkret bedeutet dies in der IT-Sicherheit, dass sie sich auf die Umsetzung oder das Garantieren von Schutzzielen für Hardware, Software und Systeme konzentrieren muss.

2.1.4 Schutzziele

Ein wesentliches Problem in der IT-Sicherheit, das bis heute Bestand hat, wurde bereits in einer Studie „Security Controls for Computer Systems“ identifiziert (Ware 1970): Isolation in Systemen, die zwischen mehreren Benutzern oder Applikationen geteilt werden. Eine weitere, parallel durchgeführte Studie zur Computersicherheit in Systemen für die U.S. Air Force kam in etwa zum gleichen Schluss und machte unsichere Ressourcenteilung zum Hauptproblem. Man stellte jedoch weiter fest, dass im Grunde komplexe Systeme kaum vollständig zu verifizieren sind (d. h., dass sie den nötigen Schutz fehlerfrei ohne Bugs bieten), dass gerade große Systeme geändert werden, dass die vollständige Zertifizierung der Sicherheit damals ein ungelöstes Problem war, dass Notlaufmodi für Systeme nicht ausreichend erforscht sind und dass große Mengen an Hardware ebenfalls praktisch nicht fehlerfrei sind oder vollständig getestet werden können (Ware 1970). Die meisten dieser Schlüsse sind heute insofern überholt, als dass man praktisch aufgegeben hat, komplexe Systeme vollständig, per Hand, überprüfen oder gar zertifizieren zu wollen. Einige Projekte, die nach wie vor „Vollständigkeit“ in der Verifikation zum Anspruch haben, verwenden Betriebssysteme, die um ein Vielfaches „kleiner“ und daher auch praktisch handlicher sind als solche Betriebssysteme, die heute den Markt dominieren (z. B. Microsoft Windows, Linux, MacOS, iOS und Android). Wares Studie kann ebenfalls als eine der ersten Quellen für sogenannte „Security Control“ zitiert werden, die unter anderem die heute allgegenwärtigen Schutzziele „Vertraulichkeit“, „Integrität“ und „Verfügbarkeit“ etablieren sollen. Im englischsprachigen Raum sind sie auch bekannt unter der „CIA-Triade“ für „Confidentiality“, „Integrity“ und „Availability“. Diese Schutzziele wurden je nach Auffassung mindestens noch um „Authentifizierung“, „Autorisation“, „Prüfbarkeit“, „Privatheit“ und „Zurechenbarkeit“ bzw. „Nichtabstreitbarkeit“ über die Jahre hinweg erweitert.

Die Schutzziele sind jedoch am besten im Kontext der relevanten Schutzgüter zu verstehen: Die sogenannten Assets können dabei verschiedene wichtige Anwendungen, Dienste und Daten (z. B. Unternehmens- oder Kundendaten) umfassen. Um adäquate Schutzziele zu verfassen, muss das Schutzgut bekannt sein. Zur Sicherstellung von Schutzzielen in Form von konkreten Maßnahmen muss zusätzlich auch geklärt wer-

den, ob diese überhaupt gefährdet sind. Hierzu sind die Zusammenhänge zwischen Gefahren, Bedrohungen, Schwachstellen, Gefährdung und Angriff bzw. Verletzung wichtig:

- **Gefahr:** In der IT-Sicherheit und auch generell beschreibt die Gefahr eine Situation, die negative Auswirkungen haben kann. Gefahren stehen dabei nicht in direktem räumlichen oder zeitlichen Zusammenhang mit einem Schutzziel. Gefahren in der IT-Sicherheit können z. B. Computerviren, Botnets, Phishing- oder Denial-of-Service-Angriffe etc. sein.
- **Bedrohung:** Wenn eine Gefahr im tatsächlichen, zeitlichen oder räumlichen Zusammenhang mit einem Schutzgut steht, dann spricht man von einer Bedrohung. Ein Beispiel hierfür wäre ein Datenträger mit Schadsoftware, welcher mit einem Computersystem (das Schutzgut) verbunden ist. Dies bedeutet jedoch nicht, dass die Schadsoftware auch ausgeführt wird bzw. das Schutzgut sofort angegriffen ist.
- **Schwachstellen:** Werden oft englisch als „Vulnerabilities“ genannt und bezeichnen die Möglichkeit zur Umgehung von Sicherheitsmechanismen. Beispiele hierfür sind nicht nur schlechte Zugriffsbeschränkungen, Rollenmodelle oder unsichere Benutzerkonten (z. B. durch schwache Passwortrichtlinien), sondern auch Fehler (Bugs) in Software- und Hardwaresystemen jeder Art. Man nimmt dabei an, dass der „Industriestandard“ für Bugs pro Zeile Programmcode dabei zwischen 15 und 20 liegt – wobei weder System noch Programmiersprache sonderlich relevant scheinen (Hatton 1995).
- **Gefährdung:** Eine Gefährdung besteht immer dann, wenn Schutzgüter mit Schwachstellen in Verbindung kommen. Ein Beispiel hierfür sind die Speicherung und Verarbeitung von sensiblen Daten (d. h. das Schutzgut) auf Systemen mit veralteter und komprimierbarer Software (d. h. die Schwachstelle). Gefährdungen entstehen dabei durch unabsichtliche Handlungen (z. B. Unfälle und Unachtsamkeiten), durch absichtliche Handlungen (z. B. Sabotage) oder durch natürliche Ursachen (z. B. Ausfälle und Verwüstung durch Katastrophen).
- **Angriff:** Der Versuch, eine Schwachstelle auszunutzen, um an ein Schutzgut zu gelangen oder ein Schutzziel zu unterwandern, wird als Angriff definiert. Hierzu zählen primär vorsätzliche Handlungen, die dazu führen, dass ein oder mehrere Schutzziele gebrochen werden. Einfache Beispiele umfassen hier die Installation von Schadsoftware (Verlust der Integrität) oder der unerlaubte Zugriff auf Informationen (Verlust der Vertraulichkeit).

In der IT-Sicherheit kümmert man sich primär um Schutzmaßnahmen (Hürden), um für das Schutzgut gewisse Schutzziele zu erreichen und möglichst zu garantieren (siehe Bild 2.1). Der folgende Abschnitt geht auf eine Auswahl ein:

Sicherstellung gewünschter Schutzziele *unter widrigen Umständen*:

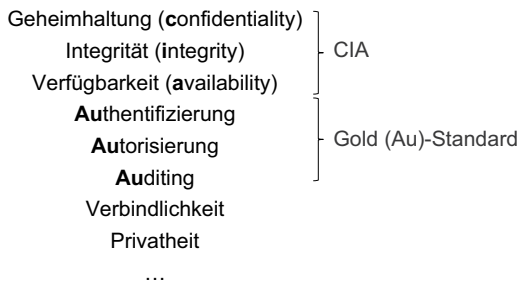


Bild 2.1 Wesentliche Schutzziele aus der Computer- und Informationssicherheit

- **Geheimhaltung** (Confidentiality): Unter Geheimhaltung versteht man die Beschränkung des Zuganges zu Informationen auf autorisierte Personen. Dazu ist jedoch stets auch ein Schutzmechanismus nötig, der Informationen vor unautorisierter Informationsgewinnung bewahrt. Bekannte Beispiele sind hierfür Regeln für den Umgang mit Informationen und allgemeine Bestimmungen für die Informationssicherheit. Solche Regeln sind in Unternehmen in der Form von Informationssicherheitsrichtlinien umzusetzen, und es bedarf sowohl Systeme, welche eine Umsetzung fasilitieren, als auch das Bewusstsein der Mitarbeitenden zur Einhaltung der Richtlinien. Einfachste Beispiele für „IS-Regeln“ stellen die Informationsklassifikationen „Öffentlich“, „Intern“ und „Geheim“ dar. Die Transition von Information (Objekte) zwischen verschiedenen Geheimhaltungsstufen und Personengruppen (Subjekten) wird insbesondere im militärischen Bereich mit Informationsflusskontrollen umgesetzt (Denning 1976). Bedingt durch die Komplexität in der Umsetzung hat sich jedoch die Zugriffskontrolle durchgesetzt. In der Zugriffskontrolle werden Personen, Gruppen oder Rollen gewisse Rechte (z. B. lesen, schreiben, ausführen) für bestimmte Objekte (z. B. Dateien) eingeräumt. Einen weiteren Baustein, um Informationen gerade in unsicheren Umgebungen (z. B. beim Transport oder während der Übertragung) geheim zu halten, stellt die Kryptografie mit zahlreichen Optionen für die effiziente Verschlüsselung ganzer Festplatten und großer Datenmengen dar.² Die Verschlüsselung von Daten im gesamten Kreislauf ihrer Nutzung ist allerdings praktisch nicht zu gewährleisten, sodass Verschlüsselung alleine nicht als ganzheitliche Lösung zu betrachten ist (Lauer 2020). Zuletzt ist zur „sicheren“ Übertragung auch die persönliche Übergabe eine Option, um die Geheimhaltung von Informationen auf dem Transportweg zwischen Parteien zu gewährleisten.
- **Integrität** (Integrity): Das Schutzziel Integrität bezieht sich meist auf Daten und beschreibt deren Vollständigkeit und die Abwesenheit von nicht gestatteten Ver-

² <https://docs.microsoft.com/en-us/windows/security/information-protection/bitlocker/bitlocker-device-encryption-overview-windows-10>

änderungen. Um die Integrität von Daten zu wahren, müssen absichtliche und unabsichtliche Veränderungen ausgeschlossen werden oder bemerkbar sein. Modifikationen können unabsichtlich, etwa als Folge von Speicher-, Bearbeitungs- oder Übertragungsfehlern, entstehen. Sie können auch absichtlich entstehen, wenn Angreifer Zugang zu Daten oder Übertragungskanälen haben. Integrität, ähnlich wie Geheimhaltung, kann teilweise organisatorisch durch Zugangskontrollen und Zugriffsregeln gewährleistet werden. Weiterhin kann man Dokumente und Dateien, die im Umlauf sein müssen, mit speziell gesicherten Originalen, die nicht im Umlauf sind, jederzeit abgleichen. Im Vergleich dazu bieten sich Zugriffskontrollen an, die wesentlich flexibler und skalierbar sind, da man lesende Zugriffe im Fall von Programmen gestatten und gleichzeitig schreibende Zugriffe für bestimmte Daten oder Programme verbieten kann. Aus praktischer Sicht sollten trotz entsprechender Vorkehrungen Veränderungen in jedem Fall immer auch bemerkbar sein, denn absichtliche und unabsichtliche Modifikationen sind schwer mit absoluter Gewissheit auszuschließen, da technische Fehler sporadisch auftreten und fehlerhafte oder umgangene Zugriffskontrollen schwer ausgeschlossen werden können. Empfehlenswert ist daher immer die Kombination solcher unterstützenden Maßnahmen mit (kryptografisch sicheren) Prüfwerten, die dann selbst gegen Modifikationen schützbar sind und als sichere Referenzwerte für Daten dienen können.

- **Verfügbarkeit** (Availability): Per Definition bedeutet die Sicherstellung der Verfügbarkeit den Ausschluss von unautorisierter oder unerwünschter Unterbrechung oder Beeinträchtigung der Nutzung oder des Zugangs zu einer Ressource. Die Verfügbarkeit kann durch Ausfälle oder Angriffe gefährdet werden, und das auf verschiedensten Ebenen. Beispielsweise kann die Verfügbarkeit eines Clouddienstes durch Naturkatastrophen und damit verbundene Ausfälle in der Stromversorgung oder Anbindung erheblich gestört werden. Die Verfügbarkeit kann auch durch gezielte Angriffe auf dort laufende Software herabgesetzt werden, weil Server abstürzen. Sie kann jedoch auch durch natürliche oder absichtlich erzeugte Überlastung verursacht werden. Letzteres ist besonders bedrohlich in Form von verteilten Angriffen, die zur Überlastung führen sollen. Diese sind bekannt als *Distributed-Denial-of-Service*-Angriffen und schwer zu verteidigen, da sie von ganzen Gerätepools (teilweise > 100 000 Geräte weltweit) ausgehen können. Ebenso sorgt das Löschen oder Zerstören von Daten (z. B. Benutzerkonten, Inventarlisten) für eine erhebliche Störung. Maßnahmen zur Steigerung der Verfügbarkeit schließen Backups und Sicherungen, die redundante Auslegung von „kritischen“ Komponenten, Systemen oder Diensten oder (hoch-)skalierbare Infrastrukturen ein. Gerade die Skalierung bei steigendem Bedarf und Erkennung von möglichen DDoS-Angriffen setzt echtzeitfähige Nutzungsstatistiken und die Überwachung von Ressourcen voraus, denn dort lassen sich Attacken oft durch ungewöhnlich starke Belastung bestimmter Ressourcen zuverlässig erkennen. Zuletzt gilt es aber, im Zuge der Steigerung auch die Krisenfestigkeit und Widerstandsfähigkeit von Systemen oder Diensten zu stär-

ken, indem man sich nicht nur um den Schutz und die Prävention, sondern auch auf die Reaktion und Behebung von Angriffen oder Ausfällen in der Vorbereitung und Planung konzentriert (White & Sjinlin 2022).

- **Authentifizierung** (Echtheit): Dieses Schutzziel betrifft sowohl Subjekte (z. B. Personen, Gruppen, Systeme, Dienste, Anwendungen etc.) und Objekte (z. B. Daten, Nachrichten etc.) und beschreibt die Möglichkeit, diese möglichst eindeutig zu identifizieren. Weiter sind in diesem Schutzziel auch oft die Urheberschaft und die Vertrauenswürdigkeit mit eingeschlossen. Beispiele hierfür wären die eindeutige Identifikation der Absenderin einer Nachricht oder die korrekte Konfiguration eines Systems im Falle der Vertrauenswürdigkeit. Subjekte, gerade Personen oder Personengruppen, werden gängig mit individuellen Benutzerkonten und Passwörtern versehen. Es stehen jedoch auch kryptografische Schlüssel, biometrische Faktoren, Tokens, SmartCards und andere Faktoren zur Verfügung, um die Identifikation zu ermöglichen. Für Systeme, Dienste und Anwendungen (z. B. Webseiten) eignen sich besonders Token, kryptografische Schlüssel und damit verbundene Zertifikate. Die korrekte Umsetzung von Authentifizierung oder Authentifikation setzt auf der Gegenseite auch die korrekte Prüfung von Eigenschaften, Passwörtern, Token und besonders Zertifikaten voraus. Letztlich bieten sich zur elektronischen Authentifikation auch sogenannte Frage-Antwort-Protokolle (engl. Challenge-Response) an, bei denen auf im Protokoll festgelegte Fragen (*Challenge*) eine mit Spezialwissen (d. h. der Identifikation dienlich) erzeugte Antwort (*Response*) gegeben wird.
- **Autorisierung**: Die Autorisierung folgt üblicherweise auf eine Identifikation eines Subjektes. In Folge der erfolgreichen Authentifizierung sollte dann geprüft werden, welche Berechtigungen das Subjekt im System hat. Der Autorisierung sind also die Identifikation und ein Regelwert vorausgesetzt, ohne diese die Handlungen und Berechtigungen im System nicht verwaltet werden können. In Zugriffskontrollsystemen sind jeder Handlung (z. B. Datei lesen, schreiben, ausführen ...) die Prüfung und anschließende Autorisation des Vorgangs vorausgesetzt. Zur effektiven Umsetzung eines Frameworks für Autorisierung wird also primär ein sicherer Monitor (oder Wächter) benötigt, der
 1. den Zugang zu Objekten erlauben oder verwehren kann,
 2. Zugriff auf ein eindeutiges Regelwerk (*Policies*) hat und
 3. isoliert von Subjekten ist und von diesen nicht beeinflusst werden kann, um so etwa Schutzmechanismen zu umgehen.
- **Auditing** (Überprüfbarkeit): Ein letzter Baustein des Zusammenspiels aus Authentifizierung und Autorisierung ist das Auditing oder die Fähigkeit, Handlungen im System nachzuvollziehen und eindeutig zuzuordnen. Audits werden typischerweise basierend auf von Systemen geführten Protokollen (d. h. Logs) sowie externen Dokumentationen über Prozesse und Abläufe geführt. Audits sind dabei nicht nur ein wesentlicher Bestandteil der Dokumentation der sicheren Produktent-

wicklung (z. B. DevSecOps³), des Betriebs (z. B. Performance und Compliance) und der Wartung, sondern sie spielen auch eine essenzielle Rolle in der Identifikation von Missbräuchen (z. B. Leaks, Umgehung der Zugriffskontrolle) oder Fehlerquellen in komplexen Systemen und tragen damit erheblich zur forensischen Analyse bei. Log-Dateien können dabei auf unterschiedlichen Systemebenen erzeugt werden und schließen Hardware, Betriebssysteme, Sicherheitsfeatures und Virenprogramme, Netzwerk-, System- und Application-Firewalls und beliebige andere Telemetrie (z. B. Lokation, Strom oder Wärmesensoren) ein. Oft entwickelt sich erst durch eine Betrachtung mehrerer Quellen ein zuverlässiges Lagebild. Beim Auditing ist es ebenfalls essenziell, dass Angriffe oder Ausfälle nicht dazu führen, dass auch die Aufzeichnungen bis dorthin nicht absichtlich vernichtet oder verändert werden können (*Forward Integrity*) (Bellare & Yee 1997), denn das „Aufräumen“ nach einem Angriff zählt zu den typischen Abläufen im Hacking. Insgesamt werden Auditing und die Überprüfbarkeit von Handlungen in digitalen Systemen in Zukunft wesentlich an Wichtigkeit gewinnen, da die Zuordnung bzw. Attributierung von Angriffen nicht nur die Strafverfolgung, sondern internationale Beziehungen beeinflusst.

- **Verbindlichkeit:** Im Sinne der Informationssicherheit bedeutet Verbindlichkeit im klassischen Sinne die eindeutige Zuordenbarkeit von Aktionen oder Informationen (Objekte) zu bestimmten Akteuren (Subjekte), wie etwa Personen, Diensten oder Systemen. Dabei baut die Verbindlichkeit auf verschiedenen Bausteinen auf: Einerseits setzt man oft voraus, dass sowohl Subjekte als auch Objekte eindeutig identifizierbar sind, und andererseits erwartet man auch Mechanismen, die eine nachträgliche Modifikation durch Dritte bemerkbar machen. Durch den Einsatz von digitalen Signaturen ist beides gegeben: Der für die Signatur verwendete Schlüssel sollte einem bestimmten Akteur zugeordnet sein, und das Objekt, z. B. eine E-Mail, wird mittels signierten Hashes (kryptografisch sicherer Prüfwert) gegen unautorisierte Modifikation geschützt. Verbindlichkeit kann jedoch auch entstehen, wenn Personen Konten mit entsprechenden Berechtigungen (z. B. neue Konten anlegen) sicher dokumentierte Aktionen durchführen (Audit).
- **Privatheit:** Die Einhaltung spezifischer Bedingungen an die Privatsphäre der Nutzer ist spätestens seit der Einführung der Datenschutz-Grundverordnung (DSGVO) integraler Bestandteil von jeglichen Systemen und Produkten. Generell versteht man heute unter Privatheit die „informationelle Selbstbestimmung“ und die Bestimmung der Nutzer über ihre Privatsphäre. Privatheit bezieht sich in der IT-Sicherheit in erster Linie auf Daten, die Aufschlüsse über bestimmte Nutzer geben. Daten werden auf unterschiedlichste Weisen erhoben und können von Benutzern direkt durch Eingaben kommen. Sie können auch durch ihr Verhalten innerhalb von Diensten gesammelt werden (z. B. Suchanfragen, Zeit, die auf bestimmten An-

³ <https://www.ibm.com/topics/devsecops>

zeigen verbraucht wird, etc.) – letztere Option ist Benutzern oft schleierhaft und wirkt bei der Verwendung oder Weitergabe besonders verletzend in Bezug auf die Privatsphäre. Es gibt jedoch verschiedene Maßnahmen zur Wahrung der Privatsphäre, wie etwa die Entwicklung hin zur sparsamen Datensammlung oder gar die Vermeidung von Daten oder des Sammelns innerhalb einer Anwendung. Die Umsetzung gestaltet sich jedoch oft schwer, denn personenbezogene Daten können „unabsichtlich“ in Log-Dateien und sonstigen Systemaufzeichnungen gespeichert werden. Sie sind dort ebenso problematisch wie absichtlich gespeicherte Daten. Neben der sparsamen Datensammlung ist auch die Zweckbindung der Daten wichtig, um Benutzern zu garantieren, dass die Daten, die unbedingt gesammelt werden müssen, auch nur zum Zweck der Erbringung der Dienstleistung gesammelt werden. Unter den vorherigen Gesichtspunkten wäre eine Datenerhebung in Form von Umfragen und dergleichen praktisch nur schwer umsetzbar. In solchen Fällen sollten Datenaggregation und Anonymisierung der Daten stattfinden, sodass sich zwar ein statistisches Gesamtbild ergibt, jedoch eine einzelne Umfrageteilnehmerin nicht identifizierbar ist. Generell können solche Probleme, bei denen Nutzerinnen nicht identifiziert werden *müssen* oder sollen, durch Anonymisierung gelöst werden. Anonymisierung zeichnet sich dabei durch die Eigenschaft aus, dass jegliche Beobachter von Daten, Prozessen etc. ein Subjekt nicht von anderen Subjekten innerhalb bestimmter Gruppen unterscheiden können.

2.2 Grundprinzipien der IT-Sicherheit

Die Sicherstellung und vor allem die Garantie dieser Schutzziele hat sich jedoch in echten Umgebungen und außerhalb von wissenschaftlichen Studien als große Herausforderung präsentiert. Leider wird dies nur selten durch Reviews und Tests im Vorfeld bestätigt, sondern durch korruptierte Systeme mit geleakten Nutzerdaten, Ausfällen und Imageschäden für betroffene Konzerne. Dies ist nicht zuletzt auch dem eingangs erwähnten Fakt geschuldet, dass Probleme (z. B. Isolation und Vertrauenswürdigkeit) bei komplexen Systemen auch heute noch schwer zu erreichen und noch schwerer zu garantieren sind. In den folgenden Abschnitten werden zehn praktische Grundprinzipien der IT-Sicherheit mit dem Ziel eingeführt, die Entwicklung und den Betrieb sicherer Systeme zu vereinfachen.

2.2.1 Kenne die Bedrohungen

Zunächst ist es wichtig, dass die Bedrohungen für ein IT-Produkt oder System bedacht werden. Bedrohungen können dabei durch Versehen, durch absichtliche Handlungen (Angriff) und durch natürliche oder Umweltfaktoren entstehen. Daher ist es wichtig

abzuwägen, welche Schutzziele priorisiert werden und gegen wen oder was sie auf welche Weise zu schützen sind. Anhand folgender Beispiele kann diese Priorisierung veranschaulicht werden:

- **Katastrophenschutz und Warnsystem des Bundes:** Hier zählt primär die Verfügbarkeit des Systems (d. h. Warnungen können immer ausgegeben werden). Zusätzlich zählen noch die Integrität (Vollständigkeit der Warnungen) und die Authentizität (falsche, besonders gezielt gefälschte Warnungen reduzieren das Vertrauen) und etwas ferner noch die Autorisierung (d. h. Berechtigung, Warnungen auszugeben). Dabei ist gegen technische Störungen, gezielte Sabotage und vor allem gegen Naturkatastrophen eine Absicherung vorzunehmen.
- **Smart Grids/Intelligente Stromnetze:** Auch hier, wie oft bei „Cyber-Physical Systems“, zählt vorrangig die Verfügbarkeit des Systems. Zusätzlich kommen noch die Integrität und Authentizität der übermittelten Daten hinzu und neuerdings mit immer mehr persönlichen Informationen auch die Geheimhaltung und die Wahrung der Privatsphäre einzelner Nutzerinnen. Zu verteidigen sind diese Schutzziele primär gegen gezielte und professionelle Angriffe auf kritische Infrastrukturen.
- **Onlinebanking:** Beim Onlinebanking zählt erstrangig die Authentizität, also die Echtheit, der Interfaces und Applikationen, welche dann selbstverständlich die Geheimhaltung, Autorisierung und Verbindlichkeit der Transaktionen wahren muss. Zu schützen sind diese Ziele besonders gegen Angreifer, die z. B. durch Phishing versuchen, Kundendaten und Autorisation durch fingierte Transaktionen zu erlangen.

Bei der Einschätzung und Abwägung von Bedrohungen gibt es eine Vielzahl von Methoden und Frameworks, welche teilweise genau auf die Domäne angepasst sind, unter der Bezeichnung „Threat Modeling“. Die Methodik beinhaltet dabei in etwa folgende Schritte:⁴⁾

- Identifikation des Schutzgutes
- Eingabe von Annahmen über das Schutzgut (z. B. wo und für welchen Zweck es wie eingesetzt wird)
- Identifikation potenzieller Bedrohungen für das Schutzgut
- Handlungsempfehlungen zur Behebung der Bedrohungslage

Letztlich sollte jedoch auch immer eine Risikobewertung und Erfolgskontrolle erfolgen, um die vorgesehenen Maßnahmen, deren Umsetzung und deren Effektivität zu evaluieren und gegebenenfalls zu verbessern.

Besonders wichtig bei diesen Einschätzungen ist dabei die Definition der erwarteten Angreifer. Angreifer können Personen, Personengruppen oder Systeme sein. Beispiele dafür sind Saboteure, Hackergruppen und Botnetze. Man unterscheidet diese weiter, um deren Motive und Fähigkeiten einzugrenzen in „Skript Kiddies“, also Amateure, in klassische „Hacker“, „Insider“ (z. B. Mitarbeitende), Wirtschaftsspione und Regie-

⁴ https://owasp.org/www-community/Threat_Modeling

rungsbehörden. Amateure verfolgen dabei eher spielerische Motive und wollen Tools oder Exploits ausprobieren, um zu schauen, ob sich daraus ein Effekt ergibt. Dieses Ausprobieren ist jedoch nicht weniger schädlich als jeder andere Angriff, jedoch sind die Fähigkeiten solcher Akteure eher begrenzt auf den Einsatz oder die Kombination von „Tools“. Klassische Hacker sind im Gegensatz dazu in der Lage, das Zielsystem sorgfältig zu studieren und so gezielt zuzuschlagen, und das auch mit vergleichsweise innovativen Mitteln, mit denen man versucht, bekannte Schwachstellen (z. B. veraltete Software) gezielt auszunutzen. Die Motivation ist hier oft finanzieller Natur, entweder im Auftrag (z. B. mit Botnetzen) oder im eigenen Interesse (z. B. mit Ransomware). Ebenso kritisch wie professionelle Hacker sind „Insider“, wie etwa vergraulte Mitarbeitende, die sich an ihrer Firma „rächen“ wollen. Das Know-how und die Fähigkeiten variieren dabei stark. Mitarbeitende sind aufgrund ihrer Stellung oder Berechtigung höchst gefährlich durch ihren Zugriff auf sensible Prozesse, Systeme oder Informationen. Am gefährlichsten in Bezug auf deren Fähigkeiten sind jedoch Wirtschaftsspione und Regierungsbehörden, da diese teilweise fantastische Budgets bereitstellen, um ihr Ziel zu erreichen. Spionage zielt dabei im Wesentlichen auf Information ab. Regierungsbehörden sind zusätzlich daran interessiert, strategische und kritische Infrastrukturen auf viele Weisen zu beeinträchtigen (Desinformation, Aufklärung, Verzögerung, Störung und physische Zerstörung).

2.2.2 Sicherheit und Wirtschaftlichkeit

Eine zeitlose Beobachtung in der IT-Sicherheit ist, dass sie weder beim Aufwand noch bei den Kosten begrenzt ist. Sie kann unendlich teuer *gestaltet* werden, und teuer bedeutet auch oft besser. Praktisch verfolgt man eine rationale Strategie und sagt, dass die IT-Sicherheit, bzw. das Budget, zum Schutzgut *passen* muss. Hier kann eine Kosten-Nutzen-Analyse hilfreich sein, in der man grundsätzlich die Kosten der Abwehr gegen den potenziellen Schaden abwägt. Einfach gesprochen würde man kein Zehn-Euro-Schloss für einen Ein-Euro-Wertgegenstand verwenden, wenn der nicht, wie etwa ein Schlüssel, zu größeren Schätzen führt.

Durch einen Perspektivwechsel kann man auch betrachten, wie teuer ein Angriff und was die potenzielle Beute wert wäre. Generell geht man hier von *rationalen Angreifern* aus, die den erwarteten Gewinn natürlich größer sehen wollen als die möglichen Kosten. Dabei umfassen die Kosten sowohl die Kosten des Angriffs und die Kosten, gefasst zu werden mit einer gewissen Eintrittswahrscheinlichkeit. Man kann also schlicht sagen, dass man Systeme so gestaltet, dass sich Angriffe nicht lohnen würden. Dieser Ansatz funktioniert in verschiedenen Domänen und kann auch bedeuten, dass manche Angriffe und Exploits zu wertvoll sind (z. B. Zero-Touch-Exploits für iPhones), um in der Breite eingesetzt zu werden, wo sie dann entdeckt und verhindert werden können.

Eine weitere Methode ist die Risikoeinschätzung, die eine Eintrittswahrscheinlichkeit mit dem potenziellen Schaden verknüpft. Die entstehende Matrix aus Wahrschein-

lichkeit und Schaden erlaubt dann die Priorisierung der Schutzmaßnahmen und die Verteilung des Budgets. Die Eintrittswahrscheinlichkeit umfasst die Motivation und den potenziellen Gewinn für Angreifer. Schäden sind jedoch nicht immer direkt zu beziffern (z. B. Gefahr für Leben, Datenverlust, IP-Verlust, Produktionsausfälle etc.), sondern umfassen auch sekundäre Faktoren, wie das Image der Firma, wenn sie ihre Kundendaten nicht schützen konnte.

Zusammenfassend ist festzustellen, dass Sicherheit immer zum Schutzgut passen muss, dass teurer oft auch besser bedeutet, dass die Sicherheit jedoch hauptsächlich den zu erwartenden Angriffen standhalten muss.

2.2.3 Keine „Security through Obscurity“

Auguste Kerckhoffs hat bereits im Jahre 1883 eines der wesentlichen Prinzipien für die Kryptografie aufgestellt, welches besagt, dass die Sicherheit eines Systems niemals auf der Geheimhaltung seiner Funktionsweise beruhen darf (Kerckhoffs 1883). Gemeint hatte er Systeme, welche die praktische Chiffrierung von Nachrichten ermöglichen und deren Sicherheit auf der Geheimhaltung des Schlüssels beruhen sollten. Die Idee dahinter ist relativ eingängig, denn beruht die Sicherheit der Verschlüsselung auf der Geheimhaltung des Systems, so ist jede Verschlüsselung gebrochen, sobald das System durch den Angreifer verstanden ist. Beruht die Verschlüsselung jedoch auf der Geheimhaltung des Schlüssels, so können unendlich viele Schlüssel verwendet werden, die der Angreifer praktisch nicht erraten kann. Selbiges Prinzip wurde anschließend von Claude E. Shannon im Jahre 1949 erweitert durch den Ausspruch „The enemy knows the system“ (Shannon 1949) – der Feind kennt das System. Sein Prinzip läuft darauf hinaus, dass man Systeme so verteidigen sollte, als wüsste der Feind beim Angriff bereits, wie diese aufgebaut und verteidigt sind. Diese Prinzipien und Maxime werden über die Zeit immer wieder unterstrichen, wenn versucht wird, durch vermeintlich komplexe Prozesse oder labyrinthartige Strukturen Angreifer zu verwirren. Kennt der Angreifer nur Teile, so ist der Schutz schnell und effizient bei jedem Versuch zu brechen. Zusätzlich sind Verfahren, z. B. Coding-Strategien, welche den Angreifer verwirren sollen, auch für Entwicklerinnen und Maintainer verwirrend und eine potenzielle zusätzliche Fehlerquelle, und das wieder zum Vorteil der Angreifer. Im Gegensatz dazu haben „offene“ Verfahren, wie etwa das Kryptoverfahren RSA, benannt nach seinen Erfindern, wesentlich zu unserer heutigen IT-Sicherheit beigetragen (Rivest, Shamir, Adleman 1978).

2.2.4 Security by Design

Das Grundprinzip „Security by Design“ verlangt, dass Sicherheit bereits im Entwurf späterer Produkte und Systeme eine wichtige Rolle spielt – ganz genauso wie Funktionalität oder Benutzbarkeit. Die Ansätze, mit denen dies ermöglicht wird, sind vielfäl-

tig und beinhalten sicherlich das Schreiben von Spezifikationen. Tatsächlich kann gesagt werden, dass ein System ohne Spezifikation nicht sicher sein kann, sondern nur zufällig. Eine Spezifikation hilft wesentlich dabei, ein System zu verstehen, bevor (oft auch nachdem) man es entwickelt hat (Lampson 2002). Dabei ist es wichtig zu verinnerlichen, dass es bis heute keine Axiome für IT-Sicherheit gibt. Es gibt ebenso wenig Modelle, die generell für jedes System einsetzbar wären, und so müssen Produkte und Systeme einzeln betrachtet werden. Weiterhin hilft die Unterscheidung in Systeme, die man überhaupt spezifizieren kann und sollte, und solche, bei denen eine Spezifikation noch nicht umsetzbar ist. Systeme, die genaue Anforderungen haben, dazu zählen beispielsweise Bankensoftware, Industriesteuerungen, und Avioniksysteme, sind *präzise* und sollten dementsprechend auch spezifiziert werden und spezifizierbar sein. Software und Systeme wie etwa Suchmaschinen oder Social-Media-Sites ändern sich oft im Minutentakt und sind von vornherein viel weniger präzise beschrieben, sodass eine Spezifikation weder erstellt noch effektiv aktualisiert werden kann. Ist das System spezifizierbar, dann erstellt man ein Modell, definiert Aktionen oder Transitionen im System und überprüft anschließend, ob der geschriebene Code oder die definierten Prozesse die spezifizierten Transaktionen im Modell nachbilden. So einfach dieser Ablauf klingt, so abhängig ist er vom Detailgrad und von der Komplexität des Systems. Eine Spezifikation kann sehr schnell sehr aufwendig werden und bei falscher Modellierung auch ganz zwecklos sein.

Es gibt jedoch verschiedene Methoden, um eine Security-by-Design-Strategie für ein Produkt umzusetzen (siehe Bild 2.2).

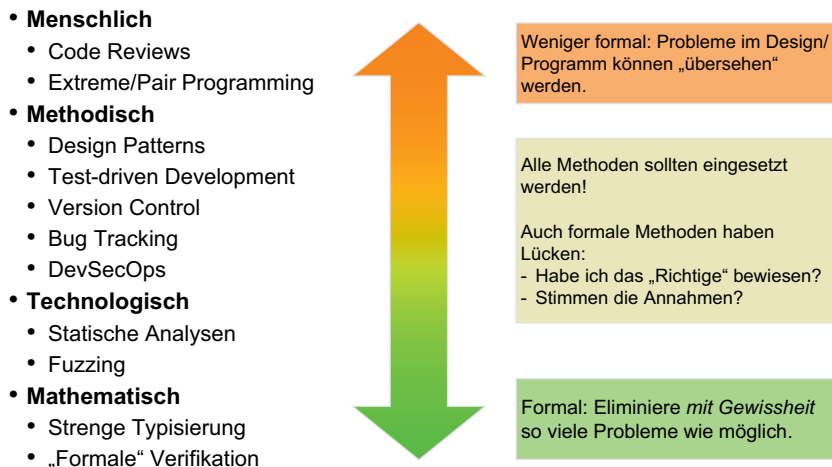


Bild 2.2 Übersicht verschiedener Ansätze zur Verbesserung der Software- und Systemsicherheit

Dabei sind die gelisteten Optionen keineswegs vollständig und sollten optimalerweise miteinander kombiniert werden.

2.2.5 Prinzip der geringsten Berechtigung

Das Prinzip der geringsten Berechtigung sagt aus, dass Personen, Systeme, Programme zu jedem Zeitpunkt nur die Berechtigung haben, die der Akteur unbedingt zur Bearbeitung benötigt. Ein wichtiger Zusatz ist die Bemerkung, dass diese Berechtigungen auch nur zeitweise in Anspruch genommen werden sollen (z. B. das Anlegen und Löschen von Kundeninformationen muss nur innerhalb der Geschäftszeiten erlaubt sein). Die Umsetzung bedeutet, dass Programme, Personen oder Module nur die Berechtigungen haben, die sie zu einem bestimmten Arbeitsschritt (z. B. in der Datenverarbeitung) unbedingt brauchen. Dazu benötigt man einerseits ein Benutzer- und Rollenverzeichnis und andererseits einen Zugriffskontrollmechanismus, der die Berechtigungen vergibt, kontrolliert und auch wieder entzieht. Aus Erfahrung hat sich gezeigt, dass zu viele unnötig erworbene Berechtigungen dazu führen, dass unbeabsichtigt Daten „geleakt“ werden und Missbrauch durch Dritte ermöglicht wird. Einfache Beispiele sind hierbei Benutzerkonten in Systemen, die über die Zeit verschiedene Rollen innehatten (z. B. Mitarbeitende, Abteilungsleitung, Buchhaltung und Bestellung) und diese nie entzogen bekommen haben. Im Effekt hat man so ein Konto, das vielleicht zu einer Mitarbeiterin gehört, die aber noch die Berechtigungen und die Einsicht der Abteilungsleitung besitzt, oder Mitarbeitende, die Einfluss auf die Buchhaltung und auf die Bestellung haben. In Betriebssystemen findet sich die Umsetzung schon in der Unterscheidung zwischen „User“ und „Superuser“, den Admin-Rollen, die nur zeitweise verwendet werden sollen. Hierin liegt auch die Herausforderung bei der Umsetzung: In letzter Instanz ist zumindest bei IT-Systemen das Betriebssystem für die Umsetzung der Rechte verantwortlich, und dazu zählt auch, dass Prozesse und deren Benutzer voneinander isoliert werden können und dass die Zugriffskontrollmechanismen für Interaktionen umgesetzt werden. Generell sollten also Benutzer nur Berechtigungen für ihre eigenen Daten und Prozesse haben und erst nach Authentifizierung und Autorisierung andere Rollen annehmen dürfen. Ist ein Prozess beendet, so müssen Rolle und damit verbundene Berechtigungen zurückgegeben werden. Ein guter Ansatz, um dem Prinzip gerecht zu werden, ist es, die Berechtigungen zu jedem Zeitpunkt, mit welchem Mechanismus auch immer, so weit wie möglich einzuschränken.

2.2.6 Trennung der Verantwortlichkeiten

Die Trennung von Verantwortlichkeiten ist ein Sicherheitsprinzip, das nicht erst mit der Computer- und IT-Sicherheit aufgekommen ist. Die Idee ist, dass man Verantwortlichkeiten und Berechtigungen stets voneinander trennt. Dies kann durch granulare Rollen und Rechtevergaben passieren, die ein Akteur nicht gleichzeitig innehaben kann (z. B. Vorsitzende ist nicht gleichzeitig Kassiererin). Ein klassisches Beispiel stellt

das „Vieraugenprinzip“ dar, in dem gewisse Aktionen nur von zwei verschiedenen Personen autorisiert werden können. Ebenso kann die Trennung von Verantwortlichkeiten Unzuverlässigkeit verschiedener Akteure abmildern, indem z. B. auf dem Weg zum Löschen von Kundendatenbanken mehrere Stellen der Aktion zustimmen müssen.

2.2.7 Zugriffskontrolle

Die vorherigen Prinzipien und essenzielle Schutzziele werden oft im Zusammenhang mit einem der elementarsten Bausteine der IT-Sicherheit beschrieben: der Zugriffskontrolle. Die Grundlage für Zugriffskontrolle stellt die Isolation dar. Die primäre Aufgabe der Zugriffskontrolle ist die Überwachung und Autorisation von Zugriffen der Akteure mit kontrollierten Ressourcen (z. B. Dateien, Geräte, Schnittstellen etc.). Eine funktionierende Zugriffskontrolle ist dabei die Grundlage für die Sicherstellung von Geheimhaltung und Integrität von Informationen. Wichtige Bausteine für die Zugriffskontrolle sind dabei: isolierte Systembereiche, Kontrolle über den Datenfluss und ein Regelwerk, welches wenigstens Subjekte, Objekte und Rechte definiert (siehe Bild 2.3).

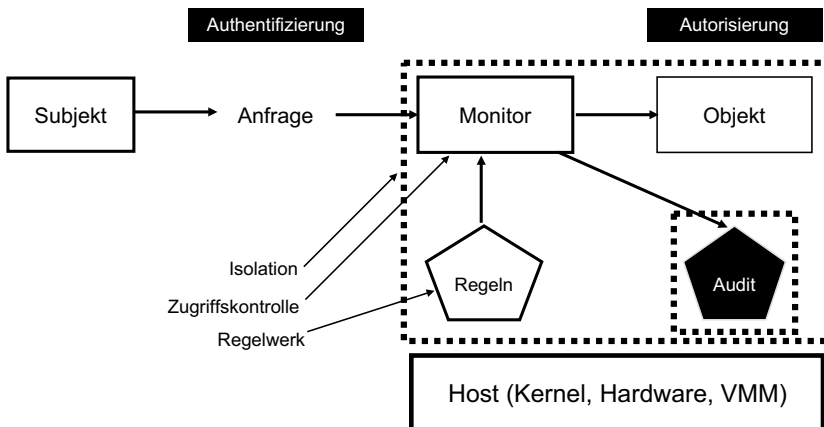


Bild 2.3 Beispielhafte Darstellung eines Zugriffskontrollsystems mit den wesentlichen Komponenten und den Schutzzielen

Der Ablauf ist dabei wie folgt: Ein Subjekt stellt eine Anfrage (z. B. *lese* Datei X) zusammen mit seiner Identifikation (Authentifizierung). Die Anfrage geht an einen Monitor oder Wächter. Der Monitor wird durch das Regelwerk informiert und entscheidet über den Zugriff (Autorisierung). In jedem Fall wird sowohl Anfrage als auch Entscheidung geloggt (Audit). Im Falle einer positiven Entscheidung kann auf die Datei anschließend lesend zugegriffen werden. Die Zugriffskontrolle kann dementspre-

chend auch den Goldstandard (Au) der Schutzziele, **Authentifizierung**, **Autorisierung** und **Auditability**, erfüllen. Die Authentifizierung dient dabei der Klärung der Frage der Subjekte, die Autorisierung klärt den Zugriff auf Objekte von Subjekten und das Audit sorgt für die Dokumentation der Vorgänge.

2.2.8 Defense in Depth

Defense in Depth ist am besten mit dem überlappenden Einsatz von IT-Sicherheitsmaßnahmen von den obersten bis in die untersten Systemschichten zu erklären. Dabei stehen verschiedenste Methoden und Maßnahmen zur Verfügung:

- **Firewalls:** Firewalls auf verschiedenen Ebenen sind nützlich, um Systeme vor „auswärtigen“ Gefahren (z. B. Angriffe über das Internet) zu schützen. Man setzt jedoch immer häufiger und aus gutem Grund auf mehr Trennung und Isolation auch in internen Netzen und damit auf mehrere Firewalls zwischen Netzwerken, Systemen und sogar Applikationen.
- **Signaturerkennung:** Die Signaturerkennung ist essenzieller Bestandteil von Anti-Viren-Scannern und Programmen, die Angriffe auf verschiedenen Systemebenen erkennen sollten. Dabei können u. a. Netzwerkdaten Aufschluss geben und bekannte Viren und Würmer entlarven, System-Logs können die typischen Vorgehensweisen von Angreifern aufweisen, und Schadsoftware kann im Programmcode als solche erkannt werden.
- **Memory Safety:** Die Speichersicherheit ist eine Entwicklung, die notwendig war, da immer mehr sog. Buffer-Overflow-Attacken durch verschiedenste Programmierfehler möglich waren. Bei solchen Attacken versucht der Angreifer gezielt den Speicher zum Überlauf zu bringen, um damit auf Speicherregionen (z. B. Prozesse) zuzugreifen, die für ihn gesperrt sind. Im schlimmsten Fall erlangen Angreifer so „Adminrechte“ oder können Code mit fremden Berechtigungen ausführen.
- **Intrusion Detection:** Die klassische Angriffserkennung ist essenziell, um verdächtige Aktivitäten zu bemerken. Die erkannten Angriffe werden dann üblicherweise an ein weiteres System (z. B. das „Security Operations Center“) zur Behandlung von und Reaktion auf Angriffe weitergeleitet.
- **Control-flow Integrity:** Die Überprüfung der Programmflüsse ist eine weitere Methode, die beispielsweise für das Checken von Software und Prozessen angeführt wird. Programme können so z. B. während ihrer Ausführung daraufhin überprüft werden, ob der Programmfluss wie beschrieben stattfindet. Man kann hierdurch eine Vielzahl von Angriffen abfangen, die bestehende Programme und deren Ausführung für ihre Zwecke manipulieren wollen.

- **Security-Prozesse:** Weiterhin gibt es auch sehr vollständige Prozesse, die bei der Entwicklung und dem Betrieb von sicheren Systemen und sicherer Software zurate gezogen werden.⁵⁾ Die Absicht dieser Prozesse ist üblicherweise, durch definierte und nachvollziehbare Schritte der Aktionen während der Phasen, Sicherheit von Beginn an und kontinuierlich zu berücksichtigen.

Keine der oben genannten Maßnahmen ist für sich allein genommen „ausreichend“. Die Sicherheit eines Systems ist erst dann hergestellt, wenn seine Angriffsflächen durch eine Kombination der verschiedenen Mittel ausreichend (*Kenne die Bedrohungen, Sicherheit und Wirtschaftlichkeit*) abgedeckt sind.

2.2.9 Der Mensch als Faktor

Angelehnt an ein weiteres von Kerckhoffs Prinzipien, muss ein kryptografisches System von Menschen ohne allzu große kognitive Anstrengungen sicher nutzbar sein (Kerckhoffs 1883). Dieses Prinzip kann heute auf Systeme allgemein übertragen werden, denn Menschen müssen prinzipiell ohne große Anstrengung in der Lage sein, diese *sicher* zu bedienen. Menschen spielen in den meisten Fällen eine entscheidende Rolle – ob in der Entwicklung, Anwendung oder in der Administration. Dabei sollte man sich erinnern, dass perfekte Sicherheit nicht umsetzbar ist: Passwortrichtlinien können perfekt entworfen sein und sind doch nutzlos, wenn die Passwörter auf dem Schreibtisch notiert werden. Rollen und Rechtssysteme können vollständig und konfliktfrei definiert werden und sind nutzlos, wenn die Nutzer ihre Rollen untereinander tauschen, falls das System zu restriktiv und der Arbeit hinderlich erscheint. Menschen in verschiedenen Rollen müssen daher immer in die Entwurfsentscheidungen mit einbezogen werden, und man sollte bedenken, dass in der „echten Welt“ oft Bequemlichkeit über Sicherheit siegt. Mitarbeitende werden immer Lücken finden, um vermeintlich sperrige Systeme zu umgehen, wenn dies ihren Arbeitsalltag erleichtert.

Des Weiteren können auch in der Entwicklung etliche Fehler entstehen, die nicht allein durch einfaches Design („keep it simple, stupid“) und Tools zu vermeiden sind. Programmierende und Admins müssen geschult werden, und es muss Prozesse geben, die davon ausgehen, dass in der Entwicklung Fehler passieren. Zusätzlich ist in der Entwicklung je nach Domäne oft der Einsatz von potenziell unsicheren Tools notwendig. In solchen Fällen steigt die Notwendigkeit für Prozesse, die eventuelle Fehler aufdecken können besonders. Hinzu kommt, dass beinahe jede andere Rolle, die ein Mensch in diesem Szenario einnimmt, auf die eine oder andere Weise auf „Social Engineering“-Attacken abzielt, um sich Zugang zu Gebäuden, Computersystemen, Diensten, Anwendungen, Daten oder Informationen allgemein zu verschaffen. „Social En-

⁵ <https://www.microsoft.com/en-us/securityengineering/sdl>

„Engineering“-Attacken sind dabei oft das Mittel der Wahl, um vermeintlich sichere Systeme zu brechen: Angreifer können sich so Insiderwissen, Identitäten oder gar Zugangsdaten besorgen, um damit für sie systemisch unüberwindbare Hürden doch zu umgehen. Zum Einsatz kommen dabei verschiedene Formen des „Social Engineerings“. Zusammenfassen kann man die Ziele aber wie folgt: „Lass jemanden etwas glauben“, „lasse jemanden auf etwas vertrauen“, „bringe jemanden dazu, etwas zu glauben“, „bringe jemanden dazu, Zugang zu gewähren“, „bringe jemanden dazu, etwas auszuhändigen“. Solche Angriffe involvieren fast immer Fälschungen wie E-Mails, Webseiten, Ausweise, Zertifikate, Karten, Adressen und werden mehr oder weniger gezielt in Spam, Phishing, Spoofing oder Junk-Mail verwendet.

Als Schlussfolgerung der Betrachtung des Menschen als wesentlichen Faktor für die Sicherheit bleibt, dass Produkte unbedingt auf deren sichere Handhabung hin getestet, dass Entwicklungs- und Betriebsprozesse mit entsprechenden Reviews und Audits versehen und dass Menschen im Umgang mit sicheren Systemen geschult werden müssen, um zumindest offensichtliche Fälschungen und Gefahren erkennen zu können.

2.2.10 Design for Resilience

Das letzte einzuführende Grundprinzip lautet „Design for Resilience“ und bedeutet übersetzt in etwa „Planung für Krisen“. Das Prinzip ist motiviert durch einige Beobachtungen: Absolute Sicherheit ist unerreichbar und nicht praktikabel. Perfekt sichere Systeme existieren nicht. Firewalls können nicht vor allen Bedrohungen schützen. Ein Fokus auf Schutz, Verschlüsselung und Angriffserkennung genügt nicht bei erfolgreichen Angriffen. Aus diesen Beobachtungen lassen sich Schlüsse ziehen: Erfolgreiche Angriffe müssen in einem IT-Sicherheitskonzept mit eingeplant werden („Assume Breach“). Systeme müssen in potenziell gefährlichen Umgebungen ohne physischen Schutz betrieben werden (z. B. beim Kunden, in der Cloud, ohne physischen Schutz etc.). Systeme müssen sowohl Ausfällen (bei verteilten Systemen) und Angriffen widerstehen können und ihre Dienstleistung erbringen. Die vielleicht wichtigste Schlussfolgerung ist, dass eine gute Strategie für die Wiederherstellung eines getroffenen Systems manchmal wertvoller ist als Schutzmaßnahmen.

Eine Methode, um z. B. die Betriebssicherheit eines Systems zu erreichen, ist die Verwendung von sogenannten „Fail-Safe“-Modi oder Notlaufmodi, die es ermöglichen, eine bestimmte grundlegende Funktionalität zu wahren, ohne das System oder die Benutzer (primär) dabei zu gefährden. Ein gutes Beispiel ist hier der Notlaufmodus eines Fahrzeuges, welcher bei erkannten Problemen die Schleichfahrt zur Werkstatt erlaubt, jedoch gefährliche Drehzahlen vermeidet. Bei Computersystemen kann man sich anhand des Beispiels eines IoT-Gerätes zur Steuerung des Haushaltsstroms in etwa vorstellen, dass bei voller Funktionalität eine Steuerung der Lichter und Geräte

per App möglich ist. Sind jedoch Angriffe erkannt oder sind Komponenten kompromittiert worden, so erlaubt das IoT-System lediglich die Steuerung der Geräte über physische Schalter vor Ort und isoliert anfällige Features von der eigentlichen Funktion. Hier gilt es, die Betriebssicherheit und die operativen Ziele gegen die IT-Sicherheit abzuwägen. Weiterhin bedarf es technischer Mittel, um Funktionen sicher zu separieren und zu isolieren, sodass Systeme tatsächlich in einen Notlaufmodus kommen, der nicht selbst kompromittiert ist.

Notlaufmodi erlauben uns, die Grundfunktionen eines Systems aufrechtzuerhalten. Eine Definition dafür ist, dass Systeme in der Lage sein müssen, ihre Dienstleistung zu erbringen, und das auch unter widrigen Umständen. Die „widrigen Umstände“ können dabei Angriffe und Ausfälle sein. Diese Eigenschaft ist besonders wichtig, da Systeme aus Plattformen bestehen und diese wiederum aus Geräten. Fallen nun Geräte aus, durch Störungen oder Angriffe, so propagieren sich diese Probleme schnell bis hin zu einem inoperablen System (siehe Bild 2.4).

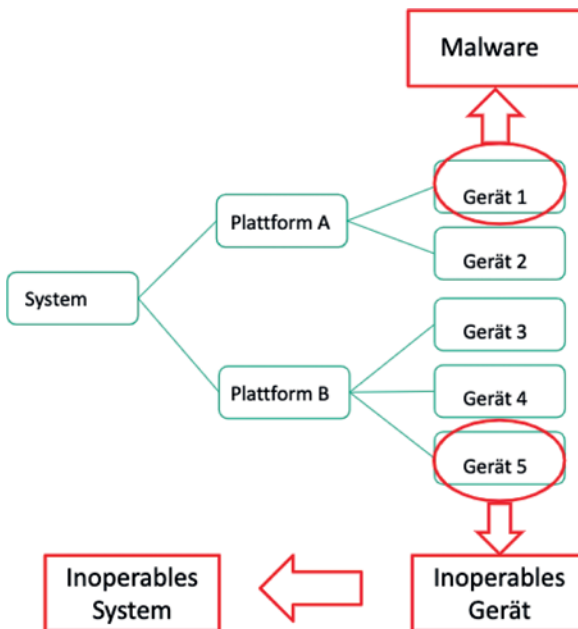


Bild 2.4

Darstellung von Sicherheitsproblemen an Endpunkten, welche jedoch auf Plattformen und ganze Systeme einwirken können

Zusätzlich zur Fehlerisolation braucht es, besonders dann, wenn es keine Redundanz gibt, eine Möglichkeit zur Wiederherstellung der Geräte. Die Wiederherstellung sollte dabei das Gerät in einen möglichst vertrauenswürdigen Zustand bringen (z. B. durch Booten in eine sichere Partition). Ist ein Angriff oder eine Störung erkannt, so muss gehandelt werden. Kann das System nicht ohne Weiteres abgeschaltet oder neu gestartet werden, so muss ein Notlaufmodus verwendet werden. Eventuell sollte jedoch ein Zeitfenster vorgesehen sein, in dem das Gerät von sicheren Images neu aufgesetzt

werden kann, sodass ein vertrauenswürdiges System nach einem weiteren Neustart vorliegt. Besser wäre der Neustart in einen Zustand, der den letzten Angriff verhindert, sodass dieser in Zukunft nicht einfach wiederholt werden kann. Jedoch werden Angriffe oft über lange Zeit vorbereitet, und technische Fehler treten typischerweise sporadisch auf, sodass auch ein Neustart in einen nur vermeintlich sicheren Modus einen wesentlichen Vorteil bietet.

Literatur

- Bellare, Mihir; Yee, Bennet: *Forward integrity for secure audit logs*. Vol. 184. Technical report, Computer Science and Engineering Department, University of California at San Diego, 1997.
- Denning, Dorothy E: *A lattice model of secure information flow*. *Communications of the ACM* 19.5 (1976): S. 236 – 243.
- Hatton, Les: *Programming Languages and Safety-Related Systems*. Achievement and Assurance of Safety. Springer, London, 1995. S. 48 – 64.
- Kerckhoffs, Auguste: *La cryptographie militaire*. In: *Journal des sciences militaires*, Vol. IX (1883), S. 5 – 38.
- Lampson, Butler: *Formal Methods For Design* (2002). <http://bwlampson.site/Slides/FormalMethodsForDesignAbstract.htm>. Abgerufen am 15.12.2021.
- Lampson, Butler: *Real-World Security* (2005). <http://bwl-website.s3-website-us-east-2.amazonaws.com/Slides/Old/Security.PDF>. Abgerufen am 15.12.2021.
- Lauer, Hagen Reinhard: *Security and Trust in Virtual Environments*. Diss. Monash University, 2020.
- Rivest, Ronald L., Adi Shamir, Adleman, Leonard: *A method for obtaining digital signatures and public-key cryptosystems*. In: *Communications of the ACM* 21.2 (1978), S. 120 – 126.
- Shannon, Claude E: *Communication theory of secrecy systems*. In: *The Bell system technical journal*, 28.4 (1949), S. 656 – 715.
- Ware, W. H.: *Security controls for computer systems*. RAND CORP SANTA MONICA CA, 1970.
- White, Gregory B.; Sjin, Natalie. *The NIST Cybersecurity Framework. Research Anthology on Business Aspects of Cybersecurity*. IGI Global, 2022. S. 39 – 55.

3

Organisation des IT-Sicherheitsmanagements im Unternehmen

Markus Nauroth



In diesem Beitrag erfahren Sie,

- welche grundlegenden Funktionen das IT-Sicherheitsmanagement in heutigen Unternehmen übernimmt,
- welche Alternativen beim Aufbau einer Organisation des IT-Sicherheitsmanagements Unternehmen abhängig von Unternehmensgröße und vorhandener Expertise bestehen und
- welche entscheidenden Aufgaben das IT Risk Council (ITRC) und der Chief Information Security Officer (CISO) innerhalb der IT-Sicherheitsorganisation übernehmen.

Das Sicherheitsmanagement im Allgemeinen und das IT-Sicherheitsmanagement im Besonderen ist vermutlich noch immer eines der am stärksten kontrovers diskutierten Themen der Unternehmenswelt. Auch seitens der Wissenschaft gibt es hierzu keine einheitliche Sichtweise, und die sich stets und schnell ändernden Bedrohungsszenarien lassen vermuten, dass sich eine einheitliche Antwort auf diese Fragen niemals finden lässt. Vielmehr bleibt es im Ermessen jedes einzelnen Unternehmens, die Ausgestaltung eines IT-Sicherheitsmanagements an den wahrgenommenen Risiken sowie den mit der Implementierung notwendiger Organisationsstrukturen verbundenen Aufwänden auszurichten. Der folgende Beitrag wird Optionen und mögliche Vorgehensweisen bei der Implementierung einer Organisation eines IT-Sicherheitsmanagements aufzeigen, um Entscheidern grundlegende Werkzeuge an die Hand zu geben, welche eine Bewertung von alternativen Vorgehensweisen und Umsetzungen erlauben.

3.1 Einführende Bemerkungen

Die Rolle der Unternehmenssicherheit wird oft missverstanden, ist bestenfalls umstritten und wird häufig von internen Konflikten überschattet. Die Wahrnehmung von Sicherheit als unnötigem Kostenblock ändert sich langsam, und die Unternehmen erkennen zunehmend, dass Sicherheit nicht nur dem Schutz von Vermögenswerten dient, sondern tatsächlich einen Mehrwert für wichtige Geschäftsprozesse darstellt. Leider fehlt es jedoch in vielen Unternehmen noch immer an hinreichender Expertise und Verständnis für diese grundlegende Fragestellung.

Auch die Sicherheit trägt ihren Teil zu diesem Mangel an Verständnis bei, insbesondere aufgrund ihrer traditionell eher introvertierten und auf Geheimhaltung ihrer inneren Mechanismen ausgelegten Natur. Viele Sicherheitsfachleute verstehen nicht, dass Unternehmenssicherheit weit mehr ist als nur eine Reihe von Sicherheitsprozessen, die in einem Unternehmen physisch durchgeführt werden. Vielfach kommen Sicherheitsfachleute in Unternehmen ursprünglich von Militär oder Polizei und wechseln erst spät in ihrer Karriere zur Unternehmenssicherheit. Die eigentliche Herausforderung besteht darin, die Sicherheitsgrundsätze und -philosophien mit der – in der Regel völlig gegensätzlichen – unternehmerischen Denkweise und der grundlegend anderen Perspektive in Einklang zu bringen, die neue Kompetenzen und zeitgemäße Fähigkeiten erfordern. Da Sicherheitsexperten meist aus Umgebungen stammen, in denen Sicherheit das Kerngeschäft ist, werden sie beim Wechsel in ein gewinnorientiertes Unternehmen nicht nur mit unterschiedlichen Prioritäten, „gegensätzlichen“ Philosophien und sich widersprechenden Bewertungen, sondern auch mit deutlich geringeren Budgets konfrontiert.

Ein Beispiel, das den Mangel an Verständnis in dieser Art von Zusammenspiel zwischen Unternehmen und Sicherheit veranschaulichen kann, ist die unterschiedliche Wahrnehmung von Begriffen wie Risiko, Schutz, Wert und Effizienz. Im Gegensatz zur Sicherheit versteht die Wirtschaft unter Risiko das Finanz- und Investitionsrisiko, während Schutz eher im rechtlichen und versicherungstechnischen als im tatsächlichen Sinne wahrgenommen wird. Was den Wert anbelangt, so misst die Wirtschaft den Wert ihres Produkts an den Kosten und dem Gewinn, während die Sicherheitsbranche den Wert eines Produkts an der Motivation zur Begehung von Straftaten misst und die Risiken auf der Grundlage dieses Werts berechnet. Schließlich bedeutet Effizienz im Sicherheitsjargon, dass ein Ziel unabhängig von den damit einhergehenden Kosten erreicht wird, während in der Wirtschaft ein Prozess nur dann effizient ist, wenn er kosteneffektiv ist.

In diesem Spannungsfeld also bewegt sich nebst der Unternehmenssicherheit auch insbesondere das IT-Sicherheitsmanagement, und diesem muss die Organisation des IT-Sicherheitsmanagements im Unternehmen Rechnung tragen.

3.2 Imperative des IT-Sicherheitsmanagements

Der Aufbau einer Organisation für das IT-Sicherheitsmanagement sollte einigen wenigen Imperativen folgen, die für eine erfolgreiche Umsetzung des Sicherheitsgedankens im Unternehmen unerlässlich sind.

3.2.1 Sicherheit ist aktiv und proaktiv

Unabhängig von dem verwendeten Sicherheitsmodell steht ein Grundprinzip der Sicherheit außer Frage: Sicherheit muss immer aktiv und proaktiv sein. In der Sicherheit, wie auch in der Natur, ist das Aktive dem Passiven immer überlegen, unabhängig von den jeweiligen Kräften. Zum Beispiel wird Wasser einen stärkeren, aber passiven Felsen formen, während die Wurzeln eines Baumes statischen Beton brechen und Metall verbiegen werden, einzig aufgrund ihrer anhaltenden Aktivität und Bewegung.

3.2.2 Routine

Routine hat zwei Seiten: eine positive und eine negative. In beiderlei Hinsicht ist die Routine einer der wichtigsten Aspekte der Sicherheit. Die Einhaltung eines Musters (Routine) ist ein negativer Aspekt der Routine. Das Durchbrechen der Routine ist eine goldene Regel der Sicherheit. So besteht eines der wichtigsten Ziele des Sicherheitsmanagements darin, einen Angriff in der frühestmöglichen Phase zu stoppen – in der Phase der Informationsbeschaffung. Ein Angreifer benötigt möglichst viele Informationen über unsere Routine, um einen Angriff planen zu können. Nicht in der Lage zu sein, diese Informationen zu sammeln, dient bereits als erste Abschreckung eines potenziellen Angreifers. Gleichzeitig bietet Routine natürlich auch die Gewähr, erprobten und als sicher bewerteten Verfahren zu folgen. Es ist diese Routine, die in der täglichen Arbeit und gerade im Umgang mit sicherheitsrelevanten Informationen die Gewissheit vermittelt, sich keinen unnötigen Risiken auszusetzen.

3.2.3 Sicherheit liegt in der Verantwortung eines jeden

Die Rolle der Sicherheitsfachleute besteht darin, die Verfahren zur Sicherheit zu bewerten, zu entwerfen, umzusetzen, zu leiten, zu verwalten und zu kontrollieren. Dennoch kann kein Sicherheitssystem funktionieren, wenn Sicherheitsexperten einzig als Verantwortliche für Sicherheit angesehen werden, ohne dass alle Personen im System einbezogen werden und ihren Teil dazu beitragen.

3.2.4 Worst-Case-Szenario

Einer der grundlegenden Sicherheitsgrundsätze besteht darin, bei der Entwicklung von Schutzstrategien das Worst-Case-Szenario zu berücksichtigen und Angriffe danach zu bewerten, welchen größtmöglichen Schaden diese anrichten könnten.

3.2.5 Es bedarf vieler Unterstützer

Der Erfolg jedes Sicherheitssystems hängt in hohem Maße von der Fähigkeit ab, Helfer zu rekrutieren, Informationen zu sammeln und alle Personen im Unternehmen für die Gefahren zu sensibilisieren. Um dieses Ziel zu erreichen, ist es entscheidend, motivierte Mitarbeiter zu haben, die ein persönliches Interesse daran haben, dieses Unterfangen zu unterstützen. Allen Mitarbeitern im Unternehmen muss deutlich werden, dass Sicherheit auch ihr persönliches Anliegen ist.

3.2.6 Denken wie ein Angreifer

Um Schwachstellen und Lücken in Systemen und die wahrscheinlichen Vorgehensweisen von möglichen Angreifern umfänglich zu erfassen, muss man sich in deren Lage versetzen. Wenn beispielsweise Informationen über die eigene Infrastruktur gesammelt werden, so werden Erkenntnisse gewonnen, welche Modelle sich für die Sammlung von Informationen eignen und an welchen Orten sie gesammelt werden können. Es liefert auch klare Hinweise darauf, wie leicht oder schwer es ist, die eigene Infrastruktur zu „erkunden“. Es wird deutlich, wo Schwachstellen liegen und an welchen Stellen es sich lohnt, Informationen abzugreifen. Indem ein Angriff simuliert wird, finden sich die besten Vorbereitungspunkte für einen Angriff. Das gewählte Vorgehen hierbei sollte selbstredend der wahrscheinlichen Bedrohung entsprechen. Es ist ein Unterschied, ob wir durch externe Angreifer oder durch den möglich Diebstahl Informationen durch interne Mitarbeiter bedroht sind.

3.2.7 Mehrschichtige Verteidigung verwenden

Die mehrschichtige Verteidigung ist ein Modell, bei dem mehrere Sicherheitskontrollen zum Schutz kombiniert werden. Obwohl es von Wissenschaftlern oft als optionales Modell betrachtet wird, ist die mehrschichtige Verteidigung eines der Grundprinzipien der Sicherheit. Auch wenn Sicherheitssysteme oft als bemannte kreisförmig gegliederte Bewachungssysteme gedacht werden, so müssen alle Ebenen eines Schutzsystems verstanden werden.

3.3 Grundlegende Pfeiler einer IT-Sicherheitsorganisation

Sicherheit, Datenschutz und Compliance sind keine technischen Probleme, die alleine von Fachleuten gelöst werden können. Diese Themen sind Top-down-Initiativen, die direkt mit den Grundfesten des Unternehmens wie beispielsweise dessen Ruf bzw. der langfristigen Nachhaltigkeit verbunden sind.

Ohne ein effektives Sicherheitsprogramm sowie ohne die Fähigkeit, dieses Vorgehen anderen gegenüber wirksam zu kommunizieren, kann das Vertrauen potenzieller und bestehender Kunden, Partner und Stakeholder nicht gewonnen bzw. aufrechterhalten werden. Nur wenige andere Unternehmensprobleme sind so grundlegend angelegt.

In diesem Kapitel wird erörtert, wie eine Organisationsstruktur so optimiert werden kann, dass Sicherheit und Compliance nahtlos ineinander übergehen, ohne das Führungsteam über Gebühr zu belasten oder unnötigen bürokratischen Aufwand zu verursachen. Darüber hinaus wird eine Reihe von Optionen für die Organisationsstruktur vorgestellt, die sich nach dem Reifegrad des Unternehmens richten, und es werden die typischen Rollen und Verantwortlichkeiten von Führungskräften erläutert.

Die grundlegenden Säulen der Organisationsstruktur eines Sicherheitsprogramms gleichen sich, unabhängig von Größe oder Komplexität des Unternehmens.

- **Top-Level-Leadership:** Dazu gehören die Mitglieder des Führungsteams, die die Autorität und den Einblick haben, um Entscheidungen im Namen des Unternehmens zu treffen. Sie können die Sicherheit im Lichte der Unternehmensziele angemessen einstufen und bestimmen wesentlich die Strategie, den Auftrag, die Ziele und die Organisation eines Sicherheitsmanagements. Der Executive Sponsor ist auch für die Genehmigung des Budgets zuständig.
- **CISO (oder gleichwertig):** Das ist letztlich eine Person, die für das Sicherheitsprogramm verantwortlich und rechenschaftspflichtig ist. In vielen Unternehmen ist dies ein offizieller CISO, in anderen Unternehmen ist dies eine Person, die Sicherheit als zusätzliche Aufgabe hat oder den Vorsitz im Sicherheitsausschuss führt. In jedem Fall sollte eine einzelne Person mit der formellen Leitung des Sicherheitsprogramms betraut werden.
- **Information Technology Risk Council (ITRC):** Der ITRC ist ein funktionsübergreifender Ausschuss, der die IT-Sicherheitsstrategie plant, die Sicherheitsrichtlinien bestimmt und Prioritäten festlegt. Das Hauptziel des ITRC besteht darin, alle Beteiligten des Unternehmens regelmäßig an einen Tisch zu bringen, um Entscheidungen in Bezug auf die Informationssicherheit zu treffen. Da diese Art von Entscheidungen in direktem Zusammenhang mit den Geschäftszielen stehen und von den Aktivitäten im gesamten Unternehmen beeinflusst werden sollten, ist es

unerlässlich, dass das ITRC funktionsübergreifend ist und Vertreter aus mehreren Geschäftsbereichen umfasst.

- **Führung der Funktionsbereiche:** Die Leiter der Funktionsbereiche (z. B. Mitglieder der Personalabteilung, der Technik, der Operations, der Entwicklung usw.) spielen eine wichtige Rolle bei der Leitung des Sicherheitsprogramms. Sie treiben die Strategie und die Entscheidungsfindung der Funktions- oder Geschäftsbereiche im Einklang mit dem Auftrag, den Zielen, der Organisation und den Richtlinien auf höchster Ebene voran.
- **Sicherheitsbeauftragte:** Die meisten Unternehmen werden nicht in jedem Funktionsbereich über Vollzeit-Sicherheitsexperten verfügen. Daher sollte das Unternehmen in jeder Abteilung „Sicherheitsbeauftragte“ benennen, die keine offiziellen Sicherheitsressourcen sind, aber als Fürsprecher für die Sicherheit fungieren. Diese Personen erhalten häufig eine spezielle Schulung und sind Hauptansprechpartner und „Einflussnehmer“, die dazu beitragen, die Sicherheit nahtlos in den täglichen Geschäftsbetrieb zu integrieren.

3.3.1 Gängige Organisationsstrukturen nach organisatorischem Reifegrad

Nachdem nun die gemeinsamen organisatorischen Komponenten und die entscheidende Rolle des ITRC vorgestellt wurden, sollen im Folgenden drei gängige Organisationsstrukturen untersucht werden,

- Neugründungen (siehe Bild 3.1),
- kleine/mittlere Unternehmen (siehe Bild 3.2) und
- Großunternehmen (siehe Bild 3.3).

3.3.1.1 Neugründung

Profil: Null bis 250 Mitarbeiter, moderner cloudbasierter Technologie-Stack, schlanke Abläufe, flache Organisationsstruktur, keine (oder nur sehr wenige) bereits bestehende Prozesse, die berücksichtigt werden müssen.

Typische Herausforderungen: Das Start-up ist eine schnelllebige Organisation, die mit begrenzten Ressourcen sehr viel erreichen muss. Wenn das Unternehmen neue Kunden akquiriert, wird es mit neuen Sicherheits- und Compliance-Anforderungen konfrontiert (vertragliche Anforderungen, Due-Diligence-Fragebögen und Zertifizierungsanforderungen), die direkt mit der Fähigkeit des Unternehmens verbunden sind, neue Kunden zu akquirieren.

Der Schlüssel zum Erfolg: Das Start-up-Unternehmen wird nur begrenzte Ressourcen für die Sicherheit bereitstellen können. Daher wird die Sicherheit wahrscheinlich eine

geteilte Verantwortung sein. Da die Sicherheit noch nicht formalisiert ist und die Ressourcen gemeinsam genutzt werden, ist die Bildung eines ITRC von entscheidender Bedeutung. Um zu skalieren, muss das Start-up die Sicherheit von Anfang an in seine Organisation integrieren (sowohl kulturell als auch mit moderner Cloudtechnologie).

Nuancen in der Organisationsstruktur: Das Start-up wird wahrscheinlich keinen traditionellen CISO haben. Stattdessen wird die Sicherheit wahrscheinlich eine geteilte Verantwortung sein. In größeren Start-ups gibt es möglicherweise Manager der mittleren Ebene und Fachexperten, die für Sicherheit oder Compliance zuständig sind. Infolgedessen fehlt dem Sicherheitsprogramm möglicherweise die Autorität der Geschäftsleitung, um Ressourcen und Budget zu beantragen. In diesem Fall müssen die oberste Führungsebene und das ITRC als ausführende Instanz für Initiativen zur Informationssicherheit fungieren. Die Organisation muss im gesamten Unternehmen Sicherheitsbeauftragte ermitteln und ausbilden, die die Sicherheit als zusätzliche Aufgabe verwalten können.

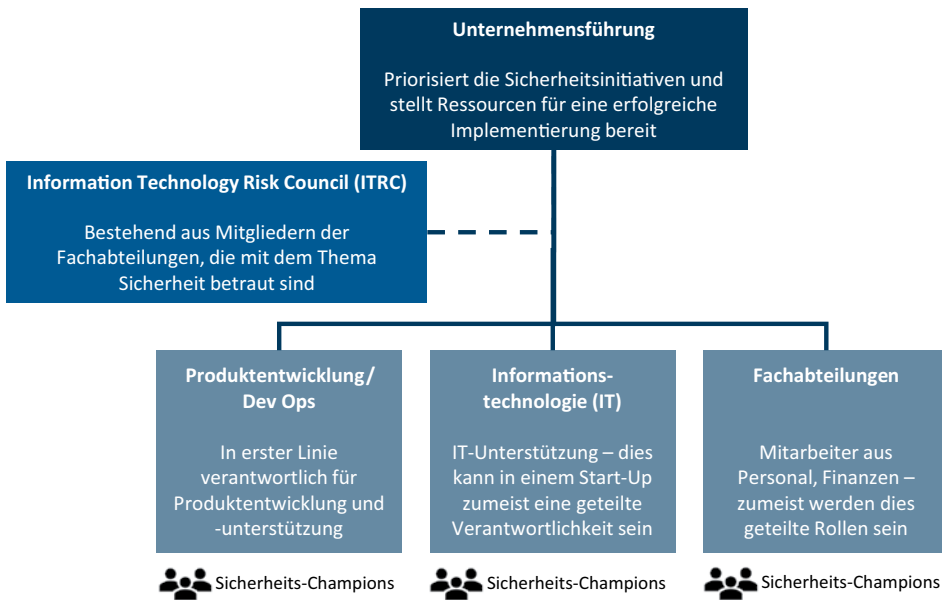


Bild 3.1 Gängige Organisationsstruktur bei Neugründungen

3.3.1.2 Kleine und mittlere Unternehmen (KMU)

Profil: 250 bis 2500 Mitarbeiter; die Komplexität der Organisationsstruktur nimmt zu, wahrscheinlich wird eine Mischung aus modernen Technologiepaketen und Altsystemen eingesetzt, die Organisation ist groß genug, um Kommunikationsprobleme zu verursachen, einige bereits bestehende Prozesse müssen berücksichtigt oder ersetzt werden.

Typische Herausforderungen: KMUs haben eine Größe und Komplexität erreicht, bei der sie einen formalen Ansatz für die Informationssicherheit entwickeln müssen. Die funktionsübergreifende organisatorische Kommunikation, die Einbindung der Interessengruppen und die konsistente Umsetzung von Sicherheitskontrollen werden schwierig. Der Einflussbereich der obersten Führungsebene reicht nicht bis zu allen Mitarbeitern oder Managern, sodass sie die Zustimmung des mittleren Managements im gesamten Unternehmen benötigen, um die Sicherheit effektiv zu implementieren/kontrollieren. Die Angriffsfläche für die Sicherheit ist größer geworden, sodass die Wahrscheinlichkeit von Sicherheitsvorfällen unvermeidlich geworden ist. Sicherheit kann keine Ad-hoc-Funktion sein, sondern erfordert eine Führungskraft an der Spitze, ein formelles Sicherheitsbudget und eine Organisationsstruktur. Veränderungen sind für KMUs manchmal schwieriger, da sie oft die Abschaffung alter Prozesse erfordern, bevor neue Prozesse eingeführt werden können, sowie die Konsultation zusätzlicher Entscheidungsträger und zusätzliche Bürokratie, die es in einem Start-up-Unternehmen nicht gibt.

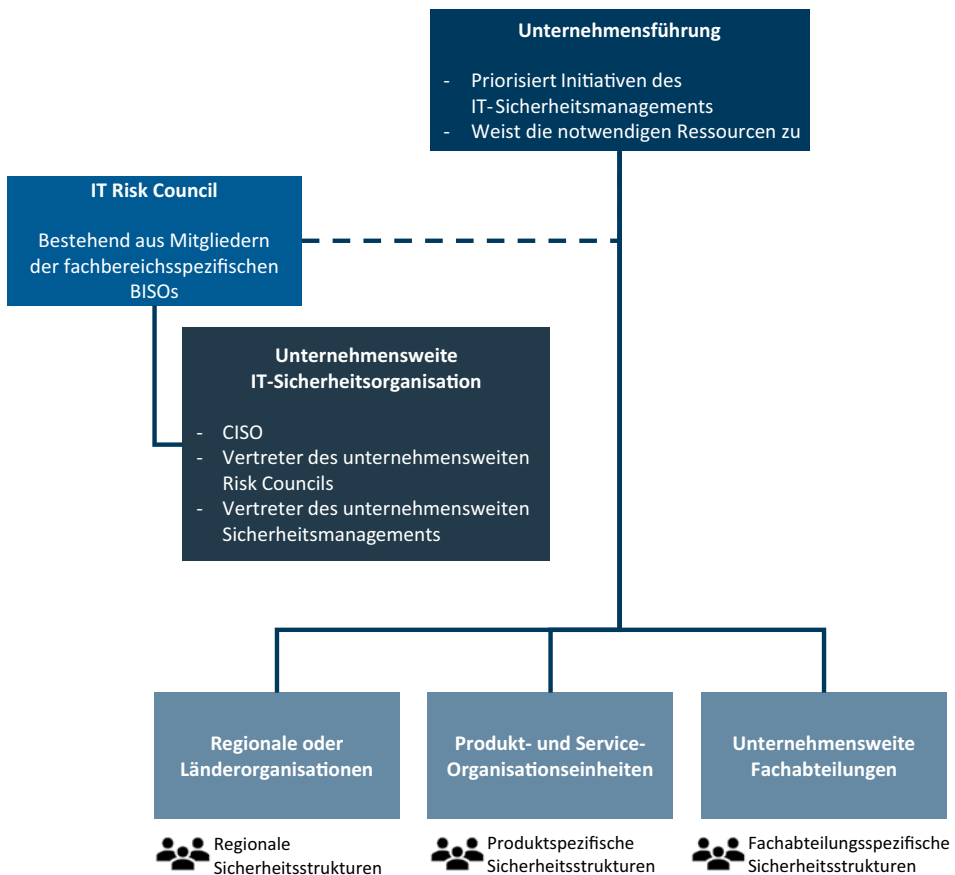


Bild 3.2 Gängige Organisationsstruktur bei kleinen und mittleren Unternehmen (KMU)

Der Schlüssel zum Erfolg: Das KMU muss eine offizielle Sicherheitsorganisation aufbauen. Die Suche nach einem CISO und der Aufbau eines Teams ist eine Voraussetzung für langfristigen Erfolg. Sicherheitsschulungen und eine konsequente Umsetzung im gesamten Unternehmen werden für die nächste Wachstums- und Reifestufe des Unternehmens von entscheidender Bedeutung sein. Die Einbindung der Sicherheit in verschiedene Abteilungen, einschließlich der Festlegung von KPIs zur Berichterstattung an das Führungsteam und den Vorstand, hilft der obersten Führungsebene, die Sicherheit zu delegieren und gleichzeitig sicherzustellen, dass sie gut verwaltet wird.

Organisatorische Struktur: Das Organigramm der KMU wird um eine formelle Sicherheitsorganisation erweitert, die dem ITRC unterstellt ist. Diese neue Sicherheitsorganisation wird einen Leiter des Sicherheitsprogramms, einen oder mehrere Spezialisten für die Einhaltung von Vorschriften sowie Fachleute für Anwendungs- und Netzwerksicherheit umfassen. Die Organisation muss für Abteilungen, in denen es keine Vollzeit-Sicherheitsressourcen gibt, Sicherheitsbeauftragte bestimmen.

3.3.1.3 Großunternehmen

Profil: Mehr als 2500 Mitarbeiter, sehr komplexe Organisationsstruktur mit vielen Geschäftsbereichen, eine Mischung aus moderner Technologie und Altsystemen, viele etablierte Prozesse, die bedacht werden müssen, jede Entscheidung muss viele Interessengruppen berücksichtigen.

Typische Herausforderungen: Organisatorische Veränderungen sind langsam und erfordern eine umfangreiche Strategie, eine funktionsübergreifende Koordination und die Zustimmung der verschiedenen Interessengruppen. Entscheidungen sind aufgrund der Vielfalt der eingesetzten Technologien, der geografischen Lage, der konkurrierenden Prioritäten und der Interessen der Beteiligten oft sehr komplex. Viele Geschäftsbereiche verdienen möglicherweise eigene untergeordnete Sicherheitsstrukturen, um ihren spezifischen Geschäftsanforderungen gerecht zu werden.

Schlüssel zum Erfolg: Der Leiter des Sicherheitsprogramms muss eine erfahrene Führungskraft sein, die über die nötigen Fähigkeiten und Erfahrungen verfügt, um organisatorische Veränderungen und den Einfluss der Interessengruppen zu bewältigen. Es muss eine formalisierte und effektive Organisationsstruktur für das Sicherheitsprogramm vorhanden sein, um eine effektive Steuerung und Änderungsverwaltung zu gewährleisten. Formalisierte Schulungs- und Kommunikationsmechanismen müssen vorhanden sein. Eine angemessene Ressourcenzuweisung (Budgets und Personal) muss für die Unterstützung des Sicherheitsprogramms ausreichen. Unter Umständen sind separate Organisationsstrukturen, Budgets und Ressourcenpläne für die einzelnen Geschäftsbereiche erforderlich.

Organisatorische Struktur: Die Organisationsstruktur wird je nach Komplexität der Organisationsstruktur sehr unterschiedlich sein. Im Großen und Ganzen wird es sich um eine Erweiterung der KMU-Organisationsstruktur handeln, die über Geschäftsbe-

reiche, geografische Gebiete oder Tochterunternehmen hinweg kopiert wird. Die Unternehmenssicherheit kann als gemeinsamer Dienst betrieben werden. Wenn die Geschäftsbereiche oder Tochtergesellschaften groß und komplex genug sind, kann es notwendig sein, Informationssicherheitsbeauftragte auf Unternehmensebene (Business-Level Information Security Officers, BISOs) einzuführen.

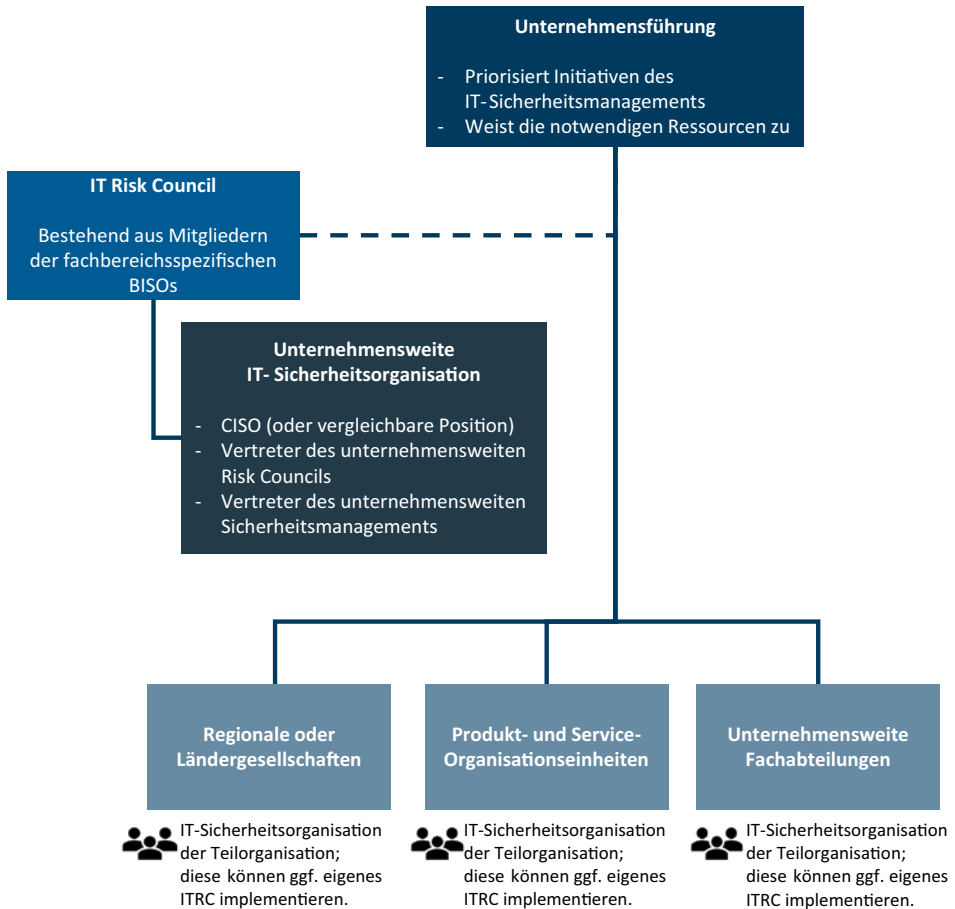


Bild 3.3 Gängige Organisationsstruktur bei weiteren Unternehmen

3.3.2 Das Information Technology Risk Council (ITRC)

Das ITRC ist das wichtigste Element der Organisationsstruktur eines IT-Sicherheitsprogramms. Es ist die Struktur, die dem Sicherheitsprogramm funktionsübergreifende Autorität und Sichtbarkeit verleiht und gleichzeitig den Funktionsbereichen Autonomie gewährt, damit sie die Geschäftsfunktionen so ausführen können, wie es

am sinnvollsten ist. Es ist das richtige Gleichgewicht zwischen der Führung auf höchster Ebene und der Freiheit der Funktionsbereiche. Wie Sie in den nachstehenden Beispielen für Organisationsstrukturen sehen werden, spielt das ITRC unabhängig von der Größe oder dem Reifegrad der Organisation eine wichtige Rolle (siehe Bild 3.4).

3.3.2.1 ITRC-Vertreter

Damit das ITRC effektiv arbeiten kann, muss es funktionsübergreifend sein. Tatsache ist, dass die Informationssicherheit keine eigenständige Geschäftsfunktion ist, sondern vielmehr jeden Aspekt des Geschäfts überlagert. Man muss sich jedoch darüber im Klaren sein, dass man die Zeit der Teammitglieder nicht vergeuden will (insbesondere die der Führungskräfte).

Im Folgenden findet sich ein Beispiel für potenzielle Mitglieder in einem ITRC.

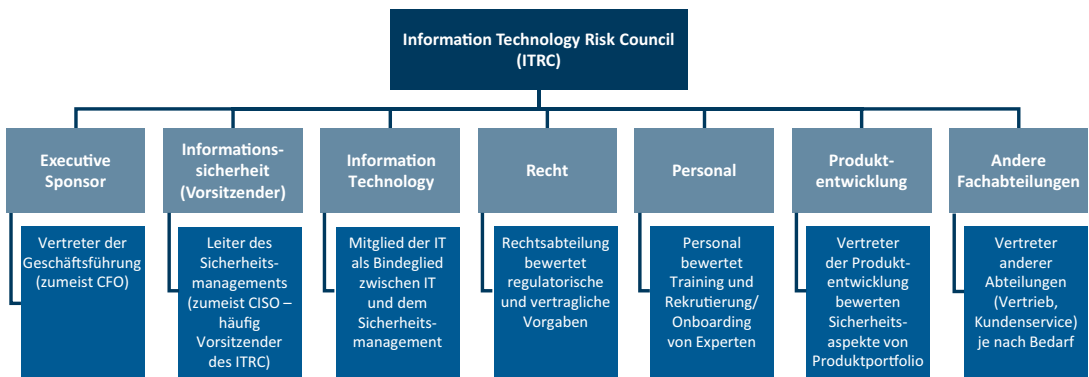


Bild 3.4 Potenzielle Mitglieder in einem Information Technology Risk Council (ITRC)

3.3.2.2 ITRC-Rollen und Zuständigkeiten

Sobald die richtigen Stakeholder für das ITRC bestimmt sind, ist es wichtig, dass die Rollen und Verantwortlichkeiten klar festgelegt werden. Dies sollte formell in einer ITRC-Charta dokumentiert werden. Im Folgenden sind einige wichtigste Elemente einer effektiven ITRC-Charta exemplarisch aufgeführt:

Steuerung

- Ratifizierung von Richtlinien und Verfahren
- Gewährung von Ausnahmen von den Richtlinien, sofern dies angemessen und mit der Risikobehandlung vereinbar ist
- Beaufsichtigung von Projektteams, die Risiken für die Organisation übernehmen
- Berichterstattung und Transparenz im Risikomanagement durch Berichterstattung an die oberste Führungsebene und den Vorstand

- Sicherstellung der Einhaltung von Unternehmensrichtlinien und aufsichtsrechtlichen Kontrollen in Bezug auf Risikobewertung und Risikomanagementaktivitäten
- Einrichtung und Förderung des Risikomanagementprogramms, der Prozesse und der Berichterstattung

Risikobewertung

- Durchführung einer jährlichen Risikobewertung der Informationstechnologie gemäß der Risikomanagement-Richtlinie zur Identifizierung von Risiken
- Dokumentation der identifizierten Risiken im Risikoregister zur Nachverfolgung und Behebung
- Bewertung, Festlegung und Genehmigung von Risikobehandlungsplänen für identifizierte Risiken (dies gilt für Projekte, Integrationen, Akquisitionen, Operationen, vertragliche Vereinbarungen und alle anderen Aktivitäten, die ein Risiko für die Organisation darstellen können)
- Einholung der Projektgenehmigung und der damit verbundenen Haushaltsgenehmigung durch die zuständigen Interessenvertreter vor der Einleitung von Risikobehandlungsprojekten

Verantwortlichkeiten für die Berichterstattung

- Regelmäßige Berichterstattung an die Geschäftsleitung und den Vorstand über die Aktivitäten des Ausschusses, Probleme und damit verbundene Empfehlungen, einschließlich der Verteilung der Protokolle aller Sitzungen des Prüfungsausschusses
- Bereitstellung eines offenen Kommunikationskanals zwischen dem CFO und dem Rest der Geschäftsleitung

Typischerweise finden sich in dem ITRC Vertreter folgender funktionaler Einheiten des Unternehmens, teilweise nach Bedarf bzw. behandelten Sachverhalten:

- Chief Operating Officer (COO)
- Chief Information Officer (CIO)
- Chief Financial Officer (CFO)
- Rechtsabteilung VP
- Personalabteilung VP
- Unternehmenskommunikation/Marketing
- Unternehmenseinheiten VPs
- Produktentwicklung/Research VP
- Informationstechnologie VP

3.4 Die Rolle des CISO: Wie man eine Führungsrolle im Sicherheitsbereich gestaltet

Neben dem IT Risk Council (ITRC) kommt der Funktion des CISO eine entscheidende Rolle bei der Ausgestaltung des IT-Sicherheitsmanagements zu. Im Folgenden soll nun diese Rolle etwas genauer beleuchtet werden. Im vorigen Kapitel wurde bereits darauf hingewiesen, dass diese Funktion nicht notwendigerweise in allen Unternehmen explizit zu finden ist. Die Komplexität der Organisationsstruktur des Unternehmens sowie Größe der funktionalen Einheiten spielen hierbei eine entscheidende Rolle.

3.4.1 Die richtige CISO-Rolle für Ihr Unternehmen entwerfen

Die meisten Organisationen, unabhängig von ihrer Größe oder ihrem Betriebsumfeld (Behörden oder Industrie), beschäftigen eine leitende Person, die für die Informationssicherheit und die Cybersicherheit zuständig ist. In vielen Organisationen wird diese Funktion als Chief Information Security Officer (CISO) oder Director of Information Security bezeichnet. CISOs und andere Personen in dieser Position stellen zunehmend fest, dass herkömmliche Strategien und Funktionen für die Informationssicherheit nicht mehr ausreichen, wenn es um das wachsende und dynamische Cyberrisikoumfeld von heute geht. Es gibt zahlreiche Veröffentlichungen mit Meinungen und Forschungsergebnissen zu einer Vielzahl von Funktionen, die eine CISO-Organisation regeln, verwalten und ausführen sollte. Es kann sich als schwierig erweisen, den Überblick zu behalten und sich für einen Ansatz zu entscheiden, der für das Geschäft, den Auftrag und die Ziele des eigenen Unternehmens geeignet ist.

Es gibt ein breites Spektrum an möglichen Aufgaben, die ein CISO übernehmen kann. Jedoch kann kein CISO alle diese Aufgaben allein erfüllen. Jedes Unternehmen hat erfahrungsgemäß eine lange Liste von „Must-haves“ bzgl. der Qualifikationen und Aufgabenbereiche des CISO. Diese gilt es zu priorisieren, um die wesentlichen Fähigkeiten zusammenzustellen und eine Stellenbeschreibung entwerfen zu können.

Um diesen Prozess zu begleiten, empfiehlt es sich, einem dreistufigen Prozess zu folgen:

1. Identifizieren der dringlichsten sicherheitsrelevanten Herausforderungen
2. Priorisieren der CISO-Rollen und Verantwortlichkeiten
3. Erstellen eines CISO-RACI-Diagramms

3.4.1.1 Identifizieren der dringlichsten sicherheitsrelevanten Herausforderungen

Zu Beginn muss das Unternehmen das „Warum“ für den Aufbau einer Sicherheitsorganisation ermitteln. Es empfiehlt sich, eine „Top-down“-Liste zu erstellen und jedes Problem nach seiner Priorität zu ordnen. Dies wird den Entscheidungsprozess für die Gestaltung der CISO-Rolle beeinflussen. Nachstehend ein einfaches Beispiel (siehe Bild 3.5).

Herausforderung	Kategorie	Priorität
IT-Sicherheit: Kunden fragen bzgl. SOC 2- und ISO 27001-Zertifizierung	Compliance	1
Aufsichtsrat und Investoren befürworten die Einrichtung einer IT- Sicherheitsorganisation	Governance	2
Neue IT-Anwendungen sammeln Personaldaten und müssen damit besonderen Sicherheitsanforderungen genügen	IT-Anwendungs-sicherheit	3
Unternehmensführung sieht steigende Kosten für IT-Sicherheit und Compliance-Herausforderungen mit Sorge, insbesondere mit Blick auf neue Rechnungslegungsrichtlinien	Governance	4
Allgemeine Herausforderungen rund um die Thematik IT-Sicherheit – wie können die damit verbundenen Risiken mitigiert werden?	Governance	5

Bild 3.5 Identifikation der dringlichsten sicherheitsrelevanten Herausforderungen (Beispiel)

3.4.1.2 Priorisierung der CISO-Rolle und -Verantwortlichkeiten

Die Verantwortlichkeiten des CISO lassen sich sinnvoll vier Schlüsselfunktionen zuordnen:

- **Schützen/Abschirmen/Verteidigen/Verhindern:** Sicherstellen, dass die Mitarbeiter, Richtlinien, Prozesse, Praktiken und Technologien der Organisation das Unternehmen proaktiv vor Cyberbedrohungen schützen, abschirmen und verteidigen und das Auftreten und Wiederauftreten von Cybersicherheitsvorfällen entsprechend der Risikotoleranz der Organisation verhindern.
- **Überwachen/Hören/Erkennen:** Sicherstellen, dass die Mitarbeiter, Richtlinien, Prozesse, Praktiken und Technologien der Organisation den laufenden Betrieb überwachen und aktiv nach Angreifern suchen und diese aufspüren sowie verdächtige und nicht autorisierte Vorfälle so schnell wie möglich melden.
- **Reagieren/Wiederherstellen/Nachhalten:** Wenn ein Cybersicherheitsvorfall eintritt, müssen die Auswirkungen so gering wie möglich gehalten und sichergestellt

werden, dass die Mitarbeiter, Richtlinien, Prozesse, Praktiken und Technologien der Organisation schnellstmöglich eingesetzt werden, um den normalen Betrieb wiederherzustellen. Zu den Vermögenswerten gehören Technologien, Informationen, Mitarbeiter, Einrichtungen und Lieferketten.

- **Management/Governance/Compliance/Schulung/Risikomanagement:** Sicherstellen, dass die Führung, die Mitarbeiter, die Richtlinien, die Prozesse, die Praktiken und die Technologien der Organisation eine kontinuierliche Überwachung, Verwaltung, Leistungsmessung und Kurskorrektur aller Cybersicherheitsaktivitäten gewährleisten. Diese Funktion umfasst die Sicherstellung der Einhaltung aller externen und internen Anforderungen und die Minderung von Risiken entsprechend der Risikotoleranz der Organisation.

Den Ausführungen zu obigen Kategorien liegen eine Reihe von Richtlinien, Rahmenwerke, Standards und Verhaltensregeln zugrunde, aus denen sich Hinweise ableiten lassen bzgl. der Rolle und den Verantwortlichkeiten eines CISO. Dazu gehören die folgenden Dokumente:

- U. S. National Institute of Standards and Technology (NIST) Special Publication 800-53 Security and Privacy Controls for Federal Information Systems and Organizations
- NIST Framework for Improving Critical Infrastructure Cybersecurity (Rahmenwerk zur Verbesserung der Sicherheit kritischer Infrastrukturen)
- Nationale Initiative für die Ausbildung im Bereich Cybersicherheit (NICE), The National Cybersecurity Workforce Framework
- SANS Critical Security Controls (Top 20)
- CERT-Resilienz-Management-Modell (CERT-RMM)
- U. S. Department of Energy Cybersecurity Capability Maturity Model (C2M2)

Zudem wird die Arbeit des CISO typischerweise durch eine Reihe von bestehenden organisatorischen Einheiten unterstützt:

- **Programmmanagement:** Projektmanagementbüro; Governance, Risiko und Compliance; Personal- und Lieferantenmanagement; Schnittstelle zum Unternehmen
- **Security Operations Center:** Situationsbewusstsein, laufende Überwachung, Sicherheits-Helpdesk, Reaktion auf Computerzwischenfälle
- **Notfalleinsätze und Vorfallsmanagement:** Vorfälle mit großer Tragweite; Planung für die Reaktion auf Vorfälle, Geschäftskontinuität, Wiederherstellung im Katastrophenfall; Tests, Übungen und Drills; Nachuntersuchungen von Vorfällen; Untersuchungen
- **Sicherheitstechnik und Anlagensicherheit:** Sicherheitstechnik, Identitäts- und Zugangsmanagement, Anwendungssicherheit, Host- und Netzsicherheit, Sicherheit von Informationsanlagen und physische Zugangskontrolle

3.4.1.3 CISO-RACI-Diagramm

Nachdem wir nun ein genaues Verständnis der Geschäftsprobleme des Unternehmens und der primären Schwerpunktbereiche des CISO haben, müssen wir in der Lage sein zu kommunizieren, wie der Rest des Sicherheitsuniversums in gemeinsamer Verantwortung verwaltet werden soll. Dies kann durch die Erstellung eines RACI-Diagramms für die fünf identifizierten Schwerpunktbereiche geschehen (siehe Bild 3.6).

Diese Übung macht deutlich, dass sich der CISO auf Governance und Compliance (blau hervorgehoben) konzentrieren wird, aber die Unterstützung von Führungskräften aus dem gesamten Unternehmen benötigt. Dies ist ein leistungsfähiges Instrument, um die Erwartungen an den CISO und den Rest des Teams zu vermitteln.

	Responsible	Accountable	Consulted	Informed
Governance	CISO	ITRC	CIO/CTO	Aufsichtsrat/ Unternehmensführung
Compliance	CISO	ITRC	CIO/CTO	Aufsichtsrat/ Unternehmensführung
Netzwerk-sicherheit	Netzwerk-administrator	CIO	CISO	ITRC
Anwendungs-sicherheit	Software-entwickler	CIO	CISO	ITRC
Informations-technologie	IT-Analyst	CIO	CISO	ITRC

Bild 3.6 CISO-RACI-Diagramm

3.4.1.4 Häufig vertretene CISO-Profil

Die obige Vorgehensweise sollte hinreichende Hinweise liefern, welche Art von CISO ein Unternehmen benötigt. Im Folgenden ist für drei gängige Anforderungen jeweils eine kurze Beschreibung des Profils aufgeführt, die als Ausgangspunkt für die Erstellung einer CISO-Stellenbeschreibung und die Suche nach dem richtigen Kandidaten dienen sollte.

CISO Typ I: Der auf Sicherheit fokussierte CISO

Typisches Profil: Der sicherheitsorientierte CISO verfügt häufig über frühere Erfahrungen in der Informationstechnologie oder im Produktbereich. Sie waren oft „Macher“ oder „Konstrukteure“ mit einem technischen Hintergrund.

Stärken: Sicherheitsorientierte CISOs fühlen sich in technisch orientierten Organisationen mit technisch interessierten Mitarbeitern, die mit dem Aufbau sicherer Systeme betraut sind, wohl. Sie sind besonders effektiv, wenn sie mit Softwareentwicklern oder Systemarchitekten kommunizieren.

Schwachstellen: Sie haben in der Regel ein tieferes technisches Verständnis für Sicherheit, haben aber oft Probleme mit der Bürokratie, die mit der Einhaltung von Vorschriften einhergeht.

Erforderliche Unterstützung: Sie werden dem Unternehmen zum Erfolg verhelfen, wenn sie mit GRC-Managern zusammenarbeiten, die bei der Einhaltung der Vorschriften helfen können.

Erfahrungsgemäß entfallen etwa 30 % der CISOs auf diese Kategorie.

CISO-Typ II: Der auf die Einhaltung von Vorschriften fokussierte CISO

Typisches Profil: Der auf die Einhaltung von Vorschriften ausgerichtete CISO verfügt wahrscheinlich über frühere Erfahrungen in den Bereichen öffentliche Rechnungslegung, Wirtschaftsprüfung und Unternehmensführung.

Stärken: Compliance-orientierte CISOs fühlen sich in stark regulierten Umgebungen wohl, da sie in der Lage sind, einem Rahmenwerk zu folgen, eine Zertifizierung zu erlangen und mit Auditoren und Regulierungsbehörden zusammenzuarbeiten. Sie verstehen es in der Regel, Audit-, Zertifizierungs- und Regelwerke zu interpretieren und zu navigieren. Darüber hinaus sind compliance-orientierte CISOs in der Regel gut darin geschult, mit der Berichterstattung an die Geschäftsführung und den Vorstand umzugehen.

Schwachstellen: Compliance-orientierten CISOs mangelt es oft an tiefem technischen Verständnis oder technischer Erfahrung. Daher haben sie möglicherweise keine praktische Erfahrung im Umgang mit Sicherheitstools oder der Erstellung von Software. Aus diesem Grund können sie sich möglicherweise nicht so gut in diejenigen hineinversetzen, die mit der Ausführung von Sicherheitsfunktionen betraut sind.

Erforderliche Unterstützung: CISOs, die sich auf die Einhaltung von Vorschriften konzentrieren, werden gut mit technischen Fachleuten zusammenarbeiten, die sich mit den technischen „praktischen“ Arbeitsanforderungen auskennen.

Erfahrungsgemäß entfallen etwa 50 % der CISOs auf diese Kategorie.

CISO Typ III: Die erfolgreiche Führungskraft mit einem CISO-Titel

Typisches Profil: Der CISO, der kein CISO ist, ist eine Führungskraft (in der Regel ein ehemaliger COO oder CTO), dem irgendwie die Verantwortung für die Leitung der Sicherheitsorganisation übertragen wurde.

Stärken: Sie sind oft großartige funktionsübergreifende Führungskräfte, die Dinge umsetzen können. Sie haben ein natürliches Gespür für die Prioritäten des Unternehmens und leiten die Sicherheitsabteilung entsprechend. Sie können sich in der Regel auch in die Menschen außerhalb der Sicherheitsorganisation einfühlen und können daher effektiv zusammenarbeiten.

Schwachstellen: Wahrscheinlich fehlen ihnen die technischen Fähigkeiten oder die Erfahrung mit der Einhaltung von Vorschriften, die normalerweise mit dem Titel CISO verbunden sind.

Erforderliche Unterstützung: CISOs, die keine CISOs sind, müssen von einem starken Team von Fachexperten auf Managementebene unterstützt werden, die keine Führungskräfte sind. Ein weiterer Schwerpunkt sollte die Berichterstattung über wichtige Leistungsindikatoren sein, die dem nichttraditionellen CISO den Zustand des Programms klar vermitteln. Darüber hinaus sollte der nichttraditionelle CISO von der Organisation insgesamt respektiert werden und offen über seinen Mangel an technischem Sachverstand sprechen. Andernfalls kann seine Glaubwürdigkeit durch Selbstdarstellung untergraben werden.

Erfahrungsgemäß entfallen etwa 20 % der CISOs auf diese Kategorie.

Ehrenvolle Erwähnung: Die IT-Führungskraft mit Sicherheitsverantwortung

Typisches Profil: Ein IT-Leiter, der informell Sicherheitsverantwortung übernommen hat.

Stärken: Sie haben das beste Verständnis für die technischen Komponenten der verschiedenen Systeme, die das Unternehmen unterstützen.

Schwächen: Da die IT-Abteilung die fraglichen Systeme entwickelt und unterstützt, kann sie bei der Bewertung der Sicherheitslage blinde Flecken haben. Außerdem besteht ein natürlicher Interessenkonflikt, da der IT-Leiter möglicherweise Bedenken hat, auf Sicherheitsschwächen in den von ihm entwickelten Systemen hinzuweisen. Und schließlich gibt es einfach zu viel zu tun – der IT-Leiter wird nicht die Zeit haben, die gesamte IT und die Sicherheit effektiv zu beaufsichtigen.

Unterstützung wird benötigt: Auch wenn der IT-Leiter die Sicherheit notgedrungen unterstützen muss (aufgrund von Ressourcen- oder Budgetbeschränkungen), ist dies für die meisten Unternehmen keine langfristige Lösung in großem Maßstab. Daher wird der IT-Leiter einen Sicherheitsmanager oder -analysten benötigen, sobald dies möglich ist.

Obwohl diese Position weit verbreitet ist, handelt es sich dabei nicht um eine CISO-Rolle, und es ist nicht effektiv/gerecht, diese Person ohne angemessene Unterstützung, Ressourcen und Budget für Sicherheitsaktivitäten verantwortlich zu machen.

3.5 Finale Anmerkungen

Es sollte deutlich geworden sein, dass die Organisation des IT-Sicherheitsmanagements in Unternehmen durch zwei Gremien bzw. Personen wesentlich geprägt wird:

- Das **IT Risk Council** (ITRC)
- Die Funktion des **CISO**

Die Ausgestaltung beider Funktionen wird im Kern durch die eine Vielzahl von Faktoren bestimmt, u. a.:

- wahrgenommenes Risiko
- bestehende Organisationsstrukturen, insbesondere in der IT
- Zusammenspiel der IT-Organisation mit den Fachabteilungen
- Größe des Unternehmens

Ich habe in diesem Kapitel davon abgesehen, auf industriespezifische oder kulturelle Faktoren einzugehen. Es steht außer Frage, dass für Unternehmen, deren Produkte und Services einen hohen Anteil an digitaler Wertschöpfung beinhalten, die Risikobewertung nochmals um weitere Komplexitätsdimensionen erweitert wird, welchen ein IT-Sicherheitsmanagement Rechnung tragen muss. So hat beispielsweise ein Fahrzeughersteller, dessen Produktwert wesentlich durch eine funktionierende IT bestimmt sind, deutlich andere Anforderungen an ein Sicherheitsmanagement als ein Mittelständler, dessen Produkte in der Landwirtschaft Verwendung finden.

Abschließend bleibt festzuhalten, dass das Themenfeld des IT-Sicherheitsmanagements im Allgemeinen und der damit einhergehenden Organisationsstrukturen im Speziellen ein sehr dynamisches Forschungsgebiet darstellt und auch weiterhin darstellen wird. Auch werden sich die Angriffsszenarien und Bedrohungen durch Cyberkriminelle in immer schnellerem Maße weiterentwickeln. Für Unternehmen wird es daher unerlässlich sein, sich dieser Dynamik zu stellen und die zugehörigen Organisationsstrukturen sowie die wesentlichen Gremien und Rollen immer wieder neu zu hinterfragen.

4

Rechtliche Rahmenbedingungen der IT-Sicherheit

Thomas Jansen



In diesem Beitrag erfahren Sie,

- welche vertrags- und haftungsrechtlichen Risiken bei der Umsetzung von IT-Sicherheitsvorgaben bestehen,
- welche technischen und organisatorischen Maßnahmen im eigenen Unternehmen erfüllt werden müssen,
- welche Risiken und welchen Schutz die strafrechtliche Seite der IT-Sicherheit birgt sowie
- welche Regelungen das IT-Sicherheitsgesetz (ITSiG 2.0) mit sich bringt und welche Pflichten sich daraus für welche Art von Unternehmen ergeben,
- welche Neuerungen das geplante NIS2UmsuCG (ITSiG 3.0) mit sich bringt und welche Pflichten sich daraus für welche Art von Unternehmen ergeben.

4.1 Einleitung

In der Unternehmens-Compliance sind Rechtsfragen bezüglich der IT-Sicherheit von höchster Bedeutung. Kaum ein Bereich birgt so hohe finanzielle Risiken und so weitreichende unvorhersehbare Folgen für das eigene Unternehmen. Neben immensen finanziellen Schäden und der potenziellen vollständigen Lahmlegung des operativen Tagesgeschäfts können sie zu einem dauerhaften Imageverlust des Unternehmens führen.

Nach einer Schätzung von Bitkom ist im Jahr 2023 deutschen Unternehmen durch Cyberangriffe ein Schaden in Höhe von 148 Milliarden Euro entstanden. In einer Umfrage gaben zwei Drittel der befragten Unternehmen an, dass sie damit rechnen, in den kommenden zwölf Monaten Opfer eines Cyberangriffs zu werden. Das BSI stellt in seinem Lagebericht für das Berichtsjahr 2023 fest, dass für Unternehmen vor allem

Angriffe durch Ransomware die größte Bedrohung sind. Danach werden als weitere Top-Bedrohungen Abhängigkeiten in der IT-Supply-Chain sowie Schwachstellen, offene oder falsch konfigurierte Online-Server genannt.

Ein Beispiel aus dem Jahr 2022 ist eine Cyberattacke auf das Tanklogistikunternehmen Oiltanking. Durch den Angriff sind die Be- und Entladesysteme des Unternehmens und somit auch eine große Zahl der von den Mineralöllieferungen abhängigen Tankstellen beeinträchtigt. Gerade hier ist das enorme und unberechenbare Ausmaß eines Cyberangriffs erkennbar. Die IT-Systeme zahlreicher Unternehmen können, auch ohne dass sie das Hauptziel des Angriffs darstellen, bei Verwendung der betroffenen Programme mittelbar von den Auswirkungen betroffen sein. Auch die IT-Systeme des Mineralöhländlers Mabanaft wurden durch den oben genannten Vorfall in Mitleidenschaft gezogen. Diese einzelne cyberkriminelle Attacke hat also Auswirkungen auf das angegriffene Unternehmen, mittelbar betroffene Konzerne, mittelständische Tankstellen und schließlich auf die Verbraucher.

Gesetzgeber und Verwaltung haben im Bereich der IT-Sicherheit daher rechtliche Regelungen getroffen und konkretisierende Empfehlungen ausgesprochen, um diesen zunehmenden Risiken zu begegnen. Da die gesetzgeberischen Neuerungen auf diesem Gebiet jedoch nicht in einem einzelnen IT-Sicherheitsgesetz, sondern fragmentarisch in verschiedenen bestehenden Gesetzen verteilt zu finden sind, kann es Verantwortlichen in diesem Bereich schwerfallen, den Überblick über die aktuell geltenden rechtlichen Rahmenbedingungen zu bewahren. In diesem Kapitel werden daher die rechtlichen Vorgaben beleuchtet, die für eine ausreichende Umsetzung der IT-sicherheitsrechtlichen Anforderungen sowie für eine Absicherung auf haftungsrechtlicher Ebene relevant sind.

4.2 Vertrags- und haftungsrechtliche Risiken

Unternehmen sind verpflichtet, den rechtlich an sie gestellten IT-Sicherheitsanforderungen nachzukommen sowie die datenschutzrechtlichen Vorgaben einzuhalten. Eine Nichteinhaltung der entsprechenden Vorschriften eröffnet vielfältige Haftungsrisiken, wobei diese regelmäßig auf Vertrags- oder Gesetzesverstößen beruhen.

4.2.1 Allgemeine Sorgfaltspflichten

Um diesen Haftungsrisiken zu begegnen, ist daher eine genaue Kenntnis der Pflichten, die das eigene Unternehmen und seine Akteure treffen, erforderlich.

Rechtsgrundlagen für allgemeine Sorgfaltspflichten und Risikovorsorge in Aktiengesellschaften sind die §§ 76, 91 Abs. 2, 93 Abs. 1 AktG. Aus diesen allgemeinen Vor-

schriften wird im Speziellen auch die Verpflichtung zur Gewährleistung der IT-Sicherheit in einem Unternehmen, einschließlich der Risikofrüherkennung und -prävention sowie der IT-Sicherheits-Compliance, abgeleitet.

Für die GmbH-Geschäftsführung regelt § 43 Abs. 1 GmbHG einen objektiven Sorgfaltsmaßstab, der grundsätzlich vergleichbar mit den oben genannten Regelungen des AktG ist.

In die Verantwortlichkeit des Vorstands fällt so, entwickelt aus der oben genannten allgemeinen Sorgfaltspflicht, die Pflicht zur Risikofrüherkennung auf Grundlage von § 91 Abs. 2 AktG. Danach hat der Vorstand geeignete Maßnahmen zu treffen, damit Entwicklungen, die möglicherweise den Fortbestand der Gesellschaft gefährden könnten, früh erkannt werden.

Diesem Zweck soll nach § 91 Abs. 2 AktG insbesondere die Einrichtung eines Überwachungssystems dienen.

Bestandsgefährdende Entwicklungen sind solche Risiken, die sich negativ auf die Gesellschaft auswirken können. Auch Verstöße gegen IT-sicherheitsrechtliche Vorgaben können als bestandsgefährdende Entwicklung in diesem Sinne zu qualifizieren sein, wie beispielsweise durch unzureichend geschützte IT-Systeme oder durch eigenverschuldete Datenlecks.

Aus der Risikofrüherkennungspflicht ergibt sich die Erforderlichkeit der Einrichtung zweier Systeme: eines Risikoüberwachungssystems und eines Risikofrüherkennungssystems. Der Inhalt bzw. die Gestaltung dieser Systeme ist nicht zwingend vorgeschrieben, sie muss für den Einzelfall festgelegt werden und nach Einschätzung der Geschäftsleitung angemessen sein.

Zudem hat der Vorstand nach § 91 Abs. 2 AktG die Pflicht, die für die Einrichtung des Risikofrüherkennungssystems getroffenen Maßnahmen zu dokumentieren. Dies kann z. B. in einem Risikohandbuch erfolgen.

Zu diesen umfangreichen Compliance-Pflichten der Geschäftsleitung eines Unternehmens hat das LG München in seinem richtungsweisenden „Neubürger Urteil“¹ aus dem Jahr 2013 ausgeführt: Vorstandsmitglieder haben im Rahmen ihrer Legalitätspflicht als Teil ihrer allgemeinen Sorgfaltspflicht dafür Sorge zu tragen, ihr Unternehmen so zu organisieren und zu beaufsichtigen, dass keine Gesetzesverstöße erfolgen. Dieser Pflicht genüge ein Vorstandsmitglied bei entsprechender Gefährdungslage nur dann, wenn es eine auf Schadensprävention und Risikokontrolle angelegte Compliance-Organisation eingerichtet hat. Zudem gehörten die Einhaltung des Legalitätsprinzips und demgemäß die Einrichtung eines funktionierenden Compliance-Systems zur Gesamtverantwortung des Vorstands.

¹ LG München NZG 2014, 345

4.2.2 Pflichten zur Gewährleistung der IT-Sicherheit

Diese oben genannten Maßstäbe gelten entsprechend auch und gerade im Bereich der IT-Sicherheits-Compliance und verpflichten insofern die Geschäftsführung zur Einführung eines präventiven IT-Sicherheits- und Notfallkonzepts.

Bestehen also entsprechende IT-Sicherheitspflichten für den Vorstand einer Aktiengesellschaft, ist es in der Praxis üblich und rechtlich zulässig, die Zuständigkeit für die Einhaltung von IT-Sicherheitsstandards im Unternehmen mittels Ressortzuweisung oder durch Einsetzung eines CIO (= Chief Information Officer) zu übertragen.

Hierbei ist jedoch zu beachten, dass diese interne Aufgabenverteilung nicht zu einer Abweichung des Grundsatzes der Gesamtverantwortung führt. Dieser besagt, dass jedes Vorstandsmitglied die Pflicht für die Geschäftsleitung im Ganzen, mithin auch für die IT-Sicherheit, trägt. Allerdings wandelt sich der Pflichtinhalt der übrigen ressortfremden Vorstandsmitglieder von einer unmittelbaren geschäftsführenden Handlungspflicht in eine Überwachungspflicht gegenüber dem Ressortverantwortlichen. Bei einer ordnungsgemäßen Erfüllung der Überwachungspflicht tritt eine Haftungsbeschränkung für die ressortfremden Vorstandsmitglieder ein.

4.2.3 Haftung für Verstöße gegen IT-sicherheitsrechtliche Anforderungen

Eine Haftung von Vorstandsmitgliedern bzw. Mitgliedern der Geschäftsführung für Verstöße gegen die oben genannten IT-sicherheitsrechtlichen Anforderungen ist sowohl im Innen- als auch im Außenverhältnis möglich und kann sich sowohl zulasten der jeweils Handelnden als auch zulasten des Unternehmens selbst auswirken.

Haftung der Organe

Die zentralen Vorschriften für eine Inanspruchnahme des Vorstands durch die AG bzw. der Geschäftsführung durch die GmbH sind § 93 Abs. 2 Satz 1 AktG und § 43 Abs. 2 GmbHG. Sowohl die Vorstandsmitglieder der AG als auch die Geschäftsführung der GmbH haften grundsätzlich gesamtschuldnerisch für den gegenüber der jeweiligen Gesellschaft entstandenen Schaden. Beide Anspruchsgrundlagen setzen für die Haftungsbegründung einen schuldhaften und schadensbegründenden Verstoß gegen IT-Sicherheitsrecht voraus. Beispiele hierfür können ein fehlender Notfallvorsorgeplan oder eine unzureichende Datensicherungsroutine sein.

Durch die in § 93 Abs. 1 S. 2 AktG normierte Beweislastumkehr obliegt es sodann den Vorstandsmitgliedern, sich bezüglich des Vorwurfs eines Sorgfaltsverstößes zu exkulpieren. Diese Vorschrift wird in ständiger Rechtsprechung entsprechend auf die GmbH angewandt.

Mögliche Auswege aus der Haftung

Mittels geeigneter Maßnahmen können die oben aufgezeigten Haftungsrisiken der verantwortlichen Organe deutlich verringert bzw. ausgeschlossen werden. Im Folgenden werden dafür Möglichkeiten aufgezeigt.

Eine erste Maßnahme ist die Delegation verschiedener, die IT-Sicherheit betreffender Aufgaben von der Geschäftsleitung an die zuständigen Bereiche/Mitarbeiter. Es bestehen hier jedoch sehr hohe Anforderungen an deren haftungsbeschränkende Wirkung. Eine Grundvoraussetzung ist die eindeutige und überschneidungsfreie horizontale und vertikale Aufgabenteilung und -vergabe.

Auch sollte zur Vermeidung der Gefahr eines Organisationsverschuldens gewissenhaft den Dokumentations- und Überwachungspflichten nachgekommen werden, sollte der Nachweis einer pflichtgemäßen Aufgabenerfüllung einmal erforderlich werden.

Bei horizontaler Verteilung besteht das Prinzip der Gesamtverantwortung. Es herrscht somit weiterhin eine gegenseitige Kontrollpflicht aller Gesellschaftsorgane. Daraus folgen eine Zuständigkeit des Geschäftsführers bzw. des Vorstands für die gesamte Organisation sowie Aufgabenerfüllung und -verteilung in Übereinstimmung mit normativen Vorgaben und unter Beachtung anerkannter Erkenntnisse und Verfahrensgrundsätze.

Diskutiert die Geschäftsleitung das Einsetzen oder Erweitern von IT-sicherheitsrelevanten Maßnahmen, so sollte dies und die sich an die Diskussion anschließende Entscheidung dokumentiert werden. Idealerweise sollte sich im Rahmen einer solchen Dokumentation auch eine Begründung der jeweiligen Entscheidung finden. Hierdurch kann nachgewiesen werden, dass IT-spezifische Risiken erkannt wurden und entsprechend gehandelt wurde. Festgehaltene Begründungen zeigen zudem die Vertretbarkeit der getroffenen Entscheidungen und vermeiden eine durch die Rückschau entstehende verzerrte Perspektive (sog. Rückschaufehler).

Eine weitere mögliche Maßnahme zur Risikominimierung für Geschäftsführer einer Gesellschaft bzw. für den Vorstand einer Aktiengesellschaft ist eine sog. D&O-Versicherung (Directors-and-Officers-Versicherung). Sie bietet Versicherungsschutz für Führungskräfte eines Unternehmens bei Inanspruchnahme durch das eigene Unternehmen (Innenhaftung) sowie durch Dritte (Außenhaftung).

Haftung von Arbeitnehmern

In der Regel sind CIOs oder Datenschutzbeauftragte nicht als Vorstandsmitglied oder Geschäftsführer einer Gesellschaft beschäftigt, sondern sind „normale Arbeitnehmer“. Erleidet ein Unternehmen durch eine schuldhafte Pflichtverletzung eines Arbeitnehmers einen Schaden, so kann das Unternehmen gegen seinen Arbeitnehmer Schadensersatzansprüche geltend machen; dies allerdings nur gemäß den Grundsätzen des sogenannten „innerbetrieblichen Schadensausgleichs“:

Die Höhe des Ausgleichsanspruchs im Verhältnis Arbeitnehmer – Arbeitgeber beurteilt sich nach den Umständen des Einzelfalls, beispielsweise nach der Zumutbarkeit der Vermeidung der Sicherheitsverletzung und nach dem Verschuldensgrad des jeweiligen Arbeitnehmers (leichte bis grobe Fahrlässigkeit, Vorsatz). Ist ihm beispielsweise lediglich leichte Fahrlässigkeit zur Last zu legen, so findet gegebenenfalls im Innenverhältnis eine Haftungsbegrenzung mit der Folge statt, dass der Regressanspruch des Arbeitgebers entfällt. Diese begrenzte Arbeitnehmerhaftung folgt dem Gedanken, dass das Schadensrisiko eines Unternehmens Teil dessen Betriebsrisikos ist und eine einseitige Abwälzung dessen auf seine Arbeitnehmer unbillig erscheint.

4.2.4 Anforderungen der DSGVO an technische und organisatorische Schutzmaßnahmen zum Schutz der IT-Sicherheit

Der Schutz persönlicher Daten und die IT-Sicherheit stehen in einem unmittelbaren Zusammenhang. Daher normiert auch die Datenschutz-Grundverordnung rechtliche Rahmenbedingungen an die IT-Sicherheit, insbesondere in Artikel 32 DSGVO. Maßgebliche Kriterien für die Bestimmung der technischen und organisatorischen Maßnahmen (TOMs) sind Art, Umfang sowie die Umstände der Datenverarbeitung.

Gemäß Artikel 32 DSGVO hat ein Unternehmen angemessene technische und organisatorische Maßnahmen zu treffen, um einen dem Risiko angemessenen Schutz der verarbeiteten personenbezogenen Daten zu gewährleisten. Auch hier ist das erforderliche Schutzniveau für den jeweiligen Einzelfall zu bestimmen. Maßgaben sind Stand der Technik, Implementierungskosten, Art, Umfang, Umstände und Zwecke der Verarbeitung sowie die unterschiedliche Eintrittswahrscheinlichkeit und Schwere des Risikos für die Rechte und Freiheiten natürlicher Personen. Insbesondere die Risiken einer unerlaubten Offenlegung oder Vernichtung, beispielsweise durch einen Cyberangriff, sind gemäß Artikel 32 Abs. 2 DSGVO zu berücksichtigen. Maßnahmen, die diesen Schutz gewährleisten, sind die Pseudonymisierung und Verschlüsselung personenbezogener Daten sowie die Fähigkeit, die Vertraulichkeit, Integrität, Verfügbarkeit und Belastbarkeit der Systeme und Dienste im Zusammenhang mit der Verarbeitung auf Dauer sicherzustellen (vgl. Art. 32 Abs. 1 lit. a–d DSGVO). Darüber hinaus fordert die DSGVO, die Effizienz der angewandten Vorkehrungen, beispielsweise durch ein Datenschutz- oder Incident-Response-Management oder durch das Durchführen sogenannter Penetrationstests, regelmäßig zu überprüfen und zu evaluieren. Zudem ist eine rasche Wiederherstellungsmöglichkeit der Daten bei einem physischen oder technischen Zwischenfall erforderlich.

Gemäß Artikel 42 DSGVO kann eine DSGVO-spezifische Zertifizierung als Beurteilungsmaßstab der Angemessenheit der Maßnahmen herangezogen werden. Die Zerti-

fizierungsstellen müssen allerdings ein umfangreiches Akkreditierungsverfahren durchlaufen, sodass das erste Zertifizierungsverfahren in Deutschland erst im Dezember 2023 genehmigt wurde.

4.2.5 Anforderungen des TKG und des TTDSG an technische und organisatorische Schutzmaßnahmen zum Schutz der IT-Sicherheit

In den Bereichen der Telekommunikation und der Telemedien, insbesondere im Telekommunikation- und im Telekommunikation-Telemedien-Datenschutz-Gesetz (TKG und TTDSG), gibt es sektorspezifische Vorgaben, die es bei der Umsetzung von TOMs zu beachten gilt.

Auch für die Adressaten des TKG, also Diensteanbieter bzw. Betreiber öffentlicher Telekommunikationsnetze und Erbringer öffentlich zugänglicher Telekommunikationsdienste mit Gewinnerzielungsabsicht, normiert § 165 TKG die Pflicht, die unternehmenseigenen IT-Systeme durch technische und organisatorische Maßnahmen ausreichend abzusichern, um das Fernmeldegeheimnis und den Schutz personenbezogener Daten zu wahren und erhebliche Beeinträchtigungen der Funktionsfähigkeit des Telekommunikationsnetzes zu verhindern.

Bereits eine partielle Versorgung mit einer Telekommunikationsleistung oder die reine Schaffung der Gebrauchsmöglichkeit sind ausreichend, um Unternehmen in den Anwendungsbereich des TKG aufzunehmen. Die Telekommunikationsdienste im Sinne des TKG müssen nicht zwingend durch das eigene Unternehmen erbracht werden.

Das Telemediengesetz hat einen weiten Anwendungsbereich und bezieht sich auf alle elektronischen Informations- und Kommunikationsdienste, wie Onlineangebote von Waren/Dienstleistungen mit unmittelbarer Bestellmöglichkeit, Onlinedienste, die Instrumente zur Datensuche, um Zugang zu Daten oder zur Datenabfrage bereitzustellen (z. B. Internetsuchmaschinen), oder die kommerzielle Verbreitung von Informationen über Waren-/Dienstleistungsangebote mit elektronischer Post (z. B. Werbemails). Anbieter digitaler Dienste unterliegen den erhöhten Anforderungen des § 8c BSIG (bzw. § 30 BSIG-E) und dem § 19 des Telekommunikation-Telemedien-Datenschutz-Gesetzes (TTDSG), nach welchen sie verhältnismäßige technische und organisatorische Maßnahmen treffen müssen, um Angriffen, Störungen und Sicherheitsrisiken ihrer Netz- und Informationssysteme vorzubeugen. Zudem besteht gemäß § 8c Abs. 3 BSIG (bzw. § 32 BSIG-E) eine unverzügliche Meldepflicht erheblicher Sicherheitsvorfälle gegenüber dem BSI.

4.2.6 Empfehlungen des BSI in Bezug auf technisch-organisatorische Maßnahmen

Um das Risiko eines Verstoßes gegen die IT-Compliance der oben ausgeführten rechtlichen Vorgaben zu minimieren, bietet der IT-Grundschutz eine vom Bundesamt für Sicherheit in der Informationstechnik (BSI) entwickelte Methodik mit den wichtigsten Anforderungen und Empfehlungen zur Absicherung der unternehmenseigenen Daten und Systeme (BSI-Standards) sowie einen Leitfaden zur Umsetzung der hohen Anforderungen an die IT-Sicherheit und den Datenschutz im eigenen Unternehmen (IT-Grundschutz-Kompendium). Er bietet einen ganzheitlichen Ansatz in Form von Maßnahmen sowohl im technischen und organisatorischen als auch im infrastrukturellen und personellen Bereich.

Im IT-Grundschutz-Kompendium, das jährlich im Februar in einer aktualisierten Edition auf der Internetseite des BSI veröffentlicht wird, werden die erforderlichen, grundlegenden Elemente eines IT-Sicherheitsschutzes erläutert. Insbesondere wird auf die IT-Grundschutz-Bausteine als essenzielle Bestandteile eines effektiven IT-Sicherheitskonzepts eingegangen. Diese zeigen mögliche Gefahrenquellen auf und legen wichtige Sicherheitsanforderungen unter anderem in den Bereichen des Sicherheitsmanagements (ISMS), der Organisation und des Personals (ORP) und der Anwendungen (APP) dar. Zusätzlich werden zu einigen Bausteinen konkrete Umsetzungshinweise gegeben, um die Implementierung im eigenen Unternehmen zu erleichtern.

Die BSI-Standards, die einen weiteren elementaren Bestandteil der IT-Grundschutz-Methodik darstellen, ergänzen das IT-Grundschutz-Kompendium. Sie geben Empfehlungen zu Methoden, Prozessen und Verfahren sowie Vorgehensweisen und Maßnahmen, um Geschäftsprozesse und Daten sicher zu gestalten. Aktuell gelten die BSI-Standards 200-1, 200-2, 200-3 und 200-4 zum Aufbau eines Informationssicherheitsmanagementsystems (ISMS), eines Risikomanagements und eines Business-Continuity-Managements.

Die Gewährleistung einer soliden Informationssicherheit erfolgt somit durch eine Kombination der bewährten Vorgehensweise der BSI-Standards zum Aufbau eines ISMS und der Umsetzung der konkreten Anforderungen der Grundschutz-Bausteine aus dem IT-Grundschutz-Kompendium. Diese Grundschutzbausteine bilden die Prüfungsgrundlage für eine Zertifizierung nach dem internationalen Standard der ISO 27 001.

Zusammenfassend sind für die Erfüllung der IT-Sicherheits-Compliance und für eine umfassende haftungsrechtliche Absicherung die eingehende Auseinandersetzung mit den gesetzlichen Rahmenbedingungen sowie die Ausarbeitung umfangreicher präventiver Sicherheits- und Notfallkonzepte notwendig.

Maßstab für eine angemessene Umsetzung technischer und organisatorischer Maßnahmen nach dem Stand der Technik sind die Empfehlungen des BSI sowie internati-

onale Zertifizierungen im IT-sicherheitsrelevanten Bereich. Zudem ist eine genaue und lückenlose Dokumentation der getroffenen Maßnahmen für die Abwendung eines Haftungsfalls zu empfehlen. Schließlich ist im Falle eines Cyberangriffs ein sorgfältig ausgearbeitetes Business-Continuity-Management-System (BCM-System) von hoher Bedeutung. Dieses Organisationssystem definiert Vorgehensweisen und Pläne, wie ein regulärer Betrieb nach einem störungsbedingten Ausfall durch unerlaubten Zugriff auf unternehmenseigene IT-Systeme wiederaufgenommen werden kann. Es trägt maßgeblich zu einer Reduktion des aus dem Angriff entstandenen Schadens und dessen verheerenden Auswirkungen bei. Auch für die Ausarbeitung eines solchen BCM-Systems bestehen internationale Standards wie die Norm ISO 22 301. Da sich eine Cyberattacke trotz aller im Vorfeld getroffenen Sicherheitsmaßnahmen nie vollständig ausschließen lässt, ist eine Ausarbeitung von effizienten Notfallplänen für eine umfassende Absicherung des Unternehmens jedoch weiterhin essenziell.

4.3 Straf- und ordnungswidrigkeitsrechtliche Folgen bei der Verletzung der IT-Sicherheit

Versäumnisse der Verantwortlichen bei der Gewährleistung von IT-Sicherheit können auch zu straf- oder ordnungswidrigkeitsrechtlichen Sanktionen führen. Im Folgenden wird ein Überblick über mögliche einschlägige Normen gegeben und aufgezeigt, welche Akteure jeweils strafrechtlich verantwortlich sein können.

4.3.1 Strafrechtliche Normen zum Schutz vor Cyberkriminalität

Eine einheitliche Kodifizierung strafrechtlicher Normen zur Bekämpfung von IT-Sicherheitsverstößen und Cyberkriminalität besteht derzeit nicht. Vielmehr sind die verschiedenen Straftatbestände sowohl im Kern- als auch im Nebenstrafrecht zu finden.

■ §§ 202a bis 202d StGB

§§ 202a bis 202d StGB schützen gespeicherte oder sich in der Übermittlung befindende Daten, unabhängig von ihrem Inhalt, vor dem Zugriff unbefugter Personen (§ 202a StGB), vor Zugriffen mit technischen Mitteln (§ 202b StGB) sowie vor dem entgeltlichen Zugänglichmachen, wenn die entsprechenden Daten zuvor rechtswidrig erlangt wurden (sogenannte Datenhehlerei, § 202d StGB).

§ 202c StGB (Vorbereiten des Ausspähens und Abfangens von Daten), der sogenannte „Hackerparagraph“, erweitert diesen Schutz auch auf entsprechende Vorbereitungshandlungen. Hierbei bestehen insbesondere mit Blick auf sogenannte „Dual-Use-Tools“ Schwierigkeiten bei der Bestimmung der Strafbarkeitsgrenze.

Dies sind Programme, die sowohl zur wünschenswerten Überprüfung von IT-Sicherheitssystemen als auch zur Vorbereitung einer strafbewehrten Handlung eingesetzt werden können.



§ 202a StGB schützt explizit Daten, die gegen einen unberechtigten Zugang gesichert sind. Um sicherzustellen, dass unternehmensinterne Daten von dem Schutz des § 202a StGB erfasst sind, sollten diese gesondert vor einem unberechtigten Zugang gesichert werden.

■ § 263a StGB

§ 263a StGB (*Computerbetrug*) sanktioniert die Beeinflussung eines Datenverarbeitungsvorgangs mit unlauteren Mitteln zum Zwecke des Erlangens eines Vermögensvorteils. § 263a StGB erfasst etwa Phishing-Mails zum Zwecke der Bereicherung. Eigentlicher Schutzzweck des § 263a StGB ist zwar das Vermögen, allerdings wird durch § 263a StGB mittelbar auch die Integrität von Daten geschützt.

■ §§ 303a, 303b StGB

§ 303a StGB (*Datenveränderung*) sanktioniert das rechtswidrige Löschen, Unterdrücken, Unbrauchbarmachen oder die Veränderung von Daten. Der Straftatbestand schützt somit das Interesse des Verfügungsberechtigten an der Unversehrtheit der in gespeicherten Daten enthaltenen Informationen und deren Verwendbarkeit.

§ 303b StGB (*Computersabotage*) sanktioniert Störungen der Datenverarbeitung und schützt somit den Betrieb eines Computers oder eines Informationssystems vor Behinderung oder Störung. Eine Tatbestandsverwirklichung des § 303a StGB und des § 303b StGB ist bei Vorliegen einer entsprechenden Garantenpflicht auch durch Unterlassen möglich.

■ § 404 AktG

§ 404 AktG schützt Betriebsgeheimnisse vor der unbefugten Offenbarung von einem Mitglied des Vorstandes, einem Mitglied des Aufsichtsrates, einem Abwickler oder einem Prüfer bzw. von dessen Gehilfe. § 404 AktG kann auch durch Unterlassen verwirklicht werden, wobei, wie stets, eine Garantenstellung erforderlich ist. Diese ist bei Mitgliedern des in § 404 AktG genannten Adressatenkreises gegeben. Kommt es also etwa durch unzureichende IT-Sicherheitsstandards dazu, dass Betriebsgeheimnisse offenbart werden, so kann eine Strafbarkeit durch Unterlassen nach § 404 AktG, § 13 Abs. 1 StGB in Betracht kommen.

■ § 42 BDSG

§ 42 Abs. 1 BDSG sanktioniert die unberechtigte gewerbsmäßige Übermittlung oder das unberechtigte gewerbsmäßige Zugänglichmachen von nicht allgemein zugänglichen personenbezogenen Daten.

■ §§ 23, 4 GeschGehG

§§ 3, 4 GeschGehG schützen das Vermögen, insbesondere das Geschäftsgeheimnis und das betriebliche Know-how als selbstständige Vermögensbestandteile. Eine Strafbarkeit nach §§ 23 Abs. 1 Nr. 1, 4 Abs. 1 Nr. 1 GeschGehG bezieht sich unter anderem auf elektronische Dateien, die der rechtmäßigen Kontrolle des Inhabers des Geschäftsgeheimnisses unterliegen und ein Geschäftsgeheimnis enthalten. § 23 Abs. 1 Nr. 3 GeschGehG, welcher die Offenlegung von Geschäftsgeheimnissen unter Strafe stellt, kann bei Vorliegen einer Garantenstellung auch durch Unterlassen verwirklicht werden.

■ Art. 83 Abs. 2 S. 2 lit. c DSGVO

Bei einer Verletzung der Grundsätze der DSGVO kommt das Vorliegen einer Ordnungswidrigkeit in Betracht. Die Höhe des zu verhängenden Bußgeldes richtet sich nach den in Art. 83 Abs. 2 S. 2 DSGVO aufgelisteten Beurteilungskriterien. Bei besonders gravierenden Fällen sind Bußgelder bis zu 20 Mio. Euro oder bis zu 4 % des weltweit erzielten Umsatzes des vorangegangenen Geschäftsjahres eines Unternehmens möglich, vgl. Artikel 83 Abs. 5 DSGVO.

4.3.2 Strafrechtliche Verantwortlichkeit der einzelnen Akteure

Eine strafrechtliche Verantwortlichkeit juristischer Personen (sog. Unternehmensstrafrecht) ist dem deutschen Strafrecht (noch) fremd, da ein Strafbarkeitsvorwurf nach der herrschenden Dogmatik bisher an die Handlungs- und vor allem die Schuldfähigkeit geknüpft wird (Schuldprinzip), welche regelmäßig nur bei natürlichen Personen vorliegen kann.

Allerdings können sich unternehmensinterne strafrechtliche Verstöße mittelbar auf das **Unternehmen** selbst auswirken, da Bußgelder nach dem Ordnungswidrigkeitengesetz auch gegen juristische Personen verhängt werden können (§ 30 Abs. 1 OWiG).

Strafrechtliche Verantwortung trifft dagegen – wie aufgezeigt – nur natürliche Personen. Ein besonderes Risiko besteht hier für die **Geschäftsleitung**. Diese ist zum einen für ihr eigenes Handeln verantwortlich, ihr kann unter bestimmten Umständen aber auch deliktisches Verhalten ihrer Mitarbeiter als eigene Verfehlung angelastet werden (sogenannte Geschäftsherrenhaftung). Im Rahmen der Zurechnung gilt hierbei der Grundsatz der Allzuständigkeit und Generalverantwortung der Geschäftsleitung. Durch gesonderte Vereinbarung kann jedoch nach dem sogenannten Ressortprinzip hiervon abgewichen werden, d. h., dass jedes Mitglied der Geschäftsleitung dann nur für den eigenen Aufgabenbereich verantwortlich ist und zunächst darauf vertrauen darf, dass die anderen Mitglieder ihre Pflichten ordnungsgemäß erfüllen. Dies bedeutet aber nicht, dass die delegierten und nicht in den jeweiligen Verantwortungsbereich fallenden Pflichten vollständig abgegeben werden können, eine grundsätzliche

Überwachungspflicht bleibt immer bestehen. Dies gilt sowohl für eine horizontale als auch für eine vertikale Aufgabenverteilung. Sind konkrete Anhaltspunkte gegeben, so folgt aus der obliegenden Überwachungspflicht eine Garantenstellung im Sinne des § 13 Abs. 1 StGB. Das bedeutet, dass die Geschäftsleitung dann rechtlich dafür einzustehen hat, dass ein bestimmter Taterfolg ausbleibt. Diese Pflicht führt dazu, dass eine Strafbarkeit durch Unterlassen in Betracht kommt, wenn einer entsprechenden Handlungspflicht nicht nachgekommen wird.



Achten Sie zur Vermeidung von Strafbarkeitsrisiken auch bei delegierten Aufgaben stets darauf, der Ihnen obliegenden Überwachungspflicht nachzukommen. Zudem empfiehlt es sich, vorgenommene Überwachungsmaßnahmen zu Beweis-zwecken zu dokumentieren. Zwar obliegt im Strafprozess den Ermittlungsbehörden die Nachweispflicht. Allerdings wird durch eine entsprechende Dokumentation den Ermittlungsbehörden der Nachweis erschwert, dass den bestehenden Pflichten nicht nachgekommen wurde.

4.4 Das IT-Sicherheitsgesetz (ITSiG 2.0)

Ein wichtiges Gesetz im Bereich der IT-Sicherheit ist das „Zweite Gesetz zur Erhöhung der Sicherheit informationstechnischer Systeme“ („ITSiG 2.0“), das im Mai 2021 in Kraft trat. Es normiert einige Änderungen für verschiedene, die Informationssicherheit betreffende Gesetze, wie das BSI-Gesetz, das Telekommunikationsgesetz (TKG), das Energiewirtschaftsgesetz (EnWG), das Außenwirtschaftsgesetz (AWG) und das Sozialgesetzbuch (SGB). Aufgrund der hohen Dynamik der technischen Entwicklungen und Risiken für die IT-Sicherheit ist eine stetige Anpassung der rechtlichen Grundlagen essenziell.

Ziel des ITSiG 2.0 ist die Stärkung der Kompetenzen des Bundesamts für Sicherheit in der Informationstechnik (BSI), um die Einhaltung eines Mindestniveaus an IT-Sicherheit, insbesondere von Betreibern kritischer Infrastrukturen (KRITIS), d. h. aus den Sektoren Energie, IT und Telekommunikation, Transport und Verkehr, Gesundheit und Wasser, Ernährung, Finanz- und Versicherungswesen sowie Siedlungsabfallentsorgung (vgl. § 2 Abs. 10 Nr. 1 BSIG), die von hoher Bedeutung für das Funktionieren des Gemeinwesens sind (vgl. § 2 Abs. 10 Nr. 2 BSI), sicherzustellen. Die Befugnisse des BSI erstrecken sich dementsprechend in erster Linie auf Unternehmen, die in einem der genannten Sektoren tätig und somit einem erhöhten Risiko von Cyberangriffen ausgesetzt sind. Weiter spezifiziert werden diese KRITIS nach §§ 2 Abs. 1 S. 2, 10 Abs. 1 BSIG in der BSI-KritisV.

Daneben werden durch das ITSiG 2.0 nun aber auch sogenannte „Unternehmen im besonderen öffentlichen Interesse“ in den Geltungsbereich des BSIG einbezogen. Dies sind solche Konzerne, die zwar nicht „KRITIS“ nach der oben genannten Definition

sind, jedoch nach ihrer inländischen Wertschöpfung zu den größten Unternehmen in Deutschland gehören und daher von erheblicher volkswirtschaftlicher Bedeutung für die Bundesrepublik Deutschland sind (§ 2 Abs. 14 Nr. 2 BSIG) sowie Unternehmen der Rüstungsindustrie (§ 2 Abs. 14 Nr. 1 BSIG) und technische Anlagen mit Austritt gefährlicher Stoffe, die unter die Störfall-Verordnung (Störfall-Verordnung – 12. BImSchV) fallen (§ 2 Abs. 14 Nr. 3 BSIG). Eine genauere Festlegung der wirtschaftlichen Kennzahlen, welche für eine solche Einordnung als „zu den größten Unternehmen in Deutschland“ gehörend maßgeblich ist, erfolgt gemäß §§ 2 Abs. 14 S. 2, 10 Abs. 5 BSIG durch Rechtsverordnung.

Bis zum Redaktionsschluss wurde das „ITSiG 3.0“, das NIS2UmsuCG noch nicht beschlossen, sodass bis dahin diese Ausführungen zum IT-SiG 2.0 ihre Geltung behalten. Nach der Verabschiedung des NIS2UmsuCG werden sich aber grundsätzliche Änderungen ergeben, die in Abschnitt 4.5 beschrieben werden.

Überblick über die wichtigsten Regelungen des IT-SiG 2.0

- Der Gesetzgeber hat mit der Aktualisierung des IT-Sicherheitsgesetzes den Kompetenzbereich des BSI erweitert. Zu den betroffenen Unternehmen zählen nun auch Unternehmen im besonderen öffentlichen Interesse (beispielsweise Rüstungsunternehmen oder Unternehmen mit hoher wirtschaftlicher Bedeutung) sowie Unternehmen des Sektors der Siedlungsabfallentsorgung, siehe Abschnitt 4.4. Auch wesentliche Zulieferer von Unternehmen im besonderen öffentlichen Interesse sind künftig in den Anwendungsbereich des BSIG einbezogen (vgl. § 2 Abs. 14 Nr. 2 BSIG), wodurch dessen Relevanz für mittelständische Unternehmen zunehmen dürfte.
- Grundsätzlich wird sowohl von Unternehmen aus dem KRITIS-Bereich als auch von solchen des besonderen öffentlichen Interesses eine angemessene und dem aktuellen Stand der Technik entsprechende Absicherung der IT-sicherheitsrelevanten Prozesse gefordert (vgl. §§ 8a Abs. 1, 8 f Abs. 1 BSIG). Die konkrete Ausgestaltung der Absicherung ist für KRITIS-Unternehmen dabei im Verhältnis zu den zu erwartenden Folgen eines Ausfalls der Infrastruktur zu beurteilen (§ 8a Abs. 1 BSIG), wobei die zu ergreifenden IT-Sicherheitsmaßnahmen im Ermessen des Unternehmens liegen.

Indizien für eine angemessene Absicherung können beispielsweise die Erfüllung des BSI-Grundschutzes durch Implementierung der später näher erläuterten IT-Grundschutz-Bausteine oder eine Zertifizierung nach einem internationalen Informationssicherheitsstandard sein.

Für die praktische Umsetzung eines IT-Sicherheitskonzepts im eigenen Unternehmen bilden internationale Zertifikate eine Richtlinie. Durch eine Zertifizierung können Unternehmen gegenüber Kunden und Behörden den Nachweis erbringen, den vom BSI definierten Sicherheitsstandards zu entsprechen. In Kapitel 5 dieses

Handbuchs wurde bereits näher auf die internationalen Sicherheitsstandards und Zertifizierungen eingegangen. Um die empfohlene Strategie für eine angemessene Absicherung zu vervollständigen, wird an dieser Stelle ein Überblick über die einzelnen rechtlich relevanten Standards gegeben.

Internationale IT-Compliance-Standards bestehen im Umgang mit Informationen (ISO/IEC 2700x, ISO/IEC TR 18 044), für den Betrieb von IT-Services (ITIL bzw. ISO/IEC 20 000, SAS 70) und Netzwerken (ISO 7492-2, ISO/IEC 18 028), für Disaster Recovery und Business Continuity Management für den Umgang mit den Auswirkungen eines Cyberangriffs (ISO/IEC 24 762, BS 25 999) sowie in der Steuerung der IT (ISO/IEC 38 500). Diese Zertifikate sind Anhaltspunkte für die IT-Sicherheits-Compliance und maßgeblich für die Beurteilung einer angemessenen Absicherung.

- Die IT-Sicherheit eines KRITIS-Unternehmens muss zudem regelmäßig im Zweijahrestakt überprüft werden (§ 8a Abs. 3 BSIG). Bei auftretenden erheblichen Störungen der IT, die Auswirkungen auf kritische Dienstleistungen (wie beispielsweise Stromerzeugung oder Wasserversorgung) haben oder haben können, besteht eine unverzügliche Meldepflicht (§ 8b Abs. 4 Satz 1 BSIG). Anschließend muss die Störung auf Anordnung des Bundesamts für Sicherheit und Informationstechnik im Einvernehmen mit der jeweils zuständigen Sicherheitsbehörde des Bundes beseitigt werden (§ 8a Abs. 3 Satz 3 BSIG).

Ab dem 1. Mai 2023 werden die Unternehmenspflichten für Betreiber kritischer Infrastrukturen zudem um den Einsatz von Systemen zur Angriffserkennung erweitert, vgl. § 8a Abs. 1a BSIG. Diese Systeme müssen sich zur Bedrohungsidentifikation eignen und adäquate Beseitigungsmaßnahmen vorschlagen. Bisher ist eine Vielzahl solcher Angriffserkennungssysteme mit unterschiedlichen Abwehrstrategien verfügbar. Beispielhaft ist ein Netzwerkmonitoring mit Anomalieerkennung, das ungewöhnliche Aktivitäten erkennt und analysiert. Die individuelle Auswahl und der Einsatz solcher Systeme liegen im Ermessen des jeweiligen Unternehmens und können an die spezifischen Bedürfnisse angepasst werden, wobei die Angemessenheitsklausel des § 8a Abs. 1 S. 3 BSIG über § 8a Abs. 1a S. 3 BSIG zu beachten ist.

- Zudem erfolgt eine stärkere Reglementierung des Einsatzes und der Nutzung „kritischer Komponenten“. Hierbei handelt es sich gem. § 2 Abs. 13 BSIG um IT-Produkte (§ 9a BSIG), die in KRITIS eingesetzt werden, bei denen Störungen der Verfügbarkeit, Integrität, Authentizität und Vertraulichkeit zu einem Ausfall oder zu einer erheblichen Beeinträchtigung der Funktionsfähigkeit kritischer Infrastrukturen oder zu Gefährdungen für die öffentliche Sicherheit führen können, die aufgrund eines Gesetzes als kritische Komponente bestimmt werden. Eine konkrete Auflistung „kritischer Komponenten“ der Bundesnetzagentur ist derzeit in Arbeit und wird demnächst auf der Website der Bundesnetzagentur (www.bundesnetzagentur.de) verfügbar sein. Der Einsatz solcher kritischen Komponenten muss dem BSI gemäß § 9b BSIG angezeigt werden, dieses kann einen solchen sodann untersagen oder spezielle Anordnungen erlassen.

- Schließlich werden dem BSI zur Einhaltung der IT-Sicherheitsstandards erweiterte Handlungsmöglichkeiten eröffnet, beispielsweise durch die oben erwähnte Kompetenz zur Gebrauchsuntersagung von „kritischen Komponenten“ oder die verbindliche Festlegung von IT-Mindeststandards für die Sicherheit der Informationstechnik des Bundes gemäß § 8 BSIG.
- Zu beachten sind weitere branchenspezifische Regelungen und Ausgestaltungen des ITSIG 2.0 für Betreiber digitaler Dienste, Telemediendiensteanbieter und Telekommunikationsunternehmen, vgl. §§ 7c, 7d, 8c BSIG.

4.5 Das NIS-2-Umsetzungs- und Cybersicherheitsstärkungsgesetz (NIS2UmsuCG)

Im Bereich der IT-Sicherheit wird es mit dem „NIS-2-Umsetzungs- und Cybersicherheitsstärkungsgesetz“ („NIS2UmsuCG“) größere Änderungen geben. Das NIS2UmsuCG soll die sogenannten NIS-2-Richtlinie der EU in nationales Recht umsetzen. Dies muss bis zum 17.10.2024 geschehen. Die NIS-2-Richtlinie der EU hat eine Harmonisierung und Erhöhung des Schutzniveaus der Cybersicherheit in der EU zum Ziel.

Bis zum Redaktionsschluss wurde das NIS2UmsuCG noch nicht beschlossen, sodass die folgenden Ausführungen sich auf den bis dahin aktuellen Gesetzesentwurf der Bundesregierung vom 24.07.2024 beziehen. Es können sich noch grundsätzliche Änderungen ergeben.

Der Entwurf sieht einige Änderungen für verschiedene, die Informationssicherheit betreffende Gesetze vor, wie das BSI-Gesetz (BSIG-E), das Telekommunikationsgesetz (TKG-E), das Energiewirtschaftsgesetz (EnWG-E), das Sozialgesetzbuch (SGB-E). Aufgrund der hohen Dynamik der technischen Entwicklungen und Risiken für die IT-Sicherheit ist eine stetige Anpassung der rechtlichen Grundlagen essenziell.

Besonders umfangreich sind die geplanten Änderungen des BSIG. Hier gibt es insbesondere eine neue Einteilung in drei Kategorien von Einrichtungen, die in den Anwendungsbereich des BSIG fallen. Damit verbunden sind strengere und umfangreichere Pflichten für die jeweiligen betroffenen Einrichtungen.

Anwendungsbereich

Die drei Kategorien der Einrichtungen sind die folgenden:

1. wichtige Einrichtungen
2. besonders wichtige Einrichtungen und
3. Betreiber kritischer Infrastruktur

Die Einordnung in diese Kategorien erfolgt insbesondere über die Größe des Unternehmens und/oder den Sektor, in dem das Unternehmen tätig ist. Anlage 1 des neuen BSIG-E enthält eine Auflistung von Sektoren besonders wichtiger und wichtiger Einrichtungen, während in Anlage 2 sonstige wichtige Einrichtungen aufgelistet werden. In § 28 Abs. 1 BSIG-E wird geregelt, wann eine besonders wichtige Einrichtung vorliegt. Das ist dann der Fall, wenn ein Unternehmen in einem Sektor tätig ist, der in Anlage 1 genannt ist, und mindestens 250 Mitarbeiter beschäftigt oder einen Jahresumsatz von mindestens 50 Millionen Euro und zudem eine Jahresbilanzsumme von über 43 Millionen Euro aufweist. Es gibt außerdem Sonderfälle, die als besonders wichtige Einrichtungen gelten, z. B. qualifizierte Vertrauensdiensteanbieter, Top Level Domain Name Registries oder DNS-Diensteanbieter, Anbieter öffentlich zugänglicher Telekommunikationsdienste, die mindestens 50 Mitarbeiter beschäftigen oder einen Jahresumsatz und eine Jahresbilanzsumme von jeweils 10 Millionen Euro aufweisen, und Betreiber kritische Anlagen.

Nach § 28 Abs. 2 BSIG-E liegt eine wichtige Einrichtung vor, wenn ein Unternehmen in einem Sektor tätig ist, der in Anlage 1 oder 2 aufgelistet ist und mindestens 50 Mitarbeiter beschäftigt oder einen Jahresumsatz und eine Jahresbilanzsumme von jeweils über 10 Millionen aufweist. Außerdem fallen auch Vertrauensanbieter sowie Anbieter öffentlich zugänglicher Telekommunikationsdienste, die mindestens 50 Mitarbeiter beschäftigen oder einen Jahresumsatz und eine Jahresbilanzsumme von jeweils 10 Millionen Euro aufweisen, hierunter.

Eine kritische Anlage liegt nach § 2 Nr. 22 BSIG-E vor, wenn die Anlage einer der durch Rechtsverordnung nach § 56 Abs. 4 BSIG-E festgelegten Anlagenarten in den Sektoren Energie, Transport und Verkehr, Finanz- und Versicherungswesen, Gesundheitswesen, Wasser, Ernährung, Informationstechnik und Telekommunikation, Weltraum oder Siedlungsabfallentsorgung zuzuordnen ist und diese die durch die Rechtsverordnung nach § 56 Abs. 4 BSIG-E festgelegten Schwellenwerte überschreitet. Betreiber kritischer Anlagen fallen zugleich unter besonders wichtige Einrichtungen.

Pflichten für betroffene Unternehmen

Aus § 30 BSIG-E ergibt sich für wichtige sowie besonders wichtige Einrichtungen die Pflicht zu einem funktionierenden Risikomanagement. § 31 BSIG-E enthält besondere Anforderungen an das Risikomanagement von Betreibern kritischer Anlagen. Besonders wichtige Einrichtungen und wichtige Einrichtungen sind verpflichtet, geeignete, verhältnismäßige und wirksame technische und organisatorische Maßnahmen zu ergreifen (§ 30 Abs. 1 BSIG-E). Dabei gelten nach § 31 BSIG-E für IT-Systeme von Betreibern kritischer Anlagen auch aufwendigere Maßnahmen als verhältnismäßig, wenn der dafür erforderliche Aufwand nicht außer Verhältnis zu den Folgen eines Ausfalls oder einer Beeinträchtigung der betroffenen kritischen Anlage steht. Zusätzlich müssen Betreiber kritischer Anlagen Systeme zur Angriffserkennung einsetzen (§ 31 Abs. 2 BSIG-E).

Aus den §§ 32 ff. BSIG-E ergeben sich für die betroffenen Unternehmen Melde-, Registrierungs-, Nachweis- und Unterrichtungspflichten.

Sanktionen

Bei Verstößen hat das BSI einige Möglichkeiten, um einzugreifen. Es kann beispielsweise Anordnungen erlassen und die Einrichtung auffordern, den Mangel zu beheben. Es kann sogar einen Beauftragten zur Überwachung einsetzen und dem Management vorübergehend die Wahrnehmung der Leitungsaufgaben untersagen. Außerdem kann eine Geldbuße bis zu 10 Mio. Euro auferlegt werden. Bei besonders wichtigen Einrichtungen mit einem Jahresumsatz von mehr als 500 Mio. Euro droht bei Verstößen eine Geldbuße von bis zu 2 % des Jahresumsatzes, bei wichtigen Einrichtungen mit einem Jahresumsatz von mehr als 500 Mio. Euro eine Geldbuße von bis zu 1,4 % des Jahresumsatzes. Es wird klargestellt, dass Geschäftsführer und Leitungsorgane für die Einhaltung der Risikomanagementmaßnahmen mit ihrem Privatvermögen haften können.

4.6 Der Cyber Resilience Act

Der Cyber Resilience Act (CRA) ist eine geplante Verordnung der EU zur Stärkung der Cybersicherheit von Produkten mit digitalen Bestandteilen. Bis Redaktionsschluss wurde sie noch nicht formell verabschiedet, soll aber noch im Jahr 2024 beschlossen werden mit einer Umsetzungsfrist von 36 Monaten. Ziel des CRA ist ein besserer Schutz für Verbraucher und Unternehmer durch die Einführung verbindlicher, einheitlicher Cybersicherheitsanforderungen.

Der CRA soll sämtliche Wirtschaftsakteure betreffen, die Produkte mit digitalen Bestandteilen in der EU in Verkehr bringen. Produkte mit digitalen Bestandteilen sollen dabei alle Hard- und Softwareprodukte sein, die sich untereinander oder mit dem Internet verbinden lassen bzw. über eine Fernzugriffsmöglichkeit verfügen. Beispiele für solche Produkte sind PC-Spiele, Router, Firewalls, Chipkarten, Festplatten, Passwortmanager, Produkte mit VPN-Funktion, Webbrowser, Antivirenprogramme, Betriebssysteme und vieles mehr.

Unternehmen müssen danach ihre Produkte mit digitalen Bestandteilen in vier Risikoklassen einteilen, u. a. nach Funktion, Verwendungszweck und dem Ausmaß möglicher Auswirkungen. Dabei gibt es unkritische Produkte wie Speichermedien und Grafikprogramme; kritische Produkte der Klasse I, z. B. Browser, Passwortmanager oder Firewalls; kritische Produkte der Klasse II, etwa Router oder Firewalls für den industriellen Einsatz; und hochkritische Produkte, die für die Resilienz der gesamten Lieferkette relevant sind.

Der CRA ergänzt bereits bekannte Pflichten für Importeure und Händler des Produktsicherheitsrechts durch weitere Pflichten im Hinblick auf IT-Sicherheit. Dabei ist das

zentrale Mittel die sogenannte Konformitätsbewertung, mit der überprüft wird, ob ein Produkt Sicherheitsanforderungen erfüllt. Konforme Produkte erhalten dann das CE-Kennzeichen. Die Anforderungen an diese Prüfung richten sich nach derjenigen Kategorie, der das Produkt angehört. So soll etwa bei unkritischen Produkten eine Selbsteinschätzung der Hersteller genügen, während bei den höheren Risikoklassen eine Bewertung durch zertifizierte Dritte notwendig sein soll.

Bei Verstößen drohen Geldbußen von bis zu 15 Mio. Euro oder 2,5 % des weltweiten Umsatzes des vorangegangenen Geschäftsjahres.

4.7 Der AI-Act

Am 21.05.2024 wurde die KI-Verordnung (AI-Act) der EU verabschiedet. Sie setzt den rechtlichen Rahmen für den Einsatz von künstlicher Intelligenz (KI) in Europa und ist das weltweit erste umfassende Regelwerk für KI. Ziel des AI-Act sind Innovationsförderung, Stärken des Vertrauens in KI und die Sicherstellung, dass KI nur so genutzt wird, dass die Grundrechte und Sicherheit der EU-Bürger respektiert werden.

Der AI-Act betrifft alle Personen, die ein KI-System nicht für lediglich private Zwecke betreiben. Dabei muss das KI-System entweder für den EU-Markt bereitgestellt werden, müssen sich die Nutzer des KI-Systems in der EU befinden oder das Ergebnis des KI-Systems innerhalb der EU genutzt werden. Dabei werden KI-Systeme in Artikel 3 Abs. 1 Nr. 1 AI-Act folgendermaßen definiert: „ein maschinengestütztes System, das so konzipiert ist, dass es mit unterschiedlichem Grad an Autonomie operieren kann und nach dem Einsatz Anpassungsfähigkeit zeigen kann, und das für explizite oder implizite Ziele aus den Eingaben, die es erhält, ableitet, wie es Ergebnisse wie Vorhersagen, Inhalte, Empfehlungen oder Entscheidungen erzeugen kann, die physische oder virtuelle Umgebungen beeinflussen können“.

Der AI-Act verfolgt einen risikobasierten Ansatz. Dabei werden die KI-Systeme in vier Risikoklassen eingeteilt; je höher das Risiko ist, desto strenger sind die Pflichten, die das KI-System treffen. Bei einem nur minimalen Risiko werden lediglich Schulungen und ein Code of Conduct verlangt (Art. 4, 95 AI-Act). Besteht ein spezifisches Risiko, treffen den Betreiber des KI-Systems besondere Transparenzpflichten (Art. 50 AI-Act). KI-Systeme mit hohem Risiko gelten als Hochrisiko-KI und müssen vor deren Einsatz ein präventives Gefahrenmanagement durchlaufen, das in den Art. 6 bis 27 AI-Act geregelt wird. Das umfasst bspw. Auch Dokumentationspflichten und Qualitätsmanagementsysteme. Die höchste Risikoklasse liegt bei unannehmbaren Risiken vor. Die Inbetriebnahme oder Verwendung solcher KI-Systeme ist verboten (Art. 5 AI-Act). Solche unannehmbaren Risiken liegen z. B. vor, wenn das KI-System menschliches Verhalten ungeschwellig nachteilig beeinflussen soll, Schwächen schutzbedürftiger Personen ausnutzen soll, oder auch durch Social-Scoring-Systeme, also die Nutzung von

KI-Systemen durch Behörden zur Bewertung oder Klassifizierung von Vertrauenswürdigkeit von Personen.

Zur Durchsetzung und Überwachung des AI-Act benennen die Mitgliedstaaten entsprechende Aufsichtsbehörden. Es wird außerdem das sogenannte „European Artificial Intelligence Board“ eingerichtet, das die Mitgliedstaaten beraten soll. Für Verstöße gegen den AI-Act können Bußgelder verhängt werden. Diese richten sich nach der Art und Schwere des jeweiligen Verstoßes und können bis zu 30 Mio. Euro bzw. 6 % des weltweiten Jahresumsatzes erreichen.

4.8 Die wichtigsten Punkte in Kürze

- Im Bereich der IT-Sicherheit bestehen *hohe Haftungsrisiken*. Zu deren Minimierung bzw. Ausschluss können jedoch konkrete Maßnahmen getroffen werden. Diese reichen von entsprechenden technischen und organisatorischen IT-Sicherheits- und Datenschutzmaßnahmen, dem Entwickeln von Notfallkonzepten, einer entsprechenden Dokumentation der Vorkehrungen, über regelmäßige Risikoanalyse und -steuerung bis zu einer lückenlosen Beaufsichtigung und Einhaltung der IT-Sicherheitspflichten.
- Neben den bestehenden Haftungsrisiken sind die *straf- und ordnungswidrigkeitsrechtlichen Risiken zu berücksichtigen*.
Bei Verletzung von Pflichten des eigenen IT-sicherheitsbezogenen Handlungsbereichs, der Überwachungspflicht delegierter Aufgaben durch die Geschäftsleitung und der dienst- bzw. arbeitsvertraglichen Pflichten durch den CIO können diese einzelnen Akteure strafrechtlich zur Verantwortung gezogen werden.
- Der *strafrechtliche Schutz vor Cyberkriminalität* ist durch Schwierigkeiten in der Strafverfolgung und unzureichende cyberspezifische Straftatbestände *als gering einzustufen*. Eine unternehmenseigene, technisch ausgereifte Ausarbeitung eines angemessenen IT-Sicherheitskonzepts in Verbindung mit einem Notfallkonzept für eventuelle IT-Sicherheitsvorfälle ist daher umso relevanter.
- Auch das *TKG*, das *TMG* und die *DSGVO* normieren Anforderungen an die IT-Sicherheitsstandards der adressierten Unternehmen. Sie fordern im Wesentlichen eine angemessene technische und organisatorische Absicherung zum Schutz der Telemedien- und Telekommunikationsnetzwerke sowie der personenbezogenen Daten der jeweiligen Nutzer.
- Für die Umsetzung angemessener TOMs im Bereich der IT-Sicherheit für die Einhaltung der rechtlichen Rahmenbedingungen im eigenen Unternehmen bilden das *IT-Grundschutz-Kompendium des BSI in Verbindung mit den BSI-Standards* das Fundament. Sie sind eine Leitlinie für verschiedene Bausteine, insbesondere für

die Aufstellung eines Sicherheitsmanagements (ISMS), die bei der Implementierung Berücksichtigung finden sollten.

- Die *Reglungen des ITSiG 2.0* umfassen im Wesentlichen
 - einen erweiterten Adressatenkreis des BSIG durch den Einbezug von Unternehmen der Siedlungsabfallentsorgung in den Bereich der KRITIS sowie
 - den obligatorischen Einsatz von Systemen zur Angriffserkennung für KRITIS ab Mai 2023.
- Ebenso werden „Unternehmen im besonderen öffentlichen Interesse“ in den Regelungsbereich des BSIG einbezogen.
- Für KRITIS sowie Unternehmen im besonderen öffentlichen Interesse sind eine *angemessene technische und organisatorische individuelle Absicherung* nach dem Stand der Technik und eine regelmäßige Überprüfung des Sicherheitssystems erforderlich.
- Die geplanten Neuerungen durch das NIS2UmsuCG umfassen im Wesentlichen:
 - Einen erweiterten Adressatenkreis des BSIG durch die Einführung von drei Kategorien von erfassten Unternehmen: wichtige und besonders wichtige Einrichtungen sowie Betreiber kritischer Anlagen.
 - Umfangreiche Pflichten für die Betreiber je nachdem, unter welche Kategorie die Einrichtung fällt, insbesondere Risikomanagement, Melde-, Registrierungs-, Nachweis- und Unterrichtungspflichten.
 - Bei Verstößen drohen je nach Einordnung des Unternehmens Geldbußen von bis zu 10 Mio. Euro bzw. 2 % des weltweiten Vorjahresumsatzes.
 - Besonders wichtige Einrichtungen und wichtige Einrichtungen sind verpflichtet, geeignete, verhältnismäßige und wirksame technische und organisatorische Maßnahmen zu ergreifen.

Zusammenfassend ist zum Schutz des eigenen Unternehmens vor immensen Finanz- und Reputationsverlusten, zur Haftungsvermeidung und zur Einhaltung der mit fortschreitender Digitalisierung einhergehenden erforderlichen IT-Sicherheitsstandards eine gründliche Auseinandersetzung und darauffolgende Ausarbeitung eines technischen und organisatorischen IT-Sicherheitskonzepts essenziell.

Literatur

Altenburg, Johannes: *Unternehmerische (Fehl-)Entscheidungen als Untreue?: Eine gefährliche (Fehl-)Entwicklung!* In: Betriebsberater Heft 7 2015, Rn. 323 (m. w.N.).

Bär, Wolfgang: *Computer- und Internetkriminalität*. In: Wabnitz, Heinz-Bernd; Janovsky, Thomas; Schmitt, Lothar (Hrsg.): *Handbuch Wirtschafts- und Steuerstrafrecht*. C. H. Beck, München 2020, Rn. 14, 102, 108 (m. w.N.).

Brodowski, Dominik; Nowak, Daniella: § 42 BDSG. In: Brink, Stefan; Wolff, Heinrich Amadeus: *BeckOK Datenschutzrecht*. C. H. Beck, München 38. Edition, Stand 01.11.2021, Rn. 31.

Bundesamt für Sicherheit in der Informationstechnik (Hrsg.): *BSI-Standards*. https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/BSI-Standards/bsi-standards_node.html (abgerufen am 17.04.2024).

Bundesamt für Sicherheit in der Informationstechnik (Hrsg.): *Das IT-Sicherheitsgesetz – Kritische Infrastrukturen schützen*. https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/Broschueren/IT-Sicherheitsgesetz.pdf?__blob=publicationFile&v=1 (abgerufen am 17.04.2024).

Bundesamt für Sicherheit in der Informationstechnik (Hrsg.): *IT-Grundschutz-Kompendium – Werkzeug für Informationssicherheit*. https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/IT-Grundschutz-Kompendium/it-grundschutz-kompendium_node.html (abgerufen am 17.04.2024).

Bundesamt für Sicherheit in der Informationstechnik (Hrsg.): *Zweites Gesetz zur Erhöhung der Sicherheit informationstechnischer Systeme (IT-Sicherheitsgesetz 2.0)*. https://www.bsi.bund.de/DE/Das-BSI/Auftrag/Gesetze-und-Verordnungen/IT-Sig/2-0/it_sig-2-0_node.html (abgerufen am 17.04.2024).

Bundesamt für Sicherheit in der Informationstechnik (Hrsg.): *Die Lage der IT-Sicherheit in Deutschland 2023*. <https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/Lageberichte/Lagebericht2023.html?nn=129410> (abgerufen am 17.04.2024).

Bundesministerium des Innern und für Heimat: *Entwurf eines Gesetzes zur Umsetzung der NIS-2-Richtlinie und zur Regelung wesentlicher Grundzüge des Informationssicherheitsmanagements in der Bundesverwaltung (NIS-2-Umsetzungs- und Cybersicherheitsstärkungsgesetz); Bearbeitungsstand: 22.12.2023*. <https://intrapol.org/wp-content/uploads/2024/03/NIS2UmsuCG-RefE-Stand-12-2023.pdf> (abgerufen am 17.04.2024).

Conrad, Isabell; Streitz, Siegfried: *Risikomanagement, Haftung der Geschäftsleitung, Compliance*. In: Auer-Reinsdorff, Astrid (Hrsg.): *Handbuch IT- und Datenschutzrecht*. C. H. Beck, München 2019, § 33, Rn. 365 – 367.

Dierlamm, Alfred: § 266 StGB. In: Erb, Volker; Schäfer, Jürgen: *Münchener Kommentar zum Strafgesetzbuch*. C. H. Beck, München 2019, Rn. 92 ff., 232 (m. w.N.).

Große Vorholt, André; Dimarch, Verena: *Haftung von Führungskräften und die Konsequenzen für die Praxis*. In: Schunder, Achim; Wallisch, Jochen; Wildschütz, Martin (Schriftleitung): *Neue Zeitschrift für Arbeitsrecht-Beilage*, Heft 4 2018, Rn. 108, 109 (m. w.N.).

Hecker, Bernd: § 303a StGB, § 206b StGB. In: Schönke Adolf; Schröder Horst: *Strafgesetzbuch Kommentar*. C. H. Beck, München 2019, Rn. 1 (m. w.N.), Rn. 8.

Heger, Martin: § 303a StGB. In: Lackner, Karl; Kühl, Kristian (Hrsg.): *Strafgesetzbuch Kommentar*. C. H. Beck, München 2023, Rn. 3.

Hiéramente, Mayeul: § 23 GeschGehG. In: Fuhrott, Michael; Hiéramente, Mayeul (Hrsg.): *BeckOK GeschGehG*. C. H. Beck, München 9. Edition, Stand 15.03.2024, Rn. 37.

Hoffmann, Andreas C.; Schieffer, Anita: *Pflichten des Vorstands bei der Ausgestaltung einer ordnungsgemäßen Compliance-Organisation*. In: Altmeyen, Holger; Bergmann, Alfred; Guette, Wulf (u. a.) (Hrsg.): *Neue Zeitschrift für Gesellschaftsrecht*, Heft 11 2017, Rn. 401 ff.

Hohmann, Olaf: § 23 GeschGehG. In: Erb, Volker; Schäfer, Jürgen (Hrsg.): *Münchener Kommentar zum Strafgesetzbuch*. C. H. Beck, München 2023, Rn. 1.

Jansen, Thomas: *Haftungsfälle Cybersecurity*. In: Euroforum Deutschland GmbH (Hrsg.): *HB Journal, Sonderveröffentlichung zum Thema „FUTURE IT“*, S. 19.

Keber, Tobias: *Einführung*. In: Schwartmann, Rolf (Hrsg.): *Praxishandbuch Medien-, IT- und Urheberrecht*. C. F. Müller, Heidelberg 2017, Rn. 1.

Kühl, Kristian: *Die strafrechtliche Garantenstellung – Eine Einführung mit Hinweisen zur Vertiefung*. In: Huber, Michael; Lorenz, Stephan; Rönau, Thomas (u. a.) (Hrsg.): *Juristische Schulung*, Heft 6 2007, 497, 499.

MDR Aktuell: *Cyberangriffe von Hackern im Ausland – Deutsche Justiz oft machtlos*. <https://www.mdr.de/nachrichten/deutschland/wirtschaft/cyber-angriffe-unternehmen-hacker-russland-strafverfolgung-100.html#st> (abgerufen am 17.04.2024).

OpenKRITIS: *Das NIS2 Umsetzungsgesetz*. <https://www.openkritis.de/it-sicherheitsgesetz/nis2-umsetzungsgesetz-cybersicherheit.html> (abgerufen am 17.04.2024).

Riehm, Thomas; Meier, Stanislaus: *Rechtliche Durchsetzung von Anforderungen an die IT-Sicherheit*. In: Auer-Reinsdorff, Astrid; Forgó, Nikolaus; Gierschmann, Sibylle (u. a.; Hrsg.): *MMR Zeitschrift für IT-Recht und Recht der Digitalisierung*, Heft 9 2020, Absatz 2 Nr. 1.

Rotsch, Thomas: *Allgemeine materielle Fragen der Criminal Compliance, § 4 Originäre strafrechtliche Verantwortlichkeit*. In: Rotsch, Thomas (Hrsg.): *Criminal Compliance*. Nomos, Baden-Baden 2015, Rn. 10 (m. w. N.).

Rücker, Daniel: *IT-Sicherheitsgesetz 2.0: Neue Anforderungen und erweiterter Adressatenkreis*. <https://www.noerr.com/de/newsroom/news/it-sicherheitsgesetz-20-neue-anforderungen-und-erweiterter-adressatenkreis> (abgerufen am 17.04.2024).

Schaal, Hans Jürgen: *§ 404 AktG*. In: Häberle, Peter (Hrsg.): *Erbs/Kohlhaas Strafrechtliche Nebengesetze*. C. H. Beck, München 2023, Rn. 11.

Schmidl, Michael: *§ 28 Recht der IT-Sicherheit*. In: Hauschka, Christoph E.; Moosmayer Klaus; Lösler, Thomas (Hrsg.): *Corporate Compliance, Handbuch zur Haftungsvermeidung von Unternehmen*. C. H. Beck, München 2016, Rn. 155 (m. w. N.).

Scholz, Claudia: *Cyberangriff legt Tanklager von Oiltanking deutschlandweit vollständig lahm – Tankwagen-Beladung außer Betrieb*. <https://www.handelsblatt.com/unternehmen/energie/energieversorgung-cyberangriff-legt-tanklager-von-oiltanking-deutschlandweit-vollstaendig-lahm-tankwagen-beladung-ausser-betrieb/28023918.html?ticket=ST-4876997-bKmwYML2gFsgljWUIBL-ap6> (abgerufen am 17.04.2024).

Singelstein, Tobias; Zech, Louisa: *§ 20 Schutz der IT-Sicherheit durch das Strafrecht*. In: Hornung, Gerrit; Schallbruch, Martin (Hrsg.): *IT-Sicherheitsrecht Praxishandbuch*. Nomos, Baden-Baden 2021, Rn. 4, 28, 63.

Spindler, Gerald: *§ 93 AktG*. In: Goette, Wulf (Hrsg.): *Münchener Kommentar zum Aktiengesetz*. C. H. Beck, München 2023, Rn. 177 f.

Von dem Bussche, Axel: *Branchenübergreifende Vorgaben*. In: Kipker, Dennis-Kenji: *Cybersecurity*. C. H. Beck, München 2023, Rn. 39.

Von dem Bussche, Axel; Schelinski, Tobias: *Rechtsgrundlagen und Haftungsfolgen in der IT-Sicherheit*. In: Leupold, Andreas; Wiebe, Andreas; Glossner, Silke (Hrsg.): *Münchener AnwaltsHandbuch IT-Recht*. C. H. Beck Verlag, München 2021, Teil 7.1.

Voigt, Paul: *IT-Sicherheitsrecht: Pflichten und Haftung im Unternehmen*. Dr. Otto Schmidt, 2021, Rn. 38, 610, 611.

**In diesem Beitrag erfahren Sie,**

- welche Standards und entsprechende Zertifizierung und Testierungen es für Unternehmen in der Informationssicherheit gibt,
- wie diese zusammenhängen und welche möglichen Synergien es gibt,
- wie im Allgemeine eine Zertifizierung oder Testierung abläuft und worauf geachtet werden sollte und
- wie Beteiligte der Informationssicherheit ihre Kompetenz durch unabhängige Organisationen nachweisen können.

5.1 Einleitung

Vertrauen ist gut, Kontrolle ist besser! Eine Redewendung, die dem russischen Politiker Wladimir Iljitsch Lenin zugeschrieben wird. Nun hat Lenin rein gar nichts mit Informationssicherheit oder gar mit Standards oder Zertifizierungen gemein. Aber das, was aus dieser Redewendung abgeleitet werden kann, passt sehr gut zu unserem Themenkomplex „Standards und Zertifizierungen“. Die Redewendung will sagen, vertraue nur auf das, was du selbst geprüft hast. Denn auch wenn Informationssicherheit definiert ist, ist gute oder nicht so gute Informationssicherheit schon eine Auslegungssache und liegt im Auge dessen, der eine solche Bewertung durchführt. Um dieser Herausforderung zu begegnen, führen Gesetze oder Standards gerne den unbestimmten Begriff „Stand der Technik“ ein. Doch was ist das genau?

Weder „Stand der Technik“ noch „gute oder angemessene Informationssicherheit“ wird abschließend geklärt. Wie soll also beurteilt werden, ob ein Unternehmen eine angemessene Informationssicherheit betreibt? Können entsprechende Maßnahmen

(sei es technisch oder organisatorisch) ergriffen werden, um Informationen vor Missbrauch, unberechtigter Veränderung, Diebstahl zu schützen? Hier kommt dann die obige Redewendung von Lenin zum Einsatz, indem ich als Interessierter (sei es als Kunde, Vertragspartner, Anteilseigner, behördliche Aufsicht, Versicherer, Bank etc.) mir selbst ein Bild davon mache. Alleine die kurze Aufzählung zeigt, dass dies wohl schwer praktikabel sein wird. Denn zum einen würden ständige Kontrollen im Unternehmen von unterschiedlichen Interessierten durchgeführt werden, und zum anderen können die Einschätzungen darüber hinaus durchaus unterschiedlich ausfallen. Was gleich zur nächsten Herausforderung führt. Wie gehe ich als Unternehmen mit unterschiedlichen Einschätzungen um und wie versuche ich diese widerspruchsfrei aufzulösen? Selbstverständlich wird jetzt der Einwand kommen, dass zwischen den interessierten Parteien und dem Unternehmen Verträge, Vereinbarungen oder gar Gesetze existieren. Dies ist grundsätzlich richtig, allerdings muss auch hier bedacht werden, dass diese niemals so genau, abschließend oder vollständig definiert werden können, dass es hier keinen Interpretationsspielraum gibt. Hier kommen Standards und Zertifizierungen ins Spiel, um eine praktikable Lösung zu sein.

Eine Verwendung von Standards und Zertifizierungen für die Außenwirkung entwickeln eine immer größere Bedeutung. Die Gründe, warum eine Zertifizierung eine wesentliche Rolle in der Informationssicherheit spielt, sind vielfältig und abhängig vom Geschäftsmodell des Unternehmens. Folgende Gründe können eine Rolle spielen (BITKOM 2014):

- Unternehmen sind in einem stark reglementierten Bereich tätig (z. B. Banken oder Versicherungen), wo Aufsichtsbehörden klare Vorgaben machen, wann und unter welchen Bedingungen Auslagerungen vorgenommen werden dürfen.
- Bei Ausschreibungen von Behörden oder Unternehmen wird zunehmend eine Zertifizierung gefordert. Wer als Unternehmen über keine zertifizierte Informationssicherheit verfügt, scheitert schon hier.
- Etablierte Informationssicherheitsprozesse basieren auf Standards und können die Prämie von Versicherungen (gerade Cyberversicherungen) positiv beeinflussen.
- Für Unternehmen aus dem Bereich der kritischen Infrastrukturen (KRITIS) sind Standards mit gewissen Übergangsfristen ein absolutes Muss. Darüber hinaus ist absehbar, dass dies nicht nur für Unternehmen der KRITIS-Branchen gilt, sondern auch Partner und Zulieferer betroffen sein werden.
- Steigende Sensibilität von Kunden bezüglich Informationssicherheit, denn spektakuläre Sicherheitsvorfälle geben berechtigten Anlass zu Zweifeln, was Unternehmen in eigenen Broschüren oder auf ihrer Homepage über ihre Informationssicherheit kundtun.

- Zertifizierungen der Informationssicherheit dienen Unternehmen als Nachweis für vorgeschriebene Audits im Umfeld von Lieferanten-/Partner-/Tochterbeziehungen.
- Im Rahmen der Datenschutzgrundverordnung (DSGVO) und der Auftragsverarbeitung sieht der Gesetzgeber selbst vor, Zertifizierungen nach Art. 42 DSGVO vorzunehmen. Hierdurch entsteht auch ein Interesse an vergleichbaren oder artverwandten Zertifizierungen.

Neben einer Außenwirkung haben Standards und Zertifizierungen auch eine deutliche Innenwirkung. Die Verwendung von etablierten Standards hat hierbei zum Ziel, die sicherheitsrelevanten IT-Prozesse zum Vorteil des Unternehmens, der Kunden und Vertragspartner, der eigenen Produkte sowie der Mitarbeiter laufend zu verbessern. Sie bieten Hilfestellungen bei der Entwicklung von technischen und organisatorischen Maßnahmen sowohl auf Managementebene als auch bei technischen Implementierungen. Als Seiteneffekt führt dies auch dazu, dass Haftungsrisiken für Vorstand oder Geschäftsführung minimiert werden, da durch die Umsetzung von Standards nachgewiesen werden kann, dass der Sorgfaltspflicht und der kaufmännischen Vorsicht nachgekommen wurde.

Der Einsatz von Standards und Zertifizierungen in der Informationssicherheit ist somit nicht Selbstzweck, sondern folgt immer einem Nutzen. Dieser Nutzen muss definiert werden, und jedes Unternehmen muss dies für sich selbst festlegen, ob nur Standards im Unternehmen umgesetzt werden oder ob auch eine unabhängige Zertifizierung erfolgen soll oder muss. Denn zuallererst dienen Standards dazu, unterschiedliche Ziele einheitlich festzulegen und auch, wie diese Ziele zu erreichen sind. Darüber hinaus muss ein Unternehmen festlegen, wie es Informationssicherheit leben möchte und welches Sicherheitsniveau angestrebt wird. Abhängig vom Standard kann der Weg zur Erreichung der Ziele technisch konkret beschrieben werden oder nur generisch gehalten sein. Erst im Schritt danach dienen Standards als Prüfgrundlage von Prüfungs- oder Zertifizierungsgesellschaften, um unabhängige Zertifikate oder Testierung zu erteilen.



Hinweis

Achten Sie im Unternehmen darauf festzulegen, welchen Fokus ein Standard haben soll. Zählt nur die Innenwirkung, so kann auf eine unabhängige Zertifizierung verzichtet werden. Denn nicht nur die Umsetzung von sicherheitsrelevanten IT-Prozessen bindet Ressourcen. Auch eine Zertifizierung ist ein nicht zu vernachlässigender Kostenfaktor mit Kosten der Zertifizierung, Vorbereitung der beteiligten Fachbereiche, Vorhalten notwendiger Nachweise, Einbindung der Fachbereiche in die Zertifizierung etc. Wenn keine Zertifizierung angestrebt wird, kann durchaus bei der Umsetzung von Standards auf einige Anforderungen verzichtet werden, wenn der interne Mehrwert nicht sofort ersichtlich und das Risiko überschaubar ist, wenn eine Anforderung nicht sofort umgesetzt wird.

5.2 Standards

Auch wenn dies nicht sofort offensichtlich ist: Ein Leben ohne standardisierte Produkte oder Dienstleistungen ist heute kaum noch vorstellbar. Kunden können darauf setzen und vertrauen, dass Produkte oder Dienstleistungen, die Standards entsprechen, ein Mindestmaß an Sicherheit und Gebrauchstauglichkeit bieten und kompatibel sind (Hartlieb 2016). Ein Beispiel für solch einen Standard ist das bekannte DIN-A4-Blatt.

Analog der Standards für Produkte oder Dienstleistungen haben sich auch Standards für Managementsysteme (der bekannteste ist wohl der Qualitätsmanagementstandard ISO 9001) entwickelt. In Unternehmen gibt es viele Themenstellungen, die über Managementsysteme erfolgreich umgesetzt werden. Dies gilt eben auch für die Informationssicherheit. So haben sich diverse Standards zur Informationssicherheit entwickelt. Je nach Fokus des Standards haben manche einen hohen Bezug zu Managementsystemen oder eben auch technische oder prozessuale Schwerpunkte. Dabei kann die in Bild 5.1 verwendete Unterscheidung genutzt werden, wo der jeweilige Standard zu verorten ist.

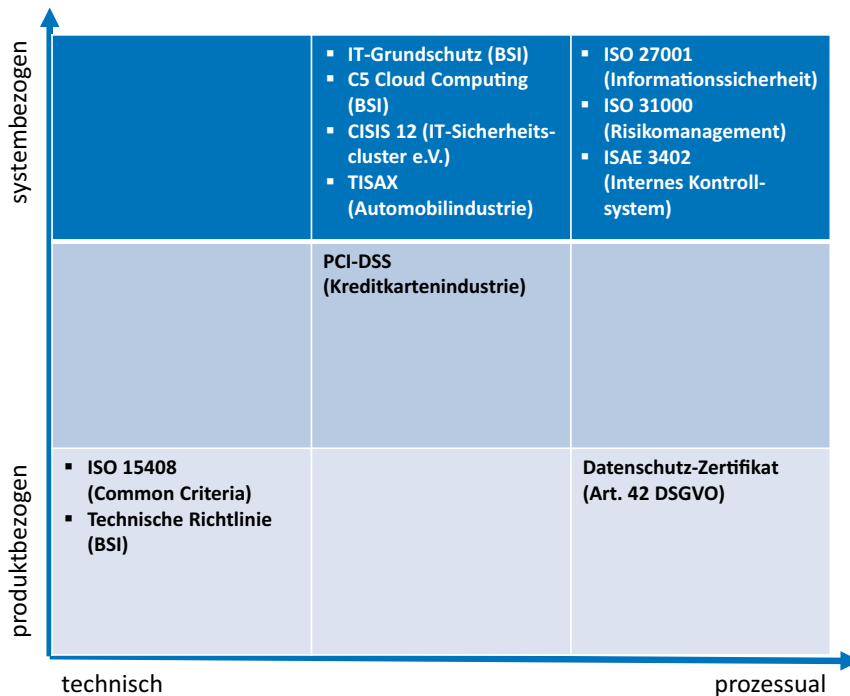


Bild 5.1 Schematische Darstellung der Standards zur Informationssicherheit und deren Verortung

Im Folgenden werden die einzelnen Standards kurz vorgestellt.

■ **ISO 27 001 (Informationssicherheit)**

Die internationale Norm ISO 27 001, herausgegeben von der International Organization for Standardization, kurz ISO, spezifiziert die Anforderungen für Einrichtung, Betrieb, Aufrechterhaltung und fortlaufende Verbesserung eines dokumentierten Informationssicherheitsmanagementsystems. Hiermit stellt diese Norm den Quasistandard für Informationssicherheit dar und besitzt den Vorteil, dass hiernach auch eine Zertifizierung erfolgen kann. Welchen Erfolg diese Norm international hat, verdeutlicht die Anzahl vorhandener Zertifizierungen weltweit (siehe Bild 5.2).

Der Vorteil dieser Norm stellt ihr risikoorientierter Ansatz dar, der es ermöglicht, diese Norm auf beliebige Unternehmensformen und -größen anzuwenden. Die Norm selbst ist in zwei wesentliche Blöcke unterteilt. Der erste Teil konzentriert sich auf das Managementsystem zur Informationssicherheit. Dieser Teil ist Pflicht für alle Unternehmen und definiert, welche Prozesse und Strukturen in der Informationssicherheit vorhanden sein müssen. Dabei handelt es sich um Themen wie Rolle der Unternehmensleitung, Vorgaben zur Informationssicherheit, Rollen in der Informationssicherheit, Prozesse zur Risikoanalyse, Kompetenz und Bewusstsein für Informationssicherheit, Überwachung der Informationssicherheit und Umgang mit erkannten Mängeln bei der Informationssicherheit.

Der zweite Teil (Anhang A der ISO 27 001) beinhaltet einen Katalog von Referenzmaßnahmen, die umgesetzt werden sollten, um Risiken der Informationssicherheit zu begegnen. Einzelne Maßnahmen können demnach auch nicht umgesetzt werden, wenn z. B. die Maßnahme nicht anwendbar ist oder das Unternehmen sich bewusst dagegen entscheidet und die willentliche Entscheidung trifft, das Risiko einzugehen, das durch die Nichtumsetzung entsteht. Bei den Referenzmaßnahmen handelt es sich allerdings nicht um konkrete technische oder organisatorische Maßnahmen, sondern um Ziele, die mit einer Maßnahme erreicht werden sollen. So wird z. B. beim Schutz gegen Schadsoftware Folgendes gefordert: „Erkennungs-, Vorbeugungs- und Wiederherstellungsmaßnahmen zum Schutz vor Schadsoftware in Verbindung mit einer angemessenen Sensibilisierung der Benutzer sind umgesetzt.“ Aus der Aussage ist zu erkennen, dass den Nutzern der Norm nicht etwas Konkretes vorgesetzt wird, was umzusetzen ist. Vielmehr fordert die Norm Unternehmen auf, sich für sich selbst damit zu beschäftigen und für sich selbst angemessene Maßnahmen umzusetzen. Auch hier ist der Ansatz erkennbar, dass die Norm für unterschiedlichste Unternehmensformen und -größen anwendbar ist. Als Hilfe zur Auslegung dieser Ziele kann sich ein Unternehmen der ISO 27 002 bedienen. Hier werden diese eingehender dargestellt und erläutert, wie diese Ziele z. B. erreicht werden können. Die ISO 27 002 stellt hierbei eine Ergänzungsnorm dar, die bei einer Zertifizierung nicht explizit berücksichtigt wird. Je nach Größe, Geschäftstätigkeit und Sensibilität der Informationen,

mit denen gearbeitet wird, können hier unterschiedliche Maßnahmen definiert werden. So schlägt die ISO 27 002 für das obige Beispiel für den Schutz vor Schadsoftware vor, nicht genehmigte Software nicht ausführen zu lassen, nur zugelassene Websites besuchen zu dürfen, Softwarelücken zeitnah zu schließen, die Installation einer Schadcode-Protection-Lösung, regelmäßige Analyse von Dateien etc. Der Maßnahmenkatalog in der ISO 27 001 ist selbstverständlich nicht abschließend. Sollte also ein Unternehmen bei ihren Risikoanalysen feststellen, dass die Maßnahmen nicht ausreichen, um das ermittelte Risiko einzugrenzen, kann es darüber hinaus weitere Maßnahmen definieren und umsetzen.

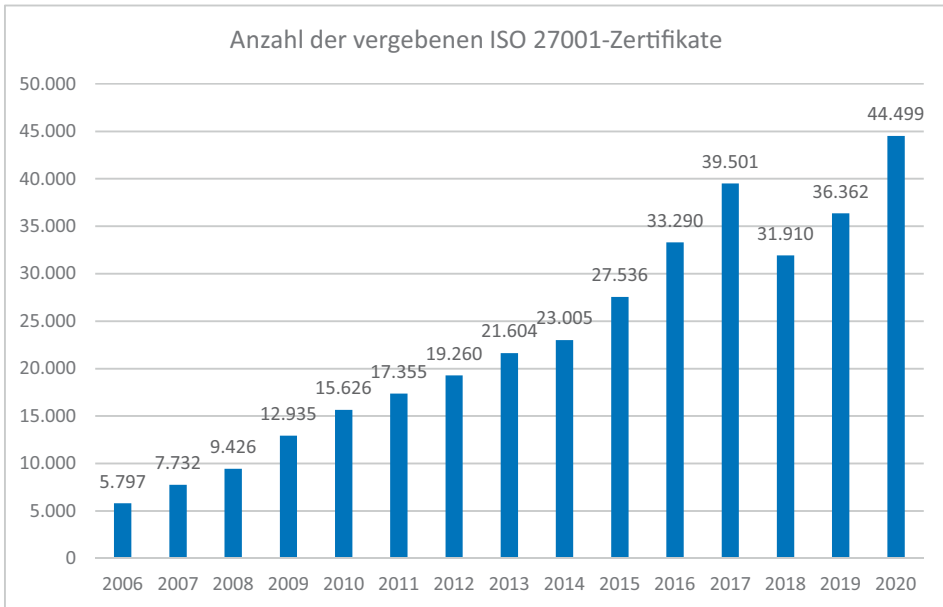


Bild 5.2 Bestand an gültigen ISO 27 001-Zertifikaten zwischen 2006 und 2020 (statistica 2021)

■ **ISO 31 000 (Risikomanagement)**

Eine internationale Norm für das Risikomanagement, die erstmalig 2008 veröffentlicht wurde. Rein formal betrachtet hat diese Norm keinen Bezug zur Informationssicherheit, doch trotzdem ist sie quasi unverzichtbar. Denn die Intention der ISO 31 000 ist es, den Risikomanagementprozess in bereits bestehende Managementsysteme zu integrieren, mit dem Ziel, den Risikomanagementprozess zu optimieren und von der reinen Gesetzesbefolgung wegzukommen. Oder kurz ausgedrückt: „Weg von der passiven Schadensbegrenzung, hin zur aktiven und vorbeugenden Risikohandlung“.

Warum spielt dann diese Norm so eine wichtige Rolle in der Informationssicherheit oder bei Zertifizierungen? Denn anders als die ISO 27 001 ist diese Norm nicht eigenständig zertifizierungsfähig. Die ISO 27 001 ist dafür gedacht, ein Informationssicherheitsmanagementsystem für Informationssicherheit aufzubauen. Dabei ist die Risikoorientierung eines der zentralen Elemente. Da die ISO 27 001 aber selbst zum Prozess des Risikomanagements recht wenig Auskunft gibt, muss sich ein Unternehmen hier alternativer Standards bedienen. Die ISO 27 001 selbst verweist hier in diesem Zusammenhang auf die ISO 31 000.

Wesentlicher Bestandteil der ISO 31 000 ist der Risikomanagementprozess, der sich vereinfacht in die einzelnen Schritte Risikobeurteilung, Risikosteuerung, Risikoüberwachung und Risikoberichterstattung aufteilen lässt. Die Norm gibt somit einen guten Rahmen für den Prozess des Risikomanagements ab, klärt aber nicht auf, auf welche Risiken bezogen auf Informationssicherheit sich ein Unternehmen denn konzentrieren sollte. Zwar erlaubt die ISO 31 000, Substandards zu definieren, um eben z. B. Risikokataloge für Informationssicherheit festzulegen. Dies ist allerdings in der Zwischenzeit nicht passiert. Hier muss sich ein Unternehmen somit alternativer Quellen bedienen. Hier kann die ISO 27 005 verwendet werden, die in ihren Anhängen Beispiele für Bedrohungen und Verwundbarkeit beinhaltet, oder der elementare Gefährdungskatalog des Bundesamts für Sicherheit in der Informationstechnik im IT-Grundschutz-Katalog.

■ ISAE 3402 (Internes Kontrollsystem)

Die ISAE 3402 (International Standards for Assurance Engagements) ist ein internationaler Prüfungsstandard für Auslagerungsvorhaben, welcher dem auslagernden Unternehmen die Beurteilung der internen Kontrollen des Dienstleisters ermöglicht. Herausgeber ist dabei die International Federation of Accountants.

Bei der ISAE 3402 lassen sich zwei Berichtstypen unterscheiden:

- *Typ 1:* Es findet eine Beurteilung der Kontrollziele und deren Umsetzung statt. Jedoch werden die Kontrollen nicht auf ihre Wirksamkeit untersucht.
- *Typ 2:* Neben den Kontrollzielen und deren Implementierung wird auch die operative Wirksamkeit der Kontrollen stichprobenartig analysiert.

Die Besonderheit der ISAE 3402 ist, dass diese nicht ein Managementsystem wie die ISO 27 001 darstellt. Vielmehr werden hier Prozesse oder Anwendungen einer Überprüfung unterzogen, die im Vorfeld als relevant klassifiziert werden.

Stellt sich die Frage: Ist die ISAE 3402 oder die ISO 27 001 die bessere Norm für Informationssicherheit? Die Hauptunterschiede liegen in den Details, der Form der Berichterstattung und dem durchgeführten Audit. Im Wesentlichen gibt es unter ISAE 3402 keine klaren definierten Regeln und Standards, sondern dem Unternehmen bleibt es selbst überlassen, seine eigenen Sicherheitskontrollen und -prinzipien zu erstellen, die von unabhängigen Wirtschaftsprüfungsgesellschaft-

ten getestet werden. Weiterer Vorteil der ISAE 3402 ist die Tatsache, dass einige Unternehmen mindestens die Variante Typ 2 mit einer SOC 2-Prüfung gleichsetzen, welche vor allem für den amerikanischen Markt wichtig ist. Die ISO 27001 besteht aus detaillierten Richtlinien und ist strenger. Wenn Risiken nicht effektiv gemanagt werden, wird dies im ISAE 3402-Bericht offengelegt. Bei der Zertifizierung der ISO 27001 durch eine akkreditierte Zertifizierungsgesellschaft wird diese Offenlegung nicht erfolgen. Eine eindeutige Aussage ist daher nicht möglich. Es kommt somit darauf an, ob ein solides System zur Verwaltung der Informationssicherheit vorhanden sein soll, dann die ISO 27001, oder ob der Fokus eher auf die Beurteilung des Risikomanagements für Prozesse oder Anwendungen liegt, dann die ISAE 3402.

■ IT-Grundschutz (Bundesamt für Sicherheit in der Informationstechnik)

Der IT-Grundschutz ist Methode, Anleitung, Empfehlung und Hilfe zur Selbsthilfe für Unternehmen, die sich mit der Absicherung ihrer Daten, ihren Systemen und Informationen befassen wollen (BSI 2021). Der IT-Grundschutz besteht dabei aus mehreren Veröffentlichungen. Die BSI-Standards 200-1 bis 200-3 legen fest, wie ein Informationssicherheitsmanagementsystem in einem Unternehmen aufgebaut werden kann, um Geschäftsprozesse abzusichern. Im IT-Grundschutz-Kompendium finden sich einzelne Abschnitte, die sogenannten IT-Grundschutz-Bausteine, was ein Unternehmen tun muss, um einen bestimmten Bereich besser abzusichern. Die Bausteine lassen sich hier in die Abschnitte Organisation und Personal, Konzepte und Vorgehensweisen, Betrieb, Detektion und Reaktion, Anwendungen, IT-Systeme, Netze und Kommunikation und Infrastruktur unterteilen. Für jeden einzelnen Baustein definiert das BSI Basisanforderungen, Standardanforderungen und Anforderungen bei erhöhtem Schutzbedarf. Anders als die ISO 27001 definieren die Anforderungen keine Ziele, sondern Maßnahmen, die ein Unternehmen umsetzen muss, und sind damit deutlich konkreter. Dabei müssen die Basisanforderungen vorrangig erfüllt werden. Gemeinsam mit den Basisanforderungen erfüllen die Anforderungen der Standardanforderungen den Stand der Technik für den jeweiligen Baustein. Anforderungen bei erhöhtem Schutzbedarf sollten dann in Erwägung gezogen werden, wenn das Unternehmen oder das jeweils zu untersuchende System mit Daten mit erhöhtem Schutzbedarf in Berührung kommt oder verarbeitet. Wichtig ist hierbei der Begriff „sollte“. Anders als bei den anderen beiden Stufen sind hier die Maßnahmen nicht verpflichtend. Vielmehr muss das Unternehmen in solchen Fällen eine Risikoanalyse durchführen und auf Grundlage des Ergebnisses festlegen, ob diese Maßnahmen umgesetzt werden müssen oder auf eine Anwendung verzichtet werden kann.

Hier wird damit auch der entscheidende prozessuale Unterschied zwischen der ISO 27001 und dem IT-Grundschutz sichtbar. Während die ISO 27001 konsequent den Weg der Risikoorientierung geht, ist dies beim IT-Grundschutz erst dann notwendig, wenn ein erhöhter Schutzbedarf vorhanden ist. In der Konsequenz bedeutet dies, dass laut ISO 27001 ein Unternehmen durchaus Daten mit geringem

Schutzbedarf auch ungeschützt lassen kann, wenn das Unternehmen die eingehenden Risiken trägt. Dies ist beim IT-Grundschutz schlichtweg nicht möglich. Denn dort gelten mindestens die Basisanforderungen oder auch die Standardanforderungen, wenn ein Unternehmen den Stand der Technik umsetzen möchte. Dieser methodische Unterschied führt aber nicht dazu, dass IT-Grundschutz und ISO 27001 inkompatibel sind. Denn die ISO 27001 legt nicht fest, wann die Risikoorientierung greift. Letztendlich kann ein Unternehmen die Methode des BSI übernehmen und damit auch eine ISO 27001-Zertifizierung erhalten.

Analog der ISO 27001 besteht auch die Möglichkeit, sich den IT-Grundschutz zertifizieren zu lassen. Dabei wird dann eine ISO 27001-Zertifizierung auf der Basis von IT-Grundschutz ausgestellt. Diese Zertifizierung ist sowohl für die Standardabsicherung als auch für die Kernabsicherung möglich. Das BSI stellt solche Zertifikate auf der Grundlage eines Auditberichts aus, den nur ein vom BSI zertifizierter Auditor erstellen darf.

■ **C5 Cloud Computing (Bundesamt für Sicherheit in der Informationstechnik)**

Cloud Computing Compliance Controls Catalogue, oder nur kurz C5 genannt, ist ein Anforderungskatalog vom BSI, der sich prinzipiell an professionelle Cloud-dienstleister richtet. Darin wird festgelegt, welche Anforderungen zu erfüllen sind bzw. auf welche Anforderungen er mindestens verpflichtet werden sollte. Durch den C5-Katalog wird ein einheitlicher Sicherheitsrahmen für die Zertifizierung von Clouddienstleistern sichergestellt, und für die Nutzer des Cloudanbieters dient er als Zusicherung, dass ihre Daten sicher verwaltet werden.

Der C5-Katalog, erstmalig 2016 erschienen und in der aktuellen Version 2020 überarbeitet, besteht aus 114 Anforderungen in 17 unterschiedlichen Teildisziplinen, wie z. B. Organisation der Informationssicherheit, Identitäts- und Berechtigungsmanagement oder der Kommunikationssicherheit. Neben den Basisanforderungen in C5 sind zu vielen Punkten auch weitergehende Anforderungen enthalten, die entweder besonders die Vertraulichkeit oder die Verfügbarkeit oder beides zugleich ansprechen.

Da der C5-Katalog auf international anerkannten Informationssicherheitsstandards basiert und gewisse Anforderungen weiterentwickelt, verwundert es nicht, dass das BSI auf seiner Homepage gleich auch umfangreiche Mapping-Tabellen anbietet. Überschneidungen zur ISO 27001 oder dem IT-Grundschutz können so einfach und schnell nachvollziehbar identifiziert werden.

■ **CISIS12 (Informationssicherheit in zwölf Schritten)**

Das Compliance-Informationssicherheitsmanagementsystem in zwölf Schritten besteht aus einer Norm, dem Maßnahmenkatalog sowie einem Handbuch, das als Grundlage für die Umsetzung dient. Herausgeber und Ersteller dieser Norm ist der IT-Sicherheitscluster e. V. Wo andere Standards den Unternehmen Möglichkeiten zur Interpretation bieten, wird in dieser Norm ein anderer Ansatz verfolgt. Es werden hier klare Handlungsempfehlungen in zwölf übersichtlichen Schritten ge-

geben. Die Einführung wird in vergleichsweise leicht handhabbare Arbeitspakete aufgeteilt, was die Einführung und den Betrieb eines Informationssicherheitsmanagementsystems vereinfacht. Somit eignet sich dieser Standard besonders für kleine Unternehmen oder Kommunen. Da der Standard auf der vorher schon vorgestellten ISO 27001 und dem IT-Grundschutz basiert, ist ein späterer Wechsel für ein Unternehmen jederzeit möglich.

Die zwölf Schritte können als Arbeitspakete interpretiert werden und beinhalten Punkte wie z.B. Leitlinie erstellen, IT-Struktur analysieren, Risikomanagement oder interne Audits. Eine Übersicht über die einzelnen Schritte und deren Reihenfolge gibt Bild 5.3.

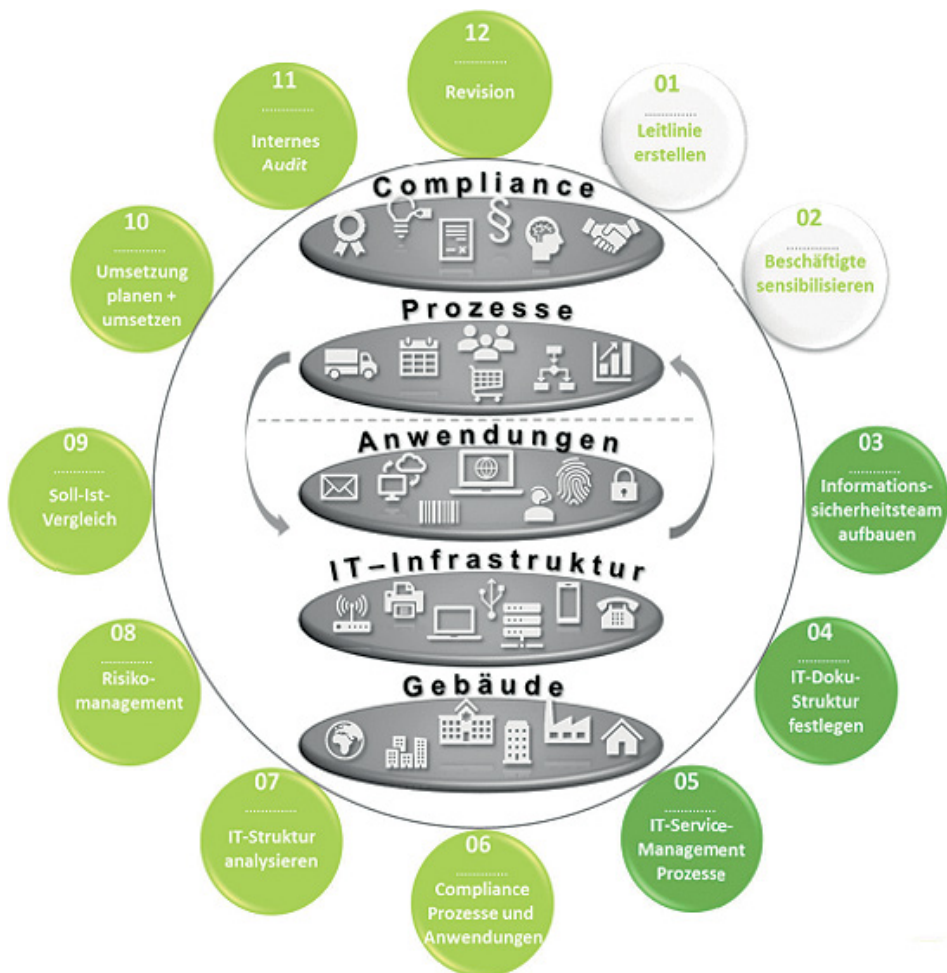


Bild 5.3 Die zwölf Prozessschritte von CISIS12 (CISIS12 2021)

■ TISAX (Trusted Information Security Assessment Exchange)

Ist ein von der Automobilindustrie (VDA – Verband der Automobilindustrie) definierter Prüf- und Austauschmechanismus von Prüfergebnissen für die Informationssicherheit und gilt für alle Zulieferer oder Dienstleister in der Automobilindustrie. Kernprodukt von TISAX ist der Fragenkatalog, der als Information Security Assessment bezeichnet wird. Schwerpunkte bei dem Assessment bilden die drei Themen Informationssicherheit, Datenschutz und Prototypenschutz. Die Basis-Controls zur Informationssicherheit basieren auf der ISO 27 001 und beinhalten im Wesentlichen auch die dort definierten Bereiche. Der Bereich Datenschutz ist dann auszufüllen, wenn bei der Dienstleistung oder Lieferung auch eine Auftragsverarbeitung im Sinne des Art. 28 DSGVO vorliegt. Der Prototypenschutz umfasst als schutzbedürftig klassifizierte Fahrzeuge, Komponenten und Bauteile, welche noch nicht der Öffentlichkeit vorgestellt wurden.

Für den Dienstleister oder Zulieferer in der Automobilindustrie ist es wichtig zu wissen, welches Assessment-Level vom Auftraggeber gewünscht wird. Dieses Level hängt ab vom Schutzbedarf der geteilten oder überlassenen Daten. Die Levels unterscheiden sich im jeweiligen Prüfverfahren und in der Intensität der Prüfung. Von einem Level 1 Assessment wird gesprochen, wenn nur ein reines Self-Assessment durchgeführt wurde. Hierfür gibt es dann auch nicht das begehrte TISAX-Label. Die höchste Stufe ist das Level 3 Assessment, in dem eine intensive Vor-Ort-Prüfung der Informationssicherheit und Managementprozesses von einem von der ENX (ENX Association ist ein Zusammenschluss europäischer Automobilhersteller, -zulieferer und -verbände) zugelassenen Prüfer durchgeführt wird.

■ PCI DSS

PCI DSS steht für Payment Card Industry Data Security Standard und wurde vom PCI Security Standards Council entwickelt, um Kreditkartenzahlungen zu schützen. Alle Firmen, die Daten von Karteninhabern verarbeiten, müssen PCI DSS genügen. Die Compliance-Validierung erfolgt über einen qualifizierten Sicherheitsgutachter (Qualified Security Assessor (QSA)), einen internen Sicherheitsgutachter (Internal Security Assessor (ISA)) oder einen Selbstbewertungsfragebogen (Self-Assessment Questionnaire (SAQ)). Letzteres gilt für Unternehmen, die Daten dieser Art nur in geringen Mengen verarbeiten.

PCI DSS zu erfüllen heißt, dass Unternehmen geeignete Maßnahmen ergreifen müssen, um die betreffenden Daten vor Diebstahl und betrügerischer Nutzung zu schützen. Die Sicherheitsanforderungen des PCI-DSS-Regelwerks lassen sich grob in die folgenden zwölf Abschnitte unterteilen (PCI-DSS 2018):

- Installation, Einrichtung und regelmäßige Aktualisierung der Firewall zum Schutz von Daten
- Keine vom Anbieter gelieferten Standardeinstellungen für Systemkennwörter und andere Sicherheitsparameter verwenden

- Schutz gespeicherter Karteninhaberdaten
- Verschlüsselung bei der Übertragung von Karteninhaberdaten über offene öffentliche Netze
- Schutz sämtlicher Systeme vor Malware und regelmäßige Aktualisierung von Antivirensoftware und Programmen
- Entwicklung und Wartung sicherer Systeme und Anwendungen
- Beschränkung des Zugriffs auf Karteninhaberdaten je nach Geschäftsinformationsbedarf
- Zugriff auf Systemkomponenten identifizieren und authentifizieren
- Physischen Zugriff auf Karteninhaberdaten beschränken
- Verfolgung und Überwachung des gesamten Zugriffs auf Netzwerkressourcen und Karteninhaberdaten
- Regelmäßiges Testen der Sicherheitssysteme und -prozesse
- Verwaltung einer Informationssicherheitsrichtlinie für das gesamte Personal
- **Datenschutz-Zertifikat (Art. 42 DSGVO)**

Die Datenschutzgrundverordnung (kurz DSGVO) schafft mit Artikel 42 DSGVO erstmalig den Rahmen für eine Zertifizierung für den Datenschutz. Zielsetzung dieser Zertifizierung soll es sein, Verantwortliche oder Auftragsverarbeiter einen Nachweis zu ermöglichen, dass ein Verarbeitungsvorgang den Anforderungen des DSGVO entspricht. Dieser Nachweis darf von akkreditierten Zertifizierungsstellen ausgestellt werden.

Da die DSGVO an sich gesehen schwer prüfbar ist, weil viel zu abstrakt, wurden für die Zertifizierung 50 prüfbare Kriterien entwickelt, die in elf Gruppen thematisch aufgeteilt sind:

- Zulässigkeit der Datenverarbeitung
- Grundsätze
- Pflichten des Verantwortlichen
- Auftragsverarbeitung
- Technisch-organisatorische Maßnahmen
- Datenschutz-Management
- Datenverarbeitung außerhalb der EU
- Betroffenenrechte
- Beschwerde-Management
- Applikations-Management
- Förderung des Datenschutzes

Auch wenn die DSGVO bereits im Mai 2018 ihre Gültigkeit erhalten hat, gibt es weder in Deutschland noch in Europa aktuell die Möglichkeit (Stand November

2021), eine solche Zertifizierung zu erlangen. Die Vorgaben zur Schaffung dieser Zertifizierung sind anspruchsvoll (Gühr 2020). Mit den ersten Möglichkeiten zur Zertifizierung wird im Laufe des Jahres 2021 zu rechnen sein.

- **ISO 15408 (Common Criteria)**

Die Norm definiert ein Anforderungskatalog für die Sicherheitsbeurteilung von IT-Produkten und IT-Systemen. Dabei besteht der Standard aus drei zusammengehörigen Teilen, der „Einführung und allgemeines Modell“, den „Funktionalen Sicherheitsanforderungen“ und den „Anforderungen an die Vertrauenswürdigkeit“. IT-Produkte und IT-Systeme können nach dem Standard, auch als Common Criteria bekannt, zertifiziert werden.

- **Technische Richtlinien (BSI)**

Neben dem IT-Grundschutz hat das BSI auch etliche technische Richtlinien veröffentlicht. Mit Stand November 2021 sind dies aktuell 57 Stück. Ziel dieser Richtlinien ist die Verbreitung angemessener IT-Sicherheitsstandards und damit der Aufbau und die Absicherung von IT-Systemen. Das Spektrum der Themen ist hierbei sehr vielfältig, angefangen vom sicheren E-Mail-Transport, Einsatz von Kryptografie, digitalen Gesundheitsanwendungen bis hin zum ersetzenden Scannen.

Nicht für jede technische Richtlinie ist hierbei eine Zertifizierung möglich. Das BSI veröffentlicht auf seiner Website eine Übersicht der möglichen Zertifizierungen durch vom BSI hierzu zugelassenen Auditoren. Ähnlich wie bei der ISAE 3402 oder Art. 42 DSGVO handelt es sich hier nicht um die Zertifizierung von ganzen Unternehmen, sondern vielmehr um sehr klar abgrenzbare Prozesse oder IT-Systeme.

5.2.1 Synergien zwischen Standards auflösen und nutzen

Im vorherigen Absatz wurden die unterschiedlichen Standards mit Bezug zur Informationssicherheit vorgestellt. Jeder Standard hat seine eigene Zielsetzung und Zielgruppe. Was jedoch nicht bedeutet, dass es keine Überschneidungen bzw. Synergien zwischen den Standards gibt. Dass es Synergien geben muss, lässt sich im Übrigen recht leicht ableiten. Denn die Informationssicherheit hat zum Ziel, die Vertraulichkeit, Integrität und Verfügbarkeit von Informationen sicherzustellen. Die Erreichung der drei Schutzziele „Vertraulichkeit“, „Integrität“ und „Verfügbarkeit“ kann durch unterschiedliche technische und/oder organisatorische Maßnahmen erfolgen. Die Menge an Maßnahmen ist allerdings endlich, sodass es zwangsweise Synergien gibt. Diese Synergien kann ein Unternehmen ausnutzen, wenn es mehrere Standards gleichzeitigen berücksichtigen will.

Wie kann ein Unternehmen diese Synergien nun konkret nutzen? Dazu ist es notwendig zu verstehen, wie Informationssicherheit über ein Managementsystem gesteuert und umgesetzt wird. Ein Informationssicherheitsmanagementsystem (ISMS) definiert

Regeln und Methoden, um die Informationssicherheit in einem Unternehmen sicherzustellen.

Bei der Aufstellung von Richtlinien ist es also wichtig zu wissen, welche Anforderungen aus den jeweiligen Standards abzuleiten sind, und daraus eine Richtlinie zu erstellen, die sämtliche Anforderungen abdeckt. Anstatt Richtlinien für jeden Standard individuell zu erlassen, muss ein Multistandardansatz verfolgt werden, um die Anzahl an Richtlinien überschaubar zu halten. Ziel muss es sein, Mitarbeitenden genau die Vorgaben zur Informationssicherheit zu präsentieren, die für sie und ihre Arbeit wichtig sind – passgenau, aktuell und als Multistandard. Ein gutes Richtlinien-Framework für Informationssicherheit verfolgt daher ein Multistandardansatz, d. h., jeder Richtlinie wird mittels eines Attributs die zugehörige Anforderungsquelle zugeordnet. Dies können eine oder mehrere Quellen sein. Dadurch ist bekannt, aufgrund welcher Quelle eine ganz spezielle Richtlinie gilt. Sinnvoll ist es, bei dem Aufbau des Richtlinien-Frameworks auf einen etablierten Standard zu setzen, etwa der ISO 27001, und darüber zunächst ein Basisset an Richtlinien zu erstellen. Im Anschluss kann ein Unternehmen die weiteren Standards heranziehen, auf ihren Regelungsinhalt hin prüfen und mit dem Richtlinien-Framework abgleichen. Das Basisset kann dann ergänzt, angepasst oder ersetzt werden (Nick 2021).

Wer weiter denkt und weiß, dass Standards zur Informationssicherheit auf einem risikobasierten Ansatz fußen, erweitert das Richtlinien-Framework gleich um die Zuordnung von Risiken; d. h., jeder Richtlinie wird nicht nur über ein Attribut ein Standard zugewiesen, sondern auch über ein Attribut ein oder mehrere Risiken. Wird eine Richtlinie dann z. B. im Unternehmen nicht oder nur teilweise umgesetzt, ist das entstandene Risiko sofort transparent erkennbar (siehe Bild 5.4).

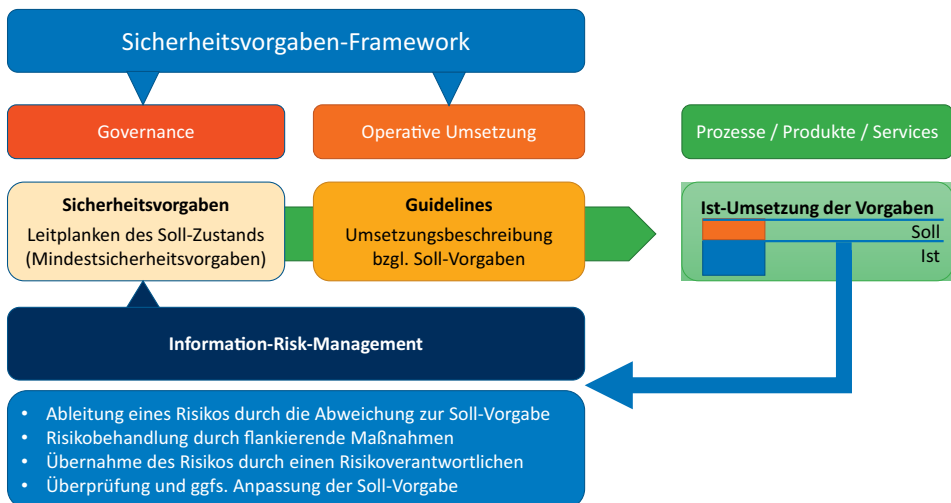


Bild 5.4 Richtlinien-Framework mit Verknüpfung zu Risiken (Nick 2021)

Um zu identifizieren, wo genau die Synergien zwischen den jeweiligen Standards sind, kann man sich hier der Suche im Internet bedienen. In vielen Fällen bieten bereits die Aussteller der Standards entsprechend frei verfügbare Mapping-Tabellen zwischen den jeweiligen Standards an (so z. B. das Bundesamt für Sicherheit in der Informationstechnik für den C5-Katalog, dem IT-Grundschutz und der ISO 27001). Oder andere Organisationen haben sich bereits die Mühe gemacht und stellen diese Mapping-Tabellen zur freien Verfügung. Wichtig ist allerdings in diesem Zusammenhang, dass die Mapping-Tabellen immer nur eine grobe Orientierung darstellen. Es entbindet den Verantwortlichen für die Informationssicherheit im Unternehmen nicht davon, sich selbst davon zu überzeugen, ob die Anforderungen identisch sind und ob aufgestellte Richtlinien damit automatisch auch die Anforderung aus den anderen Standards erfüllen. Denn bei der Aufstellung von Richtlinien können durchaus Unschärfen entstehen, die z. B. für die ISO 27001 unschädlich, aber für die Erfüllung der C5-Anforderungen plötzlich nicht mehr ausreichend sind.

Wenn sich ein Unternehmen damit beschäftigt, mehrere Standards zu vereinen, dann sollte auch das „Handbuch zur integrierten Nutzung von Managementstandards (IUMSS)“ der ISO herangezogen werden. Die aktuelle Version aus dem Jahre 2018 vereint Best-Practice-Anleitungen und Fallstudien zur Implementierung von Integrationsmanagementsystemstandards.



Hinweis

Achten Sie bei der Nutzung von Synergien darauf, welche Standards erfüllt werden sollen. Es bietet sich dabei an, ein integriertes Managementsystem aufzubauen und zu betreiben, welches sämtliche zu erfüllenden Standards abdeckt. Bestandteil dieses integrierten Managementsystems ist ein Richtlinien-Framework, welches Referenzen auf die jeweiligen Standards aufweist (Multistandardsansatz). So ist es möglich, einzelne Richtlinien zu verabschieden, die nur für ganz spezielle Fälle im Unternehmen gelten (z. B. PCI DSS für den Fall, dass mit Kreditkartendaten in einem Geschäftsprozess gearbeitet wird). Ein integriertes Managementsystem entbindet ein Unternehmen nicht davon, für jeden Standard, der zertifiziert werden soll, auch ein eigenes Zertifizierungsaudit durchführen zu lassen. In der Praxis werden diese zwar kombiniert. Allerdings bleibt es formal dabei, je Standard ein Zertifizierungsaudit.

5.2.2 Zertifizierung/Testierung

Auch wenn sich eine Zertifizierung und eine Testierung im Detail doch erheblich unterscheiden, wird in diesem Kapitel ein allgemeines Vorgehen vorgestellt, welches für beide Varianten seine Gültigkeit hat. Die Planung kann hierbei in einem Unternehmen in verschiedene Phasen unterteilt werden (siehe Bild 5.5).

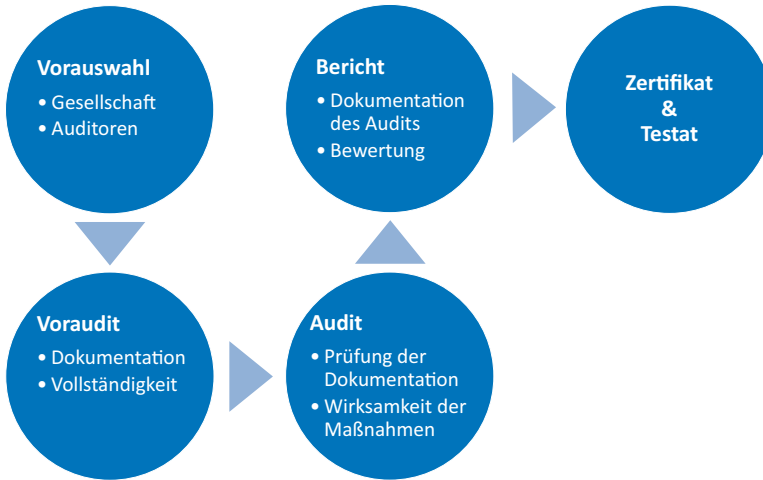


Bild 5.5 Grobablauf einer Zertifizierung bzw. Testierung

■ Vorauswahl

Grundsätzlich ist dieser Schritt im Rahmen einer Zertifizierung oder Testierung optional. Aus Sicht des Autors sollte diese Phase zwingend durchgeführt werden, denn letztendlich wird sich ein Unternehmen langfristig an eine Gesellschaft binden, die Zertifizierungen oder Testierung durchgeführt. Somit sollte ausreichend Zeit eingeplant werden, um eine Gesellschaft zu finden, die zu dem eigenen Unternehmen passt. Zum einen sollte die Philosophie der Gesellschaft zu den Zielen des eigenen Unternehmens passen. So sind einige Gesellschaften dafür bekannt, eher Prozesse und Verfahren in den Vordergrund zu stellen, andere hingegen eher technische Details. Zum anderen sollten auch die Auditoren und deren Auftreten passen. Wenn im eigenen Unternehmen eine lockere Unternehmenskultur herrscht, wird ein Auditor, der streng hierarchisch denkt, langfristig kein Erfolgsmodell sein. Zusätzlich sollte bei der Auswahl der Gesellschaft für Zertifizierungen darauf geachtet werden, dass die Gesellschaft akkreditiert bei der DAkkS (Deutsche Akkreditierungsstelle) ist. Denn nur solche Gesellschaften können am Ende akkreditierte Zertifikate ausstellen, die eine einheitliche und geprüfte Qualität darstellen.

■ Voraudit

Streng genommen ist auch diese Phase für ein Unternehmen optional. Allerdings sollte sich ein Unternehmen auch hier kritisch hinterfragen, ob es diese Phase überspringt. Denn das Zertifizierungsaudit ist immer eine Alles-oder-nichts-Prüfung. Das bedeutet, sollten im Rahmen der Zertifizierung Sachverhalte entdeckt werden, die nicht den Anforderungen genügen, so hat ein Unternehmen ein sehr kurzes Zeitfenster (in der Regel 90 Tage), um diese zu beseitigen. Andernfalls ist

die Zertifizierung nicht erfolgreich. Dies kann ein Unternehmen durch ein Voraudit umgehen. Es handelt sich quasi um eine Art von Generalprobe für die Zertifizierung. Wenn hier also Punkte identifiziert werden, die dringend zu beseitigen sind, so können diese mit ausreichend Zeit für die Umsetzung eingeplant werden. Das eigentliche Audit kann zeitlich so gelegt werden, bis alle Punkte abgearbeitet wurden.

Das Voraudit hat allerdings nicht die Tiefe und Dauer eines echten Audits, sodass hier in der Regel Schwerpunkte gesetzt werden. Hier sind es das Wissen und die Erfahrung der Auditoren, die später die Zertifizierung setzen. Diese wissen sehr genau, wo Herausforderungen sind, und können so auch entsprechende Schwerpunkte setzen aufgrund ihrer langjährigen Erfahrungen. Unternehmen sollten sich nicht scheuen, dies bei ihren Auditoren einzufordern.

■ **Audit**

Ein Audit oder eine Testierung erfolgt immer in zwei Schritten. Im ersten Schritt wird geprüft, ob die vorhandenen Dokumentationen zu technischen und organisatorischen Maßnahmen oder Prozessen ausreichend sind. Ergänzt wird die Überprüfung durch Interviews mit den Verantwortlichen. Im zweiten Schritt erfolgt die Überprüfung der Wirksamkeit. Sind die Prozesse und Maßnahmen geeignet, die jeweiligen Ziele zu erreichen, und lassen sich hierfür ausreichende Belege finden? Zum Abschluss dieser Phase werden die Auditoren ein Abschlussgespräch durchführen, in dem sie ihre Einschätzungen wiedergeben und bekannt geben, ob ein Zertifikat oder Testat erteilt werden kann. Sollten im Audit Punkte identifiziert werden, die noch nicht den Anforderungen genügen, wird hier geklärt, was zu erledigen ist, um einen erfolgreichen Abschluss zu ermöglichen.

Der Aufwand vom eigentlichen Audit kann von wenigen Tagen bis hin zu hohen zweistelligen Tagen reichen, je nach Unternehmensgröße und dem eigentlichen Untersuchungsgegenstand. Grundsätzlich kann hier festgehalten werden, dass Zertifizierungen einen deutlich geringen Umfang aufweisen als Testierungen, da hier unterschiedliche Aussagen durch das Audit getroffen werden sollen. Während Zertifizierungen die Maßnahmen und Prozesse untersuchen und sich die Wirksamkeit durch einige Belege bestätigen lassen, wird bei Testierung die Wirksamkeit durch umfangreiche und repräsentative Stichproben konkret geprüft. Zertifizierungen sagen somit aus, dass die Maßnahmen und Prozesse grundsätzlich geeignet sind, ihre Ziele zu erreichen. Eine Testierung kann dies durch die umfangreichen Stichproben belegen. Diese Stichproben sind dann auch der Grund, warum sich die Aufwände deutlich unterscheiden.

■ **Bericht**

Die Ergebnisse des Audits werden in einem Bericht zusammengefasst. Es werden seitens der Auditoren die durchgeführten Prüfungen aufgelistet und die Ergeb-

nisse, mit denen die Prüfungen abgeschlossen wurden. Auch hier unterscheiden sich Zertifizierungen und Testierungen. Während bei den Zertifizierungen der Bericht die Grundlage bildet, um danach das Zertifikat zu erhalten, stellen bei Testierungen die Berichte schon den Abschluss dar.

■ Zertifikat & Testat

Wenn der Bericht keine Gründe aufführt, warum eine Zertifizierung oder Testierung nicht erfolgen kann, wird im Anschluss von der Gesellschaft das entsprechende Zertifikat oder Testat ausgestellt. Überraschende Gründe, warum eine Ausstellung nicht möglich ist, sollte es nicht geben, da diese bereits im Abschlussgespräch angesprochen wurden.

Abschließend sei darauf hingewiesen, dass die Zertifizierung oder Testierung in der Informationssicherheit zeitlich und kostentechnisch den geringsten Aufwand darstellen. Auch wenn die Zeitdauer von Planung bis zum Zertifikat ein Jahr dauern kann und die Zertifizierung selbst je nach Unternehmensgröße auch zweistellige Personentage bedeutet, so entsteht der mit Abstand größte Aufwand dadurch, technische und organisatorische Maßnahmen zu planen, umzusetzen und zu kontrollieren und diese ständig weiterzuentwickeln.

Vor einer weiteren Herausforderung stehen Unternehmen, die sich mehreren Zertifizierungen oder Testierungen unterwerfen und sich festlegen müssen, welche Gesellschaft bzw. Gesellschaften dies tun sollen. Denn nicht nur beim Aufbau eines integrierten Richtlinie-Rahmenwerks gibt es Synergien, sondern auch hier.



Hinweis

Diese Synergien können im Regelfall nur dann genutzt werden, wenn die Zertifizierungen von einer Gesellschaft durchgeführt werden. Eine Anerkennung zwischen den Gesellschaften erweist sich in der Praxis häufig als schwierig, da fehlende Kompetenzen ins Feld geführt werden oder fehlende Informationen darüber, was und wie tief genau geprüft wurde. Die Entscheidung, alles auf eine Karte zu setzen und nur eine Gesellschaft zu beauftragen, sollte jedoch gut überlegt sein, denn wie in der jüngsten Vergangenheit einige Mal passiert, kann der Ruf einer Gesellschaft schnell beschädigt werden. Dies hat dann unverzüglich auch potenziell Auswirkungen auf das eigene Unternehmen und deren Zertifikate und Testate bzw. deren Aussagekraft. Wenn hier dann unterschiedliche Gesellschaften im Spiel sind, sind die Auswirkungen bei Weitem nicht so gravierend.

5.3 Kompetenznachweise für Beteiligte der Informationssicherheit

Die ISO 27 001 schreibt in Kapitel 7.2 Folgendes vor:

„Die Organisation muss:

- a) für Personen, die unter ihrer Aufsicht Tätigkeiten verrichten, welche die Informationssicherheitsleistung der Organisation beeinflussen, die erforderliche Kompetenz bestimmen;
- b) sicherstellen, dass diese Personen auf Grundlage angemessener Ausbildung, Schulung oder Erfahrung kompetent sind;
- c) sofern anwendbar, Maßnahmen einleiten, um die benötigte Kompetenz zu erwerben, und die Wirksamkeit der getroffenen Maßnahmen zu bewerten; und
- d) angemessene dokumentierte Information als Nachweis der Kompetenz aufbewahren.“

Um als Beteiligter nachweisen zu können, über die notwendigen Kompetenzen der obigen Anforderungen zu verfügen, um im Bereich der Informationssicherheit mitwirken zu können, stehen grundsätzlich folgende Möglichkeiten zur Verfügung:

- Bestätigungen bisheriger Arbeitgeber über Berufserfahrungen
- Referenzprojekte bei bisherigen Arbeitgebern
- Teilnahmebescheinigungen an Fort- und Weiterbildungen
- Belege von Selbststudium
- Teilnahme an Veranstaltungen als Referent oder durch
- anerkannte Personenzertifizierungen

Bei dieser Aufzählung gilt es zu berücksichtigen, dass die ersten fünf Aufzählungspunkte nicht ohne Weiteres umzusetzen sind. Denn zum einen müssen die entsprechenden Nachweise eingeholt werden, und zum anderen muss auch schon die Kompetenz vorhanden sein, die Nachweise prüfen und einschätzen zu können. Hier kommen die Personenzertifizierungen ins Spiel. Denn diese bieten klar definierte Themenschwerpunkte, und durch die abschließende Prüfung kann nachgewiesen werden, hierzu einen entsprechenden Wissensstand zu besitzen. Um die Zertifikate auch dauerhaft führen zu dürfen, bedarf es bei einem Großteil der Zertifikate eines ständigen Weiterbildungsnachweises, der sicherstellen soll, dass der Zertifikatsinhaber sich fachlich auf dem Laufenden hält.

Im Folgenden werden kurz die wesentlichen nationalen und internationalen Personenzertifizierungen mit Bezug zur Informationssicherheit vorgestellt. Es handelt sich

hierbei nur um einen grundsätzlichen Überblick, da es viele weitere themen- oder produktspezifische Zertifikate gibt, die als Ergänzung dienen können:

■ CISSP

Der Certified Information Systems Security Professional ist eine Personenzertifizierung, die vom International Information Systems Security Certification Consortium angeboten wird. Die Prüfung deckt insgesamt acht Themengebiete ab:

- Sicherheits- und Risikomanagement
- Sicherheit von Informationen und Vermögenswerten
- Sicherheitsarchitektur und Entwicklung
- Kommunikations- und Netzwerksicherheit
- Identitäts- und Zugriffsverwaltung
- Sicherheitsbewertung und -tests
- Sicherer Betrieb
- Sichere Softwareentwicklung

Die Zertifizierung setzt einiges an Erfahrung in den jeweiligen Gebieten voraus, was auch daraus ersichtlich wird, dass ein Erwerb erst dann möglich ist, wenn mehrere Jahre Berufserfahrung nachgewiesen werden. Auch gilt es zu beachten, dass hier die amerikanische Sichtweise und deren Möglichkeiten abgeprüft werden, was für Personen aus dem deutschsprachigen Raum erst einmal ein Umdenken erfordert.

■ CCSP

Der Certified Cloud Security Professional wird von derselben Organisation angeboten wie der CISSP. Die Prüfung erstreckt sich in diesem Fall auf sechs Themengebiete:

- Architekturkonzepte und Gestaltungsanforderungen
- Clouddatensicherheit
- Cloudplattform und Infrastruktursicherheit
- Cloudanwendungssicherheit
- Betrieb
- Rechtliches und Compliance

Die Anmerkungen bezüglich Erfahrungen und Einschränkungen gelten hierbei analog dem CISSP.

■ TISP

Die Einschränkungen von internationalen Personenzertifizierungen hat dazu geführt, den TISP zu etablieren. Das TeleTrusT Information Security Professional ist das einzige Personenzertifikat im Bereich der Informationssicherheit, das speziell

auf den europäischen Raum abgestimmt ist. Es legt besonderen Wert darauf, die dort geltenden Standards, Rahmenbedingungen und Gesetzgebungen explizit zu berücksichtigen. Die zu prüfenden Gebiete erstrecken sich auf (TeleTrust 2021):

- Hacking und Content Security
- Grundlagen der Netzwerksicherheit
- Kryptografie
- PKI (Public Key Infrastructure)
- Sicherheitsmanagement (ISO 27 001 und IT-Grundschutz)
- Rechtliche und wirtschaftliche Aspekte der Informationssicherheit
- Betriebssystemsicherheit und Berechtigungsmanagement
- Anwendungssicherheit
- Sicherheit in mobilen Endgeräten

■ CISA

Der Certified Information Systems Auditor ist eine von der ISACA (Information Systems Audit and Control Association) angebotene Personenzertifizierung. Wie die Bezeichnung ISACA schon verdeutlicht, handelt es sich hierbei um eine Zertifizierung im Bereich Revision, Kontrolle und Sicherheit von Informationssystemen. Bei der Prüfung werden folgende fünf Themenblöcke behandelt:

- Prüfung von Informationssystemen
- IT-Governance und IT-Management
- Beschaffung, Entwicklung und Implementierung von Informationssystemen
- Betrieb von Informationssystemen und Business Resilience
- Informationssicherheit

■ CISM

Der Certified Information Security Manager wird ebenfalls von der ISACA angeboten. Im Unterschied zum CISA richtet sich diese Personenzertifizierung an Experten der Informationssicherheit und nicht in erster Linie an Revisoren. Hierbei werden die folgenden Themengebiete abgefragt und bewertet:

- Information Security Governance
- Information Risk Management
- Information Security Program Development and Management
- Information Security Incident Management

■ CRISC

Der Letzte im Bunde der Personenzertifizierungen im Bereich Informationssicherheit der ISACA ist Certified in Risk and Information Systems Control und richtet sich an Personen, die sich im Bereich IT-Risikomanagement oder Enterprise

Risk Management weiterbilden wollen. Dort werden die nachfolgenden Gebiete abgefragt und bewertet:

- IT-Risikoidentifizierung
- IT-Risikobewertung
- Risikobehandlung und -minderung
- Risiko- und Kontrollüberwachung sowie -berichterstattung

■ ISO 27 001 Lead Auditor

Ein ISO 27 001 Lead Auditor ist ein bei einer akkreditierten Zertifizierungsstelle berufener Auditor für die Informationssicherheitsnorm ISO 27 001. Ein Unternehmen beauftragt die Zertifizierungsstelle, und in dessen Auftrag führt der Lead Auditor ein unabhängiges externes Audit durch. Auf Basis seines Berichts entscheidet die Zertifizierungsstelle, ob ein unabhängiges akkreditiertes Zertifikat nach ISO 27 001 ausgestellt werden kann. Einige Schulungsanbieter bieten hierzu Schulungen mit anschließender Prüfung an. Das Bestehen der Prüfung ist allerdings nur eine der Voraussetzungen, um bei einer Zertifizierungsstelle als ISO 27 001 Lead Auditor berufen zu werden.

Für Unternehmen kann es vorteilhaft sein, einige seiner Mitarbeiter in einer Weiterbildung zum ISO 27 001 Lead Auditor zu entsenden. Denn in dieser Ausbildung lernen die Teilnehmer, wie der Standard ISO 27 001 zu interpretieren und was Gegenstand des Zertifizierungsaudits ist. So können sie im Vorfeld der Zertifizierung die Vorbereitungen im Unternehmen ressourcenoptimiert planen, auf Augenhöhe mit den Auditoren diskutieren und zielführend unternehmensorientierte Lösungen einbringen. Der Nutzen stellt sich nur ein, wenn das Unternehmen auch langfristig an der Zertifizierung zur ISO 27 001 interessiert ist. In die Überlegung sollte allerdings die Tatsache einbezogen werden, dass manche Schulungsanbieter auch noch eine Zertifizierungsstelle für die ISO 27 001 besitzen und teilweise die Schulungen nutzen, um neue freiberufliche Auditoren zu akquirieren.



Hinweis

Personenzertifizierungen bieten darüber noch die Möglichkeit, die vorhandene Qualität im Unternehmen nach außen zu dokumentieren. Bei der Auswahl, welche Personenzertifikate für das eigene Unternehmen von Relevanz ist, sollten die folgenden Kriterien kritisch beleuchtet werden (Böhmer 2018).

- Zwischen dem aktuellen oder zukünftigen Aufgabengebiet und den Themenschwerpunkten einer Personenzertifizierung muss eine große Schnittmenge existieren. Nur so wird sichergestellt, dass die Zertifizierung gewinnbringend für das Unternehmen ist und nicht Wissen vermittelt wird, was aufgrund fehlender Anwendung schnell veraltet.

- Das Personenzertifikat sollte anerkannt sein. In einigen Fällen versuchen kleinere Anbieter, kostengünstige Alternativen zu anerkannten Zertifizierungen zu etablieren im Sinne von „Schulungsanbieter xy zertifizierter interner ISMS-Auditor“.
- Welche Schnittmengen existieren zwischen den Beteiligten in der Informationssicherheit? Es kann sinnvoll sein, eine Personenzertifizierung einer Person zukommen zu lassen, auch wenn diese die Themen aktuell nicht betreut, um eine Entlastung oder Vertretung einer anderen Person sicherzustellen.

5.4 Die wichtigsten Punkte in Kürze

- Standards zur Informationssicherheit weisen in einigen Punkten Synergien zueinander auf. Unternehmen sollten sich diese Synergien zunutze machen und ein Richtlinien-Framework mit einem Risiko- und Multinormenansatz aufbauen, um mit einem überschaubaren Satz von Richtlinien einen maximalen Abdeckungsgrad für die unterschiedlichen Standards zu erreichen. Dies hilft, ein effektives integriertes Managementsystem für die Informationssicherheit zu betreiben, und die Mitarbeitenden können eindeutigen und nachvollziehbaren Richtlinien folgen.
- Vorhandene Mapping-Tabellen erleichtern das Auffinden von Synergien zwischen den Standards. Sie dienen als erste Orientierung dazu, durch welche internen Richtlinien auch die Anforderungen anderer Standards abgedeckt werden können. Ein blindes Übernehmen dieser Zuordnungen ist nicht zielführend, da Richtlinien zum Teil Unschärfen besitzen und diese Unschärfen individuell bewertet werden müssen im Hinblick auf die Erfüllung unterschiedlicher Anforderungen aus den unterschiedlichen Standards.
- Für die Zertifizierung oder Testierung sollte in Unternehmen ausreichend Zeit eingeplant werden. Besonderes Augenmerk sollte darauf gelegt werden, wer die unabhängigen Bestätigungen durchführen soll. Mit dieser Gesellschaft wird ein Unternehmen ein langfristiges Vertragsverhältnis eingehen. Daher müssen hier die Rahmenbedingungen stimmen.
- In der Informationssicherheit gibt es zahlreiche Personenzertifizierungen, sowohl europäisch oder international. Bei der Wahl der entsprechenden Zertifizierungen muss ein Unternehmen eine eindeutige Bedarfsanalyse durchführen, um die richtigen und sinnvollen herauszusuchen. Neben den reinen Kosten gilt es zu bedenken, dass in einem nicht unerheblichen Umfang die jeweiligen Personen Zeit für die Vorbereitung einbringen müssen.

Literatur

BITKOM: Kompass der IT-Sicherheitsstandards. Auszüge zum Thema Elektronische Identitäten. Bundesdruckerei, Berlin 2014.

Böhmer, Wolfgang; Haufe, Knut; Klipper, Sebastian; Lohre, Thomas; Rumpel, Rainer; Witt, Bernhard: Managementsysteme für Informationssicherheit (ISMS) mit DIN EN ISO/IEC 27 001 betreiben und verbessern. Beuth Verlag, Berlin 2018.

BSI: IT-Grundschutz. Informationssicherheit mit System, https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/it-grundschutz_node.html. Abgerufen am 24.04.2024.

CISIS12: Compliance-Informationen-Sicherheits-Management-System in 12 Schritten, URL: <https://cisis12.de/>. Abgerufen am 09.11.2021.

Hartlieb, Bernd; Hövel, Albert; Müller, Norbert: Normung und Standardisierung. Grundlagen, 2. Auflage, Beuth Verlag, Berlin 2016.

Gühr, Alisha; Karper, Irene; Maseberg, Sönke: Der lange Weg zur Akkreditierung nach Art. 42 DSGVO, in: Datenschutz und Datensicherheit (DuD), 10/2020, S. 649 – 653.

Nick, Theo: Die Quadratur der Dokumente-Pyramide. Wie man mit einem datenbankgestützten Framework verständliche Vorgaben macht, statt Richtlinie-Bibliotheken aufzutürmen. In: <kes> Die Zeitschrift für Informations-Sicherheit Verlagsbeilage Juni 2021, S. 22 – 25.

PCI-DSS: Datensicherheitsstandard. Anforderungen und Sicherheitsbeurteilungsverfahren, Version 3.2.1 Mai 2018. https://www.pcisecuritystandards.org/documents/PCI_DSS_v3-2-1_DE.pdf?agreement=true&time=1636449546059. Abgerufen am 24.04.2024.

Statista: Bestand an gültigen ISO-27 001-Zertifikaten weltweit in den Jahren 2006 bis 2020, [https://de.statista.com/statistik/daten/studie/829313/umfrage/bestand-an-vergebenen-iso-27001-zertifikaten-weltweit/#:~:text=Die%20Statistik%20zeigt%20den%20weltweiten,Dezember\)%20auf%2044.499](https://de.statista.com/statistik/daten/studie/829313/umfrage/bestand-an-vergebenen-iso-27001-zertifikaten-weltweit/#:~:text=Die%20Statistik%20zeigt%20den%20weltweiten,Dezember)%20auf%2044.499). Abgerufen am 24.04.2024.

TeleTrust: TISP Curriculum, <https://www.teletrust.de/tisp/curriculum/>. Abgerufen am 24.04.2024.

6

Datenschutz und Informationssicherheit: ungleiche Zwillinge

Stefan Karg



In diesem Beitrag erfahren Sie,

- welche Anforderungen der europäische Datenschutz (DSGVO) an die IT-Sicherheit stellt,
- wie Datenschutz und IT-Sicherheit geschickt kombiniert werden können,
- welche Auswirkungen dies auf Abläufe und Prozesse im Unternehmen haben kann.

6.1 Einleitung

Datenschutz ist unter anderem aufgrund der europäischen Datenschutz-Grundverordnung (DSGVO) aktuell verstärkt im Fokus der öffentlichen Aufmerksamkeit und stellt Unternehmen oft vor große Herausforderungen.

Klar ist, dass es kaum möglich ist, ohne geeignete technische Maßnahmen und Lösungen effektiven Datenschutz im Unternehmen zu gewährleisten. Ein Zusammenhang zwischen IT-Sicherheit und Datenschutz ist also offensichtlich.

Welche Abhängigkeiten und Zusammenhänge zwischen Datenschutz und IT-Sicherheit aber genau bestehen, wo Gemeinsamkeiten und Unterschiede sind und was dies für die Organisation und Abläufe im Unternehmen bedeuten kann, soll im Folgenden beleuchtet werden.

Begriffsbestimmungen und Abgrenzung

Datenschutz, Informationssicherheit und IT-Sicherheit haben eine große Schnittmenge – dies geht zum Teil so weit, dass die jeweiligen Disziplinen im Alltagsgebrauch

manchmal verwechselt oder die Begriffe synonym verwendet werden. Bei aller thematischen Nähe gibt es jedoch wesentliche Unterschiede, sowohl hinsichtlich der Zielsetzung als auch in Bezug auf die Schutzgüter und den Betrachtungsaspekt (siehe Bild 6.1).

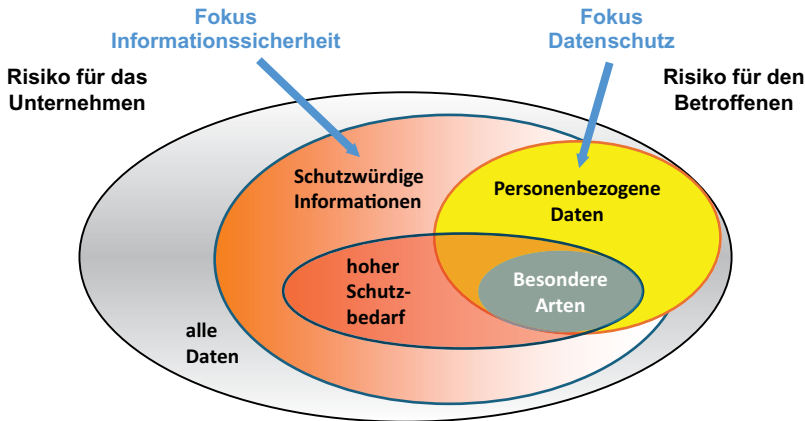


Bild 6.1 Vergleich des Anwendungsbereichs von Datenschutz und Informationssicherheit

Die **Informationssicherheit** nimmt alle schützenswerten Informationen in einem Unternehmen in den Blick, unabhängig von deren Repräsentation (z. B. als Datei, Audio- oder Videoaufzeichnung, auf Papier oder als Gesprächsinhalt) und der Art ihrer Ablage oder Verarbeitung.

IT-Sicherheit wiederum ist ein Teilaspekt der Informationssicherheit – hier wird der Fokus auf den Schutz der informationsverarbeitenden Systeme wie Rechner, Netzwerke und Speichermedien und der darin verarbeiteten Informationen gelegt. Aspekte wie der physische Zugangsschutz zu einem (Papier-)Archiv oder der Umgang mit Ausdrucken werden ausgeklammert.

Vielfach wird jedoch die Grenze zwischen Informationssicherheit und IT-Sicherheit im Unternehmen nicht scharf gezogen. So finden sich oft auch notwendige organisatorische Sicherungsmaßnahmen wie „Clean Desk“ (der Grundsatz eines aufgeräumten Schreibtisches bei Verlassen desselben) in der IT-Sicherheitsrichtlinie wieder, obwohl diese Maßnahmen (abgesehen vom Computer auf dem Schreibtisch) keinen zwingenden Bezug zur IT haben.

Der **Datenschutz** betrachtet schließlich nur die Verarbeitung personenbezogener Daten, hier jedoch zunächst unabhängig vom tatsächlichen Schutzbedarf des Einzeldatums. Als personenbezogenes Datum gilt jede Information, die sich auf eine natürliche Person direkt oder indirekt – etwa mittels einer Kundennummer oder eines sonstigen Kennzeichens – bezieht. Daten von juristischen Personen (ABC GmbH) sowie Daten ohne Personenbezug, zum Beispiel technische Daten wie Konstruktionszeichnungen, Konfigurationsdaten, Bestandslisten etc., werden unabhängig von ih-

rem Schutzbedarf nicht erfasst. Zudem werden nur die Daten berücksichtigt, die automatisiert verarbeitet (also mittels IT) oder in einer vergleichbar strukturierten Form (Karteikasten mit Index, Personalakte) organisiert werden.

Andere Betrachtungsweise

Auch der Blickwinkel auf die zu schützenden Objekte ist bei Datenschutz und Informationssicherheit unterschiedlich. Während die Informationssicherheit das Risiko für das Unternehmen in den Mittelpunkt stellt, betrachtet der Datenschutz das Risiko für die Rechte und Freiheiten der betroffenen Person. Das Risiko durch dieselbe Verarbeitung von Daten wird somit aus unterschiedlichen Perspektiven beurteilt. Auch diese Risikobetrachtung hat eine große Schnittmenge, es verbleiben aber jeweils für die Informationssicherheit und den Datenschutz spezifische Bereiche.



Beispiel

Beim Zugriff auf eine Webseite eines Unternehmens fallen regelmäßig Logfile-einträge an, welche die zugreifende IP-Adresse, den verwendeten Browser, besuchte Seiten, Dauer des Zugriffs etc. speichern. Diese Daten unterliegen wegen der (zumindest theoretischen) Rückschlussmöglichkeit von der IP-Adresse auf die verwendende Person auch dem Datenschutz.

Aus reiner Sicht der Informationssicherheit ist der „Wert“ des einzelnen Datums gering, der Schutzbedarf niedrig. Weder ein Verlust noch eine Veränderung oder ein unberechtigter Zugriff haben (außer bei der Verfolgung von Sicherheitsvorfällen) wesentliche Auswirkungen auf die Betriebssicherheit oder das Geschäft.

Aus Sicht der betroffenen Personen ist der Schutzbedarf jedoch höher, anhand der gespeicherten Daten lassen sich Rückschlüsse auf deren Interessen und ihr Verhalten im Internet treffen. Die betroffene Person hat somit ein Interesse daran, dass diese Daten nicht missbräuchlich verwendet und dass sie nach Fortfall ihres unmittelbaren Nutzens gelöscht werden.

Im Folgenden wollen wir uns im Wesentlichen mit dem Konvergenzbereich auseinandersetzen und mögliche Synergien betrachten.

6.2 Rahmenbedingungen

Mit der DSGVO besteht eine europaweit einheitliche Regelung für den Datenschutz, welche auch weitreichende, aber allgemeine Vorgaben für den Schutz personenbezogener Daten (und damit indirekt für die Informationssicherheit) macht. Im Bereich der Informationssicherheit hingegen fehlt es an einem vergleichbaren Gesetz, dafür existieren Normen und Standards, welche wie der IT-Grundschutz oder die ISO 27001 aber teilweise auch recht konkrete Maßnahmen beinhalten. Es bleibt dabei dem jeweiligen Anwender überlassen, hier beide Welten sinnvoll zusammenzuführen.

6.2.1 Datenschutz

Aspekte der Informationssicherheit haben an mehreren Stellen Eingang in die DSGVO gefunden:

So regelt **Artikel 5** Abs. 1 lit. f), dass personenbezogene Daten in einer Weise verarbeitet werden müssen, welche eine angemessene Sicherheit gewährleistet. Dies soll durch den Einsatz geeigneter technischer und organisatorischer Maßnahmen (im Folgenden sprechen wir hier kurz von TOM) erreicht werden. Die TOM sollen dabei die klassischen Schutzziele der Informationssicherheit gewährleisten, also Vertraulichkeit, Verfügbarkeit und Integrität. Darüber hinaus sollen sie auch einen Schutz vor unbefugter oder unrechtmäßiger Verarbeitung bieten.

In **Artikel 25** werden sodann unter dem Titel „Datenschutz durch Technikgestaltung“ die Rahmenbedingungen für die Verarbeitung gesetzt: Bereits bei der Planung einer Verarbeitung hat der Verantwortliche den Datenschutz als Anforderung aufzunehmen und insbesondere dabei den Schutz der verarbeiteten Daten bereits im Entwurf zu berücksichtigen (Privacy by Design).



Ergänzung

Die DSGVO macht in Artikel 25 noch weitere Vorgaben zur technischen Umsetzung, welche das Thema Informationssicherheit aber eher am Rande berühren: Sofern ein System Wahlmöglichkeiten oder Optionen in der Verarbeitung bietet, beispielsweise hinsichtlich der Übermittlung von Telemetrie- oder Diagnosedaten, so muss die jeweils datenschutzfreundlichere Variante, in unserem Fall also „keine Übermittlung“, voreingestellt sein. Dieses Prinzip läuft unter dem Label „Privacy by Default“.

Artikel 32 („Sicherheit der Verarbeitung“) definiert Auswahlkriterien und Umfang der notwendigen Schutzmaßnahmen: Diese sollen auf Basis einer Risikobetrachtung festgelegt werden, welche neben den Kriterien der „Art, des Umfangs, der Umstände und der Zwecke der Verarbeitung“ die Eintrittswahrscheinlichkeit und die Schwere des Risikos für die „Rechte und Freiheiten natürlicher Personen“ berücksichtigen. Maßgebend sind hierbei auch der jeweilige Stand der Technik sowie die Implementierungskosten der Maßnahmen. Kosten und Nutzen müssen wirtschaftlich für das Unternehmen sinnvoll bleiben, gleichzeitig muss das Risiko für die betroffenen Personen aber minimiert werden. Eine Verarbeitung, deren Risiko für die betroffenen Personen sich nicht mit wirtschaftlich vertretbaren Mitteln auf ein angemessenes Maß reduzieren lässt, darf nicht erfolgen.

Zudem wird der schnellen Änderung gerade im Bereich der Informationstechnik Rechnung getragen: Einmal implementierte Maßnahmen müssen regelmäßig auf ihre Wirksamkeit hin überprüft und gegebenenfalls angepasst werden.

Artikel 24 erlegt dann die Verpflichtung zur Umsetzung und zum Nachweis dieser technischen und organisatorischen Maßnahmen dem „Verantwortlichen“ auf (Art. 4 Nr. 7 DSGVO), hiermit ist in der Regel der Vorstand oder die Geschäftsführung gemeint, in jedem Fall diejenige Instanz, die im Unternehmen letztlich über Zwecke und Mittel der Verarbeitung (also „ob“, „wofür“ und „wie“) entscheidet.

Der Datenschutzbeauftragte (DSB), dessen Aufgaben und Stellung in **Artikel 37–39** geregelt sind, berät den Verantwortlichen dabei und versetzt diesen in die Lage, die DSGVO auch einhalten zu können. Er kontrolliert als unabhängige Instanz die Umsetzung der Maßnahmen und überwacht deren Einhaltung, trägt aber selbst nicht die Verantwortung dafür.

Vorsichtig übersetzt bedeutet dies, dass die Unternehmensleitung von Anfang an die jeweils aktuell technisch möglichen und dabei wirtschaftlich vertretbaren Maßnahmen ergreifen muss, um das Risiko für die betroffene Person so gering wie möglich zu halten. Wie dies gewährleistet wird, muss der Verantwortliche z. B. gegenüber der Aufsichtsbehörde jederzeit nachweisen können.

Ein gesetzlich definiertes Pendant zum DSB gibt es in der Informationssicherheit leider nicht. Es gilt zwar als „Best Practice“, einen Informationssicherheitsbeauftragten (ISB) oder (C-)ISO zu berufen, abseits einzelner Bereiche (KRITIS, Telekommunikation) besteht aber keine Verpflichtung dazu.

Es gibt nämlich kein nationales oder europäisches Informationssicherheitsgesetz, sondern die Anforderungen und Verpflichtungen ergeben sich indirekt, z. B. aus den allgemeinen kaufmännischen Sorgfaltspflichten oder aus branchenspezifischen Spezialregelungen (eine detaillierte Diskussion dessen findet sich in Kapitel 4, „Rechtliche Rahmenbedingungen der IT-Sicherheit“, dieses Buches).



Zusammenfassung

Die Risikobetrachtung für das Unternehmen muss um die Risiken für die betroffenen Personen erweitert werden. Personenbezogene Daten müssen mit Mitteln der Informationssicherheit und weiteren Maßnahmen angemessen und nachweisbar geschützt werden.

Wesentliche Parameter sind:

- das Risiko für die betroffenen Personen
- Notwendigkeit der Verarbeitung (Umfang, Zweck)
- Art und Weise der Verarbeitung (Art, „Umstände“)
- Stand der Technik (welche Maßnahmen sind möglich?)
- Implementierungskosten (in Relation zum Maß der Risikoreduzierung für die betroffenen Personen)

Die Maßnahmen können technischer oder organisatorischer Art sein. Sie müssen regelmäßig überprüft und gegebenenfalls angepasst werden. Verantwortlich ist die Unternehmensleitung, welche vom Datenschutzbeauftragten und gegebenenfalls von dem ISB in der Umsetzung unterstützt wird.

6.2.2 Managementsysteme

Im Bereich der Informationssicherheit gibt es mit dem IT-Grundschutz und der ISO 27 001 zwei wesentliche Ansätze für die Errichtung eines Informationssicherheitsmanagementsystems (ISMS):

Die ISO-Normen zielen auf die Etablierung eines stabilen, risikomindernden ISMS ab und schaffen einen formalen Rahmen für die Herstellung und kontinuierliche Verbesserung der Informationssicherheit. Orientierung dafür, welche Themenbereiche es dabei zu beachten gilt, bietet ein Katalog von Referenzmaßnahmen (ISO/IEC 27 001 Anhang A).

ISO/IEC 27 001 setzt dabei auf eine möglichst vollständige Erfassung der Risiken, welche auf die zu schützenden Werte („Assets“) im Anwendungsbereich wirken. Diese Risikoanalyse dient dann als Basis für die Festlegung der umzusetzenden Schutzmaßnahmen, die im Praxis-Teil der Norm (ISO/IEC 27 002) detailliert beschreiben werden.

Der IT-Grundschutz, herausgegeben vom Bundesamt für Sicherheit in der Informationstechnik (BSI), ist die nationale Idee der Umsetzung eines ISMS. Hier werden, auf Basis festgelegter Standardrisiken und Gefährdungen, standardisierte Anforderungen für verschiedene Schutzniveaus („Basisabsicherung“, „Standardabsicherung“) definiert. Eine ausführliche individuelle Risikoanalyse ist nur ergänzend für besonders gefährdete oder besonders schützenswerte Informationsverbünde notwendig. Typische Prozesse und Systeme sind im IT-Grundschutz-Kompendium in einem Baukastensystem gefasst und können je nach Anwendungsfall kombiniert werden.

Beide Managementsysteme enthalten jeweils eine Anforderung (A 5.34 bzw. CON.2.A1), welche eine Einhaltung der gesetzlichen Regelungen zum Datenschutz fordert. Damit schließt sich auch hier der Kreis.

Der IT-Grundschutz ist zudem zur ISO 27 001 kompatibel, er folgt trotz verschiedener Herangehensweisen denselben Prinzipien. Mit beiden Standards sind somit eine Zertifizierung und damit der Nachweis angemessener Informationssicherheit möglich. Ausführliche Informationen hierzu findet man in Kapitel 5, „Standards und Zertifizierungen“, dieses Buches.

6.2.3 Das Standard-Datenschutzmodell (SDM)

Im Bereich Datenschutz mangelt es noch an einem der ISO 27 001 vergleichbaren Zertifizierungsprozess. Zwar sieht die DSGVO in Artikel 42 vor, Zertifikate und Gütesiegel national oder europaweit einzuführen, dies ist aber bis dato nicht erfolgt.

Um diese Lücke teilweise zu schließen, haben die Aufsichtsbehörden der Länder in Deutschland mit dem Standard-Datenschutzmodell eine Methodik erdacht, um die rechtlichen Anforderungen der DSGVO in technische und organisatorische Maßnahmen zu überführen. Dieses SDM soll künftig als einheitliche Planungs- und Prüfgrundlage und damit perspektivisch auch zur Zertifizierung nutzbar zu sein. Von seiner Struktur und der Modellierungsmethodik her lehnt es sich dabei an den IT-Grundschutz an. Insbesondere soll analog zum IT-Grundschutz-Kompendium ein Katalog von Bausteinen für die Auswahl notwendiger technischer und organisatorischer Maßnahmen entstehen.

Um die zusätzlichen (überwiegend rechtlichen) Anforderungen des Datenschutzes abzubilden, wird die klassische Trias der Schutzziele der IT-Sicherheit, nämlich:

- **Verfügbarkeit:** Verfahren und Daten sollen zeitgerecht zur Verfügung stehen und ordnungsgemäß angewendet werden können.
- **Integrität:** Daten sollen unversehrt, vollständig, zurechenbar und aktuell bleiben.
- **Vertraulichkeit:** Es soll nur befugt auf Verfahren und Daten zugegriffen werden können.

um vier weitere Aspekte ergänzt. Diese bilden zusammen die sogenannten „Gewährleistungsziele“, welche es zu erfüllen gilt. Diese zusätzlichen Anforderungen sind:

- **Datenminimierung:** Daten müssen dem Zweck angemessen und erheblich sein, eine Verarbeitung darf nur im dafür notwendigen Maße erfolgen.
- **Transparenz:** Die Verarbeitung personenbezogener Daten soll mit zumutbarem Aufwand nachvollzieh-, überprüf- und bewertbar sein.
- **Nichtverkettbarkeit:** Personenbezogene Daten sollen nicht oder nur mit unverhältnismäßigem Aufwand für einen anderen als den definierten Zweck verarbeitet werden können.
- **Intervenierbarkeit:** Verfahren sollen so gestaltet werden, dass sie den Betroffenen die Ausübung ihrer Rechte nach den Artikeln 26 bis 30 DSGVO wirksam ermöglichen.

Leider ist die Methodik aber noch nicht vollständig, zum Zeitpunkt des Erscheinens dieses Buches liegt das SDM zwar in Version 3.0 vor, es sind bisher aber nur wenige Bausteine veröffentlicht, die zudem noch nicht alle Themengebiete abdecken. Auch lehnt sich die Methodik zwar an den IT-Grundschutz an, erschwert aber aufgrund teils abweichender Begriffe und Zielsetzungen eine aufeinander aufbauende Nutzung oder Integration in ein gemeinsames Managementsystem. Es bleibt daher abzuwarten, inwieweit sich das SDM in der Praxis über die Verwendung im (deutschen) öffentlichen Bereich hinaus etabliert.

6.3 Strategische/präventive Aspekte

Die IT und damit auch die IT-Sicherheit nehmen eine Schlüsselrolle bei der Umsetzung des Datenschutzes ein, da gerade die (automatisierte) Verarbeitung personenbezogener Daten den Kern des Schutzbereichs bildet. Wir konzentrieren uns daher im Folgenden auf diejenigen Aspekte, welche Datenschutz und IT-Sicherheit gemeinsam betreffen. Hierbei gibt es einen eher operativ geprägten Teil, welcher konkrete Schutzmaßnahmen und Prozeduren umfasst sowie einen strategischen/präventiven Teil, in dem übergeordnete Prozesse und Überlegungen zum Tragen kommen.

6.3.1 Risikomanagement

Die bestehenden Risiken im Unternehmen aktiv zu erfassen und zu verfolgen ist hauptsächlich motiviert durch folgende Aspekte:

- Realisierte Risiken können unmittelbar zu finanziellen Verlusten für das Unternehmen und seine Stakeholder führen.
- Geschäftsleitung und Mitarbeiter können für mögliche Schäden haftbar gemacht werden.
- Verschiedene Gesetze fordern eine ausreichende Vorsorge bzw. Früherkennungsmaßnahmen im Unternehmen (unter anderem AktG, GmbHG, KonTraG, KWG, DSGVO, BDSG ...).

Risikomanagement ist somit die Aufgabe der regelmäßigen Identifikation, Kontrolle und kostenoptimalen Minimierung von (Sicherheits-)Risiken, die für die Werte und Stakeholder des Unternehmens bestehen. Das Risikomanagement bildet einen wesentlichen Baustein im Informationssicherheitsmanagement und ist in der Regel auch Voraussetzung für eine Zertifizierung des Informationssicherheitsmanagementsystems (ISMS) z. B. nach ISO 27 001 oder branchenbezogenen Standards.

Auch die DSGVO legt ein Risikomanagement zugrunde, allerdings werden hier die Risiken für die betroffene Person und nicht die Risiken für die Unternehmung betrachtet. Diese liegen jedoch in der Praxis zumeist in der Ausgestaltung der Verarbeitung, sind also durch die Art und Weise bedingt, wie mit den einzelnen personenbezogenen Daten technisch und prozessmäßig umgegangen wird. Auch fordert die DSGVO explizit die Betrachtung der durch die technische Umsetzung der Verarbeitung entstehenden Risiken (siehe Art. 32 (2) DSGVO). Dadurch kommt es zu einem sehr hohen Überdeckungsgrad mit den Risiken in der IT, Unterschiede bestehen zumeist in einer unterschiedlichen Bewertung des Schutzbedarfs der einzelnen Datenkategorie aus Datenschutz- und IT-Sicht.

Neben einem übergeordneten, unternehmensweit greifenden Risikomanagement ist es häufig notwendig, speziell für die IT eine eigene Risikobetrachtung durchzuführen. Während unternehmensweite Risiken oft mit einem relativ groben Raster erfasst werden müssen, um behandelbar zu bleiben, treten in der IT auch operative Aspekte in den Vordergrund. Diese erfordern eine niedrigere Risikotoleranz und eine feinere Auflösung der betrachteten Risiken. Ein sinnvolles Risikomanagementsystem ist zumindest in größeren Organisationen somit hierarchisch über mehrere Aggregationsstufen aufgebaut.

**Hinweis**

Bei der operativen Betrachtung der IT-Risiken bietet es sich an, die Datenschutzaspekte direkt mit einfließen zu lassen, das Rad also nicht neu zu erfinden, sondern auf einen zumeist bereits etablierten Prozess aufzusetzen. Ist noch kein eigenes Risikomanagement in der IT vorhanden, so sollte spätestens durch die Anforderungen des Datenschutzes ein solches eingeführt werden.

6.3.2 Regelmäßige Überprüfung der Maßnahmen

Besteht bereits ein wirksam umgesetztes Risikomanagement in der IT, so werden regelmäßige Risikoanalysen durchgeführt. Veränderungen im Unternehmen (z. B. neue Geschäftsprozesse, Verfahren oder neue Schwachstellen) oder in der eingesetzten Technik (neue Schwachstellen, neue Bedrohungen ...) verlangen eine fortlaufende Bewertung der IT-Risiken. Über eine regelmäßige Überprüfung der Wirksamkeit der implementierten risikobehandelnden Maßnahmen und eine darauf gründende Aktualisierung der Bewertung kann die gewünschte Reduzierung von Risiken erreicht und nachgewiesen werden. Dies ist genau das, was auch vom Datenschutz gefordert wird (konkret z. B. in Artikel 32 Abs. 1 lit. d). DSGVO). Hier kann eine enge Zusammenarbeit zwischen IT und DSB erheblich dazu beitragen, Aufwände zu reduzieren.

**Hinweis**

Die Überprüfung der Maßnahmen kann auf verschiedenste Art und Weise erfolgen: als Selbstauskunft, formal als Review oder aktiv durch eine direkte Überprüfung von Nachweisen. Eine aufwendige, aber besonders wirksame und aussagekräftige Methode ist die aktive Überprüfung durch Simulation eines realen Szenarios, z. B. durch einen Penetrationstest oder Social Engineering oder auch Wiederanlauf- und Wiederherstellungstests.

6.3.3 Entwicklungsprozess

Unabhängig davon, wie der (Produkt-)Entwicklungsprozess im Unternehmen ausgestaltet ist, ob also agile Methoden oder klassische Entwicklungsmodelle zum Einsatz kommen, ist es notwendig, sich mit den Anforderungen von IT-Sicherheit und Datenschutz bereits in einem sehr frühen Stadium zu beschäftigen.

Eine Binsenweisheit in der IT besagt, dass die Kosten für die Beseitigung von Fehlern oder fehlenden Anforderungen je Projektphase/Wertschöpfungsstufe um einen Faktor 10 zunehmen (sogenannte „Rule of Ten“, dargestellt in Bild 6.2). Dies ist sicher mehr Schätzgröße als Naturgesetz, hilft aber, das Problem zu fassen:

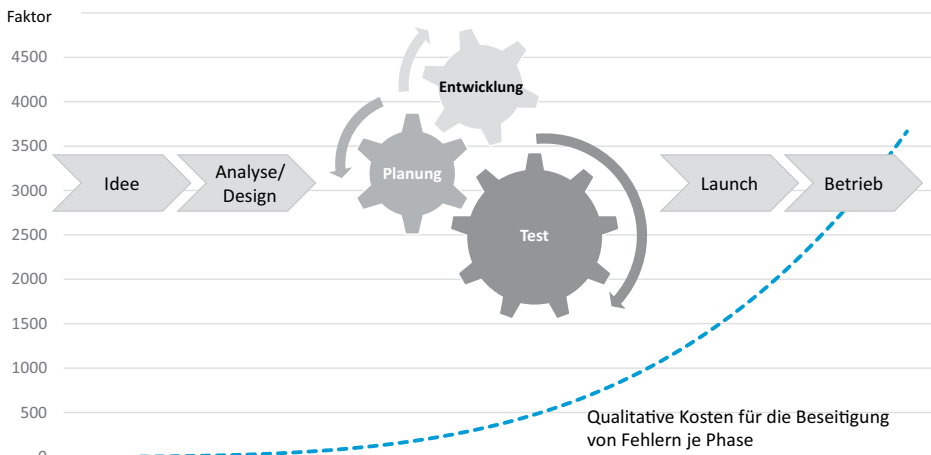


Bild 6.2 „Rule of Ten“: Kosten für die Beseitigung von Fehlern in einem generischen Entwicklungsprozess

In den Phasen Design, Planung und Entwicklung lassen sich Änderungen mit kalkulierbarem Aufwand umsetzen; je eher eine Anforderung bekannt ist oder ein Problem erkannt wird, desto einfacher (und damit kostengünstiger) ist es in der Regel, Anpassungen vorzunehmen.

Wird eine Sicherheitslücke oder ein Datenschutzproblem jedoch erst unmittelbar vor dem Launch oder der Abnahme eines Produktes erkannt, so entstehen erhebliche Mehrkosten nicht nur durch die nun aufwendigere Anpassung, sondern auch dadurch, dass frühere Phasen wiederholt werden müssen und zeitlicher Verzug eintritt. Noch größer sind diese, wenn das Produkt bereits auf dem Markt ist – hier drohen neben den Beseitigungskosten auch kostspielige Rückrufe oder Updates, Reputationsschäden und – im Falle des Datenschutzes – unangenehme Fragen der Aufsichtsbehörde und Bußgelder. Der Erfahrung nach ist der Aufwand erheblich, den eine An-

frage oder ein Kontrollbesuch der Datenschutzaufsicht im Unternehmen auslöst. Dies gilt auch für Unternehmen, die im Datenschutz gut aufgestellt sind. Oft wird dieses Risiko jedoch nicht erkannt.

Sinnvoll ist es folglich, den DSB und die IT-Sicherheit bereits zu Beginn der Entwicklung einzubinden, idealerweise zu dem Zeitpunkt, zu dem die Zielsetzung durch den Anforderer konkret beschrieben werden kann und eine erste (grobe) Idee für die Realisierung besteht, aber noch bevor wesentliche Aufwände für das Projekt geleistet wurden. So sollte bereits der Schutzbedarf von Daten, Informationen und Systemen einheitlich festgestellt werden, in IT-getriebenen Projekten durch Hinzunahme der Dimension „Datenschutz“, in anderen Fällen durch Betrachtung der Informationssicherheit.

Dies ermöglicht es, das gesetzlich geforderte Prinzip „Privacy by Design“ (siehe Kapitel 15, „Edge Computing“) beziehungsweise das wünschenswerte „Security by Design“ überhaupt zu realisieren. Identifizierte Sicherheits- und Datenschutzanforderungen sind dabei gleichwertig zu fachlich funktionalen Anforderungen zu betrachten.

DSB und ISB sollten sodann im weiteren Projektverlauf beteiligt bleiben, damit Änderungen und Erweiterungen des Vorhabens in gleicher Art und Weise beachtet werden und Entscheidungen oder auftretende Fragen hinsichtlich des Datenschutzes oder der sicherheitsrelevanten Belange schnell behandelt werden können. In Bild 6.3 wurden die notwendigen Anpassungen des generischen Entwicklungsprozesses aus Bild 6.2 vorgenommen. In der Praxis hat es sich als sinnvoll herausgestellt, den Entwicklungsprozess zudem jeweils an den Phasenübergängen durch Checkpunkte in Bezug auf Datenschutz und Informationssicherheit zu ergänzen.

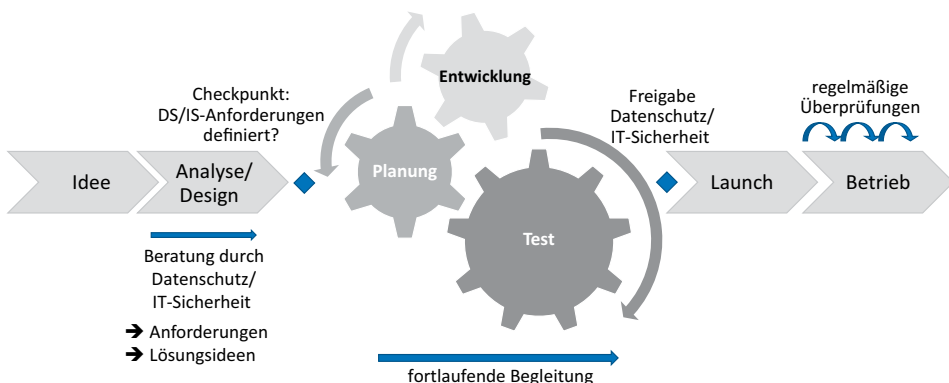


Bild 6.3 Einbindung von Datenschutz und IT-Sicherheit in einen generischen Entwicklungsprozess

Je besser die fortlaufende Einbindung von DSB und ISB realisiert ist, umso geringer ist das Risiko unliebsamer Überraschungen bei Launch und Betrieb. Der Wertschöpfungsbeitrag und die Akzeptanz sind dabei dann maximal, wenn sich DSB und ISB als Teil der Lösung verstehen, also nicht nur auf mögliche Probleme und Risiken hinweisen, sondern gemeinsam mit dem Projektteam Lösungsmöglichkeiten im Sinne des Unternehmens erarbeiten.

6.4 Operative Aspekte: technische und organisatorische Maßnahmen

Die Schutzziele der Informationssicherheit, nämlich Vertraulichkeit (Confidentiality), Integrität (Integrity) und Verfügbarkeit (Availability), decken sich mit einem großen Teil der vom Gesetz geforderten Anforderungen an eine sichere Verarbeitung personenbezogener Daten. Es ist daher folgerichtig, dass auch die zugehörigen Maßnahmen weitgehend deckungsgleich sind.

Diese werden seitens des Datenschutzes in den „technischen und organisatorischen Maßnahmen“ (TOM) seitens der IT-Sicherheit häufig in einem Sicherheitskonzept oder als Dokumente in einem Informationssicherheitsmanagementsystem abgebildet.

Bild 6.4 zeigt einen Überblick über die vom Datenschutz geforderten technischen und organisatorischen Maßnahmen. Gestrichelte Linien geben dabei solche Maßnahmen an, die keinen oder nur geringen Bezug zur Informationssicherheit haben und eher über den jeweiligen Geschäftsprozess abgebildet werden müssen. Dies betrifft z. B. die Felder „Trennung nach Zwecken der Verarbeitung“ oder den „Schutz vor unrechtmäßiger Verarbeitung“.

Werden nun Datenschutzdokumentation und ISMS nicht gemeinsam aufgebaut, sondern entstehen parallel oder nacheinander, so fehlt es häufig an einer Abbildung oder Übersetzung zwischen den Welten, sodass die Gefahr divergierender Maßnahmen und Regelungen besteht. Im Folgenden findet sich daher eine Zuordnung der im Datenschutz gebräuchlichen Begriffe zu den entsprechenden technischen Maßnahmen in der IT-Sicherheit, die es ermöglichen soll, möglichst einheitliche und abgestimmte Wege zu gehen.

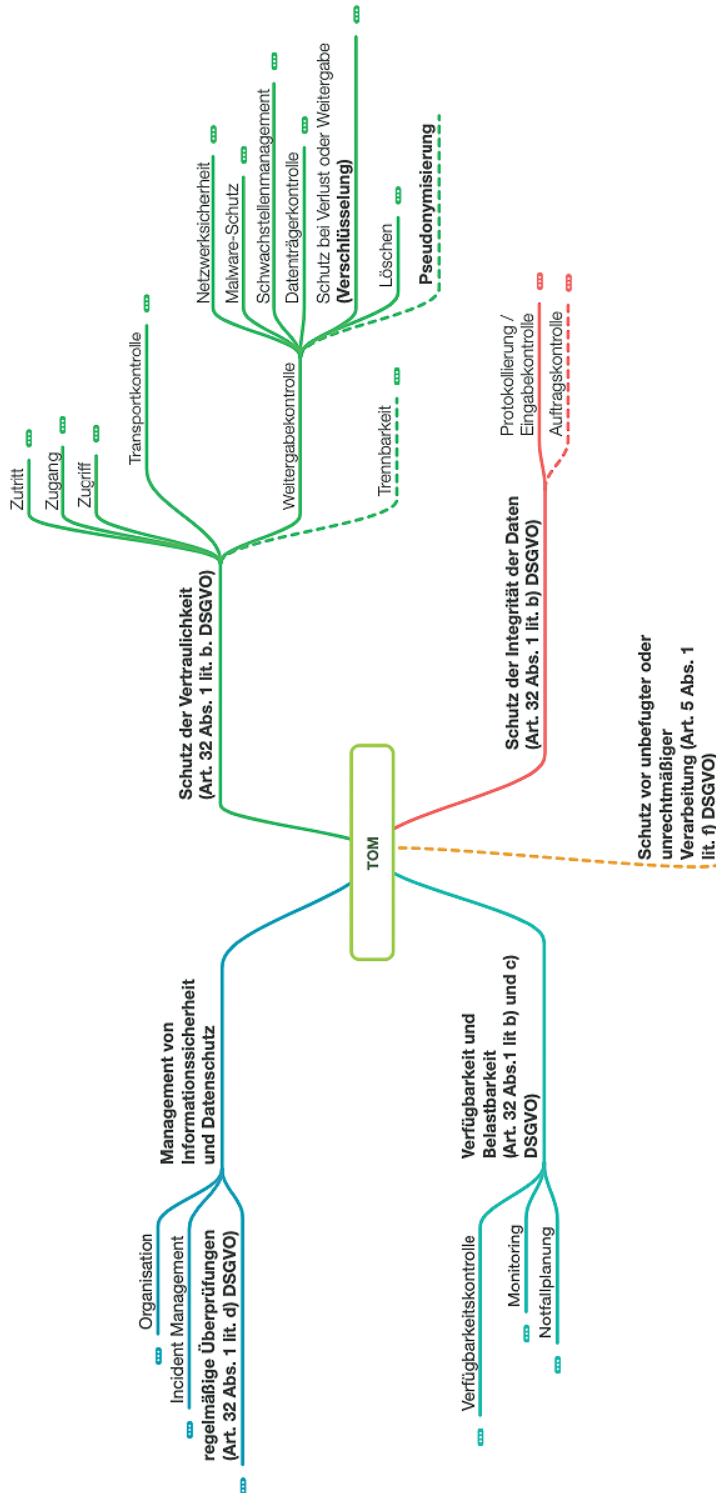


Bild 6.4 Technische und organisatorische Maßnahmen – Überblick

6.4.1 Schutz der Vertraulichkeit

Der Schutz der Vertraulichkeit ist die Maßnahmengruppe, an die man beim Thema Datenschutz vermutlich zuerst denkt. Eine Vielzahl von Maßnahmen der Informationssicherheit zielt darauf ab, Daten vor unberechtigter Kenntnisnahme durch Dritte zu schützen. Dazu gehört es auch, zu verhindern, dass berechtigte Personen die Daten unbefugt weitergeben oder dass Daten zufällig oder unbeabsichtigt bekannt werden, zum Beispiel durch Verlust eines Datenträgers oder Fehler bei der Entsorgung.

Wesentlich ist es also, die Zugangsmöglichkeiten zu den zu schützenden Daten angemessen zu beschränken. Im vom juristischen Denken geprägten Datenschutz hat es sich dabei eingebürgert, zu differenzieren zwischen

- dem physischen Zutritt zu dem Ort, an dem sich die Daten befinden oder die Verarbeitung stattfindet,
- dem Zugang (also der Zugriffsmöglichkeit) auf das verarbeitende System oder die Ablage der Daten und
- dem Zugriff auf die Daten selbst.

Maßnahmen der *Zutrittskontrolle* umfassen hierbei alles, was den unbefugten Zutritt erschwert oder verhindert. Technisch gesehen umfasst dies alles vom Schlüssel über Schließ- und Zutrittskontrollsysteme bis hin zu baulichem Einbruchschutz und der Einbruchmeldeanlage. Auf der organisatorischen Seite finden sich unter anderem Regelungen zum Empfang und Werksschutz, zum Besuchermanagement sowie zur Einteilung der Liegenschaften in verschiedene Sicherheitszonen.

Dabei besteht – zumindest für Rechenzentren, Server und Technikräume – eine entsprechende Schnittmenge mit der IT-Sicherheit, ein wesentlicher Teil der Maßnahmen wird aber häufig in anderen Bereichen wie dem Facilitymanagement oder der Personalabteilung verantwortet.

Klarer in den Kompetenzbereich der IT fällt die Domäne „Zugang“; hierunter versteht man zum Beispiel die Möglichkeit der Anmeldung (Login) an einem System. Die *Zugangskontrolle* umfasst somit alle Prozesse und Vorkehrungen im Umfeld des Identity- und Accessmanagements und deren Sicherheitsvorgaben (z. B. Regelungen zur Passwortsicherheit und zum Umgang mit Kennungen ...)

Der eigentliche Zugriff auf die Daten erfolgt sodann gesteuert durch Berechtigungen in Betriebssystem oder Anwendung, häufig durch zentrale Verzeichnisdienste unterstützt. Als Maßnahmen der *Zugriffskontrolle* sind ein rollenbasiertes Berechtigungskonzept sowie ein angemessenes Verfahren für privilegierte Zugriffe (Privileged Identity Management) Stand der Technik.

Unter *Transportkontrolle* versteht man im Datenschutz alle Maßnahmen zur Sicherung von „Data in Transit“, also Daten während jeglicher Übertragung zwischen Sys-

temen innerhalb und außerhalb des eigenen Einflussbereichs. Das vermutlich relevanteste Beispiel für eine solche Maßnahme ist die Transportverschlüsselung mittels TLS, wie sie zwischen E-Mail-Servern oder bei gesicherten Inhalten des Internets (<https://>) verwendet wird. Weiterhin fallen aber auch die physische Absicherung von Backupbändern beim Transport an einen abgesetzten Lagerort oder Sicherungsmaßnahmen beim Versand von Unterlagen oder Datenträgern in diese Kategorie. Hier ist eine geeignete Verschlüsselung der Daten in der Regel das angemessene Mittel – und diese wird als Maßnahme sogar in der DSGVO explizit erwähnt.

**Beispiel**

Daten sind verschlüsselt auf einem USB-Stick abgelegt, der auf einem Schreibtisch im Büro liegt.

Wer *Zutritt* zum Büro hat (z. B. wegen der offenen Türe), kann sich *Zugang* zu dem USB-Stick verschaffen, wenn er diesen an sich nimmt. *Zugriff* auf die abgelegten Daten bekommt er, wenn er darüber hinaus das Passwort für die Verschlüsselung kennt.

Die entsprechenden Sicherungsmaßnahmen bauen also aufeinander auf bzw. ergänzen sich.

Die *Weitergabekontrolle* schließlich umfasst zunächst die klassische Netzwerksicherheit, also Schutzmaßnahmen wie die Trennung von Netzwerken, den geregelten Einsatz von Firewalls, den Schutz durch Intrusion-Detection und -Preventions-Systeme. Da eine große Gefahr für unberechtigte Weitergabe von Daten durch Trojaner und andere Schadprogramme besteht, gehören auch die Maßnahmen zum Schutz vor Malware in diese Kategorie. Damit ist nicht nur der Virens Scanner auf Endgerät und Netz gemeint, sondern auch ein gut organisiertes Schwachstellenmanagement und eine regelmäßige Aktualisierung der Systeme, um Sicherheitslücken zu vermeiden. Ergänzend zählen zur Weitergabekontrolle auch Maßnahmen gegen Verlust und Diebstahl, insbesondere die Verschlüsselung mobiler Geräte (Laptops, Datenträger), ein Mobile-Device-Management für Smartphones und Tablets sowie Vorgaben zur sicherheitskonformen Entsorgung und Löschung von Datenträgern aller Art.

Verständliche und praxisgerechte Vorgaben (Policies, Richtlinien), eine regelmäßige Schulung der Mitarbeiter sowie Maßnahmen zur Förderung der Security-Awareness (zum Beispiel hinsichtlich Phishing etc.) sind die Kernbereiche im organisatorischen Segment.

Aus Datenschutzsicht sind noch weitere Schutzmaßnahmen zur Risikoreduzierung gefordert, welche jedoch eher geringe Schnittmengen mit der Informationssicherheit aufweisen. Hier ist der Vollständigkeit halber die im Gesetz erwähnte *Pseudonymisierung* der Daten zu nennen, also das Ersetzen des direkten Personenbezugs (z. B. Name, Geburtsdatum) durch ein anderes Merkmal (Kundennummer) zur Referenz. Damit kann in nachfolgenden Teilen der Verarbeitung ein direkter Personenbezug

vermieden werden, da nur noch das Pseudonym verwendet wird, die Zuordnungstabelle jedoch nicht weitergegeben wird.

6.4.2 Schutz der Integrität

Integrität bezeichnet als Sicherheitsgrundwert „die Sicherstellung der Korrektheit (Unversehrtheit) von Daten und der korrekten Funktionsweise von Systemen“.¹ In der Praxis versteht man darunter die Zusicherung, dass zumindest eine unerkannte Änderung von Daten nicht möglich ist. Diese Definition teilen Datenschutz und Informationssicherheit.

Wichtig wird Integrität zum Beispiel bei jeder Übertragung von Daten. Sender und Empfänger müssen sicher sein können, dass die empfangene Information der gesendeten entspricht und dass Fehler auf dem Übertragungsweg zumindest erkannt werden können.

Sicherstellen lässt sich dies durch eine Reihe von technischen Maßnahmen, zum Beispiel durch die Verwendung von Prüfsummen zur Fehlerkorrektur in Übertragungsprotokollen, kryptografische Hashes als Prüfsumme, Signaturverfahren etc.

Hierunter fallen jedoch auch organisatorische Vorgaben, wie zum Beispiel die Einhaltung eines Vieraugenprinzips oder die Etablierung von Freigabeprozessen für bestimmte Vorgänge.

Zwei weitere Aspekte sind die Protokollierung von Zugriffen auf schützenswerte Daten, um Änderungen nachvollziehen zu können, sowie der Schutz dieser Protokolle selbst vor Manipulation und Löschung. Hierunter fällt auch die als „Eingabekontrolle“ bezeichnete Aufzeichnung von Erfassungen und Änderungen von Daten, z. B. in einer Datenbankanwendung.



Beispiel

A zahlt im Geschäft mit Karte. Auf dem gesamten Weg vom POS-Terminal an die Bank müssen der Betrag, der Empfänger, das Konto des A und die Autorisierung dazu (PIN oder Unterschrift) korrekt sein. Fehler und Manipulationen müssen erkannt werden, damit kein Schaden entsteht.

Aufseiten der Bank muss der (korrekte) Auftragseingang aufgezeichnet werden. Diese Aufzeichnung muss ebenso besonders gegen Manipulation geschützt werden.

Zudem muss auch das Geschäft im Falle eines Fehlers oder einer Störung zweifelsfrei nachweisen können, dass die Zahlung erfolgt ist (per Aufzeichnung im Gerät, Beleg oder in der Kasse). Auch diese Aufzeichnung muss gegen Manipulation gesichert sein.

Alle diese Vorgänge berühren personenbezogene Daten und sind daher für Informationssicherheit und Datenschutz gleichermaßen relevant.

¹ Definition des BSI, https://www.bsi.bund.de/DE/Service-Navi/Cyber-Glossar/cyber-glossar_node.html

6.4.3 Schutz der Verfügbarkeit und Belastbarkeit

Die vom Datenschutz als „Verfügbarkeitskontrolle“, aus Sicht der IT-Sicherheit mit dem Informationssicherheitsgrundwert „Verfügbarkeit“ bezeichneten Vorkehrungen umfassen:

- Maßnahmen der Ausfallsicherheit (z. B. Einsatz von Redundanz),
- die Gewährleistung eines geregelten Ablaufes auch unter Störeinflüssen (Resilienz),
- die regelmäßige Sicherung der Daten (Backup),
- die Möglichkeit zu einer raschen Wiederherstellung der Systeme und Daten nach einem Zwischenfall (Restore, Recovery),
- Maßnahmen der Notfallplanung sowie die Schnittstelle zum Business Continuity Management.

Zudem sind hier auch die Maßnahmen der Betriebsüberwachung (Monitoring) anzusiedeln. Ein angemessenes Monitoring erlaubt es, Störungen und Ausfälle frühzeitig zu erkennen und darauf schadenbegrenzend reagieren zu können.

6.4.4 Vorfallsbehandlung (Incident Management)

Auch bei der Behandlung von Sicherheits- und Datenschutzvorfällen lassen sich sehr große Gemeinsamkeiten erkennen. Der typische (idealisierte) Ablauf zur Behandlung von Sicherheitsvorfällen in der IT sieht wie folgt aus (siehe Bild 6.5).

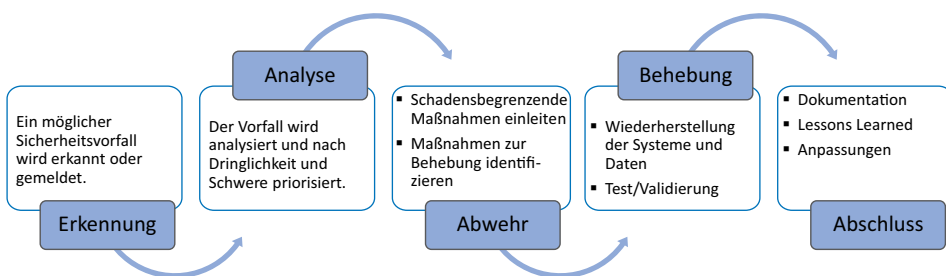


Bild 6.5 Generischer Security-Incident-Prozess in der IT

Nach Erkennen oder Melden eines potenziellen Vorfalls wird dieser zunächst von den Mitarbeitern der IT-Sicherheit analysiert und hinsichtlich der Schwere (Schadensausmaß und -potenzial, Störungsumfang, betroffene Geschäftsprozesse ...) eingestuft. Zur Schadenbegrenzung und nachfolgenden Behebung werden situationsabhängig Spezialisten aus IT und Fachbereichen zugezogen, welche gemeinsam schadenbegrenzende Maßnahmen festlegen und die Behebung der Störungen einleiten. Nach

Abschluss der Intervention wird der Vorfall dokumentiert, Schwachstellen werden identifiziert und die Schutzmaßnahmen für die Zukunft angepasst.

Sind personenbezogene Daten bei einem Vorfall betroffen – was bei den allermeisten Sicherheitsvorfällen der Fall sein dürfte –, so ist ab diesem Zeitpunkt der DSB mit in die Vorfallsbehandlung zu involvieren. Ab dem Zeitpunkt der Erkenntnis tickt für das Unternehmen zudem eine Frist: Binnen 72 Stunden ist ein Datenschutzvorfall der Aufsichtsbehörde zu melden, wenn ein Risiko für die „Rechte und Freiheiten natürlicher Personen“ besteht (Art. 33 (1) DSGVO). Das Vorliegen dieses Risikos und gegebenenfalls dessen Ausmaß festzustellen ist nun Aufgabe des DSB. Bei sehr hohem Risiko, beispielsweise wenn Passwörter oder vollständige Kreditkartendaten offenbart wurden, sind alle betroffenen Personen zusätzlich direkt zu informieren.

Diese Erkenntnis kann jedoch weder der DSB (dem in aller Regel detaillierter Einblick in die Systeme und Zusammenhänge fehlt) noch der ISB (der meist die datenschutzrechtlichen Implikationen und das Betroffenenrisiko nicht detailliert kennt) allein gewinnen. Dasselbe gilt für die Ableitung, Umsetzung und Bewertung von Schutzmaßnahmen, bei denen ebenso beide Seiten beitragen müssen. Beide Prozessteile sind also so eng verzahnt, dass ein einheitliches Vorgehen fast zwingend notwendig scheint.

Der Prozess für Sicherheitsvorfälle muss daher zum Beispiel wie in Bild 6.6 dargestellt erweitert werden, um den Anforderungen des Datenschutzes Rechnung zu tragen. Gleichzeitig sollten – um Mitarbeiter und Organisation nicht zu überfordern – auch der Meldeweg (vielfach über den Helpdesk) und die Steuerung (Workflow bzw. Ticket-system) für Datenschutz- und IT-Sicherheitsvorfälle vereinheitlicht werden. Das Auffinden ungeschreddeter Personalunterlagen am Altpapiercontainer sollte also denselben Melde- und Prozessweg nehmen können wie der Virenfund auf dem Rechner.

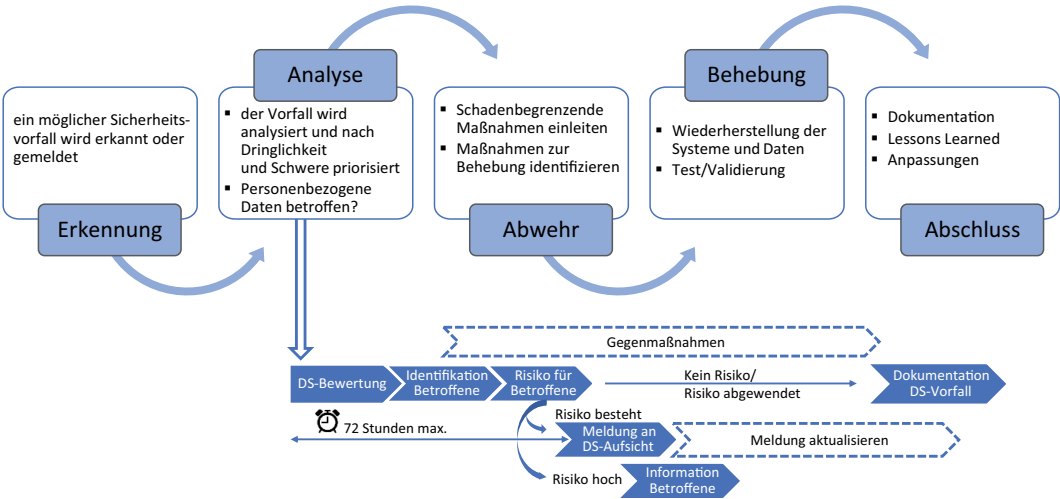


Bild 6.6 Ergänzung des Security-Incident-Prozesses um Datenschutzbelange

6.5 Organisationsaspekte

Betrachtet man das Zusammenwirken von Informationssicherheit und Datenschutz, so muss man für ein vollständiges Bild auch den Aspekt der Organisation der Funktionen im Unternehmen beleuchten:

In vielen Unternehmen ist der ISB im IT-Bereich und der DSB in der Rechtsabteilung, in Audit/Revision oder im Compliance-Bereich angesiedelt. Diese Konstellation hat sich als praxistauglich erwiesen. Einerseits profitiert der ISB dabei vom „Stallgeruch“ der IT, also der Nähe zu Technik, Prozessen, Befindlichkeiten und Abläufen, und kann so seine Aufgabe effizient und auf Augenhöhe mit den Kollegen wahrnehmen. Andererseits hat er mit dem DSB einen unabhängigen Mitstreiter, der nicht der Weisungsgebundenheit in der IT unterliegt und bei Entscheidungen im Sinne der IT-Sicherheit unterstützen kann.

Nicht sinnvoll, leider aber insbesondere in kleineren und mittleren Unternehmen manchmal praktiziert, ist es jedoch, die Funktionen von Datenschutzbeauftragtem und IT-Sicherheitsbeauftragtem zusammenzulegen. In dieser Konstellation sind Interessenkonflikte vorprogrammiert, muss doch der DSB aufgrund seines gesetzlichen Auftrags (Art. 39 DSGVO) auch die Maßnahmen und Verarbeitungen in der IT hinsichtlich der Einhaltung des Datenschutzes kontrollieren.



Beispiel Interessenkonflikt

Zu den Aufgaben des ISB gehört es, missbräuchliche Verwendung oder Angriffe auf die IT-Systeme zu erkennen und nachzuvollziehen, um Gefahren für das Unternehmen abzuwenden. Dazu benötigt dieser *möglichst vollständige, detaillierte und langfristige Aufzeichnungen* des Kommunikationsverhaltens von und zu den Unternehmensnetzwerken. Diese Logs enthalten in der Regel personenbezogene Daten wie die IP-Adressen, Kennungen etc. sowie teilweise auch Inhalte der Kommunikation (E-Mail-Header, URL ...).

Aufgabe des DSB ist es, auf die Einhaltung der gesetzlichen Anforderungen zum Datenschutz zu achten, also insbesondere auf einen sparsamen und für die betroffene Person risikominimierten Umgang mit personenbezogenen Daten hinzuwirken. Damit muss dieser darauf abzielen, die *Speicherung und die Vorhaltung der genannten Aufzeichnungen zu minimieren*, bei einigen Daten muss die Auswertung aufgrund eines hohen Risikos für die Rechte der betroffenen Person vielleicht sogar untersagt werden.

Der Interessenkonflikt ist offensichtlich, es bedarf einer neutralen Abwägung von Risiken und Nutzen und eventuell der Festlegung und Einhaltung für die IT „unbequemer“ Auflagen (Vieraugenprinzip, Anonymisierung, Begrenzung der Speicherfrist ...).

Werden beide Funktionen von einer Person wahrgenommen, kann diese neutrale Betrachtung nicht sichergestellt werden.

Eine enge Zusammenarbeit zwischen dem Datenschutzbeauftragten und dem Verantwortlichen für die IT- bzw. Informationssicherheit ist so für alle Beteiligten förderlich, diese sollte nur nicht in Personalunion münden. Aufgrund der oben beschriebenen großen thematischen Nähe und oft deckungsgleicher Interessen lassen sich durch eine vertrauensvolle Kooperation Synergien heben und Prozesse und Abläufe optimieren. Der ISB bzw. die Informationssicherheit im Unternehmen profitiert dabei von den gesetzlichen Vorgaben durch den Datenschutz, welche ohnehin für die IT-Sicherheit notwendige Maßnahmen noch besser zu verargumentieren und zu priorisieren helfen.

6.6 Fazit

IT-Sicherheit und Datenschutz haben an sehr vielen Stellen Gemeinsamkeiten, sie ergänzen sich gegenseitig und sind wesentliche Säulen im Risikomanagement eines Unternehmens. Beide Disziplinen haben dennoch so große Unterschiede, dass sich eine vollständige Zusammenlegung der Verantwortung nicht anbietet – sondern im Gegenteil aufgrund von Interessenkonflikten sogar ausschließt.

Während der Datenschutz in Händen eines IT-affinen Juristen gut aufgehoben ist, ist die IT-Sicherheit bei einem Techniker mit Datenschutzaffinität sicher in besten Händen, auch und gerade weil sich Herangehens-, Betrachtungs- und Denkweise unterscheiden.

Prozesse wie das Risikomanagement, die Behandlung von Sicherheitsvorfällen (Incident-Management) und Teile des Änderungs- und Entwicklungsprozesses werden am besten zwischen Datenschutz und IT harmonisiert. Gleiches gilt für das betriebliche Regelwerk (Policies), welches im Bereich IT-Sicherheit und Datenschutz denselben Ansatz verfolgen sollte.

Der Datenschutz bleibt jedoch immer auf die Maßnahmen der IT-Sicherheit angewiesen, ohne die eine gesetzeskonforme Verarbeitung personenbezogener Daten im Unternehmen nicht möglich ist.

Literatur

Bundesamt für Sicherheit in der Informationstechnik (Hrsg.), „Managementsysteme für Informationssicherheit (ISMS), BSI-Standard 200-1“, Version 1.0, Oktober 2017. <https://www.bsi.bund.de/grundschutz>

Bundesamt für Sicherheit in der Informationstechnik (Hrsg.), „IT-Grundschutz Methodik, BSI-Standard 200-2“, Version 1.0, Oktober 2017. <https://www.bsi.bund.de/grundschutz>

Bundesamt für Sicherheit in der Informationstechnik (Hrsg.), „Risikoanalyse auf der Basis von IT-Grundschutz, BSI-Standard 200-3“, Version 1.0, Oktober 2017. <https://www.bsi.bund.de/grundschutz>

Bundesamt für Sicherheit in der Informationstechnik (Hrsg.), „Business Continuity Management, BSI-Standard 200-4“, Version 1.0, Mai 2023. <https://www.bsi.bund.de/grundschutz>

Ebert, Christof (2013): „Risikomanagement kompakt: Risiken und Unsicherheiten bewerten und beherrschen“, 2., überarbeitete und erweiterte Auflage, Berlin Heidelberg, Springer Vieweg, 2013, ISBN: 9783 642 410 475.

Gierschmann, S.; Schlender K.; Stenzel R.; Veil W. (Hrsg.): Kommentar Datenschutz Grundverordnung, Bundesanzeiger Verlag, Köln, 2018.

ISO/IEC 27 001:2022, International Organization for Standardization (Hrsg.), Information technology – Information security, cybersecurity and privacy protection – Information security management systems – Requirements, ISO/IEC JTC 1/SC 27, 2022.

ISO/IEC 27 002:2022, International Organization for Standardization (Hrsg.), Information technology – Information security, cybersecurity and privacy protection – Information security controls, ISO/IEC JTC 1/SC 27, 2022.

Knoll, Matthias (2019): „Praxisorientiertes IT-Risikomanagement: Konzeption, Implementierung und Überprüfung“, 2., überarbeitete und erweiterte Auflage, dpunkt verlag, 2019, ISBN: 9783 864 906 558.

Rost, M.: „Das Standard-Datenschutzmodell (SDM): Einführung, Hintergründe und Kontexte zum Erreichen der Gewährleistungsziele“, Springer Vieweg (09. Dezember 2022).

IT-Sicherheit durch Bedrohungs- und Risikoanalysen stärken

Daniel Angermeier



In diesem Beitrag erfahren Sie,

- welchen Nutzen Security-Bedrohungs- und Risikoanalysen haben,
- wie sie in Unternehmensprozesse eingebunden werden können,
- welche Schnittstellen zu anderen Domänen neben der Security existieren,
- auf welche Kriterien bei der Auswahl einer Analysemethode zu achten ist.

7.1 Einleitung

Risikoanalysen sind in der Geschäftswelt allgegenwärtig und werden in vielen Domänen genutzt. Unternehmerische Risiken und Risiken bezüglich der Produkthaftung werden ebenso ermittelt wie die Risiken, die von möglichen Naturkatastrophen ausgehen. In vielen Bereichen ist eine Risikobetrachtung aus Sicht der Safety erforderlich, beispielsweise nach ISO 26 262 im Automobilbereich (ISO 2018). Ebenso verlangt die in Artikel 35 Absatz 7 der Datenschutz-Grundverordnung (DSGVO) geforderte Datenschutz-Folgenabschätzung eine Risikobetrachtung. Im Bereich der Security¹ ist die Bedrohungs- und Risikoanalyse ein Werkzeug, um Security-Anforderungen zu ermitteln, daraus Schutzkonzepte abzuleiten und diese bezüglich ihrer Wirksamkeit und Angemessenheit zu prüfen. Im Vordergrund stehen hierbei typischerweise technische Risiken, die aus möglichen Angriffen auf die Infrastruktur oder die Produkte eines Unternehmens resultieren.

¹ Der Begriff „Security“ bezeichnet in diesem Artikel die Sicherheit gegen Angriffe und wird zur Abgrenzung gegenüber der Betriebssicherheit (Safety) benutzt.

Zugleich gibt es viele Schnittstellen mit den zuvor genannten Bereichen: Security-Vorfälle können zu erheblichen finanziellen Schäden führen und sowohl das unternehmerische Risiko erhöhen als auch ganze Geschäftsmodelle gefährden. Die finanziellen Schäden durch Cybersecurity-Vorfälle werden für die deutsche Wirtschaft im Jahr 2021 auf 223 Milliarden Euro jährlich geschätzt (Gehm 2021). Produktpiraterie stellt für viele Unternehmen ein ernsthaftes Problem dar (VDMA 2020). Sonderausstattungen und Mehrwertdienste der eigenen Produkte werden häufig in Form von Software oder deren Parametrisierung verkauft, sodass eine Freischaltung am Unternehmen vorbei zu Gewinnverlusten führen kann. Die Betriebssicherheit kann durch Security-Vorfälle erheblich gefährdet werden und hängt somit unmittelbar davon ab, dass das jeweilige System ausreichend gegen Angriffe geschützt ist. Der Schutz personenbezogener Daten gilt nicht nur für die Verarbeitung durch das jeweilige Unternehmen, sondern es ist auch sicherzustellen, dass die Daten nach Stand der Technik vor unbefugtem Zugriff geschützt sind (Art. 25 DS-GVO). Aus diesem Grund ist die Bedrohungs- und Risikoanalyse nicht als Security-Aktivität zum Selbstzweck zu verstehen, sondern als wichtiger Baustein für das Erreichen zentraler Unternehmensziele. Folglich ist es wichtig, Bedrohungs- und Risikoanalysen nicht isoliert von anderen Prozessen durchzuführen, sondern entsprechende Schnittstellen zu anderen Bereichen zu etablieren.

Weiterhin gibt es einen zunehmenden Trend dazu, seitens der Gesetzgebung oder Regulierung Anforderungen an die Security im Entwicklungszyklus zu stellen, beispielsweise nach UN R.155 für die Typzulassung bei Fahrzeugen (UNECE 2021). Es ist daher wichtig, die relevanten Standards und Normen der eigenen Domäne zu kennen und anzuwenden, um sowohl den Anforderungen der Regulierungsbehörden als auch security-bewusster Kunden gerecht zu werden.

7.2 Nutzen und Mehrwert von Bedrohungs- und Risikoanalysen

Bedrohungs- und Risikoanalysen dienen primär dazu, Security-Risiken zu erkennen und zu bewerten. In der darauffolgenden Risikobehandlung gibt es im Kern vier Möglichkeiten, die in verschiedenen Ausprägungen in gängigen Standards (z. B. ISO/IEC 2018) beschrieben sind:

1. Akzeptanz
2. Übertragung
3. Vermeidung
4. Verringerung

Die *Akzeptanz* von Risiken fußt in der Regel darauf, dass das ermittelte Risiko unter einem Schwellenwert, der sogenannten Risikoakzeptanzschwelle, liegt. Es ist aber auch möglich, Risiken bewusst in Kauf zu nehmen. Dies sollte nur in Ausnahmefällen erfolgen und muss durch eine informierte, bewusste und dokumentierte Entscheidung vollzogen werden. Üblicherweise werden Risiken oberhalb der Akzeptanzschwelle durch eine der anderen drei Optionen behandelt.

Bei der *Übertragung* wird das Risiko an eine andere Partei übertragen, die dann das Risiko ihrerseits behandelt. Hierbei kann es sich um eine Versicherung handeln, die Schäden durch Cybersecurity-Vorfälle trägt, einen Dienstleister, der für Schäden durch den Ausfall eines Dienstes haftet, oder den eigenen Kunden, der bei Vertragsabschluss das Risiko übernimmt. In allen Fällen ist wichtig, eine rechtssichere Vereinbarung mit der Partei zu schließen, der das Risiko übertragen wird.

Die *Vermeidung* eines Risikos wird durch eine Änderung am Untersuchungsgegenstand umgesetzt. Beispielsweise kann ein Produktfeature, das unter wirtschaftlichen Gesichtspunkten nicht sicher umgesetzt werden kann, aus dem Produkt entfernt werden, um ein Risiko zu vermeiden. Ebenso können Aspekte des Untersuchungsgegenstands angepasst werden, um bestimmte Risiken zu vermeiden. Beispielsweise könnte das Unternehmen einen Dienst selbst umsetzen, statt auf einen Dienstleister zurückzugreifen, wenn der Dienst für das Unternehmen kritische Daten verarbeiten soll. Durch die Bedrohungs- und Risikoanalyse kann die Entscheidung zur Risikovermeidung schon früh im Entwicklungsprozess erfolgen, wodurch sich unnötige Kosten für Fehlentwicklungen vermeiden lassen.

Die *Risikoverringerung* wird schließlich durch das Einführen von Maßnahmen erreicht. Hierbei bietet die Bedrohungs- und Risikoanalyse einen weiteren entscheidenden Mehrwert: Maßnahmen können gezielt ausgewählt und eingeführt werden, da man nach Durchführung der Risikobehandlung die Security-Anforderungen präzise kennt. Dies stellt einerseits sicher, dass die ausgewählten Maßnahmen notwendig sind und keine unnötigen Kosten verursachen. Andererseits kann eine weitere Iteration der Bedrohungs- und Risikoanalyse auch sicherstellen, dass die Maßnahmen aus Konzept Sicht ausreichend sind, um eine Risikoakzeptanz zu erreichen, sodass sich auch das Schutzkonzept selbst auf den Prüfstand stellen lässt. Die Bedrohungs- und Risikoanalyse dient also dazu, ein angemessenes Schutzkonzept herzuleiten.



Bedrohungs- und Risikoanalysen unterstützen, dass

- das Schutzkonzept die Risiken ausreichend senkt (→ Risikoreduktion),
- Maßnahmen gezielt eingeführt werden, wo sie benötigt werden (→ Kostenreduktion).

Hierbei ist auch zu bedenken, dass die von Maßnahmen verursachten Kosten in unterschiedlichen Formen auftreten können. Beispielsweise kann das Bedaten eines Geräts in einer Fertigungsstraße durch das Einbringen kryptografischer Schlüssel län-

ger dauern, sodass Fertigungsprozesse angepasst werden müssen. Hardware-basierte Security bietet guten Schutz, verursacht aber auch bei jedem gefertigten Gerät Kosten. Infrastrukturen zur Erstellung und Wartung von Zertifikaten müssen betrieben und gewartet werden. Aus diesem Grund ist es oft keine Option, den maximalen Schutz nach Stand der Technik pauschal überall in Produkten und eigenen Systemen anzuwenden. Stattdessen ist ein selektives Vorgehen nötig, das Maßnahmen gezielt dort einsetzt, wo sie benötigt werden, um die in Abschnitt 7.1 beschriebenen massiven Schäden durch Cybersecurity-Vorfälle zu verhindern. Bedrohungs- und Risikoanalysen bilden die Grundlage für dieses selektive, risikobasierte Vorgehen.

7.3 Ablauf von Bedrohungs- und Risikoanalysen

Grundsätzlich werden in Bedrohungs- und Risikoanalysen die folgenden vier Aktivitäten durchgeführt, die je nach gewählter Methode unterschiedlich stringent ausfallen (Angermeier 2019):

1. Untersuchungsgegenstand modellieren
2. Schutzbedarf feststellen
3. Bedrohungen analysieren
4. Risiken analysieren

Im ersten Schritt *Untersuchungsgegenstand modellieren* muss hierbei die Person, die die Bedrohungs- und Risikoanalyse durchführt, den Untersuchungsgegenstand verstehen und die für die Bedrohungs- und Risikoanalyse wesentlichen Aspekte erfassen. Dies entspricht einer Modellierung des Untersuchungsgegenstands: Aus den komplexen Informationen, die über den Untersuchungsgegenstand vorliegen, erstellt der Analyst eine vereinfachte und auf das Wesentliche für den Analysezweck reduzierte Repräsentation des Untersuchungsgegenstands – ein Modell. Je nach genutzter Methode bauen die folgenden Schritte dann mehr oder weniger formal auf diesem Modell auf. Da das Modell aus Sicht des Analysten den Untersuchungsgegenstand repräsentiert und somit die Grundlage für die Analyse bildet, ist es für die Nachvollziehbarkeit der Analyse durch Dritte empfehlenswert, dass der Analyst das Modell verständlich dokumentiert. Für die Modellierung selbst müssen dem Analysten Informationen zum Untersuchungsgegenstand bereitgestellt werden und Ansprechpartner zur Verfügung stehen, die mit dem Untersuchungsgegenstand vertraut sind, also Produktentwickler oder Betreiber firmeneigener Systeme. Durch den Austausch zwischen Security-Experten und Domänenexperten kann sichergestellt werden, dass nicht nur die Analyse für das Modell des Analysten in sich korrekt ist, sondern auch das Modell die Wirklichkeit hinreichend präzise und korrekt abbildet. Für die Validi-

tät der Analyse ist das ein notwendiges Kriterium, da die Analyse auf einem falschen Modell unweigerlich zu falschen Ergebnissen führt.

Im zweiten Schritt *Schutzbedarf feststellen* müssen Werte (auch: Assets) im Untersuchungsgegenstand identifiziert und hinsichtlich auftretender Schäden bei Verletzung wichtiger Eigenschaften bewertet werden. Üblicherweise werden hierbei die Eigenschaften Vertraulichkeit, Verfügbarkeit, Integrität und/oder Authentizität betrachtet (siehe z. B. (BSI 2008)), wobei auch andere Eigenschaften, wie beispielsweise die Nichtabstreitbarkeit, eine Rolle spielen können. Die Kombination aus Eigenschaft und Asset wird im Folgenden Schutzziel genannt. Hierfür ist auch eine enge Abstimmung mit anderen Domänen im Unternehmen, wie beispielsweise dem Datenschutz, von großem Vorteil. Die Details hierzu werden in Abschnitt 7.4, Einbindung in Unternehmensprozesse, beschrieben. Ziel der Aktivität ist es, zu verstehen, welche (ggf. nicht materiellen) Güter im Untersuchungsgegenstand einen Wert für das Unternehmen und seine Kunden besitzen und welche ihrer Eigenschaften schützenswert sind. Manche Methoden legen den Schwerpunkt auf die Modellierung von Bedrohungen und führen diese Aktivität nicht direkt durch, sondern weisen die möglichen Schäden bei Verletzung der Schutzziele direkt den Bedrohungen zu. Dies birgt die Gefahr, dass Bewertungen inkonsistent werden, wenn mehrere Bedrohungen dasselbe Asset treffen. Insbesondere bei Änderungen an den Assets kann es dann vorkommen, dass der Zusammenhang zwischen Asset und Bedrohung übersehen wird und somit die Schadensbewertung einer Bedrohung nicht mehr korrekt ist. Folglich ist es empfehlenswert, die Schutzziele der Assets für sich zu bewerten und später eine Verknüpfung zu möglichen Bedrohungen herzustellen.

Im dritten Schritt *Bedrohungen analysieren* werden Bedrohungen ermittelt und hinsichtlich der Wahrscheinlichkeit einer erfolgreichen Durchführung abgeschätzt. Je nachdem, zu welchem Zeitpunkt im Lebenszyklus eines Systems die Analyse erfolgt, können Bedrohungen mit unterschiedlicher Genauigkeit und Detaillierung ermittelt werden. So können beispielsweise Schwachstellendatenbanken nur dann für die Erkennung und Bewertung von Bedrohungen sinnvollen Input liefern, wenn schon feststeht, mit welcher Software das System betrieben wird. In einer frühen Entwicklungsphase, in der die Bedrohungs- und Risikoanalyse idealerweise bereits erfolgen sollte, ist dies häufig nicht der Fall. Allerdings bietet auch eine spätere weitere Iteration der Analyse oder eine Analyse für zuvor noch nicht analysierte Systeme einen Mehrwert, da die Einschätzung möglicher Bedrohungen hier häufig sehr viel konkreter und präziser erfolgen kann. Als Grundlage der Ermittlung von Bedrohungen dienen häufig Kataloge, die auf den vorliegenden Untersuchungsgegenstand angewendet werden. Diese können von einer groben Kategorisierung möglicher Bedrohungen, bspw. nach Microsoft STRIDE (Geiß 2020), bis hin zu sehr detaillierten Katalogen reichen. Die Abschätzung der Wahrscheinlichkeit kann ebenso nach verschiedenen Methoden erfolgen, die üblicherweise auf einer Expertenabschätzung fußen. Beispielsweise definiert die Common Methodology for Information Technology Security Evaluation (Common

Criteria 2017) in Annex B eine Vorgehensweise, bei der anhand fünf verschiedener Faktoren (bspw. Zeit, Wissen des Angreifers) abgeschätzt wird, wie hoch der Aufwand zur Durchführung eines Angriffs ist. Dies erhöht die Nachvollziehbarkeit der Bewertung, setzt aber weiterhin eine Einschätzung durch einen Experten voraus.

Im vierten Schritt *Risiken analysieren* werden Risiken ermittelt und bewertet. Grundlage hierfür sind die Bedrohungen und die Schutzziele (sofern diese erfasst werden und nicht nur Auswirkungen direkt für die Bedrohungen modelliert werden). Die Bedrohungen liefern die Abschätzung für die Eintrittswahrscheinlichkeit eines Schadensereignisses, während die Schadenshöhe durch die verletzten Schutzziele bestimmt wird. Eine Bedrohung kann mehrere Schutzziele verletzen, ebenso kann ein Schutzziel durch mehrere Bedrohungen verletzt werden. Der „schlimmste“ Fall ist hierbei immer ausschlaggebend für die Risikobestimmung, sodass der höchste durch eine Bedrohung ausgelöste Schaden das Risiko für die Bedrohung bestimmt, während für ein Schutzziel der Angriffspfad mit der höchsten Wahrscheinlichkeit für die Risikobestimmung ausschlaggebend ist. Typischerweise werden sowohl die Eintrittswahrscheinlichkeit als auch die Schadenshöhe und das Risiko qualitativ abgeschätzt, da für eine quantitative Abschätzung sowohl auf Bedrohungs- als auch auf Schadensseite üblicherweise keine präzisen Werte vorliegen.

7.4 Einbindung in Unternehmensprozesse

Bedrohungs- und Risikoanalysen sind wesentlich für die Anforderungsermittlung aus Sicht der Security. Wie in der Einleitung beschrieben, müssen sie zudem mit anderen Bereichen im Unternehmen verknüpft werden, um valide Ergebnisse zu erhalten. Dieser Abschnitt befasst sich mit der Einbindung der Security-Aktivitäten in Unternehmensprozesse und mit der nötigen Verflechtung mit Aktivitäten anderer Domänen.

7.4.1 Anforderungsanalyse und Konzeptphase

Security ist üblicherweise ein erwartetes und notwendiges Qualitätsmerkmal eines Produkts, kein Feature im klassischen Sinn. Somit beginnt der Entwurf eines neuen Produkts meist mit funktionalen Anforderungen, die das Produkt erfüllen soll. Dies gilt ebenso für IT-Systeme und Anlagen, die ein Unternehmen plant oder betreibt: Im Fokus steht zunächst die Funktionalität. Dennoch ist es von zentraler Bedeutung, die Security bereits früh im Entwicklungsprozess zu berücksichtigen. Dies hat verschiedene Gründe:

- Die Kosten für die Behebung von Security-Problemen steigen meist während des Produktentwicklungs- und -lebenszyklus fortlaufend an: Schwachstellen im Konzept lassen sich während der Konzeptphase deutlich einfacher beheben als während der Testphase an einem Produkt, das nach einer aus Sicht der Security feh-

lerhaften Spezifikation umgesetzt wurde. Bereits im Feld ausgerollte Produkte oder im Betrieb befindliche IT- oder OT-Systeme lassen sich oft nur mit hohem Aufwand patchen. Noch teurer wird es, wenn es zu einem Security-Zwischenfall (Incident) kommt und die Schwachstelle aktiv ausgenutzt wird.

- Fehler im Konzept, die während der Entwicklung entdeckt und behoben werden, haben keine negativen Auswirkungen auf das Image der Firma, da die Kunden nicht mit der Schwachstelle in Berührung kommen.
- Klar definierte Anforderungen helfen im Falle eines Security-Zwischenfalls oft dabei, die Zeit zwischen Bekanntwerden des Problems und seiner Behebung zu reduzieren.
- Security Engineering (also ein methodisches Vorgehen zur Entwicklung sicherer Systeme aus Sicht der Security) wird zunehmend seitens der Regulierungsbehörden gefordert. Beispielsweise fordert UN Regulation No. 155 (UNECE 2021) Security in der Fahrzeugentwicklung, um eine Typzulassung zu erhalten. Der Cyber Resilience Act (CRA) der EU (European Union 2024) fordert Security (inklusive Bedrohungs- und Risikoanalyse) für Produkte mit digitalen Elementen. Selbst wenn aktuell keine solchen Anforderungen für die eigenen Produkte oder die eigene Infrastruktur vorliegen, ist es wertvoll, darauf vorbereitet zu sein, falls sich der beschriebene Trend fortsetzt.
- Insbesondere die Risikovermeidung lässt sich oft nur dann gut umsetzen, wenn die Entscheidung bereits während der Konzeptphase fällt. Wenn beispielsweise die einzig wirtschaftliche Lösung für ein Security-Problem der Verzicht auf ein Feature ist, sollte diese Entscheidung so früh wie möglich fallen, um nicht unnötig in die Entwicklung des Features zu investieren.

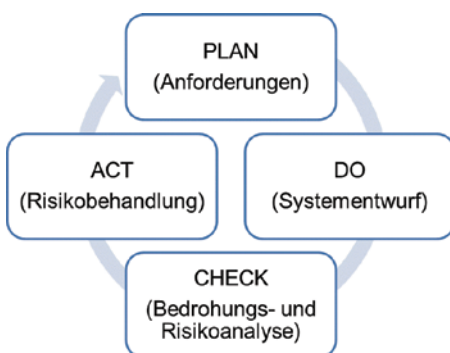


Bild 7.1

Anforderungen lassen sich gut in kleinen Zyklen ableiten, bis das Schutzkonzept zu einer akzeptablen Risikobehandlung führt.

Bedrohungs- und Risikoanalysen sind ein wesentlicher Baustein für die Anforderungsermittlung aus Sicht der Security, da die Security-Anforderungen im Rahmen der Risikobehandlung abgeleitet werden. Die Security-Anforderungen werden im Anschluss zu einem Schutzkonzept mit konkreten Maßnahmen verfeinert. Es bietet sich

an, das Schutzkonzept selbst durch ein Update der Bedrohungs- und Risikoanalyse zu prüfen. Bild 7.1 zeigt das zugrunde liegende Vorgehen, das sich an Demings PDCA-Zyklus orientiert (Moen 2006). Dieser Zyklus kann auch ohne Security-Anforderungen beginnen. In diesem Fall geht aus den funktionalen Anforderungen (Plan: Was muss das System können?) in der Produktentwicklung oder Systemplanung ein erster Systementwurf (Do: Wie können wir das umsetzen?) hervor, der in der Bedrohungs- und Risikoanalyse untersucht wird (Check: Ist das System sicher?). Die Risikobehandlung muss feststellen, ob Risiken nicht akzeptabel sind und somit Handlungsbedarf besteht (Act: Wie handhaben wir die Risiken?). Im nächsten Zyklus werden Security-Anforderungen festgelegt (Plan) und daraus ein Security-Konzept entwickelt oder ein bestehendes Konzept verfeinert (Do). Dieses Security-Konzept wird anschließend in einer weiteren Iteration der Bedrohungs- und Risikoanalyse (Check) daraufhin bewertet, ob jetzt alle Risiken akzeptiert werden können (Act). Ist dies nicht der Fall, so beginnt der nächste Zyklus, bis alle verbleibenden Risiken akzeptiert werden können. In dieser Phase ist es besonders wichtig, bei der Verfeinerung der Anforderungen auf die Abstimmung mit anderen Unternehmensbereichen zu achten. Wenn beispielsweise aus der Anforderung „die Authentizität der Bremsanforderung ist sicherzustellen“ eine konkret umsetzbare Maßnahme werden soll, so sind die Kosten möglicher Maßnahmen sowie deren Wechselwirkungen mit anderen Anforderungen zu berücksichtigen. Hierfür sind zwei Aspekte von großer Bedeutung:

1. Welche Anforderungen und Schutzbedarfe entstammen anderen Domänen? Hierunter fallen insbesondere:
 - Safety-Anforderungen und Abschätzungen der Schadensschwere bei auftretenden Fehlern.
 - Datenschutzanforderungen und Folgenabschätzung.
 - Wert von Daten und Systemen aus Sicht der Geschäftsmodelle des Unternehmens, bezogen auf Verfügbarkeit und Know-how-Schutz.
2. Abstimmung der Security-Anforderungen und des resultierenden Schutzkonzepts mit Anforderungen anderer Domänen. Hierunter fallen insbesondere:
 - Auswirkungen des Security-Konzepts auf Entwicklungs-, Herstellungs- und Betriebskosten.
 - Vereinbarkeit des Security-Konzepts mit Anforderungen an Performance und Echtzeitfähigkeit.
 - Auswirkungen des Security-Konzepts auf Benutzbarkeit von Produkten durch Kunden sowie von eigenen Systemen durch die Mitarbeiter des Unternehmens.
 - Auswirkungen des Security-Konzepts auf Wartungsprozesse für Produkte und eigene Systeme.

Der erste Aspekt *Anforderungen und Schutzbedarfe anderer Domänen* dient vor allem dazu, das Wissen aus anderen Domänen zu nutzen, um den Schutzbedarf des Unter-

suchungsgegenstands korrekt und konsistent herzuleiten. Voneinander abweichende Beurteilungen können zu Problemen führen und sind zu vermeiden: Wenn die Schäden in der Analyse höher geschätzt werden, als diese aus Sicht der Domänenexperten im jeweiligen Bereich ausfallen, so werden möglicherweise unnötige Kosten verursacht, indem nicht benötigte Maßnahmen eingeführt werden. Wenn die Schäden zu gering eingeschätzt werden, so können Risiken unterschätzt und somit ein unzureichendes Security-Konzept erstellt werden. Dabei gilt es auch zu beachten, dass in den jeweiligen Domänen typischerweise ein tieferes Verständnis für die jeweilige Problemstellung herrscht, als das bei den Security-Experten der Fall ist, die die Bedrohungs- und Risikoanalyse durchführen, sodass eine Abstimmung mit den jeweiligen Experten oder ein Rückgriff auf deren Dokumente immer von Vorteil ist. Dabei gilt es aber zu beachten, dass domänenspezifische Annahmen aus Sicht der Security manchmal zu hinterfragen sind. So kann beispielsweise ein durch zufällige Fehler entstehender Systemzustand sehr unwahrscheinlich sein, während es für einen Angreifer einfach sein kann, genau diesen Zustand herbeizuführen.

Bild 7.2 zeigt die Zusammenhänge zwischen den Disziplinen. Auf der linken Seite des Bildes sind typische Domänen im Unternehmen aufgezeigt, deren Anforderungen und Einschätzungen bei der Ermittlung der Werte und der Einstufung des Schutzbedarfs eine Rolle spielen. In der Mitte sind neben diesen Werten weitere wesentliche Bestandteile einer Bedrohungs- und Risikoanalyse und deren Zusammenhänge abgebildet. Auf der rechten Seite des Bildes werden mit den Security-Anforderungen und dem daraus resultierenden Schutzkonzept Elemente der Risikobehandlung gezeigt. Das Schutzkonzept kann das System verändern, sodass ein weiterer Zyklus der Bedrohungs- und Risikoanalyse erfolgen kann, bis ein aus Sicht der Security zufriedenstellendes Schutzkonzept entsteht.

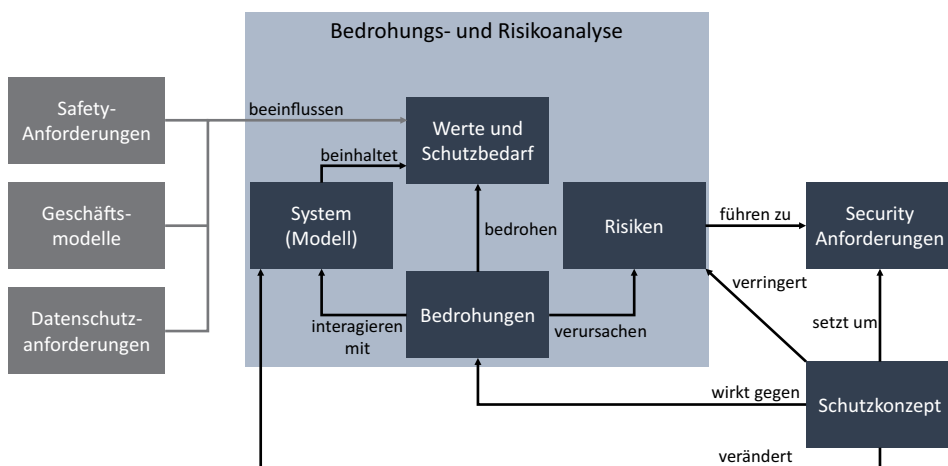


Bild 7.2 Bedrohungs- und Risikoanalysen benötigen bei der Bewertung des Schutzbedarfs Informationen aus anderen Domänen

Zusätzlich ist dabei zu beachten, dass die Veränderung des Systems durch das Schutzkonzept auch auf andere Domänen Auswirkungen haben kann. Der zweite Aspekt *Abstimmung mit Anforderungen anderer Domänen* zielt darauf ab, diese Auswirkungen zu berücksichtigen und aus den Ergebnissen der Bedrohungs- und Risikoanalyse wirtschaftlich und technisch umsetzbare Maßnahmen abzuleiten. Somit ist dies nicht mehr Bestandteil der eigentlichen Bedrohungs- und Risikoanalyse, aber für den Erfolg der Aktivitäten von großer Bedeutung.



Beispiel: Wechselwirkungen zwischen verschiedenen Entwicklungstätigkeiten im Unternehmen

Ein Bremssignal im Fahrzeug muss hinsichtlich seiner Authentizität abgesichert werden, um eine Manipulation des Signals zu verhindern. Die Kritikalität einer falschen oder einer ausbleibenden Bremsanforderung entstammt einer Safety-Analyse des Unternehmens. Für die Auswahl geeigneter Maßnahmen ist zu beachten, dass es harte Echtzeitanforderungen für das Bremssignal gibt, sodass Lösungen wegfallen, die mit der geplanten Hardware zu lange für die Berechnung brauchen, oder alternativ eine Anpassung der Hardware nötig wird, um den Echtzeitanforderungen weiterhin gerecht zu werden.

Maßnahmen können Entwicklungs-, Herstellungs- und Betriebskosten verursachen. Hierbei gilt, dass bei der Entwicklung von Maßnahmen zwar immer auf etablierte kryptografische Verfahren und Bibliotheken zurückgegriffen werden soll, um Fehler zu vermeiden. Deren Anwendung ist aber trotzdem immer an den eigenen Anwendungsfall anzupassen und in diesen zu integrieren, sodass zusätzliche Aufwände in der Entwicklung entstehen.



Beispiel: Entwicklungskosten bei Maßnahmen

Ein Bremssignal soll mit einer kryptografischen Signatur versehen werden. Hierfür wird auf Elliptische-Kurven-Kryptografie zurückgegriffen und eine geeignete Software-Bibliothek ermittelt, um das Verfahren legal ohne zusätzliche Lizenzkosten nutzen zu können. Die Parameter des Verfahrens, beispielsweise die Kurvenparameter, werden ausgewählt. Konzepte für die Erzeugung, Einbringung und Speicherung von Schlüsselmateriale müssen noch entwickelt werden.

Weiterhin sind auch unmittelbar auftretende Mehrkosten in der Herstellung von Produkten oder beim Einrichten einer Anlage zu beachten. Diese können in Form von Mehrkosten bei der Hardware auftreten, wenn beispielsweise spezielle Hardware für die Unterstützung kryptografischer Operationen benötigt wird. Ebenso ist zu beachten, dass sich die Zeit am Band verlängern kann, die ein Produkt benötigt, wenn beispielsweise zusätzliche kryptografische Schlüssel eingebracht werden

müssen. Gegebenenfalls führt das dazu, dass aufgrund der verlängerten Zeit am Band die Produktionskapazitäten für eine Komponente erhöht werden müssen, um insgesamt den angestrebten Durchsatz erreichen zu können. Ebenso können durch Maßnahmen Betriebskosten entstehen, beispielsweise wenn eine Public Key Infrastructure (PKI) betrieben werden muss, um eine zertifikatsbasierte Authentisierung zu ermöglichen. Neben den unmittelbaren Kosten einer Maßnahme sind auch die indirekten Kosten von großer Bedeutung. Kryptografische Maßnahmen benötigen Rechenzeit, sowohl auf Seite des Senders, der eine Nachricht verschlüsseln oder signieren muss, als auch auf Seite des Empfängers, der entsprechend entschlüsseln oder die Signatur prüfen muss. Besonders falls Echtzeitanforderungen bestehen, muss geprüft werden, ob die Hardware der beteiligten Komponenten ausreicht, um sowohl die kryptografische Maßnahme umzusetzen als auch die Echtzeitanforderungen zu erfüllen. Ebenso ist zu berücksichtigen, dass bei der Aushandlung kryptografischer Sitzungsschlüssel Zeit vergeht, also möglicherweise Kommunikationsbeziehungen nach einem (Neu-)Start nicht sofort verfügbar sind, obwohl sie im laufenden Betrieb dann ausreichend schnell funktionieren. Da Security im Kern dazu dient, unerwünschte Interaktion mit dem zu schützenden System zu unterbinden, wird häufig auch die erwünschte Interaktion weniger komfortabel. Beispielsweise kann durch eine gut umgesetzte Zwei-Faktor-Authentisierung wirkungsvoll verhindert werden, dass sich ein Angreifer die Rechte einer anderen Person erschleicht. Gleichzeitig bedeutet dies aber auch, dass für den Zugriff durch berechtigte Personen immer beide Faktoren (beispielsweise ein Passwort und eine Smartcard) benötigt werden, also der Bedienkomfort sinkt. Menschen neigen dazu, Maßnahmen zu untergraben, wenn diese die Benutzbarkeit zu stark einschränken. Ein klassisches Beispiel sind hier Merkzettel mit Passwörtern, die offen einsehbar am Arbeitsplatz liegen. Gerade wenn es um das eigene Produkt geht, ist die Benutzbarkeit aus Sicht des Kunden zudem wichtig für die Kaufentscheidung. Schließlich ist zu beachten, dass Security-Maßnahmen auch auf Wartungsprozesse Einfluss nehmen können. Bei der Ermittlung von Fehlern ist es oft ein Hindernis, wenn Daten verschlüsselt übertragen werden. Wenn Komponenten zur Absicherung der Kommunikation gemeinsames Schlüsselmaterial benötigen, so müssen diese bei einem Tausch einer Komponente aufeinander angelernet werden – wobei dieser Prozess selbst abgesichert werden muss, da ansonsten die ursprüngliche Maßnahme leicht umgangen werden kann. Zusammenfassend lässt sich also sagen, dass Bedrohungs- und Risikoanalysen nicht losgelöst von anderen Entwicklungsaktivitäten im Unternehmen durchgeführt werden können, da viele wechselseitige Abhängigkeiten bestehen. Ebenso ist der Weg von einer High-Level-Anforderung zu einer konkreten Maßnahme im Anschluss an die Analyse nicht trivial und von vielen Kosten-Nutzen-Abwägungen begleitet.

7.4.2 Tests planen und priorisieren, Testergebnisse bewerten

Bedrohungs- und Risikoanalysen können genutzt werden, um Security-Tests zu planen und zu priorisieren sowie um die dabei entstehenden Testergebnisse zu bewerten.

Dies beinhaltet einerseits funktionale Tests der Security-Maßnahmen, die aus den Bedrohungs- und Risikoanalysen hervorgehen. Maßnahmen, die besonders zur Risikoreduktion beitragen, sollten entsprechend mit höherer Priorität und Intensität getestet werden.

Andererseits liefern Bedrohungs- und Risikoanalysen wertvolle Anhaltspunkte für die Rahmenbedingungen anderer Security-Tests, wie beispielsweise das Penetrationstesten. In diesem Kontext ist es keine gute Idee, für den Test alle während der Bedrohungs- und Risikoanalyse gemachten Annahmen und Bewertungen als gegeben anzunehmen. Sie auf den Prüfstand zu stellen kann stattdessen helfen, die Validität der Analyse und des daraus resultierenden Schutzkonzepts zu beurteilen. Andererseits kann der in der Bedrohungs- und Risikoanalyse festgestellte Schutzbedarf dazu dienen, die wichtigsten Assets im System zu erkennen und exploratives Testen entsprechend zu fokussieren, indem die wichtigsten Schutzgüter als Angriffsziele vorgegeben werden. Da explorative Tests in der Praxis niemals abschließend „fertig“ sind, ist eine Priorisierung der Aktivitäten besonders wichtig, um in der verfügbaren Zeit die relevantesten Aspekte abdecken zu können, ohne die Tests zu stark einzuschränken und dem Prüfer „Scheuklappen“ anzulegen.

In allen Fällen gilt, dass Testergebnisse mithilfe der Bedrohungs- und Risikoanalyse besser beurteilt und eingestuft werden können, da die Auswirkungen verletzter Schutzziele oder nicht wirkungsvoller Maßnahmen unmittelbar aus der Analyse hervorgehen und somit entschieden werden kann, wie dringend das erkannte Problem behoben werden muss. Dies gilt nicht nur für Tests, die während der Entwicklung eines Produkts oder der Aufbauphase einer Anlage stattfinden, sondern auch für Erkenntnisse, die bei einem Produkt im Feld oder einer Anlage im Betrieb gewonnen werden.

7.4.3 Schwachstellen bewerten und behandeln

Werden Schwachstellen in den eigenen Systemen oder Produkten bekannt, so ist oft schnelles Handeln erforderlich, um Schäden vom Unternehmen oder von den eigenen Kunden abzuwenden. Häufig ist es aber nicht einfach, aus der Beschreibung einer Schwachstelle oder aus einem einzelnen Zwischenfall (Incident) abzuleiten, ob und wie man selbst betroffen ist. Hierfür können Bedrohungs- und Risikoanalysen nützliche Informationen liefern. Die systematische Betrachtung der eigenen Systeme

sowie ihrer Werte und der Maßnahmen aus den Analysen ist hierbei als wertvolle Zusatzinformation zu verstehen, die mit vorhandenen oder einzuholenden Informationen kombiniert werden kann, um schneller handlungsfähig zu werden. Wenn also im Unternehmen das Thema „Incident Management & Response“ etabliert ist oder wird, dann sollten Bedrohungs- und Risikoanalysen als weitere Informationsquelle genutzt werden.

Im Gegensatz dazu spielen Softwareschwachstellen in der Erstellung der Bedrohungs- und Risikoanalyse eine untergeordnete Rolle, da zunächst Security-Anforderungen ermittelt werden sollen. Gerade in frühen Entwicklungsphasen ist dabei häufig noch nicht bekannt, wie die spätere Umsetzung in Software aussehen wird, sodass eine Zuordnung konkreter Schwachstellen dann nicht möglich ist.

Die Anforderung „die Software darf keine ausnutzbaren Softwareschwachstellen beinhalten“ ist zudem immer sinnvoll, sodass keine echte Entscheidung für das Schutzkonzept nötig ist. Andererseits ist nicht entscheidbar, ob eine Software diese Anforderung erfüllt – es gibt nur die Gewissheit, dass eine Software mit bekannten Schwachstellen die Anforderung nicht erfüllt. Man kann aber beispielsweise Secure Coding Guidelines (z. B. (SEI CERT 2021)) anwenden oder von Zulieferern fordern und Software durch Code Reviews, automatisierte dynamische Tests und explorative Penetrationstests auf Schwachstellen testen. Die Bedrohungs- und Risikoanalyse kann hier nur, wie in Abschnitt 7.4.2 beschrieben, Anhaltspunkte geben, wie rigide getestet werden soll, um besonders kritische oder besonders exponierte Systeme in den Fokus der Aktivitäten zu rücken.

Anders ausgedrückt, stellen Software-Schwachstellen in der Regel **nicht spezifizierte Eigenschaften** von Systemen dar, während die Bedrohungs- und Risikoanalyse insbesondere während der Entwicklung darauf abzielt, eine aus Sicht der Security sichere Spezifikation zu erstellen. Da sich die Schwachstellen außerhalb der Spezifikation bewegen, kann die Bedrohungs- und Risikoanalyse nur Schwerpunkte für sicheres Coding und Testaktivitäten setzen sowie bekannte Schwachstellen bezüglich der Relevanz für das eigene System bewerten, aber nicht verhindern, dass Schwachstellen in der Umsetzung entstehen.

7.4.4 Laufende Systeme bewerten

Wie zuvor beschrieben, entfalten Bedrohungs- und Risikoanalyse besonders während der Entwicklung eines Systems ihren Mehrwert, indem aus den Analysen Security-Konzepte abgeleitet werden und somit „Security by Design“ erreicht werden kann. Dies bedeutet aber nicht, dass Bedrohungs- und Risikoanalysen für bestehende Systeme außer Acht gelassen werden sollten. Auch für solche Systeme gilt, dass **konzeptuelle** Schwachstellen durch Bedrohungs- und Risikoanalysen offengelegt wer-

den können. Diese können zwar prinzipiell auch durch Testen offengelegt werden, aber zu erkennen, dass es sich um einen grundlegenden Fehler im Konzept handelt, ermöglicht es, früher gezielt zu reagieren, statt schlimmstenfalls mehrere Symptome desselben Problems zu behandeln. Zudem gibt es die in Abschnitt 7.4.2 beschriebene Synergie zwischen Bedrohungs- und Risikoanalysen sowie dem Testen, das mithilfe der Analysen priorisiert und ausgewertet werden kann. Andererseits ist zu beachten, dass Bedrohungs- und Risikoanalysen nicht in der Lage sind, Schwachstellen in der Umsetzung zu erkennen, sodass das Testen nicht durch die Analysen ersetzt, sondern nur ergänzt werden kann.

7.5 Auswahlkriterien für geeignete Methoden

Ein methodisches Vorgehen ist bei der Durchführung von Bedrohungs- und Risikoanalysen ausschlaggebend, um die Qualität der Analysen sicherzustellen. Die Eigenschaften Flexibilität, Skalierbarkeit, Nachvollziehbarkeit, Wiederholbarkeit und Vergleichbarkeit sind wichtige Kriterien bei der Auswahl oder Entwicklung der Methode, mit der in Unternehmen gearbeitet werden soll (Eichler 2015). Ebenso ist bei der Wahl der Methode zu berücksichtigen, wie gut sich Änderungen am Untersuchungsgegenstand oder an anderen relevanten Informationen in eine Analyse einpflegen lassen. Gerade bei der Verwendung der Analyse zur Herleitung eines Schutzkonzepts ist zu erwarten, dass sich Änderungen während der Durchführung der Analyse ergeben.



Beispiel: Änderungen an Maßnahmenbewertungen

Eine Schwachstelle in TLS 1.3 wird bekannt. Es soll schnell nachvollzogen werden, welche Auswirkungen dies für die Cybersicherheit der eigenen Systeme hat. Hierfür ist es förderlich, wenn die Methode zur Durchführung von Maßnahmen der Bedrohungs- und Risikoanalysen im Schutzkonzept klar und explizit nennt sowie deren Auswirkungen anpassbar berücksichtigt.

Weiterhin muss eine Bedrohungs- und Risikoanalyse den Anforderungen aus der relevanten Domäne entsprechen. Hier ist beispielsweise für Produktionsanlagen die IEC 62 443 Familie (z. B. IEC 2009) zu nennen, während im Automobilumfeld der Standard ISO/SAE 21 434 (ISO/SAE 2021) anwendbar ist. Hierbei ist zu beachten, dass unterschiedliche Standards für unterschiedliche Bereiche eines Unternehmens relevant sein können. Beispielsweise muss ein Automobilhersteller sowohl die eigenen Produktionsanlagen als auch die Produkte (Fahrzeuge) absichern, sodass die beiden zuvor genannten Beispiele für Standards Anwendung finden.



Kernkriterien bei der Auswahl einer Methode für Bedrohungs- und Risikoanalysen:

- Nachvollziehbarkeit von Analysen
- Wiederholbarkeit von Analysen
- Vergleichbarkeit von Analysen
- Anpassbarkeit von Analysen an Veränderung
- Anwendbarkeit in der Zieldomäne

7.6 Die wichtigsten Punkte in Kürze

- Bedrohungs- und Risikoanalysen sind ein wichtiges Mittel, um angemessene und wirkungsvolle Schutzkonzepte zu entwickeln.
- Es gibt viele Schnittstellen in andere Unternehmensbereiche, die etabliert werden müssen, um Bedrohungs- und Risikoanalysen produktiv nutzen zu können.
- Die genutzten Methoden müssen gezielt ausgewählt werden und zum Unternehmen passen.

Literatur

Angermeier, Daniel, Kristian Beilke, Gerhard Hansch, Jörn Eichler: *Modeling security risk assessments*. Ruhr-Universität Bochum, 2019.

Bundesamt für Sicherheit in der Informationstechnik (BSI): *BSI-Standard 100-2 – IT-Grundschutz-Vorgehensweise*. BSI, Bonn, 2008.

Common Criteria Editorial Board: *Common Methodology for Information Technology Security Evaluation: Evaluation Methodology (3.1r5 ed.)*. Standard. Common Criteria.

Eichler, Jörn; Angermeier, Daniel. *Modular risk assessment for the development of secure automotive systems*. In Proceedings of the 31st VDI/VW joint conference Automotive Security, Wolfsburg, Germany, pp. 21 – 22, 2015.

European Union. *Proposal for a REGULATION OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL on horizontal cybersecurity requirements for products with digital elements and amending Regulation (EU) 2019/1020*. URL: <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=celex:52022PC0454>. Abgerufen am 06.02.2024. UNECE GRVA WP29: *UN Regulation No. 155 – Cyber security and cyber security management system*. Technical Report. UNITED NATIONS, 2021.

Gehm, Florian; Arzt, Sebastian: *Angriffsziel deutsche Wirtschaft: mehr als 220 Milliarden Euro Schaden pro Jahr*. URL: <https://www.bitkom.org/Presse/Presseinformation/Angriffsziel-deutsche-Wirtschaft-mehr-als-220-Milliarden-Euro-Schaden-pro-Jahr>. Abgerufen am 06.12.2021.

Geib, Jeremy; Baldwin, M.; Kess, Barbara: *Microsoft Threat Modeling Tool threats*. URL: <https://docs.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats>. Abgerufen am 13.12.2021.

ISO: *ISO 26 262 Road vehicles – Functional safety*. ISO, Geneva, Switzerland, 2018.

ISO/IEC: *Information technology — Security techniques — Information security risk management*. ISO, Geneva, Switzerland, 2018.

IEC: *Industrial communication networks – Network and system security – Part 1-1: Terminology, concepts and models*. IEC, Geneva, Switzerland, 2009.

ISO/SAE: *ISO/SAE 21434 Road vehicles — Cybersecurity engineering*. ISO/SAE International, Geneva, Switzerland/Warrendale, USA, 2021.

Moen, Ronald; Clifford Norman: *Evolution of the PDCA cycle*. 2006.

SEI CERT (Carnegie Mellon University): *SEI CERT Coding Standards*. URL: <https://wiki.sei.cmu.edu/confluence/display/seccode>. Abgerufen am 14.12.2021.

VDMA: *VDMA Studie Produktpiraterie 2020*. VDMA, Frankfurt am Main, 2020.

8

Sicherheitstesten

Jürgen Großmann



Sicherheitstesten ist eine umfassende Analyse­methode, mit der sich die Sicherheitseigenschaften einer IT-Infrastruktur oder einer Softwareanwendung prüfen lassen. Das Sicherheitstesten zielt darauf ab, sicherheitsrelevante Fehler und Schwachstellen in Systemen, Netzwerken, Anwendungen und anderen IT-Ressourcen sowie den relevanten Aktivitäten und Prozessen einer Organisation zu identifizieren. Das übergeordnete Ziel des Sicherheitstestens besteht darin, sicherzustellen, dass die Daten und IT-Ressourcen einer Organisation vor unbefugtem Zugriff, Datenverletzungen und anderen Bedrohungen aus der digitalen Sphäre geschützt sind. Dieser Artikel führt in die Grundlagen des Sicherheitstestens ein, zeigt Grenzen des Verfahrens und gibt einen Einblick in etablierte Methoden, Techniken und Prozesse des Sicherheitstestens. Es werden die folgenden Fragen beantwortet:

- Was sind die Grundbegriffe des Sicherheitstestens?
- Was sind Grundlagen des Sicherheitstestens?
- Welche Techniken und Methoden des Sicherheitstestens gibt es?
- Wie lässt sich der Sicherheitstest in die Prozesslandschaften einer Organisation einbetten?
- Welche Chancen und Risiken entstehen durch den Einsatz von KI, sowohl beim Testen selbst wie auch dann, wenn KI-basierte Systeme auf ihre Sicherheitseigenschaften hin getestet werden müssen?

8.1 Sicherheitstesten – ein Grundverständnis

IT-Sicherheit ist in der Regel durch die Schutzziele Vertraulichkeit, Integrität und Verfügbarkeit definiert.

- **Vertraulichkeit** stellt sicher, dass sensible Informationen vor unbefugtem Zugriff und Offenlegung geschützt werden und nur denjenigen zugänglich sind, die dazu berechtigt sind.
- **Integrität** gewährleistet, dass die Daten nur auf eine bestimmte und autorisierte Art und Weise geändert werden können.
- **Verfügbarkeit** sorgt hingegen dafür, dass Informationen und Ressourcen bei Bedarf für autorisierte Benutzer zugänglich sind und böswilligen Interaktionen wie bei gezielten Denial-of-Service-(DoS-)Angriffe widerstehen können.

In der sicheren System- und Softwareentwicklung wird in der Regel eine Reihe konstruktiver Mechanismen zur Umsetzung der genannten Schutzziele realisiert und integriert. Hierzu zählen u. a.:

- Verschlüsselung, Zugriffskontrolle und sichere Authentifizierungsmethoden zur Gewährleistung von Vertraulichkeit,
- Datenvalidierung, Prüfsummen und digitale Signaturen, um die Integrität der Software sowie der verarbeiteten Daten zu schützen, sowie
- Redundanz und Load-Balancing zur Steigerung und Sicherstellung von Verfügbarkeit.

Sicherheitstesten ist eine Analysemethode, die es erlaubt, Fehler und Schwachstellen in der Umsetzung der genannten Schutzziele zu identifizieren. Hierzu zählen zum einen die Prüfung der Funktionalität, Effizienz und Verfügbarkeit der entwickelten und integrierten Sicherheitsfunktionen und/oder -mechanismen und zum anderen die Identifikation neuer und bisher unbekannter Systemschwachstellen durch gezielte Schwachstellen- und Penetrationstests.

8.1.1 Testen als Analysemethode

Testen gilt als eine der mächtigsten und effektivsten Qualitätssicherungsmethoden in der Softwaretechnik und ist als analytische Aktivität in industriellen Softwareentwicklungsprozessen engmaschig mit den konstruktiven Softwareentwicklungsaktivitäten integriert. Testen ganz allgemein wird als

„Prozess innerhalb des Softwareentwicklungslebenszyklus, der die Qualität einer Komponente oder eines Systems und der zugehörigen Arbeitsergebnisse bewertet.“

(ISTQB, 2024)

definiert. Testen dient in allererster Linie der Fehlersuche und umfasst eine Reihe von Aktivitäten, die von der manuellen Inspektion der Entwicklungsartefakte bis hin zur automatisierten Ausführung und Stimulation der Software reichen. Dijkstra (Dijkstra 1970) wies bereits vor fünfzig Jahren darauf hin, dass Testen ein stochastisches Verfahren ist, mit dem zwar Fehler gefunden werden können, nicht aber ihre Abwesenheit bewiesen werden kann.

„Programmtests können dazu dienen, das Vorhandensein von Fehlern nachzuweisen, aber niemals dafür, deren Abwesenheit zu beweisen!“

(Dijkstra 1970)

Das gilt noch heute, tut aber der Wichtigkeit und Effektivität des Softwaretestens keinen Abbruch. Durch systematisches Testen, d. h. die Abdeckung der relevanten Risiken, Anforderungen, Wertebereiche und Strukturen in einem Programm, lassen sich sehr weitgehende Qualitätsaussagen treffen. Testen kann in diesem Sinne als essenzieller Bestandteil der Softwarequalitätssicherung dabei helfen, die Qualität eines Softwaresystems zu messen sowie das Vertrauen aller Beteiligten in die Qualität der Software zu steigern. Allerdings verbessert das Testen an und für sich die Qualität nur indirekt. Gefundene Fehler müssen für dem Testen nachgelagerte Prozesse zur Verfügung gestellt werden, die dann dafür zuständig sind, Fehler zu beheben, und dadurch die Qualität der Software oder der Systeme verbessern können. Testen muss also sinnvoll in die Prozesslandschaft einer Organisation eingebunden werden.

Grundsätzlich werden in der Literatur verschiedene Testarten unterschieden:

1. Beim dynamischen Testen liegt das System in seiner operationalen Form vor und wird durch mehr oder weniger systematisch gewählte Eingaben stimuliert. Die während der Ausführung beobachteten Ergebnisse werden mit den erwarteten Ergebnissen verglichen.
2. Beim statischen Testen wird das System nicht ausgeführt, oder es werden Artefakte untersucht, die nicht ausgeführt werden können. Dazu gehören Spezifikationen, Architekturen und Daten. Statische Tests können automatisch mithilfe spezieller Analysewerkzeuge oder manuell durch Überprüfung durchgeführt werden.
3. Monitoring ist eine Testmethode, die eine kontinuierliche Beobachtung und Messung eines Softwaresystems während seiner Laufzeit vornimmt. Sie umfasst die Sammlung und Analyse von Echtzeitdaten über die Leistung, das Verhalten und verschiedene Betriebskennzahlen des Systems.

Beim Softwaretesten wird darüber hinaus unterschieden, welcher Zugriff und Einblick in das getestete System vorliegt bzw. möglich ist.

- **Black-Box-Tests** prüfen die extern beobachtbare Funktionalität eines Systems ohne Berücksichtigung seiner internen Struktur und Funktionsweise, indem das

System an seinen Außenschnittstellen stimuliert und die Ausgabe mit dem Ziel untersucht wird, Abweichungen vom erwarteten Verhalten zu erkennen.

- **White-Box-Tests** hingegen nutzen das Wissen über die Struktur der Software und der Daten. Die Testenden haben vollen Einblick in den Quellcode der Software und nutzen dieses Wissen, um die interne Programmlogik sowie die verwendeten Datenstrukturen bei der Fehlersuche mit einzubeziehen.
- **Grey-Box-Tests** sind ein hybrider Ansatz, der Elemente von Black-Box- und White-Box-Tests kombiniert. Die Testenden verfügen über ein Teilwissen über die interne Funktionsweise einer Software. Dieses Wissen wird dazu verwendet, Testfälle effektiver zu gestalten.

Wie bereits in diesem kurzen Abschnitt deutlich wird, ist Testen ein komplexes Unterfangen, das eng in den Lebens- und Qualitätssicherungszyklus eines Softwaresystems integriert werden muss. Hierzu müssen die unterschiedlichen Testaktivitäten verstanden und entsprechend ihren Zielen, Wirkungen und Aufwänden aufeinander abgestimmt werden. Dieses erfolgt in der Regel in einem systematischen Testprozess, dem eine dezidierte Testplanung zugrunde liegt. Dazu später mehr.

8.1.2 Spezifische Herausforderungen beim Sicherheitstesten

Obwohl es beim Sicherheitstesten viele Überschneidungen zu anderen, klassischen Testaktivitäten gibt, müssen sich die Planung, Durchführung und Auswertung von Sicherheitstests verschiedenen Herausforderungen stellen, die sich vom klassischen Testen unterscheiden. Diese Herausforderungen reichen von technischen Schwierigkeiten bis hin zu organisatorischen und verfahrenstechnischen Problemen. Das Verständnis dieser Herausforderungen ist entscheidend für die Entwicklung wirksamer Strategien zur Risikominderung. Im Folgenden sind einige der prägnantesten Herausforderungen aufgelistet.

- **Dynamische Bedrohungs- und Schwachstellenlandschaft:** IT-Sicherheitsbedrohungen entwickeln sich ständig weiter, und Angreifer entwickeln neue Techniken und Werkzeuge, um potenzielle Schwachstellen auszunutzen. Das organisatorische, technische und fachliche Umfeld für die Durchführung von Sicherheitstests muss mit dieser Dynamik mithalten können und über Lern- und Anpassungsprozesse die Dynamik positiv antizipieren.
- **Begrenztes Wissen:** Sicherheitstests können in der Regel nur Schwachstellen identifizieren und Bedrohungen aufdecken, die in irgendeiner Weise bekannt oder zumindest vorhergesagt werden können. Unbekannte Schwachstellen oder Risiken werden möglicherweise nicht berücksichtigt und getestet. Suchbasiertes Testen sowie verschiedene Fuzz-Testing-Ansätze erlauben allerdings auch das Finden unbekannter Schwachstellen, wenn sie richtig angewendet werden.

- **Komplexität von Systemen und Angriffsvektoren:** Moderne IT-Systeme sind unglaublich komplex und umfassen verschiedene Technologien, Plattformen und Geräte. Diese Komplexität kann es schwierig machen, alle potenziellen Angriffsvektoren zu erkennen und eine umfassende Testabdeckung zu gewährleisten.
- **Komplexe Fehlermodelle:** Im Unterschied zu funktionalen Tests, basieren Fehlerwirkungen beim Sicherheitstesten häufig auf Seiteneffekten (wie z. B. beim Buffer Overflow), undokumentierter, ungewollter Zusatzfunktionalität (wie z. B. bei einem öffentlich zugänglichen Admin-Zugang) oder auf einer Kombination unterschiedlicher Schwachstellen, die jede für sich genommen nicht als gravierend eingeschätzt wird, aber in einer geschickten Kombination gezielter Angriffe ein hohes Schadenspotenzial haben.
- **Begrenzter Zugriff:** Bei vielen Systemen, insbesondere bei solchen, die Cloud-Dienste oder Komponenten von Drittanbietern beinhalten, haben Unternehmen häufig weder Einblick noch Zugriff auf die zugrunde liegende Infrastruktur. Dieser Mangel an Transparenz und Testbarkeit kann die Durchführung von Sicherheitstests und das Finden relevanter Fehler maßgeblich beeinträchtigen.

Zusätzlich dazu ist die Integration des Sicherheitstests mit anderen Prozessen, wie dem Risikomanagement, dem IT-Betrieb und der Softwareentwicklung, hier insbesondere in agile und DevOps-Prozesse, eine Voraussetzung für eine ganzheitliche IT-Sicherheitsstrategie und häufig weder technisch noch organisatorisch einfach umzusetzen. Hinzu kommt die Auseinandersetzung mit Ressourcenengpässen und fehlendes Know-how. Effektive Sicherheitstests erfordern beträchtliche Ressourcen, darunter qualifiziertes Personal, hochentwickelte Werkzeuge und Zeit. Automatisierung kann zumindest teilweise Ressourcen sparen helfen, setzt jedoch in den meisten Fällen, zumindest bei ihrer Etablierung, qualifiziertes Personal voraus. Darüber hinaus lassen sich nicht alle Tests automatisieren. Für bestimmte Arten von Schwachstellen und komplexe Szenarien sind häufig zusätzliche manuelle Tests erforderlich, für die qualifiziertes Personal benötigt wird. Darüber hinaus neigen insbesondere automatisierte Sicherheitstestwerkzeuge, wie beispielsweise statische Analysewerkzeuge und Schwachstellen-Scanner, zu falsch positiven Ergebnissen, die erst im Rahmen manueller Prozesse final bewertet werden können. Das Wissen über die Aufwände und Herausforderungen des Sicherheitstestens sowie eine systematische Planung und Organisation des Sicherheitstestens sind die Voraussetzung dafür, dass das Testen effektiv und effizient durchgeführt werden kann.

8.1.3 Testobjekte beim Sicherheitstesten

Ähnlich wie beim klassischen Testen lassen sich im Rahmen des Sicherheitstestens sehr unterschiedliche Testobjekte oder Gegenstände testen. Die Spannweite reicht von großen IT-Infrastrukturen, wie beispielsweise der IT-Infrastruktur einer Organisation, vollständigen Rechenzentren und Netzwerken bzw. Cloud-Infrastrukturen

über Teilsysteme, wie Router oder Datenbanken, bis hin zu einzelnen Anwendungen oder Softwarekomponenten. Verdeutlichen lässt sich der Unterschied entlang der folgenden zwei Beispiele:

- IT-Infrastruktur und Netzwerksicherheitstesten befassen sich klassischerweise mit dem Test der IT-Sicherheit von Netzwerk- und IT-Infrastrukturen. Hierzu zählen sowohl lokale IT-Infrastrukturen wie das Firmennetzwerk als auch die Cloud mit ihren Software-Stacks. Der Test konzentriert sich auf die Geräte, Anwendungen, Verbindungen und Konfigurationen, aus denen das Netzwerk oder die IT-Infrastruktur besteht. Diese Art von Tests umfasst in der Regel Audits, Schwachstellen und Netzwerk-Scans, Penetrationstests und Monitoring. Ziel ist es, Fehler und Schwachstellen in Infrastrukturkomponenten, Netzwerkgeräten (Router, Switches), Firewalls und der Netzwerkarchitektur zu ermitteln, die einen unbefugten Zugriff oder eine Unterbrechung der Dienste innerhalb des Netzwerks bzw. der IT-Infrastruktur ermöglichen könnten. Grundsätzlich soll sichergestellt werden, dass die Sicherheitsmaßnahmen des Netzes gegen Angriffe und unbefugte Zugriffsversuche wirksam sind.
- Der entwicklungsbegleitende Software- bzw. Anwendungssicherheitstests befasst sich in erster Linie mit der systematischen Identifikation von Schwachstellen in Softwareprogrammen über den gesamten Lebenszyklus der Software hinweg. Bei dieser Art von Tests werden die Sicherheitsaspekte der Software selbst untersucht, einschließlich der Art und Weise, wie die Software ihre Daten verwaltet, Operationen ausführt und mit anderer Software interagiert. Das Anwendungssicherheitstesten ist eng mit dem Softwareentwicklungsprozess gekoppelt und umfasst verschiedene Arten von Tests wie Reviews, statische Analysen, dynamische Sicherheitstests sowie Monitoring, um die Software sowohl im nicht laufenden als auch im laufenden Zustand zu untersuchen. Das Hauptziel besteht darin, sicherzustellen, dass die Software frei von Sicherheitslücken ist, die von Angreifern ausgenutzt werden könnten, um die Integrität, Vertraulichkeit oder Verfügbarkeit des Softwaresystems zu gefährden.

Wie bereits deutlich wird, gibt es beim IT-Infrastruktur und Netzwerksicherheitstesten sowie bei Software- bzw. Anwendungssicherheitstests viele Überschneidungen. IT-Infrastrukturen bestehen aus einer Vielzahl softwaregesteuerter Geräte, Software-Stacks und hochgradig komplex konfigurierter Anwendungen. Insofern hat man es auch hier mit Software zu tun. Der entscheidende Unterschied besteht darin, dass den Testenden beim entwicklungsbegleitenden Software- bzw. Anwendungssicherheitstesten ein deutlich weitreichender Zugriff auf das zu testende System gewährleistet werden kann als beim Testen einer IT-Infrastruktur. Während es die Testenden beim IT-Infrastruktur- und Netzwerksicherheitstesten in der Regel mit fertigen Systemen zu tun haben, die durch Dienstleister und Fremdhersteller bereitgestellt werden, sind entwicklungsbegleitende Software- bzw. Anwendungssicherheitstests fester Bestandteil eines Softwareentwicklungsprozesses und der damit einhergehenden Möglichkeiten, auf die verschiedenen Entwicklungsartefakte wie Anforderungen, Systemdesign, Softwarecode und Konfigurationsdaten direkt zugreifen zu können.

8.1.4 Grundlagen und Ziele des Sicherheitstestens

Ausgehend von den zu Beginn des Kapitels definierten Schutzzielen Vertraulichkeit, Integrität und Verfügbarkeit spielen Risikobewertung und die Definition konkreter Sicherheitsziele für das Sicherheitstesten eine zentrale Rolle. Sie dienen als Ausgangspunkt für die Definition der Sicherheitstestziele und bilden damit als die Grundlage für die konkrete Planung, Durchführung und Bewertung der Sicherheitstests.

Die *Risikobewertung* ist ein systematischer Prozess zur Identifizierung, Bewertung und Priorisierung von Risiken, die sich aus der Verwendung oder Bereitstellung eines Informationssystems für eine Organisation, ihr Vermögen, für Einzelpersonen, für andere Organisationen und für die Gesellschaft ergeben. Eine Risikobewertung berücksichtigt u. a. die Geschäftsstrategie und bestehende Industrievorschriften, um die für eine Organisation akzeptablen Risiken zu ermitteln und nicht akzeptable Risiken mindern zu können. Ein typischer Risikobewertungsprozess nach ISO 31 000 besteht in der Regel aus den folgenden Schritten, die aufeinander aufbauen.

1. Definition des Kontexts: Vorbereitung des Bewertungsprozesses sowie Definition des Umfangs und Geltungsbereich der Analyse
2. Risikoermittlung: Identifizierung von Risikoquellen, Wirkungsbereichen, Risikoeignissen, deren Ursachen und möglichen Folgen
3. Risikoanalyse: Erfassen der Art des Risikos und Bestimmung des Risikoniveaus
4. Risikobewertung: Vergleich der Ergebnisse der Risikoabschätzung mit Risikokriterien, um festzustellen, ob das Risiko und/oder sein Ausmaß akzeptabel oder tolerierbar ist
5. Risikobehandlung: Veränderung des Risikos durch Vermeidung oder Abschwächung

Für das Sicherheitstesten bedarf es in der Regel einer technischen Betrachtung der Risiken, die, ausgehend von der konkreten Software oder Infrastruktur, die technischen Schutzgüter, Bedrohungen und Schwachstellen sowie die konkreten technischen Gegenmaßnahmen und Sicherheitsfunktionen beschreibt, damit diese dann getestet werden können. Für die konkrete Durchführung von Sicherheitsrisikobewertungen existiert eine Reihe von Methoden wie OCTAVE, NIST SP 800-30, ISO 27 005 und FAIR. Abgeleitet davon haben sich leichtgewichtige Verfahren wie beispielsweise die Methode der Rapid Risk Analysis (RRA) der Mozilla Foundation etabliert (Mozilla Foundation 2017), mit denen Risiken relativ einfach erfasst und kommuniziert werden können, ohne sich in den Details komplexer Prozesse zu verlieren.

Sicherheitsziele definieren die spezifischen Ziele und Anforderungen, die ein Informationssystem zum Schutz vor Bedrohungen und Schwachstellen erfüllen muss. Sie definieren, was geschützt werden muss und warum, und helfen dabei, die Sicherheitstests zu planen und auf die relevanten Bereiche mit der größten Bedeutung zu konzentrieren. Sie legen Kriterien fest, anhand derer das System getestet wird, indem die

relevanten Schutzgüter benannt werden, kritische Schwellenwerte und akzeptable Risikoniveaus definiert und notwendige Sicherheitsmaßnahmen benannt werden. Durch eine systematische Festlegung spezifischer, messbarer, erreichbarer, relevanter Sicherheitsziele können Organisationen die Wirksamkeit ihrer Sicherheitsmaßnahmen und damit auch die Ergebnisse ihrer Sicherheitstests quantitativ und qualitativ bewerten.

8.1.5 Definition von Sicherheitstestzielen

Der Umfang und die Ausrichtung des Sicherheitstestens wird durch die Definition sogenannter *Sicherheitstestziele* definiert. Diese Testziele helfen, den Beteiligten zu verstehen, welche Sicherheitsaspekte bewertet werden sollen. Sie legen die grundlegenden Erwartungen an den Sicherheitstest fest und dienen dazu, den Einsatz der benötigten Ressourcen und Technologien festlegen sowie den Testaufwand abschätzen zu können. Systematisch definierte Sicherheitstestziele umreißen den Testaufwand, dienen als Entscheidungshilfe und sorgen für Effizienz und die Konzentration auf das Notwendige.

In die Definition der Sicherheitstestziele gehen sowohl organisatorische als auch technische Rahmenbedingungen des Sicherheitstests mit ein. Hierzu zählen wie in Bild 8.1 dargestellt Unternehmens- und Geschäftsstrategien, Industrievorschriften, Risiken, Sicherheitsziele, -richtlinien und -standards, die Sicherheitsarchitektur sowie die konkret geplanten Sicherheitsmaßnahmen.



Bild 8.1 Der organisatorische Kontext von Sicherheitstestzielen

Je höher die Anforderungen an die Integrität sensibler digitaler und physischer Schutzgüter sind, desto größer muss der Umfang der Sicherheitstests sein und umso umfassender und sorgfältiger müssen die Sicherheitstestziele differenziert werden. Für jede Sicherheitsmaßnahme oder jedes Risiko sollte es ein oder mehrere Sicherheitstestziele geben. Neben dem organisatorischen Kontext müssen die Sicherheitstestziele auch die spezifischen Eigenschaften der Technologie (z. B. Web, Mobile, Cloud LAN usw.) und die bekannten Bedrohungen und Schwachstellen berücksichtigen.

8.2 Testmethoden und Testtechniken

Für die Durchführung von Sicherheitstests werden verschiedene Techniken und Methoden verwendet. Ausgehend von den in Abschnitt 8.1.1 dargestellten Testarten, lässt sich das Testen weiter aufgliedern in:

- Audits und Reviews,
- statische Analysen,
- dynamisches Testen und
- Monitoring.

Im Fachjargon wird speziell dann, wenn es um Werkzeuge und Technologien geht, zusätzlich zwischen *Static Application Security Testing (SAST)* und *Dynamic Application Security Testing (DAST)* unterschieden. SAST umfasst eine Reihe von Technologien zur Analyse von Anwendungs Quellcode, Bytecode und Binärdateien auf Codierungs- und Entwurfsbedingungen, die auf Sicherheitsschwachstellen hinweisen. SAST-Technologien analysieren eine Anwendung von innen heraus in einem nicht laufenden Zustand, sind aber selbst werkzeuggestützt und automatisierbar. DAST beschreibt das werkzeuggestützte aktive Testen eines laufenden Systems oder Softwaremoduls. Dies umfasst funktionales Sicherheitstesten, Fuzz-Testing, Last- und Performanztesten sowie verschiedene Methoden des Schwachstellen-Scannings und Penetrationstestens.

8.2.1 Audits und Reviews

Ein Sicherheitsaudit ist eine formelle, systematische und dokumentierte Prüfung der Informationstechnologie und der Sicherheitsmaßnahmen einer Organisation durch geschulte Gutachter. Der Zweck eines Sicherheitsaudits ist es, zu bewerten, ob die Sicherheitsmaßnahmen einer Organisation in der Lage sind, die definierten Schutzgüter auch wirklich zu schützen. Gegenstand der Prüfung sind in der Regel die formalen

Aspekte wie Vorgehen, Abläufe und Prozesse. Sicherheitsaudits werden in der Regel durch Vorschriften oder Standards wie ISO 27 001, IT-Grundschutz, TISAX oder SOC 2 vorgeschrieben und durch akkreditierte Dienstleister durchgeführt. Audits folgen einem strengen Vorgehen, welches die Phasen Planung, Durchführung, Berichterstattung und Nachbereitung umfasst. Die Prüfung erfolgt entlang festgelegter Kriterien, Richtlinien, Verfahren und Standards mit dem Ziel, die Wirksamkeit definierter Sicherheitsmaßnahmen zu bewerten.

Das Ergebnis eines Audits ist ein förmlicher Bericht, in dem die festgestellten Mängel, einschließlich etwaiger Verstöße gegen die Vorschriften oder Schwachstellen bei den IT-Sicherheitsmaßnahmen, detailliert aufgeführt sind. Sicherheitsaudits können Teil eines Zertifizierungsprozesses sein und verbindlichen Maßnahmen nach sich ziehen, die die Organisation ergreifen muss, um festgestellte Probleme zu beheben.

Ein Review ist eine weniger formale Bewertungsmethode, die eine Inhaltsprüfung eines oder mehrerer Artefakte mit Bezug zur IT-Sicherheit einer Organisation, Infrastruktur oder Software vornimmt. Der Zweck eines Reviews besteht darin, potenzielle Fehler und Schwachstellen zu identifizieren, die Wirksamkeit bestehender Sicherheitsmaßnahmen zu bewerten und Verbesserungen zu empfehlen. Reviews können intern oder mithilfe von externen Beratern durchgeführt werden.

Reviews als Methode des entwicklungsbegleitenden Sicherheitstestens bezeichnet die systematische Untersuchung und Bewertung von Software oder anderen Artefakten aus dem Entwicklungsprozess durch eine Gruppe von Personen mit einschlägigem Fachwissen. Das Ziel von Reviews ist es, Fehler zu identifizieren und die Einhaltung von Standards, Richtlinien und Anforderungen zu prüfen. Beispiele für Reviews als Teil des entwicklungsbegleitenden Sicherheitstestens sind Reviews von Artefakten wie den Sicherheitsanforderungen, den Unterlagen des Softwareentwurfs oder Inspektionen der Software selbst.

8.2.2 Statische Analyse

Unter statischer Analyse versteht man die Untersuchung von Software, ohne dass diese tatsächlich ausgeführt wird. Im Gegensatz zu Audits und Reviews ist die statische Analyse ein automatisierter Prozess, bei dem Software mithilfe von Werkzeugen analysiert wird. Die Grundlage für die Analyse bilden vordefinierte Testregeln und Algorithmen, die beliebig oft ausgeführt werden können und daher einen hohen Automatisierungsgrad bieten. Statische Analysewerkzeuge können verwendet werden, um den Quellcode auf allgemeine Programmierfehler, die Einhaltung von Codierungsstandards und potenzielle Sicherheitslücken zu untersuchen. Dazu gehört die Überprüfung auf Pufferüberläufe, Speicherlecks und andere Probleme, die bei der Softwareentwicklung häufig auftreten. In (Felderer 2016) wird zwischen syntaktischen und semantischen Prüfungen unterschieden.

- **Syntaktische Prüfungen** konzentrieren sich auf die Struktur des Codes und stellen sicher, dass er die Syntaxregeln der Programmiersprache einhält. Diese Prüfungen erfordern kein Verständnis des Programmablaufs oder des breiteren Kontexts, in dem der Code ausgeführt wird. Ein Beispiel hierfür wäre eine Mustererkennung, die String-Verkettungen oder andere unsichere Codestrukturen identifiziert, die potenzielle SQL-Injection-Schwachstellen darstellen können.
- Bei **semantischen Prüfungen** geht es darum, die Bedeutung und das Verhalten des Codes zu verstehen. Diese Prüfungen sind anspruchsvoller als syntaktische Prüfungen, da sie die Analyse des Daten- und Kontrollflusses innerhalb der Anwendung erfordern. Sie können komplexere Schwachstellen aufdecken, beispielsweise, ob es im Anwendungsablauf Pfade gibt, die einen nicht autorisierten Zugriff auf Ressourcen oder Funktionalitäten ermöglichen.

Die statische Analyse kann mit wenig Spezialwissen durchgeführt werden, da sie auf automatisierten Werkzeugen und vordefinierten Regeln beruht, und eignet sich daher gut für die Integration in automatisierte Pipelines. Bestimmte, weniger komplexe Formen der statischen Analysen können bereits sehr früh im Entwicklungsprozess eingesetzt werden, sodass die Software bereits in der Entwicklungsumgebung oder beim Commit geprüft und so eine möglichst frühe Rückmeldung zu Fehlern sowie Schwachstellen etabliert werden kann.

Das Ergebnis einer statischen Analyse ist eine Liste potenzieller Sicherheitsschwachstellen. Die Ergebnisse sind in der Regel leicht vergleichbar, können aber eine größere Anzahl von falsch-positiven Ergebnissen aufweisen und müssen häufig manuell dahingehend geprüft werden, ob eine gefundene Schwachstelle tatsächlich ausnutzbar ist.

Es existieren SAST-Werkzeuge für die meisten weit verbreiteten Programmiersprachen und weitergehende Methoden, die statische Analysen mit dynamischer Ausführung zum Beispiel mit dem Fuzz-Testing kombinieren. In regulierten Branchen ist der Einsatz statischer Analyse oft vorgeschrieben, um eine hohe und verlässliche Testabdeckung zu erreichen und zu prüfen, ob ein System die einschlägigen Normen und Vorschriften einhält.

8.2.3 Der funktionale Sicherheitstest

Der funktionale Test betrachtet das System aus der Perspektive der Systemfunktionalität und der funktionalen Anforderungen. Er umfasst mit Unit-, Integrations-, Produkt-, System-, Interoperabilitäts- und Konformitätstests alle Stufen der Systemintegration und ist ein dynamischer Test. Der funktionale Sicherheitstest verfolgt den gleichen Ansatz wie der klassische funktionale Test, berücksichtigt aber zusätzlich auch die Möglichkeit vorsätzlicher Angriffe, die versuchen, die Ressourcen des Systems zu nutzen, ohne dazu berechtigt zu sein.

Grundlage für den funktionalen Sicherheitstest ist die Spezifikation des Systems inklusive aller Sicherheitsanforderungen sowie der funktionalen Anforderungen an die Sicherheitsfunktionalität. Sicherheitsanforderungen werden jedoch oft als negative Anforderungen formuliert, sodass eine bestimmte Anforderung eine Vielzahl einzelner Tests erfordert, um die Funktionalität zu zufriedenstellend testen zu können. Werden überwiegend negative Anforderungen berücksichtigt, wird der Testansatz auch als negatives Testen bezeichnet. Der funktionale Sicherheitstest kann sowohl positive als auch negative Testanforderungen berücksichtigen. Geprüft wird also, **was das System tun sollte** und **was das System nicht tun sollte** (ETSI 2015). Zu Ersterem zählt beispielsweise der Test von Sicherheitsfunktionen wie die Authentifizierung oder Verschlüsselung. Zu Letzterem zählt die Prüfung von Sicherheitsanforderungen wie das Nicht-Speichern vertraulicher Daten in unverschlüsselten Speicherbereichen oder die Bereitstellung sicherheitsrelevanter Informationen in z. B. Fehlermeldungen.

Obwohl funktionale Sicherheitstests in alle Testphasen integriert werden können, liegt der Schwerpunkt in der Regel auf den dynamischen Unit- und Systemtests. Beim funktionalen Unittesten werden einzelne Softwaremodule auf ihre Funktionalität getestet. Ziel ist es unter anderem, Fehler bei der Eingabevalidierung sowie Injektionsschwachstellen aufzudecken. Darüber hinaus wird lokale Sicherheitsfunktionalität, wie sie durch Verschlüsselungsmodule oder Session Manager realisiert wird, geprüft. Beim funktionalen Systemtest wird die globale Sicherheitsfunktionalität geprüft. Ziel ist es, festzustellen, ob auch nach der Integration Sicherheitsfunktionalität für alle Komponenten gewährleistet ist und das System keine ungewollte Funktionalität anbietet.

Beim funktionalen Sicherheitstest können sich insbesondere die Art und Weise der Beobachtung und Bewertung der Testergebnisse stark vom traditionellen Funktionstests unterscheiden, da häufig eine umfangreiche Instrumentierung des Zielsystems oder eine Überwachung der Kommunikation erforderlich ist, um die Testergebnisse erfassen zu können.

8.2.4 Fuzz-Testing

Fuzz-Testing oder Fuzzing ist eine automatisierte Softwaretesttechnik, bei der ungültige, unerwartete oder zufällige Daten als Eingaben in ein Computerprogramm eingegeben werden (Miller et. al 1990). Das Hauptziel besteht darin, Codierungsfehler und Sicherheitslücken in der Software zu entdecken, die zu Abstürzen, Speicherlecks oder Pufferüberläufen führen können, die von Angreifern ausgenutzt werden könnten. Fuzzing ist besonders effektiv bei der Aufdeckung von Schwachstellen, die durch die Verarbeitung unerwarteter oder gefährlicher Eingaben entstehen, was es zu einem wichtigen Werkzeug bei Sicherheits- und Zuverlässigkeitstests macht. Grundsätzlich

lässt sich zwischen Black-Box-Fuzzing, White-Box-Fuzzing und Hybrid-Fuzzing unterscheiden (Manes 2019). Black-Box-Fuzzing generiert und appliziert die Tests ohne Kenntnis der internen Mechanismen einer Anwendung.

- Beim **Zufalls-Fuzzing** werden völlig zufällige Daten als Eingaben für die Software erzeugt. Der Fuzzer berücksichtigt weder das Format noch die erwarteten Eingabetypen der Software. Die Methode ist einfach anzuwenden, erzeugt aber viele Eingaben, die irrelevant sind oder im Rahmen einer einfachen Eingabedatenüberprüfung vom System abgewiesen und daher nicht wirksam werden können.
- Beim **mutationsbasierten Fuzzing** mutieren vorhandene valide und halbvalide Eingabedaten durch zufälliges oder systematisches Ändern, Löschen oder Hinzufügen von Datenbereichen. Diese Methode orientiert sich also in gewisser Weise an den ursprünglich gültigen Eingaben und kann effektiver sein als rein zufällige Eingaben.
- **Protokoll- oder formatbasiertes Fuzzing** erzeugt Eingaben unter Berücksichtigung bekannter Protokoll- oder Formatspezifikationen. Die Eingaben entsprechen also in der Regel dem erwarteten Format, enthalten aber unerwartete oder fehlerhafte Daten.

White-Box-Fuzzing nutzt das Wissen über den Quellcode, die Architektur und die Algorithmen der Software, um passende Testfälle zu generieren. Hierbei wird auf etablierte Analyseverfahren wie statische Analyse und symbolische Ausführung zurückgegriffen.

- Wird Fuzzing mit statischer Analyse kombiniert, werden die potenziellen Eingabepositionen und Schwachstellen einer Software mithilfe statischer Analysemethoden identifiziert, um dann mit dem Fuzzer Eingaben zu erzeugen, die dazu geeignet sind, die identifizierten Schwachstellen zu erreichen und auszunutzen. Mittels einer sogenannten Taint-Analyse kann zusätzlich der Datenfluss durch die Software von den Eingabepositionen zu den potenziell verwundbaren Stellen verfolgt und der Fuzzer so gesteuert werden, dass die potenziellen Schwachstellen möglichst effizient erreicht werden können.
- Wird Fuzzing mit symbolischer Ausführung kombiniert, ergänzt das Fuzzing die symbolische Ausführung durch die Erzeugung konkreter Werte in einer realen Ausführung. Das hilft insbesondere dabei, für die komplexen symbolischen Ausdrücke eine effizientere Lösung zu finden als die traditionell eingesetzten SMT-Solver. Diese Form der konkreten und symbolischen Ausführung wird häufig auch Concolic (Concrete + Symbolic) Testing bezeichnet.

Beim hybriden Fuzzing werden Elemente von Black-Box- und White-Box-Fuzzing kombiniert. Dabei werden White-Box-Methoden verwendet, um die Generierung von Testeingaben zu steuern, die dann auf Black-Box-Basis angewendet werden. Dies kann eine dynamische Instrumentierung der Software beinhalten, um beispielsweise Laufzeitinformationen zu sammeln, die dann die weitere Testgenerierung steuern.

Effektive Fuzz-Tests erfordern die Fähigkeit, die Zielanwendung auf Ausnahmen, Abstürze und andere Indikatoren für Fehlfunktionen zu überwachen. Insbesondere White-Box-Fuzzing Methoden erfordern zusätzlich eine weitergehende Instrumentierung der Software, was White-Box-Fuzzing deutlich aufwendiger macht als Black- und Grey-Box-Verfahren.

8.2.5 Last- und Performanztesten

Ziel des Last- und Performanztests im Kontext der IT-Sicherheit ist es, die Robustheit des Systems gegenüber Denial-of-Service- und Distributed-Denial-of-Service-(DDoS-)Angriffen zu testen. Bei diesen Angriffen werden in kurzer Zeit außerordentlich große Mengen an Nachrichten oder Nachrichtensequenzen an das Zielsystem gesendet, um den gültigen Zugang zum System einzuschränken oder zu begrenzen. Im Schadensfall kann das Zielsystem aufgrund seiner Leistungseinschränkungen keine sinnvollen Nachrichten oder Informationen empfangen bzw. bereitstellen. Im schlimmsten Fall kann das gesamte System unter der Last zusammenbrechen, abstürzen oder empfänglich für weitere Angriffsvektoren und Manipulationen sein.

Der Last- und Performanztest ist ein rein dynamischer Test. Im Unterschied zu herkömmlichen Last- oder Performanztests, bei denen das System nur geringfügig über die im realen Einsatz zu erwartende Last- und Performanzanforderungen hinaus belastet wird, wird beim sicherheitsbezogenen Last- und Performanztest das System durch schnelle sequenzielle oder parallele Last vollständig an seine Grenzen gebracht.

- Parallele Last wird dazu verwendet, Systemressourcen wie Prozesse und Speicher in einer Form zu binden, die das System in einen Zustand bringt, indem es nicht mehr verfügbar ist.
- Sequenzielle Last dient zum Test der sequenziellen Verarbeitungsleistung bzw. der Bestimmung der Grenzen der Verarbeitungsleistung.

Beide Testszenarien sind in der Regel erforderlich, um die Leistungsgrenzen vollständig zu vermessen und zu demonstrieren, was passiert, wenn diese Grenzen erreicht werden (ETSI 2015).

8.2.6 Schwachstellen-Scanning

Das Schwachstellen-Scanning ist ein systematisches und automatisiertes Vorgehen, um bekannte Schwachstellen in Netzwerksystemen, Software und Anwendungen zu ermitteln und zu bewerten. Dabei werden Werkzeuge eingesetzt, die automatisiert Schwachstellen detektieren und lokalisieren sollen. Unterschieden werden kann zwischen rein metadatenbasiertem und dynamischem Schwachstellen-Scanning.

Beim rein metadatenbasiertem Schwachstellen-Scannen wird das Zielsystem nicht ausgeführt, sondern Details über das Zielsystem, wie z. B. die verwendeten Bibliotheken und ihre Softwareversionen, werden mit Datenbanken bekannter Schwachstellen verglichen. Ziel ist es, anhand der an die Datenbanken übermittelten Metadaten veraltete Softwareversionen, Fehlkonfigurationen und fehlende Patches identifizieren zu können. Diese Form des Schwachstellen-Scannings lässt sich relative einfach und rasch durchführen, sie eignet sich insbesondere als automatisierte Prüfung im Build-Prozess einer Softwareanwendung.

Aktive Schwachstellen-Scans arbeiten auf dem laufenden System und versuchen dort aktiv und automatisiert bekannte Schwachstellen zu entdecken und auszunutzen. Der Scan-Prozess beginnt in der Regel mit der Festlegung des Umfangs der Prüfung, der die Auswahl der zu prüfenden Systeme, Netzwerke oder Anwendungen umfasst. Die Scanner führen dann eine umfassende Prüfung der Zielsysteme durch und identifizieren Schwachstellen, indem sie offene Ports und laufende Dienste untersuchen und die Reaktionen der Systeme auf verschiedene Eingaben analysieren. Diese aktiven Schwachstellen-Scans können sowohl im authentifizierten als auch im nicht authentifizierten Modus arbeiten, wobei authentifizierte Scans tiefere Einblicke in das System oder die Infrastruktur gewähren, indem sie auch Funktionalität bzw. Teilsysteme testen, die durch ein Zugriffsmanagement geschützt sind.

Die Ergebnisse der Schwachstellen-Scans werden in detaillierten Berichten zusammengefasst, in denen die Schwachstellen nach Schweregrad, potenzieller Auswirkung und Ausnutzbarkeit geordnet sind. Diese Berichte dienen Administratoren und Sicherheitsteams als Orientierungshilfe bei der Behebung und Entschärfung von Schwachstellen und enthalten häufig Vorschläge für Korrekturmaßnahmen oder Empfehlungen für Patches. Regelmäßige Schwachstellen-Scans sind ein wesentlicher Bestandteil einer proaktiven Sicherheitsstrategie, die es Organisationen ermöglicht, Schwachstellen zu erkennen und zu beheben, bevor sie ausgenutzt werden können.

8.2.7 Monitoring und passives Testen

Passives Testen ist ein Testansatz, der sich auf die Analyse des Systemverhaltens unter normalen Betriebsbedingungen konzentriert, ohne den Systemzustand zu verändern oder Testdaten einzuspeisen. Ziel ist es, potenzielle Schwachstellen oder Probleme im laufenden Betrieb zu identifizieren. Er wird in der Regel in einer kontrollierten Umgebung durchgeführt, in der die Ausgaben des Systems als Reaktion auf die reguläre Interaktion des Systems mit seiner Umwelt beobachtet werden. Passives Testen ist besonders geeignet für die Prüfung von Systemen zu Zeitpunkten, in denen die Stabilität und Performanz nicht beeinträchtigt werden sollen, da das Risiko von Störungen durch aktive Stimulation des Systems vermieden wird. Die Testeingaben bleiben dadurch in der Regel beschränkt, was im Vergleich zum aktiven Testen zu einer geringeren Testabde-

ckung führt. Passive Tests ermöglichen die Prüfung des Systemverhaltens zur Laufzeit und zeigen potenzielle Sicherheitsmängel wie Fehlkonfigurationen, Protokollfehler bzw. die Verletzung von Sicherheitsrichtlinien (Mallouli 2008, Felderer 2016).

Beim Monitoring werden die Systemaktivitäten, der Netzwerkverkehr und die Leistungsindikatoren kontinuierlich beobachtet, um Anomalien, Schwachstellen, Angriffsversuche oder betriebliche Probleme möglichst frühzeitig zu erkennen. Während das passive Testen ein episodisches oder geplantes Ereignis ist, das sich auf die Systemanalyse konzentriert, ist die Überwachung ein fortlaufender Prozess, der darauf abzielt, unmittelbare Einblicke in den Zustand und die Sicherheitslage eines IT-Ökosystems zu geben.

Durch den Einsatz von geeigneten Monitoring-Werkzeugen und Kombination mit automatisierten Auswertungen und geeigneten Visualisierungen können Organisationen ihre Systeme und Infrastruktur in Echtzeit überwachen und verdächtige Aktivitäten, die auf Sicherheitsverletzungen oder Eindringversuche hindeuten könnten, frühzeitig erkennen.

Darüber hinaus erleichtern Monitoring und passives Testen die Einhaltung gesetzlicher Vorschriften durch eine kontinuierliche Überwachung der Sicherheitsmaßnahmen und kritischer Systemereignisse.

8.2.8 Risikobasiertes Sicherheitstesten

Das risikobasierte Testen ist ein pragmatischer und oft intuitiv genutzter Meta-Ansatz, um die Testaktivitäten auf diejenigen Szenarien zu konzentrieren, die die kritischsten Situationen eines Softwaresystems adressieren (Grossmann 2019). Die Kombination von Risikomanagement und Sicherheitstests kann grundsätzlich dazu beitragen, das verfügbare Testbudget durch die Konzentration auf die relevanten Risiken optimal auszunutzen und zu verhindern, dass die falschen Dinge getestet werden. Indem sich Organisationen beim Testen auf die Bereiche mit dem höchsten Risiko konzentrieren, können sie ihre Ressourcen effizienter einsetzen und sicherstellen, dass die wichtigsten potenziellen Bedrohungen zuerst angegangen werden.

Grob kann zwischen risikobasierter Testauswahl und risikobasierter Testauswertung unterschieden werden.

- Die risikobasierte Testauswahl adressiert das Problem, dass nur eine begrenzte Anzahl von Testfällen realisiert bzw. durchgeführt werden kann und dass diese Testfälle die Anwendungsfälle, Funktionen oder Komponenten abdecken sollen, mit denen das größte Risiko verbunden ist.
- Eine risikobasierte Testauswertung hingegen adressiert das Problem, dass die beim Testen gefundenen Fehler bewertet werden sollen und ggf. eine Freigabe auch mit vorhandenen Fehlern erfolgen kann, wenn diese die kritische Funktionalität nicht beeinträchtigen.

Die Voraussetzung für beide Ansätze ist das Vorhandensein einer Risikoanalyse. Diese kann unterschiedlich stark formalisiert sein und reicht von einer intuitiven Risikoeinschätzung durch den Testenden bis hin zu formalisierten und formellen Verfahren, mit denen versucht werden kann, Risiken qualitativ und quantitativ zu beschreiben.

(ETSI 2016) liefert eine vollumfängliche und systematische Zusammenstellung zu den vielfältigen Abhängigkeiten zwischen IT-Sicherheitsrisikoanalyse und den verschiedenen Optionen des risikobasierten Sicherheitstesten. In der Literatur findet sich eine Reihe weiterer spezialisierter Verfahren, die sich spezielle Modellierungstechniken wie beispielsweise Fehlermodelle und Angriffsbäume zunutze machen (Zech 2009, Grossmann 2014), um Risiken und Gefährdungen zu beschreiben, die dann als Grundlage für die Testauswahl verwendet werden.

Das Erfassen und Berücksichtigen von Risiken ist fester Bestandteil der IT-Sicherheitskultur und, wie bereits in den vorhergehenden Kapiteln erläutert, die Definition von IT-Sicherheitszielen und Sicherheitstestzielen orientiert sich immer auch an den identifizierten IT-Sicherheitsrisiken und den damit assoziierten Bedrohungsszenarien und Schwachstellen. In diesem Sinne ist das risikobasierte Testen im Sicherheitstesten weit verbreitet. Es kann auf statische und dynamische Testtechniken angewandt werden und verschiedene Arten der Risikoermittlung als Grundlage verwenden.

8.2.9 Penetrationstesten

Penetrationstests (NIST 2022; BSI 2022) werden als kontrollierter Versuch durchgeführt, die im System eingesetzten Sicherheitsmaßnahmen mit den Techniken eines Angreifers und geeigneten Hardware- und Softwarewerkzeugen auszuhebeln und Schwachstellen auszunutzen, um in das System einzudringen.

Im technischen Sprachgebrauch versteht man unter einem Penetrationstest den kontrollierten Versuch, von „außen“ in ein bestimmtes Computersystem bzw. -netzwerk einzudringen, um Schwachstellen zu identifizieren. Dazu werden die gleichen bzw. ähnliche Techniken eingesetzt, die auch bei einem realen Angriff verwendet werden (BSI 2020).

Der Penetrationstest wird in der Regel durch externe Dienstleister durchgeführt und konzentriert sich auf den Test fertiger Softwareanwendungen bzw. einer laufenden Infrastruktur. Das Hauptziel besteht darin, die Schwachstellen zu identifizieren und zu dokumentieren. Die Tests folgen einer strukturierten Methodik, die in der Regel die Phasen Planung, Erkundung (engl. Reconnaissance), Scanning, Ausnutzung (Exploitation) und Berichterstattung umfasst.

Beim Penetrationstest wird eine Vielzahl von Werkzeugen und Techniken eingesetzt, darunter Werkzeuge zur Informationsbeschaffung, Schwachstellen-Scanner sowie

Werkzeuge, mit denen Schwachstellen ausgenutzt werden können (Exploitation Tools). Dabei werden nicht nur technische Schwachstellen wie nicht aktualisierte Software oder Fehlkonfigurationen aufgedeckt, sondern auch betriebliche und verfahrenstechnische Schwachstellen untersucht.

Die Ergebnisse eines Penetrationstests werden in einem Bericht zusammengefasst, in dem die entdeckten Schwachstellen, die zu ihrer Ausnutzung verwendeten Methoden und Empfehlungen zur Behebung aufgeführt sind. Penetrationstests sind ein wesentlicher Bestandteil eines umfassenden Sicherheitsprogramms, da sie eine realistische Bewertung der Sicherheitslage eines Unternehmens ermöglichen. Indem sie Schwachstellen aktiv aufdecken und beseitigen, bevor sie von Angreifern ausgenutzt werden können, können Unternehmen ihr Risikoprofil deutlich verringern und ihre Sicherheit insgesamt verbessern.

Penetrationstests sind unter Berücksichtigung von regulatorischen und juristischen Rahmenbedingungen zu planen. Vor Beginn der Tests ist die ausdrückliche Genehmigung des Eigentümers des Systems oder der Infrastruktur unabdingbar, um rechtliche Konsequenzen zu vermeiden. Diese Zustimmung zu einem Penetrationstest wird in der Regel in einem Vertrag festgehalten, der den Umfang, die Methoden und den Zeitplan des Tests festlegt, um sicherzustellen, dass der Geschäftsbetrieb so wenig wie möglich gestört und sensible Daten sicher behandelt werden.

Darüber hinaus müssen sich die Testenden in einer komplexen Landschaft lokaler, nationaler und internationaler Gesetze zurechtfinden, die die Cybersicherheitspraktiken regeln, einschließlich Datenschutzbestimmungen wie GDPR, die strenge Anforderungen an die Verarbeitung und den Schutz personenbezogener Daten stellen. In Branchen wie dem Gesundheits- und Finanzwesen müssen Penetrationstests auch sektorspezifischen Vorschriften entsprechen wie beispielsweise der PCI-DSS im Finanzwesen. Die Beachtung der regulatorischen und rechtlichen Rahmenbedingungen stellen sicher, dass Penetrationstests auf verantwortungsvolle Weise und unter Beachtung der Privatsphäre und der Datenschutzstandards durchgeführt werden, was sie zu einem wertvollen Instrument für die Sicherung von Systemen und Infrastrukturen macht.

8.3 Prozessuale Einbettung des Sicherheitstestens

Wichtig ist, dass das Testen und seine Prozesse in eine größere Prozessinfrastruktur eingebettet sind. So müssen nach der Identifikation eines Fehlers weitergehende Aktivitäten angestoßen werden, die dafür sorgen, dass die gefundenen Fehler beseitigt und zukünftig vermieden sowie Testergebnisse in adäquater Form kommuniziert werden, sodass sie Teil der Freigabe und Risikoanalyseprozesse werden können. Diese und viele andere Randbedingungen des Softwaretestens gelten auch für das Sicherheitstesten.

8.3.1 Der Sicherheitstestprozess



Bild 8.2 Der Sicherheitstestprozess

Der klassische Sicherheitstest gliedert sich ähnlich wie der Prozess beim traditionellen Testen in mehrere Phasen (ISTQB 2023).

- In der **Testplanung** wird das Testkonzept erstellt. Dieses umfasst in der Regel die initiale Festlegung des Testumfangs, die allgemeinen Testziele, die erforderlichen Ressourcen, einen Zeitplan sowie Angaben zur Testumgebung und zu den rechtlichen und regulatorischen Rahmenbedingungen.
- Die **Testanalyse** dient dazu, die Sicherheitstestziele auszu differenzieren. Hierzu ist ein tieferes Verständnis über die zu testende Anwendung oder Infrastruktur und ihren Sicherheitsbedarf notwendig. Quellen sind wie bereits in Abschnitt 8.1.5 erläutert Unternehmens- und Geschäftsstrategien, Industrievorschriften und andere Konformitätsanforderungen, Sicherheitsrichtlinien und -standards, Informationen zu Risiken, Bedrohungsszenarien und Schwachstellen, die Sicherheitsarchitektur sowie die konkret geplanten Sicherheitsmaßnahmen.
- Der **Testentwurf** dient der Entwicklung einer konsistenten Teststrategie sowie der umfassenden Spezifikation des Testvorgehens und der Testfälle. Die Teststrategie umfasst die Festlegung des Gesamtansatzes für das Testen, einschließlich der zu verwendenden Methoden, Werkzeuge und Techniken. Die Spezifikation des Testvorgehens und der Testfälle beschreibt konkrete Testaktivitäten und abstrakte Testfälle.
- Während der **Testrealisierung** werden die Tests operationalisiert. Hierzu zählen Aktivitäten wie das Bereitstellen und Konfigurieren der Testumgebung sowie der Testhilfsmittel sowie die Bereitstellung und das Konfigurieren der für die Tests benötigten Werkzeuge und Skripte.
- Die **Testdurchführung** ist die Aktivität, während der die Sicherheitstests durchgeführt werden. Dies erfolgt sowohl mit automatisierten Werkzeugen als auch mit manuellen Techniken. Zentral ist das Erfassen der Testergebnisse inklusive aller Fehler, Schwachstellen oder Auffälligkeiten, die während der Tests entdeckt werden.
- Der **Testabschluss** dient dazu, die Testergebnisse zu bewerten, um effektive Schwachstellen zu identifizieren, ihren Schweregrad zu bewerten und die möglichen Auswirkungen auf das System zu verstehen und an interessierte Gruppen zu

kommunizieren. Diese erfolgt über Testberichte, in denen die Ergebnisse, Risikostufen und Verbesserungsvorschläge detailliert aufgeführt sind.

Inspektion und Kontrolle stellen sicher, dass über den gesamten Testprozess die Vorgaben aus der Testplanung eingehalten und in kontrollierter Art und Weise den Projektgegebenheiten angepasst werden können. Der Testabschluss umfasst Aktivitäten für ein kontrolliertes Projektende und umfasst die Freigabe der allozierten Ressourcen und das längerfristige Vorhalten der Testergebnisse.

Der Sicherheitstestprozess ist nicht notwendigerweise sequenziell aufgebaut und sollte nahtlos mit den Lebenszyklen der Softwareentwicklung und des Betriebs von Software und Infrastrukturen abgestimmt werden.

8.3.2 Sicherheitstesten im SDLC

Der Software Development Life Cycle (SDLC) bietet einen strukturierten Ansatz für die Softwareentwicklung, der die Phasen der Entwicklung von Softwareanwendungen beschreibt und der darauf abzielt, qualitativ hochwertige Software zu produzieren. Er umfasst alle relevanten Phasen der Softwareentwicklung und Bereitstellung beginnend mit der Planungsphase über die Anforderungsermittlung, Entwurf, Implementierung, Verifikation und Validierung bis hin zum Betrieb der Software und ihrer Wartung. Verschiedene SDLC-Modelle (z. B. Wasserfall, Agile, Scrum und DevOps) passen diese Phasen an verschiedene Projektmanagementstile und Unternehmenskulturen an. Bild 8.3 zeigt einen prototypischen SDLC.

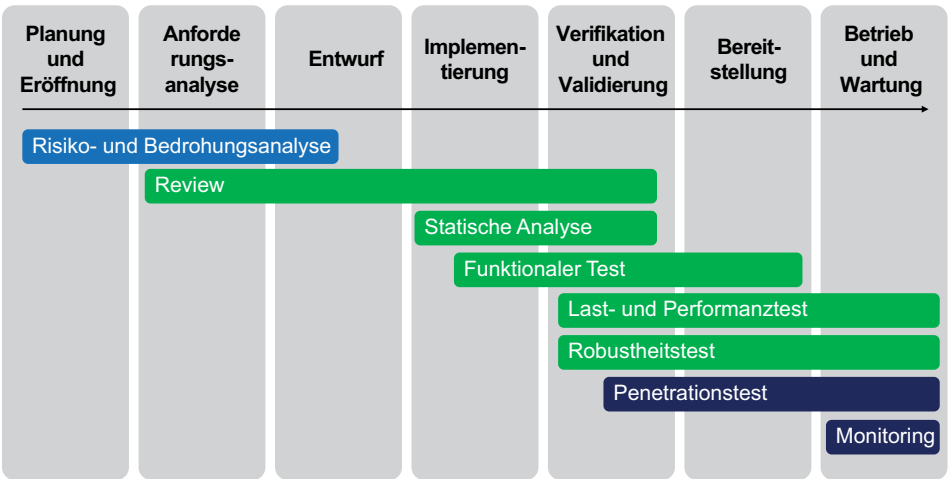


Bild 8.3 Sicherheitstestaktivitäten im Software Development Lifecycle

Die nahtlose Integration von Sicherheitstests in den Softwareentwicklungszyklus (SDLC) ist für eine systematische und frühzeitige Erkennung von Schwachstellen und sicherheitsrelevanten Fehlern unerlässlich. Sicherheitsprobleme können so deutlich vor der Bereitstellung und dadurch in der Regel kostengünstig und einfacher behoben werden.

- Bereits in den Planungs- und Anforderungsphasen werden durch Risiko- und Bedrohungsanalysen sowie die Definition von Sicherheitsanforderungen die Grundlagen für eine sichere Anwendung geschaffen.
- In der Entwurfsphase sorgen die Modellierung von Bedrohungen und der Entwurf einer sicheren Architektur dafür, dass Sicherheitsaspekte von Anfang an mit einbezogen werden. Ein Review der Risiken und Bedrohungen, der Sicherheitsanforderungen sowie der Sicherheitsarchitektur unterstützen dabei, bereits in frühen Entwicklungsphasen Schwachstellen und Unzulänglichkeiten feststellen zu können.
- In der Implementierungsphase wird der Schwerpunkt auf sichere Codierungspraktiken gelegt und der Quellcode mithilfe statischer Analysen (SAST) auf Schwachstellen untersucht. Zusätzlich werden einzelne Softwareeinheiten mittels funktionaler Tests auf ihre Sicherheitsfunktionalität geprüft.
- In der Verifikations- und Validierungsphase liegt der Schwerpunkt auf dem dynamischen Testen (DAST). Das System wird durch funktionales Testen auf Fehler in seiner Sicherheitsfunktionalität geprüft. Mittels Robustheitstests, häufig Fuzz-Testing, lässt sich das System zusätzlich auf seine Robustheit gegenüber unerwarteten Eingaben prüfen.
- Vor und während der Bereitstellung bereitet die Prüfung der Sicherheitskonfigurationen und -härtung sowie Schwachstellen-Scans die Anwendung auf einen sicheren Start vor. Durch Penetrationstests können reale Angriffe simuliert werden, um Schwachstellen zu erkennen und zu beheben.
- Während Betrieb und Wartung stellen passive Tests und Monitoring sicher, dass ungewöhnliches System- und Nutzungsverhalten erkannt und auf seine Bedeutung für die IT-Sicherheit hin analysiert werden kann. Regelmäßige Penetrationstests ermöglichen zudem, das System regelmäßig auf seine Anfälligkeit auf neue Bedrohungen und bekannt gewordene Schwachstellen zu überprüfen.

Indem Sicherheitstests systematisch in den SDLC integriert werden, lassen sich Fehler und Schwachstellen frühzeitig und systematisch erkennen und beheben, sodass sowohl Kosten durch das späte Beheben von Schwachstellen wie auch durch Schaden minimiert werden können. Im Verlauf der letzten zwanzig Jahre haben sich unterschiedliche Formen eines Secure Software Development Lifecycle (SSDLC) etabliert, die alle relevanten Sicherheitsaktivitäten benennen und in den SDLC integrieren (Microsoft 2023).

8.3.3 Sicherheitstesten in agiler Entwicklung und DevOps

Agile Methoden zielen darauf ab, den Softwareentwicklungsprozess flexibel und anpassungsfähig zu gestalten, um auf Änderungen in den Kundenanforderungen oder den Marktbedingungen schnell reagieren zu können. Durch regelmäßiges Feedback und die Einbindung von Kunden und Nutzern in den Entwicklungsprozess wird sichergestellt, dass das Endprodukt auch den Kundenanforderungen entspricht. DevOps versucht darüber hinaus die traditionelle Trennung zwischen Entwicklung und Betrieb einer Software zu überwinden und so die Zusammenarbeit und Kommunikation zu fördern und durch Automatisierung sowie durch kontinuierliche Integrations- und Auslieferungsprozesse (CI/CD) die Effizienz und Qualität der Softwareentwicklung zu erhöhen.

Agile Methoden und DevOps legen den Schwerpunkt auf schnelle, iterative Entwicklungszyklen und regelmäßige Freigaben und Releases. Automatisierung und automatisierte Tests sind zentrale Aspekte, um die Stabilität und Zuverlässigkeit der ausgelieferten Software sicherzustellen. Die Integration von Sicherheitstests in diese Prozesse ist häufig nicht einfach. Angefangen damit, dass sich, wie in Abschnitt 8.2 bereits dargestellt wurde, nicht alle Aspekte des Sicherheitstestens automatisieren lassen, führen agile Prozesse mit sich dynamisch entwickelnden Anforderungen häufig dazu, dass auch die Sicherheitsanforderungen und die davon abhängige Teststrategie kontinuierlich angepasst werden müssen. Prozesse und Werkzeuge, die sich in der klassischen Softwareentwicklung etabliert haben, passen auf einmal nicht mehr in das agile Vorgehen und sind häufig nicht in der Form automatisierbar, wie es für effiziente DevOps-Prozesse notwendig ist. Schlussendlich fehlt es in agilen Teams oft auch an speziellem IT-Sicherheitsfachwissen, um eine kontinuierliche Entwicklung von IT-Sicherheitsanforderungen und den notwendigen Sicherheitstests gewährleisten zu können.

In der Praxis hat sich eine Reihe effektiver Maßnahmen durchgesetzt, um die technischen wie auch organisatorischen Voraussetzungen zu schaffen, damit Sicherheit und Sicherheitstesten in agilen Prozessen und DevOps umgesetzt werden können. Dieses reicht von

- der Festlegung von Verantwortlichkeiten und Rollen, die sich dem Thema Sicherheit und Sicherheitstesten annehmen, über
- die Definition von Richtlinien sowie Schulungen für die agilen Teams bis hin zur
- Einführung dedizierter Sicherheitsfreigaben und Quality Gates in der agilen Entwicklung.

Mit **DevSecOps** und **SecDevOps** haben sich Prozessmodelle etabliert, die Sicherheitsaktivitäten in DevOps-Prozesse integrieren. DevSecOps steht für die Integration der Sicherheit in alle Phasen des agilen Softwareentwicklungszyklus. SecDevOps geht noch einen Schritt weiter und betrachtet Sicherheit als den zentralen Aspekt der Ent-

wicklung, dem alle anderen Aktivitäten nachgeordnet sind. Bild 8.4 zeigt, wie sich die zentralen Testaktivitäten des Sicherheitstestens auf die relevanten Phasen eines DevOps-Prozesses verteilen.

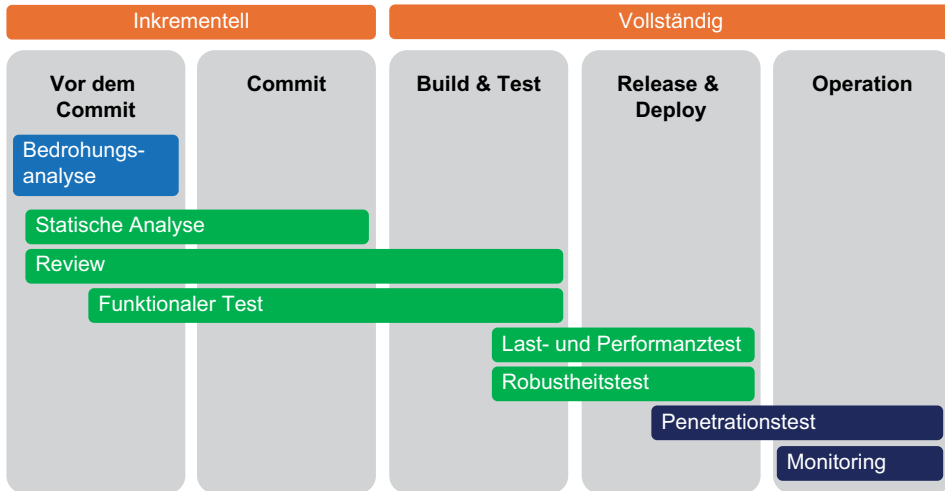


Bild 8.4 Sicherheitstestaktivitäten in agilen Projekten und DevOps-Prozessen

- Während des Kodierens werden Testaktivitäten durchgeführt, die einfach aufzusetzen, stark automatisierbar sind und inkrementell auch auf kleinere Softwareeinheiten angewandt werden können. Hierzu zählen statische Analysen, Unittests und Reviews. Alle Aktivitäten werden innerhalb eines Sprints durchgeführt, und Fehler werden in der Regel direkt behoben.
- In der Build- & Testphase stehen dann Tests im Vordergrund, die das Gesamtsystem betreffen. Hierzu zählen funktionale Sicherheitstests inklusive automatisierbarer Regressionstest.
- Zum Release und beim Deployment kommen dann Tests zum Tragen, deren Durchführung und Auswertung einen deutlich höheren Instrumentierungs- und Konfigurationsaufwand mit sich bringen. Hierzu zählen u. a. Last- und Performanztests sowie Robustheitstest. Penetrationstests und Monitoring konzentrieren sich auf die Identifikation von Schwachstellen im Betrieb.

Zentral für eine Integration von Sicherheitstests in agiles Vorgehen und DevOps-Prozesse ist neben dem Personal die Auswahl geeigneter Werkzeuge, die den Automatisierungsanforderungen in den CI/CD-Pipelines gerecht werden. Die Herausforderung besteht insbesondere darin, zu bestimmen, was automatisiert werden kann und welche Tests in welcher Projektphase sinnvoll und effizient integriert werden können. DevOps steht dabei für die Prinzipien *Shift Left* und *Shift Right*.

- *Shift Left* ist der Versuch, Tests möglichst früh in der Entwicklung durchzuführen, sodass Fehler schnell behoben werden können. Das ist, wie oben bereits dargestellt, für alle Testmethoden unterschiedlich realisierbar.
- *Shift Right* steht für die Integration und den Rückfluss von Testergebnissen aus dem Betrieb in die Entwicklung. Hierzu müssen die Teams aus Entwicklung und Betrieb eng miteinander zusammenarbeiten und über geeignete Kommunikationskanäle verfügen, um die Ergebnisse insbesondere aus dem Monitoring und den Penetrationstests in die Entwicklung zurückzuspielen.

Darüber hinaus zwingen die starken Abhängigkeiten zwischen Anwendungs- und Infrastruktursicherheit bei der Nutzung von Cloud- und Container-Infrastrukturen dazu, dass ein zwischen Entwicklung und Betrieb abgestimmtes Sicherheitstestkonzept existiert, das neben der Softwareanwendung auch Infrastrukturkomponenten und Konfigurationen stärker in den Fokus nimmt. Einen guten Überblick über die Integration von Sicherheitsaktivitäten inklusive der notwendigen Testaktivitäten findet sich im The OWASP DevSecOps Maturity Model (OWASP 2024).

8.4 Chancen und Herausforderungen durch KI

KI besitzt ein enormes Automatisierungspotenzial. So lassen sich mittels KI große Datenmengen deutlich schneller analysieren, als es menschliche Analysten könnten. Durch die Automatisierung sich wiederholender und zeitaufwendiger Aufgaben können prinzipiell Aufwände reduziert und Arbeitskosten gesenkt werden, sodass sich Experten stärker auf strategischere Aktivitäten konzentrieren können. KI besitzt ein enormes Potenzial, die Automatisierung im Kontext des Sicherheitstestens voranzubringen. Dieser Aspekt wird in Abschnitt 8.4.1 erläutert. Zusätzlich führt die zunehmende Integration von KI in Softwareanwendungen dazu, dass mit neuen KI-spezifischen Bedrohungsszenarien und Schwachstellen umgegangen werden muss. Dieses wird in Abschnitt 8.4.2 weiter ausgeführt.

8.4.1 KI-gestützte Automatisierung beim Sicherheitstest

In den letzten Jahren hat KI die Art und Weise, wie Sicherheitsexperten an Softwareentwicklung, Schwachstellenerkennung, Bedrohungsmodellierung und das Testen herangehen, deutlich beeinflusst. Der aktuelle Hype um das Potenzial von Large-Language-Modellen (LLM) hat diese Entwicklung noch einmal forciert. KI-basierte Ansätze beim Sicherheitstesten nutzen maschinelles Lernen (ML), um die Effektivität und Effizienz von Sicherheitstestprozessen zu verbessern. Ziel ist es, durch den Einsatz von KI neue Schwachstellen und Bedrohungen identifizieren, die Testauswahl optimieren und beschleunigen und die Qualität der Tests verbessern zu können.

ML zeichnet sich durch seine Fähigkeit aus, subtile Muster und Korrelationen in großen Datenbeständen zu erkennen. Diese Fähigkeit ist dann besonders hilfreich, wenn der Untersuchungsgegenstand so komplex ist, dass er sich von Menschen kaum beurteilen lässt bzw. Strukturmerkmale und Abhängigkeiten so subtil codiert sind, dass Menschen diese nicht oder nur mit viel Aufwand identifizieren können. Die folgenden Punkte können als Beispiele für den erfolgreichen Einsatz von ML im Bereich des Sicherheitstestens gesehen werden.

- Es gibt bereits seit Längerem KI-basierte Verfahren zur Anomalieerkennung, die im Rahmen des Monitorings Anomalien erkennen können, die auf eine Sicherheitsverletzung hindeuten (Wang et. al 2023).
- In der statischen Analyse wird ML eingesetzt, um durch ein gelerntes Verständnis des Kontexts und der Variabilität von Programmstrukturen besser zwischen Schwachstellen und gutartigem Code unterscheiden zu können (Harzevili 2023). Ziel ist es, insbesondere die hohe Anzahl Falsch-Positiver Rückmeldungen in der statischen Analyse durch ML zu reduzieren. Aktuelle Forschungsergebnisse zeigen dann auch, dass der Einsatz von ML in und zur Unterstützung der statischen Analyse die Effektivität traditioneller Analysewerkzeuge übertreffen kann (Yeramreddy 2023, Zeng 2020). Voraussetzung dafür ist allerdings das Vorhandensein großer, qualitativ hochwertiger Trainingsdatensätze mit vielfältigen Beispielen zu sicherem und unsicherem Code. Diese sind in der Regel nicht einfach verfügbar und müssen auf die Spezifika der verwendeten Programmiersprachen, der Domäne und der etablierten Programmierstile angepasst werden.
- Im Kontext des klassischen Penetrationstests kann ML und insbesondere Reinforcement Learning (RL) bei der Erstellung und Optimierung von Angriffsgraphen eingesetzt werden. Angriffsgraphen sind formalisierte Repräsentationen von Schwachstellen, Geräten, Schutzgütern und Akteuren, die miteinander verknüpft werden können, um Kompromittierungspfade zu wichtigen Zielen innerhalb eines Netzwerks darstellen zu können. ML verbessert die Erstellung und Optimierung dieser Graphen durch die Identifikation von Mustern oder Korrelationen zwischen Schwachstellen, Geräten, Schutzgütern und Akteuren. Beispielsweise lernen Reinforcement-Learning-(RL-)Agenten aus der Interaktion mit einer simulierten Netzwerkumgebung, um die Pfade eines Angriffsgraphen zu identifizieren, die mit den geringsten Kosten einen höchsten Schaden verursachen (Cody 2022). RL ist insbesondere für die Erkundung großer, dynamischer Netzwerke interessant, für deren Test komplexe Angriffsgraphen analysiert werden müssen.

Berücksichtigt man die aktuell absehbaren Produktivitätssprünge durch den Einsatz von spezialisierten LLMs in der Softwareentwicklung, ist davon auszugehen, dass im Bereich des Sicherheitstestens neues Automatisierungspotenzial entsteht. Derzeit wird beispielsweise untersucht, welchen Beitrag LLMs beim Erkennen von Schwachstellen in Code realisieren können. Die Ergebnisse sind allerdings noch sehr heterogen und reichen von kritischen Aussagen, dass ChatGPT in der Version 3 dieser Auf-

gabe nur wenig gewachsen ist (Cheshkov, Zadorozhny, Levichev 2023), bis hin zu positiveren Einschätzungen in (Bakhshandeh 2023), die zeigen, dass ChatGPT in der Version 4 die Falsch-Positiv- und Falsch-Negativ-Raten in der statischen Analyse reduziert und das Potenzial hat, für die Erkennung von Schwachstellen sinnvoll eingesetzt werden zu können. Insgesamt sind die Ergebnisse aber kaum validiert und noch mit Vorsicht zu genießen.

8.4.2 Sicherheitstesten von KI

Beim Sicherheitstesten von KI-Systemen geht es darum, Anwendungen der künstlichen Intelligenz in Bezug auf ihre Widerstandsfähigkeit gegen Angriffe zu testen. Da KI zunehmend in verschiedene Aspekte der Technologie und des täglichen Lebens integriert wird, wird die Gewährleistung der Sicherheit dieser Systeme immer wichtiger: Vierunddreißig Prozent der Unternehmen weltweit nutzen oder implementieren bereits jetzt Maßnahmen, um die Anwendungssicherheit von KI sicherstellen und die mit der Anwendung generativer KI (GenAI bzw. GenKI) einhergehenden Risiken minimieren zu können. Mehr als die Hälfte (56 %) der Befragten gab an, dass sie Maßnahmen in Erwägung ziehen (Gartner 2023).

Das Sicherheitstesten von KI-Systemen ist ein sich rasch entwickelnder Bereich, der sich sowohl mit den spezifischen Schwachstellen von KI-Technologien als auch mit den traditionellen Sicherheitsanforderungen von Softwaresystemen befasst. Zu den klassischen Schwachstellen und Verwundbarkeiten von KI zählen:

- **Fehlende Robustheit gegen Evasionsangriffe.** Bei Evasionsangriffen werden sorgfältig ausgearbeitete Eingaben in KI-Systeme eingespeist, um sie dazu zu bringen, falsche Entscheidungen zu treffen oder sensible Informationen preiszugeben. Die Erkennung und Eliminierung dieser Angriffe ist aufgrund der fehlenden Robustheit der Modelle auch gegen subtile Verfälschungen der Eingabedaten ausgesprochen komplex.
- **Anfälligkeit für Datenverfälschung und andere Lieferkettenangriffe.** KI-Modelle entstehen in komplexen Trainingsprozessen. Insbesondere die Integrität der zum Trainieren verwendeten Daten ist entscheidend für die Zuverlässigkeit der Modelle. Bei sogenannten Datenvergiftungsangriffen (Data Poisoning Attacks) werden Daten in den Trainingsdatensatz eingespeist, die zu verzerrten oder falschen Modellergebnissen führen. Andere Angriffe beruhen auf vorab modifizierten Modellen, die bereits böses Verhalten wie Hintertüren oder blinde Flecken aufweisen und mit dem Ziel in Umlauf gebracht werden, bei der unbedachten Verwendung der Modelle von dem bösen Verhalten zu profitieren.
- **Anfälligkeit für die Extraktion von Daten.** Die Daten, mit denen ein Modell trainiert wurde, können aus den unterschiedlichsten Gründen vertraulich sein, sind

aber trotzdem als Parameter im Modell codiert und nicht per se sicher vor Zugriff durch Dritte. So lassen sich beispielsweise allein durch die geschickte Interaktion mit einem Modell Antworten generieren, die Aufschluss über die Trainingsdaten geben. Weitaus kritischer ist es, wenn Angreifer nicht nur Zugriff auf die Inferenzschnittstelle des Modells haben, sondern das vollständige Modell in die Hände bekommen.

Die Komplexität der ML-Modelle und die oben dargestellten Schwachstellen wie die fehlende Robustheit gegenüber feindlichen Angriffen, die Möglichkeiten des Jailbreak sowie die diversen Möglichkeiten der Datenvergiftung erfordern neue Ansätze beim Sicherheitstesten, die mit den aktuellen Werkzeugen und Methoden nur bedingt umzusetzen sind. So helfen etablierte Verfahren zum Integritätsschutz, die Trainingsdaten zu schützen. Unabhängig davon ist es allerdings kaum möglich, kompromittierte Datensätze als solche zu erkennen. Gegen adversariale Angriffe helfen robuste Trainingsmethoden. Der Erfolg dieser Methoden lässt sich dann wiederum durch den Test mit selbst generierten feindlichen Angriffen testen. Entsprechende Werkzeuge zur Durchführung der Tests, wie beispielsweise die *Adversarial Robustness Toolbox*, sind aber eher akademischer Natur und nicht für den industriellen Einsatz konzipiert. Grundlegende Techniken für den Sicherheitstest von KI-Modellen wie beispielsweise *Fuzz-Testen*, *Metamorphes Testen*, *Differentielles Testen* und die verschiedenen Arten *adversarialer Angriffe* werden allerdings im Rahmen eines technischen Berichts der ETSI (ETSI 2024) systematisch dargestellt und erläutert.

Beim Sicherheitstesten von LLMs und GenKI steht aktuell insbesondere die Erkennung von Jailbreak-Schwachstellen im Vordergrund. Als Jailbreak wird in diesem Kontext der erfolgreiche Versuch verstanden, die vom Modellanbieter auferlegten Standardbeschränkungen eines Modells zu umgehen oder außer Kraft zu setzen. In der Forschung entwickelte Methoden wie *PrivQA* und *FuzzLLM* sind geeignet, solche Schwachstellen zu erkennen, und erlauben es, das Risiko entsprechender Angriffe mit den bestehenden Sicherheits- und Datenschutzzielen abzuwägen. (Greshake et al. 2023) betonen darüber hinaus die Notwendigkeit, auch subtilere Formen der Manipulation wie indirekte Prompt-Injections und vergiftete Trainingsdaten erkennen zu können. Die Forschung in diesem Bereich steht allerdings noch ganz am Anfang, und es ist davon auszugehen, dass im Verlauf der nächsten Jahre neue und effektive Verfahren zum Sicherheitstesten von LLMs und GenKI entwickelt werden.

8.5 Zusammenfassung

Dieses Buchkapitel gibt einen Überblick über die Grundlagen des Sicherheitstestens sowie die verschiedenen, in der Industrie etablierten Methoden und Techniken des Sicherheitstestens. Hierzu zählen Reviews, statisches Testen, dynamisches Testen und

Monitoring sowie Techniken wie statische Analyse, Fuzz-Testing, risikobasiertes Testen und Penetrationstesten.

Aufbauend darauf wird die Einbettung des Sicherheitstestens in die Prozesslandschaft der Softwareentwicklung beschrieben. Dies umfasst sowohl die Strukturierung des Testens über die Phasen eines Sicherheitstestprozesses wie auch die Verteilung der Testaktivitäten über den Softwareentwicklungslebenszyklus.

Im letzten Kapitel wurde zusätzlich ein Ausblick auf aktuelle Entwicklungen und Forschungsansätze zum Sicherheitstesten mit und von KI gegeben. Es ist ein Bereich mit ausgesprochen dynamischer Entwicklung, der in den nächsten Jahren vielversprechende Lösungsansätze erwarten lässt.

Literatur

- Barton P. Miller, Lars Fredriksen, and Bryan So. 1990. An empirical study of the reliability of UNIX utilities. *Commun. ACM* 33, 12 (Dec. 1990), 32 – 44. <https://doi.org/10.1145/96267.96279>
- Bakhshandeh, A., Keramatfar, A., Norouzi, A., Chekidekhoun, M. M., 2023. Using ChatGPT as a Static Application Security Testing Tool. <https://doi.org/10.48550/ARXIV.2308.14434>
- BSI. 2022. IS-Penetrationstest. https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Sicherheitsberatung/Pentest_Webcheck/Beschreibung_Pentest.pdf?__blob=publicationFile&v=3
- Cheshkov, A., Zadorozhny, P., Levichev, R., 2023. Evaluation of ChatGPT Model for Vulnerability Detection. <https://doi.org/10.48550/ARXIV.2304.07232>
- Cody, T., 2022. A Layered Reference Model for Penetration Testing with Reinforcement Learning and Attack Graphs, in: 2022 IEEE 29th Annual Software Technology Conference (STC). Presented at the 2022 IEEE 29th Annual Software Technology Conference (STC), IEEE, Gaithersburg, MD, USA, S. 41 – 50. <https://doi.org/10.1109/STC55697.2022.00015>
- Dijkstra E. W., 1970. *Notes On Structured Programming* (EWD249), Section 3 („On The Reliability of Mechanisms“), corollary at the end.
- ETSI DTR 101 583. 2015. Methods for Testing and Specification (MTS); Security Testing; Basic Terminology, Security Testing Terminology.
- ETSI EG 203 251. 2016: Methods for Testing & Specification; Risk-based Security Assessment and Testing Methodologies.
- ETSI DTR 104 066. 2024: Securing Artificial Intelligence TC (SAI); Security Testing of AI (noch unveröffentlicht).
- Felderer, M., Büchler, M., Johns, M., Brucker, A. D., Breu, R., Pretschner, A., 2016. Security Testing, in: *Advances in Computers*. Elsevier, S. 1 – 51. <https://doi.org/10.1016/bs.adcom.2015.11.003>
- Fontes, A., Gay, G., 2021. Using machine learning to generate test oracles: a systematic literature review, in: *Proceedings of the 1st International Workshop on Test Oracles*. Presented at the ESEC/FSE '21: 29th ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering, ACM, Athens Greece, S. 1 – 10. <https://doi.org/10.1145/3472675.3473974>
- Gartner 2023. <https://www.gartner.com/en/newsroom/press-releases/2023-09-18-gartner-survey-revealed-34-percent-of-organizations-are-already-using-or-implementing-ai-application-security-tools>
- Greshake, K., Abdelnabi, S., Mishra, S., Endres, C., Holz, T., Fritz, M., 2023. Not what you've signed up for: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection.
- Großmann, J., Schneider, M., Viehmann, J., Wendland, M.-F., 2014. Combining Risk Analysis and Security Testing, in: Margaria, T., Steffen, B. (Eds.), *Leveraging Applications of Formal Methods, Verification and Validation. Specialized Techniques and Applications*, Lecture Notes in Computer Science. Springer Berlin Heidelberg, Berlin, Heidelberg, S. 322 – 336. https://doi.org/10.1007/978-3-662-45231-8_23

- Großmann, J., Felderer, M., Viehmann, J., Schieferdecker, I., 2019. A Taxonomy to Assess and Tailor Risk-based Testing in Recent Testing Standards.
- Harzevili, N. S., Belle, A. B., Wang, J., Wang, S., Ming, Z., Jiang, Nagappan, N., 2023. A Survey on Automated Software Vulnerability Detection Using Machine Learning and Deep Learning.
- ISTQB, 2024. International Software Qualification Board – Standardglossar der Fachbegriffe im Softwaretesten, <https://glossary.istqb.org>, abgerufen Juni 2024
- ISTQB, 2023, Certified Tester Lehrplan Foundation Level 4.0.1a. https://www.gtb.de/wp-content/uploads/2024/02/ISTQB_CTFL_Lehrplan-2023_V4.0.1a_DE.pdf
- Joint Task Force, 2022. Assessing security and privacy controls in information systems and organizations (No. NIST SP 800 – 53Ar5). National Institute of Standards and Technology (U. S.), Gaithersburg, MD. <https://doi.org/10.6028/NIST.SP.800-53Ar5>
- Manes, V. J. M., Han, H., Han, C., Cha, S. K., Egele, M., Schwartz, E. J., Woo, M., 2019. The Art, Science, and Engineering of Fuzzing: A Survey.
- Mallouli, W., Bessayah, F., Cavalli, A., Benameur, A., 2008. Security Rules Specification and Analysis Based on Passive Testing, in: IEEE GLOBECOM 2008–2008 IEEE Global Telecommunications Conference. Presented at the IEEE GLOBECOM 2008–2008 IEEE Global Telecommunications Conference, IEEE, New Orleans, LA, USA, S. 1 – 6. <https://doi.org/10.1109/GLOCOM.2008.ECP.400>
- Microsoft, 2024. Microsoft SDL, <https://www.microsoft.com/en-us/securityengineering/sdl> abgerufen Juni 2024
- Mozilla Foundation, 2015. Rapid Risk Assessment. https://infosec.mozilla.org/guidelines/risk/rapid_risk_assessment
- OWASP, 2024. The OWASP DevSecOps Maturity Model (DSOMM), <https://owasp.org/www-project-devsecops-maturity-model/> abgerufen Juni 2024
- Schieferdecker, I., Grossmann, J., Schneider, M., 2012. Model-Based Security Testing. <https://doi.org/10.48550/ARXIV.1202.6118>
- Wang, S., Balarezo, J. F., Kandeepan, S., Al-Hourani, A., Chavez, K. G., Rubinstein, B., 2021. Machine Learning in Network Anomaly Detection: A Survey. IEEE Access 9, 152 379–152 396. <https://doi.org/10.1109/ACCESS.2021.3126834>
- Xue, M., Yuan, C., Wu, H., Zhang, Y., Liu, W., 2020. Machine Learning Security: Threats, Countermeasures, and Evaluations. IEEE Access 8, 74 720–74 742. <https://doi.org/10.1109/ACCESS.2020.2987435>
- Yerramreddy, S., Mordahl, A., Koc, U., Wei, S., Foster, J. S., Carpuat, M., Porter, A. A., 2023. An empirical assessment of machine learning approaches for triaging reports of static analysis tools. Empir Software Eng 28, 28. <https://doi.org/10.1007/s10664-022-10253-z>
- Zech, P.: Risk-Based Security Testing in Cloud Computing Environments; PhD Symposium at the Fourth IEEE International Conference on Software Testing, Verification and Validation (ICST), 2011 Trust Management (IFIPTM'2009), S. 215 – 233, Springer, 2009.
- Zeng, P., Lin, G., Pan, L., Tai, Y., Zhang, J., 2020. Software Vulnerability Analysis and Discovery Using Deep Learning Techniques: A Survey. IEEE Access 8, 197158 – 197172. <https://doi.org/10.1109/ACCESS.2020.3034766>



„Der Mensch ist das größte Risiko für die Informationssicherheit in Unternehmen!“ Diese Aussage ist schädlich, wenn Mitarbeitende für Informationssicherheit sensibilisiert werden sollen. Tatsächlich sind Menschen ein wichtiger Sicherheitsfaktor. Sie sind Teil der Lösung und kein Problem. Dieser Beitrag stellt den Menschen in den Mittelpunkt. Um Menschen effektiv für Informationssicherheit zu sensibilisieren, hilft ein Blick in die Verhaltenspsychologie, da ein komplexes Zusammenspiel verschiedener Faktoren das menschliche Handeln steuert. Sind diese Faktoren bekannt, können sie zielgerichtet gefördert und beeinflusst werden.

In diesem Beitrag erfahren Sie,

- warum Menschen keine Schwachstellen für die Informationssicherheit sind, sondern ein Teil der Lösung,
- warum sich Menschen manchmal unsicher verhalten und die Informationssicherheit gefährden,
- mit welchen Tricks und Instrumenten Menschen manipuliert werden können, um Social Engineers unbewusst zu helfen,
- was Information Security Awareness ist und wie Menschen durch Awareness-Maßnahmen zu einem Sicherheitsfaktor werden können,
- wie Awareness der Mitarbeitenden auf den Gebieten Wissen, Verhaltensabsicht, Salienz und Gewohnheit zielgerichtet gefördert werden kann.

Dieser Beitrag basiert auf den Inhalten des Buches „Mensch und Informationssicherheit“ (Weber, 2024).

9.1 Der Mensch als Lösung

Annika findet die Einladung zur jährlichen Faschingsparty des lokalen Fußballvereins in ihrer E-Mail-Inbox. Im Text wird darauf hingewiesen, dass dieses Jahr aufgrund der laufenden Umbaumaßnahmen im Vereinsheim noch weniger Karten als üblich zur Verfügung stehen. Kurz kommt es Annika verdächtig vor, dass die Einladung an ihre berufliche E-Mail-Adresse geschickt wurde, und das ca. zwei Wochen früher als sonst, dann klickt sie schnell auf den Link zur Bestellung der Karten.

Ein typisches Beispiel dafür, wie leicht Menschen manipuliert werden können, wie leichtsinnig sie mit ihren Daten umgehen und wie unsicher sie sich immer wieder verhalten? Zeigt das Beispiel nicht deutlich, dass Menschen das schwächste Glied in der „Sicherheitskette“ sind bzw. die größte Schwachstelle für die Informationssicherheit?

Nein – in diesem Beitrag soll es um eine andere Sichtweise auf den Faktor Mensch gehen. Menschen sollen nicht als Problem, sondern als Teil der Lösung gesehen werden. Anwendende als **Sicherheitsfaktor** verhalten sich nicht nur gemäß den aufgestellten Regeln. Sie sind generell aufmerksam und in der Lage, auch in unbekannten, vorher nicht trainierten Situationen, richtig (sicher) zu reagieren. Sie schützen sich und andere durch ihr umsichtiges Handeln vor Gefahren für die Informationssicherheit. Sie melden mögliche Sicherheitsvorfälle oder ungewöhnliches Verhalten ohne Zögern an das Fachpersonal und tragen somit wesentlich dazu bei, dass schnell weitere Maßnahmen zum Schutz der Organisation und ihrer Mitglieder getroffen werden können und Schaden verhindert werden kann.

Häufig werden Mitarbeitende für Informationssicherheitsvorfälle verantwortlich gemacht. Da das IT-Personal Sicherheitsupdates nicht schnell genug eingespielt hat, konnten Kriminelle eine Software-Schwachstelle ausnutzen. Eine Mitarbeiterin fällt auf eine Phishing-Nachricht herein, weil sie unvorsichtig war. Sensible Daten konnten abfließen, weil ein Kollege sein Passwort weitergegeben hat. Fast jedes unerwünschte Ereignis kann auf menschliches Versagen zurückgeführt werden. Der Mensch steht der Informationssicherheit im Weg.

Gemäß dieser Logik können Informationssicherheitsverstöße vermieden werden, wenn das Verhalten der Menschen überwacht und vor allem eingeschränkt wird. Es sollte viel automatisiert werden, und technische Sicherheitslösungen sind organisatorischen oder personellen Maßnahmen vorzuziehen. Es müssen Richtlinien für richtiges und falsches Verhalten aufgestellt und diese streng durchgesetzt werden. Als Reaktion auf Vorfälle ist es wichtig, die Schuldigen auszumachen, sie zu bestrafen und mehr Training zu verordnen.

In Wirklichkeit gibt es bei Informationssicherheitsvorfällen häufig mehrere Ursachen. Der Mensch trägt sicherlich in vielen Szenarien dazu bei, dass etwas Ungeplantes oder Ungewolltes passiert, aber dies ist nicht die ganze Geschichte. Unternehmen

und Organisationen sind soziotechnische Systeme, und diese sind komplex, hochgradig interaktiv und unvorhersehbar; und mehrere Faktoren führen zusammen zu unerwünschten Ereignissen (Ebert et al., 2023; Klipper, 2022; Zimmermann & Renaud, 2019, S. 11).

Die Sicherheitswissenschaft (Safety Science) beschäftigt sich schon deutlich länger mit dem „Faktor Mensch“. Dort hat ein Umdenken längst stattgefunden. In den letzten Jahren wird verstärkt untersucht, wie der menschliche Faktor zum Erfolg in sicherheitsrelevanten Betriebsumgebungen beitragen kann. Forschende fanden heraus, dass in hochkomplexen Systemen (z. B. in der Luftfahrtkontrolle) deutlich weniger Unfälle passieren, als zu erwarten wäre. Flexibilität, Freiheit und die Fähigkeit der Mitarbeitenden, auf unbekannte Situationen zu reagieren, haben zu diesem Plus an Sicherheit beigetragen.

Ähnlich wie in der Sicherheitswissenschaft sollte auch in der Informationssicherheit der Mensch nicht mehr als Problem, sondern als Teil der Lösung angesehen werden. Zimmermann und Renaud (2019) schlagen dieses neue Paradigma – **Humans as Solution** – mit folgenden Prinzipien vor:

- Menschen sind integraler Bestandteil und unverzichtbar für das Funktionieren von soziotechnischen Systemen und tragen damit zur Sicherheit bei.
- Die Unvorhersehbarkeit von menschlichen Handlungen ist eine Stärke, da sie häufig zu normalen Abläufen und deren Erfolg beiträgt und nur selten zu Fehlern führt. Werden Menschen durch Automatisierung aus dem System „eliminiert“, können sie nicht aktiv zum Erhalt und zur Verbesserung der Sicherheit beitragen.
- Menschen versuchen grundsätzlich, keine Fehler zu machen. Halten sie sich nicht an Sicherheitsregeln, dann haben sie meist einen guten Grund dafür, z. B., dass die Regeln sie in der Ausübung ihrer eigentlichen Tätigkeit behindern. Daher sollten Menschen beim Erstellen der Sicherheitsregeln mit einbezogen werden.
- Sicherheitsvorfälle sollten untersucht werden, um daraus etwas zu lernen, und nicht, um Schuldige zu finden.
- Statt sich über Fehler zu ärgern, sollte man auf Erfolge stolz sein. Beispielsweise fallen fast 80 % der Angestellten NICHT auf Phishing herein.

Menschen sind nicht nur unverzichtbar beim Erkennen und Melden von Sicherheitsvorfällen, sondern auch erfolgreicher und effizienter als Tools (Burkhead, 2014, S. 114 f; Heartfield & Loukas, 2018). Anwendende merken, dass sich ihr Rechner ungewöhnlich verhält, und melden dies an die Verantwortlichen. Sie können den IT-Helpdesk innerhalb weniger Sekunden darauf hinweisen, dass sie eine Phishing-E-Mail bekommen haben. Sie sprechen Personen auf dem Firmengelände an, wenn diese keinen Ausweis tragen, oder sie geben gefundene USB-Sticks sowie andere dubiose Datenträger ab.

Für das Paradigma *Human as Solution* muss der Mensch als elementarer Bestandteil des Informationssicherheitskonzepts verstanden werden, seine Bedürfnisse, Fähig-

keiten und Eigenschaften müssen in das Design sicherer Lösungen einbezogen werden. Als Teil des Paradigmenwechsels sollten die Ursache für menschliches Handeln erforscht, die Komplexität der Einflussfaktoren gewürdigt und die Wechselwirkungen verstanden werden. Statt zu versuchen, Risiken durch zu starre und einschränkende Sicherheitsmaßnahmen zu vermeiden, sollten die Widerstandsfähigkeit und Flexibilität gestärkt werden (Zimmermann & Renaud, 2019, S. 19).

Die Awareness der Mitarbeitenden für Informationssicherheit ist ein zentraler Baustein für ein sicheres System. Mitarbeitende müssen befähigt werden, ihrer wichtigen Rolle gerecht zu werden. Sie sollen sich nicht stur an Regeln halten, sondern eigenständig entscheiden und so handeln, wie es im Moment erforderlich ist. Eine „Mindfulness“ oder gewisse Resilienz erlaubt es ihnen, sich auch in unbekannten, nicht vorab trainierten Situationen richtig zu verhalten. Das versetzt sie in die Lage, dazu beizutragen, ein möglicherweise gefährdetes System wieder in einen stabilen Zustand zu bringen. Dürfen sie sich am Thema Informationssicherheit aktiv beteiligen und Verantwortung für ihre Handlungen übernehmen, führt dies zu bewusstem und sichererem Verhalten (Adams & Sasse, 1999, S. 45; Sasse et al., 2023, S. 250).

Dieses Plus an Verantwortung und ein Minus an strengen Vorgaben können dazu führen, dass es vorsätzlich böswillig handelnden Personen einfacher gemacht wird, Organisationen Schaden zuzufügen (Zimmermann & Renaud, 2019, S. 24). Dieses zusätzliche Risiko steht allerdings im Kontrast zu der Tatsache, dass nicht mehr allen Personen in den Organisationen per se unterstellt wird, dass sie Schaden verursachen wollen. Alle Personen zu gängeln, obwohl sich nur ein sehr kleiner Teil absichtlich schadhafte verhält, ist unverhältnismäßig und zeugt nicht von einer förderlichen Sicherheitskultur.

9.2 Der Mensch als Bedrohung

Anwendende, die unbewusst oder bewusst Richtlinien ignorieren, sich am Arbeitsplatz und außerhalb der Organisation unbedacht oder fahrlässig verhalten, können die Informationssicherheit der eigenen Organisation gefährden. Die Gründe für ein derartiges Verhalten sind vielfältig, und in vielen Fällen kann den Anwendenden nicht einmal ein Vorwurf gemacht werden. Mitarbeitende konzentrieren sich auf die Erledigung ihrer eigentlichen Aufgaben, und das für die Einhaltung von Sicherheitsmaßnahmen erforderliche Verhalten stellt oft ein Hindernis dar.

Dieser Abschnitt zeigt zunächst typische Beispiele und Szenarien aus dem Unternehmensalltag, in welchen Mitarbeitende mit ihrem Verhalten die Sicherheit von Unternehmensinformationen beeinflussen können. Im Anschluss werden mögliche Gründe oder Ursachen für unsicheres Verhalten aufgezeigt. Es ist wichtig, diese Gründe zu kennen und zu verstehen, damit Menschen keine „Bedrohung“ sind, sondern zu einem „Sicherheitsfaktor“ werden.

9.2.1 Sicheres und unsicheres Verhalten

Im Unterschied zu IT-Sicherheit umfasst Informationssicherheit auch Informationen, die außerhalb von IT-Systemen existieren, sich also z. B. auf Papier befinden oder in den Köpfen der Mitarbeitenden. Informationssicherheit will jegliche Art von Information schützen, egal auf welchem Medium sie gespeichert, verarbeitet oder übertragen wird. Der Mensch spielt hierfür eine wichtige Rolle.

Typische **Gefährdungen** für die Informationssicherheit führt das Bundesamt für Sicherheit in der Informationstechnik im IT-Grundschutz auf (BSI, 2023). Für einige dieser Gefährdungen liegt (u. a.) fehlerhaftes Verhalten von Menschen zugrunde, darunter beim Verlust von Geräten oder Dokumenten, bei der Offenlegung schützenswerter Informationen, bei der fehlerhaften Nutzung von Systemen oder beim Datenverlust. Anwendende haben somit eine große Verantwortung. Die Sicherheit der Informationen und Informationssysteme des Unternehmens hängt auch davon ab, dass sie sich richtig, also **informationssicherheitskonform** verhalten.

„Falsches“ oder „richtiges“ Verhalten sind allerdings nicht fest definiert. Es gibt allgemeine Verhaltensweisen, die als richtig oder falsch gelten, im Detail können sich die Verhaltensweisen je nach Sicherheitsstrategie der Organisation unterscheiden und auch im Laufe der Zeit ändern. Bis vor ein paar Jahren galt das regelmäßige Ändern des Passworts als wichtige Sicherheitsmaßnahme. Inzwischen ist bekannt, dass dieses Ändern nicht notwendig ist und der Sicherheit sogar eher schadet.

Idealerweise schreibt jede Organisation ihren Mitgliedern in Form von Richtlinien vor, welches Verhalten als richtig (sicher) und welches als falsch (unsicher) angesehen wird.

Die im Folgenden dargestellten Szenarien zeigen Beispiele für sichere und unsichere Verhaltensweisen bzw. den Einfluss des menschlichen Handels auf die Informationssicherheit.

Bildschirm Sperre

Um den unberechtigten Zugriff auf den eigenen Rechner und damit auf die dort abgelegten Dokumente oder die verbundenen Netzlaufwerke und Informationssysteme zu verhindern, sollten die Anwendenden beim Verlassen des Arbeitsplatzes den Bildschirm ihres Rechners sperren. Auch Smartphones oder andere mobile Endgeräte, welche am Arbeitsplatz zurückgelassen werden, sollten gesperrt werden.

Die Anwendenden müssen also bei jedem Verlassen des Arbeitsplatzes zunächst daran denken, die Bildschirm Sperre zu aktivieren – auch dann, wenn ihre Abwesenheit vermutlich nur sehr kurz sein wird. Dazu müssen sie wissen, wie sie die Sperre aktivieren können. Bei ihrer Rückkehr sollten sie sich an das Passwort oder die PIN zum Entsperren des Geräts erinnern.

Umgang mit sensiblen Informationen

Anwendende müssen sich bewusst sein, wie sensitiv und schützenswert die Informationen sind, mit denen sie arbeiten. Meist gibt es im Unternehmen verschiedene Schutzstufen von *öffentlich* über *intern* und *vertraulich* bis zu *geheim*. Je nach Einstufung gelten andere Schutzmaßnahmen. Beispielsweise sollten vertrauliche Informationen nur verschlüsselt per E-Mail versendet werden. Geheime Informationen dürfen nur nach ausdrücklicher Genehmigung an andere Personen über klar definierte Kanäle weitergegeben werden.

Häufig sind sich Mitarbeitende gar nicht bewusst, wie wertvoll eine bestimmte Information sein kann, und posten z. B. in ihrem Social Media Account, dass sie sich über ihren bevorstehenden Urlaub in Südfrankreich freuen, wie genial es ist, dass die Chefin gerade auf einer Weiterbildung in Hamburg ist, oder dass der Kollege aus der IT (Herr Scheuer) heute besonders nett und hilfsbereit war. Diese vermeintlich harmlosen Informationen können Social Engineers aber bereits helfen, eine glaubwürdige Geschichte zu erfinden, mit deren Hilfe sie problemlos an weitere sensible Informationen kommen (vgl. Abschnitt 9.3).

Egal ob privat oder geschäftlich, wenn die Anwendenden außerhalb des Unternehmens unterwegs sind, ist weiterhin auf Informationssicherheit zu achten. Sie sollten sich bewusst sein, was sie in der Öffentlichkeit, z. B. im Zug oder im Café, erzählen und wer mithören kann, wenn geschäftliche Dinge am Telefon besprochen werden. Ebenso sollten sie beachten, ob der Bildschirminhalt eingesehen werden kann, besonders, wenn sie ihre Login-Daten eingeben.

Schädliche E-Mails

E-Mails werden häufig genutzt, um Schadsoftware zu verbreiten und sie auf den Rechnern der Adressierten zu installieren. Über Phishing-Mails werden die Login-Daten oder Kreditkartennummern der Adressierten ausgespäht. Per E-Mail werden auch manipulierte Rechnungen versendet, um so das Opfer zu verleiten, Geld auf ein falsches Bankkonto zu überweisen.

Die Adressierten müssen sich zunächst dieser Missbrauchsversuche bewusst sein. Sie sollten wachsam und skeptisch sein und theoretisch alle eingehenden E-Mails auf ihre Glaubwürdigkeit hin untersuchen. Wird eine E-Mail als potenziell schädlich eingestuft, müssen die Adressierten richtig reagieren; also keine Links anklicken oder Anhänge öffnen, die E-Mail löschen oder besser an den IT-Helpdesk weiterleiten. Eine telefonische Nachfrage bei der vermeintlichen absendenden Person kann ebenfalls Klarheit über die Authentizität der E-Mail bringen.

Verwenden von USB-Sticks

Ein manipulierter USB-Stick, der an einen Rechner angeschlossen wird, kann unbemerkt Schadsoftware installieren oder Passwörter mitlesen. Anwendende sollten USB-Datenträger daher nur dann verwenden, wenn sie genau wissen, woher sie stammen, und wenn sie sich absolut sicher sind, dass sie keine Schadsoftware enthalten. Im Zweifelsfall sollten sie also lieber auf die Verwendung von USB-Sticks verzichten. Gefundene USB-Sticks oder auch Werbegeschenke sollten zur Prüfung dem IT-Helpdesk übergeben werden.

Sicherheitsverstöße und -vorfälle melden

Werden potenzielle Gefährdungen für die Informationssicherheit schnell erkannt, ist es meist möglich, durch rasches Handeln und Einleiten von Gegenmaßnahmen einen Sicherheitsvorfall zu verhindern oder negative Konsequenzen abzumildern. Wachsame und skeptische Mitarbeitende tragen entscheidend dazu bei, dass ungewöhnliche Aktivitäten erkannt und an die Verantwortlichen gemeldet werden.

Das Weiterleiten von potenziellen Phishing-E-Mails an den IT-Helpdesk und das Abgeben von gefundenen Wechseldatenträgern gehören dazu. Anwendende können auch ungewöhnliches oder verdächtiges Verhalten ihres Rechners bemerken und melden. Dieses Verhalten kann auf eine Infektion mit einer Schadsoftware hinweisen.

9.2.2 Gründe für unsicheres Verhalten

Anwendende verhalten sich nicht immer richtig oder sicher. Die Gründe und Ursachen dafür sind vielfältig und manchmal gut nachvollziehbar. In der Literatur werden u. a. folgende Gründe genannt: falsche Annahmen treffen, fehlende Alternativen, fehlendes Bewusstsein für Gefahren, Irrtum, Leichtsinn, mangelnde Erfahrung, Nachlässigkeit, Unachtsamkeit, unbeabsichtigte Fehler, Unkenntnis über die Folgen des eigenen Handelns, Unwissenheit, unzureichende Schulungen und Zeitmangel (Helisch, 2009, S. 16 f; Weber et al., 2019, S. 5 f; Whitman & Mattord, 2019, S. 23). Beispielhafte Aussagen von Betroffenen zu diesen Punkten sind (Beris et al., 2015):

- Wo stellen Sie Ihren Laptop zu Hause hin? ... Haben Sie keine Angst, dass Ihre Kinder etwas damit anstellen? ... – Nein, ich habe eher Angst, dass sie etwas mit meinem eigenen Laptop anstellen, den ich dann ersetzen müsste.
- Ich weiß nicht, wie die Anleitung zur Wiederherstellung von Passwörtern lautet, nein.
- Ich erstelle Passwörter, die so einfach sind, wie es das System zulässt, und ich schreibe sie in einem Word-Dokument auf. ... Ich kann sie mir nicht alle merken ...

- Ich lese die Richtlinie, wenn sie mir zugeschickt wird, aber ... ich muss sie nicht auswendig lernen, also lerne ich sie nicht auswendig.
- Ich denke, die Menschen können die Gründe für die Regeln verstehen, aber wenn sie in der Praxis nicht immer funktionieren, werden sie ignoriert.
- Ich komme auf Arbeit und tue das, was alle anderen auch tun.

Unsichere Verhaltensweisen, Fehler und der Einsatz von Umgehungsstrategien werden auch auf fehlende Usability (Nutzbarkeit) von Informationssystemen oder Sicherheitsmaßnahmen zurückgeführt. Die sicherste Maßnahme ist nicht sicher, wenn deren Berücksichtigung eine zu große Hürde für die Anwendenden darstellt, sie also nicht nutzbar bzw. umsetzbar ist. Die Vorgabe, möglichst lange Passwörter zu verwenden, führt dazu, dass die Passwörter aufgeschrieben und in der Nähe des Schreibtischs postiert werden, da die Nutzenden nicht in der Lage sind, sich diese langen Passwörter zu merken.

Sicherheitsmechanismen werden häufig nicht aus Sicht der Nutzenden entwickelt. Menschen müssen ohne große mentale Anstrengung, aufwendiges Training und zeitliche Zusatzbelastung in der Lage sein, Informationssysteme sicher zu bedienen. Eine Empfehlung lautet, sie in den Entwurf von Systemen und Sicherheitsmaßnahmen einzubeziehen (Lauer & Kuntze, 2022, S. 38; Sasse et al., 2023, S. 250; Zimmermann & Renaud, 2019, S. 17).

Sind Sicherheitsmaßnahmen und deren Wirkungsweise bzw. deren Nutzen für die Anwendenden nicht verständlich, werden sie meist versuchen, die Maßnahmen zu umgehen oder zu ignorieren. Viele Nutzende haben gelernt, dass es kaum Konsequenzen hat, wenn sie Sicherheitswarnungen zu fehlenden Zertifikaten, unsicheren Webseiten oder möglicherweise infizierten Dateien ignorieren und einfach „wegklicken“ (Pfleeger et al., 2014).

Sicherheitsmaßnahmen werden besonders dann umgangen, wenn diese Maßnahmen die Anwendenden bei ihrer eigentlichen Arbeit behindern oder zusätzlichen Aufwand bedeuten (siehe Beutement et al., 2008). Wird die Nutzung von USB-Sticks zum Datenaustausch verboten, werden geschäftliche Daten über private Cloud-Dienste geteilt. Sicherheit hat für die Anwendenden meist nicht den Stellenwert, den sich die Verantwortlichen für Informationssicherheit wünschen würden. Funktionalität, Geschwindigkeit, Kompatibilität, Nutzbarkeit oder Produktivität haben bei Anwendenden eine höhere Priorität (Dodier-Lazaro et al., 2017, S. 2 f; Pfleeger et al., 2014). Sie umgehen Sicherheitsmaßnahmen, um Deadlines einzuhalten, die Ausführung von Aufgaben zu erleichtern oder schneller mit Kolleginnen und Kollegen zu interagieren. Ein Verlust an Produktivität zugunsten von mehr Sicherheit wird nur in begrenztem Maße hingenommen (Beyer et al., 2015; Sasse et al., 2023).

Aus welchen Gründen die Empfangenden einer Phishing-Mail auf den darin enthaltenen Link geklickt haben, zeigt Bild 9.1. Befragt wurden in dieser Untersuchung ca.

2000 Mitarbeitende aus den USA und UK, die zugegeben haben, auf Phishing hereingefallen zu sein (Statista, 2021, S. 12). Der dafür am häufigsten genannte Grund war Ablenkung. In eine ähnliche Richtung gehen die Gründe Müdigkeit und Unaufmerksamkeit. Aus den anderen genannten Gründen geht hervor, dass die Angreifenden die Opfer davon überzeugen konnten, dass die E-Mails legitim sind oder dass sie von einer vorgesetzten Person oder von einer vertrauenswürdigen Marke zu stammen schienen.

Reasons employees click on phishing emails in 2020

Why employees click on phishing emails in 2020

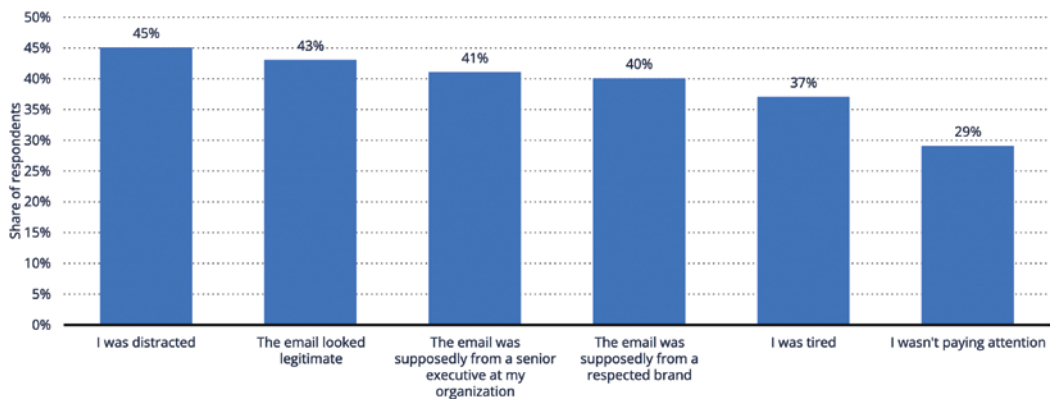


Bild 9.1 Die häufigsten Gründe, aus denen Mitarbeitende auf Links in Phishing-Mails klicken (Statista, 2021, S. 12)

Manchmal sind gut gemeinte Sensibilisierungsmaßnahmen Ursache für unsicheres Verhalten. Mit Phishing-Simulationen sollen die Mitarbeitenden für den Ernstfall trainiert werden. Es besteht aber die Gefahr, dass Mitarbeitende aus Neugier auf eine vermeintliche Trainings-E-Mail klicken. Oder sie sind derart genervt von diesen Mails, dass sie generell negativ auf jegliche Schulungs- und Sensibilisierungsmaßnahmen reagieren. Gleiches kann bei verpflichtenden und schlecht gemachten E-Learning-Kursen passieren. Mitarbeitende sollen einmal jährlich die Online-Schulung zur Informationssicherheit durchlaufen. Diese ist seit Jahren unverändert, die immer gleichen Fragen kennt man auswendig. Es ist nur lästig, dieses Training durchzuklicken. Und statt sensibilisierter für das eigene Verhalten zu werden, steigt der Frust auf alles, was mit Informationssicherheit zu tun hat.

Die individuellen Gründe und Ursachen zu kennen, warum Menschen sich nicht an Sicherheitsmaßnahmen halten, ist die Voraussetzung, um passende Gegenmaßnahmen zu ergreifen. Statt einer „One-Size-Fits-All“-Mentalität soll gezielt da angesetzt werden, wo die Ursachen für ein potenzielles Fehlverhalten liegen.

9.3 Der Mensch als Opfer

Angreifende entscheiden sich häufig dafür, technische Sicherheitsmaßnahmen zu umgehen, indem sie gezielt den Menschen angreifen bzw. ausnutzen. Als Social Engineering werden die meisten Angriffsformen bezeichnet, bei denen Menschen geschickt manipuliert werden. Phishing-Mails dienen beispielsweise dazu, Passwörter abzugreifen, oder Social Engineers geben sich als Technikpersonal aus, um Zugang zu einem Gebäude oder Raum zu erhalten.

Dieser Abschnitt erläutert, warum Menschen so leicht Opfer von Manipulation werden. Instrumente, Taktiken und Techniken des Social Engineerings werden vorgestellt und typische Formen von Social Engineering wie (Spear) Phishing, CEO Fraud, Impersonating und Watering Hole Attacks anhand von Beispielen erläutert (vgl. Abschnitt 9.3.2). Welche psychologischen Tricks Social Engineers einsetzen, um ihre Opfer zu manipulieren, erklärt Abschnitt 9.3.3.

9.3.1 Social Engineering

Social Engineering ist eine ernst zu nehmende Bedrohung für die Informationssicherheit. Social Engineering nutzt gezielt menschliche Schwächen, um Zugang zu sensiblen Informationen oder Systemen zu erlangen. Social Engineering beschreibt die gezielte Manipulation von Menschen. Menschen sollen so beeinflusst werden, dass sie im Sinne der Social Engineers und nicht notwendigerweise in ihrem eigenen Interesse handeln (Hadnagy & Wilson, 2011). Das sogenannte Human Hacking ist die am meisten verwendete Angriffstechnik auf den Menschen.

Manipulierte USB-Sticks oder Phishing-E-Mails sind typische Formen von Social Engineering. Ein gefundener USB-Stick soll bei den Findenden Neugier und Hilfsbereitschaft wecken. Sie verbinden den USB-Stick mit ihren Rechnern, um zu schauen, was sich darauf befindet – schon installiert sich eine Schadsoftware. Eine Phishing-E-Mail will die Adressierten dazu verleiten, ihre Logindaten oder Kreditkartennummern auf einer Webseite der Angreifenden einzugeben. Beides sind Handlungen, die definitiv gegen die Interessen der Opfer verstoßen.

Aber auch gezielte Informationsbeschaffung zur Vorbereitung eines Angriffs ist Teil von Social Engineering. Je mehr die Human Hacker über ihre Opfer wissen, desto besser können sie ihren Angriff planen und durchführen. Für das Sammeln von Informationen nutzen Social Engineers zunächst meist öffentlich verfügbare Informationen. Daher wird es auch als Open Source Intelligence, kurz **OSINT**, bezeichnet.

Als Quellen für die Informationssuche können zahlreiche Webseiten, Social-Media-Plattformen und Internettools verwendet werden. Zudem nutzen Social Engineers nichttechnische Mittel, wie Shoulder Surfing, Dumpster Diving und Eavesdropping.

Shoulder Surfing bedeutet, einer Person über die Schulter oder auf den Bildschirm bzw. die Tastatur zu schauen, während sie etwas in ihren Computer oder ihr Smartphone eingibt, mit dem Ziel, z. B. Logindaten oder andere sensible Informationen abzulesen. Unter **Dumpster Diving** versteht man das Herumwühlen im Müll. Social Engineers versuchen so, über mehr oder weniger öffentlich aufgestellte Müllcontainer an unachtsam und unsachgemäß entsorgte Informationen oder Datenträger des Unternehmens zu kommen. **Eavesdropping** bedeutet nichts anderes, als Personen zu belauschen, z. B. bei öffentlich geführten Gesprächen, Telefonaten oder Videokonferenzen.

Ausgestattet mit den gesammelten Informationen bereiten die Social Engineers in der Regel einen sogenannten **Pretext** (deutsch in etwa „Vorwand“) vor. Das sind eine gefälschte Person und Geschichte, die sie benutzen, um ihre Ziele zu erreichen: die Chefin auf Dienstreise, die hilfsbereite IT-Administratorin, ein interessierter Forschungspartner oder der Hilfe suchende Praktikant. Die Angreifenden nehmen persönlich, per E-Mail oder telefonisch Kontakt mit ihren Opfern auf und erzählen eine erfundene Geschichte. So braucht die angebliche IT-Admin ein Passwort oder einen Zugang zum PC, der erfundene Praktikant ganz schnell einen Ausdruck oder die vermeintliche Chefin sofort eine Überweisung auf ein ausländisches Konto, um eine geheime geschäftliche Transaktion durchzuführen. Je besser die vorab gesammelten Informationen, desto besser passt der Pretext. Wirkt er authentisch und plausibel, wird das Opfer wahrscheinlich darauf hereinfallen.

Human Hackers kennen sich gut mit Psychologie aus. Sie verstehen, wie Menschen „funktionieren“, und sind in der Lage, sie zu ihren Gunsten zu beeinflussen. Beispielsweise vertrauen Menschen Autoritätspersonen fast blind und stellen deren Entscheidungen nicht unbedingt infrage. Social Engineers nutzen diese für Menschen typischen angeborenen oder antrainierten Verhaltensweisen (vgl. Abschnitt 9.3.3) gezielt zu ihrem Vorteil aus.

9.3.2 Instrumente im Social Engineering

Social Engineers nutzen zahlreiche Instrumente, Techniken und Methoden für ihre Angriffe. Phishing, also das „Angeln“ nach sensiblen Informationen wie Passwörtern, wird beim Social Engineering am häufigsten eingesetzt. Weitere Angriffsszenarien und Methoden sind z. B. Reverse Social Engineering, Tailgating und Watering Hole Attacks.

Phishing

Die bekannteste und erfolgreichste Social-Engineering-Technik ist Phishing. Phishing ist ein Versuch, Zugang zu sensiblen Informationen zu erhalten oder die Phishing-Opfer zu gefährlichen Handlungen zu verleiten, wie z. B. Schadsoftware zu installieren.

Ein gängiger Ansatz für Phishing-Angriffe ist das Versenden von E-Mails an mehr oder weniger zufällige E-Mail-Adressen. Die betrügerische E-Mail enthält einen Link zu einer gefälschten Webseite und einen Text, in dem die Opfer aufgefordert werden, dem Link zu folgen. Geben die Opfer ihre persönlichen Daten in das Formular auf der Webseite ein, haben die Angreifenden Zugriff auf die eingegebenen Informationen. Bei einer weiteren typischen Phishing-Variante enthält die E-Mail ein Dokument im Anhang, welches einen Schadcode enthält. Beim Öffnen des Dokuments installiert sich die Schadsoftware auf dem Rechner des Opfers. Es kann sich beispielsweise um einen Keylogger handeln, der alle auf dem Rechner eingegebenen Daten protokolliert und an die Angreifenden sendet.

Phishing-Nachrichten werden nicht nur klassisch per E-Mail, sondern auch über andere Kanäle verschickt, z. B. Social Media, Messenger-Dienste und SMS („Smishing“, vgl. Bild 9.2). Daneben gibt es Phishing auch per Telefon („Vishing“).

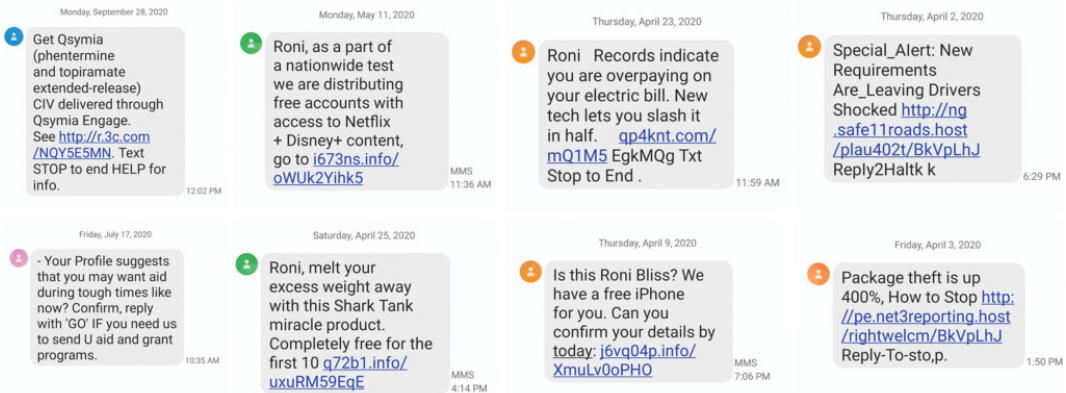


Bild 9.2 Beispiele für Smishing-Nachrichten (Crane, 2020)

Spear Phishing nimmt gezielt bestimmte Personen oder eine bestimmte Organisation ins Visier. Für die Vorbereitung eines solchen Angriffs ist eine intensive Informationsbeschaffung notwendig. Die Angreifenden nutzen in der Phishing-Nachricht dann die gefundenen Informationen, wie z. B. Anrede, Absenderadresse, hierarchische Beziehungen und vermeintliche Insiderinformationen. Dadurch werden die Nachrichten glaubhafter und sind schwerer als Betrug zu erkennen. Ein Spear-Phishing-Angriff, der speziell auf hochrangige Ziele einer Organisation wie leitende Angestellte, CEO oder CFO abzielt, wird **Whaling** genannt (von Whale-Phishing).

CEO Fraud

Beim CEO Fraud (auch Business-E-Mail-Compromise-/Fake-President-Betrug) erhalten gezielt ausgewählte Mitarbeitende aus der Finanzabteilung eine E-Mail. Vermeintlich

stammt diese Mail von einer hochrangigen Führungsperson. Die Nachricht fordert sie dazu auf, einen hohen Geldbetrag auf ein (angebliches) Bankkonto des Unternehmens, das sich typischerweise im Ausland befindet, zu überweisen. Aufgrund vorheriger Informationsbeschaffung sieht die Nachricht tatsächlich aus, als stamme sie von der Geschäftsleitung. Wird die darin enthaltene Anweisung ausgeführt, ist das Geld meist unwiederbringlich verloren.

Watering Hole Attack

Der Name des Watering-Hole-Angriffs leitet sich vom Wasserloch ab, welches die Tiere der Savanne oder Wüste am Morgen aufsuchen, um Wasser zu trinken. Die Opfer eines Watering-Hole-Angriffs sind meist bestimmte Gruppen mit ähnlichem Surfverhalten, wie Unternehmen, Branchen oder Regionen. Die Angreifenden ermitteln, welche Webseiten die Zielpersonen regelmäßig besuchen. Sie infizieren diese Webseiten dann mit bösartigem Code. Die Ziele werden kompromittiert, wenn sie die Webseite aufrufen, Software (Malware) herunterladen oder auf (bösartige) Links klicken.

Beispielsweise stellen die Angreifenden eine Software über eine Webseite zur Verfügung und geben vor, dass die Software das kostenlose Herunterladen und Anschauen von Pornobildern oder -videos ermöglicht.

Reverse Social Engineering

Beim Reverse Social Engineering wird das Opfer dazu verleitet, von sich aus Kontakt mit den Angreifenden aufzunehmen. Ein typischer Reverse-Social-Engineering-Angriff läuft in drei Schritten ab (Allen, 2006). Zunächst bieten die Social Engineers ihre Hilfe an, falls es zu Problemen kommen sollte. Das tun sie z. B., indem sie ihre Visitenkarte beim Opfer hinterlassen oder ihre Kontaktdaten in einer Fehlermeldung angeben. Dann verursachen sie absichtlich die bereits angekündigten Probleme, indem sie beispielsweise den Anschein erwecken, dass ein System kompromittiert ist oder nicht richtig funktioniert. Im letzten Schritt meldet sich das Opfer freiwillig bei den Social Engineers, die dann bei der Behebung des vermeintlichen Problems „helfen“. Dabei installieren sie z. B. eine Schadsoftware auf dem Rechner des Opfers. Die Problemlösung gibt ihnen auch einen scheinbar legitimen Grund, dem Opfer alle möglichen Fragen zu stellen.

Nach einem ähnlichen Prinzip funktioniert **Scareware**. Den Nutzenden wird beim Surfen im Internet suggeriert, dass ein Problem mit ihrem Computer besteht, beispielsweise eine Schadsoftware-Infektion oder eine Fehlfunktion des Betriebssystems. Oder es wird mit einem wichtigen Sicherheits-Update geworben. Vertrauen die Anwendenden diesen Meldungen, installieren sie die angebotene Software und infizieren dadurch selbst das System mit einer Schadsoftware.

Tailgating & Baiting

Bei den bisher beschriebenen Instrumenten besteht meist nur indirekt über (elektronische) Hilfsmittel Kontakt zwischen Social Engineers und deren Opfern. Es gibt einige Methoden, die zumindest zeitweise eine physische Anwesenheit der Social Engineers oder sogar direkten Kontakt erfordern. Neben den oben beschriebenen Methoden Dumpster Diving, Shoulder Surfing, Eavesdropping und bestimmten Formen des Pretexting sind dies Tailgating und Baiting.

Beim **Tailgating** oder **Piggybacking** (deutsch in etwa „sich an jemanden dranhängen“) lässt eine berechnete Person eine nicht autorisierte Person in einen nicht öffentlich zugänglichen Bereich eines Gebäudes hinein. Das Opfer hält z. B. einem sehr freundlich lächelnden vermeintlichen Kollegen aus Höflichkeit die Tür zum Bürogebäude offen. Vor allem in größeren Organisationen kennen sich nicht alle untereinander, und wenn das Erscheinungsbild des Social Engineers passend ist, besteht eine große Wahrscheinlichkeit, dass diese Technik funktioniert.

Die Technik **Baiting** (deutsch „ködern“) wird beim Trick mit dem USB-Stick eingesetzt. Die angreifende Person hinterlässt einen manipulierten USB-Stick an einem Ort, an dem er von den Opfern wahrscheinlich gefunden wird, z. B. auf dem Parkplatz. Der USB-Stick ist mit dem Logo des Zielunternehmens oder anderen attraktiven Elementen versehen, um die Opfer dazu zu verleiten, den Stick mitzunehmen und in den Computer zu stecken. Nach dem Einstecken wird der bösartige Code automatisch ausgeführt.

9.3.3 Psychologische Tricks

Menschen reagieren auf bestimmte „Trigger“ (Auslöser) automatisch mit einem bestimmten Verhalten. Diese menschlichen Verhaltensmuster haben sich im Laufe der Evolution gebildet, weil sie sich als vorteilhaft erwiesen haben. Dazu gehört, dass Menschen Autoritätspersonen vertrauen und deren Entscheidungen nicht hinterfragen. Zudem erwidern wir gerne Gefallen und sind hilfsbereit.

Diese Trigger sind grundsätzlich etwas Gutes. Social Engineers nutzen die menschlichen Verhaltensmuster jedoch als Schwachstellen aus. Die Opfer bemerken diese Manipulation meist nicht und haben während und nach dem Kontakt mit Social Engineers auch kein ungutes Gefühl.

Nobelpreisträger Kahnemann (2011) erklärt dieses automatische Verhalten damit, dass wir in zwei verschiedenen Systemen denken. System 1 arbeitet automatisch und schnell, weitgehend mühelos und ohne willentliche Steuerung („thinking fast“). Beispiele sind das Wahrnehmen von Größenunterschieden und einfache Berechnungen wie $1 + 1$. System 2 lenkt die Aufmerksamkeit auf die anstrengenden mentalen Aktivitäten, die auf bewusstes Denken angewiesen sind, z. B. komplexe Berechnungen („thinking slow“). Der Großteil unseres Denkens findet in System 1 statt. Alles andere wäre zu anstrengend. In System 2 hingegen konzentrieren wir uns nicht nur, wir können auch bewusst entscheiden.

Social Engineers nutzen das System 1 aus. Die Opfer können nicht willentlich entscheiden und denken nicht rational. Gegen Social-Engineering-Angriffe hilft bereits, zu wissen, dass es diese Trigger gibt, und ihren gezielten Einsatz zu erkennen. Wird der Manipulationsversuch erkannt, wird System 2 eingeschaltet und hilft beim besonnenen Reagieren.

Im Folgenden sollen fünf dieser psychologischen Prinzipien näher vorgestellt werden: Autorität; soziale Bewährtheit; Sympathie, Ähnlichkeit & Täuschung; Verpflichtung, Gegenseitigkeit & Konsistenz sowie Ablenkung (vgl. Cialdini, 2007; Ferreira et al., 2015; Stajano & Wilson, 2011; Weber, Schütz, Fertig et al., 2020).

Autorität

Menschen folgen Anweisungen von Autoritäten und stellen diese nicht infrage. Als Autoritätspersonen gelten bestimmte Personengruppen wie z. B. Lehrkräfte, Eltern, Polizei, ärztliches Personal, prominente Persönlichkeiten oder Führungskräfte. Autorität kann bei Personen auch durch Titel, Kleidung (vor allem Uniformen) oder Statussymbole wie teure Autos und Uhren ausgedrückt werden. Manche Institutionen werden als Autorität angesehen, wie Regierungsinstitutionen, Kirchen, Banken, Fernsehsender, aber auch bekannte Unternehmen wie Apple oder Amazon.

Autorität kann leicht gefälscht werden, indem die Symbole für Autorität verwendet werden. Bei Institutionen kann Autorität z. B. durch wichtig aussehende Logos oder Zertifikate hergestellt werden. Damit das Prinzip Autorität funktioniert, reicht es, dass die Opfer glauben, dass es sich bei der anfragenden Person oder Institution um eine Autorität handelt.

Im Social Engineering wird dieses Prinzip auf verschiedene Arten ausgenutzt. Ganz deutlich ist es beim CEO Fraud. Eine Anfrage von ganz oben hat mehr Aussicht auf Erfolg, weshalb sich Social Engineers als Pretext gerne eine Führungskraft aussuchen. Bei Anwendung des Autoritätsprinzips ist es weniger wahrscheinlich, dass die Opfer die Gültigkeit einer Anfrage (oder eines Angebots) infrage stellen. Auch Phishing-E-Mails, in denen die Adressierten von ihrer Bank aufgefordert werden, zur Legitimationsprüfung auf einer Webseite ihre Logindaten einzugeben, nutzen dieses Prinzip.

Soziale Bewährtheit

Besonders in unbekannten Situationen tendieren Menschen dazu, das Verhalten von anderen zu imitieren. Auf diese Weise reduzieren sie das Risiko, durch unangemessenes Verhalten (unangenehm) aufzufallen. Zudem fühlen sie sich so nicht verantwortlich für ihre Taten. Sie tun nur das, was die anderen auch tun.

Es gibt sehr negative Konsequenzen von sozialer Bewährtheit. Beispielsweise kann unterlassene Hilfeleistung auf dieses Phänomen zurückzuführen sein. Viele Personen beobachten ein Verbrechen oder einen Unfall, aber keiner unternimmt etwas. Tailgating funktioniert u. a. nach diesem Prinzip. Da niemand die unbekannte Person anspricht, kann sie das Gebäude problemlos betreten, selbst wenn sie einigen Angestellten auffällt.

Social Engineers nutzen soziale Bewährtheit, z. B. beim Phishing, insbesondere Social Media Phishing, um ihre Opfer von der Legitimität ihrer Anfrage zu überzeugen. Sie geben vor, dass bereits viele andere Personen, vor allem Freunde oder Kolleginnen und Kollegen, ihrem Anliegen bereits gefolgt sind. Oder Social Engineers nutzen soziale Bewährtheit, um Druck aufzubauen. Sie wissen, dass niemand gerne unangenehm auffallen möchte, und ermutigen ihre Opfer, „mit dem Strom zu schwimmen“. Mit einer Aussage wie „Alle anderen haben das Update schon installiert – Sie sind einer der Letzten, die noch die alte unsichere Version nutzen, also handeln Sie noch heute.“ setzen sie sie zudem unter Zeitdruck.

Sympathie, Ähnlichkeit und Täuschung

Menschen gewähren Bitten, die von Bekannten, Freundinnen und Freunden kommen, bereitwilliger als Bitten von fremden Personen. Das Prinzip von Sympathie, Ähnlichkeit und Täuschung funktioniert auch, wenn die bittstellende Person den Opfern sympathisch, attraktiv oder ähnlich ist.

Vor allem Ähnlichkeit lässt sich einfach und bewusst herstellen. Es reichen oft kleine (vermeintliche) Gemeinsamkeiten, wie ein Lieblings-Urlaubsziel, das gleiche Hobby, ähnliche Interessen und der Geburtsort, den man mit der anderen Person teilt. Auch ein bewusst gewählter Kleidungsstil kann Ähnlichkeit suggerieren. Sympathisch wird man anderen Personen, wenn man sie offen anlächelt, ihnen Komplimente macht, einen kleinen Gefallen tut oder versucht, attraktiv auf sie zu wirken.

Social Engineers versuchen, ihre Opfer so zu manipulieren, dass sie sie mögen und sich bei ihnen wohlfühlen. So ist es sehr viel wahrscheinlicher, dass sie mit ihren Forderungen erfolgreich sind. Ein Social Engineer kann ein Gespräch damit beginnen, dass er auf derselben Konferenz, demselben Musikkonzert oder in demselben Restaurant wie seine Zielperson war. Derartige Anknüpfungspunkte sind über die vorherige Informationsrecherche z. B. in sozialen Netzwerken leicht herauszufinden. Ist die Beziehung zum Opfer hergestellt, können die Social Engineers nach Informationen fragen oder das Opfer um einen kleinen Gefallen bitten.

Verpflichtung, Gegenseitigkeit & Konsistenz

Haben sich Menschen einmal für etwas entschieden, fühlen sie sich – sich selbst gegenüber – verpflichtet, ihrer Entscheidung bis zum (bitteren) Ende zu folgen. Beginnt eine Person mit scheinbar harmlosen Fragen ein Gespräch und entlockt dem Gegenüber ein „Ja“, so sagt die Konsistenz, dass weiter mit dieser Person gesprochen werden muss und auch weitere Fragen eher mit „Ja“ beantwortet werden. Ist es den Social Engineers also erst einmal gelungen, ihren Opfern eine noch so kleine Information zu entlocken, werden die Opfer auf weitere Nachfragen noch bereitwilliger antworten. Aus diesem Muster auszubrechen, erfordert enorme Willenskraft und mentale Anstrengung.

Ein anderes Verhaltensmuster ist die Reziprozität oder Gegenseitigkeit, die sich auf das Gefühl bezieht, einen Gefallen erwidern zu müssen. In unserer Gesellschaft wird

erwartet, dass man sich für etwas revanchiert, was man von einer anderen Person bekommen hat. Ein Geschenk oder eine Gefälligkeit kann auch mit einer Auskunft oder Informationsweitergabe erwidert werden.

Beim Phishing wird häufig das Prinzip der Konsistenz ausgenutzt. Hat sich das Opfer dazu entschieden, auf den in der E-Mail enthaltenen Link zu klicken, wird es weitere konsistente Handlungen durchführen, wie die Eingabe von Logindaten auf der gefälschten Webseite.

Ablenkung

Durch eine Ablenkung rutschen Menschen bei allen anderen Denkprozessen in System 1 (automatisch, ohne Nachdenken). Sie werden blind für alles andere, was um sie herum passiert, und können nicht mehr rational denken. Ablenkung kann auf viele verschiedene Arten erfolgen: durch Zeitdruck, Angst, Gier, Neugier, Überraschungen, Sehnsüchte und Wünsche, zu viele Informationen oder Knappheit. Typische Mittel zur Ablenkung sind vermeintliche Preisausschreiben oder Wettbewerbe, bei denen schnell reagiert werden muss, um etwas zu gewinnen, sowie zeitlich limitierte Angebote.

Ablenkung wird häufig in Kombination mit den anderen Prinzipien eingesetzt und ist häufig der Hauptgrund, warum die Anfragen der Social Engineers funktionieren. Die von den Social Engineers „verlorenen“ USB-Sticks machen die Findenden neugierig. Sie wollen wissen, was sich darauf befindet. Oder sie wollen helfen und den Stick der besitzenden Person zurückgeben. Bei vielen Phishing-Versuchen wird zeitlicher Druck auf die Opfer ausgeübt. Sie sollen z. B. schnell reagieren und ihr Passwort ändern, weil sie sonst nicht mehr auf ihr Nutzungskonto zugreifen können.

In Bild 9.3 wird sowohl zeitlich Druck aufgebaut als auch das Autoritätsprinzip genutzt, da der Footer suggeriert, dass die E-Mail von einer Regierungsorganisation kommt.

[EXT] Aufmerksamkeit



Bild 9.3 Phishing-E-Mail mit Ablenkung und Autorität (eigene Darstellung)

Smishing-Nachrichten enthalten vermeintliche Hilferufe der eigenen Kinder, deren Handy angeblich gestohlen wurde oder verloren gegangen ist, und lösen bei vielen Eltern Angst und Hilfsbereitschaft aus.

9.4 Menschen sensibilisieren

Menschen sind ein wichtiger Bestandteil des Informationssicherheitskonzepts jeder Organisation. Ihre Information Security Awareness (ISA) entscheidet darüber, wie gut sie diese Aufgabe meistern können. Die Awareness beschreibt den Grad der Sensibilisierung einer Person für Informationssicherheit. Sensibilisierte Menschen kennen Bedrohungen für die Informationssicherheit und entsprechende Gegenmaßnahmen. Sie fallen seltener auf Manipulationsversuche von Social Engineers herein. Sie wissen, wie sie sich richtig im Umgang mit Informationen und Informationssystemen verhalten, und verhalten sich auch tatsächlich so. Personen mit einer hohen Awareness sind ein Sicherheitsfaktor.

Mittels ISA-Maßnahmen können Menschen für Informationssicherheit stärker sensibilisiert werden. Abschnitt 9.4.1 beschreibt das Konzept Information Security Awareness und erklärt die zugrunde liegenden psychologischen Modelle. Die Modelle erklären nicht nur, was Awareness ist, sondern wie sie das Verhalten der Menschen beeinflusst (vgl. Abschnitt 9.4.2). Soll also das Verhalten der Menschen in Bezug auf Informationssicherheit verändert oder beeinflusst werden, führt der Weg über die Awareness. Da Awareness für jeden Menschen verschieden ist, müssen auch Maßnahmen zur Steigerung oder Förderung der Awareness individuell sein (vgl. Abschnitt 9.4.3).

9.4.1 Information Security Awareness

Information Security Awareness, auch Security Awareness oder einfach nur Awareness, beschreibt den Zustand des „Für-Informationssicherheit-Sensibilisiert-Seins“ oder den „Grad der Sensibilisierung“. Für Informationssicherheit sensibilisierte Menschen treffen richtige Entscheidungen. Sie sperren ihren Bildschirm, wenn sie den Arbeitsplatz verlassen, geben einen gefundenen USB-Stick beim IT-Helpdesk ab und sprechen die unbekannte Person an, die sich hinter ihnen ins Gebäude schmuggeln möchte, ohne einen Ausweis zu zeigen.

Den Zusammenhang zwischen dem Zustand Awareness und der Informationssicherheit zeigt Bild 9.4. Letztendlich ist Awareness „nur“ Mittel zum Zweck. Information Security Awareness (2) führt (hoffentlich) zu informationssicherem Verhalten (3) der Mitarbeitenden. Dieses trägt zur Sicherheit der Informationen und Informationssysteme (4) des Unternehmens bei. Und eine hohe Informationssicherheit unterstützt und ermöglicht den geregelten Ablauf der Geschäftsprozesse im Unternehmen, sodass dieses seine Ziele (5) verfolgen und erreichen kann. Awareness-Maßnahmen (1) wie Schulungen, Informationsveranstaltungen, Newsletter, Videos oder Flyer sollen dazu beitragen, den Grad der Sensibilisierung bei den Mitarbeitenden zu erhöhen, also die Awareness zu steigern oder zu fördern.

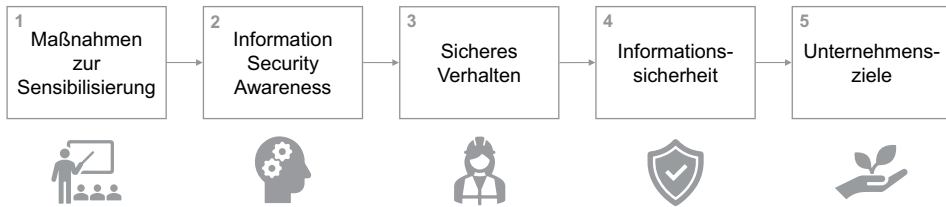


Bild 9.4 Zusammenhang zwischen Maßnahmen zur Steigerung der Awareness und Informationssicherheit (eigene Darstellung)

Nach Helisch (2009) ist Security Awareness ein Zusammenspiel der drei Faktoren Wissen, Wollen und Können. *Wissen* (Kognition) bedeutet, dass die Anwendenden wissen, welche Bedrohungen es für die Informationssicherheit gibt und wie sie diese Bedrohungen erkennen können. Zudem wissen sie, wie sie sich vor Bedrohungen schützen können. Der Faktor *Wollen* (Handlungsabsicht) beschreibt den Willen, sich gemäß diesem Wissen zu verhalten. *Können* (Organisation) bedeutet, dass das Unternehmen sicherstellt, dass sich die Mitarbeitenden überhaupt informationssicherheitskonform verhalten können. Dem gewünschten Verhalten dürfen keine Hindernisse oder Beschränkungen entgegenstehen.

Der Unterschied zwischen *Wissen* und *Wollen* ist für die Wirkung von Awareness auf die Informationssicherheit entscheidend (Pfeil zwischen 2 und 3 in Bild 9.4). Wissen ist eine Grundvoraussetzung für informationssicherheitskonformes Handeln. Ist kein oder wenig Wissen vorhanden, können die Menschen nicht gezielt, aber zufällig richtig handeln. Das richtige Wissen allein reicht aber nicht für richtiges Handeln, wie die Beispiele im folgenden Kasten zeigen. Nur das Wollen bzw. das Umsetzen dieses Wissens in richtiges Verhalten erhöht die Informationssicherheit in Unternehmen (4 in Bild 9.4).



Annika weiß, dass sie ihren Rechner jeden Abend herunterfahren, alle Unterlagen wegsperren und die Fenster und Türen schließen soll, bevor sie nach Hause fährt. Das Herunterfahren des Rechners ist ihr zu unbequem, da sie sonst am nächsten Morgen zu lange warten muss, bis er wieder hochgefahren ist. Sie vergisst, die Unterlagen in den Schrank zu legen und abzuschließen, da sie es heute eilig hat. Das Fenster lässt Annika eigentlich im Sommer immer gekippt, damit nachts etwas kühle Luft ins Büro kommt. Die Tür schließt sie nicht ab, da später ohnehin noch die Putzkraft ins Büro kommt, um sauber zu machen.

Der dritte Faktor *Können* ist ebenfalls nicht zu unterschätzen. Sind im Büro keine abschließbaren Schränke vorhanden, können die Mitarbeitenden vertrauliche Dokumente nicht wegsperren. Nutzen mehrere Personen gleichzeitig einen Schrank und dieser hat nur einen Schlüssel, wird er nicht abgeschlossen werden. Die Office-Anwendung erlaubt nur Passwörter mit maximal zwölf Zeichen oder akzeptiert keine Ziffern und Sonderzeichen.

Auf diesem Modell aufbauend, ist ein weiteres Verständnis von Information Security Awareness entstanden (vgl. Schütz & Fertig, 2023; Weber et al., 2019). Demnach ist Information Security Awareness ein mentales Konstrukt, welches zu einem informationssicherheitskonformen Verhalten führt (vgl. Bild 9.5). Gemäß dem aus der Sozialpsychologie stammenden Integrierten Verhaltensmodell von Montañó und Kasprzyk (2008) beeinflussen fünf Faktoren das Verhalten. Neben den bereits bekannten Faktoren Wissen, Verhaltensabsicht (Wollen) und Können sind es die beiden Faktoren Salienz und Gewohnheit. *Salienz* beschreibt, wie sichtbar oder herausstechend das Verhalten ist und wie viel Aufmerksamkeit dieses Verhalten hat. Wird ein Verhalten regelmäßig ausgeführt, kann es zur *Gewohnheit* werden und wird zukünftig aufgrund eines Auslösers automatisch, ohne großes Nachdenken, ausgeführt.

Der Faktor *Können* aus dem Modell von Helisch (2009) kann beeinflussen, ob sich ein Individuum informationssicher verhält oder nicht. Der Faktor bezieht sich aber nicht auf die individuellen Fähigkeiten einer Person, sondern auf deren Umfeld oder Organisation. Können ist daher kein mentales Konstrukt und deswegen nach diesem Verständnis nicht Teil von Information Security Awareness. In Bild 9.5 wird der Faktor Können als *Einschränkungen aus dem Umfeld* als moderierender Faktor zwischen Awareness und Verhalten dargestellt. Einschränkungen können dazu führen, dass trotz vorhandener Information Security Awareness ein bestimmtes Verhalten nicht oder nur unzureichend ausgeführt werden kann.

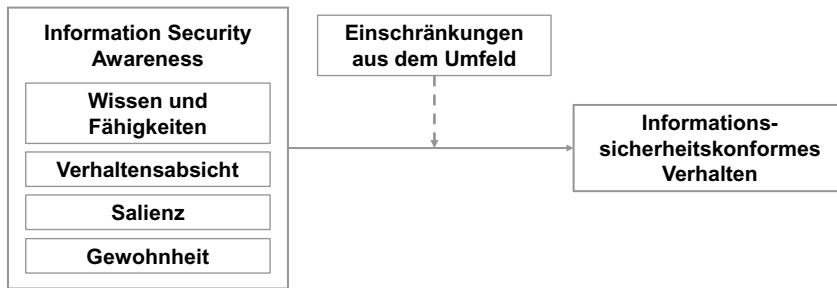


Bild 9.5 Faktoren der Information Security Awareness (in Anlehnung an Schütz & Fertig, 2023, S. 6848; Weber et al., 2019, S. 12)

Um Menschen fit für Informationssicherheit zu machen, sollte ihre Awareness mittels Awareness- oder Sensibilisierungsmaßnahmen gesteigert werden. Diese Maßnahmen sollen die Faktoren Wissen und Fähigkeiten, Verhaltensabsicht, Salienz und/oder Gewohnheit positiv beeinflussen, fördern bzw. erhöhen (vgl. Abschnitt 9.5). Gleichzeitig müssen Einschränkungen beseitigt werden, die das gewünschte Verhalten behindern können.

Um die passenden Awareness-Maßnahmen auszuwählen, ist ein genaues Verständnis von Information Security Awareness und der Ursachen unsicheren Verhaltens notwendig (vgl. Abschnitt 9.2.2). Wissen Mitarbeitende nicht, woran sie eine Phishing-E-

Mail erkennen oder welche Gefahren von USB-Sticks ausgehen, dann kann eine Schulung das fehlende Wissen vermitteln. Sind die Mitarbeitenden nicht davon überzeugt, dass es wichtig ist, E-Mails auf Anzeichen von Phishing zu untersuchen, wird eine reine Wissensvermittlung zu keiner Steigerung der Awareness führen. Dann müssen Awareness-Maßnahmen die Verhaltensabsicht (Wollen) beeinflussen. Verhalten sich Mitarbeitende aus Gewohnheit „falsch“, dann müssen diese Gewohnheiten geändert werden. Vergessen Mitarbeitende manchmal, den Bildschirm zu sperren oder Türen zu schließen, dann kann dieses Verhalten salient gemacht werden.

Alle Modelle gehen davon aus, dass sich Awareness immer auf eine Person und ein bestimmtes (vorher definiertes, bekanntes) Verhalten bezieht: beispielsweise „ich wähle ein sicheres Passwort“, „ich schließe die Tür, bevor ich nach Hause fahre“ oder „ich sperre meinen Bildschirm, wenn ich den Raum verlasse“. Die Kombination der vier Faktoren ist bei jeder Person und für jedes Verhalten anders (vgl. Abschnitt 9.4.3).

9.4.2 Psychologische Grundlagen von Awareness

Um das Verhalten von Menschen zu verstehen, lohnt sich ein Blick in die Sozialpsychologie. Das Integrierte Verhaltensmodell (IBM) vereint die wichtigsten Konstrukte von gängigen sozialpsychologischen Theorien in einem einzigen Modell. Es hilft zu verstehen, wie sich das Verhalten eines Menschen bildet und warum er sich eventuell nicht sicherheitskonform verhält. Das Modell beschreibt die Faktoren, welche einen Einfluss auf das gezeigte Verhalten eines Menschen haben (Montaño & Kasprzyk, 2008). Die vier relevanten Faktoren (vgl. Bild 9.5) werden im Folgenden näher erläutert.

Wissen und Fähigkeiten

Wissen in Bezug auf Informationssicherheit und die Fähigkeit, dieses Wissen umzusetzen, sind wichtige Voraussetzungen für sicherheitskonformes Handeln. Anwendende sollen wissen, welche Gefahren es für die Informationssicherheit gibt, und sie sollen in der Lage sein, diese Gefahren zu erkennen. Sie wissen auch, welche Konsequenzen ihnen und der Organisation durch diese Gefahren drohen können. Zudem wissen die Anwendenden, wie sie sich vor den Gefahren für die Informationssicherheit schützen können, also welche Gegenmaßnahmen es gibt bzw. wie sie sich sicher verhalten sollen. Anwendende wissen, wie sie mit ihrem Verhalten zur Sicherheit der Organisation beitragen.

Verhaltensabsicht

Der Faktor Wollen bzw. Verhaltensabsicht hat den größten Einfluss auf das informationssicherheitskonforme Verhalten. Um effektiv die Informationssicherheit zu verbessern, müssen die Menschen ihr Wissen über Bedrohungen und wie man sie bekämpft in tatsächliches Handeln umsetzen wollen.

Die Verhaltensabsicht ist ein komplexes Konstrukt, welches sich aus Emotionen und Überzeugungen einer Person im Hinblick auf ein bestimmtes Verhalten bildet. Ob eine Person eine Verhaltensabsicht bildet, hängt von ihrer Einstellung zu dem Verhalten, ihrer Wahrnehmung der Normen in ihrem sozialen Arbeitsumfeld und ihrer Einschätzung ihrer persönlichen Handlungsfähigkeit ab.

Die **Einstellungen** umschreiben das Ausmaß an Zustimmung oder Ablehnung eines Menschen gegenüber einer bestimmten Verhaltensweise. Sie beruhen u. a. auf persönlichen Erfahrungen, Emotionen und Gefühlen, die mit dem Verhalten verbunden sind. Positive Emotionen erhöhen die Wahrscheinlichkeit der Verhaltensausführung.

Die **wahrgenommene Norm** entspricht dem von einer Person gefühlten Druck des Umfelds, ob ein Verhalten ausgeführt werden soll oder nicht. Eine Person trifft u. a. aus dem Verhalten anderer Annahmen darüber, welches Verhalten von ihr erwartet wird und ob andere ein Verhalten akzeptieren oder ablehnen.

Die **persönliche Handlungsfähigkeit** beschreibt die wahrgenommene Fähigkeit bzw. das Selbstvertrauen einer Person und wie sie ihre Fähigkeit einschätzt, auf Ereignisse im Umfeld zu reagieren. Sie beschreibt u. a., ob sich die Person die Ausführung eines Verhaltens zutraut und ob sie über die benötigten Ressourcen (z. B. Hilfsmittel, Zeit, Wissen) zur Ausführung eines Verhaltens verfügt.

Salienz

Hat eine Person eine Verhaltensabsicht gefasst und ist dieses Verhalten für sie im Moment salient – also sichtbar oder auffällig –, dann setzt sie dieses Verhalten auch um. Als salient werden Dinge, Anregungen oder Ereignisse bezeichnet, die mehr Aufmerksamkeit auf sich ziehen als andere. Sie sind besonders wichtig oder auffallend. Salienz beschreibt auch die Eigenschaften eines Objektes, die dieses aus seinem Umfeld herausstechen lassen und es somit dem Bewusstsein der Menschen leichter zugänglich machen. Salienz hat aber auch etwas mit persönlicher Relevanz zu tun. Reize und Ereignisse, die persönlich bedeutungsvoll und emotional provozierend sind, sind salienter.

Gewohnheit

Verhalten, welches zu einer Gewohnheit geworden ist, wird automatisch ausgeführt. Bestimmte Trigger (Ereignisse, Reize, Hinweise) lösen das Verhalten aus, ohne dass die Person darüber nachdenken muss. Zu einer Gewohnheit können Verhaltensweisen werden, wenn sie regelmäßig, an bestimmte Gegebenheiten gekoppelt, ausgeführt werden, z. B. immer nach dem Mittagessen oder bei jedem Anruf. Nimmt die Gewohnheit zu, dann nimmt der Einfluss der Verhaltensabsicht auf die Ausführung des Verhaltens ab. Das Verhalten wird ohne Nachdenken und ohne den Einfluss der verschiedenen Faktoren, welche die Verhaltensabsicht bilden, ausgeführt.

9.4.3 Individualisierung

So unterschiedlich die Menschen sind, so unterschiedlich ist auch ihre Information Security Awareness. Jede Person treibt etwas anderes an, jede hat ein anderes Verständnis von der Welt und nimmt sie mit anderen Augen wahr; jeder hat andere Erfahrungen gemacht, und alle haben andere Vorlieben, Bedürfnisse, Ängste und Überzeugungen. Alle diese Aspekte prägen die Awareness und damit das Verhalten der Menschen. Personen haben unterschiedliche Aufgaben und verschiedene Arten von Verantwortung in Organisationen, sie sind anderen Risiken in ihrer Tätigkeit ausgesetzt und kommen mit verschiedenen Aspekten der Informationssicherheit in Berührung.

Mit dem Ansatz „One Size Fits All“ alle Personen gleichermaßen mit Sensibilisierungsmaßnahmen erreichen zu wollen, scheint also von vornherein zum Scheitern verurteilt. Dennoch ist es genau das, was viele Unternehmen in der Vergangenheit getan haben, um die Awareness ihrer Mitarbeitenden zu erhöhen. Mit den gleichen, quartalsweise/jährlich wiederkehrenden Schulungen bzw. E-Learnings soll die Awareness gesteigert und damit ein sicheres Verhalten gefördert werden (z. B. Bada et al., 2015; Beris et al., 2015; Sasse et al., 2023; Schütz et al., 2020).

Für eine effektive Sensibilisierung der Mitarbeitenden ist es notwendig, deren Bedürfnisse und Anforderungen, aber auch die Ist-Situation im Unternehmen zu kennen und diese bei der Erstellung und der Durchführung von Awareness-Maßnahmen zu berücksichtigen. Effektiv bedeutet in diesem Zusammenhang, dass die Maßnahmen dazu geeignet sind, die Awareness tatsächlich zu erhöhen und damit letztendlich das Verhalten der Mitarbeitenden informationssicherer zu machen (vgl. Bild 9.4).

Jede Person da abzuholen, wo sie steht, ist nicht nur effektiv, es macht auch betriebswirtschaftlich Sinn. Es ist eine Verschwendung von Ressourcen, wenn sich Mitarbeitende jedes Quartal mit den gleichen Aspekten auseinandersetzen müssen, die sie bereits kennen und verstanden haben, die sie aber nicht umsetzen können oder nicht umsetzen wollen. Genauso wenig macht es Sinn, alle Mitarbeitenden gleichermaßen in Sicherheitsexpertinnen und -experten verwandeln zu wollen und ihnen jeden Aspekt der Informationssicherheit bis ins kleinste Detail zu erklären (Beyer et al., 2015). Die Arbeitszeit der zu sensibilisierenden Mitarbeitenden kann sinnvoller für andere Tätigkeiten verwendet werden, und auch die Ausgaben bzw. Kosten für diese Sensibilisierungsmaßnahmen kann sich das Unternehmen sparen.

Individualisierte Sensibilisierungsmaßnahmen würden auf jede Person einzeln zugeschnitten, deren jeweilige Überzeugungen, Anforderungen sowie Emotionen adressieren und individuelle Lernpräferenzen berücksichtigen. Diese komplette Individualisierung von Awareness-Maßnahmen ist ökonomisch allerdings auch (noch?) nicht sinnvoll.¹⁾ Stattdessen werden in der Praxis Gruppen von Personen gebildet und für diese Gruppen individuelle bzw. zielgruppenspezifische Maßnahmen erstellt.

¹ Es gibt bereits Überlegungen, mithilfe von künstlicher Intelligenz Lerninhalte tatsächlich individuell auf einzelne Personen zuzuschneiden.

Bildung von Zielgruppen

Ein typischer Ansatz zur Zielgruppenbildung ist die Orientierung an den Jobprofilen der Mitarbeitenden. Ein Jobprofil kombiniert verschiedene Aspekte, die für die Sensibilisierung relevant sind:

- Risikoprofil: potenzielle Risiken (z. B. besonderes Ziel für Phishing-Angriffe), welchen die Mitarbeitenden ausgesetzt sind, und mögliche negative Konsequenzen dieser Risiken
- Informationsverantwortung: Verantwortung im Hinblick auf bestimmte Tätigkeiten und zu verarbeitende Informationen, z. B. Mahnwesen und dazu relevante Regelungen
- Ausbildung und Wissensstand: fachliche Skills, z. B. Java-Kenntnisse
- Externe Interaktion: ob und wie viel Kontakt mit externen Parteien besteht, z. B. mit Kunden
- Nutzung von Software/Hardware: aktiv im Arbeitsalltag genutzte Software (z. B. SAP) und genutzte Geräte (z. B. Laptop, Smartphone)

Ausgehend von einer für alle Mitarbeitenden gleichen Grundsensibilisierung, werden je nach Arbeitsgebiet im Unternehmen andere Inhalte präsentiert. Zielgruppen sind beispielsweise das Management, die Mitarbeitenden der IT oder die Personalabteilung.

Die Orientierung an unterschiedlichen Anforderungen gemäß Aufgabenbereichen oder Abteilungen ist ein erster möglicher Schritt in Richtung Zielgruppenorientierung. Es können und sollten weitere Aspekte berücksichtigt werden, z. B. (Kutzner, 2023):

- hierarchische Stellung im Unternehmen
- Vorwissen und Fähigkeiten zur Informationssicherheit
- zur Verfügung stehende Zeit für Awareness-Maßnahmen
- Präferenzen für mediale Darstellung oder Tools
- Sprachkenntnisse/Muttersprache
- Kulturkreis/kultureller Hintergrund
- persönliche Barrieren, z. B. körperliche oder geistige Beeinträchtigungen

Awareness-Maßnahmen sollten idealerweise immer in der Muttersprache der Adressierten erstellt werden. Die Verwendung soziodemografischer Merkmale zur Bildung von Zielgruppen scheint hingegen nicht notwendig zu sein. Viele Studien kommen zu dem Ergebnis, dass beispielsweise das Alter und das Geschlecht der Personen keinen oder kaum einen Einfluss auf die Awareness haben (siehe Bullée & Junger, 2019, S. 10f).

Vorteile und Herausforderungen der Individualisierung

Individualisierte oder zumindest zielgruppenspezifische Awareness-Maßnahmen sind sinnvoll. Vorteile der Individualisierung sind, dass die Mitarbeitenden sich eher abgeholt und verstanden fühlen, wenn die Inhalte auf ihre Aufgaben im Unternehmen zugeschnitten sind. Sie sind dann eher bereit, den präsentierten Regeln und Hinweisen zu folgen. Die Mitarbeitenden merken sich Inhalte, die nicht zielgruppenspezifisch sind oder unrealistische Forderungen an sie stellen, nicht und werden sie dementsprechend auch nicht befolgen (Beris et al., 2015; Beyer et al., 2015). Ihr Wille, sich aktiv an der Sicherheit im Unternehmen zu beteiligen, wird sinken.

Trotz dieser verlockenden Vorteile ist die Individualisierung von Awareness-Maßnahmen in der Praxis nur teilweise bzw. schwer umsetzbar. Die Umsetzung einer zielgruppenzentrierten Sensibilisierung ist meist mit erheblichem Aufwand und organisatorischen Hürden verbunden.

Nicht nur Budget und Zeit müssen zur Verfügung stehen, im Unternehmen müssen auch Personen mit unterschiedlicher Fachexpertise vorhanden sein. Sie müssen eine Ist-Analyse durchführen können, sinnvolle Zielgruppen bilden, die Regelungen der Informationssicherheit verstehen und in der Lage sein, Awareness-Maßnahmen individualisiert zu erstellen. Bei einer falschen Herangehensweise (z. B. einer fehlerhaften Ist-Analyse) kann Individualisierung von Maßnahmen auch negative Auswirkungen haben und z. B. eine ablehnende Haltung fördern.

Es gilt also gut abzuwägen, wie viel Individualisierung betriebswirtschaftlich tatsächlich sinnvoll und im Unternehmen auch realistisch und gut umsetzbar ist. Grundsätzlich kann aber festgehalten werden: je individueller die Ansprache, umso effektiver die Maßnahmen: „more is not better – less but relevant is“ (Sasse et al., 2023).

9.5 Awareness fördern

Es ist die Aufgabe der Organisation, ihre Mitglieder dazu zu befähigen, ein Sicherheitsfaktor zu sein. Verschiedene Maßnahmen sind geeignet, die Information Security Awareness einzelner Personen zu erhöhen, zu fördern oder zu beeinflussen – immer mit dem Ziel, die Organisation informationssicherer zu machen. Menschen mit einer hohen Awareness sind nicht nur in der Lage, sich gemäß den Vorgaben der Organisation sicher zu verhalten, sie sind auch in unbekannten Situationen achtsam und können sichere Entscheidungen fällen.

Im Folgenden werden Techniken, Instrumente, Ideen und Möglichkeiten dargestellt, um die vier Faktoren der Information Security Awareness zu fördern. Es soll die grundsätzliche Wirkung einer Maßnahme auf die Förderung oder Beeinflussung eines Faktors dargestellt und beschrieben werden. Das menschliche Wesen ist komplex, nicht linear und hat komplizierte Ursache-Wirkungs-Beziehungen. Daher gibt es bei

keiner Maßnahme eine Garantie, dass sie tatsächlich in der Art und Weise wirkt, wie sie das – theoretisch – soll. Maßnahmen, die aus der einen Perspektive heraus sinnvoll erscheinen, können für andere Faktoren u. U. nachteilig sein. Die Wirkung hängt zudem auch von der Gestaltung der Maßnahmen ab (z. B. Design, sprachliche Gestaltung, Zeitpunkt), die je nach Zielgruppe, Organisation, kulturellem Hintergrund etc. unterschiedlich ausfallen kann.

Verzweiflung ist trotzdem nicht angesagt, jeder ernsthafte Versuch, den Menschen in den Mittelpunkt zu rücken und die Awareness-Faktoren gezielt zu fördern, ist besser, als es gar nicht erst zu versuchen.

9.5.1 Wissen erhöhen und Fähigkeiten fördern

Mitarbeitende wissen, wie sie ihren Computerbildschirm sperren. Bei ihrer Rückkehr an den Arbeitsplatz müssen sie sich an ihr Passwort erinnern. Sie können eine Phishing-E-Mail von einer legitimen E-Mail unterscheiden. Sie kennen die Tricks, mit denen Social Engineers arbeiten. Sie wissen, dass USB-Sticks Malware übertragen können. Wissen die Mitarbeitenden über die Bedrohungen, denen ihr Unternehmen ausgesetzt ist, Bescheid und wissen sie, wie sie sich davor schützen können, ist dies der erste Schritt zu mehr Informationssicherheit im Unternehmen.

Wissen ist die Basis für zukünftiges Handeln (Lehner, 2019, S. 76) und damit eine Grundvoraussetzung für die Ausführung informationssicherer Verhaltensweisen. Unwissenheit, falsche Annahmen, Unkenntnis über die Folgen des eigenen Handelns und unzureichende Schulungen der Mitarbeitenden werden u. a. als Ursachen für nicht sicheres Verhalten am Arbeitsplatz genannt (vgl. Abschnitt 9.2.2). Ist kein Wissen vorhanden, können die Mitarbeitenden nur zufällig richtig handeln. Die Fähigkeit, das Wissen in Handlungen umzusetzen, ist eine weitere Voraussetzung für richtiges Handeln.

Das richtige Wissen und die vorhandenen Fähigkeiten sind nicht nur eine Grundvoraussetzung für sicheres Verhalten. Dieser Faktor wirkt zum Teil auch verstärkend und fördernd auf andere Faktoren von Information Security Awareness, z. B. auf Selbstwirksamkeit, Einstellungen und wahrgenommene Normen als Bestandteil von Verhaltensabsicht (vgl. Abschnitt 9.5.2).

Wissenserwerb ist eng mit dem Konzept des Lernens verbunden. Durch Lernen erwirbt, verarbeitet und versteht ein Individuum neue Informationen, Fähigkeiten, Verhaltensweisen oder Konzepte und wendet sie an. Lernen ermöglicht es Menschen, ihr Wissen zu erweitern, sich an veränderte Umstände anzupassen und ihre Fähigkeiten zu verbessern. Lernen ist individuell und ein Prozess der Veränderung.

Es gibt formales und informelles Lernen. Das **formale** oder strukturierte Lernen findet klassischerweise in Bildungseinrichtungen statt. Es gibt einen festgelegten Plan, eine feste Lernumgebung und Lehrpersonen. Wissensvermittlung findet systematisch statt, und die Lernergebnisse werden bewertet. Im **informellen** Lernen gibt es keine festen

Lehrpläne, Lernorte oder Lehrpersonen. Es findet im (Arbeits-)Alltag ohne Anleitung z. B. im Austausch mit Kolleginnen und Kollegen oder durch das Sammeln von Erfahrungen statt. Informelles Lernen ist selbstständig, spontan und situationsbedingt.

Gemäß des 70:20:10-Modells (vgl. Schildknecht, 2018, S. 62 f) lernen arbeitende Personen 70 % durch informelles Erfahrungslernen mittels Anwenden von Wissen und praktischen Erfahrungen bei der Arbeit. Soziales Lernen macht 20 % aus. Hier lernen Personen durch Interaktion mit anderen Menschen, z. B. indem sie etwas fragen. Und nur 10 % entfallen auf das strukturierte oder formale Lernen über Schulungen, Workshops oder E-Learning-Kurse.

Dieses Modell lenkt den Fokus in Unternehmen auf das informelle Lernen. **Informelles Lernen** ist nicht planbar und kann nur gefördert oder möglich gemacht werden. Jede Person ist für ihr eigenes Lernen verantwortlich, indem sie sich das, was sie braucht, selbst holt. Die Organisation ist verantwortlich, den Mitgliedern die richtigen Ressourcen für das eigenständige Lernen zur Verfügung zu stellen – zur richtigen Zeit über die richtigen Kanäle.

Eine Möglichkeit, Ressourcen zur Verfügung zu stellen, ist das Intranet. Hier können Artikel über aktuelle Bedrohungen informieren und Anweisungen, Hilfsmittel und nützliche Links gesammelt werden. Bild 9.6 zeigt Ausschnitte von der Homepage zu Informationssicherheit und Datenschutz der THWS. Hier sind allerlei Wissensartikel hinterlegt sowie weitere Ressourcen für die Hochschulmitglieder.



Bild 9.6 Online-Ressourcen ermöglichen informelles Lernen.
(Quelle: informationssicherheit.thws.de)

Zu informellem Lernen gehört die wiederholte Anwendung des Wissens in der Praxis. Durch Ausprobieren und Scheitern können Menschen ihr Wissen und ihre Fähigkeiten verbessern.

Soziales Lernen kann gefördert werden, indem die Lernenden die Möglichkeit bekommen, anderen zuzuhören, sie zu beobachten und mit ihnen zu sprechen (Schildknecht, 2018, S. 64f). Die „anderen“ können Kolleginnen und Kollegen sein oder Coaches, Mentorinnen und Mentoren, Führungskräfte oder Personen mit Expertise außerhalb des eigenen Unternehmens. Mitarbeitende untereinander können auch Tandems oder Peer Groups bilden und sich gegenseitig unterstützen und motivieren.

Formales Lernen findet in der betrieblichen Praxis vor allem durch Präsenzs Schulungen, Workshops, Seminare, Trainings, in Form von E-Learning-Kursen oder durch Fortbildungen statt. Formal aufbereitete Lerninhalte können auch als Ressource für informelles und selbstständiges Lernen zur Verfügung stehen. Wichtig ist, dass der Fokus nicht auf der reinen Vermittlung von Wissen liegt, sondern in der Anwendung und Übung des Gelernten, damit es nicht so schnell in Vergessenheit gerät.

In der Didaktik, der Wissenschaft vom Lehren und Lernen, werden häufig Lernziel-taxonomien eingesetzt, um den Kompetenzerwerb beim Lernen in verschiedenen schwierige Stufen einzuteilen. Je höher die Stufe, desto schwieriger oder komplexer sind Lernergebnisse.

Eine der bekanntesten Lernzieltaxonomien ist die auf Bloom (1956) basierende Überarbeitung durch Anderson und Krathwohl (2001). Sie beinhaltet die sechs Stufen: Erinnern (Wissen), Verstehen, Anwenden, Analysieren, Beurteilen und (Er-)Schaffen. Ein Beispiel für ein Lernziel auf Stufe 1 (Erinnern) ist: „Regeln für die sichere Gestaltung von Passwörtern kennen.“ Für Stufe 4 (Analysieren) ist ein Beispiel: „Eine Liste von Passwörtern nach ihrer Stärke sortieren.“ Es wird meist davon ausgegangen, dass die höheren Stufen die niedrigeren Stufen beinhalten, wer also etwas anwenden kann, versteht es auch – oder Verstehen ist eine Voraussetzung für Anwenden.

Damit Mitarbeitende in der Lage sind, informationssicher zu handeln, müssen in den meisten Fällen Lernziele der Stufen 3 bis 5 erreicht werden. Mitarbeitende sollten nicht nur in der Lage sein, Gelerntes zu reproduzieren. Sie müssen verstehen, warum informationssicheres Handeln notwendig ist, und sie müssen das Wissen auch anwenden können. Um eine Phishing-E-Mail zu erkennen, ist Wissen der Stufe 5 (Beurteilen) notwendig (Handelt es sich um eine Phishing-Mail oder nicht?).

In den meisten Fällen ist es aufwendiger, Wissen zu vermitteln, welches auf höheren Stufen angesiedelt ist. Es sind anspruchsvollere Lernmethoden und individuellere Herangehensweisen erforderlich, z. B. projektbasiertes Lernen, Fallstudien, Analyse von Sachproblemen, Diskussionen, Simulationen oder Rollenspiele. Einige Beispiele für solche Methoden zur Vermittlung von Informationssicherheitswissen finden sich z. B. in (Jaschob & Pokoyski, 2023; Pokoyski et al., 2023; Puhze, 2023).

9.5.2 Verhaltensabsicht fördern und beeinflussen

Bildet eine Person eine Verhaltensabsicht, entschließt sie sich verbindlich für ein bestimmtes Handlungsziel, z. B.: „Ich achte darauf, dass mir niemand zusieht, wenn ich mein Passwort eingebe.“ Ob eine Person eine Verhaltensabsicht bildet, hängt von ihren *Einstellungen* zu dem Verhalten ab (mir ist es wichtig, mich informationssicher zu verhalten), von ihrer *Wahrnehmung der Normen* in ihrem sozialen Arbeitsumfeld (alle in meinem Team halten sich an die Informationssicherheitsregeln) und von der eigenen Einschätzung ihrer *persönlichen Handlungsfähigkeit* (ich bin in der Lage, mich informationssicher zu verhalten).

Einstellungen

Einstellungen sind individuelle Bewertungen, Meinungen, Gefühle und Neigungen gegenüber Objekten, Personen, Themen oder Verhaltensweisen. Einstellungen sind positiv, neutral oder negativ und beeinflussen, wie Menschen auf Dinge reagieren und wie sie sich in Bezug auf sie verhalten.

Persönliche Erfahrungen mit einem Verhalten sind eine wichtige Informationsquelle für die Bildung von Einstellungen. Positive Erfahrungen können zu einer positiven Einstellung gegenüber einem Verhalten führen, negative Erfahrungen zu einer negativen Einstellung. Diese Art von Information kann jedoch nicht „vermittelt“ werden. Erfahrungen müssen die Personen selbst machen. Daher sollte ihnen reichlich Gelegenheit gegeben werden, die gewünschten Verhaltensweisen auszuprobieren.

Wenn Menschen besser verstehen, warum ein bestimmtes Verhalten wichtig oder vorteilhaft ist, sind sie eher bereit, ihre Einstellung dazu zu ändern und entsprechend zu handeln. Demnach lassen sich mittels Übermittlung der „richtigen“ Information die Einstellungen eines Individuums verändern, beispielsweise:

- **kognitive Informationen:** Informationen, die auf Fakten und rationalen Argumenten basieren, z. B. wissenschaftliche Beweise und Daten
- **emotionale Informationen:** Informationen, die starke emotionale Reaktionen hervorrufen, z. B. Geschichten oder Bilder
- **soziale Informationen:** von anderen Menschen akzeptierte Meinungen und praktizierte Verhaltensweisen, insbesondere von Gleichaltrigen oder Vorbildern.

Es ist wichtig, aus welchen Quellen diese Informationen stammen. Menschen sind eher geneigt, Informationen von Personen mit Expertise oder aus als glaubwürdig angesehenen Quellen zu akzeptieren (Prinzip der Autorität). Informationen sollten wiederholt vermittelt werden. Eine wiederholte Exposition gegenüber Informationen kann dazu beitragen, diese in den Gedanken der Menschen zu verankern (vgl. Salienz).

Der Erfolg der Maßnahmen hängt auch davon ab, wie die Informationen vermittelt werden. Kommunikationstechniken, die auf Überzeugung und Beeinflussung abzielen, sind besser geeignet, Einstellungen zu ändern. Das können der Einsatz überzeugender Argumente und logischer Schlussfolgerungen, emotionale Ansprachen, Humor oder das Erzählen von Geschichten sein. Die von Social Engineers eingesetzten psychologischen Tricks, wie Autorität, Reziprozität, soziale Beweise und Knappheit (Ablenkung), können Verwendung finden (vgl. Abschnitt 9.3.3). Ebenso sollten Informationen und Argumente inhaltlich und gestalterisch so präsentiert werden, dass sie die Bedürfnisse und Interessen des Publikums ansprechen. Verstehen Mitarbeitende – vor allem auf einer emotionalen Ebene –, welchen Risiken die Organisation ausgesetzt ist, wenn sie sich nicht richtig verhalten, kann dies ihre Einstellung ändern (Beautement et al., 2008).

Durch Belohnungen und andere Anreize in Bezug auf ein gewünschtes Verhalten können die Einstellungen beeinflusst werden. Wenn ein Verhalten belohnt wird, neigen Menschen dazu, eine positivere Einstellung dazu zu entwickeln, oder sie wollen von möglichen Anreizen für ein bestimmtes Verhalten profitieren. Anreize können Anerkennung, Lob, Geschenke, Wettbewerbe sowie Entwicklungsmöglichkeiten, aber auch Selbstbestimmung und Autonomie sein.

Die Art und Weise, wie ein Verhalten in öffentlichen Medien dargestellt wird, hat einen erheblichen Einfluss auf die Einstellungen (vgl. auch Agenda Setting Theory, Abschnitt 9.5.3). Verantwortliche könnten sich dies zunutze machen, indem sie den Mitarbeitenden gezielt förderliche Berichterstattung aus öffentlichen Kanälen auch intern zur Verfügung stellen. Beispielsweise können Berichte, in denen auf die Bedeutung informationssicheren Verhaltens hingewiesen wird, oder Berichte über aktuelle Sicherheitsvorfälle im Intranet verlinkt oder in Schulungen und Newslettern eingebaut werden.

Einstellungsänderungen erfordern oft Zeit und Wiederholung, da Einstellungen tief verwurzelt sein können. Ein einziger Versuch, eine Einstellung zu ändern, ist häufig nicht ausreichend. Daher sollten mehrere Ansätze miteinander kombiniert werden.

Wahrgenommene Norm

Die wahrgenommene Norm bezieht sich auf die subjektive Wahrnehmung einer Person darüber, wie andere Personen sich in ihrer sozialen Umgebung verhalten oder wie diese Personen bestimmte Verhaltensweisen bewerten (Fishbein & Ajzen, 2011, S. 129 f). Es ist die individuelle Einschätzung einer Person über die sozialen Erwartungen, Meinungen oder Verhaltensmuster anderer. Da Personen sich oft an sozialen Erwartungen orientieren und sich anpassen möchten, kann die wahrgenommene Norm das Verhalten einer Person beeinflussen.

Das Gefühl der Gruppenzugehörigkeit bietet einen schönen Ansatz, um informationssicheres Verhalten zu fördern. Mitarbeitende, die eine starke Identifikation mit ihrem

Unternehmen haben, sind eher bereit, sich an die dort geltenden Normen und Regeln zu halten. Ein solches Zugehörigkeitsgefühl zu erzeugen, dürfte jedoch allein aus der Information Security Awareness heraus schwierig sein. Die Unternehmenskultur spielt dafür eine entscheidende Rolle. Über einen unternehmensweiten Wettbewerb oder größere Präsenzveranstaltungen (z.B. Town Hall Meeting, Live Hacking) als Awareness-Maßnahmen ist es aber vielleicht möglich, ein Gefühl der Zusammengehörigkeit zu etablieren, von dem die Informationssicherheit dann längerfristig profitiert.

Die Identifikation mit einer kleinen Gruppe, also einem Team, einer Abteilung oder einer Filiale, ist hingegen einfacher und häufig bereits gegeben. Sie kann für die Awareness genutzt werden; indem gezielt Personen innerhalb der Gruppe als Multiplikatoren – sogenannte Security Champions – ausgebildet werden, welche die Normen dann durch Vorleben der gewünschten Verhaltensweisen und durch Kommunikation an die anderen Mitglieder der Gruppe vermitteln.

Wahrgenommene Normen bilden sich besonders durch das Verhalten von Vorbildern. Es ist also besonders wichtig, dass sich vorgesetzte Personen richtig verhalten. Ihr Verhalten wird am ehesten als Norm angesehen. Im Unternehmen sollte ein Bewusstsein dafür geschaffen werden, dass alle Mitarbeitenden mögliche Vorbilder für andere sein können. Und auch schlechte Verhaltensweisen können von Vorbildern nachgeahmt werden. Ist ihnen bewusst, dass sie womöglich für andere ein Vorbild darstellen und ihre Handlungen und Entscheidungen von anderen beobachtet werden, verhalten sich Mitarbeitende tendenziell verantwortungsbewusster und wollen ein gutes Beispiel abgeben.

Injunktive Normen beschreiben gemeinsame Erwartungen, Meinungen und Bewertungen darüber, wie sich die Mitglieder der Gruppe verhalten sollen. Sie entstehen u. a. über mündliche oder schriftliche Kommunikation innerhalb der Gruppe, z.B. durch Aussagen, Ratschläge, Anweisungen oder Empfehlungen. Belohnungen oder Bestrafungen zeigen sehr deutlich, welches Verhalten akzeptabel ist und welches als inakzeptabel gilt.

Richtlinien, Regeln oder Vorschriften sind eine direkte Art, injunktive Normen in einer Gruppe zu etablieren und zu kommunizieren. Richtlinien definieren klar, welches Verhalten gewünscht ist („Jeden Abend den Arbeitsplatz aufräumen“) und welches Verhalten nicht gewünscht ist („Passwörter nicht aufschreiben und nicht am oder in der Nähe des Schreibtischs aufbewahren“).

Kommunikation und Informationsvermittlung sind daher ein wichtiger Ansatzpunkt, um injunktive Normen zu beeinflussen – sei es über Richtlinien, Schulungen, Plakate, Newsletter oder Präsenzveranstaltungen. Bild 9.7 zeigt, wie ein gewünschtes Verhalten als Plakat visualisiert werden kann. Regeln (= akzeptiertes Verhalten) schriftlich zu kommunizieren hat den Vorteil, dass es kaum Spielraum für subjektive Wahrnehmung oder Einschätzung gibt.

Mülltrennung macht Sinn. Gut für die Umwelt, gut für dich! ☺

Das darf rein:

- Papier, Zeitung, Blöcke
- Brotzeitpapier
- Taschentücher



Das darf NICHT rein:

- Kaffeebecher
(sind beschichtet und können
nicht recycelt werden)



Bild 9.7

Plakat zur Bewerbung von Mülltrennung in Cafeterien und Mensen (Quelle: Technischer Betrieb, THWS, Würzburg)

Deskriptive Normen bilden sich durch Beobachtungen, basieren aber auch auf Überzeugungen oder Einschätzungen, z. B. wenn ein Verhalten nicht direkt beobachtet werden kann („Wahl eines sicheren Passworts“). Die Einschätzungen können dann auf Informationen, Erfahrungen oder Gesprächen mit anderen basieren. Auch soziale Signale wie Hinweise, Symbole, Gestik oder Mimik können deskriptive Normen beeinflussen.

Menschen tendieren dazu, sich an Verhaltensweisen zu orientieren, die sie leicht beobachten können (vgl. Abschnitt 9.5.3). Je sichtbarer oder auffälliger die Verhaltensweisen sind, umso größer die Wahrscheinlichkeit, dass sich eine deskriptive Norm bildet. Allerdings – vor allem bei Verhaltensweisen, die nicht beobachtet werden können – entstehen deskriptive Normen auch aus Schätzungen oder Annahmen darüber, wie viele Personen ein Verhalten ausführen oder wie häufig ein Verhalten ausgeführt wird. Diese Annahmen können gezielt durch entsprechende Kommunikation und Berichterstattung beeinflusst werden. Beispielsweise können Kennzahlen zum Verhalten veröffentlicht werden („Im letzten Monat haben 703 Mitarbeitende Phishing-E-Mails an den IT-Helpdesk gemeldet.“).

Darstellungen von Verhaltensweisen in den Medien, einschließlich Fernsehen, Filmen und sozialen Medien, können ebenfalls deskriptive Normen prägen. Es entsteht der Eindruck, dass die dargestellten Verhaltensweisen häufig ausgeführt werden. Gibt es interne Kommunikationskanäle, die häufig von den Mitarbeitenden genutzt werden, wie Social-Media-Plattformen oder Unternehmensfernsehen, können diese eingesetzt werden, um wiederholt die Ausführung gewünschter Verhaltensweisen am Arbeitsplatz zu zeigen. Beispielsweise wird eine Mitarbeiterin in einem Fernsehbeitrag zu einem Thema interviewt und sperrt ganz selbstverständlich ihren Bildschirm, bevor sie sich dem Interviewer zuwendet, um seine Fragen zu beantworten. Wenn Bilder aus den Büros gezeigt werden, sind die Arbeitsplätze immer aufgeräumt, es liegen keine Dokumente herum, und alle Bildschirme sind gesperrt.

Auf der firmeneigenen Social-Media-Plattform könnte ein Kanal erstellt werden, in welchem Mitarbeitende Screenshots von Phishing-E-Mails hochladen können, die sie

erhalten haben. Sie können auch dazu schreiben, woran sie den Phishing-Versuch erkannt haben. Je mehr Mitarbeitende mitmachen, umso eher wird es als deskriptive Norm angesehen, bei E-Mails auf die Merkmale von Phishing zu achten.

Persönliche Handlungsfähigkeit

Die Kernüberzeugung, durch ihre eigenen Handlungen die gewünschte Wirkung zu erzielen, bildet die Grundlage des menschlichen Handelns. Wenn Menschen nicht daran glauben würden, hätten sie wenig Anreiz, zu handeln oder im Falle von Schwierigkeiten durchzuhalten.

Selbstwirksamkeitserwartung

Der Glaube an die eigene Wirksamkeit ist eine wichtige persönliche Ressource für die persönliche Entwicklung und Veränderung. Die Wirksamkeitserwartung bezieht sich auf die Überzeugung einer Person in ihre Fähigkeit, bestimmte Aufgaben zu bewältigen, Herausforderungen zu meistern und Ziele zu erreichen.

Die Selbstwirksamkeitserwartung kann gefördert werden, indem das Selbstvertrauen einer Person gestärkt wird, z. B. durch die folgenden Methoden und Techniken.

Konstruktives Feedback bietet eine konkrete Rückmeldung darüber, wie gut eine Person eine Aufgabe bewältigt hat. Dies kann Unsicherheiten oder Zweifel beseitigen und das Vertrauen in die eigenen Fähigkeiten stärken. Werden Fähigkeiten und Anstrengungen durch positives Feedback gewürdigt, stärkt dies das Selbstvertrauen und die Überzeugung, auch in Zukunft ähnliche Herausforderungen zu bewältigen. Feedback ermöglicht es einer Person auch, ihre Leistung mit anderen zu vergleichen. Wenn sie feststellt, dass sie in Bezug auf andere gut abschneidet, kann dies ebenfalls ihr Selbstbewusstsein und ihre Selbstwirksamkeitserwartung steigern.

Eine sehr wirksame Form des Feedbacks ist, den Mitarbeitenden, die Sicherheitsvorfälle melden, eine Antwort zu senden. Meldet eine Mitarbeiterin eine Phishing-E-Mail an den IT-Helpdesk, ist bereits ein kurzes – gegebenenfalls sogar automatisiert versendetes – *Dankeschön* hilfreich. Wirksamer als ein Dankeschön ist eine konkrete Rückmeldung, welche der Mitarbeiterin sagt, dass es sich tatsächlich um einen Phishing-Versuch handelte und dass durch ihr schnelles Handeln Schritte zur Abwehr der Gefahr unternommen wurden.

Neben persönlichem Feedback durch Vorgesetzte, Beauftragte für Informationssicherheit oder Kolleginnen und Kollegen können durch technische Mittel und kleine Aktionen einfache Formen des Feedbacks etabliert werden:

- Unternehmen könnten eine Anwendung anbieten, die den Mitarbeitenden Feedback gibt, ob ein gewähltes Passwort stark oder schwach ist.
- Nach einem erfolgreich durchgeführten Update könnte der Rechner eine Meldung zeigen, die den Anwendenden dankt, dass sie das Update zeitnah durchgeführt haben.

- Chatbots oder virtuelle Assistenzsysteme können Mitarbeitenden Informationen, Ratschläge oder Feedback zu informationssicherheitsrelevanten Verhaltensweisen geben.

Gamification (Gamifizierung) kann an verschiedenen Stellen eingesetzt werden, um Mitarbeitende zu motivieren und ihnen positive Rückmeldung zu geben, beispielsweise verschiedene Elemente im Zusammenhang mit E-Learning. Mitarbeitende können ihren Fortschritt bei der Bearbeitung der einzelnen zu absolvierenden Lerneinheiten angezeigt bekommen, verschiedene Abzeichen für Erfolge sammeln oder sehen, wie weit sie im Vergleich mit ihren Kolleginnen und Kollegen sind.

Vorbilder sind Personen, die in einem bestimmten Bereich Erfolg haben und als inspirierende Beispiele dienen. Security Champions können so eine Vorbildrolle innehaben. Vorbilder zeigen, wie Aufgaben oder Herausforderungen erfolgreich bewältigt werden können. Indem sie ihre Fähigkeiten und Strategien zeigen, vermitteln sie, dass diese Aufgaben gemeistert werden können. Dies kann das Vertrauen der beobachtenden Personen in die eigenen Fähigkeiten stärken („Wenn mein Vorbild das kann, schaffe ich das auch!“). Teilen Vorbilder ihre eigene Geschichte und berichten auch über Zweifel, Ängste und Hürden auf ihrem Weg zum Erfolg, können sie helfen, Selbstzweifel und negative Gedanken bei anderen zu überwinden. Dies zeigt, dass Erfolg nicht immer einfach ist, aber durch Anstrengung und Durchhaltevermögen erreicht werden kann.

Unter Einsatz von Storytelling können kleine Geschichten über Personen erzählt werden, die erfolgreich eine Herausforderung mit einem informationssicherheitsrelevanten Verhalten gemeistert haben. Die Person kann fiktiv sein, sollte jedoch mit solchen Eigenschaften erdacht werden, dass sich die Adressierten mit ihr identifizieren können.

Teilnahme und Eigenverantwortung ermutigt Menschen, aktiv und engagiert zu sein – Eigenschaften, die in der Regel einen positiven Einfluss auf die Selbstwirksamkeit haben. Erfahrungen bei der Ausführung von Aufgaben können dazu beitragen, das Vertrauen in die eigenen Fähigkeiten zu stärken. Durch kleine Aufgaben und leicht zu erreichende Ziele haben Personen wiederholt kleine Erfolgserlebnisse.

In Wettbewerben könnten Mitarbeitende eigene Vorschläge zur Verbesserung der Informationssicherheit einreichen, neue Slogans für Plakate oder Sticker entwerfen oder ihren eigenen Sicherheitstipp formulieren.

Bei Schulungen oder Fortbildungen zur Informationssicherheit sollten Komponenten enthalten sein, in denen die Teilnehmenden das Erlernte aktiv erproben können. Beispielsweise werden verschiedene Mails gezeigt, und es soll erkannt werden, ob es sich um Phishing handelt oder nicht. Die Teilnehmenden können gebeten werden, sichere Passwörter zu erstellen oder aus einer vorgegebenen Liste von Passwörtern die geeigneten herauszusuchen. Werden Teilnehmende ermutigt, das Gelernte an andere Kolleginnen und Kollegen weiterzugeben, die nicht an der Fortbildung teilgenommen haben, stärkt das auch die Eigenverantwortung.

Wahrgenommene Verhaltenskontrolle

Die wahrgenommene Verhaltenskontrolle ist die Zuversicht, ein zukünftiges Verhalten durchführen zu können. Die Verhaltenskontrolle basiert auf Überzeugungen zu wahrgenommenen und vorhandenen Ressourcen. Ressourcen sind externe Faktoren oder Hilfsmittel, von denen eine Person denkt, dass sie sie zur Verfügung hat, um eine bestimmte Handlung oder Verhaltensweise erfolgreich auszuführen oder zu beeinflussen. Beispiele für Ressourcen sind Zeit, Wissen und Fähigkeiten, finanzielle Mittel, soziale Unterstützung, Werkzeuge oder Tools und Umweltbedingungen (Ajzen, 2020).

Ressourcen, von denen nicht angenommen wird, dass sie zur Verfügung stehen, können als Hindernisse oder Schwierigkeiten wahrgenommen werden, z. B. Zeitmangel, mangelndes Selbstvertrauen oder Motivation, fehlende Werkzeuge, ein Mangel an Wissen oder Fähigkeiten.

Je mehr Ressourcen Individuen glauben zu besitzen und je weniger Hürden und Hindernisse sie erwarten, desto größer ist ihre wahrgenommene Kontrolle über das Verhalten. Das Erhöhen oder Fördern dieser Ressourcen oder das Sichtbarmachen von vorhandenen – aber vielleicht nicht wahrgenommenen – Ressourcen sind wesentliche Ansätze zur Förderung der wahrgenommenen Verhaltenskontrolle.

Wird das Wissen gestärkt und werden Fähigkeiten gefördert (vgl. Abschnitt 9.5.1), so wirken sich diese Ressourcen auch positiv auf die wahrgenommene Kontrolle aus. Eine hohe Motivation und ein hohes Selbstvertrauen stärken nicht nur die Selbstwirksamkeit, sondern stehen auch als psychologische Ressourcen zur Verfügung.

Mitarbeitende sollten genug Zeit bekommen, um eine Aufgabe auszuführen, z. B., um sich in eine neue Software einzuarbeiten oder sich in die neuen Regelungen zur Informationssicherheit am Arbeitsplatz einzulesen. Wenn es möglich ist, sich die Zeit selbst einzuteilen, im eigenen Tempo zu arbeiten und selbst den Fortschritt zu überwachen, erhöht dies das Gefühl der Kontrolle über die eigene Arbeit. Eine gut organisierte und unterstützende Umgebung kann die Ausführung des Verhaltens erleichtern. Gibt es im Kollegium Personen, auf die man sich verlassen kann und die bei Problemen angesprochen werden können, ist diese soziale Unterstützung eine wertvolle Ressource bei der Bewältigung schwieriger Aufgaben.

Im Kontext Informationssicherheit ist das Bereitstellen von Hilfsmitteln oder Tools als Ressource in vielen Fällen möglich. Erfahrene Mitarbeitende könnten Dokumentationen über komplexe Prozesse schreiben, um diese als Hilfsmittel für weniger erfahrene Mitarbeitende zur Verfügung zu stellen. Über Newsletter oder Infoboards kann regelmäßig auf die Existenz solcher Wikis oder Dokumentationen hingewiesen werden.

Die Einführung eines Passwortmanagers erleichtert das Vergeben starker Passwörter und speichert alle Passwörter, wodurch sich die wahrgenommene Kontrolle über das Vergeben von sicheren Passwörtern und das Merken von Passwörtern erhöht. Um die Verhaltensweise „Vermeidung von USB-Sticks“ zu erleichtern, kann das Unternehmen ein eigenes Medium zur Verfügung stellen, durch das Mitarbeitende einfacher Daten austauschen können, z. B. eine unternehmenseigene Cloud.

Ein mögliches Hilfsmittel ist die Aktivierung einer automatischen Bildschirmsperre. Dadurch sperrt sich der Bildschirm nach einer gewissen Zeit der Untätigkeit automatisch. Für Personen, die befürchten, die Bildschirmsperre zu vergessen, kann dies eine hilfreiche Ressource sein. Die Übernahme dieser Aufgabe durch den Computer könnte für andere Personen aber auch als nervig und weniger selbstbestimmend angesehen werden und damit die wahrgenommene Verhaltenskontrolle negativ beeinflussen.

Wichtig ist also, in den Szenarien Tools einzusetzen, wo sie als Hilfe und Unterstützung – und nicht als Bevormundung – wahrgenommen werden. Die Schwierigkeit besteht darin, dass sich diese Wahrnehmung von Person zu Person unterscheidet.

Nicht immer müssen neue Ressourcen geschaffen werden – vorhandene Ressourcen müssen sichtbar und leicht zugänglich sein. Wissen Mitarbeitende beispielsweise nicht, wo sie ihr Passwort ändern können, werden sie es auch nicht tun, selbst wenn sie die Befürchtung haben, dass es kompromittiert wurde. Awareness-Maßnahmen aus dem Bereich des sozialen Marketings, wie Flyer, Newsletter oder Plakate (vgl. Abschnitt 9.5.3), können eingesetzt werden, um auf vorhandene Ressourcen hinzuweisen: Wo befinden sich Richtlinien und Dokumentationen, welche Schulungskurse gibt es, wer sind die Ansprechpersonen für Informationssicherheit und wie erreicht man diese? Ein Beispiel für leichte Zugänglichkeit sind kleine Security Cards, welche die wichtigsten Verhaltensweisen kurz erklären, zum Beispiel eine übersichtliche Darstellung der typischen Merkmale von Phishing-E-Mails. Die Karten finden da Platz, wo sie gebraucht werden, auf oder am Schreibtisch.

Eine weitere Möglichkeit zur Förderung der wahrgenommenen Verhaltenskontrolle bietet das Beseitigen von wahrgenommenen oder zu erwartenden Hürden. Wenn eine Person weiß, dass Hürden, die ein Verhalten erschweren, nicht mehr vorhanden sind, wird damit auch die wahrgenommene Kontrolle erhöht. Im Zusammenhang mit sicheren Verhaltensweisen kann eine solche Hürde ein vermeintlich geforderter Kompromiss zwischen Produktivität und Sicherheit sein.

Ein Hindernis beim regelmäßigen Update ist beispielsweise das langsame Hochfahren des Rechners am Morgen sowie das Starten der Programme. Durch das Austauschen alter Hardware durch aktuellere Geräte kann das Hochfahren des Rechners beschleunigt werden. Mitarbeitende müssten nicht mehr die langen Wartezeiten fürchten und würden dann eher dazu neigen, den Rechner abends herunterzufahren. Updates würden dann automatisch eingespielt werden.

9.5.3 Salienz fördern

In der Wahrnehmungsforschung beschreibt der Begriff Salienz Eigenschaften eines Objektes, die dieses aus seinem Umfeld herausstechen lassen. Diese Eigenschaften lenken die Aufmerksamkeit der Menschen auf das Objekt und machen es somit dem Bewusstsein leichter zugänglich.

Außerhalb der Wahrnehmungsforschung liegt der Fokus von Salienz eher auf dem Aspekt der persönlichen Relevanz. Reize oder Ereignisse, die persönlich bedeutungsvoll und emotional provozierend sind, werden als salient bezeichnet. Menschen erinnern sich eher an Objekte, die aufgrund ihrer Bedeutung für sie salient sind. Sie haben einen erleichterten Zugang zu diesen Objekten in ihrem Bewusstsein. Im Kontext Information Security Awareness ist Salienz die Neigung, in einer potenziellen Risikosituation an informationssicherheitskonformes Verhalten zu denken.

Die Grundlagen zum Verständnis von Salienz liefern mögliche Ansatzpunkte zur Förderung der Salienz mittels Awareness-Maßnahmen. Zum einen sollten Awareness-Maßnahmen so gestaltet sein, dass sie sich abheben und hervorstechen und möglichst in dem Moment, in dem Personen eine sicherheitsrelevante Entscheidung treffen, wahrnehmbar und sichtbar sind. Zum anderen zeigt die Agenda-Setting-Theorie, dass durch andauernde Berichterstattung zu einem Thema dessen Bedeutung auch in der Wahrnehmung der Empfangenden steigt und sogar beeinflusst werden kann, wie sie über dieses Thema denken. Unternehmen sollten daher in regelmäßigen Abständen über informationssicherheitsbezogene Themen berichten, um zu beeinflussen, dass ihre Mitarbeitenden über Informationssicherheit nachdenken und wie sie das tun (positiv/negativ).

Ähnlich argumentiert auch die assoziative Netzwerktheorie. Durch häufige Wiederholung der gleichen Botschaften werden starke Verknüpfungen zwischen assoziierten Informationen im Gedächtnis gebildet. Durch neue Botschaften, die an vorhandene Informationen anknüpfen, können neue Knoten und Verbindungen gebildet werden. Beides führt dazu, dass informationssicherheitsrelevante Informationen schneller zugänglich sind.

Somit können Awareness-Maßnahmen allgemein die Wahrnehmung der Informationssicherheit beeinflussen und die generelle Sichtbarkeit des Themas erhöhen. Das wirkt sich z. B. positiv auf die Sicherheitskultur im Unternehmen aus. Bei einer generell hohen Salienz der Informationssicherheit in der Organisation sollten Mitarbeitende demnach grundsätzlich eher „informationssichere“ Entscheidungen treffen.

Durch wiederholte Konfrontation mit einem Thema wird dieses für eine Person bedeutender, präsenter und die entsprechenden Verhaltensweisen dem Bewusstsein leichter zugänglich. Probate Mittel dafür bietet das Marketing. Marketingmittel sind zum Beispiel Plakate, Flyer, Newsletter, Blogs, Videos, soziale Netzwerke, das Intranet oder Unternehmenszeitschriften. Im Unternehmen könnten also beispielsweise Plakate oder Flyer zu informationssicherheitskonformem Verhalten aufgehängt bzw. verteilt werden.

Ein Beispiel sind die „Tipps des Monats“, welche Studierende an der THWS (damals noch FHWS) regelmäßig an die wichtigsten Verhaltensweisen erinnern oder auf Gefahren aufmerksam machen sollen (vgl. Bild 9.8). Die Tipps wurden zeitgleich über die Social-Media-Kanäle der Hochschule sowie auf den in den Gebäuden hängenden Infobildschirmen veröffentlicht.

TIPP DES MONATS: Gute Vorsätze? - Updates!



Immer wieder werden Schwachstellen von/in digitalen Produkten bekannt.
Schwachstellen sind ein großes Risiko für die Sicherheit und korrekte Funktionsfähigkeit eurer digitalen Helfer.

Prüft daher regelmäßig, ob Updates für eure Software verfügbar sind und spielt sie zeitnah ein. So werden eure Geräte sicherer und ihr kommt gleichzeitig in den Genuss von Verbesserungen und neuen Features.

Mehr zur Informationssicherheit an der FHWS
erfahrt ihr hier:
protect.fhws.de

TIPP DES MONATS: Sicherer in nur 3 Sekunden



Eine E-Mail kommt euch „phishy“ vor? Führt den „3 Sekunden Sicherheitscheck“ durch!

- Kennt ihr die Absender-Adresse?
 - Stimmt die Absender-Adresse mit dem angezeigten Namen überein?
 - Hat der Inhalt einen sinnvollen Bezug auf eure bisherigen Nachrichten?
 - Ist der Betreff sinnvoll?
 - Erwartet ihr einen Anhang / Link?
- Falls ihr auch nur eine Frage mit Nein beantwortet, bleibt vorsichtig und meldet euch beim Helpdesk!

Mehr zum Thema Phishing erfahrt ihr hier:
protect.fhws.de/phishing

TIPP DES MONATS: Ihr Ziel? - Eure Daten!



Social Engineers bringen euch mit scheinbar harmlosen Fragen und anderen Tricks dazu, sensible Daten preiszugeben.

Auch Fragen nach Ansprechpartnern oder der genutzten IT-Ausstattung helfen Social Engineers Cyber-Angriffe vorzubereiten.

Geht daher bei Anfragen nur die nötigsten Informationen preis, besprecht keine sensiblen Themen in der Öffentlichkeit und gebt niemals jemandem eure Zugangsdaten!

Wenn ihr mehr über die Tricks der Social Engineers wissen wollt:
protect.fhws.de/social-engineering/

TIPP DES MONATS: Vom Passwort „password“



„passwort“, „hallo123“, „lol123“, „1234567890“, „abc123“, „ichliebedich“ ...
Diese unsicheren Passwörter stehen in der TOP 20 der meistgenutzten Passwörter in Deutschland.

Sichere Passwörter stehen nie im Wörterbuch, sind mindestens 10 Stellen lang, enthalten Großbuchstaben, Kleinbuchstaben, Ziffern und Sonderzeichen und kommen ohne Wiederholungsmuster wie „123456789“, „qwertz1234“, „1234asdfghjkl“ aus.

Mehr zu sicheren Passwörtern erfahrt ihr hier:
protect.fhws.de/passwort

Bild 9.8 Tipps des Monats für Studierende an der THWS (Quelle: THWS)

Gelingt es, Maßnahmen mit den Zielen und persönlichen Präferenzen der Mitarbeitenden zu verknüpfen, dann werden sie eher wahrgenommen und folglich auch eher umgesetzt (vgl. Abschnitt 9.4.3). Dieses Prinzip kann folgendermaßen Anwendung finden:

- Botschaften mit bekannten Beispielen aus dem Arbeitsalltag verknüpfen
- Risiken nicht allgemein, sondern spezifisch für die jeweilige Zielgruppe erklären
- Aufzeigen, welche Vorteile ein sicheres Verhalten nicht nur beruflich, sondern auch für den privaten Umgang mit Informationen und Endgeräten haben kann

9.5.4 Gewohnheiten fördern

Das Herunterfahren des Rechners am Ende des Arbeitstages könnte als Gewohnheit bei den Anwendenden etabliert werden. Gewohnheiten können das richtige (informationssicherheitskonforme) Verhalten von Menschen beeinflussen.

Forschende der Psychologie verstehen unter Gewohnheiten „eine gelernte Verknüpfung zwischen einem Reiz und der darauffolgenden Reaktion“ (Koch, 2010, S. 32). Gewohnheiten sind als feste Wissensstrukturen anzusehen, genauer gesagt als **Verhaltensskripte**. Die Skripte können einfach oder komplex sein. Ein einfaches Beispiel ist das „Restaurant-Skript“, das Elemente wie *Betreten des Restaurants*, *Suchen eines (freien) Tisches*, *Hinsetzen* und *Ansehen der Speisekarte* enthält.

Die Verhaltensskripte werden automatisch ausgeführt. Automatismus bedeutet, dass das Verhalten in der Regel unabhängig von einem bestimmten Ziel abläuft, es läuft unbewusst und kann dem Bewusstsein sogar unzugänglich sein, es erfordert keinerlei anstrengende Aufmerksamkeit oder mentale Verarbeitung, und es wird häufig durch Reize in der Umgebung ausgelöst. Das Verhalten ist zudem schwer kontrollierbar.

Zu einer Gewohnheit können Verhaltensweisen werden, wenn sie regelmäßig, an bestimmte Gegebenheiten gekoppelt, wiederholt ausgeführt werden, z. B. immer nach dem Mittagessen oder bei jedem Anruf. Die regelmäßige Ausführung eines Verhaltens ist dabei weit wichtiger zur Ausprägung einer Gewohnheit als die häufige Wiederholung.

Bevor eine Gewohnheit etabliert ist, wird ein entsprechendes Verhalten intentional, also zur Erreichung eines Ziels, ausgeführt. Das Zielsystem motiviert die Menschen zu dem entsprechenden Verhalten, welches dann wiederholt ausgeführt wird. Mit der Zeit nimmt die Motivation ab, das angestrebte Ziel zu erreichen, und **Hinweisreize** („Cues“) bestimmen dann die Auslösung. Hinweisreize können emotionale Zustände oder äußere Faktoren wie Ort, Tageszeit und vorangegangene Handlungen sein. Aber auch abstrakte Konzepte wie „bei der Arbeit“ oder „Geselligkeit“ können eine gewohnheitsmäßige Reaktion auslösen (Kaffee holen, rauchen).

Aus Sicht der Informationssicherheit stellt sich die Frage, welches sicherheitsrelevante oder informationssicherheitskonforme Verhalten überhaupt zu einer Gewohnheit werden kann. Nach den genannten Merkmalen sind dies vor allem Verhaltensweisen, welche sich regelmäßig (wiederholt) in einem stabilen Kontext, ausgelöst durch Hinweisreize, ausführen lassen, wie z. B.:

- Beim Verlassen des Arbeitsplatzes den Bildschirm am Rechner sperren
- Datensicherungen/Backups/Updates zu bestimmten Zeitpunkten durchführen
- Neu erstellte Dokumente beim ersten Speichern klassifizieren
- Bei der Annahme eines Telefonats/Videocalls überprüfen, dass keine unbefugten Personen mithören können

Organisationen können Einfluss auf die Bildung von (informationssicherheitsrelevanten) Gewohnheiten bei ihren Mitarbeitenden nehmen und die Habitualisierung von wünschenswerten Verhaltensweisen fördern. Folgende Faktoren fördern die Habitualisierung von Verhalten:

- gute Planung (z. B. durch Umsetzungsabsichten)
- ereignisbasierte Hinweisreize und stabile Umgebungen
- regelmäßige Ausführung des Verhaltens
- geringe Komplexität des Verhaltens

- intrinsische Belohnungen oder zufriedenstellende Konsequenzen
- intrinsische Motivation
- gutes Maß an Selbstkontrolle durch die ausführende Person

Nicht alle dieser Faktoren können durch die Organisation beeinflusst werden. Insbesondere die Selbstkontrolle bzw. die Sicherstellung des Ergebnisses und die konstante Ausführung hängen sehr stark von den Mitarbeitenden selbst ab.

Vor allem aber die Komplexität des Verhaltens und eine gute Planung inklusive ereignisbasierter Hinweisreize kann durch die Organisation gesteuert werden. Beispielsweise würden sehr allgemein gehaltene Anweisungen wie „Prüfen Sie eine E-Mail auf Hinweise von Phishing“ nicht zur Gewohnheitsbildung beitragen. Anders wäre folgende Anweisung: „Überprüfen Sie immer, bevor Sie einen Anhang in einer E-Mail öffnen, welches Format die Datei im Anhang hat. Öffnen Sie den Anhang nicht, wenn er auf *.exe, *.zip, *.rar, *.dll ... endet.“ Die zweite Anweisung reduziert die Komplexität des Verhaltens deutlich. Sie betrachtet zunächst allerdings nur einen Aspekt von Phishing. Die restlichen Aspekte müssten dann in ähnlicher Manier erläutert werden.

Ein anderes Beispiel: „Sperren Sie Ihren Bildschirm immer – auch bei kurzer Abwesenheit vom Arbeitsplatz.“ Besser wäre: „Sperren Sie Ihren Bildschirm immer, sobald Sie Ihren Arbeitsplatz verlassen. Drücken Sie dazu gleichzeitig die Windows-Taste und die L-Taste.“ Der ereignisbasierte Hinweis ist in diesem Beispiel das Verlassen des Arbeitsplatzes. Und zwar ausnahmslos, die Mitarbeitenden müssen nicht darüber nachdenken, ob es sich lohnt oder nicht, weil die geplante Abwesenheit eventuell nur sehr kurz ist. Zusätzlich wird eine genaue Handlungsplanung mitgegeben, wie der Bildschirm zu sperren ist.

In beiden Beispielen ist eine hohe Wiederholungshäufigkeit bei Mitarbeitenden, die viel am PC arbeiten, automatisch gegeben. Die meisten verlassen mehrmals täglich ihren Arbeitsplatz und bekommen auch mehrere E-Mails mit Anhängen pro Tag. Bei Verhaltensweisen, die nicht so häufig ausgeführt werden, kann die Organisation durch (regelmäßiges) Training unterstützen. Beispielsweise die Benutzung eines Passwortmanagers oder des VPN könnten so eingeübt werden.

(Extrinsische) Belohnungen und Anreize zur Ausführung des Verhaltens können teilweise ebenfalls gegeben werden. Mitarbeitende, die eine verdächtige E-Mail an den Helpdesk melden, bekommen ein „Dankeschön“ per Mail zurück. Oder sie bekommen – falls sie wirklich eine Phishing-Mail gemeldet haben – einen Punkt gutgeschrieben, und am Ende des Monats gibt es eine Belohnung für die fünf fleißigsten Phishing-Meldenden. Alle Mitarbeitenden, deren Computer am Feierabend bei einer unangemeldeten „Kontrolle“ heruntergefahren ist, bekommen eine kleine Tüte Gummibärchen auf den Schreibtisch gelegt usw.

Auf intrinsische Belohnungen und auf die intrinsische Motivation von Mitarbeitenden Einfluss zu nehmen, ist aufwendiger und komplexer, aber durchaus möglich. Hierfür hängt sehr viel von der Sicherheitskultur im Unternehmen ab und von der

Art und Weise, wie Sicherheitsmaßnahmen vermittelt werden. Anwendende sollten sich grundsätzlich wertgeschätzt fühlen und Anerkennung für ihren Beitrag zur Informationssicherheit bekommen, beispielsweise durch eine Grafik im Intranet, in der die Zahl der Phishing-Angriffe auf das Unternehmen mit der Zahl der erfolgreich gemeldeten Vorgänge gegenübergestellt wird.

Am Arbeitsplatz gibt es Situationen, in denen bestimmte, für die Informationssicherheit relevante Verhaltensweisen bereits habitualisiert sind. Ein Beispiel ist, die „schlechte“ Gewohnheit, den Arbeitsplatz ohne Sperren des Bildschirms zu verlassen, durch die „gute“ Gewohnheit, den Bildschirm automatisch beim Verlassen des Arbeitsplatzes zu sperren, abzulösen. Aus Sicht der Informationssicherheit ist das erstgenannte Verhalten unerwünscht, weil damit u. a. das Risiko einhergeht, dass Unbefugte an vertrauliche Unternehmensdaten kommen.

Sollen diese Verhaltensweisen geändert werden, um die Information Security Awareness zu erhöhen und die Informationssicherheit zu verbessern, müssen sich neue und „richtige“ Gewohnheiten bilden, um damit die bereits habitualisierten „schlechten“ bzw. „falschen“ Verhaltensweisen zu verdrängen oder abzulösen. Das Modell von Dahlstrand und Biel (1997) beschreibt einen möglichen Ansatz zur Überführung von natur- und umweltschädlichen Gewohnheiten in umweltschützende habitualisierte Verhaltensweisen in sieben Teilschritten oder Stufen. Das Modell kann allgemein für die Etablierung neuer positiver Gewohnheiten aus bereits bestehenden schädlichen Gewohnheiten verwendet werden – und damit auch im Kontext Informationssicherheit.

9.6 Ausblick

Es ist Montagmorgen. Annika sitzt – noch immer etwas verkatert nach der Faschingsparty am Wochenende – an ihrem Rechner. Ein kleines „Bing“ ertönt, als eine neue E-Mail eingeht. Die Mail enthält einen Link mit Fotos von der Faschingsparty. Plötzlich ist Annika hellwach. Noch einmal will sie nicht auf diesen Trick hereinfallen. Laura vom IT-Support hatte ihr genau erklärt, wie Phishing funktioniert. Annika klickt auf den Button im E-Mail-Programm, um diese Mail an den IT-Helpdesk zu melden. Wenig später ruft Laura an und lobt Annika, dass sie den Phishing-Versuch erkannt hat.

In diesem Beispiel waren die Awareness-Maßnahmen erfolgreich. Es gelingt jedoch nicht immer, Informationssicherheitsvorfälle zu verhindern. Irren ist menschlich und Fehler machen ebenso. Unter Stress oder durch Ablenkung kann es ganz schnell passieren, dass trotz aller Awareness etwas schiefgeht. Umso wichtiger ist es, dass sich alle Mitglieder einer Organisation ihrer wichtigen Rolle für die Informationssicherheit bewusst sind. So können Fehler oder Unachtsamkeiten Einzelner durch achtsames Verhalten anderer aufgefangen werden, und die Organisation ist insgesamt gerüstet gegen Angriffe von außen und kann Sicherheitsvorfälle verhindern.

Ein Umdenken über die Rolle des Menschen in der Informationssicherheit hin zum Verständnis „Humans as a Solution“ muss stattfinden und findet statt. Die Information Security Awareness der Mitarbeitenden wird in diesem Umbruch weiterhin im Mittelpunkt stehen. Das Verständnis, was Awareness bedeutet und wie sie gezielt gefördert werden kann, wird wichtiger werden. Dieses Kapitel hat gezeigt, wie vielfältig Awareness ist und wie vielfältig die Maßnahmen sind, um sie zu erhöhen bzw. zu fördern. Die Sicherheitskultur in den Organisationen wird stark an Bedeutung gewinnen. Nicht die einzelnen Mitarbeitenden stehen im Fokus, sondern die Awareness der gesamten Organisation.

Eine gute Sicherheitskultur mit sichtbaren und klar definierten Idealen und Werten stärkt die Motivation der Mitglieder einer Organisation, informationssicher zu handeln und Verantwortung zu übernehmen. „No blaming, no shaming“ sind wichtige Merkmale einer Sicherheitskultur. Es geht nicht darum, mit dem Finger auf vermeintlich Schuldige zu zeigen und sie an den Pranger zu stellen. Redet die Organisation über vergangene Sicherheitsvorfälle, ist das ein Zeichen von Vertrauen und einem offenen Umgang mit Fehlern. Alle können aus diesen Fehlern lernen. Mitarbeitende sollten gefeiert werden – für jeden Verdachtsfall, den sie melden, und für jeden Sicherheitsvorfall, den sie durch ihr achtsames Verhalten verhindern. Führungskräfte sollten sich nicht als etwas Besonderes ansehen – über jede Regel erhaben. Sie sollten stattdessen mit gutem Beispiel vorangehen, selbst besonders aufmerksam sein und die Mitarbeitenden ermutigen, es ihnen gleichzutun.

Interdisziplinarität ist ein Schlüssel für die weitere Forschung zum Faktor Mensch in der Informationssicherheit. Unterschiedliche Disziplinen tragen zum Verständnis bei, wie der Mensch „funktioniert“ und wie er dabei unterstützt werden kann, sich sicher und achtsam zu verhalten. Ausgewählte relevante Fragestellungen zu verschiedenen Disziplinen sind:

- Verhaltenspsychologie: Wie bildet sich Verhalten? Wie lassen sich Gewohnheiten etablieren und ändern? Wie lassen sich Menschen beeinflussen bzw. manipulieren?
- Soziologie/Sozialpsychologie: Wie beeinflussen Gemeinschaften das Handeln der Individuen? Wie interagieren Personen in Gemeinschaften? Wie bilden sich gemeinsame Werte und Normen?
- Informatik: Welchen Bedrohungen ist die Informationssicherheit in Organisationen ausgesetzt und wie können sie sich davor schützen? Welche Rolle spielt der Mensch in Informationssystemen? Wie können Informationssysteme „menschenfreundlich“ gestaltet werden?
- Didaktik/Bildungswissenschaften: Wie lernen Menschen? Wie kann Wissen effektiv vermittelt werden?
- Marketing/Kommunikation: Wie werden Botschaften verständlich überbracht? Mit welchen Mitteln wird die Zielgruppe erreicht? Wie können Maßnahmen effizient individualisiert werden?

- Management/Organisation: Welchen Einfluss hat die Unternehmens-/Führungskultur auf das Verhalten der Mitarbeitenden? Wie kann eine förderliche Fehler-/Sicherheitskultur geschaffen werden? Welche organisatorischen Voraussetzungen müssen für sicheres Handeln geschaffen werden?

Auch die für Informationssicherheit Verantwortlichen, die häufig in der IT verortet sind, sollten sich in ihren Organisationen mit Expertinnen und Experten aus anderen Disziplinen – Kommunikation, Marketing, Legal, HR – zusammentun, um die bestmöglichen Maßnahmen zur Förderung des Faktors Mensch zu ersinnen.

9.7 Die wichtigsten Punkte in Kürze

- Informationssicherheitsvorfälle haben meist mehrere Ursachen. Der Mensch ist keine Schwachstelle – im Gegenteil. Er kann durch Flexibilität, Freiheiten und seine Fähigkeiten zu einem Sicherheitsfaktor werden.
- In verschiedenen betrieblichen Prozessen spielt das richtige Handeln der Mitarbeitenden eine entscheidende Rolle für die Informationssicherheit. Um diese wichtige Aufgabe zu erfüllen, müssen die Mitarbeitenden sensibilisiert und befähigt werden.
- Angreifende entscheiden sich häufig dafür, bewusst menschliche Schwächen zu ihrem Vorteil auszunutzen. Social Engineers nutzen verschiedene Instrumente (z. B. Phishing, CEO Fraud, Shoulder Surfing, Pretexting) und Tricks (z. B. Autorität, soziale Bewährtheit, Sympathie, Ablenkung), um wertvolle Informationen zu sammeln und Menschen zu manipulieren.
- Menschen mit einer hohen Information Security Awareness (ISA) sind ein Sicherheitsfaktor. ISA besteht aus den vier Faktoren Wissen, Verhaltensabsicht, Salienz und Gewohnheit. Diese vier Faktoren müssen durch Awareness-Maßnahmen zielgerichtet und individuell gefördert werden.
- Wissen kann z. B. durch formales, informales und soziales Lernen gefördert werden. Verhaltensabsicht bildet sich z. B. durch positive Emotionen, das Verhalten anderer, konstruktives Feedback und Belohnungen. Salienz kann durch Marketingmaßnahmen und regelmäßige Berichterstattung erhöht werden. Gewohnheiten lassen sich durch wiederholte und regelmäßige Ausführung eines bestimmten Verhaltens in einem stabilen Kontext etablieren.
- Verschiedene Disziplinen müssen zusammen forschen und arbeiten, um passende Maßnahmen rund um den Faktor Mensch in der Informationssicherheit zu entwickeln. Beispielsweise fördert eine gute Sicherheitskultur das sichere Verhalten der Mitarbeitenden.

Literatur

- Adams, A. & Sasse, M. A. (1999). Users Are Not the Enemy. *Commun. ACM*, 42(12), 40 – 46. <https://doi.org/10.1145/322796.322806>
- Ajzen, I. (2020). The theory of planned behavior: Frequently asked questions. *Human Behavior and Emerging Technologies*, 2(4), 314 – 324. <https://doi.org/10.1002/hbe2.195>
- Allen, M. (2006). Social Engineering: A Means To Violate A Computer System (529). SANS Institute. <https://www.sans.org/white-papers/529/>
- Anderson, L. W. & Krathwohl, D. R. (Hrsg.). (2001). A taxonomy for learning, teaching, and assessing: A revision of Bloom's taxonomy of educational objectives (Complete ed). Longman.
- Bada, M., Sasse, A. & Nurse, J. (2015). Cyber Security Awareness Campaigns: Why do they fail to change behaviour? International Conference on Cyber Security for Sustainable Society. <https://ora.ox.ac.uk/objects/uuid:cfed4907-d32a-4450-b075-ad37477b10d8>
- Beautement, A., Sasse, M. A. & Wonham, M. (2008). The compliance budget: Managing security behaviour in organisations. *Proceedings of the 2008 New Security Paradigms Workshop*, 47 – 58. <https://doi.org/10.1145/1595676.1595684>
- Beris, O., Beautement, A. & Sasse, M. A. (2015). Employee Rule Breakers, Excuse Makers and Security Champions: Mapping the risk perceptions and emotions that drive security behaviors. *Proceedings of the 2015 New Security Paradigms Workshop*, 73 – 84. <https://doi.org/10.1145/2841113.2841119>
- Beyer, M., Ahmed, S., Dörlemann, K., Arnell, S., Parkin, S., Sasse, A. & Passingham, N. (2015). Awareness is only the first step — A framework for progressive engagement of staff in cyber security [Business White Paper]. Hewlett Packard Enterprise.
- Bloom, B. S. (Hrsg.). (1956). *Taxonomy of educational objectives: The classification of educational goals* ([1st ed.]). Longman Group.
- BSI (Hrsg.). (2023). IT-Grundschutz-Kompendium. Reguvis. https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/Kompendium/IT_Grundschutz_Kompendium_Edition2023.pdf?__blob=publicationFile&v=4#download=1
- Bullée, J.-W. & Junger, M. (2019). Social Engineering. In *The Palgrave Handbook of International Cybercrime and Cyberdeviance* (S. 1 – 28). Springer International Publishing. https://doi.org/10.1007/978-3-319-90307-1_38-1
- Burkhead, R. L. (2014). A phenomenological study of information security incidents experienced by information security professionals providing corporate information security incident management [Capella University]. <https://www.proquest.com/openview/99b9a26ae6ba188163d5aab0e10b7ddb/1?pq-origsite=gscholar&cbl=18750>
- Cialdini, R. B. (2007). *Influence: The psychology of persuasion* (Rev. ed., [Nachdr.]). Collins.
- Crane, C. (2020, November 3). What Is Smishing? Definition, Examples & Protection Tips. Hashedout by The SSL Store. <https://www.thesslstore.com/blog/what-is-smishing-definition-examples-protection-tips/>
- Dahlstrand, U. & Biel, A. (1997). Pro-Environmental Habits: Propensity Levels in Behavioral Change. *Journal of Applied Social Psychology*, 27(7), Article 7. <https://doi.org/10.1111/j.1559-1816.1997.tb00650.x>
- Dodier-Lazaro, S., Abu-Salma, R., Becker, I. & Sasse, A. (2017, Mai 9). From Paternalistic to User-Centred Security: Putting Users First with Value-Sensitive Design. 3rd CHI Workshop on Values in Computing, Denver, Colorado, USA. <https://discovery.ucl.ac.uk/id/eprint/1557895/>
- Ebert, N., Schaltegger, T., Ambuehl, B., Schöni, L., Zimmermann, V. & Knieps, M. (2023). Learning from safety science: A way forward for studying cybersecurity incidents in organizations. *Computers & Security*, 134, 103435. <https://doi.org/10.1016/j.cose.2023.103435>
- Ferreira, A., Coventry, L. & Lenzini, G. (2015). Principles of persuasion in social engineering and their use in phishing. *International Conference on Human Aspects of Information Security, Privacy, and Trust*, 36 – 47.
- Hadnagy, C. & Wilson, P. (2011). *Social Engineering: The Art of Human Hacking*. Wiley.
- Heartfield, R. & Loukas, G. (2018). Detecting semantic social engineering attacks with the weakest link: Implementation and empirical evaluation of a human-as-a-security-sensor framework. *Computers & Security*, 76, 101 – 127. <https://doi.org/10.1016/j.cose.2018.02.020>

- Helisch, M. (2009). Definition von Awareness, Notwendigkeit und Sicherheitskultur. In M. Helisch & D. Pokoyski (Hrsg.), *Security Awareness — Neue Wege zur erfolgreichen Mitarbeiter-Sensibilisierung* (S. 9–28). Vieweg + Teubner.
- Jaschob, A. & Pokoyski, D. (2023). Gamifizierte Cyber-Sicherheit. *TAKE AWARE sec&life magazine*, 5(6), 20–27.
- Kahneman, D. (2011). *Thinking, fast and slow* (1st ed). Farrar, Straus and Giroux.
- Klipper, S. (2022). Weirde Sociotechnical Systems. In K. Weber & S. Reinheimer (Hrsg.), *Faktor Mensch* (S. 331–347). Springer Fachmedien Wiesbaden. https://doi.org/10.1007/978-3-658-34524-2_18
- Koch, T. (2010). Macht der Gewohnheit? Der Einfluss der Habitualisierung auf die Fernsehnutzung (1. Aufl.). VS Verlag für Sozialwissenschaften.
- Kutzner, A. (2023). Faktoren zur Individualisierung von Information Security Awareness Maßnahmen [Masterarbeit]. THWS.
- Lauer, H. & Kuntze, N. (2022). Grundprinzipien zur Gewährleistung der IT-Sicherheit. In *IT-Sicherheit* (S. 23–41). Hanser.
- Lehner, F. (2019). *Wissensmanagement: Grundlagen, Methoden und technische Unterstützung* (6., überarbeitete und erweiterte Auflage). Hanser.
- Montaño, D. E. & Kasprzyk, D. (2008). Theory of Reasoned Action, Theory of Planned Behavior, and the Integrated Behavioral Model. In *Health behavior and health education: Theory, research, and practice*, 4th ed (S. 67–96). Jossey-Bass.
- Pfleeger, S. L., Sasse, M. A. & Furnham, A. (2014). From Weakest Link to Security Hero: Transforming Staff Security Behavior. *Journal of Homeland Security and Emergency Management*, 11(4), 489–510. <https://doi.org/10.1515/jhsem-2014-0035>
- Pokoyski, D., Haucke, A. & Scholl, M. (2023). Game over vs. Game Lover—Serious Games als wirksame Security Awareness-Maßnahmen für KMU im Projekt „ALARM Informationssicherheit“. https://alarm.wildau.biz/static/0fa10a2f646ddcc06fb36d5636a5025f/Studie3_final.pdf
- Puhze, C. (2023). Mit drei Klicks Verhalten ändern? Warum wir lieber mit Security spielen. *TAKE AWARE sec&life magazine*, 5(6), 14–15.
- Sasse, M. A., Hielscher, J., Friedauer, J. & Buckmann, A. (2023). Rebooting IT Security Awareness – How Organisations Can Encourage and Sustain Secure Behaviours. In S. Katsikas, F. Cuppens, C. Kalloniatis, J. Mylopoulos, F. Pallas, J. Pohle, M. A. Sasse, H. Abie, S. Ranise, L. Verderame, E. Cambiaso, J. Maestre Vidal, M. A. Sotelo Monge, M. Albanese, B. Katt, S. Pirbhulal & A. Shukla (Hrsg.), *Computer Security. ESORICS 2022 International Workshops* (Bd. 13785, S. 248–265). Springer International Publishing. https://doi.org/10.1007/978-3-031-25460-4_14
- Schildknecht, K. (2018). Lernen im Wissenstransfer: Lernen in einer agilen Welt, lebenslanges Lernen und organisationales Lernen. In B. Ackermann, O. Krancher, K. North, K. Schildknecht & S. Schorta, *Erfolgreicher Wissenstransfer in agilen Organisationen* (S. 53–78). Springer Fachmedien Wiesbaden. https://doi.org/10.1007/978-3-658-19468-0_5
- Schütz, A. E. & Fertig, T. (2023). The Forgotten Model—Validating the Integrated Behavioral Model in Context of Information Security Awareness. In T. X. Bui (Hrsg.), *56th Hawaii International Conference on System Sciences, HICSS 2023, Maui, Hawaii, USA, January 3-6, 2023* (S. 6841–6850). ScholarSpace. <https://hdl.handle.net/10125/103462>
- Schütz, A. E., Weber, K. & Fertig, T. (2020). Analyze Before You Sensitize: Preparation of a Targeted ISA Training. *Hawaii International Conference on System Sciences*. <https://doi.org/10.24251/HICSS.2020.800>
- Stajano, F. & Wilson, P. (2011). Understanding scam victims: Seven principles for systems security. *Communications of the ACM*, 54(3), 70. <https://doi.org/10.1145/1897852.1897872>
- Statista. (2021). Phishing (Digital & Trends). <https://www.statista.com/study/102216/phishing/>
- Weber, K. (2024). Mensch und Informationssicherheit: Verhalten verstehen, Awareness fördern, Human Hacking erkennen. Hanser.
- Weber, K., Schütz, A. E. & Fertig, T. (2019). Grundlagen und Anwendung von Information Security Awareness: Mitarbeiter zielgerichtet für Informationssicherheit sensibilisieren. Springer Fachmedien Wiesbaden. <https://doi.org/10.1007/978-3-658-26258-7>

Weber, K., Schütz, A. E., Fertig, T. & Müller, N. H. (2020). Exploiting the Human Factor: Social Engineering Attacks on Cryptocurrency Users. In P. Zaphiris & A. Ioannou (Hrsg.), *Learning and Collaboration Technologies. Human and Technology Ecosystems* (Bd. 12 206, S. 650–668). Springer International Publishing. https://doi.org/10.1007/978-3-030-50506-6_45

Whitman, M. & Mattord, H. J. (2019). *Management of information security* (6th edition). Cengage.

Zimmermann, V. & Renaud, K. (2019). Moving from a „human-as-problem“ to a „human-as-solution“ cybersecurity mindset. *International Journal of Human-Computer Studies*, 131, 169–187. <https://doi.org/10.1016/j.ijhcs.2019.05.005>

**In diesem Beitrag erfahren Sie,**

- welches die wichtigsten Aspekte für die IT-Sicherheit von Unternehmen sind,
- welche Strategien, Methoden und Tools zu Erfolg führen und
- welche aktuellen Herausforderungen und Erfolgsfaktoren es in der IT-Sicherheit gibt.

10.1 Einleitung

Die Situation und die Stellung der IT-Sicherheit in Unternehmen haben sich in den letzten Jahren erheblich verändert. Während man zur Jahrtausendwende noch richtig gute Überzeugungsarbeit leisten musste, um die Unterstützung des Senior Managements zu bekommen, sieht das Bild heutzutage schon positiver aus. Die Wichtigkeit des Themas ist mittlerweile in den Chefetagen angekommen. In den meisten Unternehmen hat man verstanden, dass es im Zeitalter der Daten und Informationen ganz ohne IT-Sicherheit nicht mehr funktionieren kann.

Heutzutage wird der Erfolg der IT-Sicherheit in Unternehmen durch sehr unterschiedliche Faktoren beeinflusst. Neben den „hard facts“, also den technischen Maßnahmen wie zum Beispiel dedizierten Sicherheitstools und Produkten, spielen auch weniger greifbare Faktoren eine große Rolle und können entscheidend für die Wirksamkeit der IT-Sicherheit sein. Neben den notwendigen Prozessen muss man hier klar den Menschen als Risikofaktor hervorheben.

10.1.1 Das Wichtigste beim Start mit IT-Sicherheit

Ein solides Fundament und eine klare Vorgehensweise bzw. Strategie ist bei der IT-Sicherheit unumgänglich und somit ein wichtiger Erfolgsfaktor. Dabei spielt es erstmals keine große Rolle, ob man für die Sicherheit eines kleinen Start-ups oder die eines DAX-Unternehmens verantwortlich ist. Am Anfang sollte man verstehen und wissen, worum es eigentlich geht. Welche Daten und Informationen sind dem Unternehmen wichtig und somit besonders schützenswert?

In der Regel kennt das obere Management ihre sogenannten „kritischen Assets“ und kann bei deren Identifikation bzw. Zuordnung unterstützen. Damit wären wir auch beim ersten wichtigen Thema, mit dem sich Unternehmen befassen sollten, einer Auflistung ihrer kritischen Assets in Form einer Art Inventarliste. Dabei sollte man alle geschäftskritischen Daten, Informationen, Prozesse sowie die zu deren Verarbeitung und Speicherung notwendigen Applikationen (Software) und Hardware in diese Übersicht mit aufnehmen. Diese Übersicht ist eine notwendige Basis für das Informationssicherheitsmanagementsystem (ISMS) und somit ein wichtiger Dreh- und Angelpunkt für eine erfolgreiche IT-Sicherheitsstrategie.

Grundsätzlich sollte sich das Unternehmen sehr früh Gedanken darüber machen, wie die IT-Sicherheit im Unternehmen verankert werden soll. Es gibt hierbei die verschiedensten strategischen Ansatzweisen. Die Mehrzahl der Unternehmungen in Deutschland ist in der vorteilhaften Situation, dass sie bezüglich der IT-Sicherheit keine klaren Vorgaben vom Staat oder von den Behörden vorgeschrieben bekommen – andere jedoch unterliegen regulatorischen Vorschriften und müssen konkrete Maßnahmen umsetzen. Je nach Anwendungsfall können dann auch die Sicherheitsstrategie und die IT-Sicherheitsorganisation unterschiedlich aufgesetzt und strukturiert werden. Daher ist es wichtig, neben den kritischen Assets auch die gesetzlichen und regulatorischen Vorgaben (z. B. BaFin, KRITIS etc.) des eigenen Marktes zu kennen. Falls sich Unternehmen besonders gut positionieren wollen, sehen sie sich die Anforderungen ihrer potenziellen Geschäftspartner an, sofern man ein Business-to-Business-(B2B-)Geschäftsmodell verfolgt. So kann man sich frühzeitig auf etwaige Sicherheitsanforderungen vorbereiten und durch IT-Sicherheit evtl. auch Geschäfte generieren.

Sobald die grundlegenden Rahmenbedingungen bekannt und die kritischen Informationen identifiziert sind, sollte man sich überlegen, wie viel IT-Sicherheit man in-house haben und wie viel man sich extern einkaufen möchte.



In der Regel sollten sich die Unternehmen mit den folgenden Themen und Bereichen der IT-Sicherheit beschäftigen:

- Sichere Infrastruktur (Rechenzentrum, Cloud, Server, Clients ...)
- Sichere Anwendungsentwicklung (intern oder extern entwickelte Software)
- Mitarbeiterschulungen (Security Awareness)
- Notfallmanagement, Backup-Management, Business Continuity Management (BCM)
- IT-Risikomanagement (Risikoanalysen, Schwachstellenanalysen und Penetrationstests)
- IT-Sicherheitsbetrieb – Security Operations Center (SOC)

Vorgehensweise

Es ist notwendig, sich sehr früh mit den sogenannten Data Ownern, also den Verantwortlichen der einzelnen Bereiche, zu unterhalten, um sich ein Bild über die aktuellen Geschäftsprozesse, über die eingesetzten Anwendungen und die in den jeweiligen Bereichen verarbeiteten Daten zu machen. Diese Informationen sind für die initiale Erstellung der Asset-Übersicht notwendig und helfen dem Sicherheitsverantwortlichen auch beim zukünftigen Risikomanagement.

Um sich auf das Wesentliche zu konzentrieren und nicht den Überblick zu verlieren, hilft eine Kategorisierung der Prozesse und Anwendungen in sogenannte Risikoklassen. Anhand dieser Clusterung können die Sicherheitsexperten notwendige technische und organisatorische Maßnahmen definieren, die der jeweiligen Risikoklasse entsprechen. Damit kann eine objektive Priorisierung vorgenommen werden.

Die Risikoklassen werden initial, zusammen mit den Geschäftsbereichen, anhand des aktuellen Risikoappetits erstellt. In der Praxis haben sich zwischen drei und vier Risikoklassen bewährt. Bei der Kategorisierung der Geschäftsprozesse und Anwendungen in die Risikoklassen helfen sogenannte Business-Impact-Analysen (BIA). Um eine BIA zu erstellen, bedient man sich der grundlegenden IT-Schutzziele Vertraulichkeit (Confidentiality), Integrität (Integrity) und Verfügbarkeit (Availability). Oft wird diese sogenannte CIA-Triade noch mit dem Schutzziel Authentizität erweitert.

Mit deren Hilfe können dann konkrete Kennzahlen und mögliche finanzielle Schadenshöhen ermittelt werden.

Folgende Übersicht (Tabelle 10.1) zeigt, wie man mithilfe von verschiedenen Risikoklassen ein durchgängiges Risikomanagement betreiben kann. Es können, je nach Kritikalität und erwarteter Schadenshöhe, unterschiedliche Maßnahmen festgelegt werden. Das hilft den Unternehmen, sich auf die wesentlichen Themen zu konzentrieren, und vermeidet, dass z. B. für weniger wichtige Anwendungen und Geschäftsprozesse die gleichen Maßnahmen umgesetzt werden müssen wie für die weniger wichtigen.

Tabelle 10.1 Risikoklassen

Risikoklasse 1	Risikoklasse 2	Risikoklasse 3
hohe/sehr hohe Schadenshöhe	mittlere Schadenshöhe	geringe Schadenshöhe
jährlicher Penetrationstest	Penetrationstest alle 2 Jahre	Penetrationstest alle 2 Jahre
Risikoübernahme für maximal 6 Monate möglich	Risikoübernahme für maximal 12 Monate möglich	Risikoübernahme für maximal 18 Monate möglich

Generelle Fehler, die man vermeiden kann

Es ist wichtig, sich nicht in Details zu verlieren. Je einfacher und verständlicher die Methodik ist, desto besser ist sie in der Praxis umzusetzen. Auch bei der Toolauswahl sollte man auf Bewährtes zurückgreifen. Die Asset-Liste und die Risikoklassen samt Business Impact Analyse lassen sich sehr gut in einem einfachen Tabellenkalkulations-Tool abbilden. IT-Security an sich ist bereits ein sehr heikles und sensibles Thema. Deshalb ist es ratsam, zusätzlichen Aufwand für das Business so gut es geht zu vermeiden.

Erfolgsfaktoren, die zu beachten sind

In der Regel sind die IT-Sicherheit und die damit verbundenen Anforderungen, die es mit sich bringt, kein Lieblingsthema der Fach- bzw. Geschäftsbereiche. Man wird als Verhinderer wahrgenommen und als ein Bereich gesehen, der Projekte verzögert und zusätzliche Kosten verursacht. Das muss aber nicht immer so sein. Die IT-Sicherheit kann auch helfen, Geschäfte zu generieren, und sollte sich daher als Business Enabler positionieren und so agieren. Ein regelmäßiger Austausch mit Fachbereichen und Stakeholdern hilft oft, Missverständnisse aus dem Weg zu räumen und die jeweiligen Standpunkte der betroffenen Bereiche zu verstehen. Am Ende des Tages hat man ein gemeinsames Ziel, nämlich sichere Produkte und Services anzubieten und die kritischen Informationen des Unternehmens, der Mitarbeitenden und die der Kunden zu schützen. Dabei spielt die IT-Sicherheit eine wichtige Rolle und sollte auch so von allen wahrgenommen werden.

10.1.2 Strategien, Methoden und Tools

Das Hauptziel der IT-Sicherheit ist es, Risiken zu identifizieren, diese durch geeignete Maßnahmen zu minimieren und die verbleibenden Restrisiken zu managen. Das soll idealerweise unter Berücksichtigung der jeweiligen Geschäfts- bzw. Projektziele geschehen, ohne Verzögerungen und Zusatzkosten zu verursachen.

Dabei ist es essenziell, eng mit den jeweiligen Stakeholdern zusammenzuarbeiten, viel zu kommunizieren und transparent zu sein. Jeder betroffene Bereich sollte verstehen, was für die IT-Sicherheit wichtig ist und welche Maßnahmen umgesetzt werden müssen, damit es keine sicherheitsrelevanten Einwände gibt.

Es ist notwendig, die getroffenen Entscheidungen und Maßnahmen verständlich und nachvollziehbar zu dokumentieren. Hierbei hilft eine standardisierte Vorgehensweise bzw. Methodik, die bei Wiederholung auch jederzeit die gleichen Ergebnisse liefern muss – unabhängig von welcher Person sie durchgeführt wird.

IT-Sicherheitsstrategie

Eine IT-Sicherheitsstrategie hilft dem Unternehmen und der Sicherheitsorganisation, ihre Leitplanken festzulegen. Diese sollte grundsätzlich im Einklang mit der IT- bzw. Geschäftsstrategie sein. Die IT-Sicherheitsstrategie beschreibt keine technischen Details, sondern allgemeingültige strategische Ziele, Handlungsfelder, Prinzipien und Vorgehensweisen. Darunter fallen zum Beispiel Entscheidungen, ob man den IT-Sicherheitsbetrieb (Security Operations Center) im eigenen Unternehmen etabliert oder diesen extern als Managed Security Service (MSS) einkauft. In der Strategie sollten auch größere IT-Sicherheitsprojekte/Programme beschrieben werden, sofern diese entsprechend komplex und wichtig sind. Die IT-Security-Strategie eines Unternehmens sollte so früh wie möglich in groben Zügen feststehen, bevor größere Vorhaben angegangen werden.

Es ist empfehlenswert, die IT-Sicherheitsstrategie mindestens jährlich zu überprüfen – spätestens jedoch, wenn sich die allgemeine Geschäfts- und/oder IT-Strategie verändert.

Verantwortlichkeiten

IT-Sicherheit ist keine Einzeldisziplin, sondern eine Teamaufgabe. Neben den Fachbereichen sind die für die IT-Sicherheit relevanten Ansprechpartner die IT-Architektur und der Datenschutz. Die IT-Architekten helfen dabei, sicherheitsrelevante Fragestellungen und Herausforderungen an eine Sicherheitsarchitektur zu beantworten. Der Datenschutz muss prüfen und sein Einverständnis geben, sobald personenbezogene Daten erhoben und verarbeitet werden. Das ist fast bei jedem Projekt der Fall, welches das Stadium eines MVPs (Minimum Viable Products), also eines Prototyps, verlässt. Der Fachbereich ist notwendig für die Durchführung der Business-Impact-Analyse (BIA) und hilft bei der Bestimmung der Risikoklasse. Die IT-Sicherheit bestimmt dann aus den zusammengetragenen Informationen den Schutzbedarf für die Anwendung/das Projekt und definiert, je nach Risikoklasse, die geeigneten Maßnahmen zur Risikomitigierung.

Vorgehensweise/Methodik

Je einfacher und verständlicher die Vorgehensweise einer Risikobewertung ist, desto höher ist die Akzeptanz der involvierten Einheiten. Um den Schutzbedarf eines Geschäftsprozesses oder einer Anwendung zu bestimmen, bedarf es nicht vieler komplexer Einzelschritte.

Am Anfang stehen immer die Business-Impact-Analyse (BIA) und die Einstufung in eine Risikoklasse. Aufgrund der Risikoklasse hat man dann vordefinierte technische und/oder organisatorische Maßnahmen, welche umgesetzt werden müssen. Dies können z. B. Vorgaben für eine Verschlüsselung (in transit, at rest) oder etwa für die Durchführung notwendiger Penetrationstests sein.

Am Ende sind alle Risiken identifiziert und mitigiert, oder aber auch nicht. Falls bestimmte Maßnahmen aufgrund von Gründen wie Machbarkeit, technologischen Hindernissen oder Abhängigkeiten nicht umgesetzt werden können, gibt es den Weg einer Risikoübernahme für die verbleibenden Risiken. Je nach der Kritikalität des Prozesses oder der Anwendung muss das Restrisiko von einer verantwortlichen Instanz (z. B. Vorstand) verstanden und schriftlich „angenommen“ werden. Diese sogenannte Risikoübernahme beschreibt die mögliche Auswirkung (Business Impact), die beim Ausnutzen dieser Lücke mit einer bestimmten Wahrscheinlichkeit entstehen kann. Eine Risikoübernahme sollte keine unbegrenzte Gültigkeit haben. Das Ziel ist es, das Risiko innerhalb einer gewissen Zeit entweder komplett zu schließen oder so weit zu minimieren, dass der zu erwartende Schaden oder die Eintrittswahrscheinlichkeit dafür sehr gering sind. Je kritischer der Geschäftsprozess und die Anwendung, desto zeitnaher sollte das Risiko behoben werden.

Es ist darauf zu achten, dass Risikoübernahmen nicht zur Normalität werden. Diese Möglichkeit sollte man nur in den seltensten Fällen in Betracht ziehen. Dabei hilft es dann auch, wenn die Risikoübernahme nicht von einer beliebigen Person, sondern vom zuständigen Senior Management (z. B. Vorstand) unterschrieben bzw. übernommen wird. Durch die Unterschrift werden eine gewisse Verantwortung und Haftung übernommen, die nicht unerheblich ist.

In der Regel sind folgende Dokumente für die Durchführung einer Risikobewertung notwendig:

- IT-Architekturübersicht
- Business-Impact-Analyse (BIA)
- Sicherheitskonzept
- Schnittstellen- und Datenfluss-Diagramm
- Rollen- und Rechtekonzept
- Logging- und Monitoringkonzept
- Notfallmanagement-Konzept

Mit den Informationen aus diesen Unterlagen kann jeder Sicherheitsexperte ein Risikoprofil erstellen und die einzelnen Risiken für das Unternehmen ableiten.

Richtlinien, gesetzliche Vorgaben und Regulatorik

Jedes Unternehmen hat sich an Regeln zu halten, die entweder per Gesetz oder über die Regulatorik vorgegeben werden. Darüber hinaus ist es üblich, dass auch eigene, interne Richtlinien erstellt werden, sofern diese nicht bereits durch die Behörden abgedeckt sind. Für Unternehmen, die zum Beispiel im Finanz- oder Versicherungsumfeld aktiv sind, gibt die Bundesanstalt für Finanzdienstleistungsaufsicht (BaFin) die Anforderungen an die IT-Sicherheit vor. Bei Unternehmen, die in der Automobilbranche tätig sind, gibt es seitens der Hersteller (OEMs) auch entsprechende Vorgaben, an die sich Zulieferer und Partnerfirmen halten müssen (z. B. TISAX). Mit DORA und NIS 2 hat die Europäische Union kürzlich zwei EU-Rechtsvorschriften für die IT-Sicherheit veröffentlicht, welche das Sicherheitsniveau für Unternehmen in der Finanzbranche und anderen wichtigen Sektoren stärken sollen.

In der Praxis hat es sich bewährt, die aktuellen und zukünftigen Anforderungen an die IT-Sicherheit zu kennen. Diese sollten dann in umsetzbaren Richtlinien beschrieben und kommuniziert werden. Es ist darauf zu achten, dass man sich auf das Wesentliche fokussiert. Sowohl die Anzahl der Richtlinien als auch ihr Detailgrad sollte angemessen sein und niemanden überfordern.

Eine IT-Sicherheitsrichtlinie sollte mindestens folgende Bereiche abdecken:

- Nutzung von IT-Diensten
- Beschaffung und Entwicklung von Anwendungen
- Informationsklassifizierung
- Arbeitsplatz-Regelungen
- Mobiles Arbeiten
- Zutritts- und Berechtigungsmanagement
- Passwortregelung
- Verschlüsselung (Kryptografie)
- Datensicherung, Datenwiederherstellung und Archivierung
- Patch- und Schwachstellenmanagement
- Schulung und Sensibilisierung

Außerdem ist darauf zu achten, dass die Richtlinien regelmäßig überprüft und bei Bedarf angepasst werden. Nur so ist es auch möglich, regelkonform also „compliant“ zu sein.

Prozesse

In der IT-Sicherheit sind Prozesse wichtig, um Transparenz über bestimmte sicherheitsrelevante Vorgänge zu schaffen. Sie helfen dem Anwender zu verstehen, welche einzelnen Schritte notwendig sind, um ein bestimmtes Ziel zu erreichen. Prozesse sollten verständlich sein, müssen regelmäßig überprüft und bei Bedarf angepasst werden. Ähnlich wie bei den Richtlinien sollte man darauf achten, Prozesse nicht allzu komplex zu gestalten. Zu wenige Prozesse sind genauso kontraproduktiv wie zu viele. Auch hier sollte man auf eine gesunde Anzahl von, vor allem effizienten, Prozessen achten.

Der für die IT-Sicherheit wichtigste Prozess ist in der Regel der **Prozess zur Behandlung von Sicherheitsvorfällen – der Incident-Management-Prozess**. Dieser Prozess beschreibt die Vorgehensweise und einzelne Schritte, die durchzuführen sind, wenn ein kritischer Sicherheitsvorfall auftritt. Der hierbei zu involvierende Personenkreis kann recht unterschiedlich sein, sollte aber neben den relevanten Sicherheitsleuten auch Mitarbeitende aus den Bereichen Datenschutz, interne/externe Kommunikation und das notwendige IT-Personal (Betrieb, Infrastruktur oder Anwendungsentwicklung) mit einbeziehen.

Der Prozess regelt nicht nur die Behebung der Störung, sondern gibt auch ganz klar vor, wer mit wem zu welcher Zeit in welcher Form wie zu kommunizieren hat. Hierzu wird auch empfohlen, die Experten der internen und externen Kommunikation mit einzubeziehen, die dann bei Bedarf unterstützen können. Es ist ratsam, die Kontaktdaten der wichtigsten Ansprechpartner offline zur Hand zu haben und auch vorab schon entsprechende Kommunikationsvorlagen vorzubereiten. Wichtig ist es, am Ende des Vorfalls im Rahmen der Lessons Learned die Erkenntnisse nachvollziehbar zu dokumentieren. Die Frage nach Vorfällen und wie man damit umgegangen ist, wird oft von externen Prüfern, Auditoren oder auch von Versicherern im Rahmen von Überprüfungen gerne gestellt.

Ein weiterer notwendiger, aber leider oft vernachlässigter Prozess ist das sogenannte **Softwareeinsatz-Verfahren (SEV)**. Dieser kommt bei der Einführung von Anwendungen zum Einsatz. Der Prozess regelt die Vorgehensweise bei der Implementierung von Software. Dabei kann es sich um eine traditionelle Kaufsoftware oder um individuelle Datenverarbeitung (IDV) handeln. Für beide Fälle ist es wichtig, vordefinierte Überprüfungen durchzuführen, bevor eine Anwendung eingeführt wird. Dadurch vermeidet man Risiken, die durch eine unkontrollierte Schatten-IT entstehen können. In Zusammenarbeit mit den Fachbereichen, der IT, der IT-Sicherheit und Datenschutz wird die einzuführende Software überprüft und einer Risikobewertung unterzogen. Erst wenn sie der IT-Strategie, den IT-Sicherheitsanforderungen, den datenschutzrechtlichen Vorgaben und den Anforderungen des Fachbereichs genügt, kann sie eingeführt werden. So kann die IT-Sicherheit vermeiden, dass kein nicht geprüftes Produkt eingesetzt wird und dass es für Anwendungen auch einen dedizierten Ansprechpartner und Verantwortlichen gibt. Dieser ist dann im Weiteren für sicherheitsrelevante Updates, Patches und für die Härtung des Systems in der Verantwortung.

In vielen Unternehmen gibt es noch oft die sogenannte individuelle Datenverarbeitung (IDV). Das sind mehr oder weniger komplexe Eigenentwicklungen, die auch stetig überprüft und aktualisiert werden müssen. Die Schwierigkeit hierbei ist, dass die zur Entwicklung genutzten Bibliotheken meist veraltet sind, nicht mehr weiterentwickelt werden und dadurch auch Sicherheitslücken enthalten können. Eine IDV muss nicht zwangsläufig eine professionell entwickelte Anwendung sein. Eine komplexe Tabellenkalkulation mit Makros, mit Schnittstellen ins Internet, kann genauso zu einem Sicherheitsproblem werden wie eine Standardsoftware.

Ein weiterer sehr wichtiger Prozess, der den Incident- und Softwareeinsatz-Prozess komplettiert, ist der **Schwachstellen- bzw. Patchmanagementprozess**. Während sich der Prozess der Softwareeinführung vorab mit den Risiken vor und bei der Einführung von Anwendungen beschäftigt, ist der Patchmanagementprozess für die Sicherheit während des Betriebs von Anwendungen notwendig. Es ist sehr riskant, Software nur bei der Einführung einmalig zu überprüfen. Genauso oder viel wichtiger ist es auch, die im Einsatz befindlichen Anwendungen regelmäßig auf Sicherheitslücken zu überprüfen und bei Bedarf rechtzeitig zu patchen. Je nach Kritikalität der Schwachstelle ist hier eine sehr schnelle Reaktionszeit erforderlich. Ein aktiv praktiziertes und gelebtes Softwareeinsatz-Verfahren in Kombination mit einem gut funktionierenden Schwachstellenmanagement kann der IT-Sicherheitsorganisation in vielen Fällen den Einsatz des Incident-Management-Prozesses ersparen.

Checklisten

Standardisierung und Automatisierung in der IT sind Best Practices und sollten über alle Disziplinen hinweg eingeführt werden. Während wir im Bereich Software oft über Automatisierung sprechen, handelt es sich bei prozesslastigen Themen oft um Standardisierung. Das geschieht in Form von Prozessen oder auch Checklisten, die den Alltag und die Arbeit der IT-Sicherheitsorganisation auf der einen Seite und die der Fachbereiche und Stakeholder auf der anderen Seite erleichtern sollen.

In der Praxis werden die Sicherheitsexperten oft nach ihren Anforderungen gefragt. Diese sind natürlich, in der Regel im Detail, in den jeweiligen Richtlinien nachlesbar. Doch nur eine sehr geringe Zahl der Ansprechpartner greift auf diese Art von Dokumentation zurück, um sich ein Bild über IT-Sicherheitsanforderungen zu machen. Man versucht, an die Antworten über den kurzen Dienstweg zu gelangen.

Oft sind es sehr ähnliche Fragen, die man gestellt bekommt:

- Ich möchte eine Anwendung kaufen oder implementieren, auf was muss ich achten?
- Darf ich das Produkt XYZ auf meinem Rechner installieren?
- Sie haben gesagt, ich sollte mit der IT-Security reden.
- Was muss ich tun, damit ich diesen Cloud-Service nutzen kann?

Um nicht jedes Mal dieselben Antworten geben zu müssen, helfen Checklisten, die man bei Bedarf nur minimal anpassen muss.

In den vergangenen Jahren haben sehr viele IT-Organisationen von „on premise“, also im eigenen Rechenzentrum betriebenen Anwendungen, auf Cloud-Services umgestellt. Hierbei erstreckt sich die Palette von Infrastructure as a Service (IaaS) über Platform as a Services (PaaS) bis hin zu klassischen Modellen von Software as a Service (SaaS). Diese werden oft von einem der drei großen Public-Cloud-Unternehmen (Hyperscaler) angeboten.

Als das Thema Cloud noch neu und unbekannt war, ist man sehr vorsichtig an die Sache rangegangen und hat nur unkritische Anwendungen probeweise in der Cloud entwickelt oder sie im Rahmen von sogenannten „Lift and Shift“-Aktivitäten vom eigenen Rechenzentrum in die Cloud gehievt. Die Fragen, die man der IT-Sicherheit gestellt hat bzw. die für die Sicherheitsexperten relevant waren, sind damals wie heute sehr ähnlich und können im Rahmen von Checklisten zusammengefasst und beantwortet werden.

Hierbei handelt es sich nicht nur um Fragen bezüglich der IT-Sicherheit, sondern auch um Aspekte, die aus dem Datenschutz kommen. Oft geht es um Themen wie Datenhoheit oder den Standort der Datenverarbeitung.



Folgende Fragen könnten als Quick Check für eine erste Risikobewertung eines Cloud-Services hilfreich sein:

- Sitz der Gesellschaft inklusive ihrer Außenstellen und Rechenzentren?
- Ist das Unternehmen Teil eines US-Konzerns oder seiner Tochtergesellschaften?
- Gibt es die Möglichkeit, Daten ausschließlich in deutschen bzw. europäischen Rechenzentren zu hosten?
- Welche Art der Datenverarbeitung ist angestrebt? Daten mit Personenbezug oder personenbeziehbar? Sind die Daten bereits klassifiziert (öffentlich, intern, vertraulich, streng vertraulich)?
- Existiert eine Auftragsverarbeitung-Vereinbarung (AVV)?
- Werden technische und organisatorische Maßnahmen (TOMs) in Sachen Datenschutz und -sicherheit umgesetzt und garantiert?
- Beinhaltet die Lösung ein performantes Rechtemanagement mit einem wirksamen Authentifizierungssystem (z. B. Multifaktor-Authentifizierung)?
- Ist das Produkt oder das Unternehmen zertifiziert und kann dies durch Nachweise/Zertifikate und Prüfberichte bestätigt werden?
- Werden die Mitarbeiter umfassend zum Thema Informationssicherheit, Datenschutz und -sicherheit (inklusive Entwickler) geschult?
- Werden Geschäftspartner bei EU-DSGVO-relevanten Datenschutz(an)fragen unterstützt?
- Gibt es Informations- und IT-Sicherheitskonzepte, die man einsehen kann?
- Können IT-Architektur Diagramme und Datenfluss-Übersichten der Lösung zur Verfügung gestellt werden?

- Gibt es Möglichkeiten zur Isolation von Mandaten in der Betriebs-/Netzwerkumgebung an (z. B. Netzwerktrennung, Datenbanktrennung)?
- Werden Verschlüsselungstechnologien für Daten und Schlüsselmanagement-Lösungen für Daten bei der Übertragung (in transit) und Speicherung (at rest) zur Verfügung gestellt?
- Werden regelmäßig Vulnerability Assessments und Penetration-Tests durchgeführt und kann man diese vorweisen?
- Gibt es eine Übersicht der Unterauftragnehmer/Subunternehmer (Auslagerungen und Weiterverlagerungen)?
- Gibt es eine Übersicht der verwendeten Open-Source-Software-(OSS-)Komponenten?
- Bestehen individuell konfigurierbare Backup-Restore-(BR-)Möglichkeiten, sind diese dokumentiert und werden regelmäßig getestet?
- Sind Business-Continuity-(BC)- und Disaster-Recovery-(DR-)Maßnahmen implementiert, dokumentiert und werden diese regelmäßig getestet?
- Sind Security-Incident- und Notfallmanagement-Prozesse implementiert, dokumentiert und werden diese regelmäßig getestet?
- Ist ein internes Kontrollsystem (IKS) implementiert und dokumentiert, welches regelmäßig aktualisiert wird?
- Sind Ansprechpartner, Reaktionszeiten (z. B. bei Incidents), Reporting und Kommunikationswege definiert und vertraglich geregelt (z. B. in Service Level Agreements)?

Diese Art von Checklisten helfen sowohl der IT-Sicherheit als auch den Fachbereichen und den betroffenen Geschäftspartnern, Risiken zu identifizieren und ohne viel Zeitverlust die notwendigen nächsten Schritte einzuleiten.

Es ist also sinnvoll, sich Gedanken über ständig wiederkehrende Fragestellungen zu machen und zu überlegen, ob man diese Fragen in übersichtlichen Checklisten zusammenfassen kann. Diese helfen dabei, schnell und mit wenig Aufwand eine erste Indikation zu bekommen, ob es kritische Risiken gibt oder nicht. Sie ersetzen aber auf keinen Fall eine detaillierte Risikobewertung und sollten auch kein Freifahrtschein für die anfragenden Fachbereiche sein.

Tools

Neben Richtlinien, Prozessen und Methoden haben auch Tools einen festen Platz in der IT-Sicherheit. Hierbei unterscheidet man zwischen Tools für die Infrastruktur, für Anwendungen (inklusive Softwareentwicklung) und für Endgeräte (Clients und Mobilgeräte).

Klassische Produkte wie Anti-Virens Scanner oder Firewalls sind bekannte Werkzeuge und heutzutage aus modernen IT-Umgebungen nicht mehr wegzudenken. Darüber hinaus gibt es für die jeweiligen Anwendungsszenarien eine große Auswahl an weiteren Tools, deren Einsatz, je nach Unternehmen und Use Case, sinnvoll sein kann.



Infrastrukturseitig haben sich in den letzten Jahren Tools für folgende Einsatzbereiche etabliert:

- Intrusion Detection System (IDS) – überwacht das Netzwerk, um mögliche Sicherheitsbedrohungen zu erkennen
- Intrusion Prevention System (IPS) – blockiert den Netzwerkverkehr bei potenziellen Sicherheitsbedrohungen
- Host IPS, Host IDS – kontinuierliche Überwachung und Blockierung von verdächtigen Aktivitäten auf Host-Ebene
- Anti-Virus, Anti-Malware, Anti-Spam – Erkennung und Schutz vor Viren, Malware und Spam
- Advanced Threat Detection (ATD) und Advanced Threat Protection (ATP) – Erkennung und Verhinderung von komplexen Cyberangriffen und Anomalien in Netzwerken
- Vulnerability Scanning/Pentesting – Erkennung, Bewertung und Behebung von Schwachstellen in Applikationen und Anwendungen
- Static Application Testing (SAST) – statisches Analysieren, Identifizieren und Beheben von Schwachstellen und Sicherheitslücken im Sourcecode
- Dynamic Application Testing (DAST) – Dynamische Code- bzw. Schwachstellenanalyse von Webapplikation während der Laufzeit
- Web Application Firewall (WAF) – Firewall zum Schutz von Webanwendungen
- Runtime Application Self-Protection (RASP) – Echtzeiterkennung von Schwachstellen und Verhinderung von Bedrohungen in produktiven Anwendungen
- SCA (Software Composition Analysis) – automatische Erkennung von Risiken in Open-Source-Software (OSS)
- Image bzw. Container Scanning – Identifizierung von Schwachstellen und Sicherheitslücken von Containern (Docker)
- Security Information and Event Management (SIEM) – zentrale Erfassung, Korrelation und Auswertung von Logs aus unterschiedlichen IT-Systemen
- Security Awareness Tools – Tools für die Simulation und Durchführung von Phishing-Kampagnen (Schulung von Mitarbeitenden)

Die hier erwähnten Tools haben keinen Anspruch auf Vollständigkeit und sind nicht nach ihrer Wichtigkeit priorisiert. Sie dienen lediglich dazu, sich einen groben Überblick zu verschaffen und sich zu orientieren.

Kommunikation/Reporting

Der Bereich IT-Sicherheit ist für viele andere Bereiche im Unternehmen oft schwer zu verstehen und zu greifen. Deshalb ist es ratsam, in einen regelmäßigen Austausch mit den Key Stakeholdern zu gehen, um diese abzuholen und zu informieren. Dazu kann die IT-Sicherheit regelmäßige Newsletter über aktuelle Themen, Trends und Projekte erstellen und verschicken, Kampagnen und Sicherheitstage organisieren oder eine Sprechstunde einrichten, in der konkrete Fragen gestellt und beantwortet werden.

Um das Führungsteam auf dem Laufenden zu halten, sollten Lageberichte erstellt und dem Senior Management zur Verfügung gestellt werden. In der Regel reicht es

aus, wenn der Leiter der Informationssicherheit (CISO) Quartalsberichte erstellt und verschickt. Einmal im Jahr sollte auch ein Vororttermin mit der Geschäftsführung oder den Vorständen stattfinden. Dort können ein Rückblick über das abgelaufene Jahr, aktuelle Themen und ein Ausblick über anstehende Aktivitäten und Projekte vorgetragen werden. Auf alle Fälle ist es ratsam, alle sicherheitsrelevanten Ereignisse, Vorgänge und Entscheidungen zeitnah mit den betroffenen Bereichen zu besprechen und zu dokumentieren.

10.2 Organisatorische Verankerung

Das Thema organisatorische Verankerung der IT-Sicherheit wird schon seit vielen Jahren sehr kontrovers diskutiert. Die IT-Sicherheit ist, wie der Zusatz Informationstechnologie (IT) schon vermuten lässt, ein Teilbereich der IT-Abteilung und könnte daher auch in diesem Bereich untergebracht werden.

Fachlich betrachtet gehört die IT-Sicherheit aber auch zur Informationssicherheit, die nicht zwangsläufig Teil der IT-Organisation sein muss. Es gibt sogar Stimmen, die eine strikte Trennung zwischen IT und Informationssicherheit fordern. Der Leiter der Informationssicherheit (CISO) sollte neben dem Leiter der Informationstechnologie (CIO) positioniert werden und nicht darunter. Eine disziplinarische Abhängigkeit zwischen CIO und CISO könnte zu Konfliktsituationen führen, wenn die Anforderungen der Sicherheitsexperten zu zusätzlichen Kosten oder Verzögerungen in der IT führen. Aufgrund der operativen und betriebsnahen Themen hängt in vielen Unternehmen die IT-Sicherheit organisatorisch im Bereich der IT-Infrastruktur (vgl. Bild 10.1).

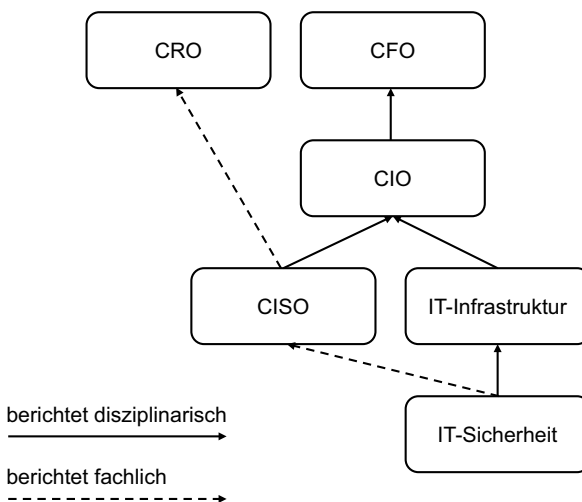


Bild 10.1

Klassische Organisation der IT-Sicherheit/Informationssicherheit

Doch es gibt auch einige Unternehmen, welche die IT-Sicherheit und Informationssicherheit trennen. Dabei wird die Informationssicherheit sehr nahe am Vorstand oder an der Geschäftsführung verankert. Dadurch können Interessenkonflikte mit der IT-Abteilung vermieden werden. Üblicherweise hängt dann die Informationssicherheit an einem risikoorientierten Bereich wie dem Risikomanagement, also am Chief Risk Officer (CRO), oder berichtet direkt an den Finanzvorstand (CFO).

Bild 10.2 zeigt so eine mögliche Organisationsstruktur, welche bereits in einigen Unternehmen umgesetzt wird. Diese Struktur hat den großen Vorteil, dass die Behörden (z. B. die BaFin), zumindest bei regulierten Unternehmen oder Bereichen, die Nähe von der Informationssicherheit bzw. dem CISO zur IT (CIO) nicht sehr gerne sehen – wegen des oben beschriebenen möglichen Interessenskonfliktes. Ihrer Meinung nach sollte der CISO direkt unter dem Topmanagement hängen und auch an dieses berichten. Eine Konstellation zusammen mit dem CISO ist zwar hilfreich, zum Beispiel, um über aktuelle und geplante IT-Vorhaben oder Projekte informiert zu werden, kann aber auch problematisch sein. Daher ist die Trennung der technischen IT-Sicherheit von der Informationssicherheit vorteilhaft. Die Positionierung der betriebsnahen, operativen IT-Sicherheitsthemen sollte in der IT beheimatet sein. Der Leiter dieses Bereiches muss sich aber eng mit der Informationssicherheit und dem CISO abstimmen und müsste sogar fachlich an den CISO berichten (gestrichelte Linie).

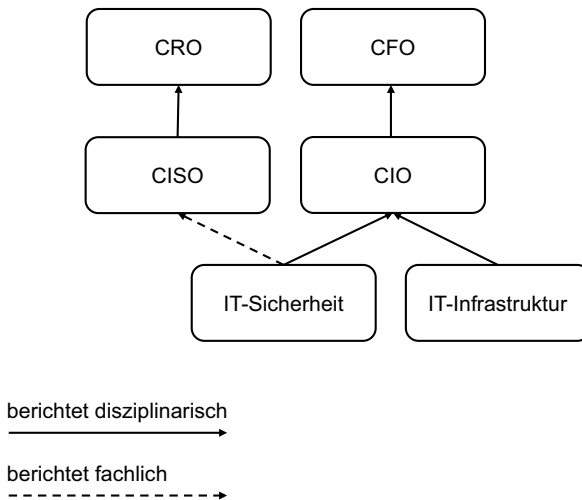


Bild 10.2

Moderne Organisation der IT-Sicherheit/Informationssicherheit

Verantwortlichkeiten

Bei einem komplexen Thema wie der IT-Sicherheit ist es ratsam und vorteilhaft, wenn die Verantwortlichkeiten klar definiert und gegenüber allen relevanten Stakeholdern kommuniziert sind. Klare Zuordnungen helfen allen Beteiligten in ihrem Tagesgeschäft.

Grundsätzlich sollte man sich überlegen, ob man die Verantwortlichkeiten auf fachlicher oder organisatorischer Ebene trennt. Das hängt aber auch ein Stück weit von der Größe und Organisationsstruktur des Unternehmens ab.

Die Verantwortlichkeiten für die IT-Sicherheit eines lokalen Start-ups sind anders geregelt als die Verantwortlichkeiten eines international aufgestellten Konzerns. Bei sehr kleinen Unternehmen hat man meistens ein bis zwei Sicherheitsexperten, die sich um alles kümmern. Auf Konzernebene könnte man sich überlegen, ob man regionale Verantwortlichkeiten definiert, da diese sich auch gegebenenfalls mit den regionalen gesetzlichen Anforderungen auseinandersetzen müssen. Das würde dann bedeuten, dass es eine Sicherheitsorganisation und entsprechende Verantwortlichkeiten pro Region oder sogar Land gibt (z. B. Regional-IT-Security-Officer-Infrastruktur). In seltenen Fällen gibt es auch Regelungen, bei denen eine Person über alle Regionen hinweg die Verantwortung für ein Thema hat (z. B. IT Security Officer für die globale Infrastruktur).

Wenn man alle Domänen der Informations- bzw. IT-Sicherheit betrachtet, kann man grob zwischen den strategischen und technischen Themen unterscheiden.

Es sollten klare Verantwortungen für folgende Bereiche geben:

- Sicherheitsstrategie
- Richtlinien
- Prozesse
- IT-Infrastruktur
- IT-Anwendungsentwicklung
- IT-Risikomanagement
- Mitarbeiterschulungen (Security Awareness)



IT-Sicherheit ist kein Thema, das ausschließlich zentral aus einer Organisationseinheit heraus verantwortet wird. Es ist sehr wichtig, dass sich jeder Technologie- oder Produktverantwortliche mit der IT-Sicherheit seines Bereiches auskennt und auch die Verantwortung dafür trägt. Ein CISO, der Vorgaben für die Härtung einer Datenbank oder eines Servers macht, muss nicht zwangsläufig wissen, wie man diese Vorgaben auf technischer Ebene umsetzt. Das muss der jeweilige Spezialist (DB-Admin, Server-Admin) wissen und entsprechend implementieren.

Für die jeweiligen Verantwortungsbereiche gibt es dann entsprechende Rollen, die sich konkret um diese Themen kümmern.

10.2.1 Rollen in der IT-Sicherheit

IT-Sicherheitsorganisationen sind hierarchisch sehr flach und beinhalten nicht so viele unterschiedliche Rollen wie andere Organisationseinheiten. Es wäre auch nicht sinnvoll, durch viele Rollen zusätzliche Komplexität zu erzeugen. Normalerweise gibt es einen Hauptverantwortlichen „Leiter/in Informationssicherheit“, „Leiter/in IT-Sicherheit“ oder „Chief Information Security Officer (CISO)“ und dedizierte Fachexperten, die mehr oder weniger Themen in ihren Rollen verantworten.

Leiter Informationssicherheit/IT-Sicherheit bzw. CISO

Trägt die Gesamtverantwortung für die Informationssicherheit und IT-Sicherheit. Definiert die Sicherheitsstrategie, ist Richtlinien- und Prozessverantwortlicher und Hauptansprechpartner für das Senior Management, Behörden, interne/externe Auditoren und Prüfer.

IT Security Officer (ITSO)

Security-Experten der IT-lastigen Bereiche wie Infrastruktur und Anwendungsentwicklung.

Sie sind technische Hauptansprechpartner und Berater für sicherheitsrelevante Fragestellungen in Projekten und IT-Vorhaben.

Information Security Officer (ISO)

Security-Experten für weniger technische Bereiche wie Sensibilisierung der Mitarbeitenden (Security Awareness) oder Risikomanagement. Sie sind unter anderem zuständig für Sicherheitsschulungen und unterstützen Projekte bei Risikoanalysen und -bewertungen.

Security Architect

Kümmert sich bei Projektvorhaben um die Anforderungen der IT-Sicherheit und hilft dabei, die Zielarchitektur mitzubestimmen (Security By Design).

IT-Sicherheitskoordinator

In größeren Unternehmen zu finden, die einen konkreten Ansprechpartner bzw. eine Schnittstelle für die IT-Sicherheit benötigen. In der Regel sind das keine Vollzeitstellen, sondern Personen, die das Thema IT-Sicherheit zusätzlich zu ihrem Hauptberuf mit abdecken. Viele IT-Sicherheits-Koordinatoren sind gleichzeitig auch Datenschutz-Koordinatoren, übernehmen also eine ähnliche Rolle für die Themen aus dem Datenschutz.

Darüber hinaus gibt es Variationen dieser Rollen in den unterschiedlichsten Konstellationen wie Head of, Leiter etc. Am Ende des Tages ist nicht die Bezeichnung der Rolle das Ausschlaggebende, sondern es sind die Tätigkeiten und Verantwortlichkeiten, die dahinterstecken. Bei sehr großen Organisationen kann es daher sinnvoll sein, die Rollen und Verantwortungen einmal durchgängig zu bestimmen und in einer Übersicht (z. B. RACI-Matrix) darzustellen.

10.2.2 Kompetenzen in der IT-Sicherheit

Früher hatten IT-Sicherheitsverantwortliche durchgängig technische Lebensläufe und Ausbildungen. Viele dieser Experten waren Informatiker, Mathematiker, Physiker oder hatten einen Elektrotechnik-Hintergrund. Man musste sich gut in technisch komplexen Umgebungen zurechtfinden und sprach idealerweise die Sprache der IT.

Das Bild hat sich in den letzten Jahren etwas verändert. Heutzutage arbeiten auch viele Quereinsteiger in der IT-Sicherheit. Ein analytisches Verständnis und eine schnelle technische Auffassungsgabe sind aber auch heute noch gern gesehene Kompetenzen. Je nach Geschäftszweig, Unternehmensgröße und -kultur kann auch das Beherrschen der englischen Sprache erforderlich sein. Technische Dokumentationen, Konzepte und Richtlinien oder aber auch die Projektsprache sind mittlerweile in vielen deutschen Unternehmen zum Standard geworden.

Veränderung von Kompetenzen

Auch auf technischer und technologischer Ebene hat sich einiges getan. So wie in allen IT-Bereichen üblich, muss sich auch der IT-Sicherheitsexperte ständig an Veränderungen anpassen.

Früher musste man sich um die Sicherheit von Anwendungen kümmern, die in klassischen Wasserfall-Projekten entwickelt und in eigenen Rechenzentren betrieben wurden. Heutzutage werden die Anwendungen entweder als Software as a Service (SaaS) eingekauft, oder man entwickelt in einem dynamischen, agilen Projektumfeld (z. B. mit Scrum-Methoden) moderne cloud-native Anwendungen, die in (Public-) Cloud-Umgebungen betrieben werden.

Die klassischen Sicherheitsüberprüfungen wie Penetrationstests von Anwendungen, die man vor dem „Go live“ noch durchgeführt und dann freigegeben hat, gibt es kaum noch mehr in dieser Form. Die Frage nach dem „Sag mir, wann dein Produkt zu Ende entwickelt ist, dann sehen wir uns das an“ wird heutzutage mit „das Produkt entwickelt sich ständig weiter“ beantwortet. Daher muss sich die IT-Sicherheit, genauso wie die moderne Welt der Softwareentwicklung (agil) und Infrastruktur (Cloud), auch weiterentwickeln. IT-Sicherheitsexperten müssen zusammen mit den Product Ownern (PO) in agilen Projekten Security User Storys schreiben und diese in das Backlog

einbringen bzw. in den einzelnen Entwicklungszyklen (Sprints) dafür sorgen, dass die Anforderungen umgesetzt werden.

Themen und Begriffe wie sichere Softwareentwicklung (Secure Software Development Lifecycle, SSDLC), DevSecOps und Continuous Integration/Continuous Delivery (CI/CD) in der Anwendungsentwicklung sollten genauso wenig Fremdwörter sein wie Infrastructure as a Service (IaaS), Platform as a Services (PaaS) und Software as a Service (SaaS) im Infrastrukturkontext.

Unbedingt notwendige Kompetenzen

In den letzten Jahren bzw. Jahrzehnten hat sich die IT-Welt vom Rechenzentrum in die Cloud bewegt. Die Art und Weise der Softwareentwicklung hat sich verändert. Das war die erste größere Umstellung für die IT-Sicherheit nach der Ablösung der Mainframes bzw. Großrechner durch moderne Client-Server-Architekturen.

Mittlerweile steht die IT-Security vor einem weiteren großen Umbruch und der nächsten großen Herausforderung. Durch die künstliche Intelligenz (KI) und den dadurch geschaffenen Möglichkeiten müssen die Sicherheitsexperten noch weiter über den Tellerrand schauen als bisher. Die KI ist im Vormarsch und hält Einzug in die Unternehmen. Leider wird sie nicht nur für gute Zwecke genutzt, sondern ist mittlerweile auch zu einem Werkzeug der „dunklen Seite“ geworden. Sowohl Privatpersonen als auch organisierte Hackergruppen nutzen die Methoden der künstlichen Intelligenz, um Unternehmen anzugreifen und Schaden zu verursachen. Perfekt formulierte Phishing E-Mails, falsche Videos, (Deep Fakes und durch KI entwickelte Schadsoftware sind nur die Spitze des Eisberges).

Neben den technischen Kompetenzen ist es mittlerweile auch sehr wichtig, das Kerngeschäft des eigenen Unternehmens besser zu verstehen. IT-Sicherheit sollte sich als Business Enabler positionieren und den Fachbereichen helfen, ihre Geschäftsziele umzusetzen. Daher ist es vor sicherheitsrelevanten Entscheidungen enorm wichtig, den Einfluss der Entscheidung (Business Impact) auf das Unternehmen genau zu verstehen. Es schadet also nicht, wenn sich IT-Sicherheitsexperten einer Bank oder Versicherung mit den Anforderungen für Finanzdienstleister und der Regulatorik auskennen.

Gewährleistung von Kompetenzen

Durch ein kontinuierliches Mitverfolgen (Monitoring) von Technologietrends und der konkreten Weiterbildung der Sicherheitsexperten kann man zumindest den kompletten Kompetenzverlust vermeiden. Es wird nicht möglich sein, alle notwendigen Fähigkeiten und Kenntnisse in der IT-Sicherheit zu bündeln. Daher ist es zwingend erforderlich, die IT-Sicherheit zu einem Thema für alle Bereiche zu machen. Jeder Mitarbeitende eines Unternehmens sollte sich mit dem Thema Sicherheit beschäftigen, mögliche Angriffspunkte in seinem Arbeitsumfeld kennen und sich mindestens mit Standard-Sicherheitsschulungen, in denen zumindest die wichtigsten Grundlagen vermittelt werden, regelmäßig weiterbilden.

Auf der anderen Seite muss das Topmanagement von Unternehmen auch die notwendigen finanziellen und zeitlichen Mittel für eine kontinuierliche Weiterbildung und Entwicklung von Kompetenzen zur Verfügung stellen und darf nicht an der falschen Ecke sparen. Jeder Sicherheitsvorfall kann ganz schnell viel mehr finanziellen Schaden verursachen als die Kosten für Präventionsmaßnahmen.

10.3 Entscheidende Änderungen bei IT-Sicherheit

Die größten Veränderungen für die IT-Sicherheit finden immer noch im Technologiemfeld statt. Im Rahmen der Digitalisierung und Modernisierung von IT-Landschaften gab es in den letzten Jahren einige Änderungen im Applikations- und Infrastruktur-Umfeld. In komplexen Transformationsprojekten haben Unternehmen damit begonnen, ihre Anwendungen von eigens betriebenen Rechenzentren in Cloud-Umgebungen zu migrieren. Dadurch haben sich die Angriffsvektoren verändert, was dazu führte, dass sich die IT-Sicherheit mit zusätzlichen technischen und organisatorischen Maßnahmen für den Schutz von Daten und Informationen befassen musste.

Nicht nur vonseiten der Infrastruktur gab es enorme Veränderungen, auch die Art und Weise, wie man heutzutage Software entwickelt, hat sich geändert. Die klassischen Wasserfall-Projekte mit dedizierten Quality Gates und Abnahmekriterien (z. B. Penetrationstests) wurden durch moderne, agile Softwareentwicklungsmethoden (z. B. Scrum) abgelöst. Das Motto „you build it, you run it“, welches den modernen DevOps-Ansatz beschreibt, ist ein weiteres Beispiel dafür, wie sich die IT und damit auch die Herausforderungen für die IT-Sicherheit in den letzten Jahren verändert haben.

Die Auswirkungen der künstlichen Intelligenz (KI) für die IT-Sicherheit sind momentan noch nicht ganz absehbar. Aber es deutet sich schon ab, dass die KI sowohl Fluch als auch Segen zugleich ist. Potenzielle Angreifer nutzen die KI unter anderem für die Generierung von Phishing-E-Mails oder Fake-Videos. Auf der anderen Seite wird die KI dafür genutzt, um neue Technologien und Produkte für die IT-Sicherheit zu entwickeln. Diese sollen zum Beispiel Anomalien bzw. bestimmte Angriffsmuster (Pattern) erkennen und so frühzeitig Angreifer oder Schadsoftware identifizieren und abwehren. Das Thema künstliche Intelligenz wird die IT-Sicherheit in den nächsten Jahren noch sehr beschäftigen und sollte dadurch auf alle Fälle intensiv beobachtet werden.

Des Weiteren ist die Anzahl von externen Partnern und Dienstleistern von Unternehmen in den letzten Jahren stark angestiegen. Viele der benötigten Leistungen kauft man sich heutzutage von draußen ein, oft in Form von Software as a Service (SaaS) oder aber auch als reine Beratungsleistung im Rahmen von Consulting oder Professional Services. Die IT-Sicherheit darf sich deshalb nicht nur mit den Risiken im eigenen Unternehmen beschäftigen, sondern muss nun oft auch die ganze Lieferkette (End-to-End) betrachten, bewerten und entsprechend absichern.

10.4 Besondere IT-Sicherheits Herausforderungen

Aus der Regulatorik und auf gesetzlicher Ebene gibt es immer wieder Themen, auf die sich die IT-Sicherheit einstellen muss. Mit der EU-Datenschutz-Grundverordnung (DS-GVO) von 2018 gab es vor einigen Jahren bereits die ersten rechtlichen Vorgaben, welche auch einen Einfluss auf die IT-Sicherheit hatten. Fragen, wie man die Daten schützt, wo diese liegen und verarbeitet werden, vor allem im Cloud-Kontext, kennt jeder Sicherheitsexperte.

Aktuell kommen mit DORA und NIS 2 zwei weitere EU-Rechtsvorschriften und Richtlinien auf die IT-Sicherheit zu, welche das Niveau der Cybersicherheit erhöhen und die Resilienz von Unternehmen stärken sollen. Obwohl diese Gesetzgebungen nicht für alle Sektoren gelten, werden sich viele Unternehmen damit beschäftigen müssen. Die Vorgaben werden konkrete Anforderungen und Maßnahmen an die IT-Sicherheit formulieren, welche dann im Umkehrschluss auch zeitnah umgesetzt werden müssen. Die Umsetzung und der Reifegrad werden dann, so wie üblich, durch externe Prüfer und Auditoren kontrolliert.

Technologisch wird sich neben den aktuellen Cloud-Themen die künstliche Intelligenz als große Herausforderung herauskristallisieren. Die KI und die damit umsetzbaren Anwendungsfälle (Use Cases) werden bereits in vielen Unternehmen zwischen Fachbereich und IT-Sicherheit intensiv diskutiert. Dabei geht es in den meisten Fällen um Fragen rund um den Datenschutz und um die Vertraulichkeit. „Welche Daten dürfen in welchen KI-Umgebungen wie genutzt werden?“ wird der eine oder andere IT-Sicherheitsexperte in Zukunft womöglich öfter hören.

10.5 Erfolge erzielen – Fehler vermeiden

Die IT-Sicherheit ist erfolgreich, wenn das eigene Unternehmen von Sicherheitsvorfällen verschont bleibt, die kritischen Daten kontinuierlich geschützt sind und alle relevanten Richtlinien und Vorgaben eingehalten werden. Wenn man noch einen Schritt weitergeht, kann man noch den Zusatz, das alles ohne Zeitverzug und zusätzliche Kosten zu verursachen, hinzufügen. Es ist aber explizit zu erwähnen, dass Zeit und Kosten keine Messgrößen für den Erfolg der IT-Sicherheit sind, sondern eher aus dem Blickwinkel der Fachbereiche und des Managements wichtig sind. Wie bereits erwähnt, sollte die IT-Sicherheit sich aber schon als Business Enabler sehen und auch diese Punkte zumindest im Hinterkopf haben.

Genauso wichtig ist es auch, dass offensichtliche und schwerwiegende Fehler vermieden werden müssen. Anders vielleicht als in anderen Unternehmensbereichen, kön-

nen Fehler der IT-Sicherheit sehr große Auswirkungen auf das Unternehmen haben. Die Schäden können sich von kleineren Betriebsunterbrechungen bis hin zu kompletten Stillständen des Betriebs erstrecken.

10.5.1 Erfolgsfaktoren

Um erfolgreich zu sein, müssen IT-Sicherheitsverantwortliche generell folgende Punkte beachten:

- die zu schützenden kritischen Assets (Daten, Informationen und Applikationen) und Geschäftsziele des Unternehmens kennen
- alle proaktiven und reaktiven Phasen (Identifizieren, Schützen, Erkennen, Reagieren und Wiederherstellen) der IT-Sicherheit betrachten und geeigneten Maßnahmen umsetzen
- Zeit und Geld in Mitarbeiterschulungen und Sensibilisierungskampagnen investieren – am Ende des Tages ist der einzelne Mitarbeitende das größte Ziel und das schwächste Glied der Kette
- für Management-Buy-in und das notwendige Sicherheitsbudget sorgen
- immer die rechtlichen Vorgaben und die anwendbare Regulatorik im Hinterkopf behalten
- sich für Spezialthemen externe Unterstützung holen (z. B. Penetrationstest, Managed Security Services wie SOC)
- Vorgaben, Richtlinien und Prozesse verständlich, schlank und anwendbar gestalten
- Entscheidungen, Vorfälle und Ausnahmen nachvollziehbar dokumentieren und ablegen

10.5.2 Fehler, die zu vermeiden sind

Natürlich gibt es auch Fehler, die man als IT-Sicherheitsverantwortlicher vermeiden sollte, zum Beispiel:

- Entscheidungen zu treffen, die über die eigene Kompetenz hinausgehen und nur auf Topmanagementebene (Vorstand, Geschäftsführer) entschieden werden können
- „aus dem Bauch heraus“ zu entscheiden, ohne eine transparente und nachvollziehbare Vorgehensweise oder Methodik anzuwenden

10.5.3 Verbesserungspotenziale

Die Stellung und Wahrnehmung der IT-Sicherheit haben sich in den letzten Jahren enorm verbessert. Das, was früher als unnötig und störend angesehen worden ist, ist in vielen Unternehmen zu einem sehr wichtigen Thema geworden. Der Schutz von Unternehmens- und Kundendaten ist heutzutage wichtiger als je zuvor. Die persönliche Haftung des Managements bei Fahrlässigkeit hat auch ihren Beitrag zur Sensibilisierung geleistet.

Trotzdem gibt es Luft nach oben. Obwohl viele Unternehmen die Wichtigkeit des Themas erkannt haben, müssen IT-Sicherheitsbereiche um Budget und Personalstellen mit anderen IT-Abteilungen konkurrieren. Das Verhältnis von IT-Sicherheitsexperten im Vergleich zur Anzahl der IT-Mitarbeitenden ist oft zu gering.

Um in Zukunft noch besser zu funktionieren, muss die IT-Sicherheit separat von der IT betrachtet werden. Sie benötigt ein eigenes Budget und muss die notwendigen Planstellen zur Verfügung gestellt bekommen, um sich auf die stetig zunehmende Bedrohungslage vorbereiten zu können. Durch die aktuell herrschende Qualifizierungslücke und den Fachkräftemangel ist zu überlegen, ob man durch eigene interne Ausbildungsprogramme IT-Sicherheitsexperten ausbildet. Hierzu gehört auch das Angebot für eine regelmäßige Teilnahme an Fortbildungs- und Zertifizierungsmaßnahmen.

Ein Investment in die IT-Sicherheit wird sich für Unternehmen auf alle Fälle auszahlen. Es wäre falsch, die Sparschraube an falscher Stelle anzusetzen, da sich das mittel- oder langfristig nicht rechnen wird. Denn es ist keine Frage, ob man einen Sicherheitsvorfall haben wird, die Frage ist nur, wann und in welchem Ausmaß.

10.5.4 Lessons Learned

Pauschal über Lessons Learned zu sprechen, die auch auf andere Unternehmen anwendbar sind, ist bei dem Thema IT-Sicherheit nicht ganz einfach. Jedes Unternehmen hat einen anderen Risikoappetit und ist je nach Marktsegment mehr oder weniger im Fokus von Hackern.

Es gibt Initiativen, die man eigentlich auf alle Branchen und Unternehmensgrößen anwenden kann. Das Wichtigste ist hierbei die Schulung und Sensibilisierung der Mitarbeitenden. Wie bereits erwähnt, ist der Endanwender das schwächste Glied in der Kette. Regelmäßige Security-Awareness-Schulungen und Kampagnen helfen allen Unternehmen, das Risiko eines Sicherheitsvorfalls enorm zu reduzieren. Idealerweise sind diese Maßnahmen nicht „out of the box“, sondern gezielt angepasst auf das jeweilige Umfeld. Dabei kann man zum Beispiel ein aktuelles Großprojekt aufgreifen, welches im Moment durchgeführt wird und das alle kennen, oder man bedient sich

Themen, die den Mitarbeitenden besonders wehtun könnten, falls da etwas schief laufen sollte (z. B. Probleme mit der Gehaltszahlung).

Der Grund dabei ist, nicht die Mitarbeitenden zu ärgern. Vielmehr geht es darum, dass auch die Angreifer von außen genau diese Einfallstore nutzen, um über Phishing, Social Engineering oder CEO Fraud Schaden zu verursachen und an Geld zu kommen. Heutzutage wird jedes Großprojekt laut und deutlich in den sozialen wie beruflichen Netzwerken beworben. Der Implementierungspartner rühmt sich mit dem Großprojekt und dem tollen Kunden, der CIO oder Ressortleiter macht Werbung für das Unternehmen oder seinen Bereich.

Die potenziellen Angreifer nehmen diese Informationen dankend an und verfassen, vielleicht noch mit Einsatz von künstlicher Intelligenz, perfekt formulierte Phishing-Nachrichten und gehen gezielt auf relevante Bereiche und Personen vor, welche sie vorher in den jeweiligen Netzwerken recherchiert haben.

Diese Art von Angriffen sollte man üben – nicht nur einmal im Rahmen einer Pflichtschulung, sondern permanent, auch unangekündigt und immer gut vorbereitet. Idealerweise sind diese so gut gemacht, dass die Mitarbeitenden sie fast nicht von realen Nachrichten unterscheiden können und manchmal auch bei Non-Spam und Non-Phishing nachfragen, ob das wieder eine der Kampagnen ist.

Die Wirksamkeit dieser Sensibilisierungsmaßnahmen kann sehr gut gemessen werden. Durch die Klick-, Interaktions- und Öffnungsraten kann der Lerneffekt der Schulungen und Kampagnen nachgewiesen werden. Es gibt Beispiele, bei denen die Technik, welche eine Phishing- oder Spam-Nachricht abwehren sollte, diese nicht als solche erkannt hat. In dem Fall haben geschulte Anwender die Nachricht als Gefahr identifiziert und mithilfe eines Phishing-Buttons gemeldet.

Gezielte Mitarbeiterschulungen sind sehr wirkungsvoll und sollten in allen Unternehmen ganz oben auf der Liste stehen.

Auf der anderen Seite bringen die 08/15-Schulungen, die keinen Bezug zum Unternehmen haben und nur einmal am Anfang beim Eintritt des Mitarbeitenden in Rekordzeit abgearbeitet werden, sehr wenig bis gar nichts.

10.5.5 Was könnte man anders machen?

Die meisten Unternehmen machen schon vieles richtig bei der IT-Sicherheit. Es gibt natürlich auch Themen und Bereiche, die man heutzutage anders angehen sollte. Die Zusammenarbeit bzw. die Schnittstelle zwischen den Fachbereichen, also dem Business und der IT-Sicherheit, birgt das größte Konfliktpotenzial.

Auch wenn es schon immer vordefinierte Prozesse, Methoden und Vorgaben gab, sind diese oft nicht eingehalten worden. Der Grund dafür waren in der Regel sehr strikte Richtlinien, komplexe Prozesse und so hohe Hürden, dass diese kaum erreicht

werden konnten. Das führte dazu, dass man alles dafür getan hat, diese Vorgaben zu vermeiden. Da jede Anfrage aus dem Business so schnell wie möglich umgesetzt werden musste, hat man mal Prozesse ignoriert, Workarounds eingerichtet oder riskante Entscheidungen getroffen, ohne sich konkret über das Ausmaß Gedanken zu machen. Natürlich müssen in der IT-Sicherheit Regeln eingehalten und strikt befolgt werden. Deshalb muss man darauf achten, alle Vorgehensweisen und notwendigen Sicherheitsüberprüfungen schlank, verständlich und umsetzbar zu gestalten, damit das Business und die Projekte überhaupt eine Chance haben, vernünftig damit umzugehen. Viele Richtlinien, Prozesse und Vorgaben bedeuten nicht zwangsläufig, dass alles sicherer wird. Im Gegenteil, das führt dazu, dass Projekte alles daransetzen, diese Themen zu vermeiden und Abkürzungen zu finden. Es ist nicht sinnvoll, die Wirksamkeit und den Erfolg der IT-Sicherheit an der Anzahl der Richtlinien, Vorgaben, Prozesse, auszufüllenden Unterlagen oder abgelehnten Anfragen zu messen. Früher mag das vielleicht so gewesen sein und hatte seine Daseinsberechtigung. Heutzutage ist das nicht mehr praktikabel und zeitgemäß. Die IT-Sicherheit muss sich, wie das gesamte Business auch, schlank organisieren und aufstellen. Klare, einfache Richtlinien, wenige verständliche Prozesse und mehr Standardisierung, Automatisierung und Toolunterstützung sind in der heutigen Zeit der Schlüssel zum Erfolg.

Die Angreifer sind modern, flexibel, schnell und dynamisch. Diese kann man nicht mit komplexen Regeln, Richtlinien und Prozessen bezwingen.

10.6 Zusammenfassung

Wie man sieht, ist die IT-Sicherheit ein sehr komplexes, aber auch hochinteressantes Aufgabengebiet. Das Thema wird von Jahr zu Jahr wichtiger und bekommt glücklicherweise auch in den Unternehmen mittlerweile die nötige Anerkennung. Es gibt immer zwei Seiten einer Medaille. Wir alle haben uns für die gute Seite entschieden und versuchen tagtäglich, unser wichtigstes Gut, die Daten und Informationen unserer Kunden, Partner, Mitglieder und Mitarbeitenden, zu schützen.

Leider gibt es auch die andere Seite der Medaille, die Angreifer, die sehr gut organisiert und aufgestellt sind. Es sind nicht mehr nur die jungen Hacker, die in ihren Kinderzimmern nachts vor dem Rechner sitzen und zum Spaß und für die Ehre versuchen, Systeme zu hacken. Nein, es sind auch Unternehmen und teilweise ganze Nationen, die einen organisierten und sehr gut strukturierten Cyberkrieg führen.

Jeder Unternehmensbereich sollte sich der Wichtigkeit und Kritikalität dieses Themas bewusst sein und konstruktiv zusammenarbeiten, um dieses große Risiko gut in den Griff zu bekommen.

10.6.1 Hot Topics

In den nächsten Jahren gibt es einige Themen, die im Fokus der IT-Sicherheitsinitiativen stehen sollten.

Cloud

Weiterhin ganz oben auf der Liste ist das Thema Cloud. Viele Unternehmen haben ihre Cloud-Initiativen abgeschlossen und sind mitten in Migrationsprojekten. Einige hatten sich bisher aufgrund von für den Datenschutz relevanten Fragestellungen etwas zurückgehalten. Doch mit Erlassung des neuen Angemessenheitsbeschlusses für die USA im Jahre 2023 seitens der EU-Kommission und der Einführung des EU-US Data Privacy Frameworks, sind die USA wieder (zumindest Stand heute) ein sicherer Empfänger und Verarbeiter von Daten. Aufgrund dieser Ereignisse nutzen wieder viele Firmen die Cloud-Umgebungen der großen Hyperscaler. IT-Sicherheit für Cloud-Umgebungen ist deshalb weiterhin eines der Themen, die in den nächsten Jahren weiterhin im Fokus stehen werden.

Künstliche Intelligenz (KI)

Die künstliche Intelligenz hält Einzug in alle möglichen Unternehmensbereiche. In allen Unternehmen wird das Thema hoch und runter diskutiert. Im März 2024 verabschiedete das Europäische Parlament ein Gesetz und erste Regulierungen für die künstliche Intelligenz. IT-Sicherheitsverantwortliche müssen sich zwangsläufig mit dem Thema KI auseinandersetzen.

Drittparteien-Risiken

Für ihre wichtigen Geschäftsprozesse benötigen viele Unternehmen heutzutage strategische Partner, Dienstleister und Lieferanten. Diese Drittparteien verarbeiten unter anderem kritische Unternehmensdaten und müssen daher ins eigene Risikomanagement aufgenommen werden. Das hat zur Folge, dass sich IT-Sicherheitsexperten die gesamte Lieferkette ansehen müssen, um alle möglichen Risiken zu identifizieren. Durch die Auslagerungen erhöht sich das Gesamtrisiko für sicherheitsrelevante Vorkommnisse, da die Angreifer oft nicht direkt das Zielunternehmen angreifen, sondern den Weg über die strategischen, wichtigen Lieferanten und Dienstleister gehen. Der Grund dafür ist, dass man sich erhofft, dass Drittparteien weniger gute Sicherheitsvorkehrungen haben und bereits bestehende technische Zugänge zum Zielunternehmen genutzt werden können. Idealerweise betreut dieser Lieferant auch andere wichtige Unternehmen, die dann in diesem Rahmen auch Ziel von Angriffen werden können. Die Überprüfung dieser Drittparteien und der damit verbundenen Risiken ist und wird eines der wichtigsten Themen der nächsten Jahre sein und werden.

Managed Security Services (MSS)

Viele sicherheitsrelevante Technologien sind mittlerweile sehr komplex und ohne Spezialwissen kaum bedienbar, oder es fehlt einem am notwendigen Personal. Aus diesem Grund gibt es viele Unternehmen, die ihr Geschäftsmodell auf diese Bereiche ausrichten. Sie bieten Unternehmen, welche nicht das notwendige Wissen oder zu wenige Ressourcen haben, Managed Security Services (MSS) an. Diese Dienstleistungen werden oft rund um die Uhr (7/24) angeboten und helfen Unternehmen, ihre Cyber-Resilienz zu verbessern. Ein Beispiel für diese Art von Services ist ein Managed Security Operations Center mit einem 24-Stunden-Monitoring der kritischen Assets und einem Krisenreaktionsteam, welches bei Bedarf innerhalb von wenigen Stunden in Aktion treten kann.

Die nächsten Hot Topics kommen aus der Gesetzgebung und Regulatorik, sind nicht für jedes Unternehmen relevant, aber trotzdem so wichtig, dass sie Erwähnung finden müssen.

Digital Operational Resilience Act (DORA)

DORA ist eine europäische Regulierung für Unternehmen im Finanzsektor (z. B. Banken und Versicherungen), die entsprechende Anforderungen an die Cybersicherheit und Informations- und Kommunikationstechnologie (IKT) vorgibt, welche Anfang 2025 umgesetzt und nachgewiesen werden müssen.

Network and Information Security Directive (NIS 2)

Die Cybersicherheits-Richtlinie der EU, welche im Oktober 2024 verbindlich wird, verpflichtet EU-Staaten, strengere Cybersecurity-Vorgaben zu erlassen, diese durchzusetzen und nachzuhalten. Sie ist relevant für wesentliche, also wichtige Unternehmen in der EU, welche für die Aufrechterhaltung der Wirtschaft notwendig sind.

10.6.2 Top-3-Ratschläge

Es ist immer schwer, gute Ratschläge zu geben, die für jeden sinnvoll sind. Durch die Vielzahl an unterschiedlichen Firmen ist das so pauschal kaum möglich. Es gibt nicht viele Themen, die für viele Unternehmen zutreffen. Daher sind die Ratschläge, die hier gegeben werden, eher allgemeiner Natur, mit der Hoffnung, dass sie dem einen oder anderen beim Thema IT-Sicherheit in Unternehmen helfen.

Top-3-Ratschläge für Personen in der IT-Sicherheit

1. Achte darauf, Mitarbeiter und Talente im Team weiterzubilden und zu fördern, damit jeder auf dem aktuellen Stand der Technik ist.

2. Sorge für schlanke Richtlinien, verständliche/nachvollziehbare Vorgehensweisen (Prozesse und Methoden) und kommuniziere darüber.
3. Dokumentiere jede Entscheidung und jeden Vorfall so detailliert es geht.

Top-3-Ratschläge für Beschäftigte von Unternehmen

1. Nimm die IT-Sicherheitsschulungen und Sicherheitskampagnen ernst – denn der Mitarbeitende ist das größte Ziel von Angreifern.
2. Wenn du unsicher bist, frage lieber einmal zu oft bei der IT-Sicherheit nach als einmal zu wenig.
3. Lass dich von keinem und niemandem zu keiner Zeit unter Druck setzen, um etwas zu tun, was du nicht tun möchtest oder wobei du ein schlechtes Gefühl hast.

Warum IT-Sicherheit zwischen Erfolg und Insolvenz entscheidet

Florian Jörgens



In diesem Beitrag erfahren Sie,

- wieso eine vorausschauende Planung über Erfolg oder Scheitern entscheidet,
- dass Kommunikation der Schlüssel zu mehr Awareness ist,
- wieso der CISO in der Zukunft Mitglied des Vorstands wird und
- wann es unumgänglich ist, zu kündigen und das Unternehmen zu wechseln.

11.1 Das Wichtigste beim Start mit IT-Sicherheit

Eine gewissenhafte und ausführliche Planung stellt eine Grundvoraussetzung für die erfolgreiche Umsetzung dar. Dabei müssen diverse Überlegungen im Vorfeld angestellt werden. Grundsätzlich muss ein Unternehmen sich der Notwendigkeit und Dringlichkeit bewusst sein. Das aktuelle Szenario stellt nicht die Frage, „ob“ ein Unternehmen irgendwann angegriffen wird, sondern „wann und wie es darauf vorbereitet ist“. Dieser Gedanke muss von der obersten Führungsebene verstanden und vorgelebt werden. Die Umsetzung von IT-Sicherheitsmaßnahmen bedingt die Bereitstellung von Ressourcen in Form von Budget, Zeit und Mitarbeitern. Dabei darf nicht vergessen werden, dass auch das Business, also die operativen Abteilungen, ihre Projekte gegebenenfalls herunter priorisieren müssen. Dies bedeutet allerdings auch, dass alle relevanten Stakeholder (intern als auch extern) miteingebunden werden. Dies muss im Vorfeld geschehen, um ein gemeinsames Verständnis des Zielbildes zu haben.

Die Ausgangsbasis für das Befassen mit IT-Sicherheit sollte für Unternehmen immer eine Erhebung des aktuellen Reifegrads darstellen. Dies kann beispielsweise in Form

eines Security-Maturity-Audits durch externe Berater erfolgen. Grundlage hierfür bieten häufig gängige Normen wie die ISO 27001 oder der BSI-Grundschutz. Dabei ist das Ziel nicht, sich in Details zu verlieren, sondern einen allgemeinen Überblick über

- den aktuellen Reifegrad,
- den Reifegrad der Branche und
- das Zielbild

zu erhalten.

Dabei stellt die Grundlage dieser Erhebung das Vorhandensein einer Inventurliste dar. Unternehmen müssen eine vollständige Liste ihrer Assets pflegen und zur Verfügung stellen können. Dies beinhaltet IT-Infrastruktur und -Systeme, Applikationen, Geräte, Schnittstellen, Lizenzen, Berechtigungen und Informationen. Nur durch ein genaues Verständnis der technologischen Landschaft können Schwachstellen identifiziert und angemessene Sicherheitsmaßnahmen implementiert werden.

Dabei ist einer der häufigsten Fehler, Sicherheit als ein rein technisches Problem zu sehen und den Aspekt der Informationssicherheit außen vor zu lassen. Obwohl technische Maßnahmen wichtig sind, muss eine umfassende Sicherheitsstrategie auch Schulungen und Sensibilisierungsmaßnahmen für Mitarbeiter umfassen, um das Bewusstsein für Sicherheitsrisiken zu schärfen und sicherzustellen, dass jeder im Unternehmen seinen Teil zur Sicherheit beiträgt. Der Hintergrund dessen ist die Tatsache, dass – je nach Studienlage – 70 % bis 90 % aller Angriffe auf den Menschen abzielen und lediglich ein kleiner Teil sich rein auf Systeme konzentriert. Darüber hinaus müssen auch Themen wie die physikalische Sicherheit, dargestellt durch den Zutrittschutz, oder der Umgang mit non-digitalen/analoge Dokumenten geregelt werden. Ein weiterer häufiger Fehler ist die Annahme, dass Sicherheit ein einmaliges Projekt ist. Dabei handelt es sich vielmehr um einen Prozess, der in allen Bereichen des Unternehmens implementiert und gelebt werden muss. IT-Sicherheit erfordert kontinuierliche Aufmerksamkeit und Investitionen. Unternehmen sollten nicht den Fehler machen, nach der Implementierung einer Sicherheitslösung davon auszugehen, dass ihre Arbeit getan ist. Die Bedrohungslandschaft verändert sich ständig, daher müssen Sicherheitsmaßnahmen regelmäßig überprüft, aktualisiert und verbessert werden. Die Betrachtung der Bedrohungslandschaft darf sich dabei natürlich nicht nur auf externe Angreifer konzentrieren, sondern auch auf interne Risiken wie unbeabsichtigte Datenlecks, Fehlkonfiguration oder Sabotage. Der letzte, sehr häufig anzutreffende Fehler ist, die Bedeutung der Compliance zu unterschätzen. Unternehmen setzen sich zu spät und nur halbherzig mit regulatorischen Anforderungen auseinander, die es zu erfüllen gilt. Dies kann die DSGVO, NIS-2 oder Cyber Resilience Act sein. Dabei drohen bei Missachtung nicht nur erhebliche Geldbußen, sondern teilweise auch die persönliche Haftung des Managements.

Mit einer entsprechenden vorausschauenden Planung lässt sich die Erfolgswahrscheinlichkeit allerdings auch massiv erhöhen. Ein entscheidender Faktor ist die Un-

terstützung und aktive Beteiligung der Geschäftsleitung. Wenn Führungskräfte die Bedeutung von IT-Sicherheit betonen und Ressourcen bereitstellen, wird dies die Akzeptanz und Umsetzung im gesamten Unternehmen verbessern. Weiterhin muss die Sicherheitsstrategie integraler Bestandteil der gesamten Geschäftsstrategie sein. Diese hat als einzige Aufgabe, das Business zu unterstützen. Um dies zu gewährleisten, muss ein „Security by Design“-Ansatz im gesamten Unternehmen verankert werden. Weiterhin ist es ratsam, sich externe Unterstützung von Spezialisten zu holen. Die Zusammenarbeit mit anderen Unternehmen, Branchenorganisationen und Regierungsbehörden kann dazu beitragen, Informationen über aktuelle Bedrohungen auszutauschen und bewährte Verfahren zu teilen. Sicherheitsunternehmen können auch bei der Erhebung des aktuellen Reifegrads unterstützen. Als letzten Punkt ist die kontinuierliche Verbesserung und Anpassung der Sicherheitsmaßnahmen zu nennen. Diese müssen regelmäßig überprüft, aktualisiert und verbessert werden. Sicherheit ist ein Prozess, kein Projekt.

11.2 Organisatorische Verankerung

Die Sicherheit im Unternehmen steht und fällt mit den Menschen, welche sie täglich leben. Daher erfordert die organisatorische Verankerung eine durchdachte und strukturierte Herangehensweise. Die Grundlage stellt auch hier das Commitment der Geschäftsführung dar, welche die Bedeutung von IT-Sicherheit versteht und aktiv unterstützt. Dies bedeutet, dass Budget für die Einstellung dedizierter Mitarbeiter freigegeben wird. An der obersten Stelle steht hier der Chief Information Security Officer (CISO). Dieser ist ganzheitlich verantwortlich für die Informationssicherheit. Zusammen mit einem Team kümmert er sich um Entwicklung, Implementierung und Überwachung der Informationssicherheitsstrategie. In manchen Unternehmen existiert eine dedizierte Abteilung für IT-Sicherheit. Diese sollte dem CISO unterstellt sein. Es gibt durchaus auch Ansätze, in denen die Abteilung IT-Sicherheit dem Leiter Infrastruktur oder Operations zugeteilt wird. Auch dies ist ein valides Szenario, wobei dann an den CIO berichtet wird. Ein Szenario, welches in der Praxis eine Menge Nachteile mit sich bringt, ist dies, in dem der CISO an den CIO berichtet. Hierbei entstehen diverse Interessenkonflikte, die in der Praxis kaum gelöst werden können. Der CISO sollte daher im Idealfall eine direkte Berichtslinie an den Vorstand haben oder zumindest im Governance-/Compliance-Umfeld verankert sein.

Grundsätzlich ist es möglich, die Verantwortlichkeit innerhalb eines Unternehmens zu delegieren. So kann beispielsweise der CISO oder der CIO die Verantwortlichkeit für die IT-Sicherheit übernehmen. Die Verantwortung an sich obliegt allerdings der Geschäftsführung. Im Falle eines erfolgreichen Cyberangriffs kann diese, beispielsweise bei grober Fahrlässigkeit, zur Haftung herangezogen werden. Daher ist es auch hier entscheidend, dass sich das Topmanagement dessen bewusst ist. In der Praxis ist

aber jeder Mitarbeiter dafür verantwortlich, Schäden vom Unternehmen abzuwehren. Alle Mitarbeiter sollten für IT-Sicherheit sensibilisiert werden und wissen, welche Rolle sie in Bezug auf Sicherheit spielen. Dies kann bedeuten, dass alle Mitarbeiter Schulungen zum Thema IT-Sicherheit erhalten oder dass bestimmte Teams für die Schulung ihrer Mitglieder verantwortlich sind. Um diesen Verantwortlichkeiten nachzukommen, müssen klare Berichtslinien und Kommunikationskanäle festgelegt werden, damit Mitarbeiter wissen, an wen sie sich wenden müssen, wenn sie Sicherheitsbedenken haben oder Sicherheitsvorfälle melden möchten. Wie bereits erwähnt, betrifft IT-Sicherheit nicht nur die IT-Abteilung, sondern das gesamte Unternehmen. Daher sollten Verantwortlichkeiten für IT-Sicherheit in alle Geschäftsbereiche integriert werden, einschließlich Personalwesen, Recht, Compliance, Finanzen und Betrieb. Die festgelegten Verfahren sollten regelmäßig überprüft und aktualisiert werden, um sicherzustellen, dass sie den aktuellen Anforderungen und Bedrohungen entsprechen. Dies erfordert eine kontinuierliche Überwachung der Sicherheitslage und eine agile Anpassung bei Bedarf.

11.3 Verbesserungspotenzial

Natürlich existieren auch Möglichkeiten zur Verbesserung. Dies beginnt bei dem grundlegenden Verständnis über die Risiken, welche die Digitalisierung mit sich bringt. Häufig ist IT-Sicherheit für Mitarbeiter mit geringer Technikaaffinität zu abstrakt. Die Vorstellung, ein Klick auf einen Link oder das Einstecken eines USB-Sticks könnte fatale Folgen haben, ist für manche nicht nachvollziehbar. Hier helfen praxisnahe Sensibilisierungsmaßnahmen wie zum Beispiel Live-Hacking. Die Sicherheitsstrategie ließe sich ebenfalls leichter umsetzen, wenn sie von vornherein in die Businessstrategie und damit auch in die Businessprozesse implementiert würde. Dabei sollte die Sicherheit nicht als separater Aspekt betrachtet werden, sondern eng mit den geschäftlichen Zielen und Strategien des Unternehmens verbunden sein. Eine enge Integration kann dazu beitragen, Sicherheitsmaßnahmen proaktiv zu gestalten und sicherzustellen, dass sie die geschäftlichen Anforderungen unterstützen. Ein „Security by Design“-Ansatz reduziert nachträgliche Kosten und beschleunigt den Freigabeprozess für neue Initiativen. Dies bedingt auch eine verbesserte Zusammenarbeit und Informationsteilung zwischen verschiedenen Abteilungen und Unternehmen. Die interne Kommunikation profitiert davon, dass Projekte zeitnah gemeldet und somit durch die Informationssicherheit mitgestaltet werden können. Der unternehmensübergreifende Austausch hingegen erhöht das Sicherheitsniveau durch das Teilen von Best-Practice-Ansätzen oder Empfehlungen zu Technologieanbietern.

Der letzte Punkt gilt ebenfalls für externe Stakeholder. Bei der Verbesserung der Sicherheit legen Unternehmen häufig den Fokus auf die interne Sicht. Dabei sind das schwächste Glied innerhalb der Kette immer externe Dienstleister. Diese verwenden

teilweise die gleichen vertraulichen Informationen bei wesentlich schlechterem Schutzniveau. Dies macht es Angreifern einfach, nicht ihr direktes Ziel, sondern einen Zulieferer zu attackieren und sich entweder dort die gewünschten Informationen zu besorgen oder deren, schwächer geschützte, Zugänge zu verwenden. Daher ist es wichtig, ebenfalls die externen Partner in die Risikobetrachtung einfließen zu lassen.

11.4 Entscheidende Änderungen bei IT-Sicherheit

Ein wichtiger Aspekt in den letzten Jahren ist die zunehmende Anzahl an Cyberangriffen. Dabei hat sich die Art und Weise der Angriffe kaum verändert. Im Kern basieren diese weiterhin auf ungepatchten Systemen und Phishing-E-Mails im großen Stil. Erschreckend ist allerdings zu sehen, wie schlecht, fast fahrlässig, manche Unternehmen dabei aufgestellt sind. Hier zeigt sich, dass das Thema jahrelang ignoriert wurde. Diesen Technologievorsprung nun wieder einzuholen, stellt Unternehmen vor Herausforderungen und führt dazu, dass Woche für Woche erfolgreiche Angriffe gemeldet werden. Inzwischen hat Cyberkriminalität dabei den weltweiten Drogenhandel als erfolgreichstes Geschäftsmodell abgelöst. Ein weiterer Trend ist die verstärkte Nutzung von Clouddiensten und mobilen Geräten, was zu neuen Herausforderungen in Bezug auf die Sicherheit von Daten und Infrastruktur führt. Unternehmen müssen ihre Sicherheitsstrategien entsprechend anpassen, um diese neuen Technologien und Arbeitsweisen zu berücksichtigen und sicherzustellen, dass ihre Daten und Systeme geschützt sind. Dabei wird häufig davon ausgegangen, eine Auslagerung in die Cloud gehe mit einem Sicherheitsgewinn einher. Allerdings muss sichergestellt werden, dass nicht nur die Konfiguration entsprechend eingestellt ist, sondern die Daten auch verschlüsselt werden. Darüber hinaus gewinnt auch die Einhaltung von regulatorischen Anforderungen wie der DSGVO, NIS-2 oder der CRA an Bedeutung. Dabei betreffen diese nicht nur Unternehmen der kritischen Infrastruktur (KRITIS), sondern alle Branchen und Größen. Unternehmen müssen sicherstellen, dass sie diese Anforderungen erfüllen, um rechtliche Konsequenzen und finanzielle Verluste zu vermeiden. Während sich im Rahmen von Sensibilisierungsmaßnahmen der Ansatz innerhalb der letzten Jahre kaum geändert hat, gab es auf technischer Seite einige gravierende Neuerungen. Dazu zählt zum Beispiel die Implementierung der Zero-Trust-Architektur, bei der nicht mehr davon ausgegangen wird, dass interne Netzwerke sicher sind. Stattdessen werden jeder Benutzer und jedes Gerät streng authentifiziert und autorisiert, unabhängig davon, ob sie sich innerhalb oder außerhalb des Netzwerks befinden. Weiterhin hat die stetig wachsende Zahl an internetfähigen Geräten dazu geführt, dass die Bedeutung deren Sicherheit steigt. Unternehmen erkennen die Notwendigkeit, IoT-Geräte angemessen zu schützen, um potenzielle Einfallstore für Cyberangriffe zu minimieren. Dies wird auch durch die zukünftige Regulierung über den Cyber Resilience Act vorangetrieben. Die letzte große Veränderung betrifft den

Bereich der künstlichen Intelligenz und des maschinellen Lernens. Die verstärkte Nutzung dieser Technologien kann dazu führen, Anomalien und verdächtiges Verhalten frühzeitig zu erkennen und automatisierte Reaktionen zu starten. Natürlich werden auch Kriminelle diese Möglichkeiten nutzen, um demnach intelligente Angriffe zu starten.

11.5 Besondere IT-Sicherheits Herausforderungen in der eigenen Branche

Die derzeit größte Bedrohung für Unternehmen stellen nach wie vor Ransomware-Angriffe dar. Angreifer werden immer dabei immer dreister, um sensible Daten zu verschlüsseln und Lösegeld zu erpressen. Dabei wird auch vor Angriffen auf kritische Infrastrukturen wie Krankenhäuser nicht haltgemacht. Ein erfolgreicher Angriff führt erfahrungsgemäß zu unmittelbaren finanziellen Einbußen bis teilweise zur Insolvenz. Die weltweite Vernetzung und damit verbundene verstärkte Nutzung von Clouddiensten führen zu weiteren Herausforderungen. Die Migration in die Cloud eröffnet zwar viele Vorteile, birgt aber auch Risiken wie Datenlecks, unzureichende Zugriffskontrollen und Compliance-Probleme. Die oben erwähnte Vernetzung und Digitalisierung von Geräten führt noch zu einem weiteren Problem: das Internet der Dinge (IoT). Mit der zunehmenden Verbreitung von IoT-Geräten in Unternehmen steigt auch die Bedrohung durch Sicherheitsvorfälle im Zusammenhang mit diesen Geräten. Viele IoT-Geräte sind schlecht gesichert und stellen potenzielle Einfallstore für Cyberangriffe dar. Unternehmen müssen daher sicherstellen, dass ihre IoT-Geräte angemessen geschützt sind und nicht zum Schwachpunkt ihres Sicherheitssystems werden. Dies gilt aber auch für private Geräte, da diese übernommen und als Teil eines Botnetzes für Angriffe zweckentfremdet werden können. Die Nutzung von künstlicher Intelligenz kann Herausforderung und Chance zugleich darstellen. So können auf der einen Seite Kriminelle ihre Angriffe automatisiert und gezielter starten, auf der anderen Seite kann diese Technologie aber auch zur Abwehr genutzt werden. Was allerdings für beide Seiten eine große Herausforderung darstellt, ist der Mangel an Fachkräften. Es ist schwierig, talentierte Mitarbeiter zu finden und zu halten, die über die erforderlichen Fähigkeiten und Kenntnisse verfügen, um die ständig wachsenden Sicherheitsbedrohungen zu bewältigen.

11.6 Rolle des „IT-Sicherheitsverantwortlichen“

In diesem digitalen, von Informationen geprägten Szenario wird der CISO an enormer Bedeutung gewinnen. War es für Unternehmen vor einigen Jahren noch unvorstellbar, einen dedizierten Sicherheitsverantwortlichen im Unternehmen zu beschäftigen, so hat die Rolle des CISO inzwischen selbst im Mittelstand an Normalität gewonnen. Dabei ist der Aufgabenbereich weiter zu fassen als die Umsetzung der Informationssicherheits-/IT-Sicherheitsstrategie. Der moderne CISO stellt in seiner Rolle den Enabler für das Business dar und vermittelt über sämtliche Fachbereiche hinweg. Durch das zunehmende Outsourcing von IT-Leistungen löst er damit in seiner Wichtigkeit stellenweise den CIO ab. Die amerikanische Aufsichtsbehörde, SEC, fordert seit geraumer Zeit eine Steigerung des Cyber-Security-Know-hows im Vorstand. Dies wird langfristig den Weg des CISO in das Topmanagement eröffnen. Unabhängig vom Titel ist es unabdingbar, dass der Verantwortliche mit entsprechenden Ressourcen ausgestattet wird. Dazu zählen neben einem eigenen Budget auch Mitarbeiter für ein eigenes Team. Darüber hinaus müssen auch entsprechende Durchgriffsrechte überlassen werden, um nicht nur die Fachbereiche zur Umsetzung von Richtlinien zu bewegen, sondern auch im Falle eines Angriffs Systeme vom Netz nehmen zu dürfen.

Trotz der vielen erfolgreichen Sicherheitsinitiativen der letzten Jahre könnte die Frage „Was würden Sie heute anders machen?“ gestellt werden. Aus meiner persönlichen Sicht ist das vor allem ein Hinweis für all diejenigen, welche in Positionen arbeiten, die lediglich eine Alibifunktion erfüllen. Gelegentlich versucht das Topmanagement, seine Aktionäre und andere Stakeholder mit der Schaffung von Security-Positionen zu beruhigen, ohne dass diese tatsächlich operative Möglichkeiten haben. Dazu zählen beispielsweise CISOs ohne Budget oder Führungsverantwortung. Es ist wichtig, anzuerkennen, dass effektive IT-Sicherheit mehr als nur das Einrichten einer Sicherheitsabteilung oder das Benennen eines CISO bedeutet. Vielmehr erfordert es eine ganzheitliche Strategie, die von der Unternehmensführung getragen und in alle Aspekte des Unternehmens integriert ist. Dies beinhaltet nicht nur die Bereitstellung angemessener Ressourcen und Autorität für Sicherheitsverantwortliche, sondern auch die Schaffung einer Sicherheitskultur, in der Sicherheit als gemeinsame Verantwortung aller Mitarbeiter betrachtet wird. Mitarbeiter in solchen Positionen sollten das sinkende Schiff daher schnell verlassen und sich nach neuen Positionen umschauen oder aber akzeptieren, dass sie zahnlose Tiger bleiben.

11.7 Kompetenzen der IT-Sicherheitsverantwortlichen sowie aller Beschäftigten

IS-/IT-Sicherheitsverantwortliche sollten einige Kompetenzen mitbringen. Als Erstes sollten sie über ein tiefes Verständnis der technischen Aspekte von IT-Systemen, Netzwerken und Anwendungen verfügen. In der Praxis ist es abhängig von der Rollenbeschreibung, ob sie ebenfalls in der Lage sein sollten, komplexe Sicherheitslösungen zu entwerfen, zu implementieren und zu warten. Unabhängig davon dient das Verständnis dazu, mit Technikern auf Augenhöhe kommunizieren zu können. Da strategische Entscheidungen im Sicherheitsumfeld häufig auf Risiken basieren, ist ein Verständnis von Risikomanagementpraktiken entscheidend, um potenzielle Sicherheitsrisiken zu identifizieren, zu bewerten und angemessen darauf reagieren zu können. Zum grundlegenden Handwerk gehört dabei, dass Verantwortliche in der Lage sind, Risikobewertungen durchzuführen und Strategien zur Risikominderung zu entwickeln. Die wohl mit Abstand wichtigste Kompetenz liegt darin, effektiv mit anderen Führungskräften, Mitarbeitern und externen Partnern kommunizieren zu können. Die Verantwortlichen sollten in der Lage sein, komplexe Sicherheitskonzepte verständlich zu erklären und sicherzustellen, dass Sicherheitsrichtlinien und -verfahren angemessen umgesetzt werden. Dazu gehört auch, die Sprache des Business zu sprechen.

Neben diesen grundlegenden Kompetenzen wird es in absehbarer Zukunft neue Anforderungen geben, sodass sich die Verantwortlichen weiterentwickeln müssen, da sich die Technologie und die Bedrohungslandschaft kontinuierlich verändern. Der Fokus wird dabei verstärkt auf der Nutzung künstlicher Intelligenz und Automatisierung liegen. Die Digitalisierung und inzwischen unendliche Menge an Informationen machen eine manuelle Verarbeitung unmöglich. Technische Systeme können hier unterstützen, müssen aber effektiv eingesetzt und verwaltet werden. Parallel dazu steigt auch die Anzahl regulatorischer Anforderungen und Compliance-Vorgaben. Dies erhöht den Bedarf an Kenntnissen im Bereich Datenschutz, Governance und Sicherheitsstandards. Dabei müssen die Verantwortlichen in der Lage sein, die neusten Vorschriften zu verstehen, gegenüber dem Business in verständliche Sprache zu übersetzen und sicherzustellen, dass das Unternehmen diesen Anforderungen gerecht wird.

Hierbei darf allerdings nicht der Mitarbeiter aus dem Fachbereich außer Acht gelassen werden. Wie bereits zu Beginn erwähnt, zielt ein Großteil aller Cyberangriffe auf den Menschen ab. Die kontinuierliche Schulung der Mitarbeiter muss damit im Mittelpunkt einer jeden Sicherheitsinitiative stehen. Dabei gibt es unterschiedliche Methoden und Ansätze, dieses Ziel zu erreichen. Grundlegende Inhalte, welche den Mitarbeitern vermitteln werden sollten, sind dabei der sichere Umgang mit Informationen gemäß Vertraulichkeitsklasse, die Erkennung verdächtiger E-Mails, das Melden von Vorfällen und die Einhaltung der geltenden Richtlinien. Alles Weitere muss im Einzelfall für jedes Unternehmen individuell festgelegt werden.

Wie können/sollten Unternehmen die erforderlichen Kompetenzen der IT-Sicherheitsverantwortlichen und aller Beschäftigten gewährleisten?

Um den Aufbau einer Kultur der Cybersicherheit dauerhaft zu gewährleisten, ist es sinnvoll, auf Experten für das Thema Awareness zurückzugreifen. Berater wie auch externe Anbieter unterstützen bei dem Aufbau einer dauerhaften Sensibilisierungskampagne. Diese basiert auf spannenden, interaktiven Inhalten und dem regelmäßigen Überprüfen und Aktualisieren dieser.

Lessons Learned aus bisherigen IT-Sicherheitsinitiativen

Rückblickend betrachtet war vor allem eine spezielle Awareness-Kampagne besonders erfolgreich, welche für ein deutsches Chemie-Unternehmen durchgeführt wurde. Dabei wurden die Mitarbeiter nicht nur an unterschiedlichen Standorten über 2,5 Stunden geschult, sondern auch in die Welt der Cyberkriminellen eingeladen. Durch umfangreiches Aufzeigen von Live-Hacking war es auch technisch weniger affinen Mitarbeitern möglich, einen Einblick zu bekommen, wie Angreifer vorgehen. Diese und weitere Initiativen, verpackt in den Aufbau einer firmeninternen Cyber-Security-Marke, führten zum Erreichen des Digital Leader Award in der Kategorie Cyber-Security.

11.8 Top-3-Ratschläge

Abschließend lässt sich sagen, dass Sicherheitsverantwortliche auf der einen Seite zwar einem hohen Workload ausgesetzt sind, auf der anderen Seite aber auch immer mehr Ressourcen und Rückendeckung durch das Topmanagement erhalten. Diese Mittel sind unabdingbar für die korrekte Ausführung der Position. Sollten diese nicht bereitgestellt werden, ist es sinnvoll, das Unternehmen zu verlassen.

Einen weiteren großen Vorteil haben diejenigen, welche sich innerhalb der Branche vernetzen und sich regelmäßig austauschen, sei es auf Messen, Tagungen oder Kongressen. Am Ende des Tages sitzen alle Sicherheitsverantwortlichen in einem Boot und wollen die Businessstrategie ihres Unternehmens unterstützen. Ein vertraulicher Austausch bietet daher Vorteile für alle Beteiligten und stellt somit einen Vorteil gegenüber den Angreifern dar.

Letztendlich muss man sich über eins im Klaren sein: Eine 100%ige Sicherheit ist eine Illusion. Dennoch lautet die Frage nicht, „ob“, sondern „wann“ ein Unternehmen angegriffen wird. Vorbereitung ist dabei der Schlüssel zum Erfolg. Für den regulären Mitarbeiter hingegen dürfte es schon ausreichen, sich an folgende Punkte zu halten:

- Verwendung unterschiedlicher, komplexer Passwörter,
- das zeitnahe Einspielen von Aktualisierungen und Patches sowie
- die Aktivierung der Multi-Faktor-Authentisierung.

IT-Sicherheit heute und morgen – aus Sicht eines CISO

Markus Schmall



In diesem Beitrag erfahren Sie,

- welche grundlegenden Aspekte Verantwortliche für IT-Sicherheit/CISOs beim Setup von Sicherheitsorganisationen/Programmen zu beachten haben,
- wie wichtig der Faktor Mensch für das Thema IT-Sicherheit ist,
- welche Fehler vermieden werden können und
- wie wichtig es ist, zwischen Zertifizierungen und echter Resilienz zu unterscheiden.

12.1 Das Wichtigste beim Start mit IT-Sicherheit

Der Startpunkt für eine verstärkte bzw. erstmalige Beschäftigung mit dem Thema IT-Sicherheit kann verschiedenste Ursachen haben. Treiber hierfür sind häufig:

- Reaktion auf konkret erfolgte Angriffe in der Vergangenheit
- Reaktion auf allgemein gestiegene Bedrohungslage
- notwendige Compliance zu gesetzlichen/regulatorischen Vorgaben (z. B. NIS-2, DORA und KRITIS)
- Kundenanforderungen nach Zertifizierung (z. B. ISO 27 001, TISAX)
- Anforderungen von Investoren/Stakeholdern

Die Etablierung robuster Resilienzstrategien ist entscheidend für den nachhaltigen Schutz gegen Cyberbedrohungen. Unternehmen, die sich an internationalen Standards wie ISO 27 001 orientieren, schaffen eine solide Grundlage für ihre Sicherheitsarchitektur.

Zertifizierungen bieten zwar einen wichtigen Rahmen, jedoch ist es essenziell, dass Sicherheitsmaßnahmen nicht nur implementiert, sondern auch aktiv gelebt werden. Zertifizierungen allein genügen oft nicht, um ein dauerhaft hohes Sicherheitsniveau zu gewährleisten, insbesondere wenn sie lediglich als Reaktion auf Kundenanforderungen durchgeführt werden.

Wir konzentrieren uns darauf, Resilienz systematisch zu verbessern und die Sicherheit als integralen Bestandteil der Unternehmenskultur zu verankern. Nur so kann gewährleistet werden, dass Sicherheitsprotokolle nicht nur formell existieren, sondern auch effektiv zum Schutz des Unternehmens beitragen.

Ein zentraler Erfolgsfaktor für eine wirkungsvolle Sicherheitsstrategie sind die klare Kommunikation mit dem Kunden und die Wahrnehmung von Sicherheit als wertsteigernde Instanz innerhalb des Unternehmens.



Technische Sicherheit (als Oberbegriff für Informationssicherheit, IT-Sicherheit, Produktionssicherheit und Cyber Defense) sollte immer ganzheitlich betrachtet werden. Fahrlässig ist es, rein auf technische Aspekte abzielen, genauso wie die Fokussierung auf Compliance-Aspekte.

In der Praxis ist Informationssicherheit häufig eine Unterdisziplin der IT-Sicherheit, die sich rein um Vorgaben, Klassifizierung und Umgang mit Daten kümmert. Hierbei ist die inhaltliche Nähe zur Datenschutzfunktion zu beachten. Im Datenschutz wird häufig über sogenannte TOMs (technisch organisatorische Maßnahmen) gesprochen. Viele Organisationen definieren im Datenschutz keine eigenen TOMs, sondern stellen über die IT-Sicherheitsanforderungen die Compliance her. Dieser Ansatz ist sehr empfehlenswert, da so doppelte Anforderungen zu dem gleichen Themenkomplex wie z. B. Verschlüsselung vermieden werden.

Die eigentliche technische Resilienz und Implementierung obliegt eh typischerweise der IT-Sicherheitsfunktion bzw. den jeweiligen Technischeinheiten.

Abhängig von dem jeweiligen primären Treiber, sind das Vorgehen und das Setup zu differenzieren. Grundsätzlich bleibt aber bei allen Ausrichtungen der Sicherheit, dass eine saubere Bestandsaufnahme durchgeführt werden muss.



Beim initialen Setup sollten also klar die Prioritäten für die Sicherheitsorganisation geklärt werden. Eine rein auf ISMS ISO 27001 fokussierte Sicherheitsorganisation läuft Gefahr, den elementaren Punkt der Resilienz zu ignorieren. Eine rein auf Resilienz ausgelegte Sicherheit wird bei anstehenden Zertifizierungen durch Kunden zumindest Dokumentation nachproduzieren müssen.

Zertifizierungen bzw. die Ausrichtung an Standards bilden eine solide Grundlage für die Implementierung von Sicherheit, insbesondere für Organisationen, die über eingeschränktes Sicherheitswissen verfügen.

Jedoch bietet eine Zertifizierung allein nur eine begrenzte Sicht auf die implementierte Sicherheit eines Unternehmens. Viel wichtiger ist, dass Sicherheit tatsächlich gelebt wird. Häufig führen Unternehmen Zertifizierungen ausschließlich durch, um den jeweiligen Kundenanforderungen gerecht zu werden, wodurch eine wirklich motivierte Zertifizierung auch in den nächsten Jahren selten bleibt.

Im Folgenden konzentrieren wir uns auf die Etablierung einer höheren Resilienz, wobei der Schwerpunkt auf der Zertifizierung nach ISO 27 001 oder einem vergleichbaren Standard liegt.

Ein wesentlicher Erfolgsfaktor einer Sicherheitsfunktion ist es, die Sprache des Kunden zu sprechen und die Sicherheit klar als wertschöpfende Instanz zu verstehen.

12.2 Aufnahme des IST-Zustands

Wichtig ist, eine saubere IST-Aufnahme durchzuführen, um hieraus die nächsten Schritte abzuleiten. Hierbei ist zu beachten, dass ein umfassender Überblick über die Organisation notwendig ist, ein alleiniger Blick auf technische Aspekte ist nicht ausreichend, jedoch ein entscheidender Baustein.

Hier gibt es sicherlich mehrere Wege zum Ziel. Ein empfehlenswerter Weg kann der Weg über die Kontrollen eines der bekannten Frameworks wie NIST oder ISO 27 001 sein. Zumindest dienen diese Kontrollen zur Überprüfung, ob generelle Aspekte beachtet worden sind. Dieser Ansatz hilft es Dritten, den strukturierten Ansatz nachzuvollziehen.

Aspekte der IST-Aufnahme sollten mindestens umfassen:

- Prozesse in der Entwicklung/im Demand bzw. Anforderungsmanagement inklusive Risk Management
- Verteilung SAAS, Commercial of the Shelf (COTS) und Eigenentwicklungen (als Basis für die Identifikation notwendiger Anforderungen/Controls)
- Awareness der Mitarbeiter und Mitarbeiterinnen/Awareness-Programme
- Ausbildungsstand der Mitarbeiter und Mitarbeiterinnen (primär im technischen Bereich, aber auch im Bereich technische Sicherheit)
- Implementierte Architektur (DMZ/MZ, Segmentierung, Netzwerkübergänge, Remote Access, Privilege Access Management)
- Identity and Access Management inklusive Joiner-/Mover-/Leaver-Prozesse
- Relevante Entscheidungsgremien für Sicherheitsthemen (viele Firmen implementieren z. B. Information Security Boards als gemeinsames Entscheidungsgremium für CSO, CISO und IT)

- Relevante regulatorische Vorgaben inklusive etwaig vorhandene Monitoring-Prozesse
- Etwaig vorhandene Auflagen für Betriebsgenehmigungen bzw. Ergebnisse aus regulatorischen externen Audits
- Schnittstellen zu Einkauf, Legal und Datenschutz im Allgemeinen (sind z. B. Vorgaben vorhanden, dass kein Einkauf ohne Freigabe der Sicherheit erfolgen darf?)
- Existente Sicherheitsvorgaben und Vorgabenpyramide (Top Level Policies, Sicherheitsvorgaben und gegebenenfalls Implementierungs-Guidelines)
- Klassifikationsvorgaben für Informationen
- Setup der (potenziell vorhandenen) Sicherheitsorganisation (inklusive 1st-Line-, 2nd-Line- und 3rd-Line-Strukturen)
- Ressourcen in der Sicherheitsorganisation (inklusive Benchmarking)
- Vorhandensein einer Cyber-Security-Versicherung und von Incident-Response-Verträgen (gegebenenfalls inklusive Wochenendverfügbarkeit und auch Unterstützung bei Ransomware-Verhandlungen)
- Positionierung der Sicherheit in der Firma (d. h., wird die Sicherheit als „notwendiges Übel“ oder als echt helfende Instanz verstanden?)
- Erkennung der Hauptangriffsvektoren/Angreiferklassen/Angriffspfade
- Technischer Stand der Verteidigungsfähigkeit (eingesetztes Tooling, aber auch etablierte Incident-Response-Prozesse)

Ein weiterer Ansatz kann die Verwendung eines technisch fokussierten Frameworks wie der Controls des Centre for Internet Security (siehe <https://www.cisecurity.org/controls>), angereichert um Zusatzaspekte wie z. B. Incident-Response-Fähigkeiten (z. B. Retainern), sein.



Die CIS-Organisation bietet umfangreiche Ressourcen im Bereich Sicherheit an, häufig werden Härtungsvorgaben von CIS in Firmen verwendet.

Die CIS Controls sind in 18 Dimensionen aufgeteilt, und eine umfassende IST-Aufnahme ist auf diese Weise möglich. Da sowohl technische, prozessuale Faktoren als auch der Mensch betrachtet werden, hat sich dieses Framework bewiesen.

Hierbei ist auch generell zu beachten, dass eine Sicherheitsorganisation heutzutage dann erfolgreich ist, wenn:

- sie die Sprache ihrer Kunden spricht (z. B. die der internen IT, aber auch des Vorstands und des Aufsichtsrats)
- sie Lösungen anbietet und nicht nur Fehler findet

- sie pragmatisch agiert
- sie tragbare Risiken gemeinsam mit der Fachseite trägt

Gerade der letzte Punkt, d.h. die Aussage, dass eine Sicherheitsfunktion für einen Zeitraum unter Berücksichtigung aller Randaspekte ein Risiko mitträgt, ist ein enorm starkes Signal einer Sicherheitsorganisation (dennoch ein Ansatz, der in einem risikoaversen Umfeld selten verwendet wird).

In der Praxis hat sich dieses Vorgehen dennoch bewährt, da es das „Wir“-Gefühl zwischen verschiedensten Organisationen stärkt.

12.2.1 Verständnis der Angriffsvektoren/Angreiferlage

Als Teil der Bestandsaufnahme ist es wichtig, einen Schritt zurückzugehen und auch eine klare Identifikation durchzuführen, wer letztendlich die relevanten Angreifer sind.

Häufig wird hierzu folgende Unterteilung in Angreiferklassen verwendet:

- Innentäter
- Hacker für Ruhm und Ehre
- Politisch motivierte Hacker
- Organisierte Kriminalität
- Staatlich unterstützte Angreifer

Die Angreifer zu kennen und auch dem oberen Management dies darzustellen, hilft, sowohl finanzielle/personelle Mittel zu rechtfertigen, als auch ein gemeinsames Ambitionslevel („Risikobereitschaft“) zu definieren.



Ein Verständnis über die relevanten Angreiferklassen hilft, das Ambitionsniveau für die Resilienz und „einen gemeinsamen Feind“ zu definieren. Letztendlich können Sie so den Angreifer auch für das Topmanagement „anfassbar“ machen.

Ergänzend kann hier auch die Kombination mit einschlägigen Sicherheitslageberichten (siehe <https://www.enisa.europa.eu/topics/cyber-threats/threats-and-trends>) hilfreich sein, um ein Verständnis zu wecken, wie vielfältig die Angriffswege der einzelnen Angreifergruppen sind.

Die so gewonnenen Informationen können auch für regelmäßige Berichte an den jeweiligen Vorstand/Aufsichtsrat genutzt werden (Stichwort Bedrohungslandkarte).

Dieses Wissen kann ebenso in die allgemeine Risikobewertung/Priorisierung von Maßnahmen mit einfließen, wie z. B. in aktueller Regulierung wie dem aktuellen NIS-2-Gesetz gefordert wird.

12.2.2 Verständnis der Angriffspfade

Der nächste Schritt in der Bestandsaufnahme sollte sein, alle relevanten Angriffspfade der zuvor definierten Angreifer und Angriffsvektoren zu identifizieren.

Hierfür gibt es verschiedenste Datenquellen, wie zum Beispiel das MITRE Attack Framework (siehe MITRE). Da dieses bei allen Sicherheitsexperten hoch angesehen ist, stellt es geradeaus eine perfekte Basis für die Angriffspfadbetrachtung dar (für die Kommunikation in Richtung Topmanagement sollten die Inhalte jedoch abstrahiert werden).

Heute relevant ist die Bedrohung durch Schadsoftware. BSI/MITRE und ENISA verwenden verschiedene Begriffe, eine allgemeine Zusammenfassung dieser Bedrohung kann z. B. „Ransomware/Malware/Threats against data“ sein.

An dieser Stelle ist nun die Bedrohung bekannt, in einem nächsten Schritt kann festgehalten werden, dass diese Bedrohung primär von der organisierten Kriminalität ausgeht (nachgelagert auch durch staatliche Angreifer und bösartige Insider).

Je nach Firmenstruktur und potenziellen Zielsystemen können jetzt ein Angriffspfad und auch die jeweiligen Abwehrmaßnahmen aufgenommen werden.

Ein Beispiel aus der chemischen Industrie

Angriffspfade für die Bedrohung „Ransomware/Malware/Threats against data“ sind:

- Schwachstellen in Software
- E-Mail
- Mobile Speichermedien/USB-Sticks
- Kompromittierung externer Interfaces/Geräte
- (vereinzelt) Download verseuchter Software (auch durch externe Dienstleister)
- Aufruf von verseuchten Webseiten
- Verseuchte Hardware von Fremdfirmen (MITRE: Transient Cyber Asset)
- Unverschlüsselte Kommunikation
- Man-in-the-Middle-Angriffe (MITM; wobei dieser Punkt tatsächlich eher eine Randerscheinung darstellt und mitunter von staatlichen Angreifern verwendet wird).

Abwehrmaßnahmen (Beispiele):

- Mehrstufige Antivirus-Lösungen
- Mehrstufige E-Mail-Sicherheitslösung
- Überwachung des Internetverkehrs auf Basis von Internetproxy

- 24x7 Security Operations Center
- Segmentierung der Produktionslandschaft
- Einsatz der Firewalls zur Überwachung der Netzwerkübergänge
- Patch-Management
- Benutzer- und Berechtigungsmanagement
- Schutz externer Interfaces
- Einsatz von Quarantänesystemen zum Einschleusen externer Dateien in die OT-Netzwerke und Verwendung unterschiedlicher Protokolle für die Übertragung



Das MITRE Attack Framework bietet eine sehr gute Aufbereitung der Bedrohungen/Angriffsvektoren und kann als Referenz verstanden werden.

Auf der Grundlage eventuell fehlender Abwehrmaßnahmen kann eine risikoorientierte Roadmap zur Implementierung geeigneter Maßnahmen entwickelt werden. Da risikominimierende Maßnahmen häufig auf verschiedenen Angriffspfaden ähnlich sind, empfiehlt es sich, zunächst eine detaillierte Analyse der Angriffspfade durchzuführen und anschließend die entsprechenden Maßnahmen abzuleiten.



Es gibt erste SIEM/Angriffserkennungstools, die sich sehr stark an dem MITRE Framework orientieren, um eine Abdeckung von z. B. Datenquellen für Angriffspfade sicherzustellen. Die Definition der notwendigen Abwehrmaßnahmen kombiniert mit einem Abwehr-Tooling, welches ebenfalls auf MITRE aufsetzt, ermöglicht demnach eine adäquate Übersicht.

12.3 Typische Fehler

Es gibt auf verschiedenen Ebenen klassische Stolpersteine für den Erfolg einer Sicherheitsfunktion. Diese sind teilweise außerhalb des direkten Einflussbereichs der Sicherheitsfunktion.

Zwei klassische Fehler auf unternehmensweiter Ebene sind:

- (Unternehmensweit) falsches Verständnis der Verantwortung für IT-Sicherheit
- (Unternehmensweit) falsches organisatorisches Setup bzw. falsche Verankerung in der Organisation

IT-Sicherheit wird zu häufig als reines Problem der IT verstanden, und im gleichen Zug wird angenommen, dass die Herausforderungen der IT-Sicherheit rein durch Technik zu lösen sind. Beide Annahmen sind als falsch zu betrachten:

- Das Beispiel TISAX-Zertifizierung zeigt, wie wichtig eine funktionierende Sicherheitsfunktion ist, am Ende wird aber ein jeweiliger Standort zertifiziert und nicht die Sicherheitsfunktion, d. h., Standortverantwortliche müssen die Zertifizierung treiben. Die Verantwortung liegt also nicht zwangsläufig bei der IT-Sicherheit, sondern bei dem Standortleiter. In der Praxis hat sich hier ein Tandem mit Lead durch den Standortleiter als sinnvoller Weg dargestellt.



Eine TISAX-Zertifizierung wird heutzutage von der (deutschen) Automotive-Branche gefordert, um Sicherheit in der Lieferkette sicherzustellen. Der zugrunde liegende Information Security Annex (ISA) basiert auf ISO27 001 und Best Practices.

- Der Fakt, dass heutzutage Software auch häufig durch Fachbereiche eingekauft wird (und so mitunter Schatten-IT entsteht), stellt einen weiteren Grund dar, dass IT-Sicherheit eine Aufgabe jedes Mitarbeitenden im Unternehmen ist.



IT-Sicherheit ist eine Aufgabe für das ganze Unternehmen, explizit nicht nur von der IT-Sicherheitsfunktion oder der Technik. Grundsätzlich ist es hilfreich, wenn es ein Top-Level-Commitment zum Thema Sicherheit vom jeweiligen Vorstand gibt.

Ein weiterer Stolperstein ist der Einkauf von Hardware bzw. Software ohne Einbindung von Governance-Funktionen wie Architektur und Sicherheit.

Es muss sichergestellt werden, dass IT/allgemeine technische Komponenten nicht ohne Kenntnis der Sicherheit eingekauft werden können.

Hier ist es ratsam, einen engen Schulterschluss mit dem Einkauf zu suchen und so zu verhindern, dass Bestellungen in gemeinsam definierten Warengruppen ausgelöst werden können, deren Inhalt nicht von der Sicherheit vorher bewertet worden sind.

Gibt es typische Fehler in der Sicherheit oder der Sicherheitsorganisation selbst?

Klassische 1st-Line- und 2nd-Line-Organisationssetups führen zwangsweise zu einer Entfremdung der Vorgabenebene (2nd Line) von der betrieblichen Realität. Die Gefahr der „Elfenbeinturm“-Mentalität entsteht somit.

In Bereichen mit Spielraum empfiehlt es sich zudem, eine lebbare „80 %-Sicherheit“ zu etablieren anstelle einer nicht umsetzbaren „100 %-Sicherheit“. Besagte „80 %-Sicherheit“ kann als Startpunkt für einen weiteren Ausbau verwendet werden, ist somit ein stabiles Fundament.



Klassische Strukturen der 1st Line (operative Sicherheit, IT), 2nd Line (Vorgaben) und 3rd Line (Audit) sind nicht mehr zeitgemäß. Eine 1.5-Line-Sicherheitsorganisation bringt deutliche Vorteile für die Positionierung und Entscheidungsfindung. Die 3rd Line als klassische Auditfunktion ist weiterhin elementar wichtig für die unabhängige Kontrolle.

Es muss darauf geachtet werden, dass die IT-Sicherheit und die internen Unternehmenseinheiten („die Kunden“) dieselbe Sprache sprechen. Ohne dieses Fundament der Zusammenarbeit kann die IT-Sicherheit nicht effektiv agieren. Der Sicherheitsverantwortliche/CISO/Informationssicherheitsbeauftragte spielt hierbei eine zentrale Rolle, da er die Sicherheitslage den jeweiligen Vorständen und Aufsichtsräten verständlich darstellen und vermitteln muss.

Regulatorische Anforderungen führen häufig dazu, dass das Finden von Fehlern (z. B. Risk Assessments/Risiko Management) in den Vordergrund der IT-Sicherheitsarbeit rückt. Obwohl dies grundsätzlich wichtig ist, besteht die Gefahr, dass der Fokus zu sehr auf das Finden von Fehlern gelegt wird.

Die Aufgabe der IT-Sicherheit sollte darin bestehen, einen sicheren Geschäftsbetrieb zu ermöglichen und das Risiko für die Organisation in Bezug auf IT-Sicherheit auf ein angemessenes Niveau zu senken.

Der Aspekt der entwicklungsbegleitenden, beratenden IT-Sicherheit ist hier besonders hervorzuheben. Dies umfasst ebenso das betriebliche Patchmanagement, Schwachstellenmanagement und den Betrieb eines SIEM-Systems.

12.4 Organisation

Mit dem Verständnis über die Positionierung der Sicherheit und der Umgebung kann nun eine passende Organisation definiert werden.

Technische Sicherheitsfunktionen umfassen heute u. a. Elemente wie:

„2nd Line“-Aufgaben

- Vorgaben/Policies/Standards
- Risk Assessment

„1st Line“-Aufgaben

- CERT/SOC/Cyber Defense
- Architektur/Consulting
- Awareness
- Supplier Security
- Pentesting/Red Team



Red Teaming, d. h. Sicherheitstests ohne vorherige Ankündigung, stellen ein adäquates Mittel dar, neben der eigentlichen technischen Resilienz ebenfalls die Monitoringaspekte der Cyber CyberDefense und des Betriebs zu analysieren.

Die Organisation/Verankerung der Sicherheitsorganisation wird heute auch häufig durch regulatorische Vorgaben beeinflusst. So fordern Regulatoren im Finanzbereich häufig eine klare Trennung zwischen Vorgabe (CISO) und „umsetzender“ IT-Sicherheit. Diese Forderung basiert auf der (mitunter berechtigten) Sorge, dass eine CISO-Funktion als Teil der IT nicht effektiv agieren kann, da es zu einer Übersteuerung durch den CIO kommen kann.

Pauschale regulatorische Forderungen ohne Augenmaß umzusetzen ist mitunter nachteilig, vielmehr hängt es von dem jeweiligen Kontext bzw. Setup der Firma ab, ob eine IT-Sicherheit als Teil der IT sinnvoll ist oder eben nicht.

Die Trennung zwischen 1st Line Security (z. B. IT, SOC etc.) und 2nd Line Security (Vorgaben, CISO) birgt aber die Gefahr der Entfremdung und führt mitunter zu realitätsfremden Vorgaben.

In der Praxis habe ich selten erfolgreiche Organisationen gesehen, die dem strikten 1st Line-/2nd Line-Modell gefolgt sind und gleichzeitig erfolgreich waren.

Häufig empfiehlt sich daher ein 1.5 Line-Modell. Dabei werden 1st Line und 2nd Line in einer Organisation zusammengeführt. Der Vorteil liegt klar auf der Hand, die Vorgaben bekommen mehr Realitätsnähe, und es bedarf keiner dedizierten Funktion, die ausschließlich Policies pflegt.

In vielen Firmen werden verschiedene Sicherheitsfunktionen wie Netzwerksicherheit und IT-Sicherheit nicht in einer großen Sicherheitsorganisation vereint, sondern getrennt organisiert.

Dieser Ansatz ist häufig historisch gewachsen und etabliert, birgt aber auch Herausforderungen in sich.

Die zunehmende Konvergenz von IT und NT/OT führt zu einer Verschmelzung zumindest in einigen Bereichen. Die Verschmelzung der verschiedenen technischen Sicherheitsfunktionen in einer Organisation scheint daher eine adäquate Lösung.

Auf der anderen Seite ist es sinnvoll, innerhalb der Sicherheitsorganisationen getrennte Beratungsfunktionen für Produktion/Netzwerk und IT vorzuhalten. Dies ermöglicht eine optimierte Begleitung der jeweiligen internen Bedarfsträger.

Abhängig von dem regulatorischen Umfeld ist die Etablierung einer eigenen Supplier-Security-Funktion bzw. eines -Teams sinnvoll. Hierbei ist zu beachten, dass es zumindest im europäischen Raum auch Anforderungen aus dem Datenschutz gibt, die zumindest auch eine jährliche Validierung der technischen und organisatorischen Maßnahmen (TOMs) vorschreiben.

In gängigen Regulierungen ist auch immer prominent das Thema „Risk Management/Assessment“ zu finden. Generell ist es aus meiner Sicht wichtiger, eine saubere Beratung durchzuführen und am Ende einer Entwicklung einen Soll-Ist-Vergleich durchzuführen, der dann das eigentliche Risk Assessment darstellt.

Das heißt konkret, je nach regulatorischem Kontext macht die Funktion Risk Assessment als 2nd Line-Funktion Sinn, generell würde ich aber immer einen beratenden Ansatz bevorzugen.

12.5 Erfolgsfaktoren

In einem engen Sinne ist eine Sicherheitsorganisation erfolgreich, wenn kein Einbruch erfolgt und relevante Zertifizierungen z.B. im Kundenauftrag erlangt worden sind. Dies ist aber sicherlich nur die Basis für den Erfolg.

Eine Sicherheitsorganisation ist dann wirklich erfolgreich, wenn sie Awareness für Sicherheitsthemen etabliert hat und optimalerweise gleichzeitig auch angesehene Fachkompetenz ist.

Der Erfolg einer IT-Sicherheitsfunktion hängt damit von diversen Elementen ab. Häufig genannte Hauptelemente neben geeigneten Mitarbeiterinnen und Mitarbeitern und im Sicherheitsbereich sind:

- Klare, gute Kommunikation
- Großes technisches Wissen
- Umfangreiches Wissen über Security/die Angreiferlage
- Lösungsorientierung
- Doppelte Absicherung/Avoid Vendor Lock-in
- Betriebliche Nähe

12.5.1 Kommunikation

Grundsätzlich muss Sicherheit sichtbar sein und darf sich nicht in vermeintlichen Elfenbeintürmen verstecken. Die Kommunikation der IT-Sicherheit sollte, wo immer möglich, proaktiv erfolgen.

Ein Beispiel hierfür ist die frühzeitige Kommunikation zu Technologien wie ChatGPT oder genereller künstlicher Intelligenz. Eine proaktive Kommunikation bietet den Empfängern notwendige Orientierung und setzt klare Handlungsrahmen. Anstatt nur auf Verbote zu setzen, sollte der Umgang mit Technologien durch das Business

unterstützende Richtlinien (z. B. „Die Nutzung interner Daten ist zulässig, die Verwendung vertraulicher Daten außerhalb von selbst gehosteten Large-Language-Modellen (LLM) jedoch nicht“) reguliert werden.

Darüber hinaus ist es essenziell, eine kontinuierliche Sichtbarkeit in der internen Kommunikation zu etablieren. Regelmäßige Beiträge in relevanten Foren oder im Intranet fördern das Bewusstsein für IT-Sicherheitsbelange. Hierbei sollten sowohl Compliance-Anforderungen als auch technische Inhalte gleichermaßen berücksichtigt werden.

Eine erhöhte Sichtbarkeit kann durch Formate wie IT Town Halls erreicht werden, die den engen Schulterschluss zwischen den verschiedenen Funktionen fördern und die Integration von Sicherheitsaspekten in den Arbeitsalltag erleichtern.

12.5.2 Großes technisches Wissen

Eine Sicherheitsfunktion, die ausschließlich auf Compliance-Gedanken basiert und keine fundierten inhaltlichen Begründungen für ihre Vorgaben liefert, läuft Gefahr, lediglich als notwendiges Übel wahrgenommen zu werden, nicht jedoch als kompetenter Partner.

Dies unterstreicht die Bedeutung der technischen Ausbildung von Sicherheitspersonal, die heute wichtiger ist als je zuvor.

Idealerweise haben verschiedene Mitglieder der Sicherheitsorganisation zuvor im technischen Umfeld gearbeitet, um die Auswirkungen von Anforderungen besser einschätzen zu können. Es hat sich als Vorteil erwiesen, wenn Unternehmen, die selbst stark in der Entwicklung tätig sind, auch Mitglieder der Sicherheitsorganisation aus diesen Entwicklungsbereichen rekrutieren.

Ein weiterer Innovationsaspekt ist die kontinuierliche Weiterbildung des Sicherheitspersonals in neuesten Technologien. Durch den Einsatz von KI (maschinelles Lernen, AI etc.) können Sicherheitsmaßnahmen effizienter und präziser gestaltet werden. Zudem sollte die Sicherheitsorganisation aktiv an Innovationsprojekten beteiligt sein, um proaktiv neue Sicherheitslösungen zu entwickeln und zu implementieren.

Ein weiterer innovativer Ansatz ist die Integration von Sicherheit in den DevOps-Prozess, auch bekannt als DevSecOps. Dies stellt sicher, dass Sicherheitsüberlegungen von Anfang an in den Entwicklungszyklus integriert und nicht nur als nachträglicher Gedanke betrachtet werden.

Gerade die Integration in agile Methoden zwingt zudem die Sicherheit, gelebte Ansätze zu hinterfragen und zu optimieren.

12.5.3 Umfangreiches Wissen über Security bzw. die Angreiferlage

Die Entwicklung effektiver Vorgaben und Strategien kann nur gelingen, wenn auch die Methoden der Angreifer bekannt sind. Dazu ist es unerlässlich, klassische Publikationen sowie einschlägige Portale und soziale Netzwerke wie Mastodon und X kontinuierlich zu beobachten. Als gute Datenquellen (Portale) sind hier zu nennen:

- Bleeping Computer [BC]
- SecureList [SL]

Der XZ-Utils-[J]FROG-[V]orfall hat zudem sehr anschaulich verdeutlicht, wie schnell und effektiv die Sicherheitsgemeinschaft über Medien wie X oder Mastodon kommuniziert hat.

Durch die konsequente Verfolgung solcher Informationsquellen können interne Stakeholder besser informiert werden, was fundiertere Entscheidungen ermöglicht. Sowohl das eigene Screening der Informationslage als auch der strategische Einkauf von Threat-Intelligence-Information haben sich dabei bewährt, insbesondere um den eigenen Personalaufwand effizient zu nutzen.

Die Integration von künstlicher Intelligenz und Machine Learning in die Analyseprozesse kann zusätzlich die Effizienz und Genauigkeit der Bedrohungserkennung verbessern.

12.5.4 Lösungsorientierung

Kein Unternehmen möchte lediglich mit Security Findings konfrontiert werden, ohne gleichzeitig Lösungsmöglichkeiten aufgezeigt zu bekommen. Dies kann schnell zu einer Barriere zwischen den Fachbereichen führen.

Ein konkretes Beispiel ist die Nutzung von künstlicher Intelligenz (KI). Hier müssen klare Grenzen definiert werden, die festlegen, in welchen Bereichen die Nutzung von KI erlaubt ist und wo sie nicht eingesetzt werden darf. Unternehmen, die bereits im ersten Quartal 2023 solche Richtlinien implementiert haben, konnten ihren Mitarbeitern und Mitarbeiterinnen eine klare Orientierung bieten.

Eine lösungsorientierte Herangehensweise setzt jedoch fundierte technische Fähigkeiten und tiefgehendes Sicherheitswissen voraus. Zudem ist eine enge Zusammenarbeit zwischen IT-Sicherheit und den Fachbereichen entscheidend. Durch regelmäßige Schulungen und Workshops kann das Sicherheitsbewusstsein gestärkt und praxisnahe Lösungsstrategien können entwickelt werden.

Darüber hinaus sollten moderne Technologien und innovative Ansätze genutzt werden, um Sicherheitsmaßnahmen kontinuierlich zu verbessern. Der Einsatz von Auto-

omatisierung und KI-basierten Tools zur frühzeitigen Erkennung und Behebung von Sicherheitsrisiken kann hier einen erheblichen Mehrwert bieten.

Die Etablierung eines offenen Kommunikationskanals zwischen den Fachabteilungen und der IT-Sicherheitsabteilung ist ebenfalls von großer Bedeutung. Dies fördert das Verständnis und die Akzeptanz der Sicherheitsmaßnahmen im gesamten Unternehmen.

12.5.5 Doppelte Absicherung/Avoid Vendor Lock-in

Wie zuvor diskutiert, ist es empfehlenswert, basierend auf der definierten Angreiferlage und den identifizierten Angriffspfaden die notwendigen Tools zu definieren.

Es empfiehlt sich, auf den primären Angriffspfaden jeweils Tools von mindestens zwei verschiedenen Herstellern zu implementieren, abhängig vom verfügbaren Budget.

Zum Beispiel sollte auf einem klassischen Client jeweils ein Endpoint Detection and Response (EDR) sowie ein Antivirus (AV) unterschiedlicher Hersteller installiert sein. Auf diese Weise kann man von den unterschiedlichen Erfahrungen der Hersteller profitieren. Kommerziell gesehen vermeidet man so Vendor Lock-in und optimiert die Verhandlungsposition bei Lizenzverlängerungen.

Diese Strategie darf jedoch nicht pauschalisiert werden. Oftmals findet man in Unternehmen die Anforderung, dass Firewalls unterschiedlicher Hersteller verwendet werden sollen, insbesondere in mehrstufigen Umgebungen. Diese Anforderung ist pauschal sinnvoll, allerdings hängt ihre Umsetzung stark vom individuellen Risikoprofil und den betrieblichen Kapazitäten ab. In bestimmten Szenarien kann es sogar vorteilhaft sein, Firewalls eines einzigen Herstellers zu verwenden, um die Komplexität zu reduzieren und die Sicherheit zu erhöhen.

12.5.6 Betriebliche Nähe

Die Sicherheitsfunktion muss zudem nah am Betrieb sein, d. h., sollte es betriebliche Regelmeetings geben, sollten immer Vertreter der IT-Sicherheit an den jeweiligen Meetings teilnehmen.

- Es hilft zudem, Sicherheit immer als Teamarbeit mit dem internen Nutzer zu verstehen. Sicherheit kann nur durch intensive Zusammenarbeit etabliert werden.
- Das heißt auch, dass Sicherheit ein klar helfendes Image vertreten sollte, keine Instanz, die Fehler findet und/oder sinnlose Anforderungen definiert.

12.6 Verbesserungspotenziale

Es gibt verschiedene Möglichkeiten, IT-Sicherheit in Unternehmen noch besser zu implementieren abhängig vom jeweiligen Startpunkt.

Viele Unternehmen verwenden in internen Townhalls immer wiederkehrende Elemente wie die Anzahl von Datenschutz Incidents oder technischen Incidents. Hier ist es ein Leichtes, IT-Sicherheit ebenfalls regelmäßig in der Kommunikation mit aufzunehmen (beispielsweise auf Basis aktueller Phishing-Kampagnen-Ergebnisse) und so die Sichtbarkeit des Themas nachhaltig zu verbessern.

Ein häufig gesehenes Problem und eine Herausforderung ist das Tracking von neuen regulatorischen Vorgaben. Hier empfiehlt es sich, dieses Tracking oder die Interpretation neuer Regularien an einer zentralen Stelle durchzuführen und alle Bedarfsträger bei Bedarf zu informieren. Gerade die mitunter hohe Anzahl von Gesetzesvorhaben macht es nahezu unmöglich, dies pro Abteilung individuell zu verfolgen.

Ein weiterer Ansatz, der in betrieblichem Umfeld durchaus verwendet wird, ist die Einrichtung von festen Zeitkontingenten für Bug Fixing und Incidents (oder generell Qualitätsmaßnahmen). Dies erhöht zwangsläufig die Qualität zulasten der neu zu implementierenden Features, dennoch erscheint dieser Ansatz als sehr zukunftsweisend.

Abschließend ist noch das kontrovers diskutierte Thema Vertrauen vs. Kontrolle zu nennen. Im Zuge der Agilität wird sehr häufig die Verantwortung delegiert und Kontrolle vernachlässigt. Aus Sicherheitssicht ist der Ansatz genau umzudrehen, d. h., es sollten sichere unumstößliche Standards definiert werden, die Leitplanken für die Belegschaft darstellen. Im agilen Umfeld bietet es sich zudem an, Experten in den einzelnen DevOps-Teams mit Sicherheitswissen aufzuladen. Eine Skalierung mit dediziertem Sicherheitspersonal ist quasi unmöglich, daher erscheint dieser Ansatz alternativlos.

12.7 Entscheidende Änderungen bei IT-Sicherheit

Anfang des Jahrtausends war Sicherheit ein Randthema/Spezialthema und wurde dementsprechend vorsichtig behandelt. Die deutsche Telekommunikationsindustrie hat als eine der ersten Industrien in Deutschland den Bedarf an Sicherheit identifiziert, z. B. zu erkennen an der frühen Etablierung von „Security by Design“-Aspekten, lange bevor dieser Begriff en vogue wurde.

Durch die deutlich verschärfte Angreiferlage (basierend auf der zunehmenden Professionalisierung der Angreifer) sind Firmen heute gezwungen, deutlich mehr in Si-

cherheit zu investieren. Erschien vor zehn Jahren noch die Forderung nach einer Antivirusrösung als adäquat, sollte im Jahr 2024 auf jedem betriebenen System eine Endpoint-Detection-and-Response-Lösung (EDR) vorhanden sein.



EDR (Endpoint Detection and Response) bezieht sich auf Sicherheitslösungen, die speziell dafür entwickelt wurden, Aktivitäten auf Endgeräten zu überwachen und darauf zu reagieren. EDR ist eine wichtige Komponente in modernen Sicherheitsstrategien, da es Organisationen ermöglicht, auf Bedrohungen schnell zu reagieren und die Kontrolle über ihre Endpunkte zu behalten.

Grundsätzlich ist IT-Sicherheit bei den meisten Unternehmen ein wichtigeres Thema geworden, spätestens mit Einführung der NIS-2-Regulation muss sich jedes Unternehmen damit beschäftigen, um Strafen zu vermeiden. Die Anforderungen an das Management steigen, so wird die Beschäftigung mit IT-Sicherheit sichergestellt.

Zertifizierungen werden immer häufiger angefordert und als Basis für zukünftige Geschäftsbeziehungen betrachtet. Dies bindet weitere Ressourcen, die nicht für die eigentliche Erhöhung der Resilienz verwendet werden können. Dies kombiniert mit einem zunehmenden Fachkräftemangel führt zu einer Schwächung der IT-Sicherheitsstruktur.

Hier gilt es, perspektivisch Ansätze zu finden, um den Aufwand zu reduzieren (z. B. TISAX-Zertifizierung ersetzt eine ISO 27001-Zertifizierung) und weiter zu automatisieren.

Konstant geblieben ist die weitverbreitete Einschätzung, dass Zertifizierungen heute weiterhin primär als Business Enabler und in den wenigsten Fällen zur Erhöhung der Sicherheit gesehen werden.

Der zunehmende Trend, mehr auf SAAS-Lösungen zu setzen, stellt die internen Sicherheitseinheiten vor neue Herausforderungen. Es werden Detailanalysen zwangsweise durch generischere Supplier-Betrachtungen ersetzt. Dies bedeutet nicht automatisch, dass die Sicherheit hierdurch schlechter wird, aber die Eindringtiefe bei der Analyse wird eindeutig reduziert.

Als letzter an dieser Stelle zu nennender Trend sei AI genannt. Auch heute verwenden moderne EDR-Lösungen schon intelligente Ansätze zur Angriffserkennung. SOAR-Lösungen werden heute schon verwendet, um automatisierbare Vorgänge zu automatisieren.



SOAR (Security Orchestration, Automation, and Response) bezeichnet Tools, die dazu dienen, Sicherheitsoperationen in einer digitalen Umgebung zu automatisieren, zu orchestrieren und zu verbessern. Durch den Einsatz von SOAR können Sicherheitsteams komplexere Bedrohungen schneller erkennen, analysieren und darauf reagieren, was zu einer insgesamt verbesserten Sicherheitslage führt.

AI wird dazu führen, die initiale Hürde für Angreifer zu reduzieren, z. B. um aufwendige

Angriffe/Phishing-E-Mails zu generieren. Dies führt zu einer stärkeren respektive erfolgreicherer Angriffswellen, welche wiederum durch Automatisierung mitigiert werden können.

Weitergehende Ansätze zur AI-Verwendung (siehe <https://arxiv.org/abs/2404.08144>) wie die automatische Exploitation von 1-day-Schwachstellen werden Angriffe weiterhin schneller bzw. systematischer machen. Das heißt, die Verteidiger müssen an dieser Stelle ebenfalls, in diesem Fall schneller zur Aktualisierung der Pakete greifen.

12.8 Besondere IT-Sicherheitsherausforderungen in der eigenen Branche

Viele Branchen, speziell auch die Chemiebranche, stehen vor einer zunehmenden Digitalisierung und Konvergenz von IT und Produktionsumgebungen. Hier werden ehemals fundamentale Anforderungen wie die strikte Zonierung durchbrochen, um beispielsweise betriebliche Daten/Messpunkte auszuleiten und weiterzuverarbeiten. Die Integration in Active-Directory-Strukturen der gegebenenfalls übergreifenden Unternehmens-IT sei an dieser Stelle auch als eine weitere Herausforderung genannt.

Diverse Sicherheitslösungen wie EDR bauen zudem auch darauf, zumindest eine reine Outbound-Kommunikation zu ermöglichen.

Durch die Etablierung von Netzwerkübergängen und konkret der Möglichkeit ausgewählter eingehender Kommunikation kommen Produktionsumgebungen mindestens mittelbar in die Reichweite von organisierter Kriminalität und somit Ransomware. Generell sollte hier darauf geachtet werden, reine Outbound-Verbindungen zu etablieren, um das Risiko deutlich zu minimieren und dennoch Kommunikation zu ermöglichen.

Vor Jahren gab es Diskussionen um die Sicherheit von Mobilfunkprotokollen, heute, im Jahr 2024, ist es die Diskussion, dass ehemals stark abgetrennte Produktionsumgebungen durchlässiger werden und damit alte Technologien wieder in den Fokus der Angreifer geraten.



In Produktionsumgebungen der Chemiebranche wird häufig das Purdue-Modell auf Basis der Norm IEC 62 443 verwendet. Das heißt, es gibt eine Zone (OT DMZ) mit typischen IT-Komponenten, dann eine Zone mit Komponenten für Leitsysteme, und in einer nächsten inneren Zone kommen die eigentlichen Controller.

Die Herausforderungen der Chemiebranche im Jahr 2024 zumindest in Deutschland sind im Sicherheitsbereich vielfältig:

- „Alte“ Betriebssysteme werden mitunter noch in Produktionsanlagen verwendet, da diese schlichtweg eine sehr lange Laufzeit haben.
- Patch-Zyklen hängen hochgradig von dem jeweiligen Hersteller ab.
- „Safety first“
- Häufige Kapselung oder komplexe Netzwerk-Topologien erschweren z. B. Exfiltration von Telemetrie-Daten für ein SIEM- oder EDR-System
- Komplexe Regulierung im Produktionsumfeld, teilweise sehr stark aus Produktionssicht formuliert, und Konvergenzaspekte von IT/OT sind nachrangig zu betrachten.
- Angespannte finanzielle Lage

Aus einer puristischen Sicherheitssicht ist z. B. eine strikte Netzwerktrennung sehr wünschenswert, in der Praxis führt aber z. B. die Sperrung von reiner Outbound-Kommunikation zu Defiziten in der Überwachung, bzw. diese müssen mühsam neu etabliert werden.



Verschiedenste Systeme wie z. B. EDR-Systeme etablieren über Port 443/HTTPS eine stehende Outbound-Verbindung, um eine Remote-Steuerung zu ermöglichen.

12.9 Hot Topics

Eins der relevantesten Themen in den kommenden Jahren ist neben der regulatorischen Compliance (siehe NIS-2 und entsprechende Umsetzungsgesetze) sicher die Erhöhung der Resilienz gegenüber den primären Angreiferklassen, namentlich der organisierten Kriminalität.

Themen wie

- Incident-Response-Prozesse,
- Back-up inklusive Restore-Test,
- jegliche Form von betrieblichem Security Monitoring

bleiben wichtig.

Der XZ-Utils-Vorfall Ostern 2024 (siehe JFROG) zeigt aber auch deutlich weitere Handlungsfelder auf, die Sicherheitsorganisationen immer häufiger betrachten müssen:

- Supply-Chain-Sicherheit (inklusive Abhängigkeiten einzelner Softwarepakete)

- Benutzbare Asset-Inventare inklusive Ansätze wie „Software Bill of Materials“ (siehe SBOM)
- Threat Intelligence



XZ-Utills

Karfreitag 2024 wurde bekannt, dass es Angreifern gelungen war, Schadcode in das XZ-Utills Repository einzubringen mit dem Ziel, die Funktion von OpenSSH zu modifizieren. XZ-Utills ist eine Sammlung von Komprimierungswerkzeugen, die in jeder Linux-Distribution verwendet werden. Wäre der maliziöse Code ausgeliefert worden, hätten Angreifer weitreichenden Zugriff auf OpenSSH-Server weltweit erlangen können.

Der Angriff wurde über drei Jahre vorbereitet und ist von seiner Raffinesse durchaus mit Angriffen wie auf die Firma Solarwinds (siehe SolarWinds) vergleichbar.

Als ein weiteres wichtiges Themengebiet ist das Thema Weiterbildung der Sicherheitsorganisation zu sehen. Mit der Verbreitung des Technologie-Stacks wird es für Sicherheitsfunktionen immer schwerer, Schritt halten zu können. Konkret wird der Weiterbildungsbedarf deutlich ansteigen. War es vor einigen Jahren ausreichend, grundlegendes Verständnis über die Struktur eines Rechenzentrums zu haben inklusive routender Elemente, müssen heute komplexe Komponenten der diversen HyperScaler verstanden und in die Sicherheitsprozesse wie Incident Response integriert werden.

12.10 Rolle des IT-Sicherheitsverantwortlichen

Der IT-Sicherheitsverantwortliche (SiBe oder CISO) wird verschiedenste Aspekte je nach Zielgruppen zu beachten haben. Des Weiteren ist wichtig, zu verstehen, ob es sich um eine reine 2nd Line-Aufgabe oder eine sich in der Praxis bewährte 1.5 Line-Funktion handelt.

In Richtung Vorstand/Aufsichtsrat ist der SiBe bzw. CISO gefordert,

- die Risiken des Unternehmens inklusive Lösungsansätzen zur Reduktion darzustellen,
 - Kommunikation zu aktuellen Sicherheitsthemen/Sicherheitslage sicherzustellen,
 - kompetenter Berater in allen Sicherheitsfragen
- zu sein.

In Richtung Technologie/IT/Produktion müssen

- Anforderungen definiert,
- Projekte ganzheitlich begleitet,
- Kontrollen zur Einhaltung der Vorgaben definiert,

- KPIs definiert,
 - Lösungen/Blaupausen erarbeitet
- werden.

In Richtung der Mitarbeiter und Mitarbeiterinnen müssen

- allgemeine Anforderungen definiert werden, die gültig sind, unabhängig von der jeweiligen Rolle (häufig „Acceptable Use“-Leitfaden genannt),
- Awareness-Programme und
- Schulungsprogramme (z. B. im Rahmen von Security Guilden) etabliert werden.

Zudem wird immer häufiger der Ruf nach Unterstützung bei externen Audits geäußert. Hier ist der SiBe/CISO Unterstützer des Business. Letzteres führt zwangsläufig zu einem engen Schulterschluss, welcher der Sicherheit im Unternehmen deutlich zugute kommt.

12.11 Lessons Learned

Grundsätzlich hat sich die Sicherheitslage, die Anforderungen auch regulatorischer Natur und die Sichtbarkeit von IT-Sicherheit in den letzten Jahren stark, wenn nicht dramatisch, verändert.

In der Vergangenheit wurde häufig versucht, Sicherheit an formelle Demand-Prozesse anzudocken, welche selbst spätestens mit der aufkommenden Agilität ad absurdum geführt worden sind. Demand-Prozesse sind heute häufig zu reinen Budget-Verwaltungsprozessen umgewandelt worden.

Konkret empfiehlt es sich daher, losgelöst von Demand-Prozessen die Sicherheitsaspekte initial mit den jeweiligen realisierten Einheiten zu besprechen (damit einhergehend auch ein stärker technisches Profil in der Sicherheit zu etablieren). Begleitet werden kann diese Aktivität durch regelmäßige Austauschformate wie z. B. Security Guilden oder „Ask me anything“-Runden. Letztere bieten sich an, um als Sicherheit noch stärker in den direkten Austausch mit den Mitarbeitern und Mitarbeiterinnen zu kommen.

Der Faktor Mensch gewinnt zunehmend an Bedeutung und wird auch heute noch häufig unterschätzt.

Initial haben Sicherheitsprogramme häufig Awareness immer als reines „Web Based Training“ bzw. Phishing-Awareness-Block berücksichtigt, aber den Ausbildungsaspekt der Entwickler/Betreiber ausgeblendet. Durch die weitergehende Agilität ist aber gerade der Ausbildungsaspekt noch stärker zu fokussieren, sowohl bei Sicherheitsfunktion als auch bei Entwicklern und Betreibern.

Modernes Awareness Tooling ist in der Lage, Lernpfade aufgrund von Organisationsprofilen vorzugeben und Kombinationen aus Phishing-Trainings und Web Based

Trainings („WBTs“) individuell auszurollen. Diese Ansätze sind „out of the box“ verfügbar und sollten klassische WBTs ablösen, da diese in weiten Teilen ineffektiv sind. Ein weiterer wichtiger Aspekt ist das Thema Effizienz und Wertschöpfungstiefe. Häufig werden auch heute noch individuelle Härtingsstandards z. B. für das Windows-Betriebssystem entwickelt. Neben der Entwicklung und Pflege dieser Standards entsteht Zusatzaufwand durch notwendige Verhandlungen mit Lieferanten. Hier sollte „einfach“ auf das CIS-Framework zurückgegriffen werden.



Das **Centre for Internet Security (CIS)** bietet anerkannte Härtingvorgaben an. Die Härtingvorgaben existieren typischerweise in mehreren Abstufungen, je nach Umgebung. Hier empfiehlt es sich nicht, pauschal auf einen Level zu fokussieren, sondern alle Anforderungen zu analysieren.

Ähnlich gelagert ist das Thema Patchmanagement. Bei mehr als 25 000 Schwachstellen pro Jahr ist es nicht mehr sinnvoll, einzelnen Schwachstellen „hinterherzujagen“ und diese individuell zu tracken. Als viel sinnvoller hat es sich erwiesen, einen z. B. vierwöchigen Basispatch-Prozess zu etablieren und nur noch bei Schwachstellen ab einer Einstufung von CVSS 9 ein „Emergency“ Patching zu betreiben.

Eine Anlehnung an den monatlichen Patchzyklus von Microsoft scheint hier ratsam. Als nächste Verfeinerung könnten noch Serversysteme wie Domain Controller oder Active Directories getrennt betrachtet werden.



CVSS steht für Common Vulnerability Scoring System. Es ist ein Industriestandard, der verwendet wird, um die Schwere von Sicherheitslücken in Softwaresystemen zu bewerten. Der CVSS-Score gibt einen numerischen Indikator (von 0 bis 10) für die Schwere einer Sicherheitslücke an, basierend auf diversen Metriken, die verschiedene Aspekte der Sicherheitslücke messen.

Hierbei empfiehlt es sich, ein Regelmeeting zwischen IT und IT-Sicherheit zu etablieren, was wiederum die Gemeinsamkeiten stärkt.

12.12 Kompetenzen eines erfolgreichen Sicherheitsverantwortlichen

Sicherheitsverantwortliche müssen in erster Näherung die Resilienz einer Firma sicherstellen und zeitgleich die Compliance zu geltenden Sicherheitsvorgaben/Gesetzen etablieren. Gerade letzterer Aspekt bindet immer mehr Ressourcen, d. h., hier gilt es, effiziente Ansätze zu finden.

Zeitgleich müssen beide Aspekte/Risiken/Budgetbedarfe in dem jeweiligen Unternehmen adressiert werden. Damit wird das Spektrum eines Sicherheitsverantwortlichen deutlich breiter als noch vor einigen Jahren.

Ein erfolgreicher Sicherheitsverantwortlicher sollte daher mindestens in den Bereichen

- Fachkompetenz,
- Kommunikationsfähigkeit und
- Pragmatismus

sehr kompetent sein.

Es mag altmodisch klingen, aber ein IT-Sicherheitsverantwortlicher muss Sicherheit und Technologie verstehen und leben. Ein Sicherheitsverantwortlicher, der sich nur auf eine ISO 27001-Zertifizierung stützt, wird es schwer haben, eine inhaltlich fundierte Strategie zu entwickeln und die Mitarbeitenden zu motivieren.

Die Größe der Organisation spielt dabei ebenfalls eine entscheidende Rolle. Solange die erforderlichen Fachkompetenzen in der Organisation vorhanden sind, kann diese effektiv geschützt werden. Doch selbst eine große Organisation benötigt engagierte und kompetente Sicherheitsverantwortliche, um erfolgreich zu sein. Eine hundertköpfige Sicherheitsabteilung hat andere Anforderungen als eine mit dreißig Mitarbeitenden.

Unternehmen sollten darauf achten, IT-Sicherheitsmitarbeiter in führenden Positionen einzusetzen, die einen starken technischen Hintergrund haben. Diese historische Tiefe im Umgang mit Technologien ist essenziell, um fundierte Entscheidungen zu treffen und die Akzeptanz innerhalb des jeweiligen Kundenbereichs zu sichern.

Es besteht die Gefahr, dass Entscheidungen getroffen werden, die ausschließlich auf Compliance basieren und nicht auf tiefem technischem Verständnis. Eine weitere zentrale Fähigkeit ist die Kommunikation: Risiken müssen klar eingeordnet und präsentiert werden.

Manche könnten die technische Fokussierung als Nachteil betrachten. Die Praxis zeigt jedoch, dass gepaarte Fachkompetenz und Kommunikationsfähigkeit auf Führungsebene inzwischen als unternehmenskritisch angesehen werden. Sicherheitsverantwortliche, die sowohl technisch versiert als auch kommunikationsstark sind, sind unerlässlich.

12.13 Top-3-Ratschläge

Es gibt grundsätzlich keinen Blueprint für Sicherheitsorganisationen und keine Checkliste, die ohne Kontext abgearbeitet werden kann.

Losgelöst von dem jeweiligen individuellen Kontext haben sich dennoch folgende drei Maßnahmen/Ratschläge als sinnvoll erwiesen:

- Auf Mitarbeiter-Awareness und -ausbildung fokussieren
 - Einführung von Security-Guild-/Security-Champion-Programmen erweitert die Reichweite der Sicherheit.



Security Guild ist ein Format, in dem sich „Gleichgesinnte“ treffen und über das Thema Sicherheit austauschen. Das Thema Guilden wurde gerade im Kontext der immer stärker etablierten Agilität, um Wissen auszutauschen, sehr populär.

- Durch ausgebildete Mitarbeiter und Mitarbeiterinnen in der eigentlichen Entwicklung und im Betrieb kann ein deutlicher „Shift Left“ durchgeführt werden.
- Durch Kommunikation in der Sprache der jeweiligen Partner wie Entwickler wird eine Nähe erzeugt, und Inhalte können einfacher vermittelt werden.
- Angriffspfade kennen und doppelt absichern mit Tools unterschiedlicher Anbieter
 - Mit dem Wissen über Angreifer und Angriffspfade können Lücken in der Verteidigung identifiziert und Gegenmaßnahmen ergriffen werden.
 - Die Absicherung mit mehreren Lösungen (z. B. ein klassischer Antivirus in Kombination mit einer fortschrittlichen EDR-Lösung) erhöht die Sicherheit.
- Sicherheit vereinfachen
 - Anforderungen/Fragebögen sollten so detailliert und leicht verdaulich wie möglich formuliert werden.
 - Operative Sicherheitsprozesse sollten auf die Kernpunkte fokussiert werden.



Beispiel „Sicherheit vereinfachen“

Patchmanagement wird häufig sehr kleinteilig durchgeführt, d. h., jeder einzelne Patch bzw. fehlende Patch wird aufgeführt. Aus meiner Sicht ist es wichtiger, REGELMÄSSIG zu patchen, anstelle sich auf jeden Patch einzeln zu konzentrieren. Die Vorteile sind offensichtlich, das Tracking wird massiv vereinfacht, und es entsteht eine betriebliche Hygiene samt einem sinnvoll steuerbaren Prozess.

12.14 Die wichtigsten Punkte in Kürze

Sicherheit hängt von viele Aspekten ab, die zentralen Aspekte hierbei sind:

- Ohne Awareness und richtige Ausbildung der Mitarbeiter und Mitarbeiterinnen wird jede rein technisch fokussierte Sicherheitsorganisation scheitern.
- Standardisierung ist wichtig, Sicherheitskomponenten sollten auf jedem System vorhanden sein, und es sollte keinen Raum für Ausnahmen geben.
- Sicherheit MUSS einfach und pragmatisch sein.

Literatur

AI, <https://arxiv.org/abs/2404.08144>. Abgerufen am 10.06.2024.

BC, <https://www.bleepingcomputer.com/>. Abgerufen am 01.06.2024.

HackerNews, Newsroom: Old Meets New: Creating IT-Enabled Innovation Malicious Code in XZ Utils for Linux Systems Enables Remote Code Execution. URL: <https://thehackernews.com/2024/04/malicious-code-in-xz-utils-for-linux.html>. Abgerufen am 05.04.2024.

JFROG, URL: <https://jfrog.com/blog/xz-backdoor-attack-cve-2024-3094-all-you-need-to-know/>, Abgerufen am 20.04.2024.

MITRE, URL: <https://attack.mitre.org/>. Abgerufen am 20.04.2024.

SBOM, URL: <https://www.synopsys.com/blogs/software-security/software-bill-of-materials-bom.html>. Abgerufen am 20.04.2024.

TISAX, URL: <https://portal.enx.com/de-de/TISAX/>. Abgerufen am 20.04.2024.

SL, <https://securelist.com/>. Abgerufen am 01.06.2024.

SOLARWINDS, <https://www.csoonline.com/article/570537/the-solarwinds-hack-timeline-who-knew-what-and-when.html>. Abgerufen am 09.05.2024.



In diesem Beitrag erfahren Sie,

- welche grundlegenden Methoden und Werkzeuge zur Verfügung stehen, um eine Produktentwicklung zu gewährleisten, die sicheren Sourcecode anstrebt,
- wie sich die Entwicklung von sicheren Produkten einbettet in die Vorgehensmodelle der Softwareentwicklung,
- welche Ansätze der sicheren Produktentwicklung erfolgversprechend sind und in der Praxis angewendet werden.

13.1 Einleitung

Für Unternehmen, die softwarebasierte Produkte entwickeln (wie beispielsweise IT-Produkte, vernetzte Produkte im Zusammenhang mit dem Industrial IoT oder auch klassische IT-Lösungen im Büroumfeld), ist die IT-Sicherheit der resultierenden Produkte sehr wichtig. Eine gut entwickelte Anwendung bietet deutlich weniger Angriffsmöglichkeiten, sodass deren Betrieb, abgesehen von Kosten, die aus einem Angriff entstehen, auf mittelfristige Sicht kostengünstiger in Bezug auf Wartung, Betrieb von telefonischer Unterstützung ist. Es kann festgestellt werden, dass ein konsequentes Umsetzen von Maßnahmen, die die IT-Sicherheit stärken, auch einen positiven Einfluss auf die Qualität der Software hat, die entsteht.

Für eine sichere Entwicklung („Security by Design“) ist es wichtig, dies während des gesamten Lebenszyklus zu betrachten. Einzelne Maßnahmen können ohne eine erfolgreiche Einbettung in den Lebenszyklus in vielen Fällen kaum ihre volle Wirkung entfalten.

Neben dem Entwicklungsprozess selbst beinhaltet der Lebenszyklus auch weitere Phasen wie Projektakquise, Deployment, Wartung/Maintenance/Updates und die Dekommissionierung (End-of-Life), in denen Security eine Rolle spielt. Jede Phase in diesem Lebenszyklus muss entsprechend aus Sicherheitssicht begleitet werden, sodass die Software nicht nur entsprechend dem Stand der Technik entwickelt wird, sondern deren Einsatz auch in geeigneter Weise ausgestaltet ist. Hierfür ist es wichtig, dass für jede Phase konkrete Vorgehensweisen und Werkzeuge eingesetzt werden.

Obwohl es hierfür mittlerweile etablierte Vorgehensweisen gibt, wie z. B. von Microsoft die Secure Development Library oder OWASP-Vorgaben, werden noch nicht in allen Unternehmen umfängliche Prozesse systematisch umgesetzt. Hierbei ist zu sehen, dass in vielen Fällen die Integration von Sicherheit in den Produkt-Lebenszyklus meist aus der Perspektive der Entwicklung heraus gedacht wird. Zudem wird die IT-Sicherheit auch zumeist als eine nachgelagerte Anforderung wahrgenommen und nicht als integraler Bestandteil der Anforderungen und Ziele eines Entwicklungsprojektes.

Bereits 1972 wurde in der Anderson-Studie der USAF festgestellt, dass klare Vorgaben für die Entwicklung von sicherer Software entscheidend sind, um eine deutliche Kostenreduktion zu erzielen, und zum anderen eine deutliche Steigerung der Sicherheit. Hierbei wurde bereits zu diesem frühen Zeitpunkt der Entwicklung der IT-Sicherheit eine umfassende Sicht auf die Phasen des Lebenszyklus geworfen, sodass Design, Entwicklung, aber auch Einkauf und Zertifizierung hierbei beachtet wurden.

Generell kann man, je nach dem zugrundeliegenden Vorgehensmodell, die Phasen „Planung“, „Analyse“, „Design“, „Entwicklung“, „Testen“, „Ausliefern“ sowie die Außerdienststellung im Lebenszyklus von IT-Produkten unterscheiden. Diese grobe Struktur wird auch in der Microsoft Secure Development Library (SDL) so reflektiert und, wie in folgender Tabelle dargestellt, mit Techniken verbunden.

Training	Core Security Training
Requirements	Establish Security Requirements
	Create Quality Gates/Bars
	Security and Privacy Risk Assessment
Design	Establish Design Requirements
	Analyse Attack Surface
	Threat Modelling
Implementation	Use Approved Tools
	Deprecate Unsafe Functions
	Static Analysis

Verification	Dynamic Analysis
	Fuzz Testing
	Attack Surface Review
Release	Incident Response Plan
	Final Security Review
	Release Archive
Response	Execute Incident Response Plan

Um eine sichere Produktentwicklung gewährleisten, ist es zunächst wichtig, sich die Prozesse der Softwareentwicklung im Kontext der Sicherheit zu betrachten. Hierbei stellt sich die Aufgabe zu garantieren, dass in dem jeweiligen Vorgehensmodell wie dem V-Modell oder Scrum jeweils die sicherheitskritischen Prozesse eingeführt sind und dort auch praktisch gelebt werden.

Die Basis einer sicheren Produktentwicklung ist ein definiertes Vorgehen in der Erstellung der Software. Hier haben sich verschiedene Secure Development Lifecycles hervor getan, die von großen Akteuren wie Microsoft aktiv propagiert werden. Innerhalb dieser Modelle stehen stets die Aspekte der Erhebung von Sicherheitsanforderungen, Architekturentwicklung, Implementierung, Testen und Prüfen, Maintenance und die Dekommissionierung im Vordergrund.

13.2 Vorgehensmodelle der Softwareentwicklung

Traditionell ist die Integration von IT-Sicherheit in den Entwicklungsprozess beziehungsweise von Techniken, die das Sicherheitsniveau einer Software verbessern, stets auf die letzte Phase der Entwicklung beschränkt. Die führt in vielen Fällen zu nur teilweise integrierten Ansätzen und wirkt sich auch nur bedingt auf die Qualität des Sourcecodes aus.

Software wird im kommerziellen Bereich zumeist unter Verwendung eines Vorgehensmodells erstellt. Hierbei gibt es die klassischen Ansätze wie V-Modell oder Spiralmodell als auch agile Vorgehensweisen (Scrum, Kanban oder DevOps). Dabei stellt sich die Integration der sicherheitsspezifischen Aspekte je nach dem gewählten Vorgehensmodell unterschiedlich dar.

Klassische Entwicklungsprozesse wie das V-Modell spezifizieren die Anforderungen zunächst und starten dann die eigentliche Softwareentwicklung. In einem solchen Fall können die Sicherheitsanforderungen an die Software als Teil der Spezifikation erfasst und als Teil der Abnahmetests überprüft werden. Entscheidend ist es dabei,

dass durch geeignete Maßnahmen die nötigen Sicherheitsanforderungen ermittelt wurden, sodass deren Umsetzung auch überprüft werden kann.

In agilen Vorgehensmodellen wie Scrum oder OpSec ist festzustellen, dass die Ziele des agilen Herangehens mit den Notwendigkeiten der IT-Sicherheit zunächst im Widerspruch stehen. Agiles Vorgehen konzentriert sich auf das Erstellen kurzer Iterationen, in denen flexibel auf Änderungen reagiert wird. In der IT-Sicherheit hingegen ist es wichtig, Kontinuität und Stabilität über die Lebenszeit des Produktes zu gewährleisten, sodass Sicherheitsmaßnahmen konsistent umgesetzt werden und auditierbar sind.

Agile Methoden zeichnen sich dadurch aus, dass für das jeweils nächste Inkrement ein Plan erstellt und dieser dann umgesetzt wird. Dies wird in Scrum als Sprint bezeichnet. Schwachstellen lassen sich dabei ähnlich schwer erfassen wie funktionale Fehler. Es ist zu beobachten, dass die Teams über die Zeit ein besseres Verständnis erlangen und dieses sich in Form von Unit-Tests niederschlägt. Dadurch sinkt die Häufigkeit, dass Schwachstellen auftreten. Es erlaubt aber nicht, feste Arbeitsblöcke pro Sprint zu definieren, die sich auf das Beheben von Schwachstellen beziehen.

Ein möglicher Ansatz ist es, einen festen Block in jedem Inkrement zu planen, in dem Risiken und Schwachstellen untersucht werden können. Ein Teil davon sind Code- und Feature Reviews. Aber auch die Integration in die Gesamtsysteme muss stets hinterfragt werden. Analog verhält es sich beim Schreiben von Unit- oder Integration-Tests. In Projekten, in denen das gesamte Testing Teil des regulären Codes ist, ist es empfehlenswert, eine Risikobetrachtung im Rahmen einer COP (Community of Practice) oder einer vergleichbaren Institution durchzuführen.

Storys sind, neben Features, zum Verbessern der Sicherheit notwendig. In Scrum beschreiben Features die gewünschten Funktionen. Hingegen sind Storys die Arbeitspakete, die umgesetzt werden. Es ist somit notwendig, Arbeitspakete einzuplanen, die sich auf die Sicherheit fokussieren, und damit die Tasks zu ergänzen, die neue Funktionen einfügen. Die Teams können die Storys eigenverantwortlich beurteilen und in konkrete Aufgaben überführen. Diese Security-Storys sollten dabei als reguläre Weiterentwicklung angesehen, in Reviews bearbeitet und das Team darüber auch auf die Herausforderungen der IT-Sicherheit in der Breite informiert werden.

Das Team im agilen Entwickeln trägt eine weite Eigenverantwortung. Regelmäßige Risikoanalysen durch die Entwicklungsteams tragen dieser Eigenverantwortung Rechnung. Mögliche Risiken können so in einer frühen Phase entdeckt und behoben werden. An dieser Stelle ist auch die Schnittstelle zum Sicherheitsverantwortlichen etablierbar, der so mit aktuellen Informationen versorgt werden kann, um die Anforderungen an das ISMS zu erfüllen. Für Sicherheitsanalysen sollten Vorgehen gewählt werden, die eine hohe Strukturierung erlauben, wie dies beispielsweise durch MS Stride gegeben ist.

Mit der Entwicklung sollte der Blick auf das Produkt nicht enden. Hier hat sich das Konzept des DevOps etabliert, bei dem die Prozesse zwischen Entwicklung und Ope-

rationalisierung erfasst und automatisiert werden sollen. Der DevOps-Prozess stellt eine Schleife dar, die von der Softwareplanung über Code-, Build-, Test- und Release-Phasen über die Bereitstellung, den Betrieb, die laufende Überwachung und das Feedback wieder zur Planung zurückführt. In diesem Kontext lassen sich agile Techniken wie Scrum oder Kanban einordnen.

Die Weiterentwicklung aus dem Blick der IT-Sicherheit ist dann DevSecOps, was die Abkürzung für Development (Entwicklung), Security (Sicherheit) und Operations (Betrieb) darstellt. Der intendierte Ablauf eines typischen DevSecOp-Ablaufs stellt sich dann wie folgt dar:

- In der Entwicklung wird der Code innerhalb eines Versionsverwaltungssystems zentral verwaltet.
- Änderungen am Code werden im Versionsverwaltungssystem nachvollziehbar vorgehalten und in den Kommentaren zum Versionsstand ausgewiesen.
- Unter Verwendung geeigneter Tools wird der Code aus dem Versionsverwaltungssystem analysiert (z. B. durch statische Codeanalyse), um so etwaige Schwachstellen, Fehler oder Abweichungen von den Coding-Standards zu identifizieren.
- Es wird eine standardisierte Umgebung, beispielsweise mit einem Infrastructure-as-Code-Tool, geschaffen, und die Anwendung wird dort eingebracht. Die intendierten Sicherheitseinstellungen werden auf das System angewendet.
- Dieses Gesamtsystem wird dann durch automatisierte Tools getestet, einschließlich Tests von Back-End, Benutzeroberfläche, Integration, Sicherheit und API.
- Wenn keine Schwachstellen aufscheinen, wird die Anwendung in eine Produktionsumgebung überführt.
- Security Monitoring überwacht diese Produktionsumgebung im Sinne eines ISMS.

13.3 Secure Development Lifecycles

Sicherheit kann im Kontext der funktionalen Sicherheit oder der IT-Sicherheit definiert werden. Bei der funktionalen Sicherheit steht die korrekte Funktion der Software im Mittelpunkt sowie dass diese bei korrektem Einsatz keine Schäden an Leib und Leben verursacht. Dies ist entsprechend in der Normenreihe IEC 61 508 „Funktionale Sicherheit sicherheitsbezogener elektrischer/elektronischer/programmierbar elektronischer Systeme“ definiert.

IT-Sicherheit hingegen zielt auf den Schutz der Software gegen vorsätzliche und zielgerichtete Manipulation der Software bzw. von Datenstrukturen ab und fußt in den Schutzziele der Vertraulichkeit, Integrität und Verfügbarkeit, auch bekannt als CIA-Triade. Weitere, teilweise abgeleitete Ziele sind die Authentizität, Nichtabstreit-

barkeit, Zurechenbarkeit und Resilienz, welche im Rahmen der DSGVO ausgestaltet wird. Auch der Schutz der Privatsphäre durch Anonymität, Pseudonymität oder anderer Privacy Enhancing Technologies (PET) wird hier zugerechnet als Ziel.

Hierbei haben sich verschiedene Vorgehen etabliert wie Microsoft SDL, CORAS, Systems Development Lifecycle (SDLC), Cigital Touchpoints oder Comprehensive, Lightweight Application Security Process (CLASP). Diese Methoden wurden entwickelt, um Software-Entwicklungsteams dabei zu helfen, Sicherheit in den frühen Phasen bestehender und neu beginnender Software-Entwicklungszyklen auf strukturierte, wiederholbare und messbare Weise zu integrieren. Generell sind hierbei die folgenden Phasen zu beobachten.

- **Anforderungen:** Als Grundlage für Entwurfsentscheidungen müssen die Entwickler die Betriebsumgebung eines Systems, einschlägige Bedrohungen und Risiken, die Sicherheitsziele der Beteiligten, bestehende Sicherheitsrichtlinien usw. ermitteln, was auch als Requirements Engineering bezeichnet wird. Die Analyse solcher Informationen führt zu dokumentierten Annahmen über das System und seine Einsatzumgebung und zu Prioritäten für die weitere Sicherheitstechnik. Einige Sicherheitsfunktionen können bereits in diesem Stadium gefordert werden.
- **Architektur:** Die Entwickler müssen eine praktikable Sicherheitsarchitektur entwerfen und dabei Sicherheitsmechanismen so kombinieren, dass sie aufeinander aufbauen und nicht leicht unterlaufen werden können. Die Sicherheitsarchitektur definiert Aspekte wie Vertrauensbeziehungen und die Angriffsfläche eines Systems.
- **Entwurf:** Der Sicherheitsentwurf betrifft Aspekte wie die Auswahl bestimmter Varianten einer allgemeinen Art von Sicherheitsfunktion, den Entwurf sicherheitsbezogener Benutzerschnittstellen und den Entwurf interner Aspekte wie Programmierschnittstellen oder die Stelle innerhalb der Architektur, an der bestimmte Funktionen implementiert werden sollen. Es können Kompromisse zwischen verschiedenen Sicherheitsanforderungen oder zwischen Sicherheit und anderen Anforderungen entstehen, die im Rahmen des Entwurfsprozesses gelöst werden müssen.
- **Implementierung:** Da eine Sicherheitsarchitektur schon durch geringfügige Fehler zum Scheitern gebracht werden kann, muss die Implementierung darauf abzielen, solche Fehler zu vermeiden. Sie können bei der Implementierung oder Anwendung von Sicherheitsfunktionen auftreten, aber auch bei der Implementierung jedes anderen Teils eines Systems, wenn die Sicherheitsarchitektur explizit oder implizit davon abhängt.
- **Testen und Prüfen:** Um Schwachstellen aufzudecken, sind spezielle Test- und Evaluationstechniken erforderlich. Einige Arten von Implementierungsfehlern können mit automatisierten Sicherheitsscannern gefunden werden. Tiefer ge-

hende Probleme können durch Penetrationstests oder durch Code- und Entwurfsüberprüfungen gefunden werden, die mehr Aufwand erfordern. Gefundene Schwachstellen sollten analysiert werden, um ihre Ursachen zu identifizieren und zu beheben.

13.4 Requirements Engineering

Unter dem Requirements Engineering werden die Prozesse der Definition, Dokumentation und Pflege von Anforderungen im Prozess des Entwurfs von Software verstanden, es stellt somit einen essenziellen Anteil in der Softwareentwicklung dar.

Die mit dem Requirements Engineering assoziierten Aktivitäten sind je nach Art des zu entwickelnden Systems unterschiedlich. Hierbei können aber einige Kernaufgaben betrachtet werden (Summervill 2009):

- Bei der **Anforderungsaufnahme oder Anforderungserhebung** treffen sich Entwickler und Interessengruppen und ermitteln in einer Art Interview ihre Bedürfnisse und Wünsche in Bezug auf das Softwareprodukt. Hierbei ist ein geordnetes Vorgehen unverzichtbar (Holzblatt 1997).
- In der **Anforderungsanalyse und -aushandlung** werden die Anforderungen ermittelt (einschließlich neuer Anforderungen, wenn die Entwicklung iterativ erfolgt) und Konflikte zwischen sich widersprechenden Anforderungen aufgelöst. Dabei müssen die Anforderungen an die IT-Sicherheit erfasst und ebenfalls schriftlich fixiert werden.
- Bei der **Systemmodellierung** werden die Anforderungen an das Gesamtsystem in ein geeignetes Modell überführt. Hier kommen Ansätze wie UML zum Einsatz. Die IT-Sicherheit erweitert diesen Schritt um für die Modellierung von Sicherheitseigenschaften geeignete Ansätze. Hier sind insbesondere Modelle wie Microsoft STRIDE zu nennen.
- Die **Anforderungsspezifikation** erfasst die Anforderungen und erlaubt eine Validierung dieser Anforderungen. Hierbei kommen sowohl schriftliche als auch grafische Darstellungen zum Einsatz. MS STRIDE führt für jedes Element des Systems die intendierten Schutzmaßnahmen in Form von Listen auf und bietet mit den Data Flow Diagrams auch eine visuelle Repräsentation.
- Die **Anforderungvalidierung** führt die Überprüfung, ob die dokumentierten Anforderungen und Modelle konsistent sind und den Bedürfnissen der Beteiligten entsprechen, durch.
- Gerade bei sich agil verändernden Entwicklungsprojekten ist das **Anforderungsmanagement** zur Verwaltung aller Aktivitäten bezüglich der Anforderungen un-

umgänglich. Jede Änderung der Anforderungen kann das Sicherheitsmodell beeinflussen, sodass es stets gilt, dieses konsistent mit den Änderungen stets neu zu erstellen und die Auswirkungen auf die Softwareentwicklung zu betrachten.

In dem Prozess, welcher der Microsoft Secure Development Library zugrunde liegt, wird das Requirement Engineering in Practice #2 (Define Security Requirements) und Practice #3 (Define Metrics and Compliance Reporting) erfasst.¹⁾ Hierbei legt SDL den Fokus auf eine klare Erfassung der Anforderungen und auf definierte Metriken, die es ermöglichen, einen sicheren Mindeststandard festzulegen. In der konkreten Situation der Entwicklung kann dabei auch eine „Gamification“ dieses Prozesses erfolgen unter Verwendung des MS SDL Card Game.²⁾

Einen ähnlichen Ansatz verfolgt das OWASP Threat Modelling,³⁾ welches sich an den Fragen „Woran arbeiten wir?“, „Was kann schiefgehen?“, „Was können wir dagegen tun?“ und „Haben wir gute Arbeit geleistet?“ orientiert. Hierbei stellen sich die ersten Fragen zu den erwähnten Practices der SDL ab.

13.5 Architektur und Entwurf

In der Abwehr von Angriffen auf ein System ist die Kenntnis über die Ziele der Angreifer von entscheidender Bedeutung. Je nach der Intention des Angreifers wird dieser verschiedene Techniken einsetzen, die dann wiederum in unterschiedlich konkreten Prozeduren enden. Dies wird innerhalb des Mitre Att&ck Framework als Tactics, Techniques und Procedures bezeichnet. Diesem Ansatz liegt die Erkenntnis zugrunde, dass einzelne Angriffe meist jeweils ein Baustein eines übergeordneten Angriffes sind.

Hierbei zeigt Mitre Att&ck die für die Entwicklung interessanten Angriffsvektoren auf, die in der Planung und Konzeption verstanden sein sollten. So werden die Angriffsvektoren auf der Ebene der Procedures mit dem jeweiligen Ziel des Angreifers verknüpft. Mitre Att&ck hilft hierbei, auch weniger bekannte Angriffsvektoren zu achten. Beispielsweise sind Angriffe gegen die Entwicklungswerkzeuge zu nennen oder Supply-Chain Attacks. Diese beispielhaft gewählten Klassen von Angriffen erlauben es Angreifern, Schwachstellen in eine Vielzahl von Produkten einzubauen, ohne dass die Entwickler einen Fehler gemacht haben. Ähnlich diesem Ansatz ist auch die Lockheed Martin Cyber Kill Chain anzusehen.

¹ <https://www.microsoft.com/en-us/securityengineering/sdl/practices>

² <https://www.microsoft.com/en-us/download/details.aspx?id=20303>

³ https://owasp.org/www-community/Threat_Modeling

Diese Betrachtung der Fähigkeiten von Angreifern und deren Zielen fließt ein in die Modellierung der Gefahren, die auf ein System einwirken. Einfache Methoden betrachten dabei die Schnittstellen, über die ein System kommuniziert. Dies wird als eine Analyse des Attack Surface bezeichnet. In dieser Methode wird dann für jede Schnittstelle hinterfragt, wie diese exponiert ist und welche Schutzmaßnahmen dort realisiert werden, um diese Schnittstelle zu schützen. Diese Betrachtung wird ebenfalls für die Daten durchgeführt, die potenziell über die Schnittstelle verfügbar sind. Dieser Ansatz bietet allerdings eine relativ geringe Unterstützung bei der eigentlichen Durchführung.

Weiter entwickelte Vorgehensmodelle wie OWASP Threat Modeling⁴⁾ oder MS STRIDE bieten deutlich mehr Unterstützung und Struktur. Durch Tools wie das MS Threat Modelling Tool⁵⁾ werden die Entwickler durch den Prozess der Analyse geführt. Im Fall der STRIDE-Analyse stellt das Data Flow Diagram (DFD) das zentrale Objekt der Betrachtung dar. Im DFD werden die Systeme anhand ihrer elementaren Bausteine (Data Flows, Data Store, Process, Interactors und Trust Boundaries) erfasst und visualisiert. Für jeden Baustein sind die möglichen Gefahren zugeordnet, sodass am Ende der Analyse Listen stehen, die es dem Team erlauben zu prüfen, ob an allen wichtigen Punkten des Designs ausreichende Maßnahmen getroffen wurden.

Die Sicherheitsziele, die nun in den DFDs und den resultierenden Listen repräsentiert werden, definieren zu einem Großteil auch die möglichen Fähigkeiten der Angreifer. Das Bewusstsein um die Fähigkeiten der Angreifer ist entscheidend für die Planung und Priorisierung von Maßnahmen, aber auch, um die Problematik bei den beteiligten Personen greifbar zu machen. Somit erfüllen die Threat-Modelle neben dem Zweck der konkreten Planung und Analyse auch die Aufgabe, das Bewusstsein für die möglichen Risiken im Entwurf zu schärfen.

13.6 Implementierung

Im Rahmen der eigentlichen Softwareentwicklung ist Sorge zu tragen, dass die entwickelte Software zum einen der Architektur entspricht, die zuvor entworfen wurde. Zum anderen soll eine hohe Qualität der Software garantiert werden. Gerade die Qualität in der Entwicklung kann durch verschiedene Maßnahmen flankiert werden, die es erlauben, die Implementierung zu flankieren und damit Schwachstellen in der Implementierung zu verhindern.

Die wichtigste Maßnahme stellt immer eine ausreichende Qualifikation der Entwickler dar und eine klare Definition der Ziele innerhalb eines Entwicklungsschrittes.

⁴ <https://threatdragon.org>

⁵ <https://www.microsoft.com/en-us/securityengineering/sdl/threatmodeling>

13.7 Coding-Standards

Coding-Standards stellen die Regeln, nach denen eine Software entwickelt wird, zusammen. Dies betrifft insbesondere den Stil, den ein Team verwendet. Hierdurch wird eine bessere Lesbarkeit des Projektes ermöglicht. Ohne eine klare Definition dieser Regeln können sich Fehler durch schlechte Variablenbezeichnungen einschleichen, und die Wartbarkeit des Codes nimmt über die Zeit deutlich ab. Zumeist legt sich ein Entwicklungsteam eigene Coding-Standards an, die auf allgemein anerkannten Werken basieren, wie es z. B. die SEI CERT-Coding-Standards sind.

Bei den SEI CERT-Coding-Standards handelt es sich um Software-Coding-Standards, die vom CERT Coordination Center⁶ entwickelt wurden, um die Sicherheit und Zuverlässigkeit von Softwaresystemen zu verbessern. Die Regeln lassen sich als ein Beispiel für die wichtigsten, sprachunabhängigen Vorgaben wie folgt zusammenfassen:

- **Input validieren:** Eingaben aus nicht vertrauenswürdigen Quellen, somit also alle Eingaben durch die Nutzer, müssen stets überprüft werden. Dabei ist auf die Länge, spezielle Zeichen oder auch fehlerhafte Datenformate oder Formatierungen zu achten. Eine korrekte Überprüfung von Eingaben verhindert eine große Menge an möglichen Schwachstellen. Die Überprüfung muss sich dabei auf praktisch alle externen Quellen erstrecken wie Kommandozeilenargumente, Netzwerkschnittstellen, Umgebungsvariablen und Dateien, die durch einen Nutzer in das System eingelesen werden (Seacord 2005).
- **Beachten von Compiler-Warnungen:** Beim Übersetzen des Sourcecodes sollte stets der jeweils höchste Level für Warnungen gewählt und die dann entstehenden Warnungen auch konsequent behoben werden (C MSC00-A, C++ MSC00-A). Der Einsatz von statischen wie dynamischen automatisierten Analysen, um Schwachstellen zu entdecken und dann zu beheben, ist angeraten.
- **Architektur und Design auslegen für Sicherheitsrichtlinien:** Die Softwarearchitektur muss darauf ausgelegt sein, Sicherheitsrichtlinien umsetzen und durchsetzen zu können. Hierbei kann es nötig sein, dass die Architektur sich an den Grenzen der benötigten Rechte orientiert und schon durch eine Separation of Duties im Sourcecode ein Zuordnen von unterschiedlichen Rechten ermöglicht.
- **Keep it simple:** Ein Design sollte stets so einfach und verständlich wie möglich gehalten werden, da Komplexität stets die Gefahr für Fehler erhöht (Saltzer 1974, Saltzer 1975). Sicherheit und die deren Implementierung lebt von der Korrektheit der Umsetzung der nötigen Maßnahmen. Auch muss beachtet werden, dass komplexe Strukturen nur deutlich aufwendiger zu überprüfen sind in Reviews.

⁶ <https://wiki.sei.cmu.edu/confluence/display/seccode/SEI+CERT+Coding+Standards>

- **Default deny:** Zugriffsregeln sollten stets zunächst einen Zugriff ablehnen und nur unter klar definierten Regeln einen Zugriff gewähren (Saltzer 1974, Saltzer 1975).
- **Prinzip der geringsten Rechte:** Jeder Prozess sollte mit den Satz von Rechten ausgestattet sein, die für die Erfüllung der Aufgabe nötig sind. Jedes zusätzliche Zugriffsrecht erhöht die Gefahr, dass im Falle eines Angriffs Informationen offengelegt werden, beispielsweise wenn ein Angreifer in der Lage ist, eigenen Code mit den Rechten des Anwenders auszuführen (Saltzer 1974, Saltzer 1975).
- **Bereinigen von Daten:** Daten, die an andere Systeme gesendet werden, wie Kommandozeilen, relationale Datenbanken oder andere kommerzielle/zugekaufte Komponenten, sollten zunächst bereinigt werden (C STR02-A). Bereinigt bedeutet, dass die Daten entsprechend der Regeln der jeweiligen Systeme aufbereitet sind. Hierbei muss auf Sonderzeichen, eingebettete Befehle oder ähnliche Strukturen geachtet werden. Ohne die Maßnahme könnte es einem Angreifer gelingen, an sich nicht zugängliche Funktionen in den Zielsystemen auszunutzen, wie es in SQL Injection-Angriffen oft der Fall ist. Bereinigen und Validierung sind verwandte Konzepte. Während die Validierung eingangsseitig erfolgt und nur ein begrenztes Wissen über die folgenden Systeme besitzen kann, wird die Bereinigung (Sanitization) ausgangsseitig durchgeführt, wo dieses Wissen in Form der Schnittstellenspezifikation vorhanden ist. In der Validierung sollte eine eher einfach geartete Behandlung der Daten erfolgen im Sinne einer Akzeptanzentscheidung. Bereinigungsmaßnahmen in der Validierung werden nicht als sinnvoll erachtet.
- **Verteidigung in der Tiefe:** Risiken sollte durch verschiedene gestaffelte Maßnahmen begegnet werden, sodass diese verschiedenen Ansätze sich gegenseitig ergänzen können. Hierdurch kann auch bei einer Verwundbarkeit in einer Gegenmaßnahme das Gesamtsystem weiterhin geschützt werden. Verschiedene Techniken bieten sich dabei an, in einem Gesamtkonzept kombiniert zu werden. Beispielsweise können sichere Programmiersprachen mit Sandboxing-Techniken (wie eine abgesicherte Laufzeitumgebung) kombiniert werden (Seacord 2005).
- **Qualitätssicherung:** Auch unter idealen Bedingungen können Fehler im Design oder in der Implementierung vorkommen. Dies ist aufgrund der Komplexität und Abhängigkeit von externen Bibliotheken kaum vermeidbar. Eine gut organisierte und durchgeführte Qualitätssicherung auf der Basis von Ansätzen wie Vulnerability Scannern, Fuzzing, Penetration Testing sowie Sourcecode-Auditierungen sollte Teil der regulären Maßnahmen sein, die in der Entwicklung immer wieder durchgeführt werden. Auch sollten die Auswirkungen der Entwicklungsmodelle jeweils betrachtet werden, sodass eine gute Kultur in der Entwicklung bereits zur Qualitätssicherung beiträgt. Externe Reviewer erhöhen nochmals die Qualität der Aussagen, da diese eine neue Sicht auf den Sourcecode und die Entwicklungsprozesse bringen (Seacord 2005).

- **Umsetzen eines Secure-Coding-Standards:** Jede Programmiersprache und Entwicklungsumgebung kann unterschiedliche Anforderungen an die Standards, die der Entwicklung zugrunde liegen, stellen. Eine dedizierte Entwicklung eines Secure-Coding-Standards oder dessen Ableitung von einem bestehenden kann also unerlässlich sein für eine sichere Entwicklung. Die Einhaltung der Regeln sollte nach Möglichkeit automatisiert geprüft werden. Hierzu bietet es sich an, die Vorgaben in Regeln zu überführen, die dann durch Skripte oder den Compiler überprüft werden können.

Neben diesen allgemeinen Vorgaben, die für die Implementierung von Software gemacht werden können, gibt es auch jeweils sprachen- und domänenabhängige Vorgaben. Hier ist beispielhaft die funktional sichere Entwicklung von C MISRA⁷⁾ zu nennen. Aber auch in C gibt es entsprechende Vorgaben.⁸⁾

13.8 Wahl der Programmiersprache

Ein wichtiger Teil in der Entwicklung von sicherer Software ist die Unterstützung von Sicherheitskonzepten bereits durch die verwendete Programmiersprache bzw. die Umgebung, die für eine Ausführung der Software zuständig ist. Hierbei können verschiedene Sicherheitseigenschaften von Programmiersprachen und Programmierkonzepten definiert werden.

Eine Programmiersprache besitzt die Eigenschaft der Memory Safety, wenn Garantien bezüglich der Speichernutzung erfolgen. Hierbei werden zwei Ausprägungen zu meist unterschieden. Zum einen, dass ein Programm nicht in der Lage ist, Speicher zu nutzen, der nicht von dem Programm angefordert wurde. Dies bedeutet auch, dass ein solches Programm niemals einen „Segmentation Fault“ erzeugen kann. Zum anderen kann es noch eine zusätzliche Schutzstufe geben, wenn das Programm niemals Speicher nutzen kann, der nicht vor Verwendung initialisiert wurde. Die Memory Safety bedeutet auch, dass die Zugriffsschutzmaßnahmen des Betriebssystems theoretisch nicht mehr benötigt werden, wenn angenommen werden könnte, dass die Implementierung der Memory Safety fehlerfrei erfolgt. Auch muss nicht mehr auf das explizite Nullen von Speicher durch die Entwickler geachtet werden, da dies durch die Sprache garantiert wird.

Type Safety garantiert das Einhalten der Regeln, die mit einem Datentyp vorgegeben werden. Wird beispielsweise ein `bool` definiert, so ist es unter Annahme der Type Safety nicht mehr möglich, diesen als einen Integer-Wert zu verwenden.

⁷ <https://www.misra.org.uk/misra-c/>

⁸ <https://gcc.gnu.org/codingconventions.html>

Safe Arithmetic beschreibt das Verhalten der Programmiersprache gegenüber Ausnahmen in der Verarbeitung von Werten in arithmetischen Termen. Beispielfhaft kann hier ein Overflow einer Rechnung gesehen werden. Ohne Safe Arithmetic wird das Systemverhalten ungeprüft weiterverarbeitet, was wiederum zu Angriffsvektoren führen kann.

Am komplexesten ist Thread Safety und Aliasing zu betrachten, da hier die Effekte von Nebenläufigkeiten mit Bezug auf die Initialisierung von Variablen oder deren Werten zugrunde liegen. Dabei können Programmiersprachen Lösungskonzepte bieten, die aber zumeist deutlich an Performance kosten.

Die Unterschiede dieser Garantien können anhand der Sprachen C, Java und Rust gut demonstriert werden. C bietet keinerlei Garantien, und die Entwickler können ein Maximum an Freiheit in der Entwicklung genießen. Diese Freiheit führt aber auch immer zu schwerwiegenden Sicherheitsvorfällen, da ohne diese Garantien Probleme wie Buffer-Overflows nicht durch die Sprache bereits reduziert werden. Demgegenüber stehen Sprachen wie Java oder Rust, die verschiedene Sicherheitsgarantien in ihrem Design jeweils umsetzen und so den Entwicklern bereits einige Schwachstellen abnehmen.

Es gilt aber auch, dass es jeweils immer wieder Möglichkeiten gibt, an den Schutzfunktionen vorbei zu arbeiten. Hier ist es nötig, die Entwickler durch Coding-Standards zu unterstützen und die Ergebnisse der Entwicklung stets durch Review-Maßnahmen in der Qualität zu sichern. Wichtige Aspekte sind dabei (Unit-)Tests, Code Reviews, Static Code Analysis sowie eine gute Validierung.

In der Praxis besteht immer die Herausforderung der bereits bestehenden Entscheidungen bezüglich der gewählten Programmiersprache, die in der Vergangenheit getroffen wurden. Hier muss je nach Situation durch das Projektmanagement jeweils entschieden werden, wie zu verfahren ist. Beispielsweise besteht ein Weg in der „schleichenden“ Migration, wie es im Bereich der Linux-Kernelentwicklung zu beobachten ist. Dort wird zunehmend der Einsatz von Rust als Ersatz für das bisherige C in Position gebracht.

Falls eine unsichere Programmiersprache gewählt wird, so ist durch entsprechende Coding-Standards sicherzustellen, dass Konstrukte, die zu Sicherheitsproblemen führen können, ausgeschlossen werden im Einsatz. Beispielsweise wird in C ein String als eine Zeichenkette definiert, welche nullterminiert ist. Typische Befehle wie strcpy verlassen sich dabei auf diesen Terminator, was eine Ursache für Buffer-Overflow-Angriffe ist. Ein Ansatz ist die explizite Übergabe der Länge der Datenstruktur, sodass die Nullterminierung nicht mehr trägt. Also strcpy verbieten und nur noch strncpy verwenden. Dies löst zwar das grundlegende Problem nicht, erhöht aber zumindest die Schwelle und zwingt die Entwickler, sich mit der Thematik zu beschäftigen.

13.9 Tests

Die Integration von Tests in den Sourcecode stellt eine wichtige Ergänzung zu den Coding-Standards dar. Der Grundsatz dabei lautet, dass durch das Schreiben von Tests für alle Teile der Software automatisierte Tests bestehen, die häufig und automatisch den geschriebenen und/oder überarbeiteten Code prüfen. Diese Tests werden in die Entwicklung bzw. die Entwicklungsmodelle integriert, sodass der Programmcode während der Entwicklung bereits frühzeitig und kontinuierlich gesichert wird.

Der Grundsatz hierbei lautet, dass, bevor die eigentliche Funktionalität entwickelt wird, die Tests definiert werden, die dann geeignet sind, ein korrektes Verhalten der Software zu bestätigen. Bei der Entwicklung von Tests ist zu beobachten, dass zumeist Tests definiert werden, die in ihrer Anlage einen erfolgreichen Durchlauf definieren. Fehlerfälle werden zumeist durch die Entwickler nicht modelliert. Dies ist auf die Komplexität in der Modellierung von Fehlerfällen zurückzuführen. Auch ist die Anzahl der möglichen Fehlerfälle in vielen Fällen nicht trivial in der Bestimmung.

13.10 Code Reviews

Ein Code Review ist eine systematische Untersuchung von Quellcode mit dem Ziel, Fehler und Mängel im Code zu finden. Das Ziel dabei ist die Verbesserung der Softwarequalität. Der Ablauf hierbei ist, dass ein Programmabschnitt nach oder während der Entwicklung von einem oder mehreren Gutachtern Korrektur gelesen wird, um so mögliche Fehler, Vereinfachungen oder Testfälle zu finden. Dabei kann der Gutachter selbst ein Softwareentwickler sein.

Ein solcher Code Review erfordert stets einen Reviewer, der bisher in den zu begutachtenden Code-Stücken nicht oder nur wenig involviert ist, sodass er unvoreingenommen das Review durchführen kann. Daher ist es hier weit verbreitet, solche Reviews von externen Beratern durchführen zu lassen, sodass diese unbelastet von der bisherigen Entwicklung die Beurteilung durchführen können.

Eine Variante zu Code Reviews ist der Ansatz des eXtreme Programming, welches als einen Bestandteil das Pair Programming und kollektive Eigentum in der Entwicklung verfolgt. Dabei entwickeln zwei Teammitglieder zusammen bzw. abwechselnd den Sourcecode und überwachen sich dadurch bereits während der Entwicklung. Dies senkt die Anzahl der kritischen Codebereiche.

13.11 Static Code Analysis

In Code Reviews werden häufig Probleme gefunden, die bestimmten Regelmäßigkeiten entsprechen bzw. die formalisiert und als Patterns definiert werden können. Diese Patterns können in automatisierten Verfahren auf den Sourcecode angewendet werden und damit regelmäßige Prüfungen auf Sicherheitslücken ermöglichen als fester Bestandteil der Build Chain. Diese als statische Codeanalyse bezeichnete Vorgehensweise untersucht den Quellcode einer Anwendung, bevor ein Programm ausgeführt wird.

Die statische Codeanalyse wird in der Regel nach der Codeentwicklung und vor den Unit-/Komponenten-/Integrationstests eingesetzt. Die daraus gewonnenen Informationen zur Qualität des Sourcecode kann dann innerhalb der CI/CD-Pipelines als Qualitätskontrolle vor Weitergabe und der weiteren Verwendung des Sourcecode weitergegeben werden.

13.12 Formale Analyse

Eine deutlich höhere Abstraktion in der Kontrolle des Sourcecodes wird in der formalen Analyse angestrebt. Es wird hierzu ein formales Modell zumeist parallel zum eigentlichen Sourcecode entwickelt, welches dann verwendet wird, bestimmte Eigenschaften des Gesamtsystems nachzuweisen.

Der dadurch entstehende Aufwand kann dabei als erheblich angesehen werden, da die Software quasi doppelt entwickelt werden muss und auch stets zu prüfen ist, ob Software und formales Modell noch zueinander in Beziehung stehen. Diese Beziehung ist dabei entscheidend, da nur dann, wenn diese besteht, die Aussagen der Analyse des formalen Modells valide sind.

In der Praxis hat sich die formale Verifikation lediglich in sehr engen Nischen etabliert, insbesondere wenn die Software kritische Funktionen zu erfüllen hat. Hierbei sind Ansätze wie FramaC⁹ oder Theorem Prover wie Isabelle¹⁰ zumeist zu beobachten.

⁹ <https://frama-c.com/>

¹⁰ <https://isabelle.in.tum.de/>

13.13 Validierung

Nach dem Abschluss der eigentlichen Entwicklung steht mit der Validierung ein weiterer Schritt zur Sicherung der Qualität an. Im Rahmen dieser Tests wird die Software dynamischen Analysen unterzogen und damit das Programm anhand seiner Eigenschaften, die es im Betrieb hat, untersucht.

Hierbei können Vulnerability Scanner eingesetzt werden, die auf der Basis einer Bibliothek von bekannten Schwachstellen das System testen. Eine solche Analyse erlaubt es, auf eine breite Basis an Schwachstellen automatisiert zu testen. Dadurch kann auch verhindert werden, dass bereits behobene Schwachstellen wieder in den Sourcecode Einzug halten. In diesem Bereich sind Tools wie openVAS¹¹⁾ (heute Greenbone Vulnerability Scanner) oder Nessus¹²⁾ etabliert.

Eine dynamische Analyse (oder auch Fuzzing) testet den Sourcecode im Betrieb auf Schwachstellen. Ein solches Fuzzing basiert auf der automatischen Erzeugung von Eingabevektoren, die auf das Target of Evaluation (TOE) angewendet werden. Beispielfhaft können hier die Tools American Fuzzing Loop¹³⁾ (AFL) oder OWASP ZAP¹⁴⁾ genannt werden. AFL zielt dabei auf die Analyse von C-Programmen ab, wobei es auch Anpassungen des Konzepts auf weitere Sprachen gibt. Dabei wird beobachtet, bei welchen Eingabevektoren die Software abstürzt. Diese Eingaben haben dann das Potenzial für weitergehende Angriffe, da sich hinter einem solchen Absturz z. B. ein Buffer-Overflow verstecken kann. ZAP hingegen arbeitet mit webbasierten Systemen als Ziel.

Als komplexeste Methode ist das Penetration Testing aufzuführen. Wohingegen die Vulnerability Scanner und Fuzzer automatisierte bzw. teilautomatisierte Analysen darstellen, wird beim Penetration Testing durch Experten die Software analysiert unter Verwendung der Tools und Ansätze, die auch ein Angreifer hätte. Somit ist diese Methodik dem realen Angreifer praktisch identisch. Dieser Schritt wird meist als Dienstleistung eingekauft. Vorbereitend sollten die bisher diskutierten Methoden ausgeschöpft werden.

¹¹⁾ <https://www.openvas.org/index-de.html>

¹²⁾ <https://de.tenable.com/products/nessus>

¹³⁾ <https://github.com/google/AFL>

¹⁴⁾ <https://www.zaproxy.org/docs/desktop/addons/fuzzer/>

13.14 Maintenance

Nach der Fertigstellung der Software geht diese in den Betrieb über, entweder innerhalb der gleichen Organisation oder als Lösung für externe Kunden. In beiden Szenarien entstehen neue Anforderungen an die Software, die sich auf die Software einwirken in Form von Änderungen.

In der Entwicklung von Software gilt es, die Entwicklung (Development) und den anschließenden Betrieb (Operations) eng zu verzahnen und die Sicherheit (Security) ebenfalls von Anfang an in der Entwicklung mitzudenken. Der daraus entstehende Ansatz des DevSecOps beschreibt dabei keine konkrete Technologie, sondern vielmehr die Kultur und Prozesse, die nötig sind, um eine Software in dieser Gemengelage zu entwickeln.

Im Rahmen des DevSecOps-Ansatzes können entsprechend des OWASP DevSecOps Maturity-Modells die Dimensionen Build and Deployment, Culture and Organization, Implementation, Information Gathering sowie Test and Verification unterschieden werden.¹⁵ Jede dieser Dimensionen wird dann entsprechend der Stärke der Ausprägung in vier Level bewertet. Diese Dimensionen zielen darauf ab, die Verbindung von Entwicklung und Betrieb sicherzustellen. Dabei wird auf Aspekte wie das Vorhandensein von Regeln und das Entstehen von Patches für den Betrieb insbesondere Wert gelegt.

Um eine Maintenance einer Gesamtlösung sicherzustellen, ist es wichtig, bereits in der Planungsphase die Use Cases sowie die intendierte Einsatzumgebung klar zu definieren. Nur so ist es möglich, die Sicherheitstests in einer realistischen Umgebung mit validierbaren Annahmen durchzuführen. Über diese Sicherheitstests hinaus muss sichergestellt werden, dass es klare Prozesse gibt, wie Informationen über Sicherheitsvorfälle in der Produktentwicklung abgebildet werden. Ein wichtiger Aspekt dabei ist das Erstellen aussagekräftiger Informationen, die den Betrieb beschreiben. Solche Log-Dateien dürfen aber auf der anderen Seite nicht selbst wieder zu einem Sicherheitsproblem führen.

In vielen Fällen erreicht ein Softwaresystem einen Punkt, an dem dieses nicht weiter sinnvoll weiterentwickelt werden kann, die Pflege des Systems zu stark die Weiterentwicklung behindert oder das Einführen neuer Funktionen erschwert. Dieser Punkt wird als End-of-Life (EoL) bezeichnet und wird in vielen Fällen bereits bei der Produkteinführung eingeplant, sodass eine Planungssicherheit auf Kundenseite besteht. In der Planung des Lebenszyklus können ebenfalls Aspekte der Sicherheit einfließen. Hier sind die Lebenszyklen von kryptografischen Verfahren als ein mögliches Beispiel zu nennen. Diese Verfahren werden von den nationalen Behörden bezüglich ih-

¹⁵ <https://dsomm.timo-pagel.de/>

rer Lebenserwartung beurteilt, und diese Werte werden dann in den einschlägigen Publikationen wie der BSI TR-02 012 erwähnt.¹⁶⁾ Die dort genannten Zeiträume sollten in der Planung der Lebenszyklen Einfluss finden, sodass ein Wechsel der kryptografischen Verfahren zusammen mit einem großen Update oder einem Sprung in der Versionsnummer erfolgen kann.

Ein wichtiger Teil der Maintenance ist die Verteilung der Updates und das Sicherstellen, dass Updates nicht durch einen Angreifer verändert wurden oder gar vollständig ausgetauscht. Diese Supply Chain Attacks können sich einerseits gegen die Updates richten, die aus dem Entwicklungsprozess entstehen, gegen die Bibliotheken, die in der Entwicklung verwendet werden, oder aber gegen die Tools, die durch die Entwickler verwendet werden.

Um die Updates an die Kunden abzusichern, haben sich Konzepte wie signierte Updates etabliert. Um dies zu ermöglichen, muss in der Entwicklung ein klarer Prozess definiert sein, der beschreibt, wann ein Update zur Auslieferung fertig ist und wie dann die Signatur erstellt wird. Hierbei sind die Regeln zur Verwendung von Signaturverfahren einzuhalten und die verwendeten Schlüssel speziell zu schützen.

13.15 Die wichtigsten Punkte in Kürze

- Aspekte der IT-Sicherheit müssen im Design und in der Entwicklung von Produkten früh berücksichtigt werden.
- Geeignete Methoden erlauben es, die einzelnen Entwicklungsphasen grundlegend zu unterstützen und Kosten zu reduzieren.
- IT-Sicherheit in der Produktentwicklung ist kein Selbstzweck, sondern unterstützt die Produktqualität durch eine Verbesserung von Design und Entwicklungsmethoden.

Literatur

Adkins, H., Beyer, B., Blankinship, P., Lewandowski, P., Oprea, A., Stubblefield, A. (2020). *Building Secure and Reliable Systems: Best Practices for Designing, Implementing, and Maintaining Systems*. O'Reilly Media.

Anderson, R. (2020). *Security engineering: a guide to building dependable distributed systems*. John Wiley & Sons.

Beck, K. (2003). *Extreme Programming: die revolutionäre Methode für Softwareentwicklung in kleinen Teams*; [das Manifest]. Pearson Deutschland GmbH.

De Meer, J., *Betriebssicherheit durch Cyber-Security-Testing* (2015). Datenschutz.

Holtzblatt, K., Beyer, H. (1997). *Contextual design: defining customer-centered systems*. Elsevier.

Howard, M., Lipner, S. (2006). *The security development lifecycle* (Vol. 8). Redmond: Microsoft Press.

¹⁶ https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR02102/BSI-TR-02102.pdf?jsessionid=C2A3280FEC036B197F062F89FDCD2955.internet081?__blob=publicationFile&v=2

- Lund, M. S., Solhaug, B., Stølen, K. (2010). *Model-driven risk analysis: the CORAS approach*. Springer Science & Business Media.
- Saltzer, J. H., *Protection and the Control of Information Sharing in Multics*. Communications of the ACM 17, 7 (July 1974): 388 – 402.
- Saltzer, J. H., Schroeder, M. D., *The Protection of Information in Computer Systems*. Proceedings of the IEEE 63, 9 (September 1975), 1278 – 1308.
- Seacord, R. *Secure Coding in C and C++*. Upper Saddle River, NJ: Addison-Wesley, 2006
- Sommerville, Ian (2009). *Software Engineering* (9th ed.). Addison-Wesley.
- Strom, B. E., Applebaum, A., Miller, D. P., Nickels, K. C., Pennington, A. G., Thomas, C. B. (2018). *Mitre att&ck: Design and philosophy*. Mitre Product Mp, 18-0944.
- Swiderski, F., Snyder, W. *Threat Modeling*. Redmond, WA: Microsoft Press, 2004.
- The cyber kill chain. <https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>. Abgerufen im Dezember 2021.
- Türpe, S., Poller, A. (2017). *Managing Security Work in Scrum: Tensions and Challenges*. SecSE@ ESORICS, 2017, 34 – 49.

Cybersicherheit in Produktion, Automotive und intelligenten Gebäuden

Marko Schuba, Hans Höfken



In diesem Beitrag erfahren Sie,

- welche Auswirkungen die fortschreitende Digitalisierung der Automatisierung auf die Cybersicherheit in verschiedenen Anwendungsbereichen hat,
- welche Fehler im Automatisierungsumfeld zu Mängeln der Cybersicherheit führen,
- welche Vorgehensweise für ein akzeptables Cybersicherheitsniveau in der Automatisierungstechnik erforderlich ist,
- welche Standards und Best Practices dabei helfen, dieses Cybersicherheitsniveau zu erreichen, und
- welche Techniken und Abläufe der Standard ISA/IEC 62443 spezifisch für das Anwendungsgebiet der Cybersicherheit in der industriellen Produktion beschreibt.

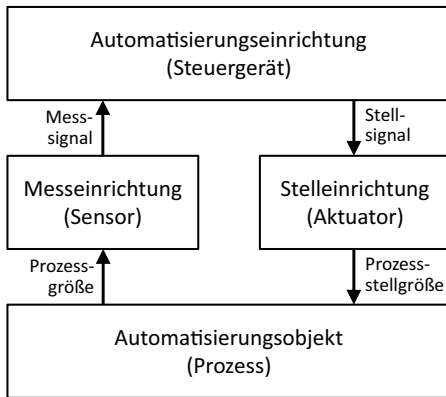
14.1 Einleitung

Cyberphysische Systeme, also Systeme, die die digitale Welt mit realen physikalischen Prozessen verbinden, durchdringen unseren Alltag. In cyberphysischen Systemen werden physikalischen Prozesse durch Computer gesteuert, was innovative Automatisierungslösungen beispielsweise in der industriellen Produktion, in Fahrzeugen oder in der Gebäudesteuerung ermöglicht. Waren cyberphysische Systeme vor Jahren noch isoliert, sind sie heute mit dem Internet vernetzt und ziehen ihre Innovation bzw. ihren Mehrwert vor allem aus dem Austausch von Informationen mit anderen Systemen und deren intelligenten Weiterverarbeitung. Diese Innovationen werden dann unter Begriffen wie Industrie 4.0, (Industrial) Internet of Things, Connected Vehicles oder Smart Buildings vermarktet. Die Entwicklung solcher vernetzten Automatisierungs-

lösungen führt zu großen Herausforderungen. Neben der Umsetzung funktionaler Anforderungen müssen auch nichtfunktionale Anforderungen berücksichtigt werden, z. B. auch solche, die die Sicherheit betreffen. Stand bei der klassischen Automatisierungstechnik aufgrund der Kopplung mit physikalischen Prozessen die funktionale Sicherheit (engl. Safety) im Vordergrund, entsteht durch die Öffnung zu externen Netzen und die Verwendung von Standardkomponenten eine zunehmend größer werdende Fläche für Cyberangriffe. Aspekte der Cybersicherheit (Security) werden immer wichtiger. Da die beteiligten Computer- bzw. Steuerungssysteme in der Automatisierung einen direkten Einfluss auf die zugrundeliegenden physikalischen Prozesse haben, können sich Probleme der Cybersicherheit indirekt auf Unversehrtheit von Menschen oder der Umwelt auswirken. Dementsprechend ist es notwendig, dass Cybersicherheit von allen Beteiligten, also den Herstellern der einzelnen Komponenten, den Integratoren (z. B. Maschinen- oder Automobilherstellern) und den Betreibern der Systeme angemessen berücksichtigt wird. Hierbei ist zu beachten, dass Automatisierungstechnik andere Anforderungen hat als klassische IT-Umgebungen, beispielsweise was die Echtzeitfähigkeit oder die hohe Verfügbarkeit anbelangt, weshalb Cybersicherheitslösungen aus der IT nicht 1:1 umgesetzt werden können, sondern an die jeweiligen cyberphysischen Systeme angepasst werden müssen.

14.1.1 Automatisierungstechnik

Automatisierungstechnik dient dazu, Prozesse in einzelnen Geräten, größeren Maschinen oder ganzen Anlagen zu steuern oder zu regeln, sodass sie weitestgehend selbstständig ablaufen (Zander 2015). Der Unterschied zwischen Steuerung und Regelung ist dabei, dass eine Steuerung eine gezielte Veränderung des Prozesses bewirken soll (z. B. „erhöhe die Temperatur auf 120 °C“), wohingegen eine Regelung vor allem die Stabilisierung des Prozesses gegenüber Störgrößen erreichen soll (z. B. „halte die Temperatur trotz wechselnder Umgebungsbedingungen bei 120 °C“). Die Umsetzung erfordert die Messung aktueller Prozessgrößen wie Temperatur, Druck oder Geschwindigkeit mittels Messeinrichtungen (Sensoren), die dann als Messsignale an eine Automatisierungseinrichtung (z. B. ein Steuergerät) übertragen werden. Ein solches Steuergerät enthält Programme zur Steuerung oder Regelung des Prozesses auf der Basis der gemessenen Prozessgrößen. Um das Automatisierungsobjekt (den Prozess) zu verändern, werden sogenannte Stellsignale an Stelleinrichtungen (Aktuatoren) gesendet, die den zugrunde liegenden Prozess über Prozessstellgrößen beeinflussen können (z. B. Temperatur, Druck oder Geschwindigkeit zu erhöhen oder zu verringern). Der Einfluss der Aktuatoren auf den Prozess wird wiederum von den Sensoren erfasst und an die Steuergeräte geliefert, was zu einer Rückkopplung und einem geschlossenen Wirkungskreis führt. Dieser Wirkungskreis eines Automatisierungssystems ist in Bild 14.1 dargestellt.

**Bild 14.1**

Wirkungskreis eines Automatisierungssystems (nach Zander 2015)

Automatisierungstechnik findet sich in cyberphysischen Systemen verschiedener Anwendungsbereiche wieder. Primär sind dies die industrielle Produktionstechnik (inklusive Fertigungs-, Verfahrens- und Energietechnik), der Bereich Fahrzeugtechnik (oder „Automotive“) sowie die Automatisierung im Rahmen von Gebäudetechnik.

Produktionstechnik

In der industriellen Produktion begann die Automatisierung in den 1970er-Jahren mit dem Einsatz von Elektronik und IT im Produktionsumfeld, der sogenannten dritten industriellen Revolution (Kagermann 2011, Spath 2013). Insbesondere die zunehmende Vernetzung von Industrieanlagen mit dem Internet und damit indirekt mit Mitarbeitern, Kunden und Benutzern, wird häufig als zweite Stufe der Digitalisierung oder auch mit dem Begriff Industrie 4.0 bezeichnet. Sie ermöglicht einerseits, Produktionsprozesse prinzipiell von überall aus zu steuern und zu regeln, und andererseits, Prozessdaten zu extrahieren und intelligent weiterzuverarbeiten. Letztendlich wird der Wirkungskreis aus Bild 14.1 um weitere Ebenen oberhalb der Automatisierungseinrichtung erweitert. Solche erweiterten Systeme werden in der Literatur häufig als Industrial Control Systems (ICS), Industrial Automation and Control Systems (IACS) oder auch Supervisory Control and Data Acquisition (SCADA) bezeichnet.

Fahrzeugtechnik

Die Automobilelektronik bestand zunächst aus Geräten mit analogen Bausteinen, die in den 1970er-Jahren zunehmend durch digitale Elektronik mit programmierbaren Speichern und Mikroprozessoren ersetzt wurden (Bosch 2024). Hohe Umweltbelastungen und eine hohe Zahl von Verkehrstoten führten in den 1980er-Jahren zu weiteren Verbesserungen der Fahrzeuge, die nicht nur rein konstruktiv waren, sondern insbesondere die Möglichkeiten der Elektronik nutzten (Borgeest 2014). Heutzutage ist die Fahrzeugtechnik nicht mehr isoliert, sondern die Steuerkomponenten sind über Telematikmodule in ein Dienstmodell eingebunden, welches es beispielsweise

erlaubt, Telemetriedaten der Fahrzeuge extern zu verarbeiten bzw. von außen aus Einfluss auf das Fahrzeug zu nehmen: eine der Grundvoraussetzungen für das autonome Fahren.

Gebäudetechnik

Als Teil der Gebäudetechnik hat die Gebäudeautomation in den letzten 50 Jahren zunehmend an Bedeutung gewonnen. Dies gilt insbesondere für komplexe Gebäudeformen wie z. B. Bürogebäude, Krankenhäuser oder Flughäfen (Karbach 2004). Neben der reinen Automatisierung spielt die Flexibilität bei den gebäudetechnischen Anlagen wie Raumklimatisierung, Beleuchtung und Beschattung eine wichtige Rolle. In den vergangenen Jahren rückten zudem Energiekonzepte und Nachhaltigkeit – z. B. die dezentrale Energieversorgung – in den Vordergrund, bei denen Automatisierungstechnik eine entscheidende Komponente darstellt. Auch bei der Gebäudeautomation wird ein erweiterter Wirkungskreis deutlich: Das Gebäude liefert Daten, die außerhalb (z. B. in der Cloud) mittels intelligenter Algorithmen ausgewertet werden. Auf Basis der Ergebnisse werden wiederum Aktionen eingeleitet, die über Steuergeräte und Aktoren im Gebäude umgesetzt werden.



Hinweis

Egal ob Produktions-, Fahrzeug- oder Gebäudetechnik: Cyberphysische Systeme werden über einen Wirkungskreis aus Sensoren, Steuergeräten und Aktoren gesteuert und geregelt. Im Zeitalter der Digitalisierung werden diese Wirkungskreise zunehmend erweitert, indem zentrale Algorithmen (z. B. künstliche Intelligenz in der Cloud) Daten der Automatisierungstechnik auswerten und Veränderungen am cyberphysischen System veranlassen.

14.1.2 Spezifische Anforderungen der Automatisierungstechnik

Eine Besonderheit der Automatisierungstechnik ist die Kopplung von digitalen Steuerungen und deren Sensoren und Aktoren mit einem physikalischen Prozess, häufig umschrieben als cyberphysisches System. Im Gegensatz zu einem rein digitalen Prozess hat ein cyberphysisches System somit eine direkte Auswirkung auf seine Umwelt. Dementsprechend sind bei der Entwicklung von Systemen im Bereich der Automatisierungstechnik spezifische Anforderungen, die mit dem physikalischen Prozess zusammenhängen, zu berücksichtigen, wozu insbesondere die Echtzeitfähigkeit, die Verfügbarkeit und die funktionale Sicherheit zählen.

Echtzeitfähigkeit

Vereinfacht gesagt besagt der Begriff der Echtzeitfähigkeit, dass ein System garantieren kann, eine Aktion innerhalb eines fest definierten Zeitintervalls durchzuführen. Im Kontext der Automatisierungstechnik beinhaltet dies häufig die Signal- und Datenverarbeitung durch den Sensor, das Steuergerät und den Aktuator inklusive der Kommunikation zwischen den beteiligten Komponenten. Ohne diese Echtzeitfähigkeit würde zu spät in den physikalischen Prozess eingegriffen werden, und das System befände sich nicht mehr in einem vorgesehenen Zustand.



Beispiel

Ein Sicherheitsventil einer chemischen Anlage soll im Notfall innerhalb einer bestimmten Zeitspanne schließen. Hierzu muss die komplette Signal- und Datenverarbeitung vom Auslöser (z. B. eine gemessene Druckprozessgröße, die einen Schwellwert überschreitet) bis hin zum Schließen des Ventils (Signalisierung der Prozessstellgröße für den Stellantrieb des Ventils) innerhalb dieser Zeitspanne durchgeführt werden.

Verfügbarkeit

Verfügbarkeit ist definiert als die „Wahrscheinlichkeit, dass sich ein System zu einem beliebigen Zeitpunkt in einem Zustand befindet, in dem es seine definierte Funktion erfüllen kann“ (Eberlin 2014). Das System soll also „wie geplant“ funktionieren. Obgleich dieser Begriff auch in der rein digitalen Welt verwendet wird, hat eine Verletzung der Verfügbarkeit im Bereich der Automatisierungstechnik häufig signifikantere Auswirkungen, da der korrekte Ablauf des physikalischen Prozesses beeinflusst wird.



Beispiel

Der Ausfall des Antiblockiersystems eines Fahrzeugs kann den Bremsweg des Fahrzeugs verlängern. Dies kann in Notsituation zu schwerwiegenden Unfallverläufen führen.

Funktionale Sicherheit

Nach Norm SAE J3061 ist funktionale Sicherheit der „Zustand eines Systems, der keine Schäden für Leben, Eigentum oder die Umwelt verursacht“ (SAE 2016). Vereinfacht gesagt, schützt die funktionale Sicherheit also den Menschen (und dessen Eigentum und Umwelt) vor der Maschine. Um dieser Anforderung nachzukommen, wird vor der eigentlichen Entwicklung eines Systems eine Risikoanalyse – z. B. in der Form eines Risikographen – durchgeführt. Da es grundsätzlich keine hundertprozentige Si-

cherheit geben kann, wird basierend auf dem Ergebnis dieser Analyse eine Sicherheitsanforderungsstufe (im Englischen: Safety Integrity Level, SIL) festgelegt, mit deren Maßnahmen das System die notwendige Risikominderung für ein tolerierbares Risiko erreicht. Genauere Informationen zur funktionalen Sicherheit liefert insbesondere die Normenreihe DIN EN 61 508 (DKE/GK 2024).



Beispiel

Der Austritt von heißem Dampf einer großen Heizungsanlage kann zu schweren Verletzungen bis hin zum Tod führen. In dem entsprechenden Anlagenbereich halten sich zwar nur selten Personen auf, jedoch können die getroffenen Schutzmaßnahmen die Eintrittswahrscheinlichkeit nicht auf ein sehr geringes Maß reduzieren, weshalb das verbleibende Risiko als nicht tolerierbar bewertet wird. Die Anlage erhält deshalb zusätzlich die Sicherheitsanforderungsstufe SIL 1, und es wird ein (funktionales) Sicherheitssystem installiert, welches zusätzlichen Schutz bietet.

14.1.3 Spezifische Eigenschaften der Automatisierungstechnik

Ein weiteres Merkmal von Anlagen der Automatisierungstechnik liegt in deren besonderen Betriebsform. Typischerweise ist der Lebenszyklus im Vergleich zu normalen IT-Produkten relativ lang, es werden sehr spezielle, oft genau für den Verwendungszweck konzipierte Systeme benutzt, und der Betrieb und die Wartung der Systeme erfolgt durch spezielles Personal. All dies hat Auswirkungen auf die Cybersicherheit und obwohl dieses Thema im Rahmen dieses Kapitels noch gar nicht im Detail diskutiert wurde, sollen hier schon einmal Hinweise auf Cybersicherheitsprobleme gegeben werden.

Langer Lebenszyklus

Wenn die Lebensdauer in der klassischen IT so wäre wie in der Automatisierungstechnik, hätten wir alle noch Windows 3.1 auf unserem PC. Nach dem Motto „Never change a running system“ laufen viele Systeme der Automatisierungstechnik über Jahrzehnte ohne große Veränderungen. Das betrifft Industrieanlagen genauso wie Autos oder Installationen von Gebäudetechnik. Erst wenn sich der Betrieb trotz Reparaturen und Wartung der Mechanik bzw. Elektronik ökonomisch nicht mehr lohnt, werden die Systeme außer Betrieb genommen und ersetzt bzw. verschrottet.

**Hinweis**

Was hat der Lebenszyklus eines Systems mit Cybersicherheit zu tun? Automatisierungstechnik besteht – wie klassische IT – aus Hardware und Software. Und ebenso enthalten die komplexen Systeme der Automatisierungstechnik meist Fehler (Schwachstellen), die von potenziellen Angreiferinnen und Angreifern ausgenutzt werden können. Solange alle Systemkomponenten von ihren Herstellern regelmäßig gewartet werden, d. h. insbesondere entdeckte Schwachstellen in der Software zeitnah beseitigt werden, ist die Cybersicherheit durch geeignetes Patchmanagement (das Einspielen der ausgebesserten Software) unter Kontrolle. Je länger jedoch der Lebenszyklus eines Systems, desto weniger Hersteller warten ihre Systeme: Es ist ökonomisch einfach nicht sinnvoll, die Software von Geräten zu warten, die bereits 15 Jahre in Betrieb sind. Somit werden zu einem späteren Zeitpunkt bekannt gewordene Schwachstellen in Systemen der Automatisierungstechnik nie mehr behoben und Angreiferinnen und Angreifer haben ein leichtes Spiel.

Vielfältige Technologien

Automatisierungstechnik hat ein breites Anwendungsfeld. Dementsprechend gibt es viele Hersteller, die Technikkomponenten auf der Basis der unterschiedlichsten Anforderungen entwickeln. Aufgrund der geringeren Stückzahlen der Gesamtlösung (Maschine, Fahrzeug, Gebäude) im Vergleich zu klassischen IT-Geräten bei gleichzeitig höheren Produktpreisen lohnt es sich, spezielle Systeme herzustellen, bei denen häufig proprietäre Software zum Einsatz kommt. Einzelne Komponenten und Geräte werden schließlich von Integratoren zu einem Gesamtsystem kombiniert, das – zumindest bei Industrieanlagen und Gebäudetechnik – mehr oder weniger einmalig existiert und schlussendlich von den jeweiligen Kunden betrieben wird.

**Hinweis**

Da jede Kette nur so stark ist wie das schwächste Glied, ist ein durchgängiges Niveau von Cybersicherheit für alle Komponenten die Voraussetzung für ein (cyber-)sicheres Automatisierungssystem. Aber nicht nur die einzelnen Komponenten müssen sicher sein, Gleiches gilt für die integrierte Lösung aus allen Komponenten, weil auch hier sicherheitsrelevante Fehler gemacht werden können. Neben den rein funktionalen Anforderungen des Gesamtsystems und dessen funktionaler Sicherheit auch noch Cybersicherheit angemessen zu berücksichtigen, ist aufgrund der Vielfalt der Technologien eine immense Herausforderung.

Betrieb und Instandhaltung

Ist eine fertig integrierte Automatisierungslösung erst einmal an den Kunden übergeben, ist sie für lange Zeit in Betrieb (vgl. Abschnitt „Langer Lebenszyklus“). Die Personen, die die Lösung nutzen bzw. betreiben, sind genau darauf spezialisiert: Sie kön-

nen die Industrieanlage bedienen, das Auto fahren oder die Heizung betreiben. Eventuell können sie auch einfache Wartungs- oder Reparaturarbeiten selbst durchführen. Sobald es jedoch komplexer wird, müssen Fachleute her. Dies sind entweder die Integratoren der Lösung, also die Anlagenbauer, Fahrzeughersteller oder Gebäudetechniker (und deren Partner), oder aber die Hersteller einzelner Komponenten selbst. Um den normalen Betrieb des Systems nicht zu stören, können insbesondere größere Wartungsarbeiten nicht zu beliebigen Zeitpunkten durchgeführt werden, sondern erfordern ein Wartungsfenster. Zudem werden teilweise Spezialisten benötigt, die nicht vor Ort anwesend sein können, sondern per Fernwartung auf das System zugreifen.



Hinweis

Aus Sicht der Cybersicherheit sind im Zusammenhang mit Betrieb und Wartung verschiedene Punkte relevant. Zunächst einmal sind die Kunden bzw. Betreiber des Systems in den meisten Fällen Laien in Bezug auf das System: Das betrifft häufig die Technik und fast immer die Cybersicherheit. Die Systeme müssen also inhärent cybersicher sein. Die Wartungsfenster stellen – neben dem weiter oben schon angesprochenen langen Lebenszyklus – ein weiteres Problem dar: Schwachstellen, die bekannt sind, werden unter Umständen erst sehr spät oder gar nicht behoben, weil kein Wartungsfenster zur Verfügung steht. Zu guter Letzt kann insbesondere die Fernwartung zu Sicherheitsproblemen führen, da die Gefahr eines nichtautorisierten Zugriffs auf das System besteht.

14.2 Schöne neue Welt – das Internet der Dinge

„The good news is that we are connected to the Internet. The bad news is that the Internet is also connected to us.“ Dieses Zitat unbekannter Herkunft beschreibt das Dilemma, in dem sich neue Systeme im Zeitalter des „Internets der Dinge“ befinden. Neben allen Chancen, die eine Vernetzung und die praktisch unbegrenzte Möglichkeit zum Austausch von Informationen bieten, öffnet sich mit der Vernetzung auch eine Tür, über die Angreiferinnen und Angreifer potenziell Zugriff auf unsere Systeme bekommen können.

14.2.1 Internet der Dinge (IoT)

Der Begriff Internet der Dinge (engl. Internet of Things, IoT) stammt ursprünglich aus einer Präsentation von Kevin Ashton im Jahr 1999 (Ashton 2009). Heutzutage versteht man darunter die Verknüpfung von eindeutig identifizierbaren physischen Objekten

mit ihrer virtuellen Repräsentation in Internet-ähnlichen Strukturen, oder vereinfacht gesagt: Jedes „Ding“ kann über das Internet prinzipiell mit allen anderen „Dingen“ Informationen austauschen.

Für die Automatisierungstechnik und die Anwendungsgebiete Produktionstechnik, Fahrzeugtechnik und Gebäudetechnik bedeutet dies, dass jede Komponente eines Systems lokal gesammelte Informationen an jede Stelle im Internet verschicken kann und ebenso von allen Internet-Systemen Informationen erhalten kann. Auch wenn diese Kommunikation grundsätzlich direkt sein kann, durchläuft sie häufig mehrere Stufen (Bradicich 2018), wie in Bild 14.2 dargestellt.

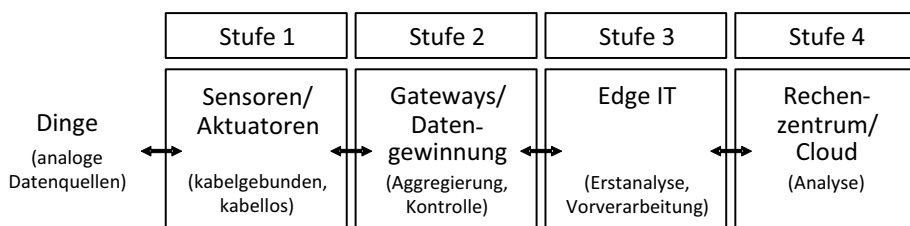


Bild 14.2 Vierstufige IoT-Architektur (nach Bradicich 2018)

Während die zuvor geschilderte Automatisierungstechnik im Wesentlichen die Stufen 1 und 2 abdeckt (die Maschine, das Auto, das Gebäude), erweitert die Stufe 3 die Systeme Analyse und Steuerungsmöglichkeiten im direkten Umfeld und nahezu in Echtzeit (z. B. in der lokalen IT, an der Grenze/Edge zum Internet), wohingegen Stufe 4 tiefgehende Analysen (z. B. Data Science, künstliche Intelligenz) und strategische Steuerungsmöglichkeiten – nicht in Echtzeit – erlaubt. Dies ermöglicht völlig neue Möglichkeiten, aber birgt auch Risiken.

14.2.2 IoT-Chancen für die Automatisierungstechnik

Die meisten etablierten Hersteller bzw. Betreiber von Automatisierungslösungen gehen davon aus, dass die Einführung der Vernetzung ihrer Systeme zum IoT zu höheren Einnahmen oder Einsparungen führt (WEF 2015). Einnahmen sollen dabei insbesondere durch neue Produkte und Dienstleistungen möglich werden. Zu den am häufigsten genannten Anwendungen gehören die vorausschauende Wartung und die Fernwartung von Systemen, welche Ausfälle oder unerwartete Ausfallzeiten auf der Grundlage von der auf Stufe 4 (siehe Bild 12.2) verfügbaren Informationen verhindern können. Weitere Vorteile von IoT-basierten Systemen sind die höhere Produktivität von Arbeitskräften, bessere Arbeitssicherheit und Arbeitsbedingungen sowie bessere Kundenerlebnisse: Die vernetzten Systeme übernehmen schwere und gefährliche Aufgaben bzw. bieten uns einfachere und schnellere Dienste – und das überall und jederzeit.

14.2.3 IoT-Risiken für die Automatisierungstechnik

Was die Risiken anbelangt, werden bei IoT im Zusammenhang mit der Automatisierungstechnik insbesondere die fehlende Interoperabilität bzw. fehlende Standards sowie Sicherheitsbedenken genannt (WEF 2015). So ist die Anfälligkeit für Cyberangriffe eine der größten Sorgen, da immer mehr physische Systeme online gehen. Betrachtet man das Stufenmodell aus Bild 12.2, so können solche Angriffe nicht nur durch unautorisierte Eingriffe in Stufe 1 und 2 entstehen, sondern auch aus der eigenen IT (Stufe 3) bzw. dem Internet (Stufe 4) kommen. Dass solche Angriffe grundsätzlich nicht unwahrscheinlich sind, zeigt die Zunahme von Angriffen auf die normale IT, von denen viele Unternehmen und Organisationen in Deutschland betroffen sind. Ein Schutz ist nicht immer einfach, weil mit der steigenden Komplexität des IoT auch die Schutzmaßnahmen komplexer und vielschichtiger aufgebaut werden müssen (sogenannte Defense in Depth). Da wir zudem mehr und mehr von vernetzten Systemen abhängig sind, ist Cybersicherheit beim Übergang zum IoT in der Automatisierungstechnik unerlässlich.



Beispiel

In jüngster Zeit machen vermehrt sogenannte Ransomware-Angriffe von sich reden. Ransomware ist eine Form von Schadsoftware, die Dateien auf einem Gerät verschlüsselt, wodurch alle Dateien und deren Systeme unbrauchbar werden. Böswillige Akteure fordern dann Lösegeld (Ransom) im Austausch für die Entschlüsselung.

Den Autoren sind eine Reihe von Angriffen auf produzierende Unternehmen in den vergangenen Jahren bekannt, die zu einem Stillstand der IT und der Produktion führten, zum Teil weltweit. Die Fälle reichten dabei von kleinen Unternehmen bis hin zu solchen mit mehreren Tausend Mitarbeiterinnen und Mitarbeitern und Dutzenden von internationalen Standorten.

14.3 Was läuft schief?

Cybersicherheit in der Automatisierungstechnik umzusetzen ist ohne Zweifel eine Herausforderung. Damit die Vernetzung in der Automatisierungstechnik nicht zum Super-GAU wird, soll das, was heute nicht gut funktioniert, in den folgenden Unterabschnitten zunächst identifiziert werden, um danach mit Maßnahmen adressiert werden zu können.

14.3.1 Zu viel Vertrauen in andere

Kein Unternehmen ist in der Lage, die Cybersicherheitsprobleme der Automatisierungstechnik alleine zu lösen. Dazu ist die Automatisierungstechnik inzwischen zu komplex und zu stark in die normale IT integriert. Probleme können in einem Bereich auftreten und dann andere Bereiche – inklusive einer Automatisierungslösung – in Mitleidenschaft ziehen. So hat der Ausfall der IT meist sofort auch den Ausfall der Produktion zur Folge. Betrachtet man spezifisch die Automatisierungstechnik vom Hersteller von Komponenten über den Integrator bis hin zum Betreiber des Systems, so tragen alle Beteiligten dabei mehr Verantwortung, als ihnen oftmals bewusst ist. Nur wenn Cybersicherheit im gesamten Entwicklungs- und Lebenszyklus der Systeme berücksichtigt wird, kann die Technik sicher betrieben werden. Eine integrierte Automatisierungslösung erfordert cybersichere Komponenten (Verantwortung Hersteller), die sicher zu einem Gesamtsystem zusammengebaut werden (Verantwortung Integrator) und schlussendlich sicher im Zusammenspiel mit der eigenen IT betrieben werden (Verantwortung Betreiber/Kunde bzw. Instandhaltungsdienstleister). Nur wenn diese teils sehr komplexe Lieferkette und die Einbettung in eine ebenfalls gut abgesicherte IT funktionieren, kann eine Automatisierungslösung cybersicher betrieben werden; und selbst das nicht mit hundertprozentiger Sicherheit. Deshalb: Alle Beteiligten tragen Verantwortung und müssen dies auch von ihren Partnern einfordern.

14.3.2 Zu wenig Management-Fokus

Das Management vieler Organisationen – und gerade in der Automatisierungstechnik – verbindet die Cybersicherheitsproblematik noch viel zu häufig ausschließlich mit der klassischen IT. Dabei sind klassische IT und Automatisierungstechnik in allen in diesem Kapitel besprochenen Anwendungsfeldern (Produktion, Automotive, intelligente Gebäude) inzwischen meist nahtlos miteinander verschmolzen. Die damit verbundenen Cybersicherheitsrisiken sind in den letzten Jahren stetig gewachsen und erfordern deswegen eine angemessene Würdigung des verantwortlichen Managements. Insbesondere ist es Aufgabe der obersten Leitungsebene, Cybersicherheit auch in der Automatisierungstechnik permanent im Blickfeld zu haben und entsprechende Strukturen und Ressourcen bereitzustellen. Mehr dazu später im Abschnitt 14.4.2.

14.3.3 Sicherheits-Features zu teuer oder nicht genutzt

Die angemessene Würdigung von Cybersicherheit durch das Management muss sich letztendlich auch in der Technik widerspiegeln. Die Beteiligten im Entwicklungszyklus vom Hersteller einzelner Komponenten über den Integrator zu einem Gesamtsys-

tem bis hin zum Betreiber/Nutzer wurde schon erwähnt. Jeder dieser Akteure muss dafür verantwortlich sein, die notwendige Cybersicherheit des von ihm entwickelten bzw. betriebenen Produkts aufrechtzuerhalten. Das bedeutet insbesondere, dass in diese Produkte alle erforderlichen Sicherheits-Features in angemessener Form integriert werden. Das Argument, dass Sicherheit-Features zu teuer sind, darf für eine „angemessene“ Cybersicherheit keine Rolle spielen – letztendlich kann Schlamperei langfristig zu viel höheren Kosten führen, wenn die durch fehlende Sicherheitsmechanismen entstehenden Schwachstellen durch Cyberkriminelle oder anderweitig ausgenutzt werden und zu Störungen bis hin zum Ausfall ganzer Automatisierungslösungen führen – von menschlichen und Umweltschäden im Zusammenhang mit cyberphysischen Systemen ganz zu schweigen. Dort, wo Sicherheits-Features vorhanden sind, müssen sie auch angemessen konfiguriert eingesetzt werden. Oft mangelt es hier an geeignetem Personal, welches ausgebildet werden muss.

14.3.4 Es ist noch nie etwas passiert – und das bleibt auch so

Dieses gern artikuliert Argument mag in manchen Fällen zutreffen, greift aber bei Cybersicherheit in der Automatisierungstechnik zu kurz. Wir alle sind noch nicht gestorben, haben aber trotzdem eine Lebensversicherung. Die meisten schwerwiegenden Cyberangriffe, die Unternehmen treffen, treffen diese zum ersten Mal. Im Nachgang ist es immer einfach zu sagen: „Wären wir doch besser aufgestellt und besser vorbereitet gewesen.“ Des Weiteren wurde die Automatisierungstechnik gerade in den vergangenen Jahren immer mehr mit der klassischen IT verzahnt, d. h., die Angriffsfläche und damit die Wahrscheinlichkeit, dass ein Cyberangriff auch Automatisierungslösungen betrifft, hat immer mehr zugenommen. Wichtig ist es, damit zu rechnen, dass die eigene Organisation betroffen sein kann. Neben präventiven Maßnahmen, die Angriffe verhindern sollen, sind deshalb auch erkennende und reaktive Maßnahmen ein absolutes Muss für den durchaus realistischen Fall, dass ein Angriff trotz aller präventiver Maßnahmen erfolgreich ist. Daneben sollten auch proaktive Maßnahmen wie beispielsweise Penetrationstests eingesetzt werden, um zu testen, inwieweit die präventiven Maßnahmen funktionieren.

14.3.5 Never change a running system

Viele Betreiber von Automatisierungstechnik glauben, dass Systemarchitekturen, die über Jahre oder Jahrzehnte ohne Probleme gelaufen sind, inhärent sicher sind. Das ist ein Trugschluss (vgl. auch vorherigen Abschnitt). Oftmals werden Schwachstellen von Systemen erst nach Jahren bekannt. Gelangt die Kenntnis über solche Schwachstellen in die falschen Hände, können Cyberkriminelle diese Schwachstellen ausnutzen und Schaden anrichten. Tatsächlich gibt es im Internet inzwischen die verschie-

densten Suchmaschinen, die Angreiferinnen und Angreifern das Leben erleichtern. So gibt es Suchmaschinen, die das Internet nicht hinsichtlich von Texten oder Bildern indizieren, sondern in Bezug auf Geräte (Shodan 2024, Censys 2024): Hier findet man über das Internet zugängliche Industrieanlagen oder Gebäudesteuerungen mit Informationen über Typ und Versionsstand der verwendeten Geräte. Passend dazu gibt es Datenbanken mit sogenannten Exploits, also Programm(fragment)en, welche bekannte Schwachstellen solcher Geräte gezielt ausnutzen, um die Geräte zu manipulieren oder komplett die Kontrolle zu übernehmen. So hat die Exploit Database der Sicherheitsfirma Offensive Security über 46 000 Einträge – da wird man für viele Geräte schnell fündig (OS 2024). Was hier hilft: Patchmanagement. Dazu später mehr.

14.3.6 Sensibilisierung und Weiterbildung zu teuer/aufwendig

Dass Sensibilisierungs- und Weiterbildungsmaßnahmen Geld kosten, steht außer Frage. Wie hoch sind diese Kosten jedoch im Vergleich zu den Kosten eines dadurch nicht verhinderten Cybersicherheitsvorfalls? Betrachtet man die Kosten von „gehackten“ Unternehmen, ist die Antwort eindeutig: Eine vorherige Investition in Cybersicherheit und insbesondere Sensibilisierung oder Schulung hätte sich definitiv gelohnt. Cybersicherheit in der Automatisierungstechnik betrifft eine große Anzahl von Menschen: bei Herstellern und Integratoren vor allem das Entwicklungspersonal, das dafür zuständig ist, cybersichere Technik zu entwickeln, bei Betreibern, Kunden und Dienstleistern diejenigen, die für den technischen Betrieb bzw. die Wartung der Automatisierungslösung zuständig sind. Bei allen diesen Personen ist eine ausreichende Schulung in Bezug auf Cybersicherheit zwingend notwendig.



Beispiel

Der Bedarf an Cybersicherheitsschulungen für Entwickler zeigt sich den Autoren insbesondere durch die Dozententätigkeit für Unternehmen: Entwickler von Automatisierungslösungen und das technische Personal der Betreiber sind herausragende Expertinnen und Experten in ihrem jeweiligen Fachgebiet, z. B. der Automatisierung. Von Cybersicherheit haben die meisten von ihnen keine oder nur rudimentäre Kenntnis. Nach einem mehrtägigen Kurs mit Theorie und praktischem Hackingangriff hat sich ihr Verständnis von und ihr Verhältnis zu Cybersicherheit komplett verändert.

Neben dem technischen Personal sind aber auch (fast) alle anderen Mitarbeiterinnen und Mitarbeiter mit Bezug zu Automatisierungstechnik oder IT für Cybersicherheit verantwortlich. Fast jeder hat heute beruflich mit einem elektronischen Gerät zu tun, und Cyberkriminelle setzen normalerweise bei dem schwächsten Glied in der Kette an – dem Menschen. Mit geschickten Manipulationen in der Form von fingierten Szenarien (Stichwort: Social Engineering) wird versucht, Menschen zu falschem Verhal-

ten zu verleiten oder Zugangsdaten freizugeben. Alle Beschäftigte sollten sich dessen bewusst sein, was insbesondere durch Cybersicherheits-Awareness-Aktionen oder -Schulungen gefördert werden kann. Beispielsweise zeigen von den Autoren durchgeführte Phishing-Kampagnen im Auftrag von Unternehmen, dass etwa die Hälfte der Mitarbeiter ihre Computerzugangsdaten auf einer fingierten Webseite eingeben – wenn sie nur eine ausreichend echt erscheinende Aufforderungs-E-Mail erhalten.

14.4 Was ist zu tun?

Um Cybersicherheit einzuführen und aufrechtzuerhalten, sind technische und organisatorische Maßnahmen notwendig. Viele dieser Maßnahmen sind allgemein und daher für alle Organisationen gültig, andere sind nur für bestimmte Branchen relevant. Von daher gibt es sowohl allgemeine als auch branchenspezifische Standards und Best Practices, die Organisationen helfen, ihr Cybersicherheitsniveau auf ein angemessenes Niveau zu bringen.

14.4.1 Cybersicherheit allgemein

Die Einführung und Aufrechterhaltung von konkreten Einzelmaßnahmen für die Cybersicherheit einer Organisation erfordert Managementprozesse. Ein Informationssicherheitsmanagementsystem (ISMS) ist ein Prozess-Rahmenwerk, das eine Organisation in die Lage versetzt, ihre Abläufe und Vermögenswerte vor internen und externen Bedrohungen zu schützen und insbesondere die Vertraulichkeit, Integrität und Verfügbarkeit relevanter Informationen und Systeme sicherzustellen. Für den Aufbau und Betrieb eines solchen allgemeinen ISMS können Verantwortliche auf eine Reihe von Standards und Best Practices zurückgreifen (z. B. ISO 27001 (ISO-a 2017), IT-Grundschutz des BSI (BSI-a 2020) oder NIST Cyber Security Framework (vgl. NIST-a 2018)).

Viele der oben genannten Standards ermöglichen es Organisationen, ihr ISMS zertifizieren zu lassen. Aber auch wenn keine sofortige Zertifizierung angestrebt wird, kann man sich an diesen Dokumenten orientieren, da sie alle für die Cybersicherheit wichtigen technischen und organisatorischen Aspekte berücksichtigen und dadurch verhindern, dass Dinge vergessen werden. Sollte später eine Zertifizierung ins Auge gefasst werden, sind alle vorhandenen Prozesse und Techniken des ISMS schon mit den Standards kompatibel und müssen nicht von Grund auf neu aufgebaut werden.

Was gerade zu Beginn häufig unterschätzt wird, ist der für den Betrieb eines ISMS notwendige Aufwand. Viele Organisationen nehmen initial Geld in die Hand, um Cy-

bersicherheit einzuführen, setzen aber keine Prozesse für deren Aufrechterhaltung um. Damit die Investition auch langfristig erfolgreich ist, sollte Cybersicherheit von Beginn an als Prozess und nicht nur als Projekt verstanden werden. Ohne eine massive Unterstützung des Managements (siehe Abschnitt 14.3.2) wird das Ziel Cybersicherheit auf Dauer nicht zu erreichen bzw. zu erhalten sein.

14.4.2 Cybersicherheit in der Automatisierung

Cybersicherheitsanforderungen in der IT sind heute technisch oft gut umzusetzen. Für viele Betriebssysteme, Protokolle und Netzwerkinfrastruktursysteme existieren Lösungen, die einfach zu installieren sind und dauerhaft Schutz bieten.

Bei industriellen Anlagen, Gebäuden und Automotive ist das größtenteils etwas anderes. Im Folgenden demonstrieren drei Beispiele aus dem Industriebereich, warum es Probleme bei der Umsetzung von Cybersicherheitsanforderungen gibt.



Beispiel 1

Die Bandgeschwindigkeit einer Papiermaschine wird über einen Frequenzumrichter gesteuert. Dieser Frequenzumrichter wird über das Protokoll MODBUS mit der Leitstelle verbunden. Damit eine Angreiferin oder ein Angreifer nicht die Bandgeschwindigkeit manipulieren kann, soll die Kommunikation verschlüsselt werden.

Die Datenpakete mit dem Wert für die Bandgeschwindigkeit müssen in einer festgelegten Zeit wiederholt an den Frequenzumrichter gesendet werden (Echtzeit/Real Time). Allerdings kann eine Ver- und Entschlüsselung der Datenpakete dazu führen, dass diese Zeiten nicht mehr eingehalten werden können, was dazu führt, dass eine Kontrolle und Veränderung der Bandgeschwindigkeit nicht mehr durchgeführt werden kann. Damit ist die Verschlüsselung keine Option.

Beispiel 2

Eine Teilanlage in einem Produktionsprozess wird ausschließlich vom Hersteller dieser Teilanlage gewartet. Über einen verschlüsselten Tunnel verbindet sich der Hersteller mit dem Betreiber der Produktionsanlage, und seine Daten werden dann an die Produktionsanlage weitergesendet. Allerdings hat er auf diese Weise auch die Möglichkeit, Daten an andere Teile der Produktionsanlage zu senden.

Das soll unterbunden werden. Der Teilanlagenhersteller soll ausschließlich Daten an die eigenen Systeme senden dürfen. Diese Aufgabe übernimmt in der IT eine Firewall, und über Firewall-Regeln wird genau festgelegt, welche Daten an welche Stelle gelangen dürfen.

Leider wird für die Kommunikation mit der Teilanlage ein proprietäres Protokoll verwendet, für das es auf dem gesamten Markt keine Firewall gibt. Damit ist die Firewall keine Option.

Beispiel 3

In einem Umspannwerk, weit weg von der Leitstelle, gibt es eine speicherprogrammierbare Steuerung (SPS), die über das Internet erreichbar ist und Daten für die Leitstelle zur Verfügung stellt. Die SPS ist in der Lage, einen verschlüsselten Tunnel zur Verfügung zu stellen, über den die Daten sicher abgerufen werden können.

Leider wurde vor kurzer Zeit eine Schwachstelle für eben diese verwendete SPS veröffentlicht, die es einer Angreiferin oder einem Angreifer ermöglicht, das System zu übernehmen.

Um diese Schwachstelle zu beseitigen, müsste vom Hersteller ein Patch zur Verfügung gestellt werden. Da die SPS schon 20 Jahre alt und auch nicht mehr vom Hersteller verkauft wird, gibt es keine Software-Updates mehr. Damit ist Patchen keine Option.

Wie man sieht, sind nicht alle Cybersicherheitsanforderungen in der Automatisierung einfach umzusetzen. Manchmal muss man stattdessen kompensierende Maßnahmen einführen, bei denen mögliche Schwachstellen zwar nicht behoben, jedoch so isoliert werden, dass das mit der Ausnutzung der Schwachstelle verbundene Risiko akzeptabel wird (Workaround).

Eine generelle Hilfe bei der Einführung von Cybersicherheit in der Automatisierungstechnik können branchenspezifische Cybersicherheitsstandards wie der ISA/IEC 62 443 (ISA-a 2024 für Produktions- und Gebäudetechnik), der ISO/SAE 21 434 (ISO-b 2021) sowie weitere Standards bzw. Best Practices sein. Vier davon werden im Folgenden kurz vorgestellt.

Cybersicherheit für Produktion und Gebäude – ISA/IEC 62 443

Die Standardreihe ISA/IEC 62 443 entwickelte sich aus dem Standard ISA99, der 2002 veröffentlicht wurde (ISA-a 2024). Das Ziel war das Erreichen von Cybersicherheit für industrielle Produktions- und Steuersysteme. Der Standard ist aber auch auf Gebäudetechnik anwendbar. Der Standard bestand schon ursprünglich aus mehreren Teilen. 2009 vereinte sich eine Arbeitsgruppe der IEC (*International Electrotechnical Commission*) mit ISA99, und dieser Standard ging in den Standard ISA/IEC 62 443 über. Die Teile blieben weitestgehend die gleichen, wurden jedoch ergänzt und erweitert. Aktuell besteht ISA/IEC 62 443 aus 13 Teilen, von denen einige noch in der Entwurfsphase sind (DKE 2020).

Die Teile des IEC 62 443 sind in vier Gruppen eingeteilt. Die Gruppen 2, 3 und 4 wenden sich an Betreiber, Integratoren und Komponentenhersteller und damit an alle Beteiligten im Umfeld industrieller Anlagen und von Gebäuden. Durch den Standard sprechen alle Beteiligten die gleiche Sprache, und Forderungen eines Betreibers können schon im Vorfeld von einem Komponentenhersteller erfüllt werden. Dadurch kann das gemeinsame Ziel Cybersicherheit erreicht werden.

Cybersicherheit für Produktion – NIST 800-82

Die NIST Special Publication 800-82 fokussiert auf die Cybersicherheit im industriellen Umfeld (NIST-b 2023) und kann als Grundlage zur Einarbeitung in das Thema dienen. Das Dokument gibt eine Übersicht über typische IT- und Automatisierungssysteme einer Industrieanlage, beschreibt, wie Risiken erfasst und verwaltet werden können, und gibt schließlich Hinweise, wie Cybersicherheit eingeführt und betrieben werden kann. Weiterhin werden viele technische Verfahren, die zum Einsatz kommen können, dargestellt. Es werden z. B. Datenprotokolle beschrieben und bewertet, hilfreiche Netzwerktechniken wie Firewalls und die Einführung von Zonen betrachtet, aber auch Monitoring und Logging werden berücksichtigt. Am Ende werden Maßnahmen beschrieben, mit denen die Cybersicherheit aufrechterhalten werden kann. Dazu gehören auch Personalschulungen. Viele Maßnahmen verweisen auf weitere NIST-Dokumente, sodass neben dem Ursprungsdokument eine Reihe weiterer Dokumente durchzulesen und zu beachten sind.

Cybersicherheit für Produktion – Dokumente des BSI

Auf nationaler Ebene ist das Bundesamt für Sicherheit in der Informationstechnik (BSI) nicht nur für das allgemeine Thema Informationssicherheit, sondern auch für die Cybersicherheit im industriellen Bereich zuständig. Neben dem einführenden Dokument „ICS Security Kompendium“ (BSI-b 2012) gibt es weitere Informationen zu speziellen Teilen der ICS-Sicherheit (BSI-c 2024). Auch zu aktuellen Ereignissen findet man Informationen (BSI-d 2024). Alles in allem bildet das BSI eine umfangreiche Informationsquelle in deutscher Sprache, weshalb hier einige Dokumente kurz vorgestellt werden sollen.

- **„Industrial Control System Security: Top 10 Bedrohungen und Gegenmaßnahmen“:** In dieser Sammlung wird auf die aktuell am häufigsten vorkommenden Angriffe auf Industrieanlagen eingegangen. Die aktuellste Version von 2022 beschreibt die Probleme und Ursachen für jede Bedrohung sowie Gegenmaßnahmen, die präventiv ergriffen werden können. Anhand von Bedrohungsszenarien kann leicht die Relevanz für die eigene Situation erkannt werden (BSI-e 2022).
- **„Fernwartung im industriellen Umfeld“:** In diesem Dokument wird kurz und knapp alles zusammengefasst, was bei der Fernwartung einer Anlage zu berücksichtigen ist. Dies kann bei der Neueinrichtung einer Fernwartungslösung schon im Vorfeld berücksichtigt werden. Soll eine vorhandene Fernwartungslösung gesichert werden, ist das Dokument „Grundregeln zur Absicherung von Fernwartungszugängen“ zu empfehlen (BSI-f 2018).
- **„Industrial Control System Security: Innentäter“:** Dieses Dokument fokussiert auf Cybersicherheitsvorfälle, die durch Innentäter verursacht werden. Tatsächlich kommt gerade bei Industrieanlagen ein großer Teil der Täter aus der Gruppe der ehemaligen Mitarbeiter. Diese Täter besitzen neben der Kenntnis, wie die An-

lage funktioniert, oft noch Zugänge zum Firmen- und Produktionsnetz und müssen bei einer Abwehrstrategie durch ergänzende Maßnahmen besonders berücksichtigt werden (BSI-g 2018).

Insgesamt bietet das BSI viele hilfreiche Dokumente zu einzelnen Teilbereichen der Cybersicherheit an. Auch wenn man sich für einen Standard oder eine Best Practice als Grundlage für die eigene Cybersicherheit entschieden hat, ist die Lektüre der BSI-Literatur zu empfehlen. Einige Dokumente haben grundlegenden Charakter, andere beziehen sich auf aktuelle Geschehnisse. Gerade die aktuellen Trends können zur Analyse der Bedrohungslage für die eigene Organisation verwendet werden und dienen der Vorbereitung auf potenzielle Angriffe.

Cybersicherheit für Automotive – ISO/SAE 21 434

Vernetzten, autonom fahrenden Fahrzeugen gehört die Zukunft. Die Fahrzeuge erhalten dazu alle notwendigen Daten von eigenen eingebauten Sensoren, aber auch aus dem Umfeld. So kommunizieren Fahrzeuge in der Zukunft mit der Verkehrsinfrastruktur (Ampel, Schranke, Parkhaus), mit anderen Verkehrsteilnehmern und mit dem Internet, z. B. mit dem Backend des Fahrzeugherstellers. Damit das Fahrzeug seine Aufgabe sicher erfüllen kann, ist Cybersicherheit unerlässlich und muss schon in der Entwicklungsphase berücksichtigt werden. Ein Nachbessern bei Millionen verkaufter Fahrzeuge wäre viel zu teuer. Hier kommen Standards ins Spiel, die die Voraussetzung dazu liefern sollen.

Die ISO/SAE 21 434 ist ein Standard, der gemeinsam von der International Standards Organization (ISO) und der Society of Automotive Engineers (SAE) entwickelt wurde (ISO-b 2021). Der Standard befasst sich mit Cybersecurity-Risiken bei der Konzeption und Entwicklung von Fahrzeugelektronik. Dabei sind die Bedrohungsanalyse und das Risikomanagement zentrale Punkte des Standards. Der Standard deckt alle Phasen des Lebenszyklus eines Fahrzeugs ab, vom Entwurf über Produktion und Betrieb bis hin zur Stilllegung. Aufgrund der starken Abhängigkeit von Lieferketten bei der Fahrzeugproduktion werden insbesondere auch Zuliefererbeziehungen im Rahmen des Standards berücksichtigt.

14.5 Praxisbeispiel: Einführung von Cybersicherheit in der Produktion (Orientierung an ISA/IEC 62 443)

Im Folgenden soll anhand ausgewählter praktischer Beispiele gezeigt werden, wie Cybersicherheit in der Produktion eingeführt werden kann. Der Abschnitt orientiert sich an der Standardreihe ISA/IEC 62 443 (ISA-a 2024), die neben rein technischen Empfehlungen auch ein Informationssicherheitsmanagementsystem (ISMS) beinhaltet (ISA-b 2015). Das ISMS der IEC 62 443 lehnt sich dabei weitgehend an den Standard ISO 27 001 an und ergänzt ihn um Dinge, die speziell im industriellen Umfeld benötigt werden.

14.5.1 Audit

Auf die Frage, wie es konkret technisch bzw. organisatorisch um die Cybersicherheit einer Anlage oder eines Gebäudes bestellt ist, kann nur ein Fachmann nach einem gründlichen Audit kompetent antworten. Allein die Tatsache, dass es bisher noch keinen erfolgreichen Angriff gab (siehe Abschnitt 14.3.4), bedeutet nicht, dass die Cybersicherheit gut oder das Unternehmen als Angriffsobjekt uninteressant ist. Der Standard IEC62 443 beschreibt ausführlich, welche Anforderungen an einen Audit gestellt werden (vgl. Information Security Review, ISA-b 2015, S. 112 ff.). Dabei hängt es von vielen Faktoren ab, welches Risiko aufgrund nicht vorhandener oder nur unzulänglicher Maßnahmen existiert und mit welchen Konsequenzen nach einem erfolgreichen Angriff zu rechnen ist. Neben der eingesetzten Technik sind auch die Ausbildung des Personals und das Management der Cybersicherheit entscheidend.

Die Durchführung eines Audits im Bereich der Automatisierungstechnik erfolgt vorwiegend durch gezielte Interviews mit den Personen, die die für die Beurteilung der Cybersicherheit notwendigen Informationen haben. Hier sind vom Vorstand bis hin zum Maschinenführer alle gefragt. Daneben ist eine stichprobenartige Sichtung von Dokumenten und Systemen sinnvoll. Der Einsatz automatisierter Tools in der Produktion ist detailliert abzuwägen, da solche Tests zu unvorhergesehenen Ausfällen führen können, die gerade im Produktionsbereich erhebliche finanzielle Schäden verursachen können. Wichtig für die Qualität des Auditergebnisses ist: Nur wenn die richtigen Informationen vorliegen, können die richtigen Schlussfolgerungen getroffen und die richtigen Maßnahmen ausgewählt und umgesetzt werden. Maßnahmenentscheidungen basierend auf unzureichenden oder falschen Informationen führen nicht nur zu einem schlechten Cybersicherheitsniveau, sondern auch zu Unverständnis und Widerständen in der Belegschaft.

Manchmal werden durch einen Audit eklatante Mängel offenbar. Dann sind die notwendigen Maßnahmen aufwendig, und eine komplette Umsetzung scheint unmöglich. Hierbei gilt es zu beachten: Jede Reise, sollte sie noch so lang sein, beginnt mit dem ersten Schritt. Am Anfang sollten die einfach erreichbaren und besonders wichtigen Dinge umgesetzt werden. Danach kann in weiteren kleinen Schritten an der Perfektion des Systems gearbeitet werden (vgl. Maturity Level, ISA-c 2016, S. 63–67).



Hinweis

Neben den im Standard geforderten regelmäßigen Audits empfehlen die Autoren einen Audit als Einstieg in die Cybersicherheit. So sind bereits vorab viele cybersicherheitsrelevanten Informationen bekannt, und die Entscheidung, was gemacht werden muss, kann kompetenter getroffen werden.

14.5.2 Festlegen eines Sicherheitslevels

Der Standard definiert fünf (Cyber-)Sicherheitslevel 0 bis 4 (vgl. ISA-c 2016, S. 73–80 oder ISA-d 2013, S. 60–67), die einen Schutz gegen bestimmte Gruppen von Angreiferinnen und Angreifern bieten sollen. So hilft der Sicherheitslevel 1 gegen unerfahrene Angreiferinnen oder Angreifer, während der Sicherheitslevel 4 die maximale Sicherheit erreichen soll und so z. B. professionelle Cyberkriminelle abhält. Je höher der Sicherheitslevel, desto mehr Anforderungen werden vom Standard gestellt und desto teurer wird die Umsetzung der entsprechenden Cybersicherheitsmaßnahmen. Damit nicht mehr Geld ausgegeben wird als notwendig, sollten sich Organisationen deshalb zunächst für einen angemessenen Sicherheitslevel entscheiden.



Beispiel

Das Steuerprogramm einer wichtigen SPS muss regelmäßig angepasst werden. Die SPS soll den Sicherheitslevel 3 erfüllen, was ein Einloggen der Benutzer zwingend erforderlich macht.

Wenn bei der Planung der Anlage schon klar ist, dass Sicherheitslevel 3 erreicht werden soll, kann von einem Hersteller, der seine Produkte ebenfalls nach IEC 62 443 ausrichtet, eine SPS verbaut werden, die Sicherheitslevel 3 erfüllt. Somit ist auch ohne Detailkenntnis der SPS klar, dass die Möglichkeit zum Einloggen vorhanden sein muss.

Sollte die Möglichkeit bestehen, in Zukunft einen höheren Sicherheitslevel zu erreichen, kann schon bei der Planung eine entsprechende SPS vorgesehen werden.

14.5.3 Risikobeurteilung

Risiken spielen im Cybersicherheitsumfeld eine große Rolle. Es lohnt sich nicht, viel Geld für den Schutz eines Systems auszugeben, wenn Angriffe extrem unwahrscheinlich sind oder der Ausfall dieses Systems völlig belanglos ist. Deswegen werden Maßnahmen gemäß IEC 62 443 nicht pauschal vorgeschlagen, sondern es wird zunächst eine organisationsspezifische Risikobeurteilung gefordert, die als Grundlage für die Entwicklung eines Risikobehandlungsplans (die sinnvollerweise zu ergreifenden Maßnahmen) dient. Ohne eine fundierte Risikobeurteilung (bestehend aus Identifizierung, Analyse und Bewertung der Risiken) kann Cybersicherheit in einer Organisation nicht angemessen aufgebaut und wirksam betrieben werden.

Um eine im Standard beschriebene Grundtechnik (die Zonierung, vgl. Abschnitt 14.5.5) einzuführen, müssen die Risiken der in den Zonen vorhandenen Systeme bewertet worden sein. Damit der Aufwand in Grenzen gehalten wird, empfiehlt der IEC 62 443, zunächst eine High-Level-Risikobeurteilung durchzuführen, die in späteren Iterationen durch eine detaillierte Risikobeurteilung ergänzt bzw. ersetzt werden soll (vgl. High-Level bzw. Detailed Cybersecurity Risk Assessment, ISA-e 2016).

**Beispiel**

An einem Produktionsprozess sind vier Teilanlagen beteiligt. Drei dieser Anlagen produzieren Teile, die von der vierten Anlage zum Endprodukt zusammengesetzt werden. Die Teile der Teilanlage 1 und 2 können auch kurzfristig über einen Zulieferer zugekauft werden, während die Teile der Teilanlage 3 ausschließlich selbst gefertigt werden können.

Bei einer High-Level-Risikourteilung wird das Risiko der dritten Teilanlage höher bewertet als von den Anlagen 1 und 2.

Aufgrund dieser Beurteilung sollen Zonen eingerichtet werden, eine Zone mit den Teilanlagen 1 und 2, eine Zone mit der Teilanlage 3 und eine Zone mit der Endmontage.

14.5.4 Defense in Depth

Um eine industrielle Anlage oder einen Gebäudekomplex gut gegen einen Angriff zu schützen, ist es vorteilhaft, mehr als eine Sicherheitsmaßnahme einzusetzen. Genau das macht Defense in Depth (ISA-c 2016). Der koordinierte Einsatz unterschiedlicher Sicherheitsmaßnahmen erhöht den Schutz erheblich, denn sollte eine Maßnahme ausfallen oder von Angreiferinnen oder Angreifern überwunden werden, ist immer noch ein Schutz da. Die Sicherheitsmaßnahmen können dabei auf unterschiedlichen Schichten angesiedelt sein.

**Beispiel**

Um einen SCADA-Server einer Industrieanlage zu schützen, werden folgende Sicherheitsmaßnahmen verwendet.

1. Der Server steht in einem abgeschlossenen Raum (physische Schicht).
2. Der Server ist durch eine Firewall vom Internet und von dem IT-Firmennetz getrennt (Kommunikationsschicht).
3. Im Netzwerk des Servers läuft ein sogenanntes Intrusion Detection System, das erkennt, wenn ein Angriff gegen den Server durchgeführt wird (Netzwerkschicht).
4. Um auf dem Server arbeiten zu können, muss man sich einloggen (Betriebssystemschicht).
5. Um ein Steuerprogramm auf dem SCADA-Server ausführen zu können, benötigt der eingeloggte Benutzer besondere Rechte (Betriebssystemschicht).
6. Auf dem Server läuft ein Anti-Virusprogramm, das den Einsatz von Schadsoftware verhindern soll (Betriebssystemschicht).
7. Auf dem Server läuft eine Firewall, die die Kommunikation mit Systemen im gleichen Netz prüft (Betriebssystemschicht).

Wenn eine Angreiferin oder ein Angreifer aus dem Internet diesen Server angreifen und manipulieren will, muss sie/er viele unterschiedliche Hürden überwinden.

Aber auch durch Defense in Depth kann keine hundertprozentige Sicherheit garantiert werden. Deshalb ist es wichtig, auch auf den Fall eines erfolgreichen Angriffs gut vorbereitet zu sein. Helfen können dabei die Log-Dateien der unterschiedlichen Defense in Depth-Systeme, die zur Angriffsanalyse (Forensik) eingesetzt werden können. Dabei muss das eigentliche Ziel des Angriffs noch gar nicht erreicht worden sein. Schon in den übergeordneten Schichten kann ein Angriff anhand von Log-Einträgen erkannt und es können weitere Gegenmaßnahmen eingeleitet werden.

14.5.5 Zonierung

Ein Angriff gegen ein bestimmtes System besteht aus unterschiedlichen Schritten. In der Regel wird das eigentliche Ziel nicht direkt angegriffen, da die Täter keinen direkten Zugang zum System haben, weil es sich z. B. hinter der Firmenfirewall befindet, welche sämtliche Zugriffe auf das System blockiert. Deshalb konzentrieren sich Cyberkriminelle zunächst auf die Angriffswege, welche die Firewall zulässt. In der Regel sind dies E-Mails und Webverkehr. Schafft es eine Angreiferin oder ein Angreifer z. B. mittels einer Schadsoftware-E-Mail, einen Mitarbeiter-PC zu infizieren, so kontrolliert sie bzw. er nun ein System hinter der Firewall und kann von dort aus weitere Systeme im gleichen lokalen Datennetz direkt angreifen (sog. Lateral Movement). Gäbe es hingegen eine weitere Trennung der Netze (üblicherweise durch interne Firewalls), so müssten die Täter erst diese zusätzliche Hürde überwinden, um dahinterliegende Systeme angreifen zu können. Sprich: Eine interne Zonierung von Netzen mittels Firewalls macht Angreiferinnen und Angreifern das Leben schwer und kann insbesondere kritische Systeme zusätzlich schützen.

Daher fordert der Standard IEC 62 443, Zonen zu bilden (vgl. Establishing Zones and Conduits, ISA-e 2016). Innerhalb einer Zone sollen sich nur Systeme befinden, die direkt miteinander kommunizieren müssen oder ein ähnliches Risiko nach einer erfolgreichen Kompromittierung darstellen. Die trennende Firewall kann dabei den Datenverkehr in die Zone hinein und aus der Zone heraus kontrollieren und gegebenenfalls einschränken. Je besser die Trennung zwischen den Systemen ist, desto kleiner ist das Risiko eines Angriffs auf dieses System von außerhalb der Zone.



Beispiel 1

Bei einer Produktionsanlage für Stückgüter wird eine optische Qualitätskontrolle durchgeführt. Eine Kamera macht Bilder der produzierten Stücke und eine Bildverarbeitungs-Software beurteilt die Qualität. Bei Nichterreichen der vorgegebenen Qualitätsstufe wird über eine direkte Rückmeldung an die Produktionsanlage der Ausschuss des Stücks veranlasst.

Die Qualitätskontrollsoftware läuft auf einem Server, der im Office-IT-Netzwerk angesiedelt ist. Damit hat er auch Zugang zum Internet oder kann von Arbeitsstationen aus dem Büro erreicht werden. Durch eine Manipulation könnten einwandfreie Produkte aussortiert oder fehlerhafte Produkte übernommen werden. Somit stellen Angriffe gegen diesen Server ein erhöhtes Risiko dar.

Würden der Server und die Produktionsanlage in einer eigene (Netz-)Zone liegen, die vom übrigen Netz durch eine Firewall getrennt wäre, könnten Zugriffe weitestgehend abgeblockt werden. Ein Angreifer hätte es deutlich schwerer.

Beispiel 2

Ein Unternehmen mit mehreren Standorten möchte die Gebäudesteuerung zentral automatisieren. Neben Licht, Heizung und Fenstern sollen auch die Schranken am Eingang zum Gelände der Standorte über Chipkarten, die von einem zentralen Server ausgewertet werden, mit einbezogen werden. Um kein eigenes Netz für diese Steuerungen aufbauen zu müssen, wird die vorhandene Office-IT-Netzwerkinfrastruktur verwendet.

Durch die Integration der Schrankensteuerung in das Office-IT-Netz ergibt sich ein Einfallstor, über das Angreiferinnen und Angreifer direkt kritische Office-IT-Systeme angreifen können. So reicht beispielsweise der Anschluss eines kleinen Netzwerkadapters an das Schrankensystem, um Tätern einen direkten Zugriff auf das interne Office-IT-Netz zu ermöglichen.

Wären Schrankensystem, interne Gebäudetechnik und Office-IT in unterschiedlichen Zonen untergebracht, wären Angriffe ungleich schwieriger.

Die Einteilung der Zonen erfolgt zunächst auf Basis einer High-Level-Risikobeurteilung. Mittels einer detaillierten Risikobeurteilung wird die Wahl und Einteilung der Zonen danach verifiziert und gemäß den neuen Erkenntnissen angepasst (vgl. Abschnitt 14.5.3).

14.5.6 Patchmanagement

Patches werden installiert, um Fehler zu beheben, Sicherheitsprobleme zu lösen oder den Betrieb eines Softwaresystems zu verbessern. Obwohl es einfach klingt, ist das Patchmanagement kein einfacher Prozess. Und das Patchen ist im industriellen und Gebäudeumfeld noch deutlich schwieriger als in der IT. Das hat mehrere Gründe:

- Oft muss die gesamte Produktionsanlage gestoppt werden, um einen Patch einzupflegen.
- Patchen kann die Verfügbarkeit, Bedienbarkeit und Sicherheit der SCADA/ICS-Systeme beeinflussen.
- Patchen benötigt Personal mit speziellem Wissen.
- Patches werden eventuell vom Hersteller nicht erlaubt.
- Es sind keine Patches vorhanden.

Bisher wurde das Patchen im Automatisierungsbereich eher stiefmütterlich behandelt. So gibt es oft keine konkrete Richtlinie zum Patchen, und das Patchen ist dem Anlagenbetreiber selbst überlassen. Da der Betreiber häufig genügend andere Aufgaben hat und Patchen zudem einen Produktionsstopp bzw. andere anschließende Probleme verursachen kann, ist es auf den ersten Blick lohnender, nach dem Motto „Never change a running system“ zu handeln und das Patchen zu vernachlässigen. Dass sich dies im Fall eines Cyberangriffs ins Gegenteil wandeln kann, wird dabei übersehen (vgl. Abschnitt 14.3.4).



Hinweis

Patchmanagement wird in allen Standards und Best Practices des industriellen Umfelds angesprochen und gehört nicht zu den „Kann“-Optionen, sondern ist immer ein „Muss“.

Auch der Standard IEC 62443 beschäftigt sich ausführlich mit Patchen und Patchmanagement (ISA-f 2015). Bild 14.3 zeigt den dort vorgeschlagenen Patchmanagement-Prozess.

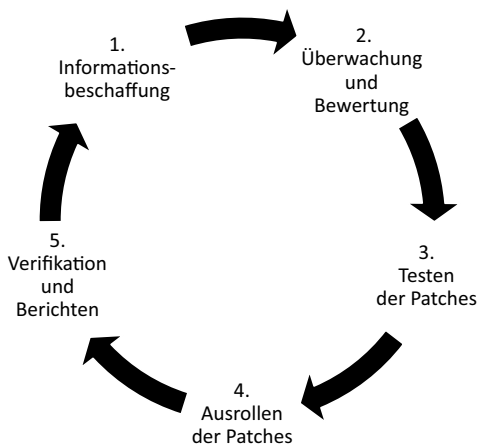


Bild 14.3

Phasen des Patchmanagement-Prozesses (nach ISA-f 2015)

Die Phasen werden im Folgenden kurz erläutert; für den detaillierten Prozess wird auf den Standard verwiesen.

1. Es werden – möglichst automatisiert – alle Informationen gesammelt, die für das Patchen relevant sind. Dazu gehören eine Inventarliste der verwendeten Hardware und Software inklusive verschachtelter Komponenten (z.B. verwendete Software-Bibliotheken) sowie Informationen über Lieferanten (z.B. Hersteller oder Integratoren) der Systeme.

2. Hersteller, Integratoren und Betreiber beobachten den Status ihrer inventarisierten Komponenten hinsichtlich Schwachstellen und geeigneten Gegenmaßnahmen (Patches oder Workarounds). Auf Basis einer Risikobeurteilung wird entschieden, inwieweit Patches für den weiteren Installationsprozess (Testen und Ausrollen) ausgewählt werden.
3. Die gewählten Patches werden zunächst getestet, damit die Installation reibungslos verläuft und die Systeme danach sofort wieder einsatzbereit sind. Das Ausrollen wird geplant, und für eventuell auftretende Probleme werden Schritte zum schnellen Rückgängigmachen der Patches definiert.
4. Das Ausrollen des Patches wird im geplanten Zeitfenster durchgeführt. Während des Ausrollens ist entsprechendes Personal in Bereitschaft, um bei Problemen rasch eingreifen zu können.
5. Nach der Installation des Patches wird geprüft, ob das System so läuft wie vorgesehen. Das Patchen wird zudem in den erforderlichen Dokumenten festgehalten.

**Hinweis**

Ein sogenannter Reaktionsplan kann helfen, den Prozess zu beschleunigen. Die Risikobeurteilung aus Phase 2 legt offen, wie hoch das Risiko für die Anlage mit und ohne Patch letztendlich ist. Je höher das Risiko ohne Patch und je wirksamer der Patch, umso schneller sollte ein Patch ausgerollt werden. Hier kann ein stufenweiser Reaktionsplan helfen, der festlegt, bei welchem Risikolevel Patches wie schnell ausgerollt werden müssen. Sprich: Ein sehr hohes Risiko rechtfertigt durchaus einen ungeplanten Stopp der Anlage und ein weniger intensives Testen des Patches. Bei geringem Risiko kann hingegen bis zum nächsten Wartungsfenster gewartet werden und ein ausführliches Testen vorab erfolgen.

14.5.7 Dienstleister

Da Anlagen der Automatisierungs- und Gebäudetechnik heutzutage sehr komplex sind, sind Betreiber auf Dienstleister angewiesen, die ihre Leistungen während der Integration und Instandhaltung einer Anlage anbieten. Zu diesem Zweck erhalten Dienstleister Zugriff auf die Anlagen (z. B. per Fernzugriff oder lokal), weshalb ein besonderes Augenmerk auf die damit verbundene Cybersicherheit gelegt werden muss. Im Standard IEC 62443 beschäftigt sich ein Teil ausschließlich mit Dienstleistern (vgl. ISA-f 2017). Hier wird umfangreich beschrieben, welche Sicherheitsanforderungen an den Dienstleister gestellt werden müssen, um die Gesamtsicherheit einer Automatisierungslösung nicht zu gefährden.

**Beispiel**

Sie setzen in ihrem Produktionsumfeld Defense in Depth ein, und jede Produktionsstraße liegt in einer eigenen geschützten Zone. Der physische Zugang zur Anlage wird genau kontrolliert, und eine Verbindung zum Internet wird über verschiedene technische Maßnahmen geregelt.

Das alles ist nutzlos, wenn ein Dienstleister Zutritt zu einer Anlage bekommt, sich mit seinem Laptop verbinden darf und auf diesem Laptop eine Schadsoftware läuft.

Das Gleiche gilt, wenn es einen Fernzugriff des Dienstleisters gibt, der nach einem Login eine verschlüsselte Verbindung aufbaut, aber der Rechner, von dem aus die Fernwartung läuft, schon kompromittiert ist und von Cyberkriminellen kontrolliert wird.

14.6 Zusammenfassung und Fazit

Es bleibt festzuhalten, dass sich Automatisierungslösungen in Produktions-, Fahrzeug- und Gebäudetechnik durch zunehmende Vernetzung und Digitalisierung verändern. Dies bringt eine erhöhte Angriffsfläche mit sich, welche von Cyberkriminellen ausgenutzt werden kann (und wird), um Unternehmen zum Teil existenziellen Schaden zuzufügen. Aufgrund der spezifischen Eigenschaften der Automatisierungstechnik können Cybersicherheitsansätze der IT nicht 1:1 übernommen werden, sondern es sind spezifische Lösungen erforderlich. Hierzu gibt es zum einen Standards (wie die Reihe ISA/IEC 62 443 oder ISO/SAE 21 434), die Unternehmen und anderen Organisationen dabei helfen können, ihre Anlagen und Systeme widerstandsfähig zu machen und auch bei Angriffen richtig zu reagieren. Zum anderen sind aber gerade für die Umsetzung solcher Standards, für die Schulung von Mitarbeitern und für cybersichere Technik Fachleute erforderlich, die entweder intern aufgebaut, rekrutiert oder als Dienstleister hinzugezogen werden müssen.

**Hinweis**

„Das Schlimmste, was eine Leitungsebene heutzutage machen kann, ist, das Problem der Cybersicherheit für den Bereich Automatisierungstechnik zu unterschätzen. Lassen Sie es nicht zu Ausfällen kommen, die die Existenz Ihrer Organisation bedrohen können. Agieren Sie proaktiv, setzen das Thema auf die Tagesordnung und lassen sich von Experten beraten.“ – Prof. Dr. Marko Schuba und Dipl.-Ing. Hans Höfken

Literatur

Ashton, K.: That 'Internet of Things' Thing, RFID Journal, Juni 2009, <https://www.rfidjournal.com/that-internet-of-things-thing>, abgerufen am 20.04.2024.

Bosch: Geschichte – Analog, digital, vernetzt – Bosch Automobilelektronik im Rückblick, <https://www.bosch.com/de/stories/geschichte-der-elektronik/>, abgerufen am 20.04.2024.

Borgeest, K.: Elektronik in der Fahrzeugtechnik – Hardware, Software, Systeme und Projektmanagement, Springer Vieweg, Wiesbaden, 3. Auflage 2014.

Bradicich, T.: The Intelligent Edge: What It Is, What It's Not, and Why It's Useful, Hewlett Packard Enterprise, November 2018, <https://iiot-world.com/industrial-iot/connected-industry/the-intelligent-edge-what-it-is-what-its-not-and-why-its-useful/>, abgerufen am 20.04.2024.

BSI-a: BSI, Informationssicherheit mit System, Der IT-Grundschutz des BSI, Artikelnummer BSI-Bro20/333, November 2020.

BSI-b: BSI, ICS Security Kompendium, Version 1.23, 2012.

BSI-c: BSI, Allgemeine Empfehlungen, https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Informationen-und-Empfehlungen/Empfehlungen-nach-Angriffszielen/Industrielle-Steuerungs-und-Automatisierungssysteme/Allgemeine-Empfehlungen/allgemeine-empfehlungen_node.html, abgerufen am 20.04.2024.

BSI-d: BSI, Kurzmitteilungen des BSI, https://www.bsi.bund.de/DE/Service-Navi/Presse/Alle-Meldungen-News/alle-meldungen-news_node.html, abgerufen am 20.04.2024.

BSI-e: BSI, Industrial Control System Security – Top 10 Bedrohungen und Gegenmaßnahmen 2022, BSI-Veröffentlichungen zur Cyber-Sicherheit, Version 1.5, 31.05.2022.

BSI-f: BSI, EMPFEHLUNG: IN DER PRODUKTION – Fernwartung im industriellen Umfeld, BSI Version 2.0, 11.07.2018.

BSI-g: BSI, EMPFEHLUNG: IT IN DER PRODUKTION – BSI-Veröffentlichungen zur Cyber-Sicherheit Industrial Control Security – Innentäter, Version 2.0, 11.07.2018.

Censys: Censys Search Engine, <https://search.censys.io/>, abgerufen am 20.04.2024.

DKE/GK 914: Funktionale Sicherheit elektrischer, elektronischer und programmierbarer elektronischer Systeme (E, E, PES) zum Schutz von Personen und Umwelt, <https://www.dke.de/de/ueber-uns/dke-organisation-auftrag/dke-fachbereiche/dke-gremium?id=2000346&type=dke%7Cgremium>, abgerufen am 20.04.2024.

DKE: IEC 62 443, Die internationale Normenreihe für Cybersecurity in der Industrieautomatisierung, Juni 2020, <https://www.dke.de/de/arbeitsfelder/industry/iec-62443-cybersecurity-industrieautomatisierung>, abgerufen am 20.04.2024.

Eberlin, S., B. Hock: Zuverlässigkeit und Verfügbarkeit technischer Systeme. Springer Vieweg, 2014.

ISA-a: ISA99, Industrial Automation and Control Systems Security, <https://www.isa.org/standards-and-publications/isa-standards/isa-standards-committees/isa99>, abgerufen am 20.04.2024.

ISA-b: ISA, ISA-62 443-2-1, Security for industrial automation and control systems: Industrial automation and control system security management system, November 2015.

ISA-c: ISA, ISA-62 443-1-1, Security for industrial automation and control systems: Models and Concepts, September 2016.

ISA-d: ISA, ISA-TR62 443-3-3, Security for industrial automation and control systems: System security requirements and security levels, Januar 2013.

ISA-e: ISA, ISA-TR62 443-3-2, Security for industrial automation and control systems: Security risk assessment for system design, September 2016.

ISA-f: ISA, ISA-TR62 443-2-3, Security for industrial automation and control systems: Patch management in the IACS environment, August 2015.

ISA-g: ISA, ISA 62 443-2-4, Security program requirements for IACS service providers, August 2017.

ISO-a: ISO/IEC 27 001, Informationstechnik – Sicherheitsverfahren – Informationssicherheitsmanagementsysteme – Anforderungen (ISO/IEC 27 001:2013 einschließlich Cor 1:2014 und Cor 2:2015); Deutsche Fassung EN ISO/IEC 27 001:2017.

ISO-b: ISO/SAE 21434:2021, Surface Vehicle Standard, Road Vehicles – Cybersecurity Engineering, August 2021.

Kagermann, H., W.-D. Lukas, W. Wahlster: *Industrie 4.0: Mit dem Internet der Dinge auf dem Weg zur 4. industriellen Revolution.*, VDI-Nachrichten, April 2011.

Karbach, A.: Gebäudeautomation und technisches Gebäudemanagement. In: Digitale Gebäudeautomation, Springer, Berlin/Heidelberg, 2004.

NIST-a: NIST, Framework for Improving Critical Infrastructure Cybersecurity, Version 1.1, April 2018.

NIST-b: NIST Special Publication 800-82 Revision 3 – Guide to Operational Technology (OT) Security, National Institute of Standards and Technology, September 2023.

OS: Offensive Security: Exploit Database, <https://www.exploit-db.com/>, abgerufen am 20.04.2024.

SAE International: J3061 Cybersecurity Guidebook for Cyber-Physical Vehicle Systems, January 2016.

Shodan: Search Engine for the Internet of Everything, <https://www.shodan.io/>, abgerufen am 20.04.2024.

Spath, D., O. Ganschar, S. Gerlach, M. Hämmerle, T. Krause, S. Schlund: Produktionsarbeit der Zukunft – Industrie 4.0, Studie des Fraunhofer IAO, 2013.

WEF: World Economic Forum, Industrial Internet of Things: Unleashing the Potential of Connected Products and Services, World Economic Forum Industry Agenda, 2015, http://www3.weforum.org/docs/WEFUSA_IndustrialInternet_Report2015.pdf, abgerufen am 20.04.2024.

Zander, H.-J.: Steuerung und Regelung als Grundfunktionen der Automatisierung, In: Steuerung ereignisdiskreter Prozesse. Neuartige Methoden zur Prozessbeschreibung und zum Entwurf von Steuerungsalgorithmen, Springer Vieweg, Wiesbaden, 2015.

**In diesem Beitrag erfahren Sie,**

- was Edge Computing bedeutet und wie es im Internet der Dinge eingesetzt werden kann,
- welche Möglichkeiten sich damit für bestehende und neue Anwendungsfälle eröffnen,
- welche Sicherheitsrisiken sich dadurch auftun und zu beachten sind und
- wie sichere Systeme für das Edge Computing entwickelt werden können, insbesondere welche Technologien dafür geeignet und bei der eigenen IT-Strategie zu berücksichtigen sind.

15.1 Einleitung

In der Welt der Informatik ist es interessant zu beobachten, wie sich Trends entwickeln, neue Paradigmen entstehen und alte ablösen. Nicht selten kommt es vor, dass sich Dinge wiederholen und als veraltet geglaubte Ansätze plötzlich wieder unter neuen Gegebenheiten dann doch als die bessere Alternative erweisen oder zumindest als Ergänzung erneut zum Einsatz kommen.

Aktuell lässt sich dieses Phänomen mit der wachsenden Bedeutung des Cloud Computing und insbesondere im „Internet der Dinge“ (engl.: Internet of Things oder kurz IoT) beobachten. Im Laufe der Geschichte der Computer gab es bereits mehrfach den Wechsel von zentralisiertem bzw. verteiltem Rechnen. Angefangen von den großen Mainframes (zentral) über den Siegeszug des Personal Computers (verteilt) hin zum Cloud Computing (zentral). Die Vorteile des Cloud Computing sind mittlerweile vielen Firmen und Organisationen klar geworden. Es gibt einen ungebrochenen Trend der

Änderung von IT-Infrastrukturen vom eigenen, selbst betriebenen Rechenzentrum hin zu Cloudanwendungen. Die Einsatzfelder von Cloud Computing sind dabei vielfältig — von Infrastruktur (virtuellen Maschinen und softwaredefinierten Netzwerken) über Plattformen (fertig konfigurierte Server) hin zu einzelnen Software-Anwendungen, wie beispielsweise Textverarbeitung oder Tabellenkalkulation in der Cloud, die einfach über einen Webbrowser genutzt werden können.

Cloud Computing ist auch wesentlicher Bestandteil vieler IoT-Architekturen. Kommerzielle Smart Home Systeme, wie Licht- und Heizungssteuerung für die Wohnung, laufen in vielen Fällen über einen Server des Herstellers oder über allgemeine Cloudplattformen. Beispiele sind HomeKit von Apple, Amazons Sprachassistent Alexa oder Samsungs SmartThings.

Mittlerweile hat es sich jedoch in einigen Anwendungsfällen gezeigt, dass eine Übertragung der Daten von IoT-Geräten in die Cloud, die Verarbeitung der Daten in der Cloud und dann die Übermittlung von daraus resultierenden Entscheidungen zurück an IoT- oder andere Endgeräte nicht immer optimal ist.



Beispiel: selbstfahrende Automobile

Würden Sie darauf warten wollen, dass Ihr Auto ein von der Kamera aufgenommenes Bild an den Cloud-Server schickt, dort analysieren lässt und dann die Nachricht zurückschickt, dass da ein Kind auf der Straße zu sehen ist und dass das Auto besser bremsen sollte? Dank technischer Innovationen wie hochskalierender Prozessoren und optimierter Software sowie 5G-Mobilfunk-Netzen sind eine Berechnung und Übertragung grundsätzlich zeitnah machbar. Aber haben Sie nicht auch da das Gefühl, dass das Auto diese Analyse und Entscheidung besser selbst machen sollte? Eventuell ist ja gerade die Mobilfunkverbindung schlecht.

Edge Computing bezeichnet im Allgemeinen das Paradigma, wenn eine Datenverarbeitung näher an der eigentlichen Datenquelle (also an der „Edge“ vom Netzwerk) stattfindet statt in der Cloud. Im obigen Beispiel trifft das zu, wenn das selbstfahrende Auto das Kamerabild selbst auswertet, die Gefahrensituation selbstständig analysiert und ein Bremsmanöver einleitet.

Natürlich gibt es Szenarien, wo eine Bearbeitung in der Cloud sinnvoller ist. Viele Sprachassistenten wie Siri und Alexa schicken die aufgenommenen Sprachbefehle an ihre Cloud-Server und das Ergebnis zurück zum Endgerät. Sprachen sind oft zu komplex, um sie auf heutigen Endgeräten, vor allem in allen Sprachvarianten, vollständig zu analysieren.

Dies sind nur zwei Beispiele, wo man sich zwischen Cloud Computing oder Edge Computing entscheiden muss. Die Vielfalt der IoT-Szenarien lässt erahnen, dass es nicht immer so einfach ist. Normalerweise muss genau analysiert werden, was wo am besten zu berechnen ist. Oft ist auch ein Mix von beiden Paradigmen sinnvoll. Im Kontext von IoT haben sich neben den eigentlichen Paradigmen auch konkrete Technologien entwickelt, um sowohl das Cloud als auch das Edge Computing zu erleichtern.

Dieses Kapitel soll genau für diese und ähnliche Szenarien eine Entscheidungshilfe geben, wann Edge Computing im Internet der Dinge sinnvoll sein kann. Dabei wollen wir besonders darauf eingehen, welche treibenden Kräfte Edge Computing nötig machen und welche Chancen sich durch den Einsatz von Edge Computing für IoT ergeben können. Es gibt allerdings auch Sicherheitsrisiken, die durch den Einsatz von Edge Computing neu hinzukommen können, die es ebenfalls zu berücksichtigen gilt. Diese werden wir ebenfalls beleuchten. Schließlich werfen wir einen Blick darauf, wie sichere Systeme für das Edge Computing entwickelt werden können und welche speziellen Technologien dazu zur Verfügung stehen.

15.2 Was ist Edge Computing?

In den folgenden Abschnitten betrachten wir, was sich genau hinter dem Begriff Edge Computing verbirgt. Zunächst beschreiben wir ein Grundmodell, wie das Internet der Dinge aufgebaut ist. Dabei nimmt das Cloud Computing (im wahrsten Sinne des Wortes) eine zentrale Rolle ein. Dann beschreiben wir, wie man vom Cloud zum Edge Computing kommt. Schließlich analysieren wir die einzelnen Impulsgeber, wann Edge Computing im Kontext von IoT sinnvoll oder gar notwendig sein kann.

15.2.1 Das Internet der Dinge

Die „Dinge“ im Internet der Dinge können vielfältiger Art sein. Dies reicht von eher klassischen Computern, z. B. ein Raspberry Pi Minicomputer, über Steueranlagen für die Industrie oder das intelligente Zuhause bis hin zu autonomen Systemen wie Robotern oder das selbstfahrende Auto.

Alle diese Dinge haben dabei eines gemeinsam: Sie sind nicht nur ein Computer im klassischen Sinne, sondern auch noch mit mindestens einem Sensor oder einem Aktuator oder beidem ausgestattet. Sensoren liefern Daten aus der physischen Welt, z. B. Temperatur oder ein Kamerabild. Aktuatoren können etwas in der physischen Welt verändern, z. B. ein Ventil öffnen oder ein Relay schalten.

Wenn diese Dinge über das Internet miteinander bzw. mit zentralen Instanzen zur Entscheidungsfindung verbunden werden, dann erhält man das „Internet der Dinge“, kurz IoT. Üblicherweise werden die Daten von Sensoren an eine zentrale Stelle (in der Cloud) übertragen, dort gespeichert und verarbeitet. Verbindungen von IoT-Geräten zur Cloud können direkt sein (z. B. über Mobilfunk zum Cloud-Server) oder indirekt über einen Hub oder Gateway. Im indirekten Fall werden IoT-Geräte per Kabel oder mit Nahbereichs-Funkverbindungen (z. B. Bluetooth Low Energy, ZigBee) mit dem Gateway verbunden und dann über eine herkömmliche Internetverbindung weitergeleitet.

Wenn die Daten in der zentralen Stelle ausgewertet wurden und eine Entscheidungsfindung stattgefunden hat (z. B. Temperatursensor meldet Werte, die als zu niedrig definiert sind), werden Informationen über auszuführende Aktionen an die mit Aktuatoren ausgestatteten IoT-Geräte gesandt (z. B. Heizungsventil aufdrehen; siehe Bild 15.1).

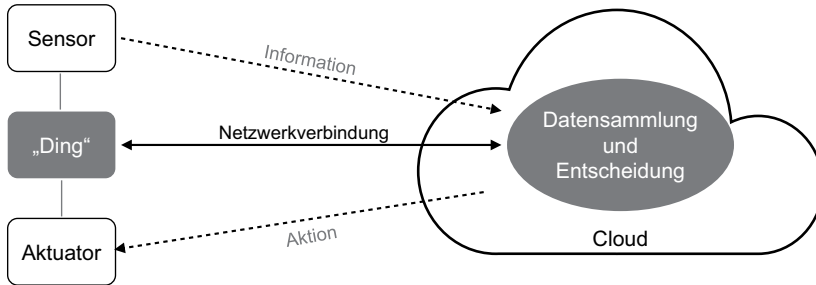


Bild 15.1 Grundmodell Internet der Dinge (IoT)



Hinweis

An der Anzahl und Menge an Datenverarbeitungen im IoT-Umfeld lassen sich Trends ablesen, dass diese immer größer und mehr werden. In einer IDC-Studie von 2023 (IDC 2023) wurde geschätzt, dass die globale Datensphäre exponentiell ansteigen und im Jahr 2027 über 260 Zettabyte umfassen wird. Man geht davon aus, dass 20 % dieser Daten als kritisch einzustufen sind für unser tägliches Leben (z. B. Energie, Gesundheit). Im Durchschnitt wird jede Person, die mit IoT-Geräten interagiert, dies fast 4800-mal am Tag tun. Dies ist eine enorme Datenmenge. Im Zuge der fortschreitenden Digitalisierung weiterer Industriebereiche lässt sich erahnen, dass dieser Trend so schnell kein Ende finden wird.

Je mehr dieser Zyklus von Sensorinformation zu Entscheidungsfindung zu Aktuator-Steuerung von der gesamten Datenübermittlung in die und von der Cloud abhängt, desto schwieriger könnte es für einige Anwendungsfälle werden. Diese Problematik wurde jedoch schon frühzeitig erkannt, und so haben sich beispielsweise Industriekonsortien wie OpenFog gegründet, welches mittlerweile im Industrial IoT Consortium aufgegangen ist (Industrial IoT Consortium 2019), um Referenzarchitekturen und Standards zu entwerfen, die Cloud Computing um weitere Paradigmen ergänzen – wie Edge Computing.

15.2.2 Von der Cloud zur Edge

Wie bereits in der Einleitung erwähnt, bedeutet Edge Computing allgemein, dass die Datenverarbeitung (und gegebenenfalls Datenspeicherung) näher an die Quelle der Daten gebracht wird. Man kann sich das Ganze wie ein Spinnennetz vorstellen: In der

Mitte ist die Cloud, das zentrale Netzwerk mit der Datenspeicherung und -verarbeitung. Dann gibt es viele Verbindungen in alle Richtungen und Zwischenstationen (z. B. Netzwerkknoten, Mobilfunk-Infrastruktur). Am äußeren Rand (der „Edge“) befinden sich die ganzen Endgeräte: Personal Computer, Smartphones und natürlich die ganzen IoT-Geräte.

Wenn entscheidende Datenverarbeitung direkt in diesen Edge-Geräten stattfindet, ohne vorher die Daten in die Cloud zu schicken und auf eine Antwort zu warten, dann ist das Edge Computing. Nun gibt es keine formelle, klar festgeschriebene Definition, was noch „Edge“ ist und was nicht. Da findet sich in der Literatur und auf entsprechenden Internetseiten ein gewisser Spielraum. So zählen in vielen Fällen auch noch Router, Gateways und ähnliche Zwischenstationen zum Edge Computing, wenn dort die Datenverarbeitung der mit diesen Geräten verbundenen IoT-Sensoren stattfindet.



Beispiel: Industrie 4.0

In einer Fabrik (siehe Bild 15.2) sind mehrere Sensoren (Licht, Temperatur) und Aktuatoren (Maschine, Roboterarm) über ein IoT-Gateway mit der Cloud verbunden. Das IoT-Gateway ist dabei so gestaltet, dass es bestimmte Datenanalysen der angeschlossenen Sensoren direkt verarbeiten kann und entsprechende Steuerbefehle an die Aktuatoren direkt ausliefert. Dafür müssen die Daten nicht an eine zentrale Instanz in der Cloud geschickt werden. Die lokale Verarbeitung mittels Edge Computing auf dem IoT-Gateway kann somit schneller und datensparsamer erfolgen. Gleichzeitig können bestimmte Daten, z. B. ausgewertete und aggregierte Daten, an eine zentrale Instanz in der Cloud geschickt werden, um dort beispielsweise Vergleichsanalysen von unterschiedlichen Fabrikstandorten zusammenzuführen.

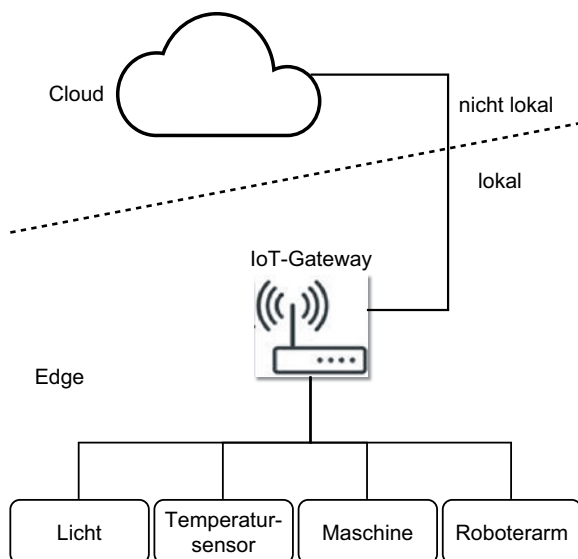


Bild 15.2

Beispiel-Architektur
für smarte Fabrik

Was jeweils in der Cloud oder per Edge Computing gespeichert und verarbeitet wird, ist die entscheidende Aufgabe für die IT-Architektur des Gesamtsystems. Dies lässt sich nicht pauschal sagen, sondern hängt vom jeweiligen Anwendungsfall und von den spezifischen Anforderungen in der eigenen Organisation ab. Es gibt jedoch eine Reihe von Impulsgebern, die bei der Entscheidungsfindung und der Planung der IT-Architektur helfen können.

15.2.3 Impulsgeber für IoT Edge Computing

Die folgenden Kriterien können treibende Kräfte sein, warum für bestimmte Anwendungsfälle Edge Computing für eine lokale Entscheidungsfindung in Betracht zu ziehen ist.

Latenz

Einige Szenarien erfordern eine sehr schnelle Entscheidungsfindung. Unter Umständen kann auf eine Analyse und Entscheidung in der Cloud nicht gewartet werden. Wenn eine zu hohe Latenz zwischen Sensor-Datenübermittlung und Erhalt des Aktuator-Befehls nicht akzeptabel ist, sollte der Prozess eher lokal ablaufen. Beispiel: autonom fahrende Automobile.

Konnektivität

Situationen, in denen eine Netzwerkverbindung zur Cloud nicht immer zuverlässig gegeben ist, kann eine lokale Entscheidungsfindung notwendig machen. Beispiel: Einsatz von mobilen IoT-Geräten, z. B. Maschinen in der Landwirtschaft, in Gegenden mit schlechter Mobilfunk-Netzabdeckung.

Kosten

Die kontinuierliche Datenübermittlung von IoT-Geräten zur Cloud und zurück kann kostspielig sein. Zum einen können dies direkte Kosten sein, z. B. die Nutzung von Mobilfunkverbindungen in teuren Tarifen bei hohen Datenmengen. Zum anderen kann es Bandbreite kosten und damit den Datenverkehr anderer Geräte beeinträchtigen. Es gilt dabei abzuwägen, ob wirklich alle Daten in die Cloud übertragen werden müssen oder ob eine lokale Analyse bzw. Entscheidungsfindung stattfinden kann. Bei anschließender Übertragung nur der Ergebnisse in die Cloud können so Datenübertragungen eingespart werden.

Energieverbrauch

Je nach eingesetzter Hardware-Plattform der IoT-Geräte kann eine lokale Datenverarbeitung zur Entscheidungsfindung energieeffizienter sein als die Übertragung und

der Empfang von Daten, insbesondere über Funkmodule. Dies hängt natürlich von der eingesetzten Technologie ab (z. B. Bluetooth Low Energy verbraucht weniger Energie als eine herkömmliche Bluetooth-Verbindung).

Datenschutz

Letztendlich kann auch Datenschutz eine entscheidende Rolle spielen. Schließlich gilt es, bei der Übertragung von lokalen Daten eines IoT-Gerätes in die Cloud eine Reihe von Faktoren zu berücksichtigen, allein rechtlicher Natur. Wo werden die Daten in der Cloud verarbeitet? Wer hat Zugriff darauf? In welcher geografischen Zone befindet sich das Cloudrechenzentrum bzw. in welchem Land hat der Cloudanbieter seinen Sitz? Selbst wenn die rechtlichen Aspekte geregelt sind, kann die öffentliche Reputation aus Kundensicht durch Datenverarbeitung in der Cloud negativ beeinflusst werden. Wenn dagegen personenbezogene Daten direkt auf den IoT-Endgeräten analysiert werden können, kann dies ein Vorteil sein. Beispiel: Gesichtserkennung von Fotos auf dem Smartphone.



Hinweis

Achten Sie bei der Planung von IoT-Architekturen auf die oben genannten Kriterien. Wenn Sie diese in Ihren Anwendungsfällen entdecken, kann dies ein Hinweis darauf sein, dass eine lokale Entscheidungsfindung mittels Edge Computing eingesetzt werden sollte. Es gilt, diese Fälle im Detail zu analysieren. Es kann durchaus auch sinnvoll sein, eine Art „Mischbetrieb“ zu fahren, d. h., bestimmte Daten werden für definierte Anwendungsfälle lokal bearbeitet (Edge Computing) und andere Daten wiederum in der Cloud. Ein gutes Beispiel dafür ist die Fotobibliothek auf Apples iPhone: Die Fotos können in der Apple iCloud synchronisiert werden (als Backup und um auf anderen Geräten ebenfalls darauf zuzugreifen), die Gesichtserkennung aus seinen persönlichen Kontakten erfolgt aber lokal auf dem iPhone, nicht in der Cloud (Apple 2024).

15.3 Chancen und Sicherheitsrisiken

Wir betrachten in den folgenden Abschnitten zunächst, welche Chancen sich mit Edge Computing ergeben und wie ein generelles Edge-Computing-Modell aussieht. Anschließend gehen wir auf die Sicherheitsrisiken ein, beschreiben ein generisches Bedrohungsmodell und geben eine Übersicht der neuen und bisherigen Herausforderungen für die Sicherheit von IoT Edge Computing.

15.3.1 Eröffnung neuer Möglichkeiten durch IoT Edge Computing

Edge Computing ist als Paradigma vielschichtig und vielseitig, wenn es um die konkrete Realisierung geht. Das hängt zum einen davon ab, um welches „Ding“ es sich handelt und mit welchen Rechen- und Speicherkapazitäten es daher kommt (z. B. Automobil, Smartphone oder kleiner Sensor mit Mikrocontroller). Zum anderen spielen die Anwendungsfälle natürlich eine zentrale Rolle für die Ausgestaltung, von einfacher Datenaufbereitung bis hin zu komplexen Analysen wie Gesichtserkennung.

Es lässt sich ein einfaches Grundmodell für das IoT Edge Computing definieren. Im Allgemeinen hat jedes Ding eine primäre Funktion, die es ausüben soll. Die Kamera soll Fotos oder Videos machen, der Roboterarm soll etwas bewegen, das Gateway soll andere lokale IoT-Geräte mit dem Internet verbinden. Edge Computing bedeutet nun, dass eine weitere Funktion hinzukommt. Diese zweite Funktion läuft zusätzlich zur primären, und sie kann sich im Laufe der Zeit ändern, kann je nach Anforderung durch andere Funktionen ausgetauscht werden. Im Gegensatz dazu bleibt die primäre Funktion üblicherweise über den gesamten Lebenszyklus erhalten. Natürlich kann es für beide Funktionen Software-Updates geben, die Details der Implementierung jederzeit ändern können. Wir betrachten hier für das Modell aber die rein logische Funktion, also die Aufgabe im höheren Sinne.

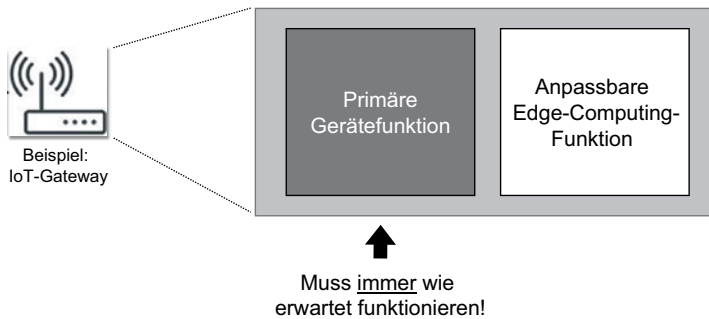


Bild 15.3 Modell des IoT Edge Computings

Bild 15.3 zeigt das Edge-Computing-Modell am Beispiel eines IoT Gateways. Die primäre Gerätefunktion ist die des Gateways, d. h., die Aufgabe besteht darin, Datenpakete anzunehmen und an das richtige Ziel weiterzuleiten. Daten gehen von den IoT-Geräten zur Cloud, und Steuerungsinformationen kommen von der Cloud zurück zu Geräten. Das IoT Gateway stellt dabei zusätzliche Rechenkapazität zur Verfügung, um eine anpassbare Edge-Computing-Funktion ausführen zu können. Dies kann eine einfache Datenkonvertierung sein, um die IoT-spezifischen Datenformate über das Internet transportieren zu können. Dies können aber auch komplexere Datenanalysen sein.

**Beispiel**

Um eine vorausschauende Instandhaltung seiner Fahrstühle zu gewährleisten, ist der Fahrstuhlhersteller Schindler mit Huawei eine Kooperation eingegangen, um in seinen Fahrstühlen Edge Computing Gateways einzubauen. Die Gateways ermöglichen eine lokale Datenanalyse in Echtzeit, um Probleme mit der Latenz und mit der Verarbeitung großer Datenmengen entgegenzutreten. In modernen Fahrstühlen sind eine Reihe von Sensoren eingebaut, die eine Vielzahl von Messwerten liefern. Diese werden in Echtzeit in der Edge-Computing-Funktion des Gateways ausgewertet, um Muster zu erkennen, die auf eine baldige Instandsetzungsarbeit hindeuten. Ergebnisse werden in der Cloud dann zusammengefasst für ein zentralisiertes Management der Fahrstühle und Visualisierung der Zustände. Die Edge-Computing-Funktion lässt sich durch standardisierte Mechanismen wie Applikationscontainer installieren und konfigurieren (CIO-Magazin 2017, Huawei 2024).

**Hinweis**

Entscheidend beim Edge Computing ist, dass die primäre Gerätefunktion zu jeder Zeit wie erwartet funktionieren muss. Denn es ist die primäre Funktion. Was auch immer die Edge-Computing-Funktion bei ihrer Ausführung macht, sie darf die primäre Funktion nicht negativ beeinträchtigen. Es wäre beispielsweise unerwünscht, wenn die Edge-Computing-Funktion Rechenzeit übermäßig beanspruchen würde, sodass die primäre Funktion nicht mehr im erforderlichen Maße reagieren könnte. Eine Edge-Computing-Plattform muss diese zentrale Anforderung berücksichtigen und durch geeignete Technologien und Mechanismen garantieren können. Achten Sie beim Kauf entsprechender Produkte darauf, welche Mechanismen der Hersteller dafür bereitstellt.

Die Umsetzung dieser zentralen Anforderung wird in der Praxis dadurch erschwert, dass die Edge-Computing-Plattform möglichst flexibel und einfach zu programmieren sein soll. Bei der Entwicklung möchte man gerne auf bekannte Programmierumgebungen und Frameworks zurückgreifen. Da sich im Cloudumfeld mittlerweile eine containerbasierte Verteilung von Anwendungen etabliert hat, wird dies auch oft für Edge Computing gefordert — und angeboten (Huawei 2024, Siemens 2024).

Flexibilität im Edge Computing bedeutet ferner, dass die Funktionen nicht nur angepasst und ausgetauscht, sondern auch wiederverwendet werden können. Entwicklungskosten lassen sich schließlich reduzieren, wenn eine zuvor entwickelte Edge-Computing-Funktion für eine Plattform ohne oder nur mit geringen Änderungen auch auf einer anderen Plattform eingesetzt werden kann. Standardisierte Verteilungsmechanismen (z. B. Container) sowie allgemeine Frameworks und Bibliotheken für die Programmierung sind dafür eine Voraussetzung.

Eine weitere interessante Anwendungsmöglichkeit kann sich durch Live-Migration eröffnen: Wie beim Cloud Computing, wo virtuelle Maschinen im laufenden Betrieb

von einer Hardware-Plattform auf eine andere verschoben werden können, lässt sich auch ein ähnlicher Mechanismus beim Edge Computing realisieren (Liguori 2019). Während es beim Cloud Computing um die optimale Ausnutzung der Hardwareressourcen geht, ist beim Edge Computing jedoch die optimale Lokalität der Datenverarbeitung der ausschlaggebende Grund. Wenn sich die Datenquelle von einer Lokalität zur anderen bewegt, kann es sinnvoll sein, die zugehörige Edge-Computing-Funktion ebenfalls zu migrieren, und zwar auf eine Plattform, die wieder nah genug an der Datenquelle ist.

15.3.2 IoT Edge Computing bringt auch neue Sicherheitsrisiken

Wie alle Technologien kommt auch Edge Computing nicht nur mit neuen Chancen, sondern auch mit Risiken für die IT-Sicherheit daher. Direkt ableiten aus dem vorherigen Modell lässt sich das Risiko, dass die Edge-Computing-Funktion das IoT-Gerät derart beeinflusst, dass die primäre Funktion gestört wird. Wir wollen in diesem Abschnitt einen systematischen Blick auf die möglichen Sicherheitsrisiken werfen.

Bedrohungsmodell

Analog zu Bild 15.2 betrachten wir in Bild 15.4 die Bedrohungen, die für ein IoT-Gateway mit Edge Computing entstehen können. Wir orientieren uns dabei an der STRIDE-Methodik (Microsoft 2009).

Spoofing (Identitätsverschleierung): Aus Sicht des Gateways könnte zum einen ein angeschlossenes Gerät seine Identität fälschen und vorgeben, ein legitimes zu sein. Dadurch könnten falsche Daten in die Edge-Computing-Funktion eingehen und das Ergebnis verfälschen. Zum anderen könnte ein aus dem Internet kontaktierender Server vorgeben, das zentrale Cloud-Management für das IoT-Gateway zu sein. Auf diese Weise könnten falsche Konfigurationsdaten oder gar neue, von einem Angreifer kontrollierte Edge-Computing-Funktionen installiert werden.

Tampering (Manipulation): Durch die Ausführung einer Edge-Computing-Funktion könnte (absichtlich oder unabsichtlich) eine unerlaubte Manipulation der Daten geschehen. Dies könnte sowohl die lokale Auswertung als auch die Weitergabe von Ergebnissen in die Cloud beeinträchtigen. Die Edge-Computing-Funktion selbst könnte ebenfalls manipuliert sein, entweder bereits vor der Installation oder im laufenden Betrieb. Letzteres kann durch Ausnutzen einer Schwachstelle im Programmcode der Funktion oder in der Plattform selbst geschehen.

Repudiation (Verleugnung): Werden auf dem Gateway Aktionen protokolliert, könnten diese Logdateien manipuliert oder gelöscht werden, um andere schadhafte Aktivitäten zu verschleiern.

Information Disclosure (Informationsabfluss): Die Edge-Computing-Funktion könnte die Daten, die sie verarbeitet und von den IoT-Geräten erhält, an unberechtigte Dritte über die Netzwerkverbindung des Gateways weiterleiten.

Denial of Service (Verweigerung des Dienstes): Die Edge-Computing-Funktion könnte den gesamten Dienst des Gateways einstellen und keine Daten mehr weiterleiten oder Steuerinformationen aus der Cloud empfangen. Es könnte auch dafür sorgen, dass Steuerinformationen zwar angenommen, aber nicht mehr an die IoT-Geräte weitergeleitet werden. Somit könnte es lange dauern, bis überhaupt ein derartiges Problem erkannt wird.

Elevation of Privilege (Ausweitung der Rechte): Durch die Edge-Computing-Funktion könnte jemand versuchen, sich unerlaubten Zugriff auf das Gateway zu verschaffen. Ein Ausbruch aus der Container-Umgebung der Edge-Computing-Funktion könnte versuchen, Systemprivilegien zu erhalten, um dann die vollständige Kontrolle über das Gateway zu übernehmen.

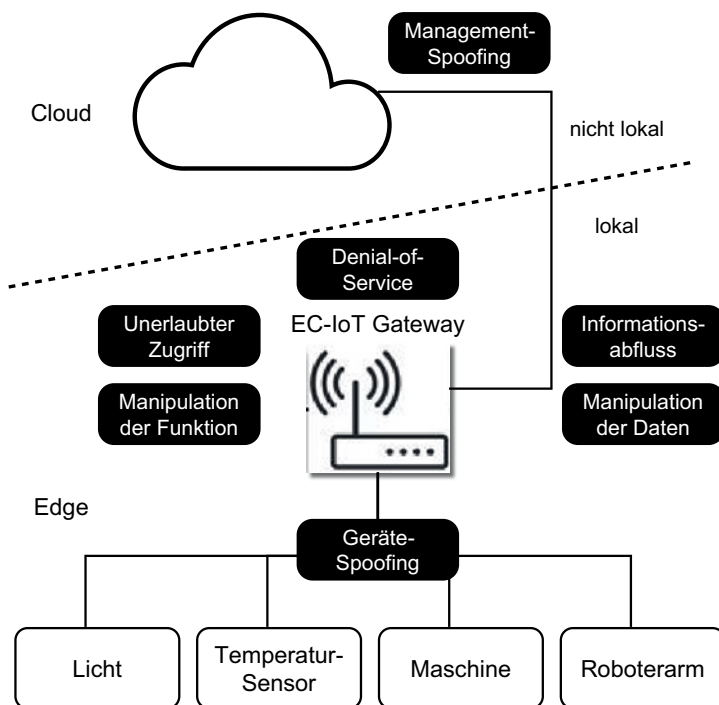


Bild 15.4 Bedrohungsmodell im IoT Edge Computing



Hinweis

Führen Sie beim Entwurf Ihrer IoT-Edge-Computing-Architektur immer eine Bedrohungsmodellierung durch. Methoden wie STRIDE können dabei helfen. Aber selbst wenn man kein Methodenwissen mitbringt, kann jeder durch ein paar einfache Schritte eine Bedrohungsanalyse durchführen. Im Prinzip macht man das bereits, wenn man morgens zur Arbeit fährt und einen Termin hat. Soll ich das Auto nehmen? Welche Strecke, wo könnte Stau sein? Lieber den Zug? Hat der nicht oft Verspätung?

Bedrohungsmodellierung lässt sich in einem Vier-Fragen-Rahmenwerk strukturieren (Shostack 2014):

- 1. Woran arbeiten wir? (Systemmodell in einer Abbildung zeichnen)
- 2. Was kann schiefgehen? (An den einzelnen Elementen und Verbindungen, z. B. nach STRIDE)
- 3. Was wollen wir dagegen tun? (Entscheidung über Maßnahmen oder Risikoakzeptanz)
- 4. Haben wir eine gute Arbeit gemacht? (Begutachtung in qualitativer und quantitativer Hinsicht)

Übersicht der Sicherheitsherausforderungen

Die Herausforderungen für die IT-Sicherheit von IoT Edge Computing lässt sich in zwei Bereiche unterteilen (Tabelle 15.1). Auf der einen Seite gibt es existierende Herausforderungen, wie wir sie bereits aus dem Cloud Computing kennen. Auf der anderen Seite kommen neue, speziell für das IoT-Szenario zutreffende Herausforderungen hinzu.

Tabelle 15.1 Sicherheitsherausforderungen für IoT Edge Computing

Existierende (vom Cloud Computing geerbt)	Neue (speziell für IoT)
Vertrauenswürdigkeit des Anbieters ▪ Vertraulichkeit der Daten ▪ Integrität der Daten und Firmware ▪ Datenschutz	Physische Exposition ▪ Geräte im Feld ▪ Angriffe auf die Hardware
Mandantenfähigkeit ▪ Isolierung von Funktionen	Geräteheterogenität ▪ Unterschiedliche (Sicherheits-)Fähigkeiten ▪ Unterschiedliche Besitzer

Edge Computing an sich kann man betrachten wie eine Art Miniatur von Cloud Computing. Verschiedene Funktionen können auf der Plattform laufen, eventuell sogar mehrere parallel, z. B. Container oder virtuelle Maschinen. Dementsprechend werden einige Aspekte geerbt, die auch beim Cloud Computing eine Rolle spielen. Wenn man eine Edge-Computing-Funktion auf einer Plattform laufen lassen will, ist die Vertrau-

enswürdigkeit des Anbieters dieser Plattform wichtig. Wie wird die Vertraulichkeit und Integrität der dort verarbeiteten Daten gewährleistet? Ist die Integrität der Firmware gesichert? Wie steht es mit dem Datenschutz? Sollen Edge-Computing-Funktionen von mehreren verschiedenen Subjekten (Kunden, Abteilungen, Benutzern etc.) auf einer Plattform ausgeführt werden, muss diese mandantenfähig sein, d. h., die Ausführung der einzelnen Funktionen und ihrer Daten voneinander ausreichend isolieren, damit sie sich funktional und sicherheitstechnisch nicht gegenseitig beeinträchtigen.

Speziell im Fall von IoT Edge Computing kommen weitere Aspekte hinzu. Meistens sind die IoT-Geräte physisch exponiert, d. h. im Feldbetrieb an Standorten außerhalb der eigenen Organisation oder sogar frei zugänglich außerhalb von Gebäuden. Angriffe auf die Hardware sind damit eher möglich als auf klassischen Computersystemen im Rechenzentrum. Gehäuse von IoT-Geräten könnten aufgemacht werden, um Hardwarekomponenten unerlaubt zu verändern oder auszutauschen.

Ein weiterer Aspekt ist die Geräteheterogenität. Im Gegensatz zum Cloud Computing, wo riesige Serverfarmen mit meist identischen Hardwarefähigkeiten zur Verfügung stehen, kommen im Edge Computing unter Umständen verschiedene Hardware-Plattformen zum Einsatz, mit unterschiedlichen Prozessoren und unterschiedlichen Speicherkapazitäten. Selbst in der Gerätekategorie der Edge-Computing-IoT-Gateways gibt es bereits mehrere Hersteller mit teils unterschiedlicher Hardware, mal mit mehr und mal mit weniger Sicherheitsfeatures. Diese Punkte gilt es beim Einsatz zu beachten.

15.4 Entwicklung sicherer Edge-Computing-Plattformen

Im Folgenden geben wir einen Überblick, worauf bei der Entwicklung von sicheren Edge-Computing-Plattformen zu achten ist, um die oben beschriebenen Sicherheitsrisiken und Herausforderungen zu meistern. IT-Verantwortliche können diese Prinzipien als Leitlinien für die eigene Entwicklung nehmen, aber auch als Kriterien bei der Auswahl von Angeboten für den Einkauf fertiger Komponenten.

15.4.1 Security-by-Design-Prinzipien

Security by Design ist ein grundlegendes Paradigma, das den Ende-zu-Ende-Entwurf zweckmäßiger Lösungen, Produkte und Dienstleistungen unter Berücksichtigung aller geschäftsrelevanten Bedrohungen und Chancen ermöglicht. Das bedeutet, dass bei der Entwicklung von Hard- und Software von Anfang an darauf geachtet wird, dass die Systeme möglichst frei von Schwachstellen und robust gegen Angriffe sind.

Dies reduziert das Sicherheitsrisiko und ist kostengünstiger als die Berücksichtigung von Sicherheitsaspekten in einer späteren Entwicklungsphase.

Das UK National Cyber Security Centre (NCSC) hat eine Liste gängiger Security-by-Design-Prinzipien zusammengestellt. Diese Prinzipien sind in fünf Kategorien unterteilt, die auf die Phasen ausgerichtet sind, in denen ein Angriff abgewehrt werden kann (nach einem „Defense-in-Depth“-Ansatz):

1. Stellen Sie den Kontext her

Bestimmen Sie alle Elemente, aus denen Ihr System besteht, damit Ihre Abwehrmaßnahmen keine Lücken haben. Erstellen Sie ein Bedrohungsmodell. Dazu gehört, sich darüber klar zu werden, was das System als Ganzes ist, was benötigt wird, um es in Betrieb zu halten, und welche Risiken akzeptabel sind. Zum Beispiel kann es in manchen Szenarien akzeptabel sein, wenn die Edge-Computing-Funktion zu viel Rechenzeit in Anspruch nimmt, solange die Korrektheit der primären Gerätefunktion gewährleistet ist.

2. Kompromittierung erschweren

Ein Angreifer kann nur die Teile eines Systems angreifen, die er erreichen kann. Machen Sie Ihr System so schwer wie möglich zu durchdringen. Vertrauen Sie im Allgemeinen keinen externen Dateneingaben, validieren Sie diese und transformieren Sie die Daten gegebenenfalls in ein sicheres Datenformat.

3. Störungen erschweren

Entwerfen Sie ein System, das gegen Denial-of-Service-Angriffe und Nutzungsspitzen widerstandsfähig ist. Betrachten Sie die Skalierbarkeit, z. B. das Ausrollen von Edge-Computing-Funktionen auf eine Vielzahl von Geräten. Versuchen Sie, Flaschenhälse frühzeitig zu erkennen und entsprechende Maßnahmen zu implementieren, um damit geeignet umzugehen. Identifizieren Sie alle Abhängigkeiten zu Komponenten von dritten Parteien und planen Sie, was zu tun ist, wenn eine dieser Parteien ausfallen sollte.

4. Vereinfachte Erkennung von Kompromittierung

Gestalten Sie Ihr System so, dass Sie verdächtige Aktivitäten sofort erkennen und die erforderlichen Maßnahmen ergreifen können. Sammeln Sie alle relevanten Sicherheitsereignisse in Logs, und schützen Sie diese vor ungewollter Veränderung oder Löschung. Kommunikationsflüsse zwischen Komponenten sollten möglichst einfach entworfen werden, um ungewöhnliches Verhalten erkennen zu können.

5. Verringerung der Auswirkungen von Kompromittierung

Gelingt es einem Angreifer, Fuß zu fassen, wird er versuchen, Ihr System auszunutzen. Machen Sie dies so schwer wie möglich. Nicht benötigte Funktionalitäten sollten entfernt oder deaktiviert werden. Erleichtern Sie die Wiederherstellung in

einen als sicher bekannten Zustand, falls dennoch ein System kompromittiert wurde. Dies kann z. B. das Zurücksetzen der Laufzeitumgebung für die Edge-Computing-Funktion sein oder das Neustarten des Gesamtsystems von einem geschützten Firmware-Abbild.

**Hinweis**

Die vollständige List der Security-by-Design-Prinzipien findet sich auf der NCSC-Webseite:

<https://www.ncsc.gov.uk/collection/cyber-security-design-principles>

15.4.2 Privacy-by-Design-Prinzipien

Privacy by Design bedeutet, dass die Einhaltung datenschutzrechtlicher Anforderungen und Grundsätze der Datenvermeidung und Datensparsamkeit ebenfalls bereits beim Entwurf und bei der Entwicklung von IT-Systemen beachtet werden. Neben der Einhaltung des rechtlichen Rahmens geht es auch darum, keine oder so wenige personenbezogene Daten wie möglich zu erheben, zu verarbeiten oder zu verwenden.

Bei den Impulsgebern für Edge Computing haben wir gesehen, dass Datenschutz selbst einer davon sein kann und dass Edge Computing dafür bereits selbst die Lösung sein kann. Durch Edge Computing können personenbezogene Daten lokal verarbeitet und entweder gar nicht oder nur anonymisiert an die Cloud weitergeleitet werden. Edge Computing trägt so bereits zur Datenvermeidung und Datensparsamkeit bei. Jedoch muss nicht jedes Szenario für IoT Edge Computing so aufgebaut sein. Im Allgemeinen gelten auch hier die Prinzipien des Datenschutzes.

Zu Privacy by Design lassen sich sieben fundamentale Prinzipien festhalten (Cavoukian 2010):

1. Proaktiv, nicht reaktiv

Maßnahmen sollten eher vorbeugend als reaktiv sein. Ereignisse, die den Datenschutz bedrohen, sollten erwartet und im Vorfeld verhindert werden.

2. Datenschutz als Standardeinstellung

Personenbezogene Daten sollten automatisch geschützt werden. IT-Systeme sollten so entworfen werden, dass Individuen nicht erst selbst irgendwelche Einstellungen vornehmen müssen, um ihre Daten schützen zu lassen.

3. Datenschutz in das Design einbetten

Datenschutzaspekte sollten in das Design und die Architektur von IT-System und Geschäftsprozessen eingebettet sein. Es sollte nicht erst nachträglich durch extra Maßnahmen hinzugefügt werden müssen.

4. Volle Funktionalität – Positivsumme, nicht Nullsumme

Es sollte versucht werden, die legitimen Interessen und Ziele aller Beteiligten in einer positiven Win-win-Summe zu berücksichtigen. Unnötige Kompromisse sollten nicht eingegangen werden, wie z. B. Sicherheit versus Datenschutz.

5. Ende-zu-Ende-Sicherheit

Datenschutz sollte über den gesamten Lebenszyklus der Daten hinweg gewährleistet werden. Dabei sind starke Sicherheitsmaßnahmen wichtig, die von Anfang bis Ende sicherstellen, dass die Daten sicher erfasst, gespeichert und am Ende auch rechtzeitig gelöscht werden.

6. Sichtbarkeit und Transparenz

Allen Beteiligten sollte versichert werden können, dass ein IT-System, unabhängig von der eingesetzten Technologie, gemäß den angegebenen Versprechen und Zielen genau so funktioniert. Dies sollte auch einer unabhängigen Überprüfung standhalten.

7. Respektieren der Privatsphäre und Benutzerorientierung

Die Interessen des Einzelnen sollten im Vordergrund stehen. IT-Verantwortliche sollten darauf achten, dass IT-Systeme entsprechende Maßnahmen wie Datenschutz als Standardeinstellung, angemessene Hinweise und benutzerfreundliche Optionen anbieten.



Hinweis

Die detaillierte Beschreibung der Privacy-by-Design-Prinzipien befindet sich auf der Webseite der International Association of Privacy Professionals (IAPP):

<https://iapp.org/resources/article/privacy-by-design-the-7-foundational-principles/>

15.4.3 Spezielle Entwicklungsprinzipien für Edge Computing

Während die Prinzipien für Security und Privacy by Design nicht nur für Edge Computing, sondern grundsätzlich bei allen IT-Systemen anwendbar sind, gibt es Aspekte, aus denen sich Entwicklungsprinzipien speziell für Edge Computing ableiten lassen. Vordergründig ist die Unterscheidung der primären Gerätefunktion und der Edge-Computing-Funktion. Aus der Anforderung, dass die primäre Gerätefunktion immer gewährleistet werden muss, ergeben sich folgende Prinzipien, die IT-Verantwortliche bei der Entwicklung oder Integration von Komponenten einbeziehen sollten.

Isolierte Bereiche

Die Edge-Computing-Plattform sollte bereits durch ihre interne Architektur isolierte Bereiche zur Verfügung stellen, in denen die Daten und der Programmcode für die

primäre Gerätefunktion getrennt von den Daten und dem Programmcode der Edge-Computing-Funktion gespeichert und ausgeführt werden. Das Betriebssystem der Plattform sollte geeignete Mechanismen dafür zur Verfügung stellen, z. B. mindestens Prozessisolierung oder vollständig virtuelle getrennte Laufzeitumgebungen.

Isolierte Bereiche sind insofern wichtig, dass, wenn im Bereich der Edge-Computing-Funktion eine Fehlfunktion oder eine Kompromittierung stattfindet, die Laufzeitumgebung der primären Gerätefunktion davon nicht betroffen ist. So kann die primäre Funktion weiterarbeiten und je nach Plattform auch Gegenmaßnahmen einleiten, um den Bereich der Edge-Computing-Funktion zu „säubern“. Derart isolierte Bereiche sind für die Erfüllung der Mandantenfähigkeit ebenfalls hilfreich. Abschnitt 15.5 betrachtet dazu einige spezielle Sicherheitstechnologien auf Plattformebene, die eine solche starke Isolierung bieten können.

Reduzierte Komplexität

Obwohl die Laufzeitumgebung von Edge-Computing-Plattformen umfangreiche und vielfältige Möglichkeiten zum Programmieren der Edge-Computing-Funktion bereitstellen muss, sollte darauf geachtet werden, die Komplexität der Laufzeitumgebung insgesamt zu reduzieren, um die Angriffsfläche für schadhaftes Verhalten möglichst gering zu halten. Schwachstellen entstehen oft durch zu große Komplexität, sodass Fehler schnell übersehen werden können. Ein Maß der Komplexität ist beispielsweise die Anzahl der Codezeilen, die eine Laufzeitumgebung mit sich bringt. Für Standard-Linux-Betriebssysteme ist diese Zahl beispielsweise in Millionenhöhe. In Abschnitt 15.5 zeigen wir einige Technologien auf, die helfen können, dieses Problem in den Griff zu bekommen.

Modularität

Edge-Computing-Plattformen werden für eine Vielfalt von Funktionen gebaut. Da die konkrete Programmlogik der Funktionen und dafür benötigte Plattformdienste im Vorfeld nicht bekannt sind, sollte die Plattform selbst eine hohe Modularität bieten. Module sollten derart gestaltet sein, dass nicht benötigte Funktionalitäten einfach entfernt oder deaktiviert werden können (siehe Abschnitt 15.4.1).

Verbindliche Zugriffskontrolle

Sicherheitsregeln der Edge-Computing-Plattform sollten klar definiert werden können. Die Durchsetzung dieser Regeln muss durch geeignete technische Mechanismen gewährleistet werden. Auf Ebene des Betriebssystems ist dies die Zugriffskontrolle für einzelne Prozesse auf die Ressourcen der Plattform. Achten Sie insbesondere auf die technischen Fähigkeiten der Hardware und Firmware der IoT-Geräte, auf denen Edge-Computing-Funktionen ausgeführt werden sollen. Die Plattform sollte verbindliche Sicherheitsregeln unterstützen, d. h., dass laufende Prozesse die Zugriffsberechtigungen ihrer Ressourcen nicht einfach wahlfrei ändern können, sondern dass dies

nur in einem festgelegten Rahmen passieren kann. Unter dem Linux-Betriebssystem bietet dies beispielsweise die Erweiterung SELinux.



Hinweis

Achten Sie beim Entwurf von Edge Computing in Ihrer IT-Architektur darauf, ein klares Verständnis für den Einsatzkontext zu entwickeln. Die konkreten **Sicherheitsziele**, die eine Edge-Computing-Plattform erfüllen muss, sowie die **Annahmen**, unter denen die Plattform betrieben werden soll, sollten vollständig und so präzise wie möglich definiert werden. Denn alles Weitere — die Einhaltung der Prinzipien und die Auswahl der Technologie — hängt davon ab!

15.5 Technologien für sichere Edge-Computing-Plattformen

Neben den obigen Prinzipien, die bei der Planung und Entwicklung der eigenen Edge-Computing-Strategie berücksichtigt werden sollten, gibt es auch technologische Entwicklungen, die hilfreich sein können, um die speziellen Sicherheitsanforderungen einer Edge-Computing-Plattform zu erfüllen. Wir werfen im Folgenden einen kurzen Blick auf einige dieser Technologien, die im Kontext von IoT fortschreitend zusammenwachsen (Moratelli 2021).

15.5.1 Sicherheitskerne

Herkömmliche Betriebssysteme für PC-Plattformen bieten einen reichen Funktionsumfang, sind aber auch dementsprechend komplex. Dies erschwert es, die Korrektheit der Umsetzung der gegebenen Sicherheitsziele genauestens prüfen zu können. Sicherheitsrelevante Funktionalitäten sind meist über viele Komponenten des Betriebssystems verstreut, Zusammenhänge oft schwer erkennbar.

Als Sicherheitskern bezeichnet man allgemein den zentralen Teil eines Computersystems bestehend aus Hardware, Firmware und Software, der die grundlegenden Sicherheitsmechanismen für die Zugriffskontrolle auf die Computerressourcen implementiert. Konzeptuell werden alle Sicherheitsfunktionen zentral gebündelt, alle relevanten Funktionen sind klar definiert, und der Sicherheitskern enthält keine überflüssigen (nicht sicherheitsrelevanten) Funktionalitäten. Dieser Ansatz ermöglicht eine bessere Evaluierung der Korrektheit und Sicherheit. Idealerweise ist der Sicherheitskern zudem von der Komplexität des Programmcodes her klein genug, um seine Korrektheit optimal testen oder gar formal beweisen zu können.

Ein Sicherheitskern bietet eine starke Isolation zwischen verschiedenen Laufzeitumgebungen, je nach Technologie für einzelne Prozesse, logische Partitionen oder virtuelle Maschinen. Zwischen den ansonsten isolierten Bereichen gibt es nur klar definierte und kontrollierte Schnittstellen als Kommunikationskanäle. Darüber hinaus muss der Sicherheitskern Funktionen bereitstellen, um die Integrität von Anwendungen zu überprüfen, anwendungsbezogene Daten sicher zu speichern (Wahrung der Vertraulichkeit und Integrität) sowie die Verfügbarkeit kritischer Systemressourcen zu gewährleisten.

Moderne Sicherheitskerne kommen typischerweise in zwei Ausgestaltungen, wobei diese auch kombiniert werden können:

- **Separation Kernel:** Hier steht die Isolation von größeren Laufzeitumgebungen im Vordergrund. Üblicherweise mithilfe von Virtualisierung werden für jeden Sicherheitsbereich eigene virtuelle Maschinen bereitgestellt. Weitere Sicherheitsfunktionen werden von einem der Bereiche aus ausgeführt, z. B. in Form eines speziell angepassten Betriebssystems in einer virtuellen Maschine. Beispiel für einen Separation Kernel für IoT ist Green Hills INTEGRITY (Green Hills 2024).
- **Mikrokern:** Nur minimale Betriebssystemfunktionen werden im Mikrokern mit den höchsten Prozessorrechten ausgeführt, alle andere Komponenten (insbesondere auch Gerätetreiber) laufen mit geringeren Rechten wie normale Anwendungsprogramme. Dies hat den Vorteil, dass der Mikrokern nicht durch fehlerhafte Prozesse oder schadhafte Gerätetreiber korrumpiert werden kann. Ein Mikrokern hat typischerweise eine Code-Größe von nur mehreren Zehntausend Zeilen. Dadurch ist die Komplexität viel geringer und eine Überprüfung auf Korrektheit eher möglich. Weitergehende Sicherheitsfunktionen können als native Anwendungen auf dem Mikrokern bereitgestellt werden. Beispiel für ein mikrokernbasiertes System ist KasperskyOS (Kaspersky 2024).

Neben der reinen Software ist der Sicherheitskern auch auf bestimmte Hardware-Funktionalitäten angewiesen. In erster Linie ist dies ein Prozessor mit geeigneter **Speicherverwaltungseinheit**. Daneben können aber auch weitere Sicherheitsmechanismen in Hardware eingesetzt werden, wie beispielsweise **Trusted Platform Modules** (TPMs). Diese Hardwarechips werden als Sicherheits- und Vertrauensanker genutzt und ermöglichen es, die Konfiguration eines Gesamtsystems zuverlässig zu bestimmen und nachzuweisen. Durch das TPM können auch kryptografische Schlüssel in Hardware geschützt werden. Ähnliche Mechanismen können je nach Hardware auch direkt vom Prozessor implementiert werden.

Secure Boot ist ein weiterer Sicherheitsmechanismus, den die Hardware bereitstellen kann. Dadurch wird sichergestellt, dass wichtige Firmware-Teile nur gestartet werden, wenn sie nicht unerlaubt verändert wurden. Dies wird mithilfe von kryptografischen Signaturen geprüft.

Bezogen auf IoT Edge Computing sieht die einfachste Architektur einer Plattform mit Separation Kernel aus wie in Bild 15.5 dargestellt. Der Separation Kernel stellt zwei Bereiche in Form von virtuellen Maschinen (VMs) bereit. In einer VM läuft die primäre Gerätefunktion, und in der anderen die Edge-Computing-Funktion. Durch Austausch der Edge Computing VM können eine einfache Anpassbarkeit und Flexibilität der Edge-Computing-Funktion ermöglicht werden. Bei Störungen kann die VM beispielsweise zurückgesetzt und von einem frischen Abbild neu gestartet werden.

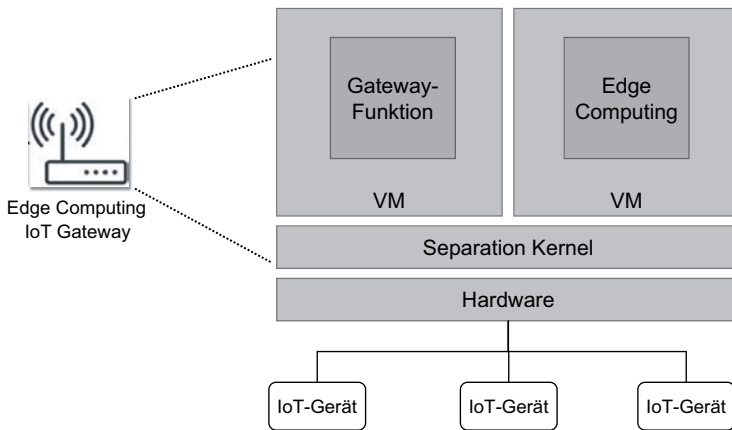


Bild 15.5 Plattform-Sicherheitsarchitektur IoT Edge Computing mit Separation Kernel

Diese Architektur bietet sich für IoT-Gateways an, die sehr allgemein gehalten werden sollen und keine zusätzlichen Sicherheitsfunktionen bereitstellen müssen. Bei größeren Anforderungen, z. B. bei einem Smart Meter Gateway, können mikrokernbasierte Sicherheitskerne weitere Sicherheitsmechanismen auf robuste Art bereitstellen (Gröne 2012).



Hinweis

Achten Sie bei der Auswahl von IoT-Edge-Computing-Plattformen darauf, dass sie einen mikrokernbasierten Sicherheitskern oder zumindest einen Separation Kernel enthalten, wenn Ihr Einsatzkontext eine starke Isolierung der Funktionalitäten erfordert. Bei hohen Integritätsanforderungen sollte Secure Boot und hardwaregeschützter Speicher für kryptografische Schlüssel vorhanden sein.

15.5.2 Trusted Execution Environments und Confidential Computing

Ein Trusted Execution Environment (TEE) ist ein abgeschirmter Bereich des Prozessors, auch Enklave genannt. Moderne Prozessortechnologien wie ARM TrustZone, AMD SEV oder Intel SGX bieten diese Enklaven. Darin kann Software ausgeführt werden, die ihre Daten und ihren Programmcode speziell geschützt hat. Außerhalb der Enklave sind die Daten verschlüsselt, auch im Hauptspeicher. Wenn ein Programm in der Enklave ausgeführt wird, können andere laufende Prozesse nicht darauf zugreifen, selbst das Betriebssystem oder eine darunter laufende Virtualisierungsschicht können dies nicht.

Diese Technologie wird mittlerweile unter dem Begriff Confidential Computing geführt. Im Confidential Computing Consortium (CCC 2024) haben sich führende Hard- und Softwarehersteller zusammengetan, um die Verbreitung und Anwendung dieser Sicherheitstechnologie voranzutreiben. Obwohl vordergründig derzeit im Umfeld von Cloud Computing angeboten, kann damit gerechnet werden, dass Confidential Computing auch im Bereich Edge Computing zunehmend Verwendung finden wird.

Diese Technologie kann dementsprechend genutzt werden, um Edge-Computing-Funktionen auszuführen, die besondere Anforderungen an die Vertraulichkeit haben oder wo kein geeignetes Betriebssystem die Sicherheitsanforderungen ansonsten erfüllen kann (z. B. Standard-Linux-Betriebssystem und kein sicherheitskernbasiertes System). Den höchsten Grad an Sicherheit bieten damit Edge-Computing-Plattformen mit einem Sicherheitskern in Kombination mit einem TEE, welches Confidential Computing für sensible Workloads bereitstellt.

15.5.3 Kryptoagilität

Kryptoagilität ist genau genommen keine konkrete Technologie, sondern eher ein Designprinzip. Hierbei geht es darum, ein System so zu entwerfen, dass die Anpassung von kryptografischen Mechanismen und Methoden keiner größeren Designänderungen im Nachhinein bedarf. Insbesondere sollte eine Anpassung von Systemen im Betrieb ohne größeren Aufwand möglich sein.



Beispiel: TPM 1.2-Chip

Für das TPM 1.2 war der Hash-Algorithmus SHA-1 fest in der Spezifikation vorgesehen (Trusted Computing Group 2011). Im Laufe der Zeit hat sich jedoch gezeigt, dass SHA-1 Schwachstellen hat, die es Angreifern erlaubt, Datensätze so zu konstruieren, dass man das gleiche Ergebnis wie bei bestimmten anderen Daten erhält. Da diese Ergebnisse für die Integritätsprüfung von Daten verwendet werden, sind somit Datenmanipulationen möglich, die nicht mehr vom Original unterschieden werden können. Einen Austausch des Algorithmus sah jedoch der Standard nicht vor. Damit sind alle im Betrieb befindlichen TPM 1.2-Chips anfällig für diese Art des Angriffs. Besonders problematisch in diesem Zusammenhang ist die Tatsache, dass viele der weiteren Mechanismen des TPM 1.2-Chips sich auf diesen SHA-1-Algorithmus bezogen und angewendet haben. Damit waren viele Funktionen des Chips auf einen Schlag quasi wertlos geworden.

Der neue Standard TPM 2.0 (Trusted Computing Group 2019) sieht dementsprechend vor, dass einzelne Algorithmen auch durch neuere Versionen ausgetauscht werden können.

Dort, wo in einem System kryptografische Methoden zum Einsatz kommen, sollte darauf geachtet werden, dass das kryptografische Subsystem so modular aufgebaut ist, dass es sich einfach aktualisieren und auch durch vollständig neue Methoden austauschen lässt.

Dies ist nicht nur von Bedeutung, wenn Schwachstellen in existierenden kryptografischen Mechanismen gefunden werden. Die Fortschritte im Quanten-Computing lassen erwarten, dass es früher oder später praktikable Systeme geben wird, die einige der gängigen Verschlüsselungssysteme wertlos machen. Quantencomputer können die geheimen Schlüssel von bestimmten Verfahren sehr schnell berechnen.

Um sich dagegen zu rüsten, gibt es zwei Entwicklungen:

- **Post-Quanten-Kryptografie**, d. h. die Entwicklung traditioneller Verschlüsselungsverfahren, die den neuen Quantencomputer-Eigenschaften widerstehen können;
- **Quanten-Kryptografie**, d. h. neue Verschlüsselungsverfahren, die auf den Eigenschaften von Quantentechnologien beruhen.

Für die eigene Strategie ist es nun relevant, sich zum einen bewusst zu machen, dass es diese beiden technologischen Entwicklungen gibt, und zum anderen darauf zu achten, dass eigene IT-Systeme für das Edge Computing so entworfen werden, dass eine Anpassung oder ein Austausch kryptografischer Module mit überschaubarem Aufwand machbar ist.

15.6 Die wichtigsten Punkte in Kürze

- Edge Computing bietet neue Möglichkeiten für das Internet der Dinge, in dem die kritische Datenverarbeitung wieder näher an die Datenquellen gebracht wird.
- Edge Computing kommt mit bestimmten Anforderungen daher, die beim Einsatz dieser Technologie als Alternative zum Cloud Computing abgewogen werden müssen. Je nach Anwendung kann eine Aufteilung bestimmter Datenverarbeitungsschritte auf Edge und Cloud sinnvoll sein.
- Da Edge Computing üblicherweise auf Systemen stattfindet, die primär noch andere Aufgaben zu erfüllen haben (z. B. IoT-Datensensor oder Gateway), kommt der Wahl bzw. dem Entwurf einer sicheren Plattform für das Edge Computing besondere Aufmerksamkeit zu.
- Gängige Plattformen (Hard- und Firmware bzw. Betriebssysteme) für allgemeine IoT-Geräte sind eher seltener geeignet, eine sichere Laufzeitumgebung für zusätzliche Edge-Computing-Aufgaben mit den einhergehenden Sicherheitsanforderungen zu realisieren.
- Es gibt spezielle Technologien im Bereich der Betriebssysteme und Hardware-sicherheit, die als Bausteine für sichere Edge-Computing-Plattformen jedoch diese Anforderungen erfüllen können.
- Entscheidungsträger sollten darauf achten, wenn Edge Computing in der IT-Strategie mit einbezogen werden soll, dass bei der Realisierung sowohl gängige Security-by-Design- und Privacy-by-Design-Prinzipien beachtet als auch dafür speziell geeignete Technologien eingesetzt werden.

Literatur

Apple: *iPhone-Benutzerhandbuch, Suchen nach Personen in der App „Fotos“ auf dem iPhone*. URL: <https://support.apple.com/de-de/guide/iphone/iph9c7ee918c/ios>. Abgerufen: 30.04.2024.

Cavoukian, Ann: *Privacy by Design: The 7 Foundational Principles*. Information and Privacy Commissioner of Ontario, Mai 2010. URL: <https://iapp.org/resources/article/privacy-by-design-the-7-foundational-principles/>. Abgerufen: 30.04.2024.

CCC: *Confidential Computing Consortium*, <https://confidentialcomputing.io/>. Aufgerufen am 30.04.2024.

Green Hills: *INTEGRITY Real-time Operating System*. <https://www.ghs.com/products/rtos/integrity.html>. Abgerufen am 30.04.2024.

Gröne, Michael; Winandy, Marcel: *Applying a Security Kernel Framework to Smart Meter Gateways*. In: ISSE 2012 Securing Electronic Business Processes, Highlights of the Information Security Solutions Europe 2012 Conference, Springer Vieweg, 2012, S. 252 – 259.

CIO-Magazin: *Wie Schindler millionenfach Aufzüge vernetzte*. URL: <https://www.cio.de/a/wie-schindler-millionenfach-aufzuege-vernetzte>. 15.09.2017.

Huawei: *Technical Architecture – Edge Computing*. URL: https://www.huaweicloud.com/intl/en-us/solution/sc_technology_edge/. Abgerufen am 30.04.2024.

IDC: *Worldwide IDC Global DataSphere Forecast, 2023-2027: It's a Distributed, Diverse, and Dynamic (3D) DataSphere*, <https://www.idc.com/getdoc.jsp?containerId=US50554523>. Abgerufen am 30.04.2024.

Industrial IoT Consortium: *Introducing the Industrial Internet Consortium, now incorporating OpenFog*. URL: <https://www.iiconsortium.org/2019/02/introducing-the-industrial-internet-consortium-now-incorporating-openfog/>. Abgerufen am 30.04.2024.

Kaspersky: *Kaspersky IoT Infrastructure Security*. URL: <https://os.kaspersky.com/solutions/kaspersky-iot-infrastructure-security/>. Abgerufen am 30.04.2024.

Liguori, Angelo; Schoo, Peter; Winandy, Marcel: *Mind the Shift: Secure Migration of Containerized Processes in Edge Computing*. In: 5th IEEE International Conference on Edge Computing and Scalable Cloud (EdgeCom), IEEE, 2019.

Microsoft: *The STRIDE Threat Model*. Microsoft, 2009. URL: [https://docs.microsoft.com/en-us/previous-versions/commerce-server/ee823878\(v=cs.20\)?redirectedfrom=MSDN](https://docs.microsoft.com/en-us/previous-versions/commerce-server/ee823878(v=cs.20)?redirectedfrom=MSDN). Abgerufen am 30.04.2024.

Moratelli, Carlos; Johann, Sergio; de Matos, Everton; Nascimento, Francisco Assis M.; Figlarz, Gabriel Rossi; Hessel, Fabiano: *The Convergence of Technologies to Provide Security on IoT Edge Devices*. IEEE Internet of Things Newsletter, September 2021. URL: <https://iot.ieee.org/newsletter/september-2021/the-convergence-of-technologies-to-provide-security-on-iot-edge-devices>.

National Cyber Security Centre: *Secure design principles – Guides for the design of cyber secure systems*. NCSC, 2019. URL: <https://www.ncsc.gov.uk/collection/cyber-security-design-principles>.

Shostack, Adam: *Thread Modeling: Designing for Security*. John Wiley & Sons, 2014.

Siemens: *Industrial Edge für Produktionsmaschinen und Anlagen*. URL: <https://new.siemens.com/de/de/produkte/automatisierung/themenfelder/industrial-edge/produktionsmaschinen.html>. Abgerufen am 30.04.2024.

Smith, Sean: *The Internet of Risky Things*. O'Reilly Media, 2017.

Trusted Computing Group: *TPM Main Specification Level 2 Version 1.2, Revision 116*. TCG, 2011. URL: <https://trustedcomputinggroup.org/resource/tpm-main-specification/>.

Trusted Computing Group: *Trusted Platform Module Library Specification, Family "2.0", Level 00, Revision 01.59*. TCG, 2019. URL: <https://trustedcomputinggroup.org/resource/tpm-library-specification/>.

Cybersicherheit für kritische Infrastrukturen (KRITIS)

Martin Serror



In diesem Beitrag erfahren Sie,

- welche Bereiche des täglichen Lebens als kritische Infrastrukturen eingestuft werden und welche rechtlichen Verpflichtungen sich daraus für KRITIS-Betreiber ergeben,
- welchen spezifischen Bedrohungen kritische Infrastrukturen durch Cyberangriffe ausgesetzt sind,
- welche Herausforderungen eine umfassende Cybersicherheit erschweren,
- wie ein besseres Verständnis über komplexe Cyberangriffe auf kritische Infrastrukturen entwickelt werden kann und
- wie diese Angriffe durch umfassende Cybersicherheitsmaßnahmen effektiv abgewehrt werden können.

16.1 Einleitung

Spätestens durch das Eintreten von größeren, globalen Krisen, wie etwa der COVID-19-Pandemie oder des russischen Angriffskriegs auf die Ukraine, wird auf anschauliche Weise die Bedeutung von kritischen Infrastrukturen (KRITIS) aufgezeigt: Sie sind unentbehrlich für unser tägliches modernes Leben und müssen daher besonders resiliente Strukturen aufweisen. Dies spiegelt sich auch in der offiziellen Definition des Bundesamts für Sicherheit in der Informationstechnik (BSI) wider:¹⁾

¹ https://www.bsi.bund.de/DE/Themen/KRITIS-und-regulierte-Unternehmen/Kritische-Infrastrukturen/kritis_node.html

„Kritische Infrastrukturen (KRITIS) sind Organisationen oder Einrichtungen mit wichtiger Bedeutung für das staatliche Gemeinwesen, bei deren Ausfall oder Beeinträchtigung nachhaltig wirkende Versorgungsengpässe, erhebliche Störungen der öffentlichen Sicherheit oder andere dramatische Folgen eintreten würden.“

Bei genauerer Betrachtung fällt auf, dass eine beträchtliche Anzahl von Bereichen des täglichen Lebens zur kritischen Infrastruktur zählt. In § 2 Abs. 10 BSIG sind insgesamt acht KRITIS-Sektoren definiert:

- Energie
- Informationstechnik und Telekommunikation
- Transport und Verkehr
- Gesundheit
- Wasser
- Ernährung
- Finanz- und Versicherungswesen
- Siedlungsabfallentsorgung

Zusätzlich werden in diesem Kontext häufig noch die Sektoren „Staat und Verwaltung“ sowie „Medien und Kultur“ genannt, die allerdings nicht im BSIG reguliert sind. Obwohl sich diese Sektoren in ihren Aufgaben und Strukturen teilweise stark voneinander unterscheiden, gibt es dennoch gemeinsame Merkmale. Alle diese Bereiche sind von einer zunehmenden Digitalisierung und Vernetzung geprägt, wobei vor allem industrielle Netzwerke und Maschine-zu-Maschine-Kommunikation eine entscheidende Rolle spielen. Diese tiefgreifende Vernetzung führt neben all ihren Vorteilen jedoch auch zu einem gesteigerten Risiko für Cyberangriffe (Makrakis 2021).

In der jüngeren Vergangenheit waren kritische Infrastrukturen immer wieder Ziel von Cyberangriffen, die teilweise verheerende Auswirkungen hatten. Dabei trat ein breites Spektrum an mutmaßlichen Motiven für die Angriffe und deren Hergang zutage. In einigen Fällen erwiesen sich anfängliche Spekulationen über die möglichen Motive und Auswirkungen als übertrieben, während in anderen Fällen die Angriffe zu lang anhaltenden Beeinträchtigungen und erheblichen finanziellen Schäden führten. Insgesamt haben diese Vorfälle immer wieder aufgezeigt, wie verwundbar kritische Infrastrukturen im Cyberraum sind und dass Szenarien, die vor wenigen Jahren noch als Science-Fiction abgetan wurden, bereits heute oder zumindest in naher Zukunft Realität werden könnten. Daher besteht ein breiter Konsens, dass kritische Infrastrukturen nicht nur gegen physische Angriffe und Störungen resistent sein müssen, sondern auch effektiv vor den stetig komplexer werdenden Cyberbedrohungen geschützt werden müssen.

Im Folgenden werden zunächst die technischen Grundlagen von kritischen Infrastrukturen dargelegt, die die Basis für die damit verbundenen Cyberbedrohungen bilden.

Anschließend wird auf bestehende und zukünftige rechtliche Verpflichtungen für KRITIS-Betreiber eingegangen, die Mindeststandards für die Cybersicherheit festlegen. Abschließend werden die spezifischen Bedrohungen durch Cyberangriffe auf kritische Infrastrukturen erläutert, die den dringenden Handlungsbedarf für Cybersicherheitsmaßnahmen trotz vorhandener rechtlicher Rahmenbedingungen verdeutlichen.



Beispiel: Cyberangriff auf Südwestfalen-IT

In der Nacht vom 29. auf den 30. Oktober 2023 wurde der kommunale Dienstleister Südwestfalen-IT Opfer eines Ransomware-Angriffs.²⁾ Als Folge musste die Südwestfalen-IT weite Teile ihrer Systeme abschalten, wodurch mehr als siebenzig Kommunen (zumindest teilweise) von ihrer IT-Infrastruktur abgeschnitten wurden. Die Auswirkungen in den betroffenen Kommunalverwaltungen waren sehr unterschiedlich und variierten in ihrer jeweiligen Abhängigkeit von der Südwestfalen-IT. Diese reichten von Ausfällen einzelner Webseiten und Online-Dienste bis hin zur vorübergehenden Schließung einiger Verwaltungen. Die vollständige Wiederherstellung aller Dienstleistungen dauerte auch Monate nach dem Vorfall an und war mit lang anhaltenden Nachwirkungen sowie erheblichen Kosten verbunden. Insgesamt verdeutlicht dieser Vorfall, dass durch exklusive Abhängigkeiten in der Digitalisierung die Auswirkungen eines Cyberangriffs weit über das betroffene Unternehmen hinausreichen können. Für den KRITIS-Bereich ist es daher unerlässlich, solche neuralgischen Punkte frühzeitig zu identifizieren und durch geeignete Maßnahmen zu entschärfen, beispielsweise durch unabhängige Redundanzsysteme.

16.1.1 Technische Grundlagen

Kritische Infrastrukturen sind in zunehmendem Maße von digitalen Technologien abhängig, um die jeweiligen Aufgaben und Dienstleistungen zu erfüllen. Dies umfasst einerseits klassische IT-Systeme, wie sie etwa für die Verwaltung von Kundendaten oder die Erstellung von Abrechnungen benötigt werden, und andererseits wird in vielen KRITIS-Sektoren auch Operational Technology (OT) benötigt, also jene Hard- und Softwarekomponenten, die für die Überwachung und Steuerung cyber-physischer Systeme und industrieller Prozesse eingesetzt werden (Makrakis 2021). In diesem Zusammenhang spielen Industrial Control Systems (ICS) eine zentrale Rolle, die meist durch Systeme der Supervisory Control and Data Acquisition (SCADA) realisiert werden, welche die Überwachung und Steuerung von vielen dezentralen Regelkreisen ermöglichen. Hierfür besteht ein SCADA-System aus einer oder mehreren Master Terminal Units (MTU), die wiederum sternförmig mit mehreren Remote Terminal Units (RTU) oder speicherprogrammierbaren Steuerungen (SPS) verbunden sind. Die

² <https://www.heise.de/news/Cyberangriff-auf-Suedwestfalen-IT-Mehr-Kommunen-betroffen-Notbetrieb-haelt-an-9532453.html>

RTU und SPS ermöglichen die lokale Überwachung und Steuerung der mit ihnen direkt verbundenen Sensoren und Aktuatoren, während die MTU eine globale Sicht auf den Gesamtprozess durch die Abfrage von Messwerten und das Senden von Steuerbefehlen ermöglicht.

Historisch gesehen wurden die Bereiche IT und OT streng voneinander getrennt. Das bedeutete, dass die OT insbesondere durch einen physischen Perimeterschutz geschützt war und von der Außenwelt abgeschirmt wurde, was als ausreichender Schutz vor unberechtigtem Zugriff angesehen wurde. Im Gegensatz dazu war im IT-Bereich aufgrund des Aufkommens des Internets bereits deutlich früher ein Bewusstsein für die Notwendigkeit von Cybersicherheitsmaßnahmen vorhanden.

Aus der Perspektive eines Angreifers gibt es sowohl für die IT als auch für die OT mehrere potenziell lohnende Ziele für Cyberangriffe. Im Bereich der IT könnten durch einen Angriff beispielsweise sensible Kundendaten abgegriffen oder Abrechnungssysteme lahmgelegt werden. Andererseits könnten Angriffe auf die OT dazu führen, dass industriellen Prozesse gestört werden, was wiederum Produktionsausfälle und physische Schäden an Anlagen verursachen könnte. Zusätzlich kommt es vermehrt zu einer Verschmelzung der Bereiche IT und OT, bekannt als IT/OT-Konvergenz (siehe Abschnitt 16.2.1). Dies hat zur Folge, dass Angriffsvektoren im IT-Bereich auch Angriffe auf die OT ermöglichen und umgekehrt.

16.1.2 Regulierungen und Pflichten

Die Politik reagiert auf die zunehmenden Bedrohungen durch Cyberangriffe auf kritische Infrastrukturen, indem sie die Betreiber stärker in die Verantwortung nimmt, entsprechende Cybersicherheitsmaßnahmen nachweislich umzusetzen. In den letzten Jahren sind bereits verschiedene Gesetze in Kraft getreten, die darauf abzielen, kritische Infrastrukturen besser vor Cyberangriffen zu schützen. Zusätzlich wurden auch auf europäischer Ebene Richtlinien verabschiedet, um ein einheitliches Mindestniveau an Cybersicherheit in der EU zu erreichen, die derzeit in nationales Recht überführt werden. Im Folgenden wird ein kurzer Überblick über die wichtigsten Gesetze und Richtlinien zur Cybersicherheit von kritischen Infrastrukturen gegeben.

IT-Sicherheitsgesetz 2.0

Das im Jahr 2021 in Kraft getretene IT-Sicherheitsgesetz 2.0 (IT-SiG 2.0) erweitert das bisherige IT-Sicherheitsgesetz 1.0 von 2015 erheblich.³⁾ Eine zentrale Rolle nimmt hierbei das Bundesamt für Sicherheit in der Informationstechnik (BSI) ein, das durch neue Aufgaben und Befugnisse zur „Nationalen Behörde für Cybersicherheitszertifi-

³ https://www.bsi.bund.de/DE/Das-BSI/Auftrag/Gesetze-und-Verordnungen/IT-SiG/2-0/it_sig-2-0_node.html

zierung“ geworden ist. Zudem führt das IT-SiG 2.0 neue Pflichten für KRITIS-Betreiber ein. Zu diesen neuen Pflichten zählen unter anderem:

- **Umsetzung von IT-Sicherheitsmaßnahmen nach „Stand der Technik“:** KRITIS-Betreiber sind verpflichtet, angemessene IT-Sicherheitsmaßnahmen gemäß dem aktuellen Stand der Technik umzusetzen und deren Wirksamkeit nachzuweisen. Dieser Nachweis erfolgt in der Regel durch geeignete Zertifizierungen, wie etwa die *ISO 27001-Zertifizierung auf Basis des IT-Grundschutzes*.
- **Einsatz von Systemen zur Angriffserkennung (SzA):** Seit Mai 2023 müssen KRITIS-Betreiber nachweisen, dass sie SzA nach Anforderungen des BSI in Betrieb genommen haben.
- **Umfangreiche Meldepflichten bei Störfällen an das BSI:** KRITIS-Betreiber sind verpflichtet, sich beim BSI zu registrieren und jegliche IT-Störungen, die zu Ausfällen oder erheblichen Beeinträchtigungen geführt haben oder führen könnten, umgehend dem BSI zu melden.
- **Umgang mit kritischen Komponenten:** KRITIS-Betreiber sind verpflichtet, den Einsatz von kritischen Komponenten beim Bundesinnenministerium anzuzeigen, welches unter bestimmten Umständen deren Verwendung untersagen kann. Als kritische Komponenten gelten IT-Produkte, deren Störung potenziell zu Ausfällen oder erheblichen Beeinträchtigungen von KRITIS-Anlagen oder zur Gefährdung der öffentlichen Sicherheit führen könnte.
- Zusätzlich wurden im Zuge des IT-SiG 2.0 die Ordnungswidrigkeiten und Bußgelder erheblich erhöht, beispielsweise bei fehlenden Nachweisen oder unterlassenen Maßnahmen.

NIS-2-Richtlinie

Die NIS-2-Richtlinie zielt darauf ab, die Cyberresilienz in der Europäischen Union durch die Einführung verbindlicher Cybersicherheitsmaßnahmen zu stärken.⁴⁾ Sie wurde am 14. Dezember 2022 von der EU-Kommission verabschiedet und löst damit die bis dato geltende NIS-(1-)Richtlinie ab. Die Überführung der NIS-2-Richtlinie in deutsches Recht ist im Laufe des Jahres 2024 geplant, wobei es zu leichten Abweichungen bei der nationalen Umsetzung kommen kann. Zu den wichtigsten Punkten der NIS-2-Richtlinie zählen:

- **Ausweitung der regulierten Sektoren und Einrichtungen:** NIS-2 betrifft insgesamt 18 Sektoren, bei denen die Einrichtungen (*Entities*) zwischen *Essential* und *Important* unterschieden werden. Diese Unterteilung wirkt sich hauptsächlich auf den Umfang der staatlichen Aufsicht und die Sanktionen aus. Zusätzlich gelten für

⁴ <https://www.openkritis.de/it-sicherheitsgesetz/nis2-umsetzung-gesetz-cybersicherheit.html>

Essential und Important Entities unterschiedliche Grenzwerte in Bezug auf die Größe, ab denen diese unter die NIS-2-Richtlinie fallen.

- **Erhöhte Anforderungen an die Cybersicherheit:** Die NIS-2-Richtlinie enthält verschiedenste Maßnahmen für eine Steigerung des Cybersicherheitsniveaus. Diese reichen von organisatorischen Maßnahmen, wie die Erstellung von Notfallplänen, bis hin zu technischen Maßnahmen, wie Vorgaben zum Einsatz von verschlüsselter Kommunikation. Darüber hinaus gibt es umfassende Meldepflichten für Störungen und Vorfälle an die jeweiligen Cybersicherheitsbehörden.
- **Verschärfung der Sanktionen:** Bei Verstößen gegen die Anforderungen sieht die NIS-2-Richtlinie verschärfte Sanktionen vor. Bei Essential Entities können diese bis zu 2 % des weltweiten Umsatzes oder mindestens 10 Mio. Euro betragen, während bei Important Entities Strafen bis zu 1,4 % des weltweiten Umsatzes oder mindestens 7 Mio. Euro verhängt werden können.
- Zusätzlich soll durch die NIS-2-Richtlinie die Kooperation zwischen den verschiedenen Sicherheitsbehörden auf nationaler und europäischer Ebene gestärkt werden. Dies soll auch durch die zentrale und koordinierende Rolle der NIS Cooperation Group erreicht werden, die unter anderem den Informationsaustausch und die Zusammenarbeit zwischen den EU-Mitgliedsstaaten und der European Union Agency for Cybersecurity (ENISA) unterstützt.

CER-Richtlinie

Mit dem geplanten KRITIS-Dachgesetz soll die CER-Richtlinie der EU zur Stärkung der Resilienz und physischen Sicherheit kritischer Infrastrukturen, die zusammen mit der NIS-2-Richtlinie Ende 2022 verabschiedet wurde, im Laufe des Jahres 2024 in nationales Recht überführt werden.⁵⁾ Laut CER-Richtlinie müssen bei der nationalen Umsetzung die jeweiligen Behörden die betroffenen Unternehmen (*Critical Entities*) anhand eigener Risikoanalysen selbst identifizieren. Maßgeblich dafür ist die Erbringung von Dienstleistungen in einem der elf durch die CER-Richtlinie definierten Sektoren, die allerdings in Deutschland weitestgehend den acht KRITIS-Sektoren und zusätzlich dem Bereich öffentliche Verwaltung entsprechen. Unternehmen, die als Critical Entities eingestuft werden, müssen Mindestmaßnahmen zum Schutz der physischen Sicherheit und zum Aufbau der Resilienz umsetzen. Diese Maßnahmen umfassen folgende Bereiche:

- **Präventionsmaßnahmen** gegen Vorfälle und Störungen
- **Physische Sicherheit** zum Schutz von Liegenschaften und Anlagen
- **Krisenmanagement** mit vordefinierten Abläufen, Plänen und Prozeduren

⁵ <https://www.openkritis.de/eu/eu-rce-direktive-kritis.html>

- **Wiederherstellungsmaßnahmen**, um nach Vorfällen und Störungen zum Normalbetrieb zurückzukehren
- **Sicherheitsmanagement** beim Personal, wie Sicherheitsüberprüfungen und Zutrittsbeschränkungen
- Regelmäßige Durchführung von **Awareness-Schulungen** und **Sicherheitstrainings**

Es sind verschiedene Überschneidungen zur NIS-2-Richtlinie erkennbar, insbesondere bei den Einstufungen, den vorgeschriebenen Maßnahmen und den Meldepflichten. Allerdings liegt bei der CER-Richtlinie der Fokus stärker auf Störungen, Katastrophen und physischer Sicherheit. Daher müssen neben der Meldepflicht an das BSI in Deutschland zusätzlich alle Vorfälle im Zusammenhang mit dem KRITIS-Dachgesetz binnen 24 Stunden dem Bundesamt für Bevölkerungsschutz und Katastrophenhilfe (BBK) gemeldet werden. Im Zuge der Umsetzung des KRITIS-Dachgesetzes ist die Einrichtung einer gemeinsamen Kontaktstelle des BBK und BSI geplant.

16.1.3 Bedrohungen durch Cyberangriffe

Es steht außer Frage, dass kritische Infrastrukturen massiven Bedrohungen durch Cyberangriffe ausgesetzt sind, die durch verschiedene Faktoren verstärkt werden. Dazu gehören die voranschreitende Digitalisierung und Vernetzung, welche Cyberangriffe begünstigen, sowie steigende Abhängigkeiten in den Lieferketten, die zu unkontrollierbaren Auswirkungen von Cyberangriffen führen können. Zudem sind KRITIS besonders attraktive Ziele für Cyberangriffe aus unterschiedlichsten Motiven, angefangen bei persönlichen Rachegelüsten bis hin zu finanziellen Motiven und politischen Absichten. Eine zusätzliche Herausforderung besteht darin, dass Tätergruppierungen häufig international operieren und nicht selten von Staaten unterstützt werden. Dies erschwert die Ermittlungen nationaler Sicherheitsbehörden und insbesondere die Zerschlagung der kriminellen Strukturen. Ein positives Beispiel in diesem Zusammenhang ist die Aushebung der Botnetz-Infrastruktur „Avalanche“ im Jahr 2016.⁶ Nach jahrelanger Ermittlungsarbeit gelang es in einer koordinierten Aktion von nationalen und internationalen Ermittlungsbehörden, unterstützt durch das BSI und das Fraunhofer FKIE, das Botnetz zu neutralisieren, Geräte zu beschlagnahmen und Verantwortliche zu verhaften. Insgesamt verschärft sich jedoch kontinuierlich die Bedrohungslage für KRITIS, wie unter anderem der BSI-Lagebericht der IT-Sicherheit in Deutschland für das Jahr 2023 zeigt (BSI 2023). Daher wird im Folgenden ein grundlegendes Verständnis für mögliche Bedrohungen durch Cyberangriffe auf KRITIS entwickelt, sowie die zugrunde liegenden Motive werden skizziert.

⁶ https://www.bsi.bund.de/DE/Themen/Verbraucherinnen-und-Verbraucher/Cyber-Sicherheitslage/Methoden-der-Cyber-Kriminalitaet/Botnetze/Botnetz-Avalanche/botnetz-avalanche_node.html

Interne Bedrohungen

Bevor man sich mit den offensichtlichen externen Bedrohungen befasst, ist es wichtig, ein Bewusstsein dafür zu schaffen, dass bereits innerhalb einer Organisation verschiedene interne Risiken existieren. Diese reichen von unbeabsichtigten bis hin zu vorsätzlich schädlichen Handlungen seitens der Mitarbeiter. Ein Beispiel hierfür ist, wenn ein Mitarbeiter (aus Bequemlichkeit) die physische Trennung von zwei Netzwerken durch die Verwendung eines USB-Speichermediums überbrückt. Häufig ist den betroffenen Mitarbeitern nicht bewusst, dass sie durch ihr Handeln bestehende Sicherheitskonzepte untergraben.

Ganz anders verhält es sich bei gezielten internen Bedrohungen, bei denen Mitarbeiter durch ihr Wissen und ihre Zugriffsrechte einen Cyberangriff initiieren oder zumindest dazu beitragen können. Dies kann beispielsweise der Fall sein, wenn sich ein ehemaliger Mitarbeiter für seinen Rauswurf am Unternehmen rächen möchte, indem er Sabotageaktionen durchführt. Darüber hinaus können finanzielle Motive eine Rolle spielen, insbesondere wenn der Angriff der Industriespionage dient.

Externe Bedrohungen

Bei den externen Bedrohungen kann ebenfalls zwischen ungezielten und gezielten Angriffen unterschieden werden. Bei ungezielten Cyberangriffen geht es nicht darum, ein spezifisches Unternehmen zu treffen, sondern die Opfer geraten eher zufällig ins Visier der Täter, beispielsweise durch Schadsoftware, die sich selbstständig über das Internet verbreitet. Dennoch sollten auch die ungezielten Angriffe nicht unterschätzt werden. Die Suchmaschine *Shodan*⁷⁾ verdeutlicht eindrucksvoll, wie einfach es ist, Schwachstellen von ans Internet angebundenen Geräten und Anlagen automatisiert aufzuspüren. Statt gezielt ein bestimmtes System auf Schwachstellen zu untersuchen, können Angreifer einfach für eine bekannte Schwachstelle nach den passenden Systemen (und Unternehmen) suchen. Dies ermöglicht großflächige, automatisierte Angriffskampagnen und ist besonders für Angreifer mit finanziellen Absichten attraktiv. So können sie gleichzeitig viele verschiedene Systeme auf die gleiche Weise angreifen und deren Betreiber in der Hoffnung erpressen, dass zumindest einer von ihnen bezahlen wird.

Dem gegenüber stehen gezielte externe Angriffe, bei denen meist mit erheblichem Aufwand eine spezifische Organisation ins Visier genommen wird. Diese Art von Bedrohung wird auch als *Advanced Persistent Threat (APT)* bezeichnet, da der Erreichung des Angriffsziels oftmals eine monatelange oder sogar jahrelange minutiöse Planung vorausgeht, in der die internen Strukturen und Abläufe auf Schwachstellen hin untersucht werden. Dabei wird beispielsweise auf *Social Engineering* zurückgegriffen, eine Manipulationstechnik, bei der Mitarbeiter dazu verleitet werden sollen, geschützte Informationen preiszugeben oder Schadsoftware auszuführen. Solche An-

⁷⁾ <https://www.shodan.io>

griffskampagnen sind oft von politischen Motiven geprägt, sei es durch Aktivismus oder staatlich unterstützte Cyberangriffe, wie sie beispielsweise im Rahmen einer hybriden Kriegsführung auftreten können.



Beispiel: Stuxnet

Der im Jahr 2010 entdeckte Computerwurm *Stuxnet* wurde gezielt dafür entwickelt, speicherprogrammierbare Steuerungen vom Typ Simatic S7 des Herstellers Siemens anzugreifen, die unter anderem auch in iranischen Atomenanreicherungsanlagen eingesetzt wurden (Kushner 2013). Ein besonderes Merkmal von Stuxnet war seine aggressive Verbreitung, die mithilfe von verschiedenen Zero-Day-Exploits und über lokale Infektionswege (LANs und USB-Speichermedien) realisiert wurde. Es gilt heute als gesichert, dass hinter der Entwicklung von Stuxnet aufgrund der technischen Komplexität, des hohen Ressourcenaufwands und seines spezifischen Angriffsziels nur staatlich unterstützte Akteure stehen konnten.

16.2 Herausforderungen

Angesichts der zunehmenden Häufigkeit von Cyberangriffen auf kritische Infrastrukturen in den letzten Jahren drängt sich die Frage auf, wie es zu dieser besorgniserregenden Entwicklung kommen konnte. Bei genauerer Betrachtung fällt auf, dass die Ursachen für Cyberangriffe stark von den jeweiligen Umständen abhängen und oft auf eine unglückliche Verkettung mehrerer Schwachstellen zurückzuführen sind. Dennoch lassen sich auch allgemeine Faktoren identifizieren, die solche Angriffe begünstigen. Ein erster Schritt zur Stärkung der Cybersicherheit besteht darin, sich dieser Herausforderungen bewusst zu werden, um sie anschließend gezielt anzugehen. Im Folgenden werden die wichtigsten Herausforderungen für die Sicherheit kritischer Infrastrukturen zusammengefasst und anhand passender Beispiele erläutert.

16.2.1 IT/OT-Konvergenz

Die voranschreitende Digitalisierung und Vernetzung bergen neben ihren zahlreichen Vorteilen auch erhebliche Cybersicherheitsrisiken für kritische Infrastrukturen, da sie neue Angriffsvektoren eröffnen (Serror 2020). Dies liegt weniger am Einsatz neuer Technologien, sondern vielmehr daran, dass die erforderlichen Cybersicherheitsmaßnahmen von Anfang an nicht angemessen berücksichtigt werden. Kritische Infrastrukturen sind beispielsweise zunehmend von der technologischen Verschmelzung der bisher getrennten Bereiche IT und OT betroffen, was auch als IT/OT-Konver-

genz bezeichnet wird. Diese Entwicklung wird durch den technologischen Fortschritt und den kostengünstigen Einsatz entsprechender Hardware für Vernetzung und Digitalisierung vorangetrieben sowie durch das Voranschreiten des (Industrial) Internet of Things, welches eine neue Flexibilisierung von industriellen Prozessen und Anwendungen ermöglicht.

Daher ist die jahrzehntelange Annahme, dass die besonders schützenswerte OT durch ausreichende physische Sicherheitsmaßnahmen vor externen Bedrohungen geschützt ist (*Air Gapping*), nicht länger zutreffend. Vielmehr erfordern die genannte Flexibilisierung der Prozesse, umfassende Automatisierung und weitreichende Datenanalysen eine enge Verzahnung zwischen IT und OT, was potenziellen Angreifern neue Angriffsflächen bietet.

Darüber hinaus nähern sich auch die eingesetzten Hardwareplattformen von IT und OT immer weiter an, da aus Kostengründen die Umsetzung spezifischer Funktionalitäten vermehrt in Software und *Commercial-off-the-Shelf-(COTS)-Hardware* statt in spezialisierter Hardware umgesetzt werden. Dies hat zur Folge, dass immer mehr Geräte auf den gleichen Architekturen und Protokollen aufbauen und somit bekannte Schwachstellen aus der IT teilweise auf die OT übertragen werden können. Zusätzlich lassen sich einmal gefundene Schwachstellen somit auf eine Vielzahl gleichartiger Geräte anwenden, was insbesondere ungezielte Cyberangriffe begünstigt (siehe Abschnitt 16.1.3).



Hinweis: Zero-Day-Exploit

Als *Zero-Day-Exploit* wird eine Sicherheitslücke in einer Software bezeichnet, die beispielsweise durch einen Programmierfehler entstehen kann und bisher den Entwicklern sowie den Anwendern unbekannt ist. Folglich existiert für diese Sicherheitslücke noch keine Lösung in Form eines Patches oder anderer spezifischer Gegenmaßnahmen. Zero-Day-Exploits lassen sich daher besonders erfolgreich für Cyberangriffe ausnutzen. Zusätzlich haben sich für Zero-Day-Exploits regelrechte Schwarzmärkte etabliert, auf denen in Abhängigkeit von der Kritikalität der Schwachstelle sehr hohe Preise gezahlt werden.

16.2.2 „Safety first“

Ein besonderes Merkmal von kritischen Infrastrukturen ist, dass die Gewährleistung der Betriebssicherheit (*Safety*) oberste Priorität hat (Ani 2017). Erst danach folgen die klassischen Schutzziele der Cybersicherheit (mit absteigender Priorität):

- Verfügbarkeit
- Integrität
- Vertraulichkeit

Dies steht im Gegensatz zu den Cybersicherheitsanforderungen von anderen Unternehmen und Branchen, wo üblicherweise die Vertraulichkeit der Daten an erster Stelle steht und Betriebssicherheit in diesem Zusammenhang eine untergeordnete Rolle spielt. Konkret bedeutet dies für die kritischen Infrastrukturen, dass zunächst die hohen Anforderungen an die Betriebssicherheit erfüllt und erst in einem zweiten Schritt Cybersicherheitsmaßnahmen umgesetzt werden, wenn diese den Betriebssicherheitsmaßnahmen nicht entgegenstehen. Stattdessen sollten Betriebssicherheit und Cybersicherheit gemeinsam betrachtet werden, da sie sich letztlich gegenseitig bedingen (Babeshko 2023).

Darüber hinaus gibt es hohe Anforderungen an die (ständige) Verfügbarkeit von kritischen Infrastrukturen. Dementsprechend sind selbst kleinste technische Veränderungen mit erheblichem Aufwand verbunden, da sie die Verfügbarkeit des Gesamtsystems nicht beeinträchtigen dürfen. Dies spiegelt sich unter anderem in den langen Lebenszyklen der eingesetzten Hardware wider, die teilweise über zwanzig Jahre im Einsatz ist (Kayan 2022). Infolgedessen bieten solche Geräte meist nur rudimentäre oder veraltete Cybersicherheitsvorkehrungen.

Des Weiteren werden bestimmte Sicherheitsfunktionen, wie beispielsweise die Verschlüsselung der Kommunikation, von KRITIS-Betreibern häufig deaktiviert, um die Verfügbarkeit, etwa durch Inkompatibilitäten, Fehlkonfigurationen oder erhöhte Verarbeitungszeiten, insgesamt nicht zu gefährden. Zusätzlich gestaltet sich ein umfassendes (und dringend benötigtes) Patch-Management in der Regel als schwierig, da die eingesetzten Geräte entweder kein Patching unterstützen, keine Patches mehr verfügbar sind oder der Updateprozess den laufenden Betrieb beeinträchtigen könnte.

16.2.3 Mangelnde physische Sicherheit

Ein häufig übersehener Aspekt der Cybersicherheit in kritischen Infrastrukturen ist der Schutz von Liegenschaften und Anlagen vor unbefugtem Zutritt, also die physische Sicherheit. Dennoch kann ein Einbruch in eine Liegenschaft den ersten Schritt eines mehrstufigen Cyberangriffs darstellen, insbesondere wenn der Angreifer dadurch Zugriff auf sensible Bereiche erhält (Krause 2021). Obwohl der Diebstahl von Wertgegenständen, wie beispielsweise Kupfer, ein häufiges Motiv für solche Einbrüche ist, besteht zumindest die Möglichkeit, dass ein Eindringling durch die Nutzung manipulierter Geräte oder externer Datenträger Cyberangriffe im internen Netzwerk initiiert und somit bestimmte Schutzvorkehrungen, wie etwa Firewalls, umgeht. Zusätzlich kann Vandalismus weitreichende digitale Auswirkungen haben, insbesondere wenn kritische Komponenten beschädigt werden.

Besonders für kritische Infrastrukturen stellt die große Anzahl von Liegenschaften, die vor unbefugtem Zutritt geschützt werden müssen, eine bedeutende Herausforde-

rung dar. Betrachtet man beispielsweise das Stromnetz, wird deutlich, dass zahlreiche Liegenschaften wie Kraftwerke, Umspannwerke und Ortsnetzstationen geschützt werden müssen, die zudem über eine weitläufige geografische Fläche verteilt sind. Der Schutz dieser Einrichtungen kann nicht allein durch Sicherheitspersonal gewährleistet werden, sondern muss vermehrt durch automatisierte Überwachungsansätze unterstützt werden.

16.2.4 Mangelnde Eigeninitiative

Obwohl die Gefahren durch Cyberangriffe bei KRITIS-Betreibern insgesamt verstärkt wahrgenommen werden und die Investitionen in Cybersicherheitsmaßnahmen vor allem aufgrund neuer gesetzlicher Vorschriften steigen (BSI 2023), werden freiwillige Investitionen in die Stärkung der Cybersicherheit häufig noch gemieden. Ein Hauptgrund dafür ist die weitverbreitete Meinung in Unternehmensvorständen, dass solche Investitionen in der Regel nicht unmittelbar zu zusätzlichen Gewinnen führen oder einen Wettbewerbsvorteil darstellen.⁸⁾

Darüber hinaus sind insbesondere kleine und mittlere Unternehmen (KMUs) häufig noch sehr schlecht in Bezug auf Cybersicherheit aufgestellt, da viele dieser Unternehmen fälschlicherweise der Ansicht sind, dass sie nicht im Fokus von Cyberangriffen stehen.⁹⁾ Zusätzlich mangelt es oft an einem kohärenten Cybersicherheitskonzept und seiner konsequenten Umsetzung. So werden technische Lösungen wie Angriffserkennungssysteme zwar angeschafft, sind jedoch unzureichend auf die vorhandene IT-Infrastruktur abgestimmt. Dadurch arbeiten solche Systeme äußerst ineffektiv oder bleiben sogar ungenutzt, da Inbetriebnahme, Wartung und Betrieb nicht angemessen berücksichtigt wurden.¹⁰⁾ Hier spielt auch der allgemeine Mangel an Fachkräften eine Rolle, da diese für die Bedienung und Betreuung der Systeme zwingend benötigt werden.

Insgesamt können diese Herausforderungen nur bewältigt werden, wenn die Stärkung der Resilienz als kontinuierlicher Prozess verstanden wird, der alle Bereiche eines KRITIS-Unternehmens betrifft. Dies schließt nicht nur das Bewusstsein für Cybersicherheitsrisiken und die Planung konkreter Maßnahmen ein, sondern auch deren Umsetzung und regelmäßige Überprüfung.

⁸⁾ https://www.trendmicro.com/de_de/about/newsroom/press-releases/2023/20230330-hidden-player-cybersecurity-als-geschäfts-und-umsatztreiber.html

⁹⁾ <https://www.security-insider.de/cybersecurity-immer-noch-keine-chefsache-a-6ba839c19c3dbc23433223658c0941c3/>

¹⁰⁾ <https://www.all-about-security.de/studie-unternehmen-erhoehen-cybersecurity-budgets-aber-zu-haefig-nach-giesskannenprinzip/>

16.3 Cyberangriffe verstehen

Um die Cybersicherheit von kritischen Infrastrukturen zu stärken, ist es zunächst notwendig, ein Verständnis für mögliche Schwachstellen zu entwickeln, bevor konkrete Schutzmaßnahmen identifiziert werden können (siehe Abschnitt 16.4). Hierfür ist es sinnvoll, sich in die Perspektive eines potenziellen Angreifers zu versetzen und verschiedene Angriffsszenarien durchzuspielen. Der individuelle Ablauf eines solchen Angriffsszenarios hängt sowohl von den Fähigkeiten und Zielen des Angreifers als auch von seinem Vorgehen und den eingesetzten Angriffstechniken ab. Im Folgenden werden daher methodische Ansätze vorgestellt, die eine Klassifizierung möglicher Cyberangriffe im KRITIS-Bereich und eine Modellierung ihres Ablaufs ermöglichen.

16.3.1 Fähigkeiten des Angreifers

Kritische Infrastrukturen sind in der Regel auf cyber-physischen Systemen aufgebaut, in denen digitale und vernetzte Komponenten mit physischen Prozessen interagieren. Das Verständnis und die komplexen Zusammenhänge dieser Systeme erfordern spezifisches Fachwissen. Allgemein lässt sich festhalten, dass ein Angreifer mit umfangreichen Kenntnissen über das Opfersystem eine größere Bedrohung darstellt, da ihm dadurch zusätzliche und komplexere Angriffsvektoren zur Verfügung stehen. Dennoch dürfen auch Angreifer mit weniger oder gar keinem Fachwissen nicht unterschätzt werden, da auch sie beträchtlichen Schaden anrichten können. Dies liegt vor allem daran, dass kritische Infrastrukturen auf vielfältige Weise angegriffen werden können.



Hinweis: Angriffsvektoren

Ein *Angriffsvektor* bezeichnet eine Möglichkeit oder Methode (unabhängig von ihrer Art), unbefugt in ein Computersystem einzudringen. Die Gesamtheit aller Angriffsvektoren bildet die *Angriffsfläche*. Deshalb wird bei einer konsequenten Schließung von Sicherheitslücken und der Umsetzung von Cybersicherheitsmaßnahmen auch von einer Minimierung der Angriffsfläche gesprochen.

Es ist daher sinnvoll, sich mit der Frage zu befassen, welche Gefahren und Angriffsarten von einem Angreifer je nach seinem Fachwissen ausgehen können. In Bild 16.1 sind eine mögliche Klassifizierung von Cyberangriffen auf KRITIS und entsprechende Beispiele basierend auf den Fähigkeiten eines Angreifers dargestellt (Bader 2023, Gaspar 2023).

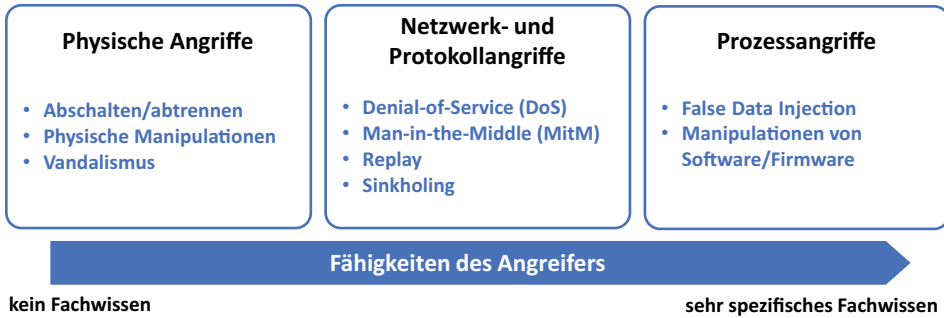


Bild 16.1 Klassifikation von Cyberangriffen in kritischen Infrastrukturen basierend auf den Fähigkeiten des Angreifers

Im Wesentlichen können drei verschiedene Angriffsklassen identifiziert werden, die jeweils unterschiedliche Fähigkeiten des Angreifers voraussetzen. Im Folgenden werden die Angriffsklassen kurz erläutert und Beispiele für jeweilige Angriffe gegeben.

Physische Angriffe

Bei physischen Angriffen hat der Angreifer direkten Zugriff auf ein Gerät oder eine Komponente der kritischen Infrastruktur, beispielsweise aufgrund unzureichender physischer Sicherheit (siehe Abschnitt 16.2.3). Selbst wenn ein Angreifer nur über wenig oder gar kein Fachwissen verfügt, kann er diesen Zugriff ausnutzen, um das Gerät oder die Komponente abzuschalten oder sogar zu beschädigen, was zu weitreichenden Folgen im Gesamtsystem führen kann. Meist sind solche Auswirkungen jedoch unbeabsichtigt, beispielsweise wenn das Motiv des Angreifers der Diebstahl von Kupferkabeln ist.



Beispiel: Sabotage des Kommunikationsnetzes der Deutschen Bahn

Am 8. Oktober 2022 wurde das Kommunikationsnetz der Deutschen Bahn sabotiert, als in Herne (NRW) und Berlin-Karow Datenleitungen durchtrennt wurden. Diese Leitungen bildeten zwei redundante Verbindungen für den Betrieb des GSM-R-Funknetzes der Deutschen Bahn, welches infolgedessen in weiten Teilen Norddeutschlands ausfiel. Als Konsequenz musste nahezu der gesamte Zugverkehr in Norddeutschland für etwa drei Stunden eingestellt werden. Obwohl neueste Erkenntnisse auf einen unglücklichen Zufall infolge von Kabeldiebstählen hindeuten,¹¹⁾ verdeutlicht dieses Beispiel auf eindrucksvolle Weise, dass selbst physische Angriffe wie die Durchtrennung von Leitungen durch die fortschreitende Digitalisierung und Vernetzung erhebliche Auswirkungen auf den Gesamtbetrieb haben können.

¹¹ <https://www.tagesschau.de/investigativ/bahn-ausfall-sabotage-kabel-diebstahl-100.html>

Netzwerk- und Protokollangriffe

Wenn der Angreifer über ein umfassendes Wissen in Bezug auf die verwendeten Kommunikationstechnologien verfügt, einschließlich der Netzwerke und Protokolle, kann er dieses Wissen nutzen, um mittels gezielter Cyberangriffe die Kommunikation zwischen verschiedenen Komponenten zu beeinträchtigen oder sogar vollständig zu unterbrechen. Hierbei werden oft spezifische Sicherheitslücken in den Kommunikationsprotokollen ausgenutzt, um beispielsweise Denial-of-Service-Angriffe (DoS) oder Man-in-the-Middle-Angriffe (MitM) durchzuführen. Diese Angriffe können die Prozesse der kritischen Infrastruktur indirekt beeinträchtigen, etwa wenn ein für den Betrieb essenzielles System nicht mehr erreichbar ist.

Prozessangriffe

Verfügt der Angreifer schließlich über umfangreiches Wissen bezüglich der Prozesse der kritischen Infrastruktur, kann er erheblichen Schaden anrichten. Dies kann beispielsweise durch sogenannte *False Data Injection* geschehen, also durch die gezielte Manipulation von Messwerten oder Befehlen in den übertragenen Prozessdaten. Eine weitere Möglichkeit besteht in der Übernahme von Steuergeräten, etwa durch Schadsoftware oder manipulierte Firmware. Darüber hinaus kann der Angreifer sein Prozesswissen nutzen, um den Angriff zu verschleiern. So kann er beispielsweise nach erfolgter Manipulation entsprechende Warnmeldungen von Überwachungsprozessen unterdrücken, was eine frühzeitige Erkennung des Angriffs erheblich erschweren kann.

Insgesamt zeigen diese Angriffsklassen eine breite Palette an Angriffsmöglichkeiten auf, selbst wenn der Angreifer nur über begrenztes Vorwissen verfügt. Während Angreifer mit wenig Fachkenntnissen eher einem ungezielten Angriffsmuster folgen und die Auswirkungen ihrer Angriffe daher auch von Zufällen abhängen können, gehen Angreifer mit spezifischem Wissen eher gezielt vor und führen sorgfältig geplante, mehrstufige Angriffe aus. Im folgenden Abschnitt wird erläutert, wie diese mehrstufigen Angriffe typischerweise ablaufen.

16.3.2 Vorgehen und Ablauf

Eine wertvolle Ressource zum besseren Verständnis des Ablaufs von Cyberangriffen im KRITIS-Bereich ist *MITRE ATT&CK for Industrial Control Systems* (Alexander 2020). Dieser Leitfaden der MITRE Corporation zur Analyse von Cyberangriffen in industriellen Netzwerken beschreibt die typischen Phasen eines solchen Angriffs, die auch als Taktiken (*Tactics*) bezeichnet werden, da sie für die Erreichung eines jeweiligen Zwischenziels stehen. Darüber hinaus werden den verschiedenen Phasen spezifische Angriffstechniken (*Techniques*) zugeordnet, die konkret beschreiben, wie das jeweilige Zwischenziel erreicht werden kann. Auf diese Weise kann jeder beliebige (reale) Cy-

berangriff anhand der verwendeten Angriffstechniken in seine individuellen Angriffsphasen unterteilt und Schritt für Schritt nachvollzogen werden. Die unterschiedlichen Angriffsphasen gemäß *MITRE ATT&CK for Industrial Control Systems* sind in Bild 16.2 dargestellt.

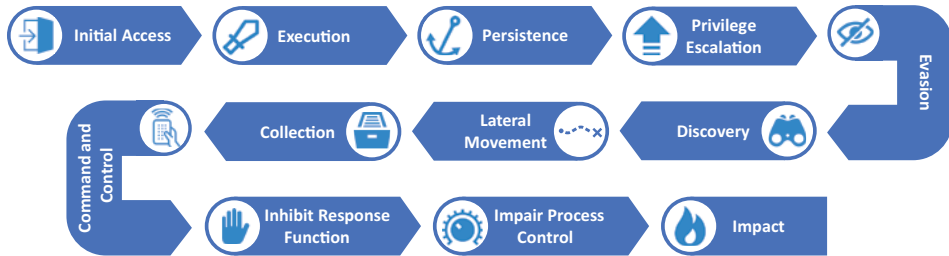


Bild 16.2 Angriffsphasen gemäß *MITRE ATT&CK for Industrial Control Systems*¹²⁾

Im Folgenden werden die verschiedenen Angriffsphasen erläutert und jeweils ein Beispiel für eine entsprechende Angriffstechnik gegeben:

1. **Initial Access:** Jeder Cyberangriff beginnt in der Regel mit einem ersten Einfallstor, von dem sich der Angriff dann weiterverbreitet und tiefer ins Netzwerk eindringt. Ein besonders relevantes Beispiel für eine Angriffstechnik im KRITIS-Umfeld ist *Spearphishing Attachment*, bei der in einer scheinbar plausiblen E-Mail an Mitarbeitende eine Malware im Anhang mitverschickt wird.
2. **Execution:** Befindet sich bösartiger Programmcode erst einmal im Netzwerk des Unternehmens, muss aus Sicht des Angreifers sichergestellt werden, dass dieser auch ausgeführt wird. Eine häufige Schwachstelle sind hier Fernwartungszugänge, wie beispielsweise Virtual Network Computing (VNC), die eine Steuerung des *Graphical User Interface* aus der Ferne ermöglichen. Sind diese schlecht abgesichert, können sie von einem Angreifer ausgenutzt werden, um Schadcode aus der Ferne auszuführen.
3. **Persistence:** Auch wenn ein bösartiger Programmcode nur einmalig ausgeführt wird, wird eines der ersten Ziele die Sicherstellung eines längerfristigen Zugriffs auf das Opfersystem sein. Ein Beispiel hierfür ist die Angriffstechnik *System Firmware*, bei der über die Updatefunktionalität einer Firmware versucht wird, eine veraltete Version der Firmware (mit bekannten Sicherheitslücken) oder eine manipulierte Firmware aufzuspielen.
4. **Privilege Escalation:** Nachdem ein Angreifer einen (begrenzten) Zugriff auf ein Opfersystem erlangt hat, wird er versuchen, seine Zugriffsrechte kontinuierlich zu erweitern. Bei der *Exploitation for Privilege Escalation* wird beispielsweise ver-

¹² <https://www.dragos.com/mitre-attack-for-ics/>

sucht, durch das Ausnutzen von Softwareschwachstellen einem Prozess, der ursprünglich mit eingeschränkten Zugriffsrechten gestartet wurde, erhöhte Zugriffsrechte zuzuweisen.

5. **Evasion:** Ein Angreifer wird zusätzlich versuchen, möglichst lange unentdeckt agieren zu können. Dies umfasst auch das aktive Verwischen von Spuren, etwa durch *Indicator Removal on Host*, also das Ändern, Löschen und Verstecken von Indikatoren für einen Angriff, die sich beispielsweise in den Logdateien des Opfer-systems befinden.
6. **Discovery:** Ausgehend von einem infizierten Opfersystem wird ein Angreifer versuchen, weitere lukrative Ziele zu identifizieren. Dies erfolgt beispielsweise durch *Network Sniffing*, also das Mitschneiden und Analysieren des Netzwerkverkehrs. Dieser Angriff wird begünstigt durch die Tatsache, dass im KRITIS-Umfeld Netzwerkverbindungen häufig unverschlüsselt sind, um die Verfügbarkeit nicht zu gefährden.
7. **Lateral Movement:** Sind lukrative Ziele einmal identifiziert, wird ein Angreifer als Nächstes versuchen, Zugriff auf diese Systeme zu erlangen, meist über lokale Netzwerkverbindungen. Eine mögliche Angriffstechnik ist *Valid Accounts*, bei der der Angreifer die Zugangsdaten von (lokalen) Benutzerkonten stiehlt oder beispielsweise auf Standardkombinationen von Benutzernamen und Passwörtern zurückgreift.
8. **Collection:** Um ein umfassendes Verständnis des Zusammenspiels der verschiedenen Systeme im kompromittierten Netzwerk zu bekommen, wird ein Angreifer möglichst viele Daten und Informationen sammeln. Mittels *Automated Collection* geschieht dies beispielsweise automatisiert mithilfe verschiedener Tools und Skripte.
9. **Command and Control:** Zur Erlangung der vollständigen Kontrolle über ein Zielsystem wird ein Angreifer einen dedizierten Befehls- und Kommunikationskanal zum System aufbauen. Eine gängige Angriffstechnik ist *Commonly Used Port*, bei der bereits offene Ports von legitimen Kommunikationsprotokollen für den Kommando- und Kommunikationskanal genutzt werden.
10. **Inhibit Response Function:** Für einen besonders effektiven Cyberangriff wird ein Angreifer im Vorfeld versuchen, Schutz- und Erkennungsmaßnahmen außer Kraft zu setzen. Ein Beispiel hierfür ist *Alarm Suppression*, bei dem Fehler- oder Alarmmeldungen für kritische Zustände vom Angreifer unterdrückt werden.
11. **Impair Process Control:** Ein häufiges Ziel von Cyberangriffen im KRITIS-Umfeld ist die Manipulation oder Übernahme von Prozesskontrollfunktionen. Aufgrund der oft fehlenden Authentifizierung in der Kommunikation können Angreifer beispielsweise mittels *Unauthorized Command Message*, also gefälschten Befehlsmeldungen, Prozesse negativ beeinflussen.

12. **Impact:** Schließlich zielen Cyberangriffe meist auf die Integrität und Verfügbarkeit des Gesamtsystems, wofür verschiedene Angriffstechniken existieren. *Damage to Property* beschreibt beispielsweise gezielte Aktionen, um Anlagen und Geräte zu beschädigen, zum Beispiel indem Messwerte manipuliert werden.

Obwohl die Phasen in der Regel aufeinander aufbauen, durchläuft ein Cyberangriff nicht zwangsläufig alle Phasen. Stimmt beispielsweise das Zielsystem des Angreifers mit dem ersten Einfallstor überein, wird kein *Lateral Movement* benötigt. Ebenso ist es möglich, dass innerhalb einer Phase mehrere Angriffstechniken zu Einsatz kommen, um das jeweilige Ziel zu erreichen.

MITRE ATT&CK for Industrial Control Systems bietet nicht nur ein verbessertes Verständnis für den Ablauf von Cyberangriffen, sondern ermöglicht auch die Bewertung der Wirksamkeit bestehender IT-Sicherheitskonzepte hinsichtlich der Abdeckung verschiedener Angriffsphasen und -techniken. Diese Überprüfung kann auch praktisch durchgeführt werden, beispielsweise mittels eines Penetrationstests. Zudem kann die Erkennung von Cyberangriffen durch die Nutzung von *MITRE ATT&CK for Industrial Control Systems* verbessert werden. Effektives Erkennen komplexer Angriffe in den frühen Phasen ermöglicht es, rechtzeitig geeignete Gegenmaßnahmen zu ergreifen, um so größere Schäden am Gesamtsystem zu verhindern. Darüber hinaus wird der Leitfaden kontinuierlich aktualisiert und durch die Integration neuester Angriffstechniken erweitert.

Zusammenfassend lässt sich festhalten, dass eine Sicherheitsbewertung aus der Perspektive von potenziellen Angreifern ein unverzichtbares Werkzeug für die Stärkung der Cybersicherheit im Bereich kritischer Infrastrukturen darstellt. Dies erfordert eine gründliche Analyse der Fähigkeiten und Motive potenzieller Angreifer sowie ein detailliertes Verständnis der verschiedenen Phasen und Techniken von Cyberangriffen. Hierbei erweist sich der Leitfaden *MITRE ATT&CK for Industrial Control Systems* als äußerst hilfreich. Er bietet wertvolle Einblicke in die Funktionsweise von Cyberangriffen auf industrielle Netzwerke und trägt maßgeblich dazu bei, die Erkennung und Abwehr solcher Angriffe signifikant zu verbessern.

16.4 Gegenmaßnahmen

Nachdem ein gründliches Verständnis für mögliche Schwachstellen und Sicherheitsrisiken erlangt wurde, ist es entscheidend, diese gezielt durch geeignete Maßnahmen anzugehen, um die Resilienz des Gesamtsystems zu stärken. Die Auswahl und Implementierung konkreter Maßnahmen sind dabei individuell abhängig von der eingesetzten Hardware und Software, der Netzwerktopologie sowie den implementierten Prozessen. Dennoch können auf einer übergeordneten Ebene Konzepte und Ziele definiert werden, um eine umfassende Cybersicherheit zu gewährleisten. Ein möglicher

Ansatz dafür ist in Bild 16.3 dargestellt. Es zeigt, wie durch einen kontinuierlichen Kreislauf aus Prävention, Detektion und Reaktion die Resilienz gegenüber Cyberangriffen gestärkt werden kann.

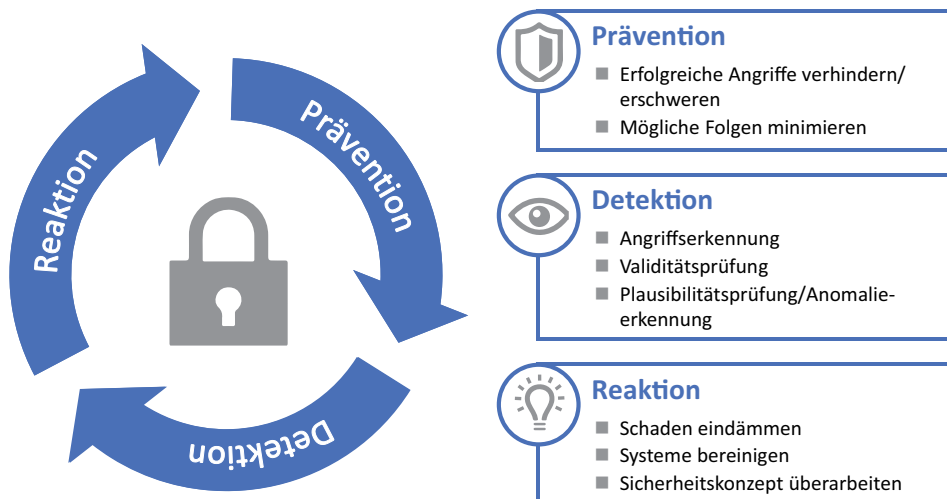


Bild 16.3 Cybersicherheit als Kreislauf aus Prävention, Detektion und Reaktion

In diesem Zusammenhang bedeutet Prävention, dass Cyberangriffe bereits im Vorfeld verhindert oder zumindest erschwert werden sollen. Dies umfasst präventive Maßnahmen, die darauf abzielen, das Ausmaß möglicher Cyberangriffe zu reduzieren, beispielsweise durch einen *Defense-in-Depth-Ansatz*. Trotz aller Bemühungen ist es jedoch äußerst unwahrscheinlich, dass Cyberangriffe vollständig durch präventive Maßnahmen verhindert werden können. Fehler bei der Umsetzung dieser Maßnahmen und die Entstehung neuer Schwachstellen sind nicht auszuschließen. Daher sind geeignete Methoden zur Erkennung laufender Cyberangriffe unverzichtbar. Schließlich ermöglicht eine frühzeitige Detektion durch angemessene reaktive Maßnahmen, Schäden zu begrenzen und Schlimmeres zu verhindern. Darüber hinaus umfasst die Reaktion auf einen Angriff neben einer gründlichen Aufklärung und Analyse des Vorfalls auch die Überarbeitung der bisherigen Sicherheitskonzepte, um nahtlos wieder in die Präventionsphase überzugehen.

Daher ist die wichtigste Erkenntnis aus diesem Kreislauf, dass die Stärkung der Resilienz niemals abgeschlossen ist. Es handelt sich vielmehr um einen fortlaufenden Prozess, der aktiv durch die Umsetzung und Überarbeitung entsprechender Cybersicherheitsmaßnahmen gestaltet werden muss. Im Folgenden werden solche Maßnahmen anhand des dargestellten Cybersicherheitszyklus erläutert und durch geeignete Beispiele für den KRITIS-Bereich veranschaulicht.

16.4.1 Prävention

Bei der Prävention von Cyberangriffen steht primär die Minimierung der Angriffsfläche im Vordergrund. Dies bedeutet, dass geeignete Maßnahmen ausgewählt und umgesetzt werden, um mögliche Angriffe zu erschweren und ihre potenziellen Auswirkungen einzuschränken. Letzteres bezieht auch die Vorbereitung auf erfolgreiche Cyberangriffe mit ein, beispielsweise durch die Erstellung eines Notfallplans. Von zentraler Bedeutung für die Prävention ist die Entwicklung eines umfassenden IT-Sicherheitskonzepts, das den Bedarf an präventiven Maßnahmen analysiert und deren Umsetzung regelt. Im Folgenden werden der Zweck und die Erstellung eines solchen IT-Sicherheitskonzepts näher erläutert.

Erstellung eines IT-Sicherheitskonzepts

Insbesondere für kritische Infrastrukturen ist die Erstellung eines IT-Sicherheitskonzepts unerlässlich. Das Ziel eines solchen Konzepts besteht darin, präventive Cybersicherheitsmaßnahmen möglichst umfassend und optimal aufeinander abgestimmt umzusetzen. Dies umfasst sowohl technische Maßnahmen wie die Konfiguration einer Firewall als auch organisatorische Maßnahmen wie die Schulung von Mitarbeitenden. Eine enge Abstimmung mit bereits vorhandenen Sicherheitskonzepten ist ebenfalls sinnvoll, da entsprechende Anforderungen und Maßnahmen sich auch auf die Cybersicherheit auswirken können. Insbesondere im KRITIS-Bereich ist dies in Bezug auf die physische Sicherheit relevant, beispielsweise reduziert der Einsatz von Zutrittskontrollen auch die Wahrscheinlichkeiten gewisser Angriffsvektoren.

Die Erstellung eines IT-Sicherheitskonzepts sollte folgende Schritte umfassen:

1. **Ziele:** Einen ersten Schritt stellt die Definition der konkreten Ziele des IT-Sicherheitskonzepts dar, die auf eine individuelle Gewichtung der verschiedenen Schutzziele aufbaut.
2. **Risiken und Bedrohungen:** Es sollte eine spezifische Bewertung der Risiken und Bedrohungen durch Cyberangriffe basierend auf der Unternehmensstruktur, der vorhandenen IT-Infrastruktur und der Abhängigkeit zu externen Dienstleistern und Zulieferern vorgenommen werden.
3. **Aktueller Stand:** Durch eine präzise Bestandsaufnahme muss geklärt werden, welche präventiven Sicherheitsmaßnahmen bereits umgesetzt wurden und inwieweit definierte Ziele bereits adressiert werden.
4. **Definition neuer Maßnahmen:** Basierend auf dem aktuellen Stand können die notwendigen präventiven Maßnahmen zur Erreichung aller Ziele definiert werden. Zusätzlich kann eine Priorisierung anhand der identifizierten Risiken und Bedrohungen erfolgen.

5. **Umsetzung und Zeitplan:** Die notwendigen Schritte zur Umsetzung der neuen Maßnahmen sollten geplant und ein realistischer Zeitplan erstellt werden.
6. **Informationen und Schulungen:** Die betreffenden Mitarbeitenden sollten über bestehende und neue Maßnahmen informiert werden, beispielsweise durch regelmäßige Awareness-Schulungen.
7. **Aktualisierungen:** Das IT-Sicherheitskonzept sollte regelmäßig überprüft und aktualisiert werden, wobei externe Audits in Betracht gezogen werden sollten.

Ein verbreitetes Missverständnis bezüglich präventiver Maßnahmen besteht darin, dass sie sich ausschließlich auf defensive Methoden beschränken. Stattdessen ist es sinnvoll, sie durch geeignete offensive Methoden zu ergänzen, wie im folgenden Abschnitt näher erläutert wird.

Proaktive Identifizierung und Behebung von Schwachstellen

Durch eine aktive Suche nach Schwachstellen können diese zeitnah behoben und bestehende Schutzmaßnahmen kontinuierlich verbessert und erweitert werden. Hierbei sind insbesondere Penetrationstests (*Pentests*) von Nutzen. Bei Pentests wird in der Regel ein externes Unternehmen beauftragt, unter Einhaltung vorab festgelegter Regeln, in das interne Netzwerk einzudringen und so Schwachstellen praxisnah zu identifizieren. Pentests können auf verschiedene Arten durchgeführt werden. Eine wesentliche Entscheidung betrifft die vorab bereitgestellten Informationen für die „Angreifer“. Hierbei wird zwischen Blackbox, Greybox und Whitebox unterschieden. Während ein Blackbox-Ansatz, bei dem den Angreifern keinerlei Informationen zur Verfügung gestellt werden, einem realen Cyberangriff ähnelt, kann ein Greybox-Ansatz, also die teilweise Bereitstellung von Informationen, sinnvoll sein, um den Test zu optimieren oder den Fokus auf bestimmte Aspekte zu legen. Ebenso kann eine vollständige Bereitstellung von Informationen im Rahmen eines Whitebox-Ansatzes für die Bewertung von Worst-Case-Szenarien geeignet sein. Darüber hinaus können gewisse Pentests teilweise oder vollständig automatisiert werden, beispielsweise durch das automatisierte Scannen offener Ports. Insgesamt sagt jedoch ein Pentest nur etwas über die aufgedeckten Sicherheitslücken aus und kann daher keine Garantien in Bezug auf die Cybersicherheit liefern.

Des Weiteren sollten alle Systeme und Anlagen durch regelmäßiges Einspielen von Sicherheitsupdates (*Patches*) geschützt werden. Dies stellt gerade in kritischen Infrastrukturen eine besondere Herausforderung dar. Einerseits bieten ältere Geräte mit langen Lebenszyklen möglicherweise keine Aktualisierungsfunktionalität, während andererseits jedes Update sorgfältig geplant werden muss, um die Gesamtverfügbarkeit der Systeme nicht zu gefährden (siehe Abschnitt 16.2). Die Vielzahl der eingesetzten Geräte erfordert zudem ein systematisches Patch-Management, um notwendige Updates zu identifizieren, zu priorisieren und zu testen. Dies erfordert sowohl Fachpersonal als auch automatisierte Lösungen, die das Fachpersonal unterstützen und entlasten.

Ein praktisches Fundament für ein solches automatisiertes Patch-Management bietet das vom BSI mitentwickelte *Common Security Advisory Framework (CSAF) 2.0*.¹³ Es wandelt die Informationen zu gefundenen Schwachstellen (*Security Advisories*) der Hersteller in ein standardisiertes, maschinenlesbares Format um. Auf diese Weise entstehen einheitliche, zentralisierte Datenbanken über die *Security Advisories*, die automatisch mit der eigenen Inventardatenbank abgeglichen und priorisiert werden können.

Besonders für eingebettete Systeme kann es jedoch herausfordernd sein, Informationen über die verwendete Geräte-Firmware und potenzielle Schwachstellen zu erhalten. Hier bieten sich systematische Analysen der eingesetzten Firmware an, etwa mit dem *Firmware Analysis and Comparison Tool (FACT)*.¹⁴ In einem ersten Schritt entpackt FACT die zu untersuchende Geräte-Firmware und stellt automatisiert Informationen zu den verwendeten Softwareversionen bereit. Dann ermöglicht FACT die Überprüfung der Firmware auf bekannte Schwachstellen, gängige Programmierfehler und hartkodierte Passwörter. Somit kann FACT dazu genutzt werden, Firmware-Updates vor dem Einspielen auf potenzielle (neue) Sicherheitslücken zu überprüfen und gegebenenfalls Nachbesserungen einzufordern oder eigene Sicherheitsmaßnahmen nachzurüsten.



Hinweis: *Security by Design* versus *Security by Default*

Obwohl die beiden Präventionskonzepte *Security by Design* und *Security by Default* ähnliche Ziele verfolgen, ergänzen sie sich in ihrer praktischen Umsetzung und verstärken einander sogar.

Security by Design zielt darauf ab, die Einbindung und Umsetzung von Cybersicherheit bereits bei der Konzeptionierung neuer Funktionalitäten zu berücksichtigen. Dies hat den Vorteil, dass essenzielle Cybersicherheitsfeatures später nicht nachgerüstet werden müssen, was oft schwierig oder sogar unmöglich ist. Stattdessen wird Cybersicherheit von Anfang an über den gesamten Lebenszyklus eines Systems mitgedacht, indem beispielsweise die regelmäßige Aktualisierung der Sicherheitsfunktionen ermöglicht wird.

Security by Default bedeutet hingegen, dass Systeme und Anlagen standardmäßig mit den höchstmöglichen Sicherheitseinstellungen betrieben werden. Zum Beispiel wäre bei einem Fernwartungszugang standardmäßig eine Zwei-Faktor-Authentifizierung (2FA) aktiviert. Dies soll unter anderem sicherstellen, dass vorhandene Sicherheitsfunktionen nicht aus Bequemlichkeit deaktiviert bleiben, sondern diese bereits bei Inbetriebnahme aktiv sind und nur aus gutem Grund deaktiviert werden dürfen.

¹³ https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Informationen-und-Empfehlungen/Empfehlungen-nach-Angriffszielen/Industrielle-Steuerungs-und-Automatisierungssysteme/CSAF/CSAF_node.html

¹⁴ <https://www.fkie.fraunhofer.de/de/forschungsabteilungen/cad/FACT.html>

16.4.2 Detektion

Neben der Implementierung präventiver Cybersicherheitsmaßnahmen ist es ebenso wichtig, Maßnahmen zur Erkennung laufender Cyberangriffe umzusetzen. Das Ziel besteht darin, Cyberangriffe frühzeitig in ihren ersten Phasen zu erkennen (siehe Abschnitt 16.3.2), damit durch entsprechende Gegenmaßnahmen der Angriff gestoppt werden kann und negative Auswirkungen begrenzt werden. Außerdem sind KRITIS-Betreiber seit dem 1. Mai 2023 gemäß dem IT-Sicherheitsgesetz 2.0 verpflichtet, Systeme zur Angriffserkennung (SzA) einzusetzen (siehe Abschnitt 16.1.2). Das BSI bietet hierzu eine Orientierungshilfe an,¹⁵ in der auch die Mindestanforderungen an ein SzA erläutert werden. Im Folgenden werden gängige Methoden zur Detektion von Cyberangriffen in kritischen Infrastrukturen kurz vorgestellt.

Intrusion-Detection-Systeme

Intrusion-Detection-Systeme (IDS) sind entscheidende Instrumente zur Erkennung von Cyberangriffen. Grundsätzlich wird zwischen *host-based* IDS und *network-based* IDS unterschieden. Während erstere als Anwendung auf einem Computersystem laufen, um dort Cyberangriffe zu erkennen, überwachen letztere den Netzwerkverkehr, also die Kommunikation zwischen mehreren Systemen. Hierzu werden in der Regel verschiedene Sensoren des IDS an strategisch wichtigen Stellen im Netzwerk platziert, beispielsweise an Übergangspunkten zwischen Netzwerken, um ein möglichst umfassendes Bild des Netzwerkverkehrs zu erhalten.

Des Weiteren wird prinzipiell zwischen zwei Erkennungsmethoden unterschieden. *Signature-based* IDS suchen nach spezifischen Mustern oder Signaturen, die auf bekannte Angriffe oder Schwachstellen hinweisen. Diese Signaturen müssen kontinuierlich mit den neuesten Informationen zu bekannten Angriffen aktualisiert werden. *Anomaly-based* IDS können hingegen auch unbekannte Angriffe entdecken, indem sie Abweichungen vom normalen Verhalten des Systems oder Netzwerks erkennen, beispielsweise durch den Einsatz von maschinellem Lernen. Allerdings erfordern anomaly-based IDS eine intensive Konfiguration und Betreuung, da sie ansonsten unter niedrigen Erkennungsraten (*false negatives*) oder hohen Fehlalarmen (*false positives*) leiden.

In industriellen Netzen, die häufig Teil von kritischen Infrastrukturen sind, bietet das typischerweise deterministische Prozessverhalten einen zusätzlichen Ansatz für anomaly-based IDS. So können vergleichsweise einfache Metriken wie die Zeit zwischen bestimmten Übertragungen oder Diskrepanzen in den übertragenen Messwerten genutzt werden, um Abweichungen vom Normalzustand zu erkennen (Wolsing 2022). Solche Abweichungen könnten ein erster Indikator für einen Cyberangriff sein.

¹⁵ <https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KRITIS/oh-sza.html>

Honeypots

Die Idee eines Honeypots besteht darin, potenzielle Angreifer durch ein äußerst attraktives Scheinziel anzulocken. Dies dient dazu, um von anderen (realen) Zielen abzulenken und laufende Cyberangriffe frühzeitig zu erkennen. Typischerweise wird dies erreicht, indem ein Produktivsystem detailgetreu nachgebildet wird, sei es als physisches oder virtuelles System, und dieses dann ins Netzwerk integriert wird. Meistens werden bewusst offensichtliche Sicherheitslücken eingebaut, um den Honeypot besonders attraktiv erscheinen zu lassen. Der Honeypot wird dann sorgfältig überwacht und kann neben einer frühzeitigen Angriffserkennung auch Einblicke in die Fähigkeiten des Angreifers liefern. Dies kann beispielsweise erreicht werden, indem unterschiedlich komplexe Schutzmechanismen implementiert werden.

Es ist jedoch wichtig zu beachten, dass Honeypots nur eine punktuelle Detektion von Cyberangriffen bieten und auch nicht die Anforderungen des BSI an ein SzA erfüllen. Daher sollten sie lediglich als sinnvolle Ergänzung zu umfassenderen Detektionsmaßnahmen betrachtet werden. Zudem erfordern sie einen relativ hohen Wartungsaufwand, da sie kontinuierlich angepasst und aktualisiert werden müssen, um weiterhin von Produktivsystemen schwer unterscheidbar zu sein. Dies ist einer der Hauptgründe, warum einerseits neue Honeypots immer weniger eingesetzt werden und andererseits bestehende Honeypots zunehmend veraltet sind.¹⁶⁾ Dennoch könnten Fortschritte im Bereich der künstlichen Intelligenz neuen Schwung in die Entwicklung von Honeypots bringen, indem dynamischere Varianten geschaffen werden, die sich automatisch an ihre Umgebung anpassen.



Hinweis: Security Operations Center (SOC)

Größere Unternehmen, insbesondere im KRITIS-Bereich, zentralisieren häufig ihre Cybersicherheitsabwehr in einem *Security Operations Center (SOC)*. Die Hauptaufgabe des SOC besteht darin, Cyberangriffe frühzeitig zu erkennen und die erforderlichen Maßnahmen zur Abwehr oder zumindest zur Minderung ihrer Auswirkungen zu koordinieren. Zu diesem Zweck analysieren Cybersicherheitsexperten die Alarmmeldungen und Log-Events verschiedener Sicherheitssysteme wie Firewalls, IDS und Virenschannern. Oftmals werden sie bei dieser Echtzeitanalyse durch ein *Security Information and Event Management (SIEM)* unterstützt, das eingehende Meldungen zentralisiert sammelt und grundlegende Korrelationen und Analysen durchführt. Eine bedeutende Herausforderung in einem SOC besteht jedoch typischerweise in der hohen Anzahl von Fehlalarmen, die zu einer starken Beanspruchung des Fachpersonals führt (Alahmadi 2022).

¹⁶ <https://www.infosecurity-magazine.com/opinions/embrace-dynamic-honeypots-outpace/>

16.4.3 Reaktion

Sobald ein laufender Cyberangriff detektiert wurde, muss umgehend durch geeignete Maßnahmen darauf reagiert werden. Ziel ist es, den Cyberangriff zu stoppen, seine Auswirkungen einzudämmen und möglichst rasch wieder zum Normalbetrieb zurückzukehren. Neben der gründlichen Bereinigung der Systeme ist es besonders wichtig, durch eine Überarbeitung des IT-Sicherheitskonzepts (siehe Abschnitt 16.4.1) und die Implementierung angepasster präventiver Maßnahmen einen Folgeangriff zu verhindern. Im Folgenden werden die wichtigsten Schritte für eine effektive Reaktion kurz vorgestellt und durch passende Beispiele veranschaulicht.

Incident Response

Besteht der Verdacht auf einen Cyberangriff, muss dieser umfassend aufgeklärt werden, um Art und Umfang des Angriffs zu ermitteln und geeignete Maßnahmen zur Behebung des Vorfalls und zur Minimierung von Schäden einzuleiten. Es ist entscheidend, trotz anfänglicher Desorientierung schnell ein strukturiertes Krisenmanagement zu etablieren und vorhandene Notfallpläne systematisch umzusetzen. Zur ersten Lageeinschätzung sollten folgende Fragen so weit wie möglich geklärt werden:

- Was ist passiert?
- Welche Daten wurden kompromittiert?
- Welche Systeme sind (noch) betroffen?
- Welche Werkzeuge wurden verwendet?
- Welche Indikatoren für den Angriff gibt es?
- Wer steckt dahinter?
- Welche Maßnahmen sind erforderlich?
- Wer hat Schuld?

Parallel dazu sollten erste Gegenmaßnahmen eingeleitet werden, um den laufenden Cyberangriff zu unterbinden. Dazu gehören, unter anderem, die Abschaltung von Systemen und Diensten, die Isolierung von Netzsegmenten und Geräten und die Blockierung verdächtigen Netzwerkverkehrs. Anschließend müssen die gesetzlichen Meldepflichten beachtet werden, da je nach Vorfall und betroffenem Unternehmen eine unverzügliche Meldung zu erfolgen hat (siehe Abschnitt 16.1.2).

Nach diesen unmittelbaren Maßnahmen ist es entscheidend, den Vorfall gründlich zu untersuchen, möglicherweise in Kooperation mit den zuständigen Behörden und externen Fachleuten. Dies beinhaltet vor allem eine eingehende forensische Analyse der kompromittierten Geräte und Netzwerke. Hierbei werden insbesondere Systemprotokolle, Logdateien und Netzwerkaktivitäten untersucht, einschließlich einer de-

taillierten Analyse des Binärcodes der eingesetzten Malware, sofern verfügbar. Das Hauptziel dieser forensischen Untersuchung besteht darin, den Angriffspfad, die ausgenutzten Schwachstellen und die eingesetzten Werkzeuge zu identifizieren. Die gewonnenen Erkenntnisse können zur Zuordnung von Angriffen zu Angreifern oder Angriffskampagnen dienen. Darüber hinaus können identifizierte Sicherheitslücken, sogenannte *Common Vulnerabilities and Exposures (CVEs)*, gemeldet werden, um potenzielle weitere Opfer zu warnen. Diese Erkenntnisse sind auch entscheidend für die Stärkung der Resilienz, indem vorhandene Schwachstellen geschlossen werden, um Folgeangriffe zu verhindern. Dies impliziert auch eine Überarbeitung des IT-Sicherheitskonzepts und schließt sich somit nahtlos an die Prävention an.



Hinweis: Meldung von IT-sicherheitsrelevanten Vorfällen

Die Meldung eines IT-sicherheitsrelevanten Vorfalls an das BSI bedarf grundsätzlich keiner spezifischen Form und kann auf verschiedenen Wegen erfolgen, etwa per E-Mail oder Telefon. Dennoch empfiehlt es sich, das Melde- und Informationsportal (MIP)¹⁷ des BSI zu nutzen, da es den Meldenden dabei unterstützt, alle relevanten Informationen zum Vorfall anzugeben. Dadurch wird eine schnellere und effektivere Verarbeitung durch das BSI ermöglicht. Eine vollständige Meldung umfasst üblicherweise die folgenden Punkte:

- Angaben zum betroffenen Unternehmen und der Ansprechperson
- Allgemeine Informationen zum Vorfall
- Ursache der Störung
- Falls zutreffend: detaillierte Informationen zum Angriffsverlauf
- Status bezüglich der Einbindung von Strafverfolgungsbehörden
- Eingeleitete oder geplante Gegenmaßnahmen

Die aufgeworfenen Fragen sollten möglichst präzise beantwortet werden, damit das BSI die Lage zutreffend einschätzen kann. Daher bietet es sich an, im Rahmen von Cybersicherheitstrainings auch das Erstellen von Erst-, Folge- und Abschlussmeldungen an das BSI zu üben. Hierfür bietet das MIP die Erstellung von Testmeldungen an, die in der Regel vom BSI auch kurz quittiert werden.

Cybersicherheitstrainings

Obwohl eine effektive Reaktion auf einen Cyberangriff stark von der Dynamik und den individuellen Umständen des jeweiligen Vorfalls abhängt, ist es dennoch unerlässlich, den Ernstfall regelmäßig zu trainieren. Cybersicherheitstrainings für Mitarbeitende bieten hierbei eine Möglichkeit, die Abläufe im Angriffsfall durch praktische Übungen zu trainieren und somit schneller und zielsicherer reagieren zu können. Darüber hinaus können diese Trainings dabei helfen, Lücken und veraltete Informationen in den Notfallplänen zu identifizieren, damit sie kontinuierlich verbessert werden können. Streng genommen handelt es sich bei der Durchführung von Cyber-

¹⁷ <https://mip2.bsi.bund.de>

sicherheitstrainings um eine präventive Maßnahme, die im IT-Sicherheitskonzept definiert sein sollte. Allerdings sind hier nicht reine Security-Awareness-Schulungen gemeint, die vor allem auf die korrekte Umsetzung der IT-Sicherheitsrichtlinien des Unternehmens abzielen, um so Cyberangriffe zu verhindern. Vielmehr geht es darum, die Mitarbeitenden auf die Bewältigung einer Krisensituation in Form eines praktischen Trainings vorzubereiten.

Eine bewährte Methode für solche Cybersicherheitstrainings ist *Red Team versus Blue Team*, bei der die Teilnehmenden in zwei Gruppen aufgeteilt werden: Das Red Team übernimmt die Rolle der Angreifer, während das Blue Team die Verteidiger stellt. Demnach versucht das Red Team, durch die Ausnutzung von Schwachstellen in das interne Netzwerk einzudringen und Cyberangriffe zu initiieren, während das Blue Team durch geeignete Gegenmaßnahmen versucht, dies zu verhindern. Ein wesentlicher Aspekt für die Durchführung solcher Cybersicherheitstrainings ist die Bereitstellung einer sicheren, aber dennoch realistischen Trainingsumgebung. Insbesondere bei kritischen Infrastrukturen können solche Trainings nicht innerhalb der Produktionssysteme durchgeführt werden. Stattdessen bieten sich Laboraufbauten an, die durch entsprechende Simulationen erweitert werden, um alle relevanten Teile der kritischen Infrastruktur detailgetreu nachzubilden. Ein Beispiel hierfür ist der Open-Source Co-Simulator Wattson,¹⁸⁾ der die Simulation eines konfigurierbaren Stromnetzes sowie die Emulation des dazugehörigen Kommunikationsnetzes ermöglicht. Auf diese Weise können reale Cyberangriffe und Gegenmaßnahmen sicher erprobt werden.

16.5 Fazit

Kritische Infrastrukturen (KRITIS) spielen eine zentrale Rolle im reibungslosen Funktionieren moderner Gesellschaften und bedürfen daher eines besonderen Schutzes vor Störungen, Ausfällen und Cyberangriffen. Die fortschreitende Vernetzung und Digitalisierung der letzten Jahrzehnte erhöhen jedoch ihre Anfälligkeit für Cyberangriffe. Dieser Herausforderung begegnet die Politik einerseits durch strengere Vorgaben und Verpflichtungen zur Cybersicherheit für KRITIS-Betreiber. Andererseits werden die Sektoren und Unternehmen, die unter diese KRITIS-Regulierungen fallen, kontinuierlich erweitert, wodurch die nachweisliche Umsetzung von Cybersicherheitsmaßnahmen für eine wachsende Anzahl von Unternehmen relevant wird. Letztlich ist eine effektive Cybersicherheit auch für KRITIS-Betreiber von größtem Interesse, um die Betriebssicherheit und Verfügbarkeit ihrer Systeme und Anlagen zu gewährleisten und damit Schäden, Umsatzeinbußen sowie Reputationsverluste zu vermeiden.

¹⁸⁾ <https://wattson.it>

Ein erster Schritt zur Stärkung der Resilienz gegenüber Cyberangriffen besteht darin, ein fundiertes Verständnis für potenzielle Schwachstellen, die verschiedenen Angriffsphasen und die verwendeten Techniken zu entwickeln. Auf dieser Grundlage können umfassende Cybersicherheitsmaßnahmen konzipiert und umgesetzt werden. Dabei ist es entscheidend, eine holistische Herangehensweise zu verfolgen, die gleichermaßen die Prävention vor, Detektion von und Reaktion auf Cyberangriffe berücksichtigt. Dieser Dreiklang muss als ein fortlaufender Kreislauf verstanden werden, der kontinuierlich verbessert und erweitert werden muss, um auch gegen zukünftige Cyberangriffe gewappnet zu sein.

16.6 Die wichtigsten Punkte in Kürze

- Kritische Infrastrukturen sehen sich zunehmend Cyberangriffen ausgesetzt, die teilweise verheerende Auswirkungen haben. Die Bedrohungen gehen dabei sowohl von externen Akteuren als auch von sogenannten Innentätern aus.
- Die Politik begegnet dieser neuen Bedrohungslage durch verschärfte Regulierungen und Pflichten für KRITIS-Betreiber, um insgesamt die Cybersicherheit von kritischen Infrastrukturen zu stärken.
- Als erste Schritte zur Umsetzung angemessener Cybersicherheitsmaßnahmen ist es entscheidend, die spezifischen Herausforderungen kritischer Infrastrukturen zu berücksichtigen und ein grundlegendes Verständnis für die Motive und Methoden potenzieller Angreifer zu entwickeln.
- Insgesamt sollte ein holistischer Ansatz verfolgt werden, der Prävention, Detektion und Reaktion gleichermaßen berücksichtigt, um die Resilienz gegenüber Cyberangriffen zu stärken und Schäden zu begrenzen.
- Prävention zielt darauf ab, die Angriffsfläche durch Awareness, IT-Sicherheitskonzepte und aktive Schwachstellensuche und -behebung zu minimieren.
- Detektion beinhaltet die zeitnahe und effektive Erkennung laufender Cyberangriffe, beispielsweise durch domänenspezifische Systeme zur Angriffserkennung.
- Reaktion umfasst die Umsetzung von Gegenmaßnahmen, die gründliche Untersuchung des Cyberangriffs und die geordnete Wiederherstellung des Normalbetriebs.
- Dieser Dreiklang muss als ein kontinuierlicher Prozess verstanden werden, der fortlaufend verbessert und erweitert werden muss, um auch gegen zukünftige Cyberangriffe gewappnet zu sein. Dies erfordert eine regelmäßige Überprüfung und Anpassung der Strategien und Maßnahmen an sich verändernde Bedrohungsszenarien und Technologien.

Literatur

- Alahmadi, Bushra A.; Axon, Louise; Martinovic, Ivan: „99 % False Positives: A Qualitative Study of SOC Analysts' Perspectives on Security Alarms“. In: *31st USENIX Security Symposium (USENIX Security 22)*, (2022).
- Alanazi, Manar; Mahmood, Abdun; Chowdhury, Mohammad Javed Morshed: „SCADA vulnerabilities and attacks: A review of the state-of-the-art and open issues“. In: *Computers & Security*, 125 (2023).
- Alexander, Otis; Belisle, Misha; Steele, Jacob: „MITRE ATT&CK for Industrial Control Systems: Design and Philosophy“. The MITRE Corporation: Bedford, MA, USA 29 (2020).
- Ani, Uchenna P. Daniel; He, Hongmei; Tiwari, Ashutosh: „Review of cybersecurity issues in industrial critical infrastructure: manufacturing in perspective“. In: *Journal of Cyber Security Technology*, 1, no. 1 (2017), S. 32 – 74.
- Babeshko, Ievgen; Di Giandomenico, Felicita: „Safety and Cybersecurity Assessment Techniques for Critical Industries: A Mapping Study“. In: *IEEE Access*, 11 (2023).
- Bader, Lennart; Serror, Martin; Lamberts, Olav; Sen, Ömer; van der Velde, Dennis; Hacker, Immanuel; Filter, Julian; Padilla, Elmar; Henze, Martin: „Comprehensively Analyzing the Impact of Cyberattacks on Power Grids“. In: *IEEE 8th European Symposium on Security and Privacy (EuroS&P)*, (2023).
- Bundesamt für Sicherheit in der Informationstechnik (BSI): „Die Lage der IT-Sicherheit in Deutschland 2023“. (2023).
- Gaspar, José; Cruz, Tiago; Lam, Chan-Tong; Simões, Paulo: „Smart Substation Communications and Cybersecurity: A Comprehensive Survey“. In: *IEEE Communications Surveys & Tutorials*, 25, Nr. 4 (2023).
- Kayan, Hakan; Nunes, Matthew; Rana, Omer; Burnap, Pete; Perera, Charith: „Cybersecurity of Industrial Cyber-Physical Systems: A Review“. In: *ACM Computing Surveys (CSUR)*, 54, Nr. 11 s (2022).
- Krause, Tim; Ernst, Raphael; Klaer, Benedikt; Hacker, Immanuel; Henze, Martin: „Cybersecurity in Power Grids: Challenges and opportunities“. In: *Sensors*, 21, Nr. 18 (2021), 6225.
- Kushner, David: „The Real Story of Stuxnet“. In: *IEEE Spectrum*, 50, Nr. 3 (2013), S. 48 – 53.
- Makrakis, Georgios Michail; Koliass, Constantinos; Kambourakis, Georgios; Rieger, Craig; Benjamin, Jacob: „Industrial and Critical Infrastructure Security: Technical Analysis of Real-Life Security Incidents“. In: *IEEE Access*, 9 (2021), S. 165 295 – 165 325.
- Serror, Martin; Hack, Sacha; Henze, Martin; Schuba, Marko; Wehrle, Klaus: „Challenges and Opportunities in Securing the Industrial Internet of Things“. In: *IEEE Transactions on Industrial Informatics*, 17, Nr. 5 (2020).
- Serror, Martin; Martini, Peter: „Wie Cybersicherheit in der Energieversorgung gelingen kann“. In: *Ökologisches Wirtschaften – Fachzeitschrift*, 38, Nr. 2 (2023), S. 26 – 27.
- Wolsing, Konrad; Thiemt, Lea; van Sloun, Christian; Wagner, Eric; Wehrle, Klaus; Henze, Martin: „Can Industrial Intrusion Detection Be SIMPLE?“. In: *European Symposium on Research in Computer Security*, Cham: Springer Nature Switzerland, (2022), S. 574 – 594.

**In diesem Beitrag erfahren Sie,**

- welche Sicherheitsfragen und -maßnahmen für Cloud-Computing spezifisch sind,
- welche Aspekte bei der Umsetzung besonders berücksichtigt werden müssen und
- welche Anforderungen IT-Verantwortliche dabei erfüllen sollten.

17.1 Einleitung

Cloud-Computing hat sich in den letzten 15 Jahren zu einem festen Bestandteil jeder Unternehmens-IT entwickelt. Dafür gab es eine Reihe von Gründen, welche durchaus von Unternehmen zu Unternehmen verschieden waren und in der Konsequenz auch zu unterschiedlichen Ansätzen in der Umsetzung geführt haben. Eine frühe bedarfsgetriebene Phase der punktuellen Integration wurde abgelöst von einer gesamtheitlichen Analyse von Cloud-Angeboten, welche eine konsistente IT-Strategie für das ganze Unternehmen unter Einbeziehung von Cloud-Diensten zum Ziel hat.

Ein Kernaspekt von Cloud-Computing ist immer der Leistungsbezug von einem Cloud-Dienstleister und die damit einhergehende Abgrenzung von Zuständigkeits- und Verantwortungsbereichen. Diese Abgrenzung wirft zwangsläufig Fragen der IT-Sicherheit auf, welche aus technischer wie rechtlicher Sicht Beachtung finden müssen. So sind konkrete Fragen zu möglichen Einsatzszenarien von den Implikationen für die IT-Sicherheit abhängig und können nicht getrennt voneinander betrachtet werden. Hier sollen in erster Linie technische Aspekte der Cloud-Sicherheit betrachtet werden.

Dabei sind die grundsätzlichen Aspekte der IT-Sicherheit, wie etwa Schutzziele und deren Umsetzung, weiterhin die Basis aller Überlegungen, welche aber je nach konkreter Nutzungsart des Cloud-Dienstes spezifiziert werden müssen (1). Dabei hat sich in den letzten Jahren eine Reihe Best Practices etabliert, welche sich zu De-facto-Standards entwickelt haben (2). Im Gegensatz zur Verarbeitung von Daten in einer unternehmenseigenen Infrastruktur, hat man es beim Cloud-Computing immer mit einer Form der Auftragsdatenverarbeitung zu tun. Vor dem Hintergrund der oben genannten Abgrenzung von Zuständigkeits- und Verantwortungsbereichen müssen Fragen der IT-Sicherheit präzise analysiert und den jeweilig beteiligten Parteien zugeordnet werden (siehe Bild 17.1).



Bild 17.1 Abstimmungsanforderungen zwischen Cloudanbieter und Cloudnutzer

Dabei sind eine Reihe von Randbedingungen zu beachten, welche zum einen durch charakteristische Eigenschaften von Cloud-Infrastrukturen an sich, zum anderen aber durch das gewählte Nutzungsmodell sowie Cloud-Anbieter vorgegeben sind.

17.2 Nutzungsmodelle

17.2.1 Servicemodelle

Die Dienstleistungsmodelle im Cloud-Computing werden typischerweise in vier Typen eingeteilt (siehe Bild 17.2).

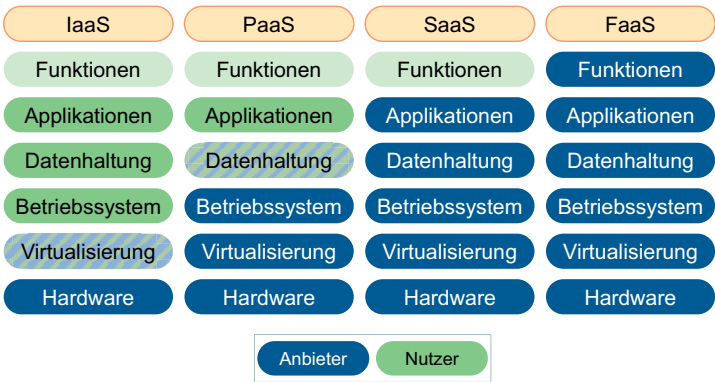


Bild 17.2 Dienstleistungsmodelle und Komponentenverantwortung (vgl. (3) S. 5)

In jedem dieser Dienstleistungsmodelle sind die Hardware sowie die eingesetzte Netzwerkinfrastruktur inklusive der damit zusammenhängenden Prozesse in der Verantwortung des Anbieters. Die Verantwortung für die weiteren Komponenten hängt vom jeweils gewählten Modell ab (3):

- **Infrastructure-as-a-Service**

IaaS ist das grundlegendste Servicemodell, bei dem Cloud-Anbieter Server, Speicher und Netzwerke anbieten, häufig in der Form von virtuellen Maschinen. Werden Teile des Betriebssystems vom Anbieter mitverwaltet und dem Nutzer ein Container dieses Betriebssystems angeboten, spricht man auch von Container-as-a-Service (CaaS). Die Nutzer können beliebige Software wie ggf. Betriebssysteme und Anwendungen einsetzen und ausführen.

- **Platform-as-a-Service**

Bei PaaS bieten die Anbieter Umgebungen für die Entwicklung, den Einsatz, das Hosting und das Testen von Softwareanwendungen an. Dazu gehören in der Regel auch Programmiersprachen und Entwicklungsumgebungen. Häufig werden auch Datenbanken mit angeboten (Database-as-a-Service, DBaaS). Die Nutzer verantworten die von ihnen betriebenen Anwendungen.

- **Software-as-a-Service**

Bei SaaS bieten Cloud-Anbieter in der Cloud gehostete Anwendungen an. Je nach konkreter Anwendung können Schnittstellen und Funktionen vom Nutzer individualisiert werden.

- **Function-as-a-Service**

FaaS bedeutet, ohne eigene Applikationen oder Serversysteme Backend-Code auszuführen. Die Nutzer können die angebotenen Funktionen, wie etwa Datenanalyse- oder Kommunikationsschnittstellen, einsetzen.

SaaS und FaaS werden auch dem Serverless-Computing zugeordnet, was im Wesentlichen bedeutet, dass der Nutzer keine Verantwortung für den Betrieb eines Servers trägt. Die Verantwortung für konkrete Sicherheitsmaßnahmen leitet sich aus der Verantwortung für die jeweilige Umsetzungsebene ab. So liegen etwa bei PaaS betriebssystemseitige Sicherheitseinstellungen in der Verantwortung des Anbieters, während der Zugriff auf etwaige Anwendungen vom Nutzer geregelt werden muss.

Die Wahl des geeigneten Modells wird häufig basierend auf konkreten Produkten von Cloud-Anbietern aufgrund technischer Evaluationen in Verbindung mit einer Kosten-Nutzen-Analyse getroffen.

17.2.2 Bereitstellungsmodelle

Die oben beschriebenen Servicemodelle können in verschiedener Art bereitgestellt werden (3) (siehe Bild 17.3):

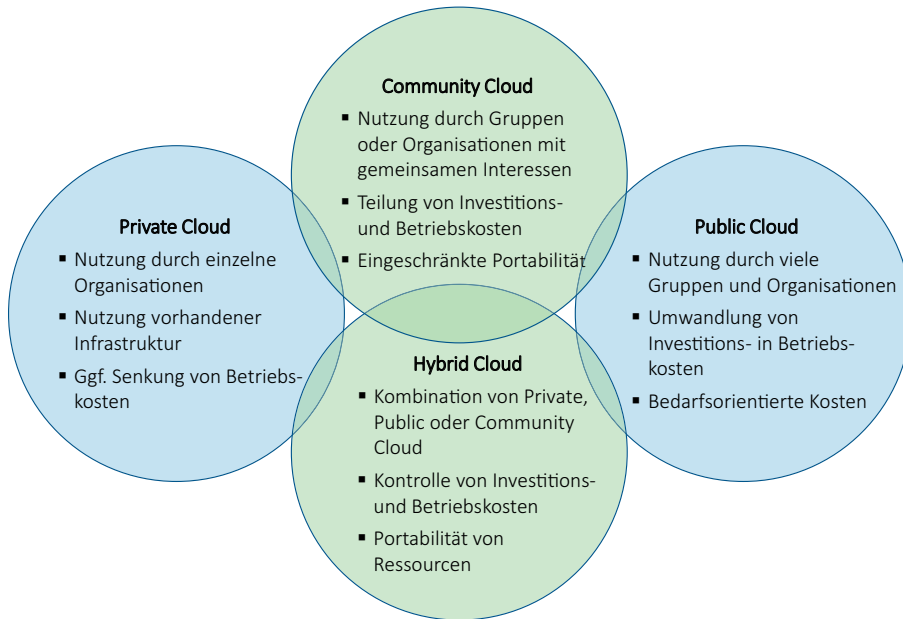


Bild 17.3 Wesentliche Aspekte der vier Bereitstellungsmodelle für Cloud-Computing

■ Public Cloud

Eine Public Cloud wird von einem Anbieter bereitgestellt, die verschiedene Dienste über das Internet für die Allgemeinheit anbietet. Die Infrastruktur ist Eigentum des Dienstansbieters, wird von diesem verwaltet und befindet sich in dessen Einrichtungen.

■ Private Cloud

Eine private Cloud wird für eine einzelne Organisation bereitgestellt und ist ausschließlich für die internen Nutzer dieser Organisation bestimmt. Die private Cloud befindet sich in den Einrichtungen des Unternehmens, kann jedoch auch von einem Drittanbieter gehostet und verwaltet werden. Die private Cloud kann im Besitz der Organisation, eines Drittanbieters oder einer Kombination aus beiden sein und von diesen verwaltet und betrieben werden.

■ Community Cloud

Eine Community Cloud wird für Gruppen von Nutzern oder Organisationen bereitgestellt, die ein gemeinsames Interesse an der Datenverarbeitung haben. Sie

kann im Besitz eines oder mehrerer Mitglieder, eines Dritten oder einer Kombination von ihnen sein sowie von diesen verwaltet und betrieben werden und sich innerhalb oder außerhalb deren Räumlichkeiten befinden.

■ Hybrid Cloud

Dies ist eine Kombination der vorherigen Typen, die eigenständige Einheiten bleiben, aber durch standardisierte oder proprietäre Technologie miteinander verbunden sind, die die Übertragbarkeit von Daten und Anwendungen ermöglicht.

Aspekte zur Wahl des geeigneten Bereitstellungsmodells ergeben sich häufig aus konkreten Projektanforderungen. Die Kontrolle der Infrastruktur aus Gründen der Datensicherheit sowie die Vermeidung von Locked-in-Effekten sind dabei zu berücksichtigen und führen in komplexen Anforderungslagen üblicherweise zu einer Kombination verschiedener Modelle in einer Hybrid Cloud.

17.3 Risiken des Cloud-Computing

17.3.1 Überblick

Generell beurteilt man die IT-Sicherheit anhand der Erreichung von Schutzzielen¹ sowie einer Bewertung von verbleibenden Risiken. Diese Vorgehensweise ist, ebenso wie bei Schwachstellen von genutzter Hard- und Software, zunächst unabhängig davon, ob IT „On-Premise“ oder als Cloud-Dienst genutzt wird.

Bei der konkreten Risikobewertung zeigen sich jedoch deutliche Unterschiede, die im Wesentlichen auf zwei Aspekten beruhen. Zum einen liegen im Cloud-Computing Teile der genutzten Infrastruktur in der Verantwortung der Cloud-Anbieter, was zu abweichenden Beurteilungsmöglichkeiten für den Nutzer führt. Zum anderen ergeben sich aus dem konkreten Cloud-Szenario unterschiedliche Einschätzungen für die Wahrscheinlichkeit der Ausnutzung von Schwachstellen sowie für möglicherweise entstehende Schäden.

Von den Schutzzielen abgeleitete Fragen sind:

- Können unberechtigte Personen oder Organisationen Zugang zu meinen Daten bekommen? (Vertraulichkeit)
- Können meine Daten von unberechtigten Personen oder Organisationen verändert werden? (Integrität)
- Kann der Zugang zu von mir genutzten Daten und Diensten verhindert werden? (Verfügbarkeit)

¹ Zentrale Schutzziele sind Vertraulichkeit, Integrität und Verfügbarkeit. Darüber hinaus gibt es diverse Erweiterungen und Konkretisierungen.

Diese können nur in Abhängigkeit vom konkreten Nutzungsmodell (Abschnitt 17.2) von Anbietern wie Nutzern der Cloud, jeweils für den von Ihnen verantworteten Bereich, beantwortet werden.

Die Bewertung der verbleibenden Risiken hängt also zentral von einer sorgfältigen Analyse des konkreten Einsatzes, der Qualität der Dokumentation des Nutzungsmodells sowie der Kooperation zwischen Cloud-Anbieter und Nutzer zusammen. Die Auswahl geeigneter Sicherheitsmaßnahmen kann als Konsequenz der Risikobewertung nur so gut sein wie die entsprechende Bewertung selbst.

Das Bundesamt für Sicherheit in der Informationstechnologie führt in seinem Grundschutzkompendium eine Liste von 47 elementaren Gefährdungen für die IT-Sicherheit auf, die je nach Service- und Bereitstellungsmodell überprüft werden müssen (4). Unter der Annahme, dass infrastruktur- und hardwarebezogene Risiken in der Verantwortung des CloudA-nbieter liegen, lassen sich die verbleibenden Gefährdungen wiederum in die Bereiche Vertraulichkeit, Integrität und Verfügbarkeit einteilen (siehe Tabelle 17.1) und anschließend die weiteren Verantwortlichkeiten klären.

Tabelle 17.1 Beispielhafte Gefährdungen (4) nach Schutzziel

Vertraulichkeit	Integrität	Verfügbarkeit
■ Ausspähen von Informationen (Spionage) ■ Abhören ■ Offenlegung schützenswerter Informationen ■ etc.	■ Manipulation von Hard- oder Software ■ Manipulation von Informationen ■ Integritätsverlust schützenswerter Informationen ■ etc.	■ Verhinderung von Diensten (DoS) ■ Datenverlust ■ etc.

Um geeignete Maßnahmen zu identifizieren, ist zu ermitteln, ob Gefährdungen auf Fehlern, versehentlichem Fehlverhalten oder der Verletzung von Gesetzen und Regelungen entstehen. Zum Schutz vor bewusster Ausspähung von Daten sind etwa andere Maßnahmen erforderlich als zum Schutz vor der versehentlichen Veröffentlichung vertraulicher Daten. In beiden Fällen wäre aber die Vertraulichkeit der Daten beeinträchtigt.

Mögliche Ursachen für Sicherheitsprobleme (Beispiele):

- **Fehler**
 - Software-Schwachstellen oder -fehler
 - Fehlerhafte Nutzung oder Administration von Geräten und Systemen
- **Bewusst schädliche oder kriminelle Aktivitäten**
 - Unbefugtes Eindringen in IT-Systeme
 - Identitätsdiebstahl

- Missbrauch personenbezogener Daten
- Schadprogramme
- Nötigung, Erpressung oder Korruption

Die Einschätzung der möglichen Risiken beinhaltet immer auch die Wahrscheinlichkeit des Eintretens von Schäden sowie deren Höhe. Die tiefgreifende und sorgfältige Analyse der bestehenden Risiken ist die Basis zur Identifikation geeigneter Sicherheitsmaßnahmen.

17.3.2 Beispiele

Folgende Beispiele zeigen reale Fälle von Sicherheitsproblemen der letzten Jahre:

- **Ungesicherte Speicherdienste**

„Die Daten von etwa vier Millionen Time Warner Cable-Kunden wurden dem öffentlichen Internet ausgesetzt, nachdem ein Auftragnehmer eine Amazon-Cloud-Datenbank nicht richtig gesichert hatte.“ (5)

- **E-Mail-Kompromittierung bei Deloitte**

Bei dem Angriff auf Deloitte wurde ein kompromittierter Systemadministrator-Zugang verwendet, um auf das in Microsoft Azure gehostete E-Mail-System des Unternehmens zuzugreifen. Das Administratorkonto verwendete nur ein Passwort zur Authentifizierung. Am 25. September 2017 berichtete *The Guardian* dazu, dass das globale Beratungsunternehmen Deloitte „... das Opfer eines Cybersecurity-Angriffs war, der monatelang unbemerkt blieb“ (6).

- **Ransomware greift Cloud-Backups an**

Obwohl es bisher nur wenige bestätigte Vorfälle zu geben scheint, deuten Berichte darauf hin, dass Ransomware aktiv Cloud-Backups nutzt, um Daten zu exfiltrieren, die dann als Lösegeld erpresst werden können, anstatt die Daten der Opfer nur dort zu verschlüsseln, wo sie sich befinden. Berichten zufolge wurde cloudbasierte Backup-Software geteert und/oder von Doppelware- und Maze-Ransomware-Betreibern verwendet, um Backups zu stehlen oder zu zerstören, was eine normale Taktik bei Angriffen ist (7).

- **SolarWinds „Solorigate“-Lieferkettenangriff**

SolarWinds ist ein Anbieter von Unternehmenssoftware für die Verwaltung von Netzwerken, Systemen und Informationstechnologie. Am 13. Dezember 2020 veröffentlichte FireEye eine Bedrohungsstudie über eine Einbruchskampagne, bei der fortgeschrittene Bedrohungsakteure die Software-Lieferkette von SolarWinds kompromittierten, um auf globale private und staatliche Netzwerke zuzugreifen. Die Angreifer nutzten dann den lokalen Zugang, um sich unbefugten Zugang zu den Cloud-Umgebungen der Opfer von Microsoft 365 zu verschaffen (8).

17.4 Sicherheitsmaßnahmen

Die Auswahl geeigneter Sicherheitsmaßnahmen stellt die größte Herausforderung im Sicherheitsmanagement dar. Die gewählten Maßnahmen müssen geeignet sein, Schäden zu verhindern, dürfen aber gleichzeitig die Nutzung nicht zu sehr mit zusätzlichen Aufgaben belasten. Die Verhältnismäßigkeit von Sicherheitsmaßnahmen muss gewährleistet sein und regelmäßig einer Überprüfung unterzogen werden. Dies ist zunächst völlig unabhängig davon, ob Informationstechnologie in einem Cloud-Computing-Umfeld eingesetzt wird oder nicht. Im Folgenden soll weniger die grundsätzliche Vorgehensweise für IT-Sicherheitsmaßnahmen betrachtet, sondern besonders auf spezifische Aspekte der Cloud-Sicherheit eingegangen werden.

17.4.1 Sicherheitsrahmen

Im Gegensatz zum klassischen On-Premise-IT-Betrieb sind, wie oben beschrieben, die Zuständigkeiten zwischen Cloud-Anbieter und Nutzer aufgeteilt. Bevor geeignete technische Sicherheitsmaßnahmen ausgewählt werden können, muss ein Sicherheitsrahmen definiert werden, aus dem hervorgeht, wer im Detail für welche Aspekt der IT-Sicherheit verantwortlich ist (2), (9). Dies geschieht in mehreren Schritten und ist, je nach Cloud-Anbieter, auch durch die entsprechenden Service-Level-Agreements (SLAs) mindestens teilweise festgelegt.

Folgende Aspekte sind in einem Sicherheitsrahmen zu berücksichtigen (10):

Beschreibung der Systeme und Leistungserbringung der IT-Sicherheit

Je nach eingesetztem Service- und Bereitstellungsmodell liegt die Verantwortung für die Administration von Systemen in der Verantwortung des Cloud-Anbieters oder des Nutzers. Eine detaillierte Festlegung konkreter administrativer Aufgaben, welche auch die Umsetzung von Sicherheitsmaßnahmen beinhalten, erfordert eine präzise Beschreibung der eingesetzten Systeme. Diese beinhaltet (2):

■ **Beschreibung und Klassifizierung von Kundensystemen**

Hierbei ist detailliert festzulegen, welche Systeme dem Kunden bis zu welcher Ebene im Sinne des gewählten Servicemodells zur Verfügung gestellt werden. Dies kann durchaus eine Kombination verschiedener Modelle sein. Beispielsweise kann ein SaaS-Angebot wie Office 365 mit einem PaaS-Angebot wie dem Hosting einer Datenbank kombiniert sein. Für die Auswahl und Umsetzung von Sicherheitsmaßnahmen, z. B. den Systemzugang, können daraus systemspezifische Entscheidungen folgen. Erforderlich ist deshalb eine Klassifikation der Systeme, welche es erlaubt, konkrete Maßnahmen abzuleiten. In Bereitstellungsmodellen wie Private oder Public Cloud können aus dem Servicemodell bereits konkrete Verant-

wortlichkeiten abgeleitet werden. In Community- oder Hybrid-Cloud-Modellen ist es erforderlich, jedes beteiligte System entsprechend zu klassifizieren.

- **Dokumentation der Netztopologie**

Die eingesetzte Netztopologie ist dann zu dokumentieren, wenn sich daraus konkrete Anforderungen für den Nutzer ergeben. Hierbei ist zu beachten, dass sich je nach Nutzungsmodell (Abschnitt 17.2) die Topologie intransparent für den Nutzer ändern kann. Dies ist häufig sinnvoll und beabsichtigt, um eine möglichst hohe Skalierbarkeit und Weiterentwicklung von Diensten zu gewährleisten. Zunächst ist also klar abzugrenzen, welche Eigenschaften der Topologie für den Nutzer in welcher Form relevant sind, um dann die Anforderungen an die Dokumentation festzulegen. In Public-Cloud-Modellen wird etwa die gesamte Netztopologie vom Cloud-Anbieter verantwortet. Für den Nutzer verbleiben in diesem Fall verhältnismäßig wenige Anforderungen an die Dokumentation. Der Rechtsbereich der Serverstandorte muss aber auch dann klassifiziert sein. In einem Hybrid-Cloud-Szenario ist erheblich mehr Dokumentation, beispielsweise durch Netzwerkdiagramme, erforderlich, um Zugangsrechte sachgemäß verwalten zu können.

- **Zuständigkeiten und Verantwortungen im Rahmen der Informationssicherheit**

Lassen sich die Funktionen der beteiligten Systeme klar trennen, folgt die Verantwortung für deren IT-Sicherheit unmittelbar aus der Verantwortung für die Administration der Systeme. Dies ist allerdings nicht überall gegeben. Zur Malware-Überprüfung der Daten eines Cloud-Datenspeichers sind etwa Maßnahmen auf Betriebssystemseite erforderlich. In einem PaaS-Modell liegt dieses aber in der Verantwortung des Cloud-Anbieters. In einem FaaS-Modell hängt die Sicherheit der Nutzeranwendung von der Aktualität des Sicherheitspatchstandes der eingesetzten Bibliotheken ab. In derartigen Fällen sind die Zuständigkeiten und Verantwortungen zwischen Anbieter und Nutzer gesondert abzustimmen.

- **Dokumentation, Kommunikation und Bereitstellung von Richtlinien und Anweisungen**

Die Sicherstellung angemessener IT-Sicherheit lässt sich nur unter Einbeziehung der damit einhergehenden Prozesse verstehen. Im Rahmen von Unternehmens-IT folgen diese oft standardisierten Prozessmodellen wie etwa ITIL. Im Rahmen einer Nutzung von Cloud-Diensten ist jedoch davon auszugehen, dass verschiedene Prozessmodelle für die Verantwortungsbereiche des Cloud-Anbieters und des Nutzers angewendet werden.

Portabilität von Daten und Diensten

Anbieter-Lock-in-Effekte gehören zu den ernst zu nehmenden Risiken im Cloud-Computing. Ein Wechsel des Cloudanbieters oder der eingesetzten Technologie kann aus

verschiedenen Gründen erforderlich werden. Um Aufwände und Kosten dafür kontrollieren zu können, ist es erforderlich, nachfolgende Prozesse zu planen und zu testen:

- **Extraktion von Daten und Verlagerung von Anwendungen**
 - zwischen verschiedenen Cloud-Anbietern
 - zwischen Cloud-Anbieter und eigener Infrastruktur
- **Sichere Löschung von Daten in der Cloud-Infrastruktur (s. u.)**

Um diese Prozesse effizient zu gestalten, empfiehlt es sich, von vornherein auf portable und interoperable Daten- und Dienststrukturen zu achten. Dies wird üblicherweise durch den Einsatz von öffentlich dokumentierten und standardisierten Formaten und Protokollen erreicht.

Sicherheitsmodell

Sicherheitsanforderungen werden im Rahmen der Unternehmens-IT gewöhnlich formal erfasst und daraus ein Sicherheitsmodell konstruiert. Im Zuge der Nutzung von Cloud-Diensten ist dieses auf die konkret geplanten Nutzungsmodelle anzupassen. Besonders anzuraten sind hier für den Cloud-Bereich die Prinzipien einer Zero-Trust-Architektur, wie diese vom NIST beschrieben wurde, bereits in der Planung zur Anwendung zu bringen (11). Diese beinhalten Anforderungen an Zugangskontrolle, Datensicherheit und Identitätsmanagement, welche nachfolgend weiter beleuchtet werden.

Compliance und Audits

Cloud-Computing selbst beruht auf einer Reihe von Standards, die ein Produkt, welches möglichst vielen Nutzern angeboten werden soll, überhaupt erst ermöglichen. Demzufolge ist es naheliegend, auch geeignete Sicherheitsstandards zur Anwendung zu bringen. Die Effektivität von Maßnahmen der IT-Sicherheit folgt dem Prinzip des schwächsten Glieds einer Kette. Sind Sicherheitsmaßnahmen unausgewogen oder fehlen für bestimmte Bereiche völlig, so werden damit andere Maßnahmen ebenso nutzlos. Zur Auswahl angemessener und ausgeglichener Sicherheitsmaßnahmen kann die Anwendung von Standards entscheidend beitragen. Generell gibt es eine Reihe von Standards, wobei als wichtigste hier ISO/IEC 27001 sowie ISO/IEC 27017, die Regelungen der CSA Cloud Controls Matrix und die Produkte des BSI wie etwa den Anforderungskatalog Cloud-Computing zu nennen wären.

Jede Umsetzung von Standards beinhaltet ebenso die Überprüfung derselben. In der Planung des Einsatzes von Cloud-Computing sind deshalb von vornherein die Durchführung unabhängiger externer Audits zu berücksichtigen.

Sind oben genannte Anforderungen an einen Sicherheitsrahmen erfüllt sowie Sicherheitsmodell und Standards gewählt, können konkrete technische Maßnahme daraus abgeleitet werden.

17.4.2 Zugangskontrolle

Wenn wir zurück auf die Fragen zu den Schutzzielen Vertraulichkeit, Integrität und Verfügbarkeit blicken, wird schnell klar, dass ohne funktionierende Zugangskontrolle eine sichere Nutzung von Cloud-Diensten nicht möglich ist. Diese beinhalten zwei Grundaufgaben:

- Identifikation von Subjekten (Personen, Rechner, Dienste), die Zugang zur Cloud-Infrastruktur suchen (Authentifizierung)
- Möglichkeiten der Gewährung oder Verweigerung angefragter Rechte basierend auf der geprüften Identität (Autorisierung)

Alle Regeln aus dem regulären Betrieb bleiben für die Nutzung von Cloud-Diensten weiter richtig und sollen hier nicht wiederholt werden.

Wo liegen also die Besonderheiten von Cloud-Diensten? Zwei Aspekte sind grundlegend anders:

- Es gibt in jedem Servicemodell Verantwortlichkeiten der Cloud-Anbieter für Infrastruktur und Hardware, welche technisch auch den Zugang zu darüber liegenden Schichten ermöglichen.
- Zugangskontrolle über die Positionierung von Hardware in entsprechenden Netzwerksegmenten und die Auslagerung von Kontrollaufgaben an die Netzwerktopologie kommt bei Cloud-Diensten nicht infrage.
- Der Zugang zur Hardware und Infrastruktur kann vom Cloud-Nutzer weder aktiv bestimmt noch kontrolliert werden. Da es sich häufig auch um geteilte Infrastruktur handelt, besteht nur die Möglichkeit, über die Vertragsgestaltung mit dem Cloud-Anbieter zu agieren. Die entsprechenden Zusicherungen sollten in jedem Fall ein Teil der Anbieterauswahl sein.

Über den Hardware- und Infrastrukturteil hinaus muss die Zugangskontrolle auf den jeweiligen Softwaresystemen umgesetzt werden.

Daraus folgen im Wesentlichen bereits die wichtigsten Prinzipien, wie diese auch in Zero-Trust-Modellen gefordert werden (11):

- **Zentrale Quelle zur Verwaltung von Identitäten**

Naheliegend ist hier der Einsatz von Systemen, welche auch im regulären Unternehmenskontext beim Zugang zu Ressourcen verwendet werden (z. B. Verzeichnisdienste). Diese Systeme sind üblicherweise auch Teil der Cloud-Infrastruktur.

- **Durchgängige Authentifizierung für Benutzer, Rechner und Dienste**

Die Durchgängigkeit ist hier unbedingt zu gewährleisten. Implizite Rechtengewährung eines Systems basierend auf der Anfrage eines anderen ohne explizite Überprüfung der Identität von Nutzer, Rechner oder Dienst darf nicht stattfinden. Lü-

cken in der Identitätskontrolle stellen häufige Einfallstore für Angriffe dar. Die Forderung nach sicheren mehrstufigen Authentifizierungsmethoden kann für Cloud-Dienste nur erneuert werden. Besonderes Augenmerk ist bei Cloud-Diensten auf Administratorenrechte zu legen, die Absprache bzw. vertraglichen Aspekte des Zugangs durch den Cloud-Anbieter sind hier zusätzlich zu berücksichtigen.

■ **Zugangsrichtlinien und -kontrolle auf Applikationsebene**

Die Anwendung von Zugangsrichtlinien ist selbstverständlich auch in der regulären Unternehmens-IT erforderlich. Die Umsetzung auf Applikationsebene ist dort allerdings unüblich, da regulär der Zugang zur Applikation über das Betriebssystem überprüft wird. In Domänenstrukturen gibt es allerdings (z. B. über Kerberos) durchaus auch applikationsbezogene Richtlinien. Für Cloud-Dienste sind diese unerlässlich. Die grundsätzlichen Anforderungen zur Erstellung von Rollenkonzepten und deren Eigenschaften, wie etwa Need-to-know oder Aufgabentrennung, müssen auch in Cloud-Diensten Anwendung finden.

Zentrale Prozesse zur Registrierung von Identitäten sowie der Rechteverwaltung müssen gegebenenfalls an die technischen Möglichkeiten der Cloud-Anbieter angepasst werden. Basis dafür sollten bereits vorhandene Prozesse der Unternehmens-IT sein.

Die regelmäßige Überprüfung von Zugriffsrichtlinien wie deren korrekte technische Umsetzung muss integraler Bestandteil des Sicherheitsmanagements sein.

17.4.3 Datensicherheit

Bei Konzepten zur Datensicherheit unterscheidet man zwischen den möglichen Zuständen:

■ **Ruhende Daten (Data-in-Rest)**

Daten, auf die nicht zugegriffen wird und die auf einem physischen oder logischen Medium gespeichert sind

■ **Daten in Verwendung (Data-in-Use)**

Daten, die von einer oder mehreren Anwendungen zur Bearbeitung geöffnet sind

■ **Daten während der Übermittlung (Data-in-Transit)**

Daten, die gerade über einen privaten oder öffentlichen Kommunikationskanal übertragen werden

Der wesentliche Unterschied in der Datensicherheit zwischen Cloud-Diensten und On-Premise-Konzepten besteht auch hier darin, dass der physische Zugang zu Datenträgern technisch nicht vom Nutzer der Cloud-Dienste kontrolliert werden kann. Darüber hinaus verwenden Cloud-Anbieter zur Steigerung der Plattformskalierbarkeit

und der Datenverfügbarkeit eigene Technologien zur Sicherung und Duplikation von Daten, welche für den Nutzer per se nicht transparent sind.

Zentral für Sicherheit von Daten in Cloud-Strukturen ist daher die Verschlüsselung von Daten in allen Zuständen. Zentrale Technologien dabei sind (3):

- **Verschlüsselte Dateisysteme**

Die Verschlüsselung muss vom jeweiligen Betriebssystem unterstützt werden. Der Zugriff auf die Informationen ist nur möglich, wenn dieses Dateisystem gerade verwendet wird oder ein anderes System den passenden Schlüssel besitzt. De facto bieten alle Cloud-Anbieter auch den Einsatz derartig verschlüsselter Dateisysteme an, auf Applikationsebene ist diese Form der Verschlüsselung transparent. Die Verantwortung für diese Form der Verschlüsselung liegt beim Betriebssystem und damit je nach Nutzungsmodell in der Verantwortung des Nutzers oder des Anbieters.

- **Verschlüsselung auf Applikationsebene**

Eine Reihe von typischen Cloudapplikationen (Datenbanken, Datenanalyse, Datenverwaltung) unterstützt die verschlüsselte Verwaltung von Datenträgern. In einem SaaS-Modell liegt die Verantwortung für die Verschlüsselung aufseiten des Cloudanbieters. In IaaS- und PaaS-Modellen liegt die Verantwortung beim Cloudnutzer. Wichtig ist zu betonen, dass das Betriebssystem auf Applikationsdaten während der Laufzeit der Applikation zugreifen kann. Technisch kann also der Schutz von Applikationen vor einem nicht vertrauenswürdigen Betriebssystem nicht gewährleistet werden.

- **Verschlüsselte Übertragung der Daten**

Die Verschlüsselung von Daten während der Übertragung zwischen verschiedenen Systemen kann entweder auf verschiedenen Ebenen des Netzwerks idealerweise durch standardisierte Protokolle (IPSEC, TLS) durch das Betriebssystem oder durch die jeweils übertragende Applikation sichergestellt werden. Die Verantwortung hängt auch hier vom jeweiligen Nutzungsmodell ab.

Von zentraler Bedeutung ist es, dass die Verschlüsselung der Daten durchgängig implementiert ist, sodass Daten in keinem Fall unverschlüsselt in einer Cloud-Infrastruktur abgelegt werden können. Anhand des Sicherheitsrahmens (Abschnitt 17.4.1) lassen sich aus den oben genannten Maßnahmen eine Richtlinie zur Nutzung von Verschlüsselungsverfahren ableiten und die jeweilige Verantwortung für dessen Implementierung ableiten.

Zugriff auf verschlüsselte Daten hat aber grundsätzlich jeder, der Zugriff auf die verwendeten Schlüssel hat. Die sichere Schlüsselverwaltung ist deshalb ein absolut entscheidender Aspekt. Grundsätzlich gilt hier das Sicherheitsprinzip Need-to-know. Schlüssel sollten also nur den Nutzern, Organisationen oder Systemen zugänglich sein, welchen diesen zur Erledigung ihrer Aufgabe benötigen. Im Idealfall finden

sich, z. B. bei reinen Cloud-Speichern oder Datenbanken, Lösungen, für die nicht einmal der Cloud-Anbieter Zugriff auf die Schlüssel und damit die Informationen hat. Derartige Lösungen finden zunehmend Eingang in die Produkte der Cloud-Anbieter und werden als clientseitige Verschlüsselung oder Bring-your-own-Key-(BYOK-)Modelle ausgewiesen. Im Interesse der Minimierung der Angriffsfläche sind diese Technologien zu bevorzugen, auch wenn diese im jeweiligen Nutzungsmodell auf Eignung und Sicherheit untersucht werden müssen. Ein Punkt, welcher der kritischen Abwägung bedarf, ist die Umsetzung von Sicherheitsdiensten durch den Cloud-Anbieter, wie etwa Malware-Scanning von in der Cloud abgelegten Daten. Derartige Dienste benötigen den Zugriff durch den Cloud-Anbieter, können aber sehr positiv zur Minimierung von Sicherheitsrisiken beitragen. Hierbei gilt es, das konkrete Einsatzszenario zu berücksichtigen.

Teil der Datensicherheit sind selbstverständlich auch Backup-, Restore- und Versionierungskonzepte, anders als in On-Premise-Umgebungen werden diese üblicherweise vom Cloud-Anbieter als Produktbestandteile mit angeboten. Hierbei ist vor allem darauf zu achten, dass Verschlüsselung und Schlüsselverwaltung nach oben genannten Prinzipien auch für gesicherte Daten gewährleistet sind. Die Regelungen für die Aufbewahrung gesicherter Daten müssen zudem auch Vereinbarungen über die möglicherweise erforderliche Löschung von Daten und entsprechende Fristen beinhalten.

Darüber hinaus gelten, je nach Standort der Datenspeicher, besondere rechtliche Anforderungen für den Cloud-Anbieter. Diese können in verschiedenen Regionen dazu führen, dass Cloud-Anbieter zur Herausgabe der ihnen bekannten Daten verpflichtet sind. Eine rechtlich detaillierte Abwägung ist im Rahmen dieser Arbeit nicht möglich, generell muss aber eine entsprechende Analyse stattfinden, die in Anforderungen an den Cloud-Anbieter mündet. Dies kann etwa in Konsequenz die ausschließliche Nutzung von Datenspeichern im eigenen Rechtsraum oder den Einsatz von BYOK-Verfahren fordern.

Datensicherheit in Cloud-Diensten und insbesondere die Verarbeitung von Daten, ohne dass ein Verarbeiter Kenntnis der Informationen erhält, stellt ein aktives Forschungsgebiet dar. Die weitere Entwicklung von Verfahren der homogenen Verschlüsselung, der durchsuchbaren Verschlüsselung oder von Whitebox-Verschlüsselungsansätzen verspricht hier in den nächsten Jahren noch weitere technische Möglichkeiten.

17.4.4 Monitoring und Überwachung

Überwachung und Protokollierung stellen auch im regulären On-Premise-Einsatz von IT eine wesentliche Säule der IT-Sicherheit dar (2). In Rahmenwerken zum IT-Management werden diese etwa in Form von Plan-Do-Check-Act-Prozesszyklen gefor-

dert (12). Im Cloud-Umfeld gewinnt diese nochmals an Bedeutung, da der physische Zugriff auf Hardware nicht gegeben ist.

Die dazu verfügbaren Maßnahmen sind strukturell verschieden, je nachdem, ob diese im laufenden Betrieb permanent stattfinden oder nicht:

■ **Permanente Maßnahmen:**

Überwachung von

- *Aktivitäten von Software:* Die schließt zum einen die Auswertung von Protokolldateien erwünschter Software sowie die Überwachung auf möglicherweise unerwünschte Software, wie Malware, ein, ebenso Prozesse zur Freigabe neuer Software (inklusive lauffähiger oder nachgeladener Komponenten wie Plug-ins). Weiterführend bietet sich noch die Überwachung auf Anomalien im Bereich der Nutzung von Ressourcen (Speicher, Prozessor, Netzwerk) an, um Probleme möglichst frühzeitig zu erkennen.
- *Netzwerkverbindungen:* Die Nutzung unerwünschter Netzwerkverbindungen sollte von vornherein technisch, etwa über Firewalls oder Access-Control-Listen, ausgeschlossen sein. Für benötigte Verbindungen ist es erforderlich, die Regularität der Nutzung zu überwachen. Änderungen in der Häufigkeit der Nutzung sowie der Menge der übertragenen Daten sind Hinweise auf mögliche Sicherheitsprobleme und müssen analysiert werden.
- *Aktivitäten durch Nutzer:* Auch im Bereich der Aktivitäten durch Nutzer ist reguläres Verhalten zu überwachen. Im Gegensatz zu Software- oder Netzwerkaktivitäten ist hier besonderes Augenmerk auf die Wahrung der Privatsphäre der Nutzer zu legen. Dennoch sollten ungewöhnliche Veränderungen im Nutzerverhalten (Login von wechselnden Rechnern oder Regionen, Intensität der Nutzung, Art der Nutzung) analysiert werden.
- *Einträge in Protokolldateien:* Unabhängig von oben genannten Aspekten, finden sich in Protokolldateien auf Betriebssystemebene eine Reihe von Hinweisen auf mögliche Sicherheitsprobleme, diese sind gegebenenfalls in einem PaaS-Modell vom Cloud-Nutzer zu überwachen, in allen anderen Modellen vom Cloud-Anbieter an den Nutzer zu melden.

■ **Regelmäßige, nicht permanente Maßnahmen:**

- *Audits:* Die im Sicherheitsrahmen (Abschnitt 17.4.1) getroffenen Regelungen müssen im Rahmen eines Audits regelmäßig überprüft werden. Ein unbemerktes Abweichen von selbst getroffenen Regeln im Sicherheitsrahmen führt im schlimmsten Fall dazu, dass nachgelagerte Maßnahmen und Prozesse nicht mehr greifen und somit wertlos werden.
- *Penetrationstests:* Penetrationstests sind erforderlich, um die Effektivität von Sicherheitsmaßnahmen aus verschiedenen Bereichen (inklusive Überwachung und Erkennung von Problemen) zu überprüfen. Diese sind ein ausge-

sprochen nützliches Werkzeug, um verborgene Schwächen der eigenen Sicherheitsstrategie frühzeitig zu erkennen und dringend anzuraten.

Diese Maßnahmen der Überwachung und Protokollierung müssen natürlich in einen Security-Incident-Management-Prozess eingebunden werden (10). Dies kann über die Erweiterung eines für die bestehende IT etablierten Prozesses für die Cloud-Komponenten erfolgen. Auch hier ist aber eine Abstimmung mit dem Cloud-Anbieter und Anpassung an dessen technische Rahmenbedingungen nötig (13). Wie in der regulären IT empfehlen sich auch hier entsprechende Compliance-Kriterien, wie etwa ein Informationssicherheitsmanagementsystem nach ISO 27001 auf der Basis des IT-Grundschutzes (4).

Die meisten dieser Maßnahmen erfordern eine enge Abstimmung zwischen Cloud-Anbieter und Nutzer in folgenden Bereichen:

- **Verantwortlichkeiten und Vorgehensmodell bei Schwachstellen, Störungen und Fehlern:** Die Verantwortlichkeiten folgen dabei den Verantwortlichkeiten für die Administration der Systeme im jeweiligen Nutzungsmodell. Eine zentrale Sicht auf den Status beteiligter Systeme sowie ein Prozess zur Behebung von neuen Schwachstellen, Störungen und Fehlern muss zwischen allen beteiligten Parteien abgestimmt und dokumentiert sein.
- **Dokumentation und Berichterstattung über Sicherheitsvorfälle:** Im Fall von Sicherheitsvorfällen ist eine gegenseitige Berichtspflicht und Dokumentation erforderlich. Da Sicherheitsvorfälle üblicherweise weitere Maßnahmen nach sich ziehen, sind entsprechende Fristen zu vereinbaren, welche die Kritikalität der vorliegenden Sicherheitsvorfälle berücksichtigt. Bei hochkritischen Vorfällen ist eine unverzügliche Benachrichtigung geboten.
- **Auswertung und Lernprozess:** Erkenntnisse aus oben genannten Überwachungs- und Monitoringaktivitäten müssen abgestimmt zu möglichen Anpassungen der getroffenen Sicherheitsmaßnahmen führen. Dazu sind diese regelmäßig auszuwerten, Vorschläge zur Modifikation zu entwickeln und die Umsetzung abzustimmen.

Die Automatisierung dieser Überwachungsprozesse sowie die Optimierung der entsprechenden Parameter benötigt in der Anfangszeit der Nutzung von Cloud-Diensten höhere Aufmerksamkeit, um unnötige Dauerbelastung, etwa durch falsch-positive Alarmierung, zu vermeiden.

Alle etablierten Cloud-Anbieter haben aber mit diesen Abstimmungsprozessen Erfahrung und stellen geeignete Werkzeuge zur Überwachung der Sicherheit der gemeinsamen Infrastruktur zur Verfügung. Die Zusammenführung der Überwachungsdaten aus Cloud- und On-Premise-Systemen bleibt in der Verantwortung des Cloud-Nutzers und muss Teil der regulären IT-Prozesse sein.

17.5 Zusammenfassung

Ist Cloud-Computing nun aus Sicherheitsgründen abzulehnen oder anzuraten? Auch wenn es regelmäßig Ratschläge in die eine oder andere Richtung gibt, kann man klar feststellen, dass nicht die Frage der Nutzung von Cloud-Diensten ausschlaggebend ist, sondern ob dafür erforderliche und verfügbare Sicherheitsmechanismen richtig eingesetzt werden. Dasselbe gilt im Übrigen auch für On-Premise-IT. Dazu gehört Technologie ebenso wie Sicherheitsprozesse, welche Ergebnis einer sorgfältigen Analyse des konkreten Nutzungsszenarios sind. Eine Analyse von Sicherheitsvorfällen in Cloud-Diensten zeigt immer wieder, dass größte Gefahr im mangelhaften Einsatz von verfügbaren Mittel liegt (14), (15), (16), (17). Ungeeignete Konfiguration oder Pflege von Zugangsregularien, mangelhafte Authentisierung, unklare Prozesse beim Verdacht auf Sicherheitsvorfälle sind typische Probleme, die immer wieder auftreten (16), (18).

Rechtliche Fragestellungen, wie etwa zu dem relevanten Rechtsraum und Bestimmungen für Datenspeicherung und -verarbeitung außerhalb der eigenen Grenzen, müssen natürlich gesondert betrachtet und berücksichtigt werden. In manchen Fällen wird aber der richtige Einsatz von Verschlüsselungstechnologie einen Betrag zur Lösung leisten, in anderen wird man den Speicher und Verarbeitungsort der Daten vertraglich regeln müssen.

Letztendlich hat sich in den letzten Jahren vielfach gezeigt, dass in Cloud-Diensten für viele Anwendungen ein ebenso hohes Sicherheitsniveau erreichbar ist wie mit On-Premise-IT.

17.6 Die wichtigsten Punkte in Kürze

- Cloud-Dienste sind in vielen Anwendungsszenarien vergleichbar sicher zu betreiben wie On-Premise-Systeme.
- Die detaillierte und präzise Analyse der beabsichtigten Nutzung ist erforderlich, um geeignete Sicherheitsmaßnahmen zu definieren.
- Besonderes Augenmerk sollte hier auf Zugangskontrolle und Datensicherheit als Bestandteile eines übergeordneten Sicherheitsrahmens liegen.
- Sicherheitsmaßnahmen müssen kontinuierlich auf ihre Wirksamkeit hin überwacht und gegebenenfalls angepasst werden.

Literatur

- (1) *Rethinking security in the era of cloud computing*. Aikat, Jay et al. 3, 2017, IEEE Security & Privacy, Bd. 15, S. 60–69.
- (2) Morrow, Timothy et al. *Cloud Security Best Practices Derived from Mission Thread Analysis*. Carnegie-Mellon University. Pittsburgh PA: s. n., 2021.
- (3) Chen, Lei, Takabi, Hassan und Le-Khac, Nhien-An. *Security, privacy, and digital forensics in the cloud*. 2019: John Wiley & Sons.
- (4) Bundesamt für Sicherheit in der Informationstechnik. *IT-Grundschutz-Kompendium*. Bonn: Reguvis Fachmedien GmbH, 2021.
- (5) Nichols, Shaun. The Register. [Online] 2017. September 2017. [Zitat vom: 20. Januar 2021.] https://www.theregister.co.uk/2017/09/05/twc_loses_4m_customer_records/.
- (6) Hopkins, Nick. The Guardian. [Online] September 2017. [Zitat vom: 20. Januar 2022.] <https://www.theguardian.com/business/2017/sep/25/deloitte-hit-by-cyberattack-revealing-clients-secret-emails>.
- (7) Abrams, Lawrence. Ransomware Attackers Use Your Cloud Backups Against You. Bleeping Computer. [Online] Bleeping Computer, 3. März 2020. [Zitat vom: 20. Januar 2022.] <https://www.bleepingcomputer.com/news/security/ransomware-attackers-use-your-cloud-backups-against-you/>.
- (8) FireEye (Mandiant). Remediation and Hardening Strategies for Microsoft 365 to Defend Against UNC2452 (Version 1.0). [Online] Dezember 2020. [Zitat vom: 20. Januar 2022.] <https://www.fireeye.com/content/dam/collateral/en/wp-m-unc2452.pdf>.
- (9) Jouini, Mouna und Rabai, Latifa Ben Arfa. A security framework for secure cloud computing environments. *Cloud security: Concepts, methodologies, tools, and applications*. s. l.: IGI Global, 2019, S. 249–263.
- (10) Bundesamt für Sicherheit in der Informationstechnik. *Anforderungskatalog Cloud Computing (C5)*. Bonn: s. n., 2017.
- (11) Rose, Scott W and Borchert, Oliver, Mitchell, Stuart und Connelly, Sean. *Zero trust architecture*.
- (12) Beims, Martin. *IT-Service Management mit ITIL*. München: Hanser, 2012.
- (13) von Faber, Eberhard und Behnsen, Wolfgang. *Joint Security Management: organisationsübergreifend handeln*. Wiesbaden: Springer Fachmedien, 2018.
- (14) *Cyber security threats in cloud: literature review*. Al Nafea, Roaa und Almaiah, Mohammed Amin. [Hrsg.] IEEE. 2021. 2021 International Conference on Information Technology (ICIT). S. 779–786.
- (15) Alatawi, Sahar et al. A Survey on Cloud Security Issues and Solution. 2020 *International Conference on Computing and Information Technology (ICCIT-1441)*. 2020, S. 1–5.
- (16) Brook, JM et al. *Top Threats to Cloud Computing: The Egregious Eleven*. Cloud Security Alliance. 2019.
- (17) Suryateja, Pericherla S. *Threats and vulnerabilities of cloud computing: a review*. International Journal of Computer Sciences and Engineering. 2018, Bd. 6, 3, S. 297–302.
- (18) Morrow, Timothy et al. *Overview of Risks, Threats, and Vulnerabilities Faced in Moving to the Cloud*. Carnegie Mellon University. Pittsburgh PA: s. n., 2020.

Herausgeber, Autorin und Autoren

Die Herausgeber



Prof. Dr. Michael Lang

ist Professor für Wirtschaftsinformatik an der Technischen Hochschule Nürnberg. Seine Forschungs- und Lehrschwerpunkte liegen in den Bereichen Digitale Transformation, Business Analytics und IT-Management. Zu diesen Themen hat er zudem 30 Fachbücher veröffentlicht. Vor seiner aktuellen Tätigkeit war Herr Prof. Dr. Lang in diversen Fach- und Führungspositionen beschäftigt und zugleich Lehrbeauftragter für Projekt- und IT-Management an verschiedenen Hochschulen. Zuletzt war er als Führungskraft bei einem der größten IT-Dienstleistungsunternehmen Europas tätig.



Prof. Dr. Hans Löhr

ist Professor für Informatik mit Schwerpunkt in den Bereichen IT-Sicherheit und Kryptografie an der Technischen Hochschule Nürnberg Georg Simon Ohm. Zuvor wurde er am Horst-Görtz-Institut für IT-Sicherheit der Ruhr-Universität Bochum promoviert. Daraufhin war er langjährig in der zentralen Konzernforschung der Robert Bosch GmbH und danach bei der SUSE Software Solutions Germany GmbH tätig. Dabei beschäftigte er sich unter anderem mit innovativen Sicherheitslösungen und -konzepten für zukünftige Produkte, Software Security und der Entwicklung und Zertifizierung von sicheren Produkten.

Autorin und Autoren**Daniel Angermeier**

ist stellvertretender Abteilungsleiter am Fraunhofer AISEC. Als Diplom-Informatiker beschäftigt er sich seit einem Jahrzehnt mit Fragestellungen der sicheren Systementwicklung in Kunden- und Forschungsprojekten.

**Dr.-Ing. Jürgen Großmann**

ist Gruppenleiter im Geschäftsbereich SQC des Fraunhofer Instituts FOKUS in Berlin und dort verantwortlich für Entwicklungs- und Testprojekte von vernetzten und eingebetteten Softwaresystemen in kritischen Anwendungsbereichen. Jürgen Großmann ist Experte für agile Softwareentwicklung, automatisiertes Testen sowie die Absicherung komplexer Systeme und Infrastrukturen. In den letzten Jahren hat er sich insbesondere mit der Absicherung lernender Systeme beschäftigt. Ergänzend dazu arbeitet er als Experte für IT-Sicherheit im Bereich kritischer Anwendungen der Automobilindustrie und im Finanzsektor. Er ist bzw. war mit seiner Expertise in zahlreiche Standardisierungs- und Normungsarbeiten in Gremien der OMG, ETSI bzw. AUTOSAR involviert.

**Diplom-Ingenieur Hans Höfken**

ist Geschäftsführer bei @-yet Industrial IT Security. Er studierte Elektrotechnik und arbeitete als Automatisierer in der Papierindustrie, ehe er zur IT-Sicherheit kam. Hier beschäftigt er sich seit über zehn Jahren mit IT-Forensik, Informationssicherheit und Hacking. Seit 2015 liegt sein Schwerpunkt auf der OT-Sicherheit im industriellen Umfeld.

**Dr. Thomas Jansen**

ist Rechtsanwalt und Partner im Münchner Büro der Sozietät HEUKING KÜHN LÜER WOJTEK. Er ist seit mehr als 25 Jahren spezialisiert auf die Beratung von deutschen und internationalen Mandanten in technologiebezogenen Transaktionen aller Art, insbesondere bei komplexen Projektverträgen und Joint Ventures. Den Schwerpunkt seiner Tätigkeit bilden IT-Projekte und Outsourcing-Vorhaben, komplexe Kooperationsvereinbarungen sowie Lizenz- und Vertriebsvereinbarungen. Darüber hinaus berät Herr Dr. Jansen zu Rechtsfragen der Virtualisierung, insbesondere zu Rechtsfragen um die Cloud sowie im nationalen und internationalen Datenschutzrecht, speziell zu Fragen der grenzüberschreitenden Datenübermittlung und des Direktmarketings.

**Florian Jörgens**

ist Chief Information Security Officer der Vorwerk Gruppe. Zusätzlich ist er als Keynote-Speaker, Dozent, Autor und wissenschaftlicher Mitarbeiter an verschiedenen Hochschulen tätig. Darüber hinaus hält er Fachvorträge zu den Themen Informationssicherheit, Awareness und Cybersicherheit.

**Stefan Karg**

studierte Informationstechnik an der TU München und ist heute als Sachverständiger, Auditor und Berater mit Schwerpunkt technischer Datenschutz und Informationssicherheit tätig. Aus dem Einsatz an der Schnittstelle zwischen Technik und Recht ist er mit den praktischen Herausforderungen in mittleren und großen Unternehmen vertraut.

**Prof. Nicolai Kuntze**

ist seit über 15 Jahren in der IT-Sicherheit in verschiedenen Rollen am Fraunhofer-Institut für Sichere Informationstechnologie SIT, Huawei, der Trusted Computing Group und seit 2017 an der Hochschule Mainz aktiv. Hierbei hat er verschiedene Projekte im Bereich der sicheren Entwicklung und Verteilung von Software, Einsatz von Trusted Computing und der Digitalisierung von Prozessen aktiv gestaltet.

**Ümit Kuşdoğan**

ist seit 25 Jahren in der IT und Informationssicherheit tätig. Während seiner Laufbahn arbeitete er in den unterschiedlichsten Branchen von Start-ups bis DAX-Unternehmen. Aktuell ist er Chief Information Security Officer (CISO) der ADAC Gruppe. Er ist Diplom-Informatiker (FH) und hat einen MBA von einer amerikanischen Universität.

**Dr. Hagen Lauer**

ist Wissenschaftler, stellvertretender Abteilungsleiter und Gruppenleiter am Fraunhofer-Institut für Sichere Informationstechnologie SIT und arbeitet an Sicherheitsaspekten in intelligenten Energienetzen. Er lehrt derzeit an der Hochschule Darmstadt und dient als Vorsitzender der Arbeitsgruppe „Virtualized Platform“ innerhalb der Trusted Computing Group. Er promovierte 2020 an der Monash University in Australien und beschäftigte sich mit dem Entwurf und der formalen Verifikation von Sicherheitseigenschaften von Virtual Trusted Platforms.

**Dr. Thomas Lohre**

ist diplomierte Kaufmann und Wirtschaftsinformatiker und hat zum Thema „IT-Risikomanagement in Unternehmen“ promoviert. Etliche in seinem Artikel beschriebenen Personenzertifizierungen hat er erfolgreich absolviert. Aktuell ist er Senior Consultant bei der DATEV eG im Bereich „Strategy & Certifications“ und beschäftigt sich dort mit der Etablierung integrierter Managementsysteme sowie deren Zertifizierungen und der Erstellung Multi-Normen Security and Privacy Frameworks.

**Prof. Dr. Markus Nauroth**

ist Assistant Professor für Cyber Security am Lehrstuhl für Computer Management and Information Systems (CMIS) Department der Southern Illinois University Edwardsville, USA, sowie Professor für Wirtschaftsinformatik an der Hochschule Mainz. Er studierte Technische Informatik an der Berufsakademie Mannheim und bei der IBM Deutschland sowie Physik an der Universität Mainz und promovierte in Theoretischer Physik an der Technischen Universität München. Prof. Dr. Nauroth arbeitete mehrere Jahre als Berater für die internationale Unternehmensberatung Booz Allen & Hamilton in New York (heute PWC Strategy+) sowie im Bereich Global Business Services der IBM in London, bevor er an die Universität wechselte. Seit 2020 ist er zudem Senior Lecturer am Swiss Cyber Institut in Zürich.

**Prof. Norbert Pohlmann**

ist Informatikprofessor für Informationssicherheit und geschäftsführender Direktor des Instituts für Internet-Sicherheit – if(is) an der Westfälischen Hochschule sowie Vorstandsvorsitzender des Bundesverbands IT-Sicherheit – TeleTrust und im Vorstand des Internetverbandes – eco.

**Markus Schmall**

entwickelte bereits 1987 sein Interesse an Computersicherheit, als er begann, Antivirus-Lösungen für die AMIGA-Plattform zu entwickeln. Dieses frühe Engagement spiegelt sich in seiner späteren Doktorarbeit wider, die er unter der Leitung von Prof. Klaus Brunnstein am renommierten Virus Test Center der Universität Hamburg durchführte. Seine Dissertation mit dem Titel „Classification and Identification of Malicious Code Based on Heuristic Techniques Utilizing Meta Languages“ befasst sich mit der Klassifizierung und Identifizierung von Schadsoftware anhand heuristischer Techniken. Seit 2003 bekleidet Markus Schmall verschiedene Führungspositionen im Bereich der IT-Sicherheit, unter anderem bei der Deutschen Telekom, der Deutschen Börse und derzeit bei Covestro.

**Prof. Dr. Marko Schuba**

war mehr als zehn Jahre bei Ericsson tätig, bevor er 2010 für das Lehrgebiet Datennetze, IT-Sicherheit und IT-Forensik an die FH Aachen berufen wurde. Als aktiver Gesellschafter der Unternehmen Schuba & Höfken GbR und @-yet Industrial IT Security GmbH kennt er die aktuellen Cybersicherheitsprobleme der Industrie. Er kooperiert u. a. mit dem LKA NRW, deutschen Sicherheitsbehörden sowie Interpol.

**Dr. Martin Serror**

ist Cybersicherheitsforscher am Fraunhofer-Institut für Kommunikation, Informationsverarbeitung und Ergonomie FKIE, wo er die Forschungsgruppe „Secure Production and Energy Networks“ leitet. Ein zentraler Fokus seiner Arbeit liegt auf der Stärkung der Cybersicherheit in Kritischen Infrastrukturen, insbesondere im Energiesektor. Zuvor hat er in Informatik an der RWTH Aachen promoviert.

**Prof. Dr. Christoph Skornia**

hat Mathematik sowie Physik im Lehramt für Gymnasien studiert und nach wissenschaftlicher Arbeit am Max-Planck-Institut für Quantenoptik promoviert. Im Anschluss fokussierte er sich auf die IT-Sicherheit und war in diesem Bereich in verschiedenen Führungspositionen für Softwareunternehmen tätig. Seit Februar 2012 ist er Professor und Leiter des Labors für Informationssicherheit an der OTH Regensburg. Zudem ist er seit 2022 dort Vizepräsident für Digitalisierung und Nachhaltigkeit sowie CIO der Hochschule.

**Prof. Dr. Kristin Weber**

ist Vizepräsidentin für Digitalisierung und CIO der Technischen Hochschule Würzburg-Schweinfurt (THWS). Als Professorin an der Fakultät Informatik und Wirtschaftsinformatik forscht und lehrt sie u. a. über den Faktor Mensch in der Informationssicherheit. Zudem ist Kristin Weber Autorin, Referentin und Beraterin für die Themen Information Security Awareness, ISMS, Data Governance und Datenqualitätsmanagement. Von 2017 bis 2024 war sie Informationssicherheitsbeauftragte der THWS.

**Dr.-Ing. Marcel Winandy**

hilft Menschen, innovativ zu sein und die Ideen zu maximieren, für die sie sich begeistern. Seit 2003 arbeitet und forscht er im Bereich IT-Sicherheit, insbesondere zu Betriebssystemen und IoT. Er blickt dabei auf mehrjährige Tätigkeiten im akademischen als auch im industriellen Umfeld zurück. Seit 2018 ist er Senior Expert Cyber Security Architect bei E.ON und hilft dabei, Security by Design in die Digitalisierung der Energienetze zu bringen. Er ist diplomierter Informatiker und hat in IT-Sicherheit an der Ruhr-Universität Bochum promoviert.

Index

A

Advanced Persistent Threat 370
agile Methoden 294
agile Vorgehensmodelle 294
AMD SEV 359
Anforderungen (Softwareentwicklung) 296
Anforderungsanalyse 297
Anforderungsaufnahme 297
Anforderungserhebung 297
Anforderungsmanagement 297
Anforderungsspezifikation 297
Anforderungvalidierung 297
Angriff 32
Angriffspfade 272
Angriffsvektoren 4, 271, 375
Anlagensicherheit 63
Anonymisierung 4
Anti-Malware 22
Architektur (Softwareentwicklung) 296
ARM TrustZone 359
Audit 107
Audit (Automatisierungstechnik) 329
Auditing 35
Authentifikation 3, 17
Authentifizierung 17, 35
Authentisierung 17

Authentizität 4
Automatisierungstechnik 312
Autorisierung 17, 35
Availability 34
Awareness 11
Awareness-Maßnahmen 200, 202, 206

B

Baiting 196
Bedrohungen 32
Bedrohungen analysieren 141
Bedrohungen (Edge Computing) 348
Belohnungen 212, 213, 222
Berechtigungen 42
Bericht (Audit) 107
Betriebsgeheimnisse 78
Big Data
– Definition 154, 363
Big Data Analytics 161, 174, 178
Bildschirmsperre 187, 218, 222
Blockchain 20
Bring your own Key (BYOK) 406
Bundesamt für Sicherheit in der Informationstechnik (BSI) 76
Business-Continuity-Management-System 77

C

C5 Cloud Computing 99
 CCSP 110
 CEO Fraud 194, 197
 CER-Richtlinie 368
 Challenge-Response 35
 Chief Information Security Officer (CISO) 259
 CIA-Triade 31
 CISA 111
 CISIS12 99
 CISM 111
 CISO (Chief Information Security Officer) 53, 61
 CISO-Profil 64
 CISO, Schwerpunktbereich 64
 CISO, Verantwortlichkeiten 62
 CISSP 110
 Cloud Computing 339, 393
 Code Review 304
 Coding-Standards 300
 Common Criteria 103
 Community Cloud 396
 Compliance-Pflichten 71
 Computerbetrug 78
 Computersabotage 78
 Confidential Computing 359
 Confidentiality 33
 Container-as-a-Service (CaaS) 395
 Control-flow Integrity 44
 CRISC 111
 Cyberkriminalität 77
 Cyber-Physical Systems 29
 Cyberphysische Systeme 311
 Cyber Security Framework (NIST) 324
 Cybersicherheitstrainings 388

D

Data-in-Transit 404
 Data-in-Use 404
 Datenmenge (Volume) 154
 Datenschutz
 – Begriff 116

– betroffene Person 117, 132
 – Blickwinkel 117
 – Edge Computing 345
 – personenbezogene Daten 116
 – Privacy by Design 118, 125
 – Sicherheit der Verarbeitung 118
 – Verantwortlicher 119
 – Zertifikat 102
 Datenschutzbeauftragter 119, 133
 – Beteiligung Entwicklung 125
 Datenschutzvorfall 132
 Datenspeicher (Cloud-Computing) 406
 Datenveränderung 78
 DDoS 6, 34
 Defense in Depth 44, 331
 Denial-of-Service-Angriff 377
 DevOps 294
 DevSecOps 307
 Dienstleistungsmodelle 394
 Distributed-Denial-of-Service 34
 DSGVO 74, 115
 Dumpster Diving 193
 dynamische Analyse 306

E

Eavesdropping 193, 221
 Echtheit 35
 Echtzeitfähigkeit 315
 Edge Computing 340, 342
 Edge Computing, Grundmodell 346
 End-of-Life (EoL) 307
 Energieverbrauch (Edge Computing) 344
 Entgegenwirken (IT-Sicherheitsstrategie) 11
 Entwicklungsprozess 293
 Entwurf (Softwareentwicklung) 296
 Erkennen von Angriffen (IT-Sicherheitsstrategie) 13
 Exploit Database 323
 externe Dienstleister 260
 eXtreme Programming 304

F

Fail-Safe 46
 False Data Injection 377
 Feedback 215
 Fernmeldegeheimnis 75
 Fernwartung 327
 Firewall 19, 44
 Forensik 14
 formale Analyse 305
 Function-as-a-Service (FaaS) 395
 funktionale Sicherheit 312
 Fuzzing 306

G

Gamification 216
 Gefahr 32
 Gefährdung 32
 Geheimhaltung 33
 Geräteheterogenität 351
 Geschwindigkeit von Daten
 (Velocity) 156
 Gewohnheiten 204, 220

H

Hackerparagraph 77
 Haftung 72, 73
 Honeypot 386
 Hot Topics 253, 284
 Humans as Solution 185, 224
 Hybrid Cloud 397

I

ICS Security Kompendium (BSI) 327
 Implementierung (Softwareentwicklung) 296
 Incident Response 387
 Industrial Control System 365
 Information Security Awareness 186,
 200, 205, 207
 – Zielgruppen 206

Informationsklassifikation 188, 221
 Informationssicherheit
 – Begriff 116
 – Gefährdung 187
 – Opfer 192
 – Schutzziele 118
 informationssicherheitskonform 187,
 201
 Informationssicherheitsmanagementsystem (ISMS) 324
 Informationssicherheitsverstoß 184
 Information Technology Risk Council 53,
 58
 Infrastructure-as-a-Service (IaaS) 395
 Innentäter (ICS) 327
 Integriertes Verhaltensmodell 202, 203
 Integrität 4, 33
 Integrity 33
 Intel SGX 359
 Internet der Dinge (IoT) 262, 318, 341
 Internet of Things (IoT) 318, 372
 Intrusion Detection 44
 Intrusion Detection System 385
 IoT-Gateway 358
 ISA99 326
 ISAE 3402 97
 ISA/IEC 62443 326
 ISB 133
 ISMS 120, 126
 – ISO 27001 120
 ISO 15408 103
 ISO 27001 95
 ISO 31000 96
 isolierte Bereiche 354
 ISO/SAE 21434 326, 328
 IST-Aufnahme 269
 IT-Compliance-Standards 82
 IT-Grundschutz 76, 98
 IT-Grundschutz-Kompendium 76
 IT/OT-Konvergenz 372
 IT-Sicherheit
 – Begriff 116
 – Schutzziele 126
 – Security by Design 125

IT-Sicherheitsgesetz (ITSiG 2.0) 80, 366
 IT-Sicherheitskonzept 382
 IT-Sicherheitsrichtlinie 235
 IT-Sicherheitsstrategie 8, 233
 IT-Sicherheitsverantwortlicher 263
 – Kompetenzen 264
 IT-Sicherheitsziele 3

K

Kanban 295
 Katastrophenschutz 38
 Kerkhoffs, Auguste 40
 Kleine und mittlere Unternehmen 55
 Kompetenzen 245, 287
 Komplexität, reduzierte 355
 Konnektivität (Edge Computing) 344
 Kosten (Edge Computing) 344
 Kritische Infrastrukturen (KRITIS) 80
 Kritische Komponenten 82
 Kryptoagilität 16, 359

L

Latenz (Edge Computing) 344
 Lead Auditor (ISO 27001) 112
 Lebenszyklus 291
 Live-Migration (Edge Computing) 347
 Lock-in-Effekte 401

M

Maintenance 307
 Malicious Insider 186
 Malware 22
 Man-in-the-Middle 5
 Man-in-the-Middle-Angriff 377
 Manipulation 192, 196
 Maßnahmen 146, 265
 mehrschichtige Verteidigung 52
 Melden Sicherheitsvorfall 185, 189, 222
 Memory Safety 44, 302
 Mensch als Sicherheitsfaktor 184, 200, 207

Mikrokern 357
 Mindfulness 186
 MITRE ATT&CK for Industrial Control Systems 377
 MITRE ATT&CK Framework 298
 Modularität 355
 MS STRIDE 299
 Multifaktor-Authentifizierung 18

N

Need-to-know (Sicherheitsprinzip) 405
 NIS-2-Richtlinie 367
 Notfalleinsatz 63

O

Onlinebanking 38
 Open Source Intelligence 192
 Operational Technology 365
 OpSec 294
 Organisation 275
 Organisation der IT-Sicherheit/Informationssicherheit 241
 Organisationsstruktur (Sicherheitsorganisation) 53
 organisatorische Verankerung 259
 OWASP Threat Modeling 299

P

Passwort 187, 190, 217
 Patches 333, 383
 PCI-DSS 101
 Penetration Testing 306
 Pentest 383
 Personenzertifizierungen 109
 Phishing 188, 190, 193, 197, 199, 215, 222
 – Smishing 199
 – Spear Phishing 194
 Phishing-Simulationen 191
 Platform-as-a-Service (PaaS) 395
 Post-Quanten-Kryptografie 360
 Pretexting 193

Prinzip der geringsten Berechtigung 42
 Privacy by Design 353
 Private Cloud 396
 Privatheit 36
 Produktentwicklung 293
 Produktivität 190, 218
 Programmiersprache 302
 Programmmanagement 63
 Protokollierung 406
 Pseudonymisierung 4
 Public Cloud 396

Q

Quanten-Kryptografie 360

R

Ransomware-Angriff 262, 365
 Reaktion auf Angriffe 13
 Red Team versus Blue Team 389
 Regelung 312
 Requirements Engineering 297
 Resilience 46
 Reverse Social Engineering 195
 Richtlinien 187, 213
 Richtlinien-Framework 104
 Risiko
 – betroffene Person 132
 – Datenschutz 122
 – IT 123
 – Überprüfung 123
 – Unternehmen 122
 Risikoanalyse 120, 142
 Risikobehandlung 138
 Risikobewertung eines Cloud-Ser-
 vices 238
 Risikoeinschätzung 39
 Risikoklassen 231
 Risikomanagement 231
 Rolle des IT-Sicherheitsverantwortli-
 chen 285
 Rollen in der IT-Sicherheit 244
 Routine 51

S

Safe Arithmetic 303
 Safety 312
 Safety Integrity Level (SIL) 316
 Safety Science 185
 Salienz 204, 218
 Scareware 195
 Schulung 191, 216
 Schutzbedarf feststellen 141
 Schutzziele 31, 126
 – Integrität 130
 – Verfügbarkeit 131
 – Vertraulichkeit 128
 Schwachstellen 32, 148
 Scrum 294
 Secure Boot 357
 Security by Default 384
 Security by Design 40, 291, 351, 384
 Security Champions 213
 Security-Maturity-Audit 258
 Security Operations Center 63, 386
 Security-Prozesse 45
 Security-Stories 294
 Security-Tests 148
 Security through Obscurity 40
 SEI CERT -Coding-Standards 300
 Sensibilisierung 200
 Separation Kernel 357
 Serverless-Computing 395
 Shoulder Surfing 193
 Sicherheitsbeauftragte 54
 Sicherheitskern 356
 Sicherheitskultur 219, 222, 224
 Sicherheitslevel 330
 Sicherheitsmodell (Cloud-Compu-
 ting) 402
 Sicherheitstechnik 63
 Sicherheitsvorfall 131
 Signaturerkennung (Virenerkennung) 44
 Smart Grid 38
 Social Engineering 46, 192, 370
 – Informationsbeschaffung 192, 194,
 198

Software-as-a-Service (SaaS) 395
 Softwareeinsatz-Verfahren 236
 Sorgfaltspflichten 70
 Sprint 294
 Stand der Technik 14
 Start-up 54
 statische Codeanalyse 305
 Steuerung 312
 strafrechtliche Normen 77
 strafrechtliche Verantwortung 79
 Supervisory Control and Data
 Acquisition 365
 Supply Chain 5
 Systeme zur Angriffserkennung 385
 Systemmodellierung 297

T

Tailgating 196, 197
 Technische Richtlinien (BSI) 103
 technische und organisatorische Maß-
 nahmen 118
 Telekommunikation 75
 Telekommunikation-Telemedien-Daten-
 schutz-Gesetz (TKG) 75
 Telemediengesetz 75
 Testat 108
 Testen (Softwareentwicklung) 296
 Tests (Sourcecode) 304
 Thread Safety 303
 Threat Modeling 38
 TISAX 101
 TISP 110
 TOM 118, 126
 – Eingabekontrolle 130
 – Protokollierung 130
 – Pseudonymisierung 129
 – Transportkontrolle 128
 – Trennung nach Zwecken 126
 – Verschlüsselung 129
 – Weitergabekontrolle 129
 – Zugangskontrolle 128

– Zugriffskontrolle 128
 – Zutrittskontrolle 128
 Top-Level-Leadership 53
 Trennung von Verantwortlichkeiten 42
 Trusted Computing 21
 Trusted Execution Environment
 (TEE) 359
 Trusted Platform Module (TPM) 357
 Type Safety 302

U

Überprüfbarkeit 35
 Untersuchungsgegenstand modellie-
 ren 140
 Updates 308
 Usability 190
 USB-Sticks 189, 196, 199

V

Validierung 306
 Velocity (Geschwindigkeit von
 Daten) 156
 Verantwortlichkeiten (Cloud Compu-
 ting) 398
 Verbindlichkeit 4, 36
 Verfügbarkeit 4, 34
 Verhaltensabsicht 203, 211
 Verifikation 305
 Vermeidungsstrategie 9
 verschlüsselte Dateisysteme 405
 verschlüsselte Datenübertragung 405
 Verschlüsselung 16
 Verschlüsselung auf Applikations-
 ebene 405
 Vertraulichkeit 3
 V-Modell 293
 Volume (Datenmenge) 154
 Voraudit 106
 Vorbild 213, 216
 Vorfallsmanagement 63

Vorgehensmodells 293
Vorstand (Verantwortlichkeit) 71
Vulnerability 32
Vulnerability Scanner 306

W

Watering Hole Attack 195
Wissen 201, 203, 208, 217
Worst-Case-Szenario 52

Z

Zero-Day-Exploit 372
Zero Trust 19
Zertifikat 108
Zertifizierung (Vorgehen) 105
Zone 332
Zugangskontrolle (Cloud-Computing) 403
Zugriffskontrolle 43, 355

IT-SICHERHEIT //

- Kompakte Orientierungshilfe für CISOs, Sicherheitsverantwortliche in Unternehmen, Projektleitende, IT-Berater:innen
- Best Practices für die Umsetzung im Unternehmen
- Mit CISO-Erfahrungsberichten
- **Neu in der 2. Auflage:** Sicherheitstesten, Cybersicherheit für Kritische Infrastrukturen (KRITIS), Der Faktor Mensch

Für Unternehmen ist es existenziell, die Sicherheit ihrer Informationen, Systeme und Produkte zu gewährleisten. Dies trifft heute mehr denn je zu, denn mit zunehmender Vernetzung wächst auch die Angriffsfläche: Jedes vernetzte Gerät ist ein potenzielles Einfallstor für Gefährdungen. Doch wie können Sie Ihr Unternehmen vor diesen Gefährdungen schützen und Sicherheit gewährleisten?

Die Antwort auf diese Frage – und viele hilfreiche Impulse und Best Practices – bietet Ihnen dieser Praxisratgeber zum Thema IT-Sicherheit. Es werden alle für Entscheider:innen relevanten Aspekte der IT-Sicherheit beschrieben. Das für weiterführende Entscheidungen erforderliche Know-how wird zielgerichtet vermittelt. Das Buch dient als Leitfaden auf Ihrem Weg zur konsequenten und gleichzeitig effizienten Sicherstellung und Umsetzung von IT-Sicherheit im Unternehmen.

An diesem Fachbuch haben mitgewirkt:

- | | |
|---------------------|---------------------|
| • Daniel Angermeier | • Thomas Lohre |
| • Jürgen Großmann | • Markus Nauroth |
| • Hans Höfken | • Norbert Pohlmann |
| • Thomas Jansen | • Markus Schmall |
| • Florian Jörgens | • Marko Schuba |
| • Stefan Karg | • Martin Serror |
| • Nicolai Kuntze | • Christoph Skornia |
| • Ümit Kuşdoğan | • Kristin Weber |
| • Hagen Lauer | • Marcel Winandy |

Die beiden Herausgeber **Michael LANG** und **Hans LÖHR** sind Professoren für Informatik und Wirtschaftsinformatik an der Technischen Hochschule Nürnberg. Ihre Forschungs- und Lehrschwerpunkte liegen u. a. in den Bereichen IT-Sicherheit und IT-Management.

AUS DEM INHALT //

- Ziele von IT-Sicherheit (Vertraulichkeit, Integrität, Verfügbarkeit)
- Grundlegende Maßnahmen (Berechtigungen zuteilen, Ausfallplanung, Tests etc.)
- Absicherung der IT-Infrastruktur im Unternehmen
- IT-Sicherheit in der Cloud
- Systematische Umsetzung von Bedrohungs- und Risikoanalysen
- Sichere Produktentwicklung
- Sicherheit in Produktionsnetzen und -anlagen
- Rechtliche Rahmenbedingungen
- Organisation des IT-Sicherheitsmanagements im Unternehmen
- Sicherheitsstandards und -zertifizierungen
- Relevante Wechselwirkungen zwischen Datenschutz und IT-Sicherheit

HANSER

